CIS Alibaba Cloud Linux 3 Benchmark

v2.0.0 - 08-27-2025

Terms of Use

Please see the below link for our current terms of use:

https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/

For information on referencing and/or citing CIS Benchmarks in 3rd party documentation (including using portions of Benchmark Recommendations) please contact CIS Legal (legalnotices@cisecurity.org) and request guidance on copyright usage.

NOTE: It is ***NEVER*** acceptable to host a CIS Benchmark in ***ANY*** format (PDF, etc.) on a 3rd party (non-CIS owned) site.

Table of Contents

Terms of Use 1

Table of Contents 2

Overview 11

Important Usage Information 11
- Key Stakeholders 11
- Apply the Correct Version of a Benchmark 12
- Exceptions 12
- Remediation 13
- Summary 13

Target Technology Details 14

Intended Audience 14

Consensus Guidance 15

Typographical Conventions 16

Recommendation Definitions 17

Title 17

Assessment Status 17
- Automated 17
- Manual 17

Profile 17

Description 17

Rationale Statement 17

Impact Statement 18

Audit Procedure 18

Remediation Procedure 18

Default Value 18

References 18

CIS Critical Security Controls® (CIS Controls®) 18

Additional Information 18

Profile Definitions 19

Acknowledgements 20

1 Initial Setup 21
- 1.1 Filesystem 21
  - 1.1.1 Configure Filesystem Kernel Modules 22
    - 1.1.1.1 Ensure cramfs kernel module is not available (Automated) 23
    - 1.1.1.2 Ensure freevxfs kernel module is not available (Automated) 27
    - 1.1.1.3 Ensure hfs kernel module is not available (Automated) 30
    - 1.1.1.4 Ensure hfsplus kernel module is not available (Automated) 33

1.1.1.5 Ensure jffs2 kernel module is not available (Automated) 36
1.1.1.6 Ensure overlay kernel module is not available (Automated) 39
1.1.1.7 Ensure squashfs kernel module is not available (Automated) 42
1.1.1.8 Ensure udf kernel module is not available (Automated) 45
1.1.1.9 Ensure firewire-core kernel module is not available (Automated) 48
1.1.1.10 Ensure usb-storage kernel module is not available (Automated) 52
1.1.1.11 Ensure unused filesystems kernel modules are not available (Manual) 56
1.1.2 Configure Filesystem Partitions 63
1.1.2.1 Configure /tmp 64
1.1.2.1.1 Ensure /tmp is tmpfs or a separate partition (Automated) 65
1.1.2.1.2 Ensure nodev option set on /tmp partition (Automated) 69
1.1.2.1.3 Ensure nosuid option set on /tmp partition (Automated) 71
1.1.2.1.4 Ensure noexec option set on /tmp partition (Automated) 73
1.1.2.2 Configure /dev/shm 75
1.1.2.2.1 Ensure /dev/shm is tmpfs (Automated) 76
1.1.2.2.2 Ensure nodev option set on /dev/shm partition (Automated) 78
1.1.2.2.3 Ensure nosuid option set on /dev/shm partition (Automated) 80
1.1.2.2.4 Ensure noexec option set on /dev/shm partition (Automated) 82
1.1.2.3 Configure /home 84
1.1.2.3.1 Ensure separate partition exists for /home (Automated) 85
1.1.2.3.2 Ensure nodev option set on /home partition (Automated) 87
1.1.2.3.3 Ensure nosuid option set on /home partition (Automated) 89
1.1.2.4 Configure /var 91
1.1.2.4.1 Ensure separate partition exists for /var (Automated) 92
1.1.2.4.2 Ensure nodev option set on /var partition (Automated) 94
1.1.2.4.3 Ensure nosuid option set on /var partition (Automated) 96
1.1.2.5 Configure /var/tmp 98
1.1.2.5.1 Ensure separate partition exists for /var/tmp (Automated) 99
1.1.2.5.2 Ensure nodev option set on /var/tmp partition (Automated) 101
1.1.2.5.3 Ensure nosuid option set on /var/tmp partition (Automated) 103
1.1.2.5.4 Ensure noexec option set on /var/tmp partition (Automated) 105
1.1.2.6 Configure /var/log 107
1.1.2.6.1 Ensure separate partition exists for /var/log (Automated) 108
1.1.2.6.2 Ensure nodev option set on /var/log partition (Automated) 110
1.1.2.6.3 Ensure nosuid option set on /var/log partition (Automated) 112
1.1.2.6.4 Ensure noexec option set on /var/log partition (Automated) 114
1.1.2.7 Configure /var/log/audit 116
1.1.2.7.1 Ensure separate partition exists for /var/log/audit (Automated) 117
1.1.2.7.2 Ensure nodev option set on /var/log/audit partition (Automated) 119
1.1.2.7.3 Ensure nosuid option set on /var/log/audit partition (Automated) 121
1.1.2.7.4 Ensure noexec option set on /var/log/audit partition (Automated) 123
1.2 Package Management 125
1.2.1 Configure Package Repositories 126
1.2.1.1 Ensure GPG keys are configured (Manual) 127
1.2.1.2 Ensure gpgcheck is configured (Automated) 130
1.2.1.3 Ensure repo_gpgcheck is globally activated (Manual) 132
1.2.1.4 Ensure package manager repositories are configured (Manual) 134
1.2.1.5 Ensure weak dependencies are configured (Automated) 136
1.2.2 Configure Package Updates 138
1.2.2.1 Ensure updates, patches, and additional security software are installed (Manual) 139
1.3 Mandatory Access Control 141
1.3.1 Configure SELinux 142
1.3.1.1 Ensure SELinux is installed (Automated) 144
1.3.1.2 Ensure SELinux policy is configured (Automated) 145
1.3.1.3 Ensure the SELinux mode is not disabled (Automated) 147
1.3.1.4 Ensure no unconfined services exist (Manual) 150

1.3.1.5 Ensure the MCS Translation Service (mcstrans) is not installed (Automated) 153
1.3.1.6 Ensure SETroubleshoot is not installed (Automated) 155
1.4 Configure Bootloader 157
1.4.1 Ensure access to bootloader config is configured (Automated) 158
1.5 Configure Additional Process Hardening 162
1.5.1 Ensure core file size is configured (Automated) 163
1.5.2 Ensure fs.protected_hardlinks is configured (Automated) 165
1.5.3 Ensure fs.protected_symlinks is configured (Automated) 170
1.5.4 Ensure fs.suid_dumpable is configured (Automated) 175
1.5.5 Ensure kernel.dmesg_restrict is configured (Automated) 180
1.5.6 Ensure kernel.kptr_restrict is configured (Automated) 185
1.5.7 Ensure kernel.randomize_va_space is configured (Automated) 190
1.5.8 Ensure systemd-coredump ProcessSizeMax is configured (Automated) 195
1.5.9 Ensure systemd-coredump Storage is configured (Automated) 200
1.6 Configure system wide crypto policy 204
1.6.1 Ensure system wide crypto policy is not set to legacy (Automated) 206
1.6.2 Ensure system wide crypto policy disables sha1 hash and signature support (Automated) 210
1.6.3 Ensure system wide crypto policy macs are configured (Automated) 213
1.6.4 Ensure system wide crypto policy disables cbc for ssh (Automated) 216
1.6.5 Ensure system wide crypto policy disables chacha20-poly1305 for ssh (Manual) 220
1.6.6 Ensure system wide crypto policy disables EtM for ssh (Manual) 224
1.7 Configure Command Line Warning Banners 227
1.7.1 Ensure /etc/motd is configured (Automated) 228
1.7.2 Ensure /etc/issue is configured (Automated) 232
1.7.3 Ensure /etc/issue.net is configured (Automated) 234
1.7.4 Ensure access to /etc/motd is configured (Automated) 236
1.7.5 Ensure access to /etc/issue is configured (Automated) 238
1.7.6 Ensure access to /etc/issue.net is configured (Automated) 240
1.8 Configure GNOME Display Manager 242
1.8.1 Ensure GDM login banner is configured (Automated) 243
1.8.2 Ensure GDM disable-user-list is configured (Automated) 248
1.8.3 Ensure GDM screen lock is configured (Automated) 252
1.8.4 Ensure GDM automount is configured (Automated) 258
1.8.5 Ensure GDM autorun-never is configured (Automated) 263
1.8.6 Ensure XDMCP is not enabled (Automated) 266
1.8.7 Ensure Xwayland is configured (Automated) 268

2 Services 270
2.1 Configure Server Services 271
2.1.1 Ensure autofs services are not in use (Automated) 272
2.1.2 Ensure avahi daemon services are not in use (Automated) 275
2.1.3 Ensure cockpit web services are not in use (Automated) 278
2.1.4 Ensure dhcp server services are not in use (Automated) 281
2.1.5 Ensure dns server services are not in use (Automated) 284
2.1.6 Ensure dnsmasq services are not in use (Automated) 286
2.1.7 Ensure ftp server services are not in use (Automated) 289
2.1.8 Ensure message access server services are not in use (Automated) 292
2.1.9 Ensure network file system services are not in use (Automated) 295
2.1.10 Ensure nis server services are not in use (Automated) 298
2.1.11 Ensure print server services are not in use (Automated) 301
2.1.12 Ensure rpcbind services are not in use (Automated) 304
2.1.13 Ensure rsync services are not in use (Automated) 307
2.1.14 Ensure samba file server services are not in use (Automated) 310
2.1.15 Ensure snmp services are not in use (Automated) 313
2.1.16 Ensure telnet server services are not in use (Automated) 316

2.1.17 Ensure tftp server services are not in use (Automated) 319
2.1.18 Ensure web proxy server services are not in use (Automated) 322
2.1.19 Ensure web server services are not in use (Automated) 325
2.1.20 Ensure xinetd services are not in use (Automated) 329
2.1.21 Ensure GNOME Display Manager is not installed (Automated) 332
2.1.22 Ensure X window server services are not in use (Automated) 334
2.1.23 Ensure mail transfer agents are configured for local-only mode (Automated) 336
2.1.24 Ensure only approved services are listening on a network interface (Manual) 339
2.2 Configure Client Services 342
2.2.1 Ensure ftp client is not installed (Automated) 343
2.2.2 Ensure ldap client is not installed (Automated) 345
2.2.3 Ensure nis client is not installed (Automated) 347
2.2.4 Ensure telnet client is not installed (Automated) 349
2.2.5 Ensure tftp client is not installed (Automated) 351
2.3 Configure Time Synchronization 353
2.3.1 Ensure time synchronization is in use (Automated) 354
2.3.2 Ensure chrony is configured (Automated) 356
2.3.3 Ensure chrony is not run as the root user (Automated) 360
2.4 Job Schedulers 361
2.4.1 Configure cron 362
2.4.1.1 Ensure cron daemon is enabled and active (Automated) 363
2.4.1.2 Ensure access to /etc/crontab is configured (Automated) 365
2.4.1.3 Ensure access to /etc/cron.hourly is configured (Automated) 367
2.4.1.4 Ensure access to /etc/cron.daily is configured (Automated) 369
2.4.1.5 Ensure access to /etc/cron.weekly is configured (Automated) 371
2.4.1.6 Ensure access to /etc/cron.monthly is configured (Automated) 373
2.4.1.7 Ensure access to /etc/cron.yearly is configured (Automated) 375
2.4.1.8 Ensure access to /etc/cron.d is configured (Automated) 376
2.4.1.9 Ensure access to crontab is configured (Automated) 378
2.4.2 Configure at 382
2.4.2.1 Ensure access to at is configured (Automated) 383
3 Network 386
3.1 Configure Network Devices 387
3.1.1 Ensure IPv6 status is identified (Manual) 388
3.1.2 Ensure wireless interfaces are not available (Automated) 391
3.1.3 Ensure bluetooth services are not in use (Automated) 395
3.2 Configure Network Kernel Modules 398
3.2.1 Ensure atm kernel module is not available (Automated) 399
3.2.2 Ensure can kernel module is not available (Automated) 403
3.2.3 Ensure dccp kernel module is not available (Automated) 406
3.2.4 Ensure rds kernel module is not available (Automated) 409
3.2.5 Ensure sctp kernel module is not available (Automated) 412
3.2.6 Ensure tipc kernel module is not available (Automated) 416
3.3 Configure Network Kernel Parameters 419
3.3.1 Configure IPv4 parameters 420
3.3.1.1 Ensure net.ipv4.ip_forward is configured (Automated) 421
3.3.1.2 Ensure net.ipv4.conf.all.forwarding is configured (Automated) 426
3.3.1.3 Ensure net.ipv4.conf.default.forwarding is configured (Automated) 431
3.3.1.4 Ensure net.ipv4.conf.all.send_redirects is configured (Automated) 436
3.3.1.5 Ensure net.ipv4.conf.default.send_redirects is configured (Automated) 441
3.3.1.6 Ensure net.ipv4.icmp_ignore_bogus_error_responses is configured (Automated) 446
3.3.1.7 Ensure net.ipv4.icmp_echo_ignore_broadcasts is configured (Automated) 451
3.3.1.8 Ensure net.ipv4.conf.all.accept_redirects is configured (Automated) 456
3.3.1.9 Ensure net.ipv4.conf.default.accept_redirects is configured (Automated) 461
3.3.1.10 Ensure net.ipv4.conf.all.secure_redirects is configured (Automated) 466

3.3.1.11 Ensure net.ipv4.conf.default.secure_redirects is configured (Automated) 471
3.3.1.12 Ensure net.ipv4.conf.all.rp_filter is configured (Automated) 476
3.3.1.13 Ensure net.ipv4.conf.default.rp_filter is configured (Automated) 481
3.3.1.14 Ensure net.ipv4.conf.all.accept_source_route is configured (Automated) 486
3.3.1.15 Ensure net.ipv4.conf.default.accept_source_route is configured (Automated) 491
3.3.1.16 Ensure net.ipv4.conf.all.log_martians is configured (Automated) 496
3.3.1.17 Ensure net.ipv4.conf.default.log_martians is configured (Automated) 501
3.3.1.18 Ensure net.ipv4.tcp_syncookies is configured (Automated) 506
3.3.2 Configure IPv6 parameters 511
3.3.2.1 Ensure net.ipv6.conf.all.forwarding is configured (Automated) 512
3.3.2.2 Ensure net.ipv6.conf.default.forwarding is configured (Automated) 517
3.3.2.3 Ensure net.ipv6.conf.all.accept_redirects is configured (Automated) 522
3.3.2.4 Ensure net.ipv6.conf.default.accept_redirects is configured (Automated) 527
3.3.2.5 Ensure net.ipv6.conf.all.accept_source_route is configured (Automated) 532
3.3.2.6 Ensure net.ipv6.conf.default.accept_source_route is configured (Automated) 537
3.3.2.7 Ensure net.ipv6.conf.all.accept_ra is configured (Automated) 542
3.3.2.8 Ensure net.ipv6.conf.default.accept_ra is configured (Automated) 547

4 Host Based Firewall 552
4.1 Configure firewalld 553
4.1.1 Ensure firewalld is installed (Automated) 555
4.1.2 Ensure firewalld backend is configured (Automated) 557
4.1.3 Ensure firewalld.service is configured (Automated) 559
4.1.4 Ensure firewalld active zone target is configured (Automated) 560
4.1.5 Ensure firewalld loopback traffic is configured (Manual) 563
4.1.6 Ensure firewalld loopback source address traffic is configured (Manual) 565
4.1.7 Ensure firewalld services and ports are configured (Manual) 568

5 Access Control 570
5.1 Configure SSH Server 571
5.1.1 Ensure sshd crypto_policy is not set (Automated) 573
5.1.2 Ensure access to /etc/ssh/sshd_config is configured (Automated) 575
5.1.3 Ensure access to /etc/sysconfig/sshd is configured (Automated) 578
5.1.4 Ensure access to SSH private host key files is configured (Automated) 580
5.1.5 Ensure access to SSH public host key files is configured (Automated) 584
5.1.6 Ensure sshd access is configured (Automated) 588
5.1.7 Ensure sshd Banner is configured (Automated) 591
5.1.8 Ensure sshd Ciphers are configured (Automated) 594
5.1.9 Ensure sshd ClientAliveInterval and ClientAliveCountMax are configured (Automated) 598
5.1.10 Ensure sshd DisableForwarding is enabled (Automated) 601
5.1.11 Ensure sshd GSSAPIAuthentication is disabled (Automated) 603
5.1.12 Ensure sshd HostbasedAuthentication is disabled (Automated) 606
5.1.13 Ensure sshd IgnoreRhosts is enabled (Automated) 609
5.1.14 Ensure sshd KexAlgorithms is configured (Automated) 611
5.1.15 Ensure sshd LoginGraceTime is configured (Automated) 615
5.1.16 Ensure sshd LogLevel is configured (Automated) 617
5.1.17 Ensure sshd MACs are configured (Automated) 620
5.1.18 Ensure sshd MaxAuthTries is configured (Automated) 625
5.1.19 Ensure sshd MaxSessions is configured (Automated) 628
5.1.20 Ensure sshd MaxStartups is configured (Automated) 630
5.1.21 Ensure sshd PermitEmptyPasswords is disabled (Automated) 632
5.1.22 Ensure sshd PermitRootLogin is disabled (Automated) 635
5.1.23 Ensure sshd PermitUserEnvironment is disabled (Automated) 637
5.1.24 Ensure sshd UsePAM is enabled (Automated) 639
5.2 Configure privilege escalation 641
5.2.1 Ensure sudo is installed (Automated) 642

5.2.2 Ensure sudo commands use pty (Automated) 644
5.2.3 Ensure sudo log file exists (Automated) 646
5.2.4 Ensure users must provide password for escalation (Automated) 649
5.2.5 Ensure re-authentication for privilege escalation is not disabled globally (Automated) 651
5.2.6 Ensure sudo timestamp_timeout is configured (Automated) 653
5.2.7 Ensure access to the su command is restricted (Automated) 655
5.3 Pluggable Authentication Modules 657
5.3.1 Configure PAM software packages 658
5.3.1.1 Ensure latest version of pam is installed (Automated) 659
5.3.1.2 Ensure latest version of authselect is installed (Automated) 660
5.3.2 Configure authselect 662
5.3.2.1 Ensure active authselect profile includes pam modules (Automated) 664
5.3.2.2 Ensure pam_faillock module is enabled (Automated) 669
5.3.2.3 Ensure pam_pwquality module is enabled (Automated) 672
5.3.2.4 Ensure pam_pwhistory module is enabled (Automated) 675
5.3.2.5 Ensure pam_unix module is enabled (Automated) 678
5.3.3 Configure PAM Arguments 680
5.3.3.1 Configure pam_faillock module 681
5.3.3.1.1 Ensure password failed attempts lockout is configured (Automated) 683
5.3.3.1.2 Ensure password unlock time is configured (Automated) 685
5.3.3.1.3 Ensure password failed attempts lockout includes root account (Automated) 687
5.3.3.2 Configure pam_pwquality module 691
5.3.3.2.1 Ensure password number of changed characters is configured (Automated) 692
5.3.3.2.2 Ensure password length is configured (Automated) 695
5.3.3.2.3 Ensure password complexity is configured (Manual) 698
5.3.3.2.4 Ensure password same consecutive characters is configured (Automated) 703
5.3.3.2.5 Ensure password maximum sequential characters is configured (Automated) 707
5.3.3.2.6 Ensure password dictionary check is enabled (Automated) 710
5.3.3.2.7 Ensure password quality is enforced for the root user (Automated) 712
5.3.3.3 Configure pam_pwhistory module 715
5.3.3.3.1 Ensure password history remember is configured (Automated) 717
5.3.3.3.2 Ensure password history is enforced for the root user (Automated) 719
5.3.3.3.3 Ensure pam_pwhistory includes use_authtok (Automated) 721
5.3.3.4 Configure pam_unix module 724
5.3.3.4.1 Ensure pam_unix does not include nullok (Automated) 725
5.3.3.4.2 Ensure pam_unix does not include remember (Automated) 728
5.3.3.4.3 Ensure pam_unix includes a strong password hashing algorithm (Automated) 731
5.3.3.4.4 Ensure pam_unix includes use_authtok (Automated) 735
5.4 User Accounts and Environment 738
5.4.1 Configure shadow password suite parameters 739
5.4.1.1 Ensure password expiration is configured (Automated) 740
5.4.1.2 Ensure minimum password days is configured (Manual) 744
5.4.1.3 Ensure password expiration warning days is configured (Automated) 747
5.4.1.4 Ensure strong password hashing algorithm is configured (Automated) 749
5.4.1.5 Ensure inactive password lock is configured (Automated) 752
5.4.1.6 Ensure all users last password change date is in the past (Automated) 754
5.4.2 Configure root and system accounts and environment 756
5.4.2.1 Ensure root is the only UID 0 account (Automated) 757
5.4.2.2 Ensure root is the only GID 0 account (Automated) 759
5.4.2.3 Ensure group root is the only GID 0 group (Automated) 761
5.4.2.4 Ensure root account access is controlled (Automated) 763
5.4.2.5 Ensure root path integrity (Automated) 765
5.4.2.6 Ensure root user umask is configured (Automated) 768
5.4.2.7 Ensure system accounts do not have a valid login shell (Automated) 771
5.4.2.8 Ensure accounts without a valid login shell are locked (Automated) 773
5.4.3 Configure user default environment 775

5.4.3.1 Ensure nologin is not listed in /etc/shells (Automated) 776
5.4.3.2 Ensure default user shell timeout is configured (Automated) 778
5.4.3.3 Ensure default user umask is configured (Automated) 782
6 Logging and Auditing 787
6.1 Configure Integrity Checking 788
6.1.1 Ensure AIDE is installed (Automated) 789
6.1.2 Ensure filesystem integrity is regularly checked (Automated) 791
6.1.3 Ensure cryptographic mechanisms are used to protect the integrity of audit tools (Automated) 794
6.2 System Logging 799
6.2.1 Configure journald 800
6.2.1.1 Configure systemd-journald service 801
6.2.1.1.1 Ensure journald service is active (Automated) 802
6.2.1.1.2 Ensure journald log file access is configured (Manual) 804
6.2.1.1.3 Ensure journald log file rotation is configured (Manual) 807
6.2.1.1.4 Ensure journald ForwardToSyslog is disabled (Automated) 809
6.2.1.1.5 Ensure journald Storage is configured (Automated) 813
6.2.1.1.6 Ensure journald Compress is configured (Automated) 817
6.2.1.2 Configure systemd-journal-remote 821
6.2.1.2.1 Ensure systemd-journal-remote is installed (Automated) 822
6.2.1.2.2 Ensure systemd-journal-remote authentication is configured (Manual) 824
6.2.1.2.3 Ensure systemd-journal-upload is enabled and active (Automated) 826
6.2.1.2.4 Ensure systemd-journal-remote service is not in use (Automated) 828
6.2.2 Configure rsyslog 830
6.2.2.1 Ensure rsyslog is installed (Automated) 831
6.2.2.2 Ensure rsyslog service is enabled and active (Automated) 833
6.2.2.3 Ensure journald is configured to send logs to rsyslog (Automated) 835
6.2.2.4 Ensure rsyslog log file creation mode is configured (Automated) 839
6.2.2.5 Ensure rsyslog logging is configured (Manual) 841
6.2.2.6 Ensure rsyslog is configured to send logs to a remote log host (Manual) 843
6.2.2.7 Ensure rsyslog is not configured to receive logs from a remote client (Automated) 845
6.2.2.8 Ensure logrotate is configured (Manual) 847
6.2.3 Configure Logfiles 849
6.2.3.1 Ensure access to all logfiles has been configured (Automated) 850
6.3 System Auditing 856
6.3.1 Configure auditd Service 858
6.3.1.1 Ensure auditd packages are installed (Automated) 859
6.3.1.2 Ensure auditing for processes that start prior to auditd is enabled (Automated) 861
6.3.1.3 Ensure audit_backlog_limit is configured (Automated) 864
6.3.1.4 Ensure auditd service is enabled and active (Automated) 867
6.3.2 Configure Data Retention 869
6.3.2.1 Ensure audit log storage size is configured (Automated) 870
6.3.2.2 Ensure audit logs are not automatically deleted (Automated) 872
6.3.2.3 Ensure system is disabled when audit logs are full (Automated) 874
6.3.2.4 Ensure system warns when audit logs are low on space (Automated) 877
6.3.3 Configure auditd Rules 880
6.3.3.1 Ensure changes to system administration scope (sudoers) is collected (Automated) 881
6.3.3.2 Ensure actions as another user are always logged (Automated) 884
6.3.3.3 Ensure events that modify the sudo log file are collected (Automated) 888
6.3.3.4 Ensure events that modify date and time information are collected (Automated) 892
6.3.3.5 Ensure events that modify the system's network environment are collected (Automated) 896
6.3.3.6 Ensure use of privileged commands are collected (Automated) 901
6.3.3.7 Ensure unsuccessful file access attempts are collected (Automated) 905
6.3.3.8 Ensure events that modify user/group information are collected (Automated) 909

6.3.3.9 Ensure discretionary access control permission modification events are collected (Automated) 913
6.3.3.10 Ensure successful file system mounts are collected (Automated) 918
6.3.3.11 Ensure session initiation information is collected (Automated) 922
6.3.3.12 Ensure login and logout events are collected (Automated) 926
6.3.3.13 Ensure file deletion events by users are collected (Automated) 929
6.3.3.14 Ensure events that modify the system's Mandatory Access Controls are collected (Automated) 933
6.3.3.15 Ensure successful and unsuccessful attempts to use the chcon command are collected (Automated) 936
6.3.3.16 Ensure successful and unsuccessful attempts to use the setfacl command are collected (Automated) 940
6.3.3.17 Ensure successful and unsuccessful attempts to use the chacl command are collected (Automated) 944
6.3.3.18 Ensure successful and unsuccessful attempts to use the usermod command are collected (Automated) 948
6.3.3.19 Ensure kernel module loading unloading and modification is collected (Automated) 952
6.3.3.20 Ensure the audit configuration is loaded regardless of errors (Automated) 957
6.3.3.21 Ensure the audit configuration is immutable (Automated) 959
6.3.3.22 Ensure the running and on disk configuration is the same (Manual) 961
6.3.4 Configure auditd File Access 963
6.3.4.1 Ensure the audit log file directory mode is configured (Automated) 964
6.3.4.2 Ensure audit log files mode is configured (Automated) 967
6.3.4.3 Ensure audit log files owner is configured (Automated) 970
6.3.4.4 Ensure audit log files group owner is configured (Automated) 973
6.3.4.5 Ensure audit configuration files mode is configured (Automated) 976
6.3.4.6 Ensure audit configuration files owner is configured (Automated) 978
6.3.4.7 Ensure audit configuration files group owner is configured (Automated) 980
6.3.4.8 Ensure audit tools mode is configured (Automated) 982
6.3.4.9 Ensure audit tools owner is configured (Automated) 984
6.3.4.10 Ensure audit tools group owner is configured (Automated) 985

7 System Maintenance 987
7.1 Configure system file and directory access 988
7.1.1 Ensure access to /etc/passwd is configured (Automated) 989
7.1.2 Ensure access to /etc/passwd- is configured (Automated) 991
7.1.3 Ensure access to /etc/group is configured (Automated) 993
7.1.4 Ensure access to /etc/group- is configured (Automated) 995
7.1.5 Ensure access to /etc/shadow is configured (Automated) 997
7.1.6 Ensure access to /etc/shadow- is configured (Automated) 999
7.1.7 Ensure access to /etc/gshadow is configured (Automated) 1001
7.1.8 Ensure access to /etc/gshadow- is configured (Automated) 1003
7.1.9 Ensure access to /etc/shells is configured (Automated) 1005
7.1.10 Ensure access to /etc/security/opasswd is configured (Automated) 1007
7.1.11 Ensure world writable files and directories are secured (Automated) 1009
7.1.12 Ensure no files or directories without an owner and a group exist (Automated) 1013
7.1.13 Ensure SUID and SGID files are reviewed (Manual) 1016
7.2 Local User and Group Settings 1019
7.2.1 Ensure accounts in /etc/passwd use shadowed passwords (Automated) 1020
7.2.2 Ensure /etc/shadow password fields are not empty (Automated) 1023
7.2.3 Ensure all groups in /etc/passwd exist in /etc/group (Automated) 1025
7.2.4 Ensure no duplicate UIDs exist (Automated) 1027
7.2.5 Ensure no duplicate GIDs exist (Automated) 1029
7.2.6 Ensure no duplicate user names exist (Automated) 1031
7.2.7 Ensure no duplicate group names exist (Automated) 1033

7.2.8 Ensure local interactive user home directories are configured (Automated) 1035
7.2.9 Ensure local interactive user dot files access is configured (Automated) 1040
Appendix: Summary Table 1045
Appendix: CIS Controls v7 IG 1 Mapped Recommendations 1068
Appendix: CIS Controls v7 IG 2 Mapped Recommendations 1074
Appendix: CIS Controls v7 IG 3 Mapped Recommendations 1085
Appendix: CIS Controls v7 Unmapped Recommendations 1096
Appendix: CIS Controls v8 IG 1 Mapped Recommendations 1097
Appendix: CIS Controls v8 IG 2 Mapped Recommendations 1104
Appendix: CIS Controls v8 IG 3 Mapped Recommendations 1115
Appendix: CIS Controls v8 Unmapped Recommendations 1126
Appendix: Change History 1127

Overview

All CIS Benchmarks™ (Benchmarks) focus on technical configuration settings used to maintain and/or increase the security of the addressed technology, and they should be used in **conjunction** with other essential cyber hygiene tasks like:

- Monitoring the base operating system and applications for vulnerabilities and quickly updating with the latest security patches.
- End-point protection (Antivirus software, Endpoint Detection and Response (EDR), etc.).
- Logging and monitoring user and system activity.

In the end, the Benchmarks are designed to be a key **component** of a comprehensive cybersecurity program.

Important Usage Information

All Benchmarks are available free for non-commercial use from the CIS Website. They can be used to manually assess and remediate systems and applications. In lieu of manual assessment and remediation, there are several tools available to assist with assessment:

- CIS Configuration Assessment Tool (CIS-CAT® Pro Assessor)
- CIS Benchmarks™ Certified 3rd Party Tooling

These tools make the hardening process much more scalable for large numbers of systems and applications.

NOTE: Some tooling focuses only on the Benchmark Recommendations that can be fully automated (skipping ones marked **Manual**). It is important that ***ALL*** Recommendations (**Automated** and **Manual**) be addressed since all are important for properly securing systems and are typically in scope for audits.

Key Stakeholders

Cybersecurity is a collaborative effort, and cross functional cooperation is imperative within an organization to discuss, test, and deploy Benchmarks in an effective and efficient way. The Benchmarks are developed to be best practice configuration guidelines applicable to a wide range of use cases. In some organizations, exceptions to specific Recommendations will be needed, and this team should work to prioritize the problematic Recommendations based on several factors like risk, time, cost, and labor. These exceptions should be properly categorized and documented for auditing purposes.

Apply the Correct Version of a Benchmark

Benchmarks are developed and tested for a specific set of products and versions and applying an incorrect Benchmark to a system can cause the resulting pass/fail score to be incorrect. This is due to the assessment of settings that do not apply to the target systems. To assure the correct Benchmark is being assessed:

- **Deploy the Benchmark applicable to the way settings are managed in the environment:** An example of this is the Microsoft Windows family of Benchmarks, which have separate Benchmarks for Group Policy, Intune, and Stand-alone systems based upon how system management is deployed. Applying the wrong Benchmark in this case will give invalid results.

- **Use the most recent version of a Benchmark**: This is true for all Benchmarks, but especially true for cloud technologies. Cloud technologies change frequently and using an older version of a Benchmark may have invalid methods for auditing and remediation.

Exceptions

The guidance items in the Benchmarks are called recommendations and not requirements, and exceptions to some of them are expected and acceptable. The Benchmarks strive to be a secure baseline, or starting point, for a specific technology, with known issues identified during Benchmark development are documented in the Impact section of each Recommendation. In addition, organizational, system specific requirements, or local site policy may require changes as well, or an exception to a Recommendation or group of Recommendations (e.g. A Benchmark could Recommend that a Web server not be installed on the system, but if a system's primary purpose is to function as a Webserver, there should be a documented exception to this Recommendation for that specific server).

In the end, exceptions to some Benchmark Recommendations are common and acceptable, and should be handled as follows:

- The reasons for the exception should be reviewed cross-functionally and be well documented for audit purposes.
- A plan should be developed for mitigating, or eliminating, the exception in the future, if applicable.
- If the organization decides to accept the risk of this exception (not work toward mitigation or elimination), this should be documented for audit purposes.

It is the responsibility of the organization to determine their overall security policy, and which settings are applicable to their unique needs based on the overall risk profile for the organization.

Remediation

CIS has developed Build Kits for many technologies to assist in the automation of hardening systems. Build Kits are designed to correspond to Benchmark's "Remediation" section, which provides the manual remediation steps necessary to make that Recommendation compliant to the Benchmark.

When remediating systems (changing configuration settings on deployed systems as per the Benchmark's Recommendations), please approach this with caution and test thoroughly.

The following is a reasonable remediation approach to follow:

- CIS Build Kits, or internally developed remediation methods should never be applied to production systems without proper testing.
- Proper testing consists of the following:
  - Understand the configuration (including installed applications) of the targeted systems. Various parts of the organization may need different configurations (e.g., software developers vs standard office workers).
  - Read the Impact section of the given Recommendation to help determine if there might be an issue with the targeted systems.
  - Test the configuration changes with representative lab system(s). If issues arise during testing, they can be resolved prior to deploying to any production systems.
  - When testing is complete, initially deploy to a small sub-set of production systems and monitor closely for issues. If there are issues, they can be resolved prior to deploying more broadly.
  - When the initial deployment above is completes successfully, iteratively deploy to additional systems and monitor closely for issues. Repeat this process until the full deployment is complete.

Summary

Using the Benchmarks Certified tools, working as a team with key stakeholders, being selective with exceptions, and being careful with remediation deployment, it is possible to harden large numbers of deployed systems in a cost effective, efficient, and safe manner.

NOTE: As previously stated, the PDF versions of the CIS Benchmarks™ are available for free, non-commercial use on the CIS Website. All other formats of the CIS Benchmarks™ (MS Word, Excel, and Build Kits) are available for CIS SecureSuite® members.

CIS-CAT® Pro is also available to CIS SecureSuite® members.

Target Technology Details

This document provides prescriptive guidance for establishing a secure configuration posture for Alibaba Cloud Linux 3 systems running on x86_64 platforms.

This guide was developed and tested against Alibaba Cloud Linux 3.2104 U12

The guidance within broadly assumes that operations are being performed as the `root` user, and executed under the default Bash version for the applicable distribution. Operations performed using `sudo` instead of the `root` user, or executed under another shell, may produce unexpected results, or fail to make the intended changes to the system. Non-root users may not be able to access certain areas of the system, especially after remediation has been performed. It is advisable to verify `root` users path integrity and the integrity of any programs being run prior to execution of commands and scripts included in this benchmark.

The default prompt for the `root` user is `#`, and as such all sample commands will have `#` as an additional indication that it is to be executed as `root`.

To obtain the latest version of this guide, please visit http://workbench.cisecurity.org. If you have questions, comments, or have identified ways to improve this guide, please write us at feedback@cisecurity.org.

Intended Audience

This benchmark is intended for system and application administrators, security specialists, auditors, help desk, and platform deployment personnel who plan to develop, deploy, assess, or secure solutions that incorporate Alibaba Cloud Linux 3 on x86_64 platforms.

Consensus Guidance

This CIS Benchmark™ was created using a consensus review process comprised of a global community of subject matter experts. The process combines real world experience with data-based information to create technology specific guidance to assist users to secure their environments. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS Benchmark undergoes two phases of consensus review. The first phase occurs during initial Benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the Benchmark. This discussion occurs until consensus has been reached on Benchmark recommendations. The second phase begins after the Benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the Benchmark. If you are interested in participating in the consensus process, please visit https://workbench.cisecurity.org/.

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
`Stylized Monospace font`	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
`Monospace font`	Used for inline code, commands, UI/Menu selections or examples. Text should be interpreted exactly as presented.
`<Monospace font in brackets>`	Text set in angle brackets denote a variable requiring substitution for a real value.
Italic font	Used to reference other relevant settings, CIS Benchmarks and/or Benchmark Communities. Also, used to denote the title of a book, article, or other publication.
Bold font	Additional information or caveats things like **Notes**, **Warnings**, or **Cautions** (usually just the word itself and the rest of the text normal).

Recommendation Definitions

The following defines the various components included in a CIS recommendation as applicable. If any of the components are not applicable it will be noted, or the component will not be included in the recommendation.

Title

Concise description for the recommendation's intended configuration.

Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

Profile

A collection of recommendations for securing a technology or a supporting platform. Most benchmarks include at least a Level 1 and Level 2 Profile. Level 2 extends Level 1 recommendations and is not a standalone profile. The Profile Definitions section in the benchmark provides the definitions as they pertain to the recommendations included for the technology.

Description

Detailed information pertaining to the setting with which the recommendation is concerned. In some cases, the description will include the recommended value.

Rationale Statement

Detailed reasoning for the recommendation to provide the user a clear and concise understanding on the importance of the recommendation.

Impact Statement

Any security, functionality, or operational consequences that can result from following the recommendation.

Audit Procedure

Systematic instructions for determining if the target system complies with the recommendation.

Remediation Procedure

Systematic instructions for applying recommendations to the target system to bring it into compliance according to the recommendation.

Default Value

Default value for the given setting in this recommendation, if known. If not known, either not configured or not defined will be applied.

References

Additional documentation relative to the recommendation.

CIS Critical Security Controls® (CIS Controls®)

The mapping between a recommendation and the CIS Controls is organized by CIS Controls version, Safeguard, and Implementation Group (IG). The Benchmark in its entirety addresses the CIS Controls safeguards of (v7) “5.1 - Establish Secure Configurations” and (v8) '4.1 - Establish and Maintain a Secure Configuration Process” so individual recommendations will not be mapped to these safeguards.

Additional Information

Supplementary information that does not correspond to any other field but may be useful to the user.

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1 - Server**

  Items in this profile intend to:

  - be practical and prudent;
  - provide a clear security benefit; and
  - not inhibit the utility of the technology beyond acceptable means.

  This profile is intended for servers.

- **Level 2 - Server**

  This profile extends the "Level 1 - Server" profile. Items in this profile exhibit one or more of the following characteristics:

  - are intended for environments or use cases where security is paramount.
  - acts as defense in depth measure.
  - may negatively inhibit the utility or performance of the technology.

  This profile is intended for servers.

Acknowledgements

This Benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

This benchmark is based upon previous Linux benchmarks published and would not be possible without the contributions provided over the history of all of these benchmarks. The CIS community thanks everyone who has contributed to the Linux benchmarks.

Contributor

Ron Colvin
Dave Billing
Dominic Pace
Mark Birch
Thomas Sjögren
James Trigg
Matthew Burket
Mike Cross
Marcus Burghardt
Graham Eames
Robert McSulla
Chad Streck
Ryan Jaynes
Cory Sherman
Simon John
Kleber Leal

Editor
Jonathan Lewis Christopherson
Eric Pinnell
Gokhan Lus
Randie Bejar
Trevor wood

Recommendations

1 Initial Setup

Items in this section are advised for all systems, but may be difficult or require extensive preparation after the initial setup of the system.

1.1 Filesystem

The file system is generally a built-in layer used to handle the data management of the storage.

1.1.1 Configure Filesystem Kernel Modules

Several uncommon filesystem types are supported under Linux. Removing support for unneeded filesystem types reduces the local attack surface of the system. If a filesystem type is not needed it should be disabled. Native Linux file systems are designed to ensure that built-in security controls function as expected. Non-native filesystems can lead to unexpected consequences to both the security and functionality of the system and should be used with caution. Many filesystems are created for niche use cases and are not maintained and supported as the operating systems are updated and patched. Users of non-native filesystems should ensure that there is attention and ongoing support for them, especially in light of frequent operating system changes.

Standard network connectivity and Internet access to cloud storage may make the use of non-standard filesystem formats to directly attach heterogeneous devices much less attractive.

Note: This should not be considered a comprehensive list of filesystems. You may wish to consider additions to those listed here for your environment. For the current available file system modules on the system see `ls /usr/lib/modules/**/kernel/fs | sort -u`.

Start up scripts

Kernel modules loaded directly via `insmod` will ignore what is configured in the relevant `/etc/modprobe.d/*.conf` files. If modules are still being loaded after a reboot whilst having the correctly configured `blacklist` and `install` command, check for `insmod` entries in start up scripts such as `.bashrc`.

Return values

Using `/bin/false` as the command in disabling a particular module serves two purposes; to convey the meaning of the entry to the user and cause a non-zero return value. The latter can be tested for in scripts. Please note that `insmod` will ignore what is configured in the relevant configuration files. The preferred way to load modules is with `modprobe`.

1.1.1.1 Ensure cramfs kernel module is not available (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `cramfs` filesystem type is a compressed read-only Linux filesystem embedded in small footprint systems. A `cramfs` image can be used without having to first decompress the image.

Rationale:

Removing support for unneeded filesystem types reduces the local attack surface of the system. If this filesystem type is not needed, disable it.

Audit:

Verify the `cramfs` kernel module is not available on the system or has been disabled.

1. Run the following script to determine if the `cramfs` kernel module is available on the system:

```
#!/usr/bin/env bash

{
   l_mod_name="cramfs" l_mod_type="fs"
   while IFS= read -r l_mod_path; do
      if [ -d "$l_mod_path/${l_mod_name//-/\/}" ] &&  \
      [ -n "$(ls -A "$l_mod_path/${l_mod_name//-/\/}")" ]; then
         printf '%s\n' "$l_mod_name exists in $l_mod_path"
      fi
   done < <(readlink -e /usr/lib/modules/**/kernel/$l_mod_type \
   || readlink -e /lib/modules/**/kernel/$l_mod_type)
}
```

If nothing is returned, the `cramfs` kernel module is not available on the system and no further audit steps are required.

Note: Some systems may include the `cramfs` filesystem as part of the kernel opposed to being available as a kernel module. In this case, the above audit will not return anything. This is also considered a passing state.

If anything is returned by the above script:

2. verify the `cramfs` kernel module is not loaded and not loadable by performing the following:

Run the following command to verify the `cramfs` kernel module is not loaded:

```
# lsmod | grep 'cramfs'
```

Nothing should be returned.

Run the following command to verify the `cramfs` kernel module is not loadable:

```
# modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+cramfs\b'
```

Verify the output includes:

```
blacklist cramfs
 -AND EITHER-
install cramfs /bin/false
 -OR-
install cramfs /bin/true
```

Example output:

```
blacklist cramfs
install cramfs /bin/false
```

Remediation:

Unload and disable the `cramfs` kernel module.

1. Run the following commands to unload the `cramfs` kernel module:

```
# modprobe -r cramfs 2>/dev/null
# rmmod cramfs 2>/dev/null
```

2. Perform the following to disable the `cramfs` kernel module:

Create a file ending in `.conf` with `install cramfs /bin/false` in the `/etc/modprobe.d/` directory.
Example:

```
# printf '%s\n' "" "install cramfs /bin/false" >> /etc/modprobe.d/60-
cramfs.conf
```

Create a file ending in `.conf` with `blacklist cramfs` in the `/etc/modprobe.d/` directory.

Example:

```
# printf '%s\n' "" "blacklist cramfs" >> /etc/modprobe.d/60-cramfs.conf
```

References:

1. CCI-000381
2. NIST SP 800-53: CM-7 a
3. NIST SP 800-53A :: CM-7.1 (ii)
4. STIG ID: RHEL-08-040025 | RULE ID: SV-230498r1069314 | CAT III
5. STIG ID: OL08-00-040025 | RULE ID: SV-248833r958478 | CAT III
6. STIG ID: RHEL-09-231195 | RULE ID: SV-257880r1044951 | CAT III
7. STIG ID: ALMA-09-029940 | RULE ID: SV-269344r1050226 | CAT II
8. STIG ID: OL09-00-000045 | RULE ID: SV-271448r1091056 | CAT III

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

1.1.1.2 Ensure freevxfs kernel module is not available (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `freevxfs` filesystem type is a free version of the Veritas type filesystem. This is the primary filesystem type for HP-UX operating systems.

Rationale:

Removing support for unneeded filesystem types reduces the local attack surface of the system. If this filesystem type is not needed, disable it.

Audit:

Verify the `freevxfs` kernel module is not available on the system or has been disabled.

1. Run the following script to determine if the `freevxfs` kernel module is available on the system:

```
#!/usr/bin/env bash

{
   l_mod_name="freevxfs" l_mod_type="fs"
   while IFS= read -r l_mod_path; do
      if [ -d "$l_mod_path/${l_mod_name//-/\/}" ] &&  \
      [ -n "$(ls -A "$l_mod_path/${l_mod_name//-/\/}")" ]; then
         printf '%s\n' "$l_mod_name exists in $l_mod_path"
      fi
   done < <(readlink -e /usr/lib/modules/**/kernel/$l_mod_type \
   || readlink -e /lib/modules/**/kernel/$l_mod_type)
}
```

If nothing is returned, the `freevxfs` kernel module is not available on the system and no further audit steps are required.

Note: Some systems may include the `freevxfs` filesystem as part of the kernel opposed to being available as a kernel module. In this case, the above audit will not return anything. This is also considered a passing state.

If anything is returned by the above script:

2. Verify the `freevxfs` kernel module is not loaded and not loadable by performing the following:

Run the following command to verify the `freevxfs` kernel module is not loaded:

```
# lsmod | grep 'freevxfs'
```

Nothing should be returned.

Run the following command to verify the `freevxfs` kernel module is not loadable:

```
modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+freevxfs\b'
```

Verify the output includes:

```
blacklist freevxfs
 -AND-
install freevxfs /bin/false
 -OR-
install freevxfs /bin/true
```

Example output:

```
blacklist freevxfs
install freevxfs /bin/false
```

Remediation:

Unload and disable the `freevxfs` kernel module.

1. Run the following commands to unload the `freevxfs` kernel module:

```
# modprobe -r freevxfs 2>/dev/null
# rmmod freevxfs 2>/dev/null
```

2. Perform the following to disable the `freevxfs` kernel module:

Create a file ending in `.conf` with `install freevxfs /bin/false` in the `/etc/modprobe.d/` directory.
Example:

```
# printf '%s\n' "" "install freevxfs /bin/false" >> /etc/modprobe.d/60-
freevxfs.conf
```

Create a file ending in `.conf` with `blacklist freevxfs` in the `/etc/modprobe.d/` directory.

Example:

```
# printf '%s\n' "" "blacklist freevxfs" >> /etc/modprobe.d/60-freevxfs.conf
```

References:

1. CCI-000381
2. NIST SP 800-53 :: CM-7
3. NIST SP 800-53A :: CM-7.1 (ii)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

1.1.1.3 Ensure hfs kernel module is not available (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `hfs` filesystem type is a hierarchical filesystem that allows you to mount Mac OS filesystems.

Rationale:

Removing support for unneeded filesystem types reduces the local attack surface of the system. If this filesystem type is not needed, disable it.

Audit:

Verify the hfs kernel module is not available on the system or has been disabled.

1. Run the following script to determine if the hfs kernel module is available on the system:

```
#!/usr/bin/env bash

{
   l_mod_name="hfs" l_mod_type="fs"
   while IFS= read -r l_mod_path; do
      if [ -d "$l_mod_path/${l_mod_name//-/\/}" ] &&  \
      [ -n "$(ls -A "$l_mod_path/${l_mod_name//-/\/}")" ]; then
         printf '%s\n' "$l_mod_name exists in $l_mod_path"
      fi
   done < <(readlink -e /usr/lib/modules/**/kernel/$l_mod_type \
   || readlink -e /lib/modules/**/kernel/$l_mod_type)
}
```

If nothing is returned, the hfs kernel module is not available on the system and no further audit steps are required.

Note: Some systems may include the hfs filesystem as part of the kernel opposed to being available as a kernel module. In this case, the above audit will not return anything. This is also considered a passing state.

If anything is returned by the above script:

2. Verify the hfs kernel module is not loaded and not loadable by performing the following:

Run the following command to verify the hfs kernel module is not loaded:

```
# lsmod | grep 'hfs'
```

Nothing should be returned.

Run the following command to verify the hfs kernel module is not loadable:

```
# modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+hfs\b'
```

Verify the output includes:

```
blacklist hfs
 -AND-
install hfs /bin/false
 -OR-
install hfs /bin/true
```

Example output:

```
blacklist hfs
install hfs /bin/false
```

Remediation:

Unload and disable the `hfs` kernel module.

1. Run the following commands to unload the `hfs` kernel module:

```
modprobe -r hfs 2>/dev/null
rmmod hfs 2>/dev/null
```

2. Perform the following to disable the `hfs` kernel module:

Create a file ending in `.conf` with `install hfs /bin/false` in the `/etc/modprobe.d/` directory.
Example:

```
# printf '%s\n' "" "install hfs /bin/false" >> /etc/modprobe.d/60-hfs.conf
```

Create a file ending in `.conf` with `blacklist hfs` in the `/etc/modprobe.d/` directory.

Example:

```
printf '%s\n' "" "blacklist hfs" >> /etc/modprobe.d/60-hfs.conf
```

References:

1. CCI-000381
2. NIST SP 800-53 :: CM-7
3. NIST SP 800-53A :: CM-7.1 (ii)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

1.1.1.4 Ensure hfsplus kernel module is not available (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `hfsplus` filesystem type is a hierarchical filesystem designed to replace `hfs` that allows you to mount Mac OS filesystems.

Rationale:

Removing support for unneeded filesystem types reduces the local attack surface of the system. If this filesystem type is not needed, disable it.

Audit:

Verify the `hfsplus` kernel module is not available on the system or has been disabled.

1. Run the following script to determine if the `hfsplus` kernel module is available on the system:

```
#!/usr/bin/env bash

{
   l_mod_name="hfsplus" l_mod_type="fs"
   while IFS= read -r l_mod_path; do
      if [ -d "$l_mod_path/${l_mod_name//-/\/}" ] &&  \
      [ -n "$(ls -A "$l_mod_path/${l_mod_name//-/\/}")" ]; then
         printf '%s\n' "$l_mod_name exists in $l_mod_path"
      fi
   done < <(readlink -e /usr/lib/modules/**/kernel/$l_mod_type \
   || readlink -e /lib/modules/**/kernel/$l_mod_type)
}
```

If nothing is returned, the `hfsplus` kernel module is not available on the system and no further audit steps are required.

Note: Some systems may include the `hfsplus` filesystem as part of the kernel opposed to being available as a kernel module. In this case, the above audit will not return anything. This is also considered a passing state.

If anything is returned by the above script:

2. Verify the `hfsplus` kernel module is not loaded and not loadable by performing the following:

Run the following command to verify the `hfsplus` kernel module is not loaded:

```
# lsmod | grep 'hfsplus'
```

Nothing should be returned.

Run the following command to verify the `hfsplus` kernel module is not loadable:

```
# modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+hfsplus\b'
```

Verify the output includes:

```
blacklist hfsplus
 -AND-
install hfsplus /bin/false
 -OR-
install hfsplus /bin/true
```

Example output:

```
blacklist hfsplus
install hfsplus /bin/false
```

Remediation:

Unload and disable the `hfsplus` kernel module.

1. Run the following commands to unload the `hfsplus` kernel module:

```
# modprobe -r hfsplus 2>/dev/null
# rmmod hfsplus 2>/dev/null
```

2. Perform the following to disable the `hfsplus` kernel module:

Create a file ending in `.conf` with `install hfsplus /bin/false` in the `/etc/modprobe.d/` directory.
Example:

```
# printf '%s\n' "" "install hfsplus /bin/false" >> /etc/modprobe.d/60-
hfsplus.conf
```

Create a file ending in `.conf` with `blacklist hfsplus` in the `/etc/modprobe.d/` directory.

Example:

```
# printf '%s\n' "" "blacklist hfsplus" >> /etc/modprobe.d/60-hfsplus.conf
```

References:

1. CCI-000381
2. NIST SP 800-53 :: CM-7
3. NIST SP 800-53A :: CM-7.1 (ii)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

1.1.1.5 Ensure jffs2 kernel module is not available (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `jffs2` (journaling flash filesystem 2) filesystem type is a log-structured filesystem used in flash memory devices.

Rationale:

Removing support for unneeded filesystem types reduces the local attack surface of the system. If this filesystem type is not needed, disable it.

Audit:

Verify the jffs2 kernel module is not available on the system or has been disabled.

1. Run the following script to determine if the jffs2 kernel module is available on the system:

```
#!/usr/bin/env bash

{
   l_mod_name="jffs2" l_mod_type="fs"
   while IFS= read -r l_mod_path; do
      if [ -d "$l_mod_path/${l_mod_name//-/\/}" ] &&  \
      [ -n "$(ls -A "$l_mod_path/${l_mod_name//-/\/}")" ]; then
         printf '%s\n' "$l_mod_name exists in $l_mod_path"
      fi
   done < <(readlink -e /usr/lib/modules/**/kernel/$l_mod_type \
   || readlink -e /lib/modules/**/kernel/$l_mod_type)
}
```

If nothing is returned, the jffs2 kernel module is not available on the system and no further audit steps are required.

Note: Some systems may include the jffs2 filesystem as part of the kernel opposed to being available as a kernel module. In this case, the above audit will not return anything. This is also considered a passing state.

If anything is returned by the above script:

2. Verify the jffs2 kernel module is not loaded and not loadable by performing the following:

Run the following command to verify the jffs2 kernel module is not loaded:

```
lsmod | grep 'jffs2'
```

Nothing should be returned.

Run the following command to verify the jffs2 kernel module is not loadable:

```
modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+jffs2\b'
```

Verify the output includes:

```
blacklist jffs2
 -AND-
install jffs2 /bin/false
 -OR-
install jffs2 /bin/true
```

Example output:

```
blacklist jffs2
install jffs2 /bin/false
```

Remediation:

Unload and disable the `jffs2` kernel module.

1. Run the following commands to unload the `jffs2` kernel module:

```
# modprobe -r jffs2 2>/dev/null
# rmmod jffs2 2>/dev/null
```

2. Perform the following to disable the `jffs2` kernel module:

Create a file ending in `.conf` with `install jffs2 /bin/false` in the `/etc/modprobe.d/` directory.
Example:

```
# printf '%s\n' "" "install jffs2 /bin/false" >> /etc/modprobe.d/60-
jffs2.conf
```

Create a file ending in `.conf` with `blacklist jffs2` in the `/etc/modprobe.d/` directory.

Example:

```
# printf '%s\n' "" "blacklist jffs2" >> /etc/modprobe.d/60-jffs2.conf
```

References:

1. CCI-000381
2. NIST SP 800-53 :: CM-7
3. NIST SP 800-53A :: CM-7.1 (ii)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

1.1.1.6 Ensure overlay kernel module is not available (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The Linux `overlay` kernel module, commonly referred to as Overlayfs, is a union mount filesystem. It allows the user to overlay one file system on top of another, and creates a single, unified view.

Rationale:

The `overlay` kernel module has known CVE's: CVE-2023-32629, CVE-2023-2640, and CVE-2023-0386. Disabling the `overlay` kernel module reduces the local attack surface by removing support for unnecessary filesystem types and mitigates potential risks associated with unauthorized execution of setuid files, enhancing the overall system security.

Impact:

WARNING: If Container applications such as Docker, Kubernetes, Podman, Linux Containers (LXC), etc. are in use proceed with caution and consider the impact on containerized workloads, as disabling the `overlay` may severely disrupt containerization.

Audit:

Verify the `overlay` kernel module is not available on the system or has been disabled.

1. Run the following script to determine if the `overlay` kernel module is available on the system:

```
#!/usr/bin/env bash

{
   l_mod_name="overlayfs" l_mod_type="fs"
   while IFS= read -r l_mod_path; do
      if [ -d "$l_mod_path/${l_mod_name//-/\/}" ] &&  \
      [ -n "$(ls -A "$l_mod_path/${l_mod_name//-/\/}")" ]; then
         printf '%s\n' "$l_mod_name exists in $l_mod_path"
      fi
   done < <(readlink -e /usr/lib/modules/**/kernel/$l_mod_type \
   || readlink -e /lib/modules/**/kernel/$l_mod_type)
}
```

If nothing is returned, the `overlay` kernel module is not available on the system and no further audit steps are required.

Note: Some systems may include the `overlay` kernel module as part of the kernel opposed to being available as a kernel module. In this case, the above audit will not return anything. This is also considered a passing state.

If anything is returned by the above script:

2. Verify the `overlay` kernel module is not loaded and not loadable by performing the following:

Run the following command to verify the `overlay` kernel module is not loaded:

```
# lsmod | grep 'overlay'
```

Nothing should be returned

Run the following command to verify the `overlay` kernel module is not loadable:

```
# modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+overlay\b'
```

Verify the output includes:

```
blacklist overlay
 -AND-
install overlay /bin/false
 -OR-
install overlay /bin/true
```

Example output:

```
blacklist overlay
install overlay /bin/false
```

Remediation:

Unload and disable the `overlay` kernel module.

1. Run the following commands to unload the `overlay` kernel module:

```
# modprobe -r overlay 2>/dev/null
# rmmod overlay 2>/dev/null
```

2. Perform the following to disable the `overlay` kernel module:

Create a file ending in `.conf` with `install overlay /bin/false` in the `/etc/modprobe.d/` directory
Example:

```
# printf '%s\n' "" "install overlay /bin/false" >> /etc/modprobe.d/60-
overlay.conf
```

Create a file ending in `.conf` with `blacklist overlay` in the `/etc/modprobe.d/` directory

Example:

```
# printf '%s\n' "" "blacklist overlay" >> /etc/modprobe.d/60-overlay.conf
```

References:

1. CCI-000381
2. NIST SP 800-53 :: CM-7
3. NIST SP 800-53A :: CM-7.1 (ii)
4. https://docs.kernel.org/filesystems/overlayfs.html
5. https://wiki.archlinux.org/title/Overlay_filesystem
6. https://cve.mitre.org/cgi-bin/cvekey.cgi?keyword=overlayfs

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

1.1.1.7 Ensure squashfs kernel module is not available (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The `squashfs` filesystem type is a compressed read-only Linux filesystem embedded in small footprint systems. A `squashfs` image can be used without having to first decompress the image.

Rationale:

Removing support for unneeded filesystem types reduces the local attack surface of the system. If this filesystem type is not needed, disable it.

Impact:

As Snap packages utilize `squashfs` as a compressed filesystem, disabling `squashfs` will cause Snap packages to fail.

`Snap` application packages of software are self-contained and work across a range of Linux distributions. This is unlike traditional Linux package management approaches, like APT or RPM, which require specifically adapted packages per Linux distribution on an application update and delay therefore application deployment from developers to their software's end-user. Snaps themselves have no dependency on any external store ("App store"), can be obtained from any source and can be therefore used for upstream software deployment.

Audit:

Verify the `squashfs` kernel module is not available on the system or has been disabled.

1. Run the following script to determine if the `squashfs` kernel module is available on the system:

```
#!/usr/bin/env bash

{
   l_mod_name="squashfs" l_mod_type="fs"
   while IFS= read -r l_mod_path; do
      if [ -d "$l_mod_path/${l_mod_name//-/\/}" ] &&  \
      [ -n "$(ls -A "$l_mod_path/${l_mod_name//-/\/}")" ]; then
         printf '%s\n' "$l_mod_name exists in $l_mod_path"
      fi
   done < <(readlink -e /usr/lib/modules/**/kernel/$l_mod_type \
   || readlink -e /lib/modules/**/kernel/$l_mod_type)
}
```

If nothing is returned, the `squashfs` kernel module is not available on the system and no further audit steps are required.

Note: Some systems may include the `squashfs` filesystem as part of the kernel opposed to being available as a kernel module. In this case, the above audit will not return anything. This is also considered a passing state.

If anything is returned by the above script:

2. Verify the `squashfs` kernel module is not loaded and not loadable by performing the following:

Run the following command to verify the `squashfs` kernel module is not loaded:

```
# lsmod | grep 'squashfs'
```

Nothing should be returned.

Run the following command to verify the `squashfs` kernel module is not loadable:

```
# modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+squashfs\b'
```

Verify the output includes:

```
blacklist squashfs
 -AND-
install squashfs /bin/false
 -OR-
install squashfs /bin/true
```

Example output:

```
blacklist squashfs
install squashfs /bin/false
```

Remediation:

Unload and disable the `squashfs` kernel module.

1. Run the following commands to unload the `squashfs` kernel module:

```
# modprobe -r squashfs 2>/dev/null
# rmmod squashfs 2>/dev/null
```

2. Perform the following to disable the `squashfs` kernel module:

Create a file ending in `.conf` with `install squashfs /bin/false` in the `/etc/modprobe.d/` directory.
Example:

```
# printf '%s\n' "" "install squashfs /bin/false" >> /etc/modprobe.d/60-
squashfs.conf
```

Create a file ending in `.conf` with `blacklist squashfs` in the `/etc/modprobe.d/` directory.

Example:

```
# printf '%s\n' "" "blacklist squashfs" >> /etc/modprobe.d/60-squashfs.conf
```

References:

1. CCI-000381
2. NIST SP 800-53 :: CM-7
3. NIST SP 800-53A :: CM-7.1 (ii)
4. STIG ID: ALMA-09-030160 | RULE ID: SV-269346r1050228 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

1.1.1.8 Ensure udf kernel module is not available (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The `udf` filesystem type is the universal disk format used to implement ISO/IEC 13346 and ECMA-167 specifications. This is an open vendor filesystem type for data storage on a broad range of media. This filesystem type is necessary to support writing DVDs and newer optical disc formats.

Rationale:

Removing support for unneeded filesystem types reduces the local attack surface of the system. If this filesystem type is not needed, disable it.

Impact:

Microsoft Azure requires the usage of `udf`.

`udf` **should not** be disabled on systems run on Microsoft Azure.

Audit:

Verify the udf kernel module is not available on the system or has been disabled.

1. Run the following script to determine if the udf kernel module is available on the system:

```
#!/usr/bin/env bash

{
   l_mod_name="udf" l_mod_type="fs"
   while IFS= read -r l_mod_path; do
      if [ -d "$l_mod_path/${l_mod_name//-/\/}" ] &&  \
      [ -n "$(ls -A "$l_mod_path/${l_mod_name//-/\/}")" ]; then
         printf '%s\n' "$l_mod_name exists in $l_mod_path"
      fi
   done < <(readlink -e /usr/lib/modules/**/kernel/$l_mod_type \
   || readlink -e /lib/modules/**/kernel/$l_mod_type)
}
```

If nothing is returned, the udf kernel module is not available on the system and no further audit steps are required.

Note: Some systems may include the udf filesystem as part of the kernel opposed to being available as a kernel module. In this case, the above audit will not return anything. This is also considered a passing state.

If anything is returned by the above script:

2. Verify the udf kernel module is not loaded and not loadable by performing the following:

Run the following command to verify the udf kernel module is not loaded:

```
# lsmod | grep 'udf'
```

Nothing should be returned

Run the following command to verify the udf kernel module is not loadable:

```
# modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+udf\b'
```

Verify the output includes:

```
blacklist udf
 -AND-
install udf /bin/false
 -OR-
install udf /bin/true
```

Example output:

```
blacklist udf
install udf /bin/false
```

Remediation:

Unload and disable the `udf` kernel module.

1. Run the following commands to unload the `udf` kernel module:

```
# modprobe -r udf 2>/dev/null
# rmmod udf 2>/dev/null
```

2. Perform the following to disable the `udf` kernel module:

Create a file ending in `.conf` with `install udf /bin/false` in the `/etc/modprobe.d/` directory
Example:

```
# printf '%s\n' "" "install udf /bin/false" >> /etc/modprobe.d/60-udf.conf
```

Create a file ending in `.conf` with `blacklist udf` in the `/etc/modprobe.d/` directory

Example:

```
# printf '%s\n' "" "blacklist udf" >> /etc/modprobe.d/60-udf.conf
```

References:

1. CCI-000381
2. NIST SP 800-53 :: CM-7
3. NIST SP 800-53A :: CM-7.1 (ii)
4. STIG ID: ALMA-09-030380 | RULE ID: SV-269348r1050230 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

1.1.1.9 Ensure firewire-core kernel module is not available (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The IEEE 1394 (FireWire) is a serial bus standard for high-speed real-time communication.

Rationale:

Disabling FireWire protects the system against exploitation of any flaws in its implementation.

Audit:

Verify the `firewire-core` kernel module is not available on the system or has been disabled.

1. Run the following script to determine if the `firewire-core` kernel module is available on the system:

```
#!/usr/bin/env bash

{
   l_mod_name="firewire" l_mod_type="drivers"
   while IFS= read -r l_mod_path; do
      if [ -d "$l_mod_path/${l_mod_name//-/\/}" ] &&  \
      [ -n "$(ls -A "$l_mod_path/${l_mod_name//-/\/}")" ]; then
         printf '%s\n' "$l_mod_name exists in $l_mod_path"
      fi
   done < <(readlink -e /usr/lib/modules/**/kernel/$l_mod_type \
   || readlink -e /lib/modules/**/kernel/$l_mod_type)
}
```

If nothing is returned, the `firewire-core` kernel module is not available on the system and no further audit steps are required.

Note: Some systems may include the `firewire-core` filesystem as part of the kernel opposed to being available as a kernel module. In this case, the above audit will not return anything. This is also considered a passing state.

If anything is returned by the above script:

2. Verify the `firewire-core` kernel module is not loaded and not loadable by performing the following:

Run the following command to verify the `firewire-core` kernel module is not loaded:

```
# lsmod | grep -P -- 'firewire(_|-)core'
```

Nothing should be returned

Run the following command to verify the `firewire-core` kernel module is not loadable:

```
# modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+firewire(_|-
)core\b'
```

Verify the output includes:

```
blacklist firewire_core
 -AND-
install firewire_core /bin/false
 -OR-
install firewire_core /bin/true
```

Example output:

```
blacklist firewire_core
install firewire_core /bin/false
```

Remediation:

Unload and disable the `firewire-core` kernel module.

1. Run the following commands to unload the `firewire-core` kernel module:

```
# modprobe -r firewire-core 2>/dev/null
# rmmod firewire-core 2>/dev/null
```

2. Perform the following to disable the `firewire-core` kernel module:

Create a file ending in `.conf` with `install firewire-core /bin/false` in the `/etc/modprobe.d/` directory
Example:

```
# printf '%s\n' "" "install firewire-core /bin/false" >> /etc/modprobe.d/60-firewire-core.conf
```

Create a file ending in `.conf` with `blacklist firewire-core` in the `/etc/modprobe.d/` directory

Example:

```
# printf '%s\n' "" "blacklist firewire-core" >> /etc/modprobe.d/60-firewire-core.conf
```

References:

1. CCI-000381
2. NIST SP 800-53 :: CM-7
3. NIST SP 800-53A :: CM-7.1 (ii)
4. STIG ID: RHEL-08-040026 | RULE ID: SV-230499r1069315 | CAT III
5. STIG ID: OL08-00-040026 | RULE ID: SV-248834r958478 | CAT III
6. STIG ID: RHEL-09-213055 | RULE ID: SV-257806r1044859 | CAT II
7. STIG ID: OL09-00-000042 | RULE ID: SV-271445r1091047 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

1.1.1.10 Ensure usb-storage kernel module is not available (Automated)

Profile Applicability:

- Level 1 - Server

Description:

USB storage provides a means to transfer and store files ensuring persistence and availability of the files independent of network connection status. Its popularity and utility has led to USB-based malware being a simple and common means for network infiltration and a first step to establishing a persistent threat within a networked environment.

Rationale:

Restricting USB access on the system will decrease the physical attack surface for a device and diminish the possible vectors to introduce malware.

Satisfies: SRG-OS-000114-GPOS-00059, SRG-OS-000378-GPOS-00163

Impact:

Disabling the `usb-storage` module will disable any usage of USB storage devices.

If requirements and local site policy allow the use of such devices, other solutions should be configured accordingly instead. One example of a commonly used solution is `USBGuard`.

Audit:

Verify the usb-storage kernel module is not available on the system or has been disabled.

1. Run the following script to determine if the usb-storage kernel module is available on the system:

```
#!/usr/bin/env bash

{
   l_mod_name="usb-storage" l_mod_type="drivers"
   while IFS= read -r l_mod_path; do
      if [ -d "$l_mod_path/${l_mod_name//-/\/}" ] &&  \
      [ -n "$(ls -A "$l_mod_path/${l_mod_name//-/\/}")" ]; then
         printf '%s\n' "$l_mod_name exists in $l_mod_path"
      fi
   done < <(readlink -e /usr/lib/modules/**/kernel/$l_mod_type \
   || readlink -e /lib/modules/**/kernel/$l_mod_type)
}
```

If nothing is returned, the usb-storage kernel module is not available on the system and no further audit steps are required.

Note: Some systems may include the usb-storage filesystem as part of the kernel opposed to being available as a kernel module. In this case, the above audit will not return anything. This is also considered a passing state.

If anything is returned by the above script:

2. Verify the usb-storage kernel module is not loaded and not loadable by performing the following:

Run the following command to verify the usb-storage kernel module is not loaded:

```
# lsmod | grep -P -- 'usb(_|-)storage'
```

Nothing should be returned

Run the following command to verify the usb-storage kernel module is not loadable:

```
# modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+usb_storage\b'
```

Verify the output includes:

```
blacklist usb_storage
 -AND-
install usb_storage /bin/false
 -OR-
install usb_storage /bin/true
```

Example output:

```
blacklist usb_storage
install usb_storage /bin/false
```

Remediation:

Unload and disable the `usb-storage` kernel module.

1. Run the following commands to unload the `usb-storage` kernel module:

```
# modprobe -r usb-storage 2>/dev/null
# rmmod usb-storage 2>/dev/null
```

2. Perform the following to disable the `usb-storage` kernel module:

Create a file ending in `.conf` with `install usb_storage /bin/false` in the `/etc/modprobe.d/` directory
Example:

```
# printf '%s\n' "" "install usb_storage /bin/false" >> /etc/modprobe.d/60-usb-storage.conf
```

Create a file ending in `.conf` with `blacklist usb_storage` in the `/etc/modprobe.d/` directory

Example:

```
# printf '%s\n' "" "blacklist usb_storage" >> /etc/modprobe.d/60-usb-storage.conf
```

References:

1. CCI-000778 | CCI-001958 | CCI-003959
2. NIST SP 800-53 :: IA-3 | NIST SP 800-53 :: CM-7 (9) (b)
3. NIST SP 800-53A :: IA-3.1 (ii)
4. STIG ID: RHEL-08-040080 | RULE ID: SV-230503r1069316 | CAT II
5. STIG ID: OL08-00-040080 | RULE ID: SV-248837r986386 | CAT II
6. STIG ID: RHEL-09-291010 | RULE ID: SV-258034r1051267 | CAT II
7. STIG ID: ALMA-09-031370 | RULE ID: SV-269357r1050240 | CAT II
8. STIG ID: OL09-00-000047 | RULE ID: SV-271450r1092466 | CAT II
9. STIG ID: OL09-00-002332 | RULE ID: SV-271702r1091818 | CAT II
10. STIG ID: UBTU-22-291010 | RULE ID: SV-260540r986276 | CAT II
11. STIG ID: UBTU-24-300039 | RULE ID: SV-270718r1067128 | CAT II
12. STIG ID: SLES-15-010480 | RULE ID: SV-234856r958820 | CAT II

Additional Information:

An alternative solution to disabling the usb-storage module may be found in USBGuard.

Use of USBGuard and construction of USB device policies should be done in alignment with site policy.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.3 Disable Autorun and Autoplay for Removable Media Disable autorun and autoplay auto-execute functionality for removable media.	●	●	●
v7	13.7 Manage USB Devices If USB storage devices are required, enterprise software should be used that can configure systems to allow the use of specific devices. An inventory of such devices should be maintained.		●	●

1.1.1.11 Ensure unused filesystems kernel modules are not available (Manual)

Profile Applicability:

- Level 1 - Server

Description:

Filesystem kernel modules are pieces of code that can be dynamically loaded into the Linux kernel to extend its filesystem capabilities, or so-called base kernel, of an operating system. Filesystem kernel modules are typically used to add support for new hardware (as device drivers), or for adding system calls.

Rationale:

While loadable filesystem kernel modules are a convenient method of modifying the running kernel, this can be abused by attackers on a compromised system to prevent detection of their processes or files, allowing them to maintain control over the system. Many rootkits make use of loadable filesystem kernel modules in this way.

Removing support for unneeded filesystem types reduces the local attack surface of the system. If this filesystem type is not needed, disable it. The following filesystem kernel modules have known CVE's and should be made unavailable if no dependencies exist:

- `ceph` - CVE-2022-0670
- `cifs` - CVE-2022-29869
- `exfat` CVE-2022-29973
- `ext` CVE-2022-1184
- `fat` CVE-2022-22043
- `fscache` CVE-2022-3630
- `fuse` CVE-2023-0386
- `gfs2` CVE-2023-3212
- `nfs_common` CVE-2023-6660
- `nfsd` CVE-2022-43945
- `smbfs_common` CVE-2022-2585

Impact:

This list may be quite extensive and covering all edges cases is difficult. Therefore, it's crucial to carefully consider the implications and dependencies before making any changes to the filesystem kernel module configurations.

Audit:

Verify filesystem kernel modules that are not in use on the system are disabled. Review currently loaded kernel modules to ensure they are needed and conform to local site policy.

Note: The "Audit script" included at the bottom of the "Audit Procedure" will perform the steps included below.

1. Run the following command to generate a list of filesystem types currently mounted on the system.

```
# findmnt -Dkerno fstype | sort -u
```

Review the output. These filesystem types should either be excluded from the audit or if no longer needed, unmounted and disabled.

Example output:

```
devtmpfs
ext4
tmpfs
vfat
```

2. Run the following script to generate a list of all file system kernel modules currently installed on the system:

```
#!/usr/bin/env bash

{
   l_search="$(readlink -e /usr/lib/modules/ || readlink -e /lib/modules/)"
   a_module=()
   while IFS= read -r -d $'\0' l_module_dir; do
      if [ ! "$(basename "$l_module_dir")" = "nls" ]; then
         while IFS= read -r -d $'\0' l_module_file; do
            l_mname="$(basename "$l_module_file" | cut -d'.' -f1)"
            if [ -f "$l_module_file" ] && ! grep -Psiq -- '\b'"$l_mname"'\b'
\
            <<< "${a_module[*]}"; then
               a_module+=("$l_mname")
            fi
         done < <(find -L "$l_module_dir" -mindepth 1 -maxdepth 1 -type f -
print0)
      fi
   done < <(find "$l_search"/**/kernel/fs/ -mindepth 1 -maxdepth 1 -type d !
-empty -print0)
   printf '%s\n' "" "${a_module[@]}"
}
```

The output is a list of the kernel modules included in the `/usr/lib/modules/{KERNEL_VERSION}/kernel/fs/` or `/lib/modules/{KERNEL_VERSION}/kernel/fs/` directories. This list has been sorted to be unique values, ignore items in the `nls` directory, and added to an array called `a_module`.

3. Run the following command to generate a list of modules currently loaded into the kernel:

```
# lsmod
```

4. compare the output from the list generated in step 2 to the list of loaded modules generated by the `lsmod` command in step 3. Any module appearing in both lists is currently loaded into the kernel. Review these to verify they are needed and approved by local site policy
5. Run the following command to generate a list of modules that are set to be Deny Listed: `blacklist {MODULE_NAME}`, and/or set be be not loadable: `install {MODULE_NAME} /bin/false` or `install {MODULE_NAME} /bin/true`:

```
# modprobe --showconfig | grep -Pi -- '^\h*(blacklist|install)\h+'
```

6. Verify all modules in the output from the list generated in step 2 are both Deny Listed: `blacklist {MODULE_NAME}` and set to be not loadable: `install {MODULE_NAME} /bin/false` or `install {MODULE_NAME} /bin/true`.

Audit Script:

```
#!/usr/bin/env bash

{
   a_check=() a_output=() a_module=() a_output2=() a_output3=()
   l_search="$(readlink -e /usr/lib/modules/ || readlink -e /lib/modules/)"
   IFS=$'\n' read -r -d '' -a a_mounted < <(findmnt -Dkerno fstype \
   | sort -u && printf '\0' )
   IFS=$'\n' read -r -d '' -a a_lsmod < <(lsmod | awk '{print $1}' && printf
'\0' )
   IFS=$'\n' read -r -d '' -a a_showconfig < <(modprobe --showconfig | \
   grep -Pi -- '^\h*(blacklist|install)\h+' && printf '\0')
   while IFS= read -r -d $'\0' l_module_dir; do
      if [ ! "$(basename "$l_module_dir")" = "nls" ]; then
         while IFS= read -r -d $'\0' l_module_file; do
            l_mname="$(basename "$l_module_file" | cut -d'.' -f1)"
            if [ -f "$l_module_file" ] && ! grep -Psiq -- '\b'"$l_mname"'\b'
<<< "${a_module[*]}"; then
               a_module+=("$l_mname")
            fi
         done < <(find -L "$l_module_dir" -mindepth 1 -maxdepth 1 -type f -
print0)
      fi
   done < <(find "$l_search"/**/kernel/fs/ -mindepth 1 -maxdepth 1 -type d !
-empty -print0)
   for l_module in "${a_module[@]}"; do
      if grep -Psoiq -- '\b'"$l_module"'\b' <<< "${a_mounted[*]}"; then
         a_output+=("  - \"$l_module\"")
      elif grep -Psoiq -- '\b'"$l_module"'\b' <<< "${a_lsmod[*]}"; then
         a_output2+=("  - \"$l_module\"")
      elif ! grep -Psioq -- '\binstall\h+'"${l_module//-/_}"'\h+\H+\b' <<<
"${a_showconfig[*]}" || \
      ! grep -Psioq -- '\bblacklist\h+'"${l_module//-/_}"'\b' <<<
"${a_showconfig[*]}"; then
         a_output3+=("  - \"$l_module\"")
      fi
   done
   [ "${#a_output[@]}" -gt 0 ] && printf '%s\n' "" \
   "- There are \"${#a_output[@}]}\" kernel modules currently mounted:"
"${a_output[@]}"
   [ "${#a_output2[@]}" -gt 0 ] && printf '%s\n' "" \
   "- There are \"${#a_output2[@]}\" kernel modules currently loaded:"
"${a_output2[@]}"
   [ "${#a_output3[@]}" -gt 0 ] && printf '%s\n' "" \
   "- There are \"${#a_output3[@]}\" Kernel modules currently loadable:"
"${a_output3[@]}"
}
```

WARNING: disabling or denylisting filesystem modules that are in use on the system may be FATAL. It is extremely important to thoroughly review this list.

Remediation:

- IF - the module is available in the running kernel:

- Unload the filesystem kernel module from the kernel
- Create a file ending in `.conf` with install filesystem kernel modules `/bin/false` in the `/etc/modprobe.d/` directory
- Create a file ending in `.conf` with deny list filesystem kernel modules in the `/etc/modprobe.d/` directory

WARNING: unloading, disabling or denylisting filesystem modules that are in use on the system may be FATAL. It is extremely important to thoroughly review the filesystems returned by the audit before following the remediation procedure.
Example of unloading the `gfs2` kernel module:

```
modprobe -r gfs2 2>/dev/null
rmmod gfs2 2>/dev/null
```

Example of fully disabling the `gfs2` kernel module:

```
printf '%s\n' "" "blacklist gfs2" "install gfs2 /bin/false" >>
/etc/modprobe.d/gfs2.conf
```

Note:

- Disable a kernel module by modifying the command above for each unused filesystem kernel module
- The example `gfs2` must be updated with the appropriate module name for the command or example script bellow to run correctly.

Below is an example script that can be modified to use on various filesystem kernel modules manual remediation process:
Example Script

```
#!/usr/bin/env bash

{
   a_output2=(); a_output3=(); l_dl="" # Initialize arrays and clear
variables
   l_mod_name="gfs2" # set module name
   l_mod_type="fs" # set module type
   l_mod_path="$(readlink -f /usr/lib/modules/**/kernel/$l_mod_type ||
readlink -f /lib/modules/**/kernel/$l_mod_type)"
   f_module_fix()
   {
      l_dl="y" # Set to ignore duplicate checks
      a_showconfig=() # Create array with modprobe output
      while IFS= read -r l_showconfig; do
         a_showconfig+=("$l_showconfig")
      done < <(modprobe --showconfig | grep -P --
'\b(install|blacklist)\h+'"${l_mod_name//-/_}"'\b')
      if  lsmod | grep "$l_mod_name" &> /dev/null; then # Check if the module
is currently loaded
         a_output2+=(" - unloading kernel module: \"$l_mod_name\"")
         modprobe -r "$l_mod_name" 2>/dev/null; rmmod "$l_mod_name"
2>/dev/null
      fi
      if ! grep -Pq -- '\binstall\h+'"${l_mod_name//-
/_}"'\h+(\/usr)?\/bin\/(true|false)\b' <<< "${a_showconfig[*]}"; then
         a_output2+=(" - setting kernel module: \"$l_mod_name\" to
\"$(readlink -f /bin/false)\"")
         printf '%s\n' "install $l_mod_name $(readlink -f /bin/false)" >>
/etc/modprobe.d/"$l_mod_name".conf
      fi
      if ! grep -Pq -- '\bblacklist\h+'"${l_mod_name//-/_}"'\b' <<<
"${a_showconfig[*]}"; then
         a_output2+=(" - denylisting kernel module: \"$l_mod_name\"")
         printf '%s\n' "blacklist $l_mod_name" >>
/etc/modprobe.d/"$l_mod_name".conf
      fi
   }
   for l_mod_base_directory in $l_mod_path; do # Check if the module exists
on the system
      if [ -d "$l_mod_base_directory/${l_mod_name/-/\/}" ] && [ -n "$(ls -A
"$l_mod_base_directory/${l_mod_name/-/\/}")" ]; then
         a_output3+=("  - \"$l_mod_base_directory\"")
         [[ "$l_mod_name" =~ overlay ]] && l_mod_name="${l_mod_name::-2}"
         [ "$l_dl" != "y" ] && f_module_fix
      else
         echo -e " - kernel module: \"$l_mod_name\" doesn't exist in
\"$l_mod_base_directory\""
      fi
   done
   [ "${#a_output3[@]}" -gt 0 ] && printf '%s\n' "" " -- INFO --" " - module:
\"$l_mod_name\" exists in:" "${a_output3[@]}"
   [ "${#a_output2[@]}" -gt 0 ] && printf '%s\n' "" "${a_output2[@]}" ||
printf '%s\n' "" " - No changes needed"
   printf '%s\n' "" " - remediation of kernel module: \"$l_mod_name\"
complete" ""
}
```

References:

1. https://cve.mitre.org/cgi-bin/cvekey.cgi?keyword=filesystem

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

1.1.2 Configure Filesystem Partitions

Directories that are used for system-wide functions can be further protected by placing them on separate partitions. This provides protection for resource exhaustion and enables the use of mounting options that are applicable to the directory's intended use. Users' data can be stored on separate partitions and have stricter mount options. A user partition is a filesystem that has been established for use by the users and does not contain software for system operations.

The recommendations in this section are easier to perform during initial system installation. If the system is already installed, it is recommended that a full backup be performed before repartitioning the system.

Note:

-IF- you are repartitioning a system that has already been installed (This may require the system to be in single-user mode):

- Mount the new partition to a temporary mountpoint e.g. `mount /dev/sda2 /mnt`
- Copy data from the original partition to the new partition. e.g. `cp -a /var/tmp/* /mnt`
- Verify that all data is present on the new partition. e.g. `ls -la /mnt`
- Unmount the new partition. e.g. `umount /mnt`
- Remove the data from the original directory that was in the old partition. e.g. `rm -Rf /var/tmp/*` Otherwise it will still consume space in the old partition that will be masked when the new filesystem is mounted.
- Mount the new partition to the desired mountpoint. e.g. `mount /dev/sda2 /var/tmp`
- Update `/etc/fstab` with the new mountpoint. e.g. `/dev/sda2 /var/tmp xfs defaults,rw,nosuid,nodev,noexec,relatime 0 0`

1.1.2.1 Configure /tmp

The `/tmp` directory is a world-writable directory used to store data used by the system and user applications for a short period of time. This data should have no expectation of surviving a reboot, as this directory is intended to be emptied after each reboot.

1.1.2.1.1 Ensure /tmp is tmpfs or a separate partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/tmp` directory is a world-writable directory used for temporary storage by all users and some applications.

Note: If an entry for `/tmp` exists in `/etc/fstab` it will take precedence over entries in a systemd unit file. There is an exception to this when a system is diskless and connected to iSCSI, entries in `/etc/fstab` may not take precedence over a systemd unit file.

Rationale:

Making `/tmp` its own file system allows an administrator to set additional mount options such as the `noexec` option on the mount, making `/tmp` useless for an attacker to install executable code. It would also prevent an attacker from establishing a hard link to a system `setuid` program and wait for it to be updated. Once the program was updated, the hard link would be broken, and the attacker would have his own copy of the program. If the program happened to have a security vulnerability, the attacker could continue to exploit the known flaw.

This can be accomplished by either mounting `tmpfs` to `/tmp`, or creating a separate partition for `/tmp`.

Impact:

By design files saved to `/tmp` should have no expectation of surviving a reboot of the system. `tmpfs` is ram based and all files stored to `tmpfs` will be lost when the system is rebooted.

If files need to be persistent through a reboot, they should be saved to `/var/tmp` not `/tmp`.

Since the `/tmp` directory is intended to be world-writable, there is a risk of resource exhaustion if it is not bound to `tmpfs` or a separate partition.

Running out of `/tmp` space is a problem regardless of what kind of filesystem lies under it, but in a configuration where `/tmp` is not a separate file system it will essentially have the whole disk available, as the default installation only creates a single `/` partition. On the other hand, a RAM-based `/tmp` (as with `tmpfs`) will almost certainly be much smaller, which can lead to applications filling up the filesystem much more easily. Another alternative is to create a dedicated partition for `/tmp` from a separate volume or disk. One of the downsides of a disk-based dedicated partition is that it will be slower than `tmpfs` which is RAM-based.

Audit:

Run the following command and verify the output shows that `/tmp` is mounted. Particular requirements pertaining to mount options are covered in ensuing sections.

```
# findmnt -kn /tmp
```

Example output:

```
/tmp   tmpfs  tmpfs  rw,nosuid,nodev,noexec
```

Ensure that systemd will mount the `/tmp` partition at boot time.

```
# systemctl is-enabled tmp.mount
```

Example output:

```
generated
```

Verify output is not `masked` or `disabled`.

Note: By default, systemd will output `generated` if there is an entry in `/etc/fstab` for `/tmp`. This just means systemd will use the entry in `/etc/fstab` instead of its default unit file configuration for `/tmp`.

Remediation:

First ensure that systemd is correctly configured to ensure that `/tmp` will be mounted at boot time.

```
# systemctl unmask tmp.mount
```

For specific configuration requirements of the `/tmp` mount for your environment, modify `/etc/fstab`.

Example of using `tmpfs` with specific mount options:

```
tmpfs   /tmp    tmpfs     defaults,rw,nosuid,nodev,noexec,relatime,size=2G  0
0
```

Note: the `size=2G` is an example of setting a specific size for `tmpfs`.

Example of using a volume or disk with specific mount options. The source location of the volume or disk will vary depending on your environment:

```
<device> /tmp    <fstype>    defaults,nodev,nosuid,noexec   0 0
```

References:

1. https://www.freedesktop.org/wiki/Software/systemd/APIFileSystems/
2. https://www.freedesktop.org/software/systemd/man/systemd-fstab-generator.html
3. https://www.kernel.org/doc/Documentation/filesystems/tmpfs.txt
4. CCI-000366
5. NIST SP 800-53 :: CM-6 b
6. NIST SP 800-53A :: CM-6.1 (iv)
7. STIG ID: RHEL-08-010543 | RULE ID: SV-230295r1017106 | CAT II
8. STIG ID: RHEL-09-231015 | RULE ID: SV-257844r1044918 | CAT II
9. STIG ID: ALMA-09-025540 | RULE ID: SV-269305r1050187 | CAT II

Additional Information:

`/tmp` can be configured to use `tmpfs`.

`tmpfs` puts everything into the kernel internal caches and grows and shrinks to accommodate the files it contains and is able to swap unneeded pages out to swap space. It has maximum size limits which can be adjusted on the fly via `mount -o remount`.

Since `tmpfs` lives completely in the page cache and on swap, all `tmpfs` pages will be shown as "Shmem" in `/proc/meminfo` and "Shared" in `free`. Notice that these counters also include shared memory. The most reliable way to get the count is using `df` and `du`.

`tmpfs` has three mount options for sizing:

- `size`: The limit of allocated bytes for this `tmpfs` instance. The default is half of your physical RAM without swap. If you oversize your `tmpfs` instances the machine will deadlock since the OOM handler will not be able to free that memory.
- `nr_blocks`: The same as size, but in blocks of PAGE_SIZE.
- `nr_inodes`: The maximum number of inodes for this instance. The default is half of the number of your physical RAM pages, or (on a machine with highmem) the number of lowmem RAM pages, whichever is the lower.

These parameters accept a suffix k, m or g and can be changed on remount. The size parameter also accepts a suffix % to limit this `tmpfs` instance to that percentage of your physical RAM. The default, when neither `size` nor `nr_blocks` is specified, is `size=50%`.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.1.2 Ensure nodev option set on /tmp partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `nodev` mount option specifies that the filesystem cannot contain special devices.

Rationale:

Since the `/tmp` filesystem is not intended to support devices, set this option to ensure that users cannot create a block or character special devices in `/tmp`.

Audit:

- IF - a separate partition exists for `/tmp`, verify that the `nodev` option is set.

Run the following command to verify that the `nodev` mount option is set.

Example:

```
# findmnt -kn /tmp | grep -v nodev

Nothing should be returned
```

Remediation:

- IF - a separate partition exists for `/tmp`.

Edit the `/etc/fstab` file and add `nodev` to the fourth field (mounting options) for the `/tmp` partition.

Example:

```
<device> /tmp    <fstype>     defaults,rw,nosuid,nodev,noexec,relatime  0 0
```

Run the following command to remount `/tmp` with the configured options:

```
# mount -o remount /tmp
```

References:

1. CCI-001764
2. NIST SP 800-53 :: CM-7 (2)
3. STIG ID: RHEL-08-040123 | RULE ID: SV-230511r958804 | CAT II
4. STIG ID: RHEL-09-231125 | RULE ID: SV-257866r958804 | CAT II
5. STIG ID: ALMA-09-026860 | RULE ID: SV-269317r1050199 | CAT II

Additional Information:

See the fstab(5) manual page for more information.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.1.3 Ensure nosuid option set on /tmp partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `nosuid` mount option specifies that the filesystem cannot contain `setuid` files.

Rationale:

Since the `/tmp` filesystem is only intended for temporary file storage, set this option to ensure that users cannot create `setuid` files in `/tmp`.

Audit:

- IF - a separate partition exists for `/tmp`, verify that the `nosuid` option is set.

Run the following command to verify that the `nosuid` mount option is set.

Example:

```
# findmnt -kn /tmp | grep -v nosuid

Nothing should be returned
```

Remediation:

- IF - a separate partition exists for `/tmp`.

Edit the `/etc/fstab` file and add `nosuid` to the fourth field (mounting options) for the `/tmp` partition.

Example:

```
<device> /tmp    <fstype>     defaults,rw,nosuid,nodev,noexec,relatime  0 0
```

Run the following command to remount `/tmp` with the configured options:

```
# mount -o remount /tmp
```

References:

1. CCI-001764
2. NIST SP 800-53 :: CM-7 (2)
3. STIG ID: RHEL-08-040124 | RULE ID: SV-230512r958804 | CAT II
4. STIG ID: RHEL-09-231135 | RULE ID: SV-257868r958804 | CAT II
5. STIG ID: ALMA-09-027080 | RULE ID: SV-269319r1050201 | CAT II

Additional Information:

See the fstab(5) manual page for more information.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.1.4 Ensure noexec option set on /tmp partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `noexec` mount option specifies that the filesystem cannot contain executable binaries.

Rationale:

Since the `/tmp` filesystem is only intended for temporary file storage, set this option to ensure that users cannot run executable binaries from `/tmp`.

Impact:

Setting the `noexec` option on `/tmp` may prevent installation and/or updating of some 3rd party software.

Audit:

- IF - a separate partition exists for `/tmp`, verify that the `noexec` option is set.

Run the following command to verify that the `noexec` mount option is set.

Example:

```
# findmnt -kn /tmp | grep -v noexec

Nothing should be returned
```

Remediation:

- IF - a separate partition exists for `/tmp`.

Edit the `/etc/fstab` file and add `noexec` to the fourth field (mounting options) for the `/tmp` partition.

Example:

```
<device> /tmp    <fstype>     defaults,rw,nosuid,nodev,noexec,relatime  0 0
```

Run the following command to remount `/tmp` with the configured options:

```
# mount -o remount /tmp
```

References:

1. CCI-001764
2. NIST SP 800-53 :: CM-7 (2)
3. STIG ID: RHEL-08-040125 | RULE ID: SV-230513r958804 | CAT II
4. STIG ID: RHEL-09-231130 | RULE ID: SV-257867r958804 | CAT II
5. STIG ID: ALMA-09-026970 | RULE ID: SV-269318r1050200 | CAT II

Additional Information:

See the fstab(5) manual page for more information.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.2 Configure /dev/shm

The `/dev/shm` directory is a world-writable directory that can function as shared memory that facilitates inter process communication (IPC)

1.1.2.2.1 Ensure /dev/shm is tmpfs (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/dev/shm` directory is a world-writable directory that can function as shared memory that facilitates inter process communication (IPC).

Rationale:

Making `/dev/shm` its own file system as `tmpfs` allows an administrator to set additional mount options such as the `noexec` option on the mount, making `/dev/shm` useless for an attacker to install executable code. It would also prevent an attacker from establishing a hard link to a system `setuid` program and wait for it to be updated. Once the program was updated, the hard link would be broken and the attacker would have his own copy of the program. If the program happened to have a security vulnerability, the attacker could continue to exploit the known flaw.

Impact:

Since the `/dev/shm` directory is intended to be world-writable, there is a risk of resource exhaustion if it is not bound to a separate partition.

`/dev/shm` utilizing `tmpfs` can be resized using the `size={size}` parameter in the relevant entry in `/etc/fstab`.

Audit:

- IF - `/dev/shm` is to be used on the system, run the following command and verify the output shows that `/dev/shm` is mounted. Particular requirements pertaining to mount options are covered in ensuing sections.

```
# findmnt -kn /dev/shm
```

Example output:

```
/dev/shm   tmpfs   tmpfs   rw,nosuid,nodev,noexec,relatime,seclabel
```

Remediation:

For specific configuration requirements of the `/dev/shm` mount for your environment, modify `/etc/fstab`.

Example:

```
tmpfs   /dev/shm        tmpfs
defaults,rw,nosuid,nodev,noexec,relatime,size=2G  0 0
```

References:

1. https://www.freedesktop.org/wiki/Software/systemd/APIFileSystems/
2. https://www.freedesktop.org/software/systemd/man/systemd-fstab-generator.html
3. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.2.2 Ensure nodev option set on /dev/shm partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `nodev` mount option specifies that the filesystem cannot contain special devices.

Rationale:

Since the `/dev/shm` filesystem is not intended to support devices, set this option to ensure that users cannot attempt to create special devices in `/dev/shm` partitions.

Audit:

- IF - a separate partition exists for `/dev/shm`, verify that the `nodev` option is set.

```
# findmnt -kn /dev/shm | grep -v 'nodev'

Nothing should be returned
```

Remediation:

- IF - a separate partition exists for `/dev/shm`.

Edit the `/etc/fstab` file and add `nodev` to the fourth field (mounting options) for the `/dev/shm` partition. See the `fstab(5)` manual page for more information.

Example:

```
tmpfs /dev/shm    tmpfs     defaults,rw,nosuid,nodev,noexec,relatime  0 0
```

Run the following command to remount `/dev/shm` with the configured options:

```
# mount -o remount /dev/shm
```

Note: It is recommended to use `tmpfs` as the device/filesystem type as `/dev/shm` is used as shared memory space by applications.

References:

1. CCI-001764
2. NIST SP 800-53 :: CM-7 (2)
3. STIG ID: RHEL-08-040120 | RULE ID: SV-230508r958804 | CAT II
4. STIG ID: RHEL-09-231110 | RULE ID: SV-257863r958804 | CAT II
5. STIG ID: ALMA-09-026530 | RULE ID: SV-269314r1050196 | CAT II

Additional Information:

Some distributions mount `/dev/shm` through other means and require `/dev/shm` to be added to `/etc/fstab` even though it is already being mounted on boot. Others may configure `/dev/shm` in other locations and may override `/etc/fstab` configuration. Consult the documentation appropriate for your distribution.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.2.3 Ensure nosuid option set on /dev/shm partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `nosuid` mount option specifies that the filesystem cannot contain `setuid` files.

Rationale:

Setting this option on a file system prevents users from introducing privileged programs onto the system and allowing non-root users to execute them.

Audit:

- IF - a separate partition exists for `/dev/shm`, verify that the `nosuid` option is set.

```
# findmnt -kn /dev/shm | grep -v 'nosuid'

Nothing should be returned
```

Remediation:

- IF - a separate partition exists for `/dev/shm`.

Edit the `/etc/fstab` file and add `nosuid` to the fourth field (mounting options) for the `/dev/shm` partition. See the `fstab(5)` manual page for more information.

Example:

```
tmpfs /dev/shm    tmpfs     defaults,rw,nosuid,nodev,noexec,relatime  0 0
```

Run the following command to remount `/dev/shm` with the configured options:

```
# mount -o remount /dev/shm
```

Note: It is recommended to use `tmpfs` as the device/filesystem type as `/dev/shm` is used as shared memory space by applications.

References:

1. CCI-001764
2. NIST SP 800-53 :: CM-7 (2)
3. STIG ID: RHEL-08-040121 | RULE ID: SV-230509r958804 | CAT II
4. STIG ID: RHEL-09-231120 | RULE ID: SV-257865r1044946 | CAT II
5. STIG ID: ALMA-09-026750 | RULE ID: SV-269316r1050198 | CAT II

Additional Information:

Some distributions mount `/dev/shm` through other means and require `/dev/shm` to be added to `/etc/fstab` even though it is already being mounted on boot. Others may configure `/dev/shm` in other locations and may override `/etc/fstab` configuration. Consult the documentation appropriate for your distribution.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.2.4 Ensure noexec option set on /dev/shm partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `noexec` mount option specifies that the filesystem cannot contain executable binaries.

Rationale:

Setting this option on a file system prevents users from executing programs from shared memory. This deters users from introducing potentially malicious software on the system.

Audit:

- IF - a separate partition exists for `/dev/shm`, verify that the `noexec` option is set.

```
# findmnt -kn /dev/shm | grep -v 'noexec'

Nothing should be returned
```

Remediation:

- IF - a separate partition exists for `/dev/shm`.

Edit the `/etc/fstab` file and add `noexec` to the fourth field (mounting options) for the `/dev/shm` partition.

Example:

```
tmpfs /dev/shm    tmpfs     defaults,rw,nosuid,nodev,noexec,relatime  0 0
```

Run the following command to remount `/dev/shm` with the configured options:

```
# mount -o remount /dev/shm
```

Note: It is recommended to use `tmpfs` as the device/filesystem type as `/dev/shm` is used as shared memory space by applications.

References:

1. CCI-001764
2. NIST SP 800-53 :: CM-7 (2)
3. STIG ID: RHEL-08-040122 | RULE ID: SV-230510r958804 | CAT II
4. STIG ID: RHEL-09-231115 | RULE ID: SV-257864r958804 | CAT II
5. STIG ID: ALMA-09-026640 | RULE ID: SV-269315r1050197 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.3 Configure /home

Please note that home directories can be mounted anywhere and are not necessarily restricted to `/home`, nor restricted to a single location, nor is the name restricted in any way.

Finding user home directories can be done by looking in `/etc/passwd`, looking over the mounted file systems with `mount` or querying the relevant database with `getent`.

The following script can be run to find user's home directories:

```
#!/usr/bin/env bash

{
 l_valid_shells="^($(awk -F\/ '$NF != "nologin" {print}' /etc/shells | sed -
rn '/^\//{s,/,\\\\/,g;p}' | paste -s -d '|' - ))$"
 awk -v pat="$l_valid_shells" -F:
'($1!~/^(root|halt|sync|shutdown|nfsnobody)$/ && ($3>='"$(awk
'/^\s*UID_MIN/{print $2}' /etc/login.defs)"' || $3 != 65534) && $(NF) ~ pat)
{print $1 " - " $6}' /etc/passwd
}
```

1.1.2.3.1 Ensure separate partition exists for /home (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The `/home` directory is used to support disk storage needs of local users.

Rationale:

The default installation only creates a single `/` partition. Since the `/home` directory contains user generated data, there is a risk of resource exhaustion. It will essentially have the whole disk available to fill up and impact the system as a whole. In addition, other operations on the system could fill up the disk unrelated to `/home` and impact all local users.

Configuring `/home` as its own file system allows an administrator to set additional mount options such as `noexec/nosuid/nodev`. These options limit an attacker's ability to create exploits on the system. In the case of `/home` options such as `usrquota/grpquota` may be considered to limit the impact that users can have on each other with regards to disk resource exhaustion. Other options allow for specific behavior. See `man mount` for exact details regarding filesystem-independent and filesystem-specific options.

As `/home` contains user data, care should be taken to ensure the security and integrity of the data and mount point.

Impact:

Resizing filesystems is a common activity in cloud-hosted servers. Separate filesystem partitions may prevent successful resizing or may require the installation of additional tools solely for the purpose of resizing operations. The use of these additional tools may introduce their own security considerations.

Audit:

Run the following command and verify output shows `/home` is mounted:

```
# findmnt -kn /home

/home   /dev/sdb  ext4  rw,nosuid,nodev,relatime,seclabel
```

Remediation:

For new installations, during installation create a custom partition setup and specify a separate partition for `/home`.

For systems that were previously installed, create a new partition and configure `/etc/fstab` as appropriate.

References:

1. AJ Lewis, "LVM HOWTO", http://tldp.org/HOWTO/LVM-HOWTO/
2. NIST SP 800-53 Rev. 5: CM-7

Additional Information:

When modifying `/home` it is advisable to bring the system to emergency mode (so auditd is not running), rename the existing directory, mount the new file system, and migrate the data over before returning to multi-user mode.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.3.2 Ensure nodev option set on /home partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `nodev` mount option specifies that the filesystem cannot contain special devices.

Rationale:

Since the `/home` filesystem is not intended to support devices, set this option to ensure that users cannot create a block or character special devices in `/home`.

Audit:

- IF - a separate partition exists for `/home`, verify that the `nodev` option is set.

Run the following command to verify that the `nodev` mount option is set.

Example:

```
# findmnt -kn /home | grep -v nodev
```

Nothing should be returned

Remediation:

- IF - a separate partition exists for `/home`.

Edit the `/etc/fstab` file and add `nodev` to the fourth field (mounting options) for the `/home` partition.

Example:

```
<device> /home    <fstype>     defaults,rw,nosuid,nodev,relatime  0 0
```

Run the following command to remount `/home` with the configured options:

```
# mount -o remount /home
```

References:

1. See the fstab(5) manual page for more information.
2. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.3.3 Ensure nosuid option set on /home partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `nosuid` mount option specifies that the filesystem cannot contain `setuid` files.

Rationale:

Since the `/home` filesystem is only intended for user file storage, set this option to ensure that users cannot create `setuid` files in `/home`.

Audit:

- IF - a separate partition exists for `/home`, verify that the `nosuid` option is set.

Run the following command to verify that the `nosuid` mount option is set.

Example:

```
# findmnt -kn /home | grep -v nosuid
```

Nothing should be returned

Remediation:

- IF - a separate partition exists for `/home`.

Edit the `/etc/fstab` file and add `nosuid` to the fourth field (mounting options) for the `/home` partition.

Example:

```
<device> /home    <fstype>     defaults,rw,nosuid,nodev,relatime  0 0
```

Run the following command to remount `/home` with the configured options:

```
# mount -o remount /home
```

References:

1. See the fstab(5) manual page for more information.
2. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.4 Configure /var

The `/var` directory is used by daemons and other system services to temporarily store dynamic data. Some directories created by these processes may be world-writable.

1.1.2.4.1 Ensure separate partition exists for /var (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The `/var` directory is used by daemons and other system services to temporarily store dynamic data. Some directories created by these processes may be world-writable.

Rationale:

The reasoning for mounting `/var` on a separate partition is as follows.

The default installation only creates a single `/` partition. Since the `/var` directory may contain world writable files and directories, there is a risk of resource exhaustion. It will essentially have the whole disk available to fill up and impact the system. In addition, other operations on the system could fill up the disk unrelated to `/var` and cause unintended behavior across the system as the disk is full. See `man auditd.conf` for details.

Configuring `/var` as its own file system allows an administrator to set additional mount options such as `noexec/nosuid/nodev`. These options limit an attacker's ability to create exploits on the system. Other options allow for specific behavior. See `man mount` for exact details regarding filesystem-independent and filesystem-specific options.

An example of exploiting `/var` may be an attacker establishing a hard-link to a system `setuid` program and waiting for it to be updated. Once the program is updated, the hard-link can be broken and the attacker would have their own copy of the program. If the program happened to have a security vulnerability, the attacker could continue to exploit the known flaw.

Impact:

Resizing filesystems is a common activity in cloud-hosted servers. Separate filesystem partitions may prevent successful resizing or may require the installation of additional tools solely for the purpose of resizing operations. The use of these additional tools may introduce their own security considerations.

Audit:

Run the following command and verify output shows `/var` is mounted.

Example:

```
# findmnt -kn /var

/var  /dev/sdb  ext4   rw,nosuid,nodev,relatime,seclabel
```

Remediation:

For new installations, during installation create a custom partition setup and specify a separate partition for `/var`.

For systems that were previously installed, create a new partition and configure `/etc/fstab` as appropriate.

References:

1. AJ Lewis, "LVM HOWTO", http://tldp.org/HOWTO/LVM-HOWTO/
2. NIST SP 800-53 Rev. 5: CM-7
3. RHEL 8 STIG Vul ID: V-244529
4. RHEL 8 STIG Rule ID: SV-244529r902737

Additional Information:

When modifying `/var` it is advisable to bring the system to emergency mode (so auditd is not running), rename the existing directory, mount the new file system, and migrate the data over before returning to multi-user mode.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.4.2 Ensure nodev option set on /var partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `nodev` mount option specifies that the filesystem cannot contain special devices.

Rationale:

Since the `/var` filesystem is not intended to support devices, set this option to ensure that users cannot create a block or character special devices in `/var`.

Audit:

- IF - a separate partition exists for `/var`, verify that the `nodev` option is set.

Run the following command to verify that the `nodev` mount option is set.

Example:

```
# findmnt -kn /var | grep -v nodev
```

Nothing should be returned

Remediation:

- IF - a separate partition exists for `/var`.

Edit the `/etc/fstab` file and add `nodev` to the fourth field (mounting options) for the `/var` partition.

Example:

```
<device> /var    <fstype>     defaults,rw,nosuid,nodev,relatime  0 0
```

Run the following command to remount `/var` with the configured options:

```
# mount -o remount /var
```

References:

1. See the fstab(5) manual page for more information.
2. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.4.3 Ensure nosuid option set on /var partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `nosuid` mount option specifies that the filesystem cannot contain `setuid` files.

Rationale:

Since the `/var` filesystem is only intended for variable files such as logs, set this option to ensure that users cannot create `setuid` files in `/var`.

Audit:

- IF - a separate partition exists for `/var`, verify that the `nosuid` option is set.

Run the following command to verify that the `nosuid` mount option is set.

Example:

```
# findmnt -kn /var | grep -v nosuid
```

Nothing should be returned

Remediation:

- IF - a separate partition exists for `/var`.

Edit the `/etc/fstab` file and add `nosuid` to the fourth field (mounting options) for the `/var` partition.

Example:

```
<device> /var    <fstype>     defaults,rw,nosuid,nodev,relatime  0 0
```

Run the following command to remount `/var` with the configured options:

```
# mount -o remount /var
```

References:

1. See the fstab(5) manual page for more information.
2. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.5 Configure /var/tmp

The `/var/tmp` directory is a world-writable directory used for temporary storage by all users and some applications. Temporary files residing in `/var/tmp` are to be preserved between reboots.

1.1.2.5.1 Ensure separate partition exists for /var/tmp (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The `/var/tmp` directory is a world-writable directory used for temporary storage by all users and some applications. Temporary files residing in `/var/tmp` are to be preserved between reboots.

Rationale:

The default installation only creates a single `/` partition. Since the `/var/tmp` directory is world-writable, there is a risk of resource exhaustion. In addition, other operations on the system could fill up the disk unrelated to `/var/tmp` and cause potential disruption to daemons as the disk is full.

Configuring `/var/tmp` as its own file system allows an administrator to set additional mount options such as `noexec/nosuid/nodev`. These options limit an attacker's ability to create exploits on the system.

Impact:

Resizing filesystems is a common activity in cloud-hosted servers. Separate filesystem partitions may prevent successful resizing or may require the installation of additional tools solely for the purpose of resizing operations. The use of these additional tools may introduce their own security considerations.

Audit:

Run the following command and verify output shows `/var/tmp` is mounted.

Example:

```
# findmnt -kn /var/tmp

/var/tmp   /dev/sdb ext4   rw,nosuid,nodev,noexec,relatime,seclabel
```

Remediation:

For new installations, during installation create a custom partition setup and specify a separate partition for `/var/tmp`.

For systems that were previously installed, create a new partition and configure `/etc/fstab` as appropriate.

References:

1. AJ Lewis, "LVM HOWTO", http://tldp.org/HOWTO/LVM-HOWTO/
2. NIST SP 800-53 Rev. 5: CM-7
3. NIST SP 800-53A :: CM-6.1 (iv)
4. RHEL 8 STIG Vul ID: V-244529
5. RHEL 8 STIG Rule ID: SV-244529r902737

Additional Information:

When modifying `/var/tmp` it is advisable to bring the system to emergency mode (so auditd is not running), rename the existing directory, mount the new file system, and migrate the data over before returning to multi-user mode.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.5.2 Ensure nodev option set on /var/tmp partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `nodev` mount option specifies that the filesystem cannot contain special devices.

Rationale:

Since the `/var/tmp` filesystem is not intended to support devices, set this option to ensure that users cannot create a block or character special devices in `/var/tmp`.

Audit:

- IF - a separate partition exists for `/var/tmp`, verify that the `nodev` option is set.

Run the following command to verify that the `nodev` mount option is set.

Example:

```
# findmnt -kn /var/tmp | grep -v nodev

Nothing should be returned
```

Remediation:

- IF - a separate partition exists for `/var/tmp`.

Edit the `/etc/fstab` file and add `nodev` to the fourth field (mounting options) for the `/var/tmp` partition.

Example:

```
<device> /var/tmp    <fstype>     defaults,rw,nosuid,nodev,noexec,relatime  0
0
```

Run the following command to remount `/var/tmp` with the configured options:

```
# mount -o remount /var/tmp
```

References:

1. See the fstab(5) manual page for more information.
2. NIST SP 800-53 Rev. 5: AC-3, MP-2
3. NIST SP 800-53 Revision 5 :: CM-7 (2)
4. RHEL 8 STIG Vul ID: V-230520
5. RHEL 8 STIG Rule ID: SV-230520r854061

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.5.3 Ensure nosuid option set on /var/tmp partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `nosuid` mount option specifies that the filesystem cannot contain `setuid` files.

Rationale:

Since the `/var/tmp` filesystem is only intended for temporary file storage, set this option to ensure that users cannot create `setuid` files in `/var/tmp`.

Audit:

- IF - a separate partition exists for `/var/tmp`, verify that the `nosuid` option is set.

Run the following command to verify that the `nosuid` mount option is set.

Example:

```
# findmnt -kn /var/tmp | grep -v nosuid

Nothing should be returned
```

Remediation:

- IF - a separate partition exists for `/var/tmp`.

Edit the `/etc/fstab` file and add `nosuid` to the fourth field (mounting options) for the `/var/tmp` partition.

Example:

```
<device> /var/tmp    <fstype>     defaults,rw,nosuid,nodev,noexec,relatime  0
0
```

Run the following command to remount `/var/tmp` with the configured options:

```
# mount -o remount /var/tmp
```

References:

1. See the fstab(5) manual page for more information.
2. NIST SP 800-53 Rev. 5: AC-3, MP-2
3. NIST SP 800-53 Revision 5 :: CM-7 (2)
4. RHEL 8 STIG Vul ID: V-230521
5. RHEL 8 STIG STIG ID: RHEL-08-040133

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.5.4 Ensure noexec option set on /var/tmp partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `noexec` mount option specifies that the filesystem cannot contain executable binaries.

Rationale:

Since the `/var/tmp` filesystem is only intended for temporary file storage, set this option to ensure that users cannot run executable binaries from `/var/tmp`.

Audit:

- IF - a separate partition exists for `/var/tmp`, verify that the `noexec` option is set.

Run the following command to verify that the `noexec` mount option is set.

Example:

```
# findmnt -kn /var/tmp | grep -v noexec

Nothing should be returned
```

Remediation:

- IF - a separate partition exists for `/var/tmp`.

Edit the `/etc/fstab` file and add `noexec` to the fourth field (mounting options) for the `/var/tmp` partition.

Example:

```
<device> /var/tmp    <fstype>     defaults,rw,nosuid,nodev,noexec,relatime  0
0
```

Run the following command to remount `/var/tmp` with the configured options:

```
# mount -o remount /var/tmp
```

References:

1. See the fstab(5) manual page for more information.
2. NIST SP 800-53 Rev. 5: AC-3, MP-2
3. NIST SP 800-53 Revision 5 :: CM-7 (2)
4. RHEL 8 STIG Vul ID: V-230522
5. RHEL 8 STIG Rule ID: SV-230522r854063

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.6 Configure /var/log

The `/var/log` directory is used by system services to store log data.

1.1.2.6.1 Ensure separate partition exists for /var/log (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The `/var/log` directory is used by system services to store log data.

Rationale:

The default installation only creates a single `/` partition. Since the `/var/log` directory contains log files which can grow quite large, there is a risk of resource exhaustion. It will essentially have the whole disk available to fill up and impact the system as a whole.

Configuring `/var/log` as its own file system allows an administrator to set additional mount options such as `noexec/nosuid/nodev`. These options limit an attackers ability to create exploits on the system. Other options allow for specific behavior. See `man mount` for exact details regarding filesystem-independent and filesystem-specific options.

As `/var/log` contains log files, care should be taken to ensure the security and integrity of the data and mount point.

Impact:

Resizing filesystems is a common activity in cloud-hosted servers. Separate filesystem partitions may prevent successful resizing, or may require the installation of additional tools solely for the purpose of resizing operations. The use of these additional tools may introduce their own security considerations.

Audit:

Run the following command and verify output shows `/var/log` is mounted:

```
# findmnt -kn /var/log

/var/log /dev/sdb ext4   rw,nosuid,nodev,noexec,relatime,seclabel
```

Remediation:

For new installations, during installation create a custom partition setup and specify a separate partition for `/var/log` .

For systems that were previously installed, create a new partition and configure `/etc/fstab` as appropriate.

References:

1. AJ Lewis, "LVM HOWTO", http://tldp.org/HOWTO/LVM-HOWTO/
2. NIST SP 800-53 Rev. 5:: CM-6 b CM-7
3. NIST SP 800-53A :: CM-6.1 (iv)
4. RHEL 8 STIG Vul ID: V-230293
5. RHEL 8 STIG Rule ID: SV-230293r902720

Additional Information:

When modifying `/var/log` it is advisable to bring the system to emergency mode (so auditd is not running), rename the existing directory, mount the new file system, and migrate the data over before returning to multiuser mode.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 Ensure Adequate Audit Log Storage Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v7	6.4 Ensure adequate storage for logs Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●

1.1.2.6.2 Ensure nodev option set on /var/log partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `nodev` mount option specifies that the filesystem cannot contain special devices.

Rationale:

Since the `/var/log` filesystem is not intended to support devices, set this option to ensure that users cannot create a block or character special devices in `/var/log`.

Audit:

- IF - a separate partition exists for `/var/log`, verify that the `nodev` option is set.

Run the following command to verify that the `nodev` mount option is set.

Example:

```
# findmnt -kn /var/log | grep -v nodev

Nothing should be returned
```

Remediation:

- IF - a separate partition exists for `/var/log`.

Edit the `/etc/fstab` file and add `nodev` to the fourth field (mounting options) for the `/var/log` partition.

Example:

```
<device> /var/log    <fstype>     defaults,rw,nosuid,nodev,noexec,relatime  0
0
```

Run the following command to remount `/var/log` with the configured options:

```
# mount -o remount /var/log
```

References:

1. See the fstab(5) manual page for more information.
2. NIST SP 800-53 Rev. 5: AC-3, MP-2
3. NIST SP 800-53 Revision 5 :: CM-7 (2)
4. RHEL 8 STIG Vul ID: V-230514
5. RHEL 8 STIG Rule ID: SV-230514r854055

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.6.3 Ensure nosuid option set on /var/log partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `nosuid` mount option specifies that the filesystem cannot contain `setuid` files.

Rationale:

Since the `/var/log` filesystem is only intended for log files, set this option to ensure that users cannot create `setuid` files in `/var/log`.

Audit:

- IF - a separate partition exists for `/var/log`, verify that the `nosuid` option is set.

Run the following command to verify that the `nosuid` mount option is set.

Example:

```
# findmnt -kn /var/log | grep -v nosuid

Nothing should be returned
```

Remediation:

- IF - a separate partition exists for `/var/log`.

Edit the `/etc/fstab` file and add `nosuid` to the fourth field (mounting options) for the `/var/log` partition.

Example:

```
<device> /var/log    <fstype>     defaults,rw,nosuid,nodev,noexec,relatime  0
0
```

Run the following command to remount `/var/log` with the configured options:

```
# mount -o remount /var/log
```

References:

1. See the fstab(5) manual page for more information.
2. NIST SP 800-53 Rev. 5: AC-3, MP-2
3. NIST SP 800-53 Revision 5 :: CM-7 (2)
4. RHEL 8 STIG Vul ID: V-230515
5. RHEL 8 STIG Rule ID: SV-230515r854056

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.6.4 Ensure noexec option set on /var/log partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `noexec` mount option specifies that the filesystem cannot contain executable binaries.

Rationale:

Since the `/var/log` filesystem is only intended for log files, set this option to ensure that users cannot run executable binaries from `/var/log`.

Audit:

- IF - a separate partition exists for `/var/log`, verify that the `noexec` option is set.

Run the following command to verify that the `noexec` mount option is set.

Example:

```
# findmnt -kn /var/log | grep -v noexec

Nothing should be returned
```

Remediation:

- IF - a separate partition exists for `/var/log`.

Edit the `/etc/fstab` file and add `noexec` to the fourth field (mounting options) for the `/var/log` partition.

Example:

```
<device> /var/log    <fstype>     defaults,rw,nosuid,nodev,noexec,relatime  0
0
```

Run the following command to remount `/var/log` with the configured options:

```
# mount -o remount /var/log
```

References:

1. See the fstab(5) manual page for more information.
2. NIST SP 800-53 Rev. 5: AC-3, MP-2
3. NIST SP 800-53 Revision 5 :: CM-7 (2)
4. RHEL 8 STIG Vul ID: V-230516
5. RHEL 8 STIG Rule ID: SV-230516r854057

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.7 Configure /var/log/audit

The auditing daemon, `auditd`, stores log data in the `/var/log/audit` directory.

1.1.2.7.1 Ensure separate partition exists for /var/log/audit (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The auditing daemon, `auditd`, stores log data in the `/var/log/audit` directory.

Rationale:

The default installation only creates a single `/` partition. Since the `/var/log/audit` directory contains the `audit.log` file which can grow quite large, there is a risk of resource exhaustion. It will essentially have the whole disk available to fill up and impact the system as a whole. In addition, other operations on the system could fill up the disk unrelated to `/var/log/audit` and cause `auditd` to trigger its `space_left_action` as the disk is full. See `man auditd.conf` for details.

Configuring `/var/log/audit` as its own file system allows an administrator to set additional mount options such as `noexec/nosuid/nodev`. These options limit an attacker's ability to create exploits on the system. Other options allow for specific behavior. See `man mount` for exact details regarding filesystem-independent and filesystem-specific options.

As `/var/log/audit` contains audit logs, care should be taken to ensure the security and integrity of the data and mount point.

Impact:

Resizing filesystems is a common activity in cloud-hosted servers. Separate filesystem partitions may prevent successful resizing or may require the installation of additional tools solely for the purpose of resizing operations. The use of these additional tools may introduce their own security considerations.

Audit:

Run the following command and verify output shows `/var/log/audit` is mounted:

```
# findmnt -kn /var/log/audit

/var/log/audit /dev/sdb ext4   rw,nosuid,nodev,noexec,relatime,seclabel
```

Remediation:

For new installations, during installation create a custom partition setup and specify a separate partition for `/var/log/audit`.

For systems that were previously installed, create a new partition and configure `/etc/fstab` as appropriate.

References:

1. AJ Lewis, "LVM HOWTO", http://tldp.org/HOWTO/LVM-HOWTO/
2. NIST SP 800-53 Rev. 5: CM-7 CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. RHEL 8 STIG Vul ID: V-230294
5. RHEL 8 STIG Rule ID: SV-230294r627750

Additional Information:

When modifying `/var/log/audit` it is advisable to bring the system to emergency mode (so auditd is not running), rename the existing directory, mount the new file system, and migrate the data over before returning to multi-user mode.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 Ensure Adequate Audit Log Storage Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v7	6.4 Ensure adequate storage for logs Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●

1.1.2.7.2 Ensure nodev option set on /var/log/audit partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `nodev` mount option specifies that the filesystem cannot contain special devices.

Rationale:

Since the `/var/log/audit` filesystem is not intended to support devices, set this option to ensure that users cannot create a block or character special devices in `/var/log/audit`.

Audit:

- IF - a separate partition exists for `/var/log/audit`, verify that the `nodev` option is set.

Run the following command to verify that the `nodev` mount option is set.

Example:

```
# findmnt -kn /var/log/audit | grep -v nodev

Nothing should be returned
```

Remediation:

- IF - a separate partition exists for `/var/log/audit`.

Edit the `/etc/fstab` file and add `nodev` to the fourth field (mounting options) for the `/var/log/audit` partition.

Example:

```
<device> /var/log/audit    <fstype>
defaults,rw,nosuid,nodev,noexec,relatime  0 0
```

Run the following command to remount `/var/log/audit` with the configured options:

```
# mount -o remount /var/log/audit
```

References:

1. See the fstab(5) manual page for more information.
2. NIST SP 800-53 Revision 5 :: CM-7 (2)
3. STIG ID: RHEL-08-040129 | RULE ID: SV-230517r958804 | CAT II
4. STIG ID: RHEL-09-231175 | RULE ID: SV-257876r958804 | CAT II
5. STIG ID: ALMA-09-027190 | RULE ID: SV-269320r1050202 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.7.3 Ensure nosuid option set on /var/log/audit partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `nosuid` mount option specifies that the filesystem cannot contain `setuid` files.

Rationale:

Since the `/var/log/audit` filesystem is only intended for variable files such as logs, set this option to ensure that users cannot create `setuid` files in `/var/log/audit`.

Audit:

- IF - a separate partition exists for `/var/log/audit`, verify that the `nosuid` option is set.

Run the following command to verify that the `nosuid` mount option is set.

Example:

```
# findmnt -kn /var/log/audit | grep -v nosuid

Nothing should be returned
```

Remediation:

- IF - a separate partition exists for `/var/log/audit`.

Edit the `/etc/fstab` file and add `nosuid` to the fourth field (mounting options) for the `/var/log/audit` partition.

Example:

```
<device> /var/log/audit    <fstype>
defaults,rw,nosuid,nodev,noexec,relatime  0 0
```

Run the following command to remount `/var/log/audit` with the configured options:

```
# mount -o remount /var/log/audit
```

References:

1. See the fstab(5) manual page for more information.
2. NIST SP 800-53 Rev. 5: AC-3, MP-2
3. NIST SP 800-53 Revision 5 :: CM-7 (2)
4. STIG ID: RHEL-08-040130 | RULE ID: SV-230518r958804 | CAT II
5. STIG ID: RHEL-09-231170 | RULE ID: SV-257875r958804 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.1.2.7.4 Ensure noexec option set on /var/log/audit partition (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `noexec` mount option specifies that the filesystem cannot contain executable binaries.

Rationale:

Since the `/var/log/audit` filesystem is only intended for audit logs, set this option to ensure that users cannot run executable binaries from `/var/log/audit`.

Audit:

- IF - a separate partition exists for `/var/log/audit`, verify that the `noexec` option is set.

Run the following command to verify that the `noexec` mount option is set.

Example:

```
# findmnt -kn /var/log/audit | grep -v noexec

Nothing should be returned
```

Remediation:

- IF - a separate partition exists for `/var/log/audit`.

Edit the `/etc/fstab` file and add `noexec` to the fourth field (mounting options) for the `/var/log/audit` partition.

Example:

```
<device> /var/log/audit    <fstype>
defaults,rw,nosuid,nodev,noexec,relatime  0 0
```

Run the following command to remount `/var/log/audit` with the configured options:

```
# mount -o remount /var/log/audit
```

References:

1. See the fstab(5) manual page for more information.
2. NIST SP 800-53 Rev. 5: AC-3, MP-2
3. NIST SP 800-53 Revision 5 :: CM-7 (2)
4. STIG ID: RHEL-08-040131 | RULE ID: SV-230519r958804 | CAT II
5. STIG ID: RHEL-09-231165 | RULE ID: SV-257874r958804 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.2 Package Management

Patch management procedures may vary widely between enterprises. Large enterprises may choose to install a local updates server that can be used in place of their distributions servers, whereas a single deployment of a system may prefer to get updates directly. Updates can be performed automatically or manually, depending on the site's policy for patch management. Organizations may prefer to test patches against their environment on a non-production system before rolling out to production.

Outdated software is vulnerable to cyber criminals and hackers. Software updates help reduce the risk to your organization. The release of software update notes often reveal the patched exploitable entry points to the public. Public knowledge of these exploits cans your organization more vulnerable to malicious actors attempting to gain entry to your system's data.

Software updates often offer new and improved features and speed enhancements

For the purpose of this benchmark, the requirement is to ensure that a patch management process is defined and maintained, the specifics of which are left to the organization.

1.2.1 Configure Package Repositories

Patch management procedures may vary widely between enterprises. Large enterprises may choose to install a local updates server that can be used in place of their distributions servers, whereas a single deployment of a system may prefer to get updates directly. Updates can be performed automatically or manually, depending on the site's policy for patch management. Organizations may prefer to test patches against their environment on a non-production system before rolling out to production.

Outdated software is vulnerable to cyber criminals and hackers. Software updates help reduce the risk to your organization. The release of software update notes often reveals the patched exploitable entry points to the public. Public knowledge of these exploits can leave your organization more vulnerable to malicious actors attempting to gain access to your system's data.

Note: Creation of an appropriate patch management policy is left to the organization.

1.2.1.1 Ensure GPG keys are configured (Manual)

Profile Applicability:

- Level 1 - Server

Description:

The RPM Package Manager implements GPG key signing to verify package integrity during and after installation.

Rationale:

It is important to ensure that updates are obtained from a valid source to protect against spoofing that could lead to the inadvertent installation of malware on the system. To this end, verify that GPG keys are configured correctly for your system.

Audit:

List all GPG key URLs

Each repository should have a `gpgkey` with a URL pointing to the location of the GPG key, either local or remote.

```
# grep -r gpgkey /etc/yum.repos.d/* /etc/dnf/dnf.conf
```

List installed GPG keys

Run the following script to list the currently installed keys. These are the active keys used for verification and installation of RPMs. The packages are fake, they are generated on the fly by `dnf` or `rpm` during the import of keys from the URL specified in the repository configuration.

Example:

```
# for RPM_PACKAGE in $(rpm -q gpg-pubkey); do
  echo "RPM: ${RPM_PACKAGE}"
  RPM_SUMMARY=$(rpm -q --queryformat "%{SUMMARY}" "${RPM_PACKAGE}")
  RPM_PACKAGER=$(rpm -q --queryformat "%{PACKAGER}" "${RPM_PACKAGE}")
  RPM_DATE=$(date +%Y-%m-%d -d "1970-1-1+$((0x$(rpm -q --queryformat
"%{RELEASE}" "${RPM_PACKAGE}") ))sec")
  RPM_KEY_ID=$(rpm -q --queryformat "%{VERSION}" "${RPM_PACKAGE}")
  echo "Packager: ${RPM_PACKAGER}
Summary: ${RPM_SUMMARY}
Creation date: ${RPM_DATE}
Key ID: ${RPM_KEY_ID}
"
done
```

Example output:

```
RPM: gpg-pubkey-9db62fb1-59920156
Packager: Fedora 28 (28) <fedora-28@fedoraproject.org>
Summary: gpg(Fedora 28 (28) <fedora-28@fedoraproject.org>)
Creation date: 2017-08-14
Key ID: 9db62fb1

RPM: gpg-pubkey-09eab3f2-595fbba3
Packager: RPM Fusion free repository for Fedora (28) <rpmfusion-
buildsys@lists.rpmfusion.org>
Summary: gpg(RPM Fusion free repository for Fedora (28) <rpmfusion-
buildsys@lists.rpmfusion.org>)
Creation date: 2017-07-07
Key ID: 09eab3f2
```

The format of the package (`gpg-pubkey-9db62fb1-59920156`) is important to understand for verification. Using the above example, it consists of three parts:

1. The general prefix name for all imported GPG keys: `gpg-pubkey-`
2. The version, which is the GPG key ID: `9db62fb1`
3. The release is the date of the key in UNIX timestamp in hexadecimal: `59920156`

With both the date and the GPG key ID, check the relevant repositories public key page to confirm that the keys are indeed correct.

Query locally available GPG keys

Repositories that store their respective GPG keys on disk should do so in `/etc/pki/rpm-gpg/`. These keys are available for immediate import either when `dnf` is asked to install a relevant package from the repository or when an administrator imports the key directly with the `rpm --import` command.

To find where these keys come from run:

```
# for PACKAGE in $(find /etc/pki/rpm-gpg/ -type f -exec rpm -qf {} \; | sort
-u); do rpm -q --queryformat "%{NAME}-%{VERSION} %{PACKAGER} %{SUMMARY}\\n"
"${PACKAGE}"; done
```

Remediation:

Update your package manager GPG keys in accordance with site policy.

References:

1. NIST SP 800-53 Rev. 5: SI-2

Additional Information:

Fedora public keys: https://getfedora.org/security/

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.3 Perform Automated Operating System Patch Management Perform operating system updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.	●	●	●
v8	7.4 Perform Automated Application Patch Management Perform application updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.	●	●	●
v7	3.4 Deploy Automated Operating System Patch Management Tools Deploy automated software update tools in order to ensure that the operating systems are running the most recent security updates provided by the software vendor.	●	●	●
v7	3.5 Deploy Automated Software Patch Management Tools Deploy automated software update tools in order to ensure that third-party software on all systems is running the most recent security updates provided by the software vendor.	●	●	●

1.2.1.2 Ensure gpgcheck is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `gpgcheck` option controls verifying package signatures after download. This option is configurable as a global option in the main section of `/etc/dnf/dnf.conf` and a per repository option in individual files in the `/etc/yum.repos.d/*` directory.

The option is enabled if `gpgcheck` is set to `1`, `true`, or `yes`. The option is disabled if `gpgcheck` is set to `0`, `false`, or `no`. If an invalid option is set, e.g. `gpgcheck=2`, the global option will be used.

Settings in files in the `/etc/yum.repos.d/` directory take precedence over the global configuration.

Rationale:

It is important to ensure that an RPM's package signature is always checked prior to installation to ensure that the software is obtained from a trusted source.

Audit:

Run the following command and verify that global configuration for `gpgcheck` is enabled:

```
# grep -Pi -- '^\h*gpgcheck\h*=\h*(1|true|yes)\b' /etc/dnf/dnf.conf
```

Verify the output is: `gpgcheck=1`, `gpgcheck=true`, or `gpgcheck=yes`.

Example output:

```
gpgcheck=1
```

Run the following command to verify `gpgcheck` is not disabled in a file in the `/etc/yum.repos.d/` directory:

```
# grep -Pris -- '^\h*gpgcheck\h*=\h*(0|[2-9]|[1-9][0-9]+|false|no)\b'
/etc/yum.repos.d/
```

Nothing should be returned

Remediation:

Edit `/etc/dnf/dnf.conf` and set `gpgcheck=1` in the `[main]` section.

Example

```
[main]
gpgcheck=1
```

Edit any failing files in `/etc/yum.repos.d/*` and set all instances starting with `gpgcheck` to `1`.

Example:

```
# find /etc/yum.repos.d/ -name "*.repo" -exec echo "Checking:" {} \; -exec
sed -i 's/^gpgcheck\s*=\s*.*/gpgcheck=1/' {} \;
```

Default Value:

gpgcheck=1

References:

1. NIST SP 800-53 Revision 5 :: CM-14
2. STIG ID: RHEL-08-010370 | RULE ID: SV-230264r1017377 | CAT I
3. STIG ID: RHEL-09-214015 | RULE ID: SV-257820r1044878 | CAT I
4. STIG ID: RHEL-09-214025 | RULE ID: SV-257822r1044880 | CAT I

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.3 Perform Automated Operating System Patch Management Perform operating system updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.	●	●	●
v7	3.4 Deploy Automated Operating System Patch Management Tools Deploy automated software update tools in order to ensure that the operating systems are running the most recent security updates provided by the software vendor.	●	●	●

1.2.1.3 Ensure repo_gpgcheck is globally activated (Manual)

Profile Applicability:

- Level 2 - Server

Description:

The `repo_gpgcheck` option, found in the main section of the `/etc/dnf/dnf.conf` and individual `/etc/yum.repos.d/*` files, will perform a GPG signature check on the repodata.

Rationale:

It is important to ensure that the repository data signature is always checked prior to installation to ensure that the software is not tampered with in any way.

Impact:

Not all repositories, notably RedHat, support `repo_gpgcheck`. Take care to set this value to false (default) for particular repositories that do not support it. If enabled on repositories that do not support `repo_gpgcheck` installation of packages will fail.

Research is required by the user to determine which repositories are configured on the local system and, from that list, which support `repo_gpgcheck`.

Audit:

Global configuration

Run the following command:

```
# grep ^repo_gpgcheck /etc/dnf/dnf.conf
```

Verify that `repo_gpgcheck` is set to `1`

Per repository configuration

Configuration in `/etc/yum.repos.d/` takes precedence over the global configuration.

As an example, to list all the configured repositories, excluding "fedoraproject.org", that specifically disables `repo_gpgcheck`, run the following command:

```
# REPO_URL="fedoraproject.org"
# for repo in $(grep -l "repo_gpgcheck=0" /etc/yum.repos.d/* ); do
  if ! grep "${REPO_URL}" "${repo}" &>/dev/null; then
    echo "${repo}"
  fi
done
```

Per the research that was done on which repositories do not support `repo_gpgcheck`, change the `REPO_URL` variable and run the test.

Remediation:

Global configuration

Edit `/etc/dnf/dnf.conf` and set `repo_gpgcheck=1` in the `[main]` section.

Example:

```
[main]
repo_gpgcheck=1
```

Per repository configuration

First check that the particular repository support GPG checking on the repodata.

Edit any failing files in `/etc/yum.repos.d/*` and set all instances starting with `repo_gpgcheck` to `1`.

References:

1. NIST SP 800-53 Rev. 5: SI-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.3 Perform Automated Operating System Patch Management Perform operating system updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.	●	●	●
v7	3.4 Deploy Automated Operating System Patch Management Tools Deploy automated software update tools in order to ensure that the operating systems are running the most recent security updates provided by the software vendor.	●	●	●

1.2.1.4 Ensure package manager repositories are configured (Manual)

Profile Applicability:

- Level 1 - Server

Description:

Systems need to have the respective package manager repositories configured to ensure that the system is able to receive the latest patches and updates.

Rationale:

If a system's package repositories are misconfigured, important patches may not be identified or a rogue repository could introduce compromised software.

Audit:

Run the following command to verify repositories are configured correctly. The output may vary depending on which repositories are currently configured on the system.

Example:

```
# dnf repolist
Last metadata expiration check: 1:00:00 ago on Mon 1 Jan 2021 00:00:00 BST.
repo id         repo name                          status
*fedora         Fedora 28 - x86_64                 57,327
*updates        Fedora 28 - x86_64 - Updates       22,133
```

For the repositories in use, inspect the configuration file to ensure all settings are correctly applied according to site policy.

Example:

Depending on the distribution being used the repo file name might differ.

```
cat /etc/yum.repos.d/*.repo
```

Remediation:

Configure your package manager repositories according to site policy.

References:

1. NIST SP 800-53 Rev. 5: SI-2

Additional Information:

For further information about Fedora repositories see: https://docs.fedoraproject.org/en-US/quick-docs/repositories/

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.3 Perform Automated Operating System Patch Management Perform operating system updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.	●	●	●
v8	7.4 Perform Automated Application Patch Management Perform application updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.	●	●	●
v7	3.4 Deploy Automated Operating System Patch Management Tools Deploy automated software update tools in order to ensure that the operating systems are running the most recent security updates provided by the software vendor.	●	●	●
v7	3.5 Deploy Automated Software Patch Management Tools Deploy automated software update tools in order to ensure that third-party software on all systems is running the most recent security updates provided by the software vendor.	●	●	●

1.2.1.5 Ensure weak dependencies are configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The RPM packaging specification allows for 3 levels of dependencies to be declared:

- hard dependencies (`Requires` / `Provides`) for packages which must be installed for a minimal installation of the application to function
- weak dependencies (`Recommends` / `Supplements`) for packages which provide additional features, but which are not required for a minimal installation to function
- hints (`Suggests` / `Enhances`) for packages which offer add-ons which might be useful.

Rationale:

Unless a system specifically requires the additional capabilities provides by the weak dependencies, it is recommended that the packages are not installed to reduce the potential attack surface.

Audit:

Run the following command and verify that global configuration for `install_weak_deps` is disabled:

```
# grep -Pi -- '^\h*install_weak_deps\h*=\h*(0|false|no)\b' /etc/dnf/dnf.conf
```

Verify the output one of the following: `install_weak_deps=0`, `install_weak_deps=false`, or `install_weak_deps=no`.

Example output:

```
install_weak_deps=0
```

Note: If no output is returned, this should be considered a failure as the default value is enabled.

Remediation:

Edit `/etc/dnf/dnf.conf` and set `install_weak_deps=0` in the `[main]` section.

```
[main]
install_weak_deps=0
```

Example script:

```
#!/usr/bin/env bash

{
   if grep -Pq '^install_weak_deps' /etc/dnf/dnf.conf; then
      sed -i 's/^install_weak_deps\s*=\s*.*/install_weak_deps=0/'
/etc/dnf/dnf.conf
   else
      printf '%s\n' "" "install_weak_deps=0" >> /etc/dnf/dnf.conf
   fi
}
```

Default Value:

```
install_weak_deps=True
```

References:

1. https://docs.fedoraproject.org/en-US/packaging-guidelines/WeakDependencies/

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

1.2.2 Configure Package Updates

1.2.2.1 Ensure updates, patches, and additional security software are installed (Manual)

Profile Applicability:

- Level 1 - Server

Description:

Security vulnerabilities and functional improvements are regularly addressed through software updates and patches.

Rationale:

Unpatched software can expose systems to known vulnerabilities that may be exploited by attackers. It is recommended that operating system updates be performed on enterprise assets through automated patch management on a monthly, or more frequent, basis.

Audit:

Run the following command and verify there are no updates or patches to install:

```
# dnf check-update
```

Check to make sure no system reboot is required

```
dnf needs-restarting -r
```

Remediation:

Use your package manager to update all packages on the system according to site policy.

The following command will install all available updates:

```
# dnf update
```

Once the update process is complete, verify if reboot is required to load changes.

```
dnf needs-restarting -r
```

References:

1. NIST SP 800-53 Rev. 5: SI-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	7.3 Perform Automated Operating System Patch Management Perform operating system updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.	●	●	●
v8	7.4 Perform Automated Application Patch Management Perform application updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.	●	●	●
v7	3.4 Deploy Automated Operating System Patch Management Tools Deploy automated software update tools in order to ensure that the operating systems are running the most recent security updates provided by the software vendor.	●	●	●
v7	3.5 Deploy Automated Software Patch Management Tools Deploy automated software update tools in order to ensure that third-party software on all systems is running the most recent security updates provided by the software vendor.	●	●	●

1.3 Mandatory Access Control

Mandatory Access Control (MAC) provides an additional layer of access restrictions to processes on top of the base Discretionary Access Controls. By restricting how processes can access files and resources on a system the potential impact from vulnerabilities in the processes can be reduced.

Impact: Mandatory Access Control limits the capabilities of applications and daemons on a system, while this can prevent unauthorized access the configuration of MAC can be complex and difficult to implement correctly preventing legitimate access from occurring.

1.3.1 Configure SELinux

SELinux implements Mandatory Access Control (MAC). Every process and system resource has a special security label called an SELinux context. An SELinux context, sometimes referred to as an SELinux label, is an identifier which abstracts away the system-level details and focuses on the security properties of the entity. Not only does this provide a consistent way of referencing objects in the SELinux policy, but it also removes any ambiguity that can be found in other identification methods. For example, a file can have multiple valid path names on a system that makes use of bind mounts.

The SELinux policy uses these contexts in a series of rules which define how processes can interact with each other and the various system resources. By default, the policy does not allow any interaction unless a rule explicitly grants access.

In Fedora Family Linux distributions, system services are controlled by the systemd daemon; systemd starts and stops all services, and users and processes communicate with systemd using the systemctl utility. The systemd daemon can consult the SELinux policy and check the label of the calling process and the label of the unit file that the caller tries to manage, and then ask SELinux whether or not the caller is allowed the access. This approach strengthens access control to critical system capabilities, which include starting and stopping system services.

This automatically limits the damage that the software can do to files accessible by the calling user. The user does not need to take any action to gain this benefit. For an action to occur, both the traditional DAC permissions must be satisfied as well as the SELinux MAC rules. The action will not be allowed if either one of these models does not permit the action. In this way, SELinux rules can only make a system's permissions more restrictive and secure. SELinux requires a complex policy to allow all the actions required of a system under normal operation.

Two such policies have been designed for use with Fedora Family Linux distributions and are included with the system:

- `targeted` - Targeted processes run in their own domain, called a confined domain. In a confined domain, the files that a targeted process has access to are limited. If a confined process is compromised by an attacker, the attacker's access to resources and the possible damage they can do is also limited. SELinux denies access to these resources and logs the denial.
- `mls` - Implements Multi-Level Security (MLS), which introduces even more kinds of labels (sensitivity and category) and rules that govern access based on these.

This section provides guidance for the configuration of the `targeted` policy.

Note:

- Remember that SELinux policy rules are checked after DAC rules. SELinux policy rules are not used if DAC rules deny access first, which means that no SELinux denial is logged if the traditional DAC rules prevent the access.
- This section only applies if SELinux is in use on the system. Additional Mandatory Access Control systems exist.
- To avoid incorrect SELinux labeling and subsequent problems, ensure that you start services using a systemctl start command.

References:

- NSA SELinux resources:
  - https://www.nsa.gov/Research/Technical-Papers-Brochures/smdsearch14229/selinux
- Fedora SELinux resources:
  - Getting started with SELinux: https://docs.fedoraproject.org/en-US/quick-docs/getting-started-with-selinux
  - User Guide: https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/8/html-single/using_selinux/index
- SELinux Project web page and wiki:
  - http://www.selinuxproject.org

1.3.1.1 Ensure SELinux is installed (Automated)

Profile Applicability:

- Level 2 - Server

Description:

SELinux provides Mandatory Access Control.

Rationale:

Without a Mandatory Access Control system installed only the default Discretionary Access Control system will be available.

Audit:

Verify SELinux is installed.

Run the following command:

```
# rpm -q libselinux

libselinux-<version>
```

Remediation:

Run the following command to install `SELinux`:

```
# dnf install libselinux
```

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.3.1.2 Ensure SELinux policy is configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Configure SELinux to meet or exceed the default targeted policy, which constrains daemons and system software only.

Rationale:

Security configuration requirements vary from site to site. Some sites may mandate a policy that is stricter than the default policy, which is perfectly acceptable. This item is intended to ensure that at least the default recommendations are met.

Audit:

Run the following command to verify SELinux policy is set to `targeted` or `mls`:

```
# grep -Psi -- '^\h*SELINUXTYPE\h*=\h*(targeted|mls)\b' /etc/selinux/config
```

Example output:

```
SELINUXTYPE=targeted
```

Remediation:

Edit `/etc/selinux/config` and add set the SELINUXTYPE line to `targeted` or `mls`:

Example:

```
SELINUXTYPE=targeted
```

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

Additional Information:

If your organization requires stricter policies, ensure that they are set in the `/etc/selinux/config` file.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.3.1.3 Ensure the SELinux mode is not disabled (Automated)

Profile Applicability:

- Level 2 - Server

Description:

SELinux can run in one of three modes: disabled, permissive, or enforcing:

- `Enforcing` - Is the default, and recommended, mode of operation; in enforcing mode SELinux operates normally, enforcing the loaded security policy on the entire system.
- `Permissive` - The system acts as if SELinux is enforcing the loaded security policy, including labeling objects and emitting access denial entries in the logs, but it does not actually deny any operations. While not recommended for production systems, permissive mode can be helpful for SELinux policy development.
- `Disabled` - disables most of the SELinux kernel and application code, leaving the system running without any SELinux protection.

Note: You can set individual domains to permissive mode while the system runs in enforcing mode. For example, to make the httpd_t domain permissive:

```
# semanage permissive -a httpd_t
```

Rationale:

Running SELinux in disabled mode is strongly discouraged; not only does the system avoid enforcing the SELinux policy, it also avoids labeling any persistent objects such as files, making it difficult to enable SELinux in the future.

Audit:

1. Run the following command to verify SELinux's configured mode:

```
# grep -Pi -- '^\h*SELINUX=(enforcing|permissive)\b' /etc/selinux/config
```

Verify the output is:

```
SELINUX=enforcing
-OR-
SELINUX=permissive
```

2. Run the following command to verify SELinux's current running mode:

```
# getenforce
```

Verify the output is:

```
Enforcing
-OR-
Permissive
```

Remediation:

1. Edit `/etc/selinux/config` and update the SELINUX parameter to either `SELINUX=enforcing` or `SELINUX=permissive`:

Example:

```
SELINUX=enforcing
```

2. Update the SELinux running state to either `enforcing` or `permissive`:

If SELinux is currently disabled:

Run the following command to create `/.autorelabel`:

```
# touch /.autorelabel
```

Run the following command to reboot the system:

```
# reboot
```

WARNING: The `autorelabel` may be a long running process and require significant downtime. This should be planed for before executing the reboot!

If SELinux is not currently disabled:

Run one of the following commands to set SELinux's running mode:

- Run the following command to set SELinux running mode to `Enforcing`:

```
# setenforce 1
```

- OR -

- Run the following command to set SELinux running mode to `Permissive`:

```
# setenforce 0
```

References:

1. https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/7/html/selinux_users_and_administrators_guide/sect-security-enhanced_linux-introduction-selinux_modes
2. NIST SP 800-53 :: SC-3
3. NIST SP 800-53A :: SC-3.1 (ii)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.3.1.4 Ensure no unconfined services exist (Manual)

Profile Applicability:

- Level 2 - Server

Description:

Unconfined processes run in unconfined domains

Rationale:

For unconfined processes, SELinux policy rules are applied, but policy rules exist that allow processes running in unconfined domains almost all access. Processes running in unconfined domains fall back to using DAC rules exclusively. If an unconfined process is compromised, SELinux does not prevent an attacker from gaining access to system resources and data, but of course, DAC rules are still used. SELinux is a security enhancement on top of DAC rules – it does not replace them

Impact:

Confining a service that inherently requires unconfined access to function may disrupt its intended operations. This restriction may lead to downtime, degraded performance, or loss in functionality. It is crucial to analyze and adjust SELinux policies in accordance with site security policies and operational requirements.

Audit:

Run the following command and verify no output is produced:

```
# ps -eZ | grep unconfined_service_t
```

Remediation:

Investigate any unconfined processes found during the audit action. If necessary create a customize SELinux policy to allow necessary actions for the service.

Warning: Knowledge about creating and configuring SELinux policies is needed. A Basic example on how to create a policy is included below.

1. Identify the unconfined service: determine the name and process of the service
2. Identify the functionality: determine if the functionality is required for operations
3. Create or add to the custom allow list in the SELinux policy configuration

Example SELinux policy configuration: service_allowlist_policy.te

```
# Example SELinux policy configuration for allowing access to specific
actions and resources for a service

module my_service 1.0;

require {
    type my_service_t;
    type system_resource_t;
    class file { read write execute };
    class dir { read write add_name };
    class tcp_socket name_connect;
}

allow my_service_t system_resource_t:file { read write execute }; # Allow
my_service_t to read, write, and execute files with the system_resource_t
context

allow my_service_t system_resource_t:dir { read write add_name }; # Allow
my_service_t to read and write to directories with the system_resource_t
context

allow my_service_t system_resource_t:tcp_socket name_connect; # Allow
my_service_t to establish TCP connections
```

4. Compile the policy

```
# checkmodule -M -, -o service_allowlist_policy.mod
service_allowlist_policy.te
```

5. Create the package

```
# semodule_package -o service_allowlist_policy.pp -m
service_allowlist_policy.mod
```

6. Load the policy

```
# semodule -i service_allowlist_policy.pp
```

7. Apply the policy to the service

```
# chcon -t se service_allowlist_policy /path/to/service_binary
```

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2
2. https://nb.fedorapeople.org/cvsfedora/web/html/docs/selinux-guide/f10/en-US/sect-Security-Enhanced_Linux-Targeted_Policy-Unconfined_Processes.html
3. https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/9/html/using_selinux/managing-confined-and-unconfined-users_using-selinux
4. https://access.redhat.com/documentation/id-id/red_hat_enterprise_linux/9/pdf/using_selinux/red_hat_enterprise_linux-9-using_selinux-en-us.pdf

Additional Information:

Occasionally certain daemons such as backup or centralized management software may require running unconfined. Any such software should be carefully analyzed and documented before such an exception is made.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.3.1.5 Ensure the MCS Translation Service (mcstrans) is not installed (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `mcstransd` daemon provides category label information to client processes requesting information. The label translations are defined in `/etc/selinux/targeted/setrans.conf`

Rationale:

Since this service is not used very often, remove it to reduce the amount of potentially vulnerable code running on the system.

Audit:

Run the following command and verify `mcstrans` is not installed.

```
# rpm -q mcstrans

package mcstrans is not installed
```

Remediation:

Run the following command to uninstall `mcstrans`:

```
# dnf remove mcstrans
```

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

1.3.1.6 Ensure SETroubleshoot is not installed (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The SETroubleshoot service notifies desktop users of SELinux denials through a user-friendly interface. The service provides important information around configuration errors, unauthorized intrusions, and other potential errors.

Rationale:

The SETroubleshoot service is an unnecessary daemon to have running on a server, especially if X Windows is disabled.

Audit:

Verify `setroubleshoot` is not installed.

Run the following command:

```
# rpm -q setroubleshoot

package setroubleshoot is not installed
```

Remediation:

Run the following command to uninstall `setroubleshoot`:

```
# dnf remove setroubleshoot
```

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.4 Configure Bootloader

The recommendations in this section focus on securing the bootloader and settings involved in the boot process directly.

1.4.1 Ensure access to bootloader config is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The grub files contain information on boot settings and passwords for unlocking boot options.

Rationale:

Setting the permissions to read and write for root only prevents non-root users from seeing the boot parameters or changing them. Non-root users who read the boot parameters may be able to identify weaknesses in security upon boot and be able to exploit them.

Audit:

Run the following script to verify grub configuration files:

- For Files located in `/boot/efi/EFI/*`: **Note:** This is a vFat filesystem
  - Mode is `0700` or more restrictive
- For Files located in `/boot/grub2/*`:
  - Mode is `0600` or more restrictive
- Owner is the user `root`
- Group owner is group `root`

```
#!/usr/bin/env bash

{
   a_output=() a_output2=()
   file_access_chk()
   {
      a_out=() a_out2=()
      [[ "$(dirname "$l_file")" =~ ^\/boot\/efi\/EFI ]] && l_pmask="0077" ||
l_pmask="0177"
      l_maxperm="$( printf '%o' $(( 0777 & ~$l_pmask )) )"
      if [ $(( $l_mode & $l_pmask )) -gt 0 ]; then
         a_out2+=("   - Is mode \"$l_mode\" and should be mode:
\"$l_maxperm\" or more restrictive")
      else
         a_out+=("   - Is correctly mode: \"$l_mode\" which is mode:
\"$l_maxperm\" or more restrictive")
      fi
      if [ "$l_user" = "root" ]; then
         a_out+=("   - Is correctly owned by user: \"$l_user\"")
      else
         a_out2+=("   - Is owned by user: \"$l_user\" and should be owned by
user: \"root\"")
      fi
      if [ "$l_group" = "root" ]; then
         a_out+=("   - Is correctly group-owned by group: \"$l_user\"")
      else
         a_out2+=("   - Is group-owned by group: \"$l_user\" and should be
group-owned by group: \"root\"")
      fi
      [ "${#a_out[@]}" -gt 0 ] && a_output+=("  - File: \"$l_file\""
"${a_out[@]}" "")
      [ "${#a_out2[@]}" -gt 0 ] && a_output2+=("  - File: \"$l_file\""
"${a_out2[@]}" "")
   }
   while IFS= read -r -d $'\0' l_gfile; do
      while IFS=: read -r l_file l_mode l_user l_group; do
         file_access_chk
      done <<< "$(stat -Lc '%n:%#a:%U:%G' "$l_gfile")"
   done < <(find /boot -type f \( -name 'grub*' -o -name 'user.cfg' \) -
print0)
   if [ "${#a_output2[@]}" -le 0 ]; then
      printf '%s\n' "" "- Audit Result:" "  ** PASS **" "${a_output[@]}" ""
   else
      printf '%s\n' "" "- Audit Result:" "  ** FAIL **" " - Reason(s) for
audit failure:" "${a_output2[@]}"
      [ "${#a_output[@]}" -gt 0 ] && printf '%s\n' "" "- Correctly set:"
"${a_output[@]}" ""
   fi
}
```

Remediation:

Run the following to update the mode, ownership, and group ownership of the grub configuration files:

- IF - Files are located in `/boot/efi/EFI/*` **Note:** This is a vFat filesystem

Edit `/etc/fstab` and add the `fmask=0077`, `uid=0`, and `gid=0` options:

Example:

```
<device> /boot/efi vfat defaults,umask=0027,fmask=0077,uid=0,gid=0 0 0
```

Note: This may require a re-boot to enable the change

- OR -

- IF - Files are located in `/boot/grub2/*`:

Run the following commands to set ownership and permissions on your grub configuration file(s):

```
# [ -f /boot/grub2/grub.cfg ] && chown root:root /boot/grub2/grub.cfg
# [ -f /boot/grub2/grub.cfg ] && chmod u-x,go-rwx /boot/grub2/grub.cfg

# [ -f /boot/grub2/grubenv ] && chown root:root /boot/grub2/grubenv
# [ -f /boot/grub2/grubenv ] && chmod u-x,go-rwx /boot/grub2/grubenv

# [ -f /boot/grub2/user.cfg ] && chown root:root /boot/grub2/user.cfg
# [ -f /boot/grub2/user.cfg ] && chmod u-x,go-rwx /boot/grub2/user.cfg
```

References:

1. NIST SP 800-53 :: CM-6 b
2. NIST SP 800-53A :: CM-6.1 (iv)
3. STIG ID: RHEL-09-212025 | RULE ID: SV-257790r991589 | CAT II
4. STIG ID: RHEL-09-212030 | RULE ID: SV-257791r991589 | CAT II

Additional Information:

This recommendation is designed around the grub bootloader, if LILO or another bootloader is in use in your environment enact equivalent settings.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.5 Configure Additional Process Hardening

1.5.1 Ensure core file size is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`core` - limits the core file size

`hard` - for enforcing hard resource limits. These limits are set by the superuser and enforced by the Kernel. The user cannot raise their requirement of system resources above such values.

Rationale:

Setting a hard limit on core dumps prevents users from overriding the soft variable.

A core dump includes a memory image taken at the time the operating system terminates an application. The memory image could contain sensitive data and is generally useful only for developers trying to debug problems.

Audit:

Run the following command to verify a hard limit for `core` is set to `0` for all users `*`:

```
# grep -Psi -- '^\h*\*\h+hard\h+core\b' /etc/security/limits.conf
/etc/security/limits.d/*
```

Example output:

```
/etc/security/limits.d/60-limits.conf:* hard core 0
```

Verify no line are returned with a value greater than `0`.

Remediation:

1. Run the following command to comment out any entries that include a `hard` value for `core` greater than `0` in `/etc/security/limits.conf` and any file(s) in the `/etc/security/limits.d/` directory.

Example:

```
# sed -ri '/^\s*[^#\n\r]+\s+hard\s+core\s+([1-9][0-9]*)/s/^/# /'
/etc/security/limits.conf  /etc/security/limits.d/*
```

2. Create or edit a file in `/etc/security/limits.d/` and add the following line:

```
* hard core 0
```

Example:

```
# printf '%s\n' "" "* hard core 0" >> /etc/security/limits.d/60-limits.conf
```

Default Value:

None

References:

1. limits.conf(5)
2. CCI-000366
3. NIST SP 800-53 :: CM-6 b
4. NIST SP 800-53A :: CM-6.1 (iv)
5. STIG ID: RHEL-08-010673 | RULE ID: SV-230313r1069304 | CAT II
6. STIG ID: RHEL-09-213095 | RULE ID: SV-257814r991589 | CAT II
7. STIG ID: ALMA-09-044900 | RULE ID: SV-269452r1050335 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

1.5.2 Ensure fs.protected_hardlinks is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`fs.protected_hardlinks` Controls the creation of hard links to files.

By enabling the `fs.protected_hardlinks` kernel parameter, users can no longer create soft or hard links to files they do not own.

Rationale:

Disallowing hardlinks mitigates vulnerabilities based on unsecure file systems accessed by privileged programs. This reduces the risk of an exploitation vector exploiting unsafe use of `open` or `creat`.

Audit:

Verify `fs.protected_hardlinks` is set to `1`.

1. Run the following command to verify `fs.protected_hardlinks` is set to `1` in the running configuration:

```
# sysctl fs.protected_hardlinks
```

Verify output is:

```
fs.protected_hardlinks = 1
```

2. Run the following script to verify `fs.protected_hardlinks = 1` is set in a file being used by systemd sysctl to configure `fs.protected_hardlinks`:

```
#!/usr/bin/env bash

{
   l_parameter_name="fs.protected_hardlinks"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "fs.protected_hardlinks = 1" is set in: "/etc/sysctl.d/60-fs_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
- Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `fs.protected_hardlinks` lines that are not `fs.protected_hardlinks=1`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="fs.protected_hardlinks" l_value="1"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(0|[2-9]|1[0-9]+)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf` and edit or add the following line:

```
fs.protected_hardlinks = 1
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "fs.protected_hardlinks = 1" >> /etc/sysctl.d/60-
fs_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

fs.protected_hardlinks = 0

References:

1. CCI-002165 | CCI-002235
2. NIST SP 800-53 :: AC-3 (4) | NIST SP 800-53 :: AC-6 (10)
3. STIG ID: RHEL-08-010374 | RULE ID: SV-230268r1017086 | CAT II
4. STIG ID: OL08-00-010374 | RULE ID: SV-248578r958702 | CAT II
5. STIG ID: RHEL-09-213030 | RULE ID: SV-257801r958702 | CAT II
6. STIG ID: ALMA-09-007060 | RULE ID: SV-269144r1050026 | CAT II
7. STIG ID: OL09-00-002401 | RULE ID: SV-271740r1091932 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

1.5.3 Ensure fs.protected_symlinks is configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

`fs.protected_symlinks` Controls how the kernel handles symbolic links

By enabling the `fs.protected_symlinks` kernel parameter, symbolic links are permitted to be followed only when outside a sticky world-writable directory, or when the user identifier (UID) of the link and follower match, or when the directory owner matches the symlink's owner.

Rationale:

Disallowing symlinks mitigates vulnerabilities based on unsecure file systems accessed by privileged programs. This reduces the risk of an exploitation vector exploiting unsafe use of `open` or `creat`.

Audit:

Verify `fs.protected_symlinks` is set to `1`.

1. Run the following command to verify `fs.protected_symlinks` is set to `1` in the running configuration:

```
# sysctl fs.protected_symlinks
```

Verify output is:

```
fs.protected_symlinks = 1
```

2. Run the following script to verify `fs.protected_symlinks = 1` is set in a file being used by systemd sysctl to configure `fs.protected_symlinks`:

```
#!/usr/bin/env bash

{
   l_parameter_name="fs.protected_symlinks"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "fs.protected_symlinks = 1" is set in: "/etc/sysctl.d/60-fs_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
- Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `fs.protected_symlinks` lines that are not `fs.protected_symlinks=1`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="fs.protected_symlinks" l_value="1"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(0|[2-9]|1[0-9]+)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf` and edit or add the following line:

```
fs.protected_symlinks = 1
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "fs.protected_symlinks = 1" >> /etc/sysctl.d/60-
fs_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

fs.protected_symlinks = 0

References:

1. CCI-002165 | CCI-002235
2. NIST SP 800-53 :: AC-3 (4) | NIST SP 800-53 :: AC-6 (10)
3. STIG ID: RHEL-08-010374 | RULE ID: SV-230268r1017086 | CAT II
4. STIG ID: OL08-00-010373 | RULE ID: SV-248577r958702 | CAT II
5. STIG ID: RHEL-09-213030 | RULE ID: SV-257801r958702 | CAT II
6. STIG ID: ALMA-09-007060 | RULE ID: SV-269144r1050026 | CAT II
7. STIG ID: OL09-00-002402 | RULE ID: SV-271741r1091935 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

1.5.4 Ensure fs.suid_dumpable is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`fs.suid_dumpable` governs whether a privileged process (with the setuid bit) can generate a core dump, regardless of other configurations.

`fs.suid_dumpable` values:

- `0` (default) - Any process that has changed privilege levels (like SUID programs) or is execute-only will not dump core.
- `1` (debug) - All processes dump core if possible. The core dump is owned by the current user and security is not applied. This is primarily intended for system debugging.
- `2` (suidsafe) - Any binary that normally wouldn't be dumped is dumped, but only if the core_pattern is set to a pipe handler or a fully qualified path. This mode is suitable for administrators debugging in a production environment.

Rationale:

core dumps may contain sensitive in-memory data like password hashes or keys. An attacker could potentially exploit this to gain access to such data.

Audit:

Verify `fs.suid_dumpable` is set to `0`.

1. Run the following command to verify `fs.suid_dumpable` is set to `0` in the running configuration:

```
# sysctl fs.suid_dumpable
```

Verify output is:

```
fs.suid_dumpable = 0
```

2. Run the following script to verify `fs.suid_dumpable = 0` is set in a file being used by systemd sysctl to configure `fs.suid_dumpable`:

```
#!/usr/bin/env bash

{
   l_parameter_name="fs.suid_dumpable"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "fs.suid_dumpable = 0" is set in: "/etc/sysctl.d/60-fs_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `fs.suid_dumpable` lines that are not `fs.suid_dumpable=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="fs.suid_dumpable" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf` and edit or add the following line:

```
fs.suid_dumpable = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "fs.suid_dumpable = 0" >> /etc/sysctl.d/60-fs_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

fs.suid_dumpable = 0

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

1.5.5 Ensure kernel.dmesg_restrict is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`kernel.dmesg_restrict` can be used to configure the Linux kernel and prevent unprivileged users access to information from the kernel's log buffer.

Rationale:

Restricting access to the kernel message buffer limits access to only root. This prevents attackers from gaining additional system information as a non-privileged user.

Audit:

Verify `kernel.dmesg_restrict` is set to `1`.

1. Run the following command to verify `kernel.dmesg_restrict` is set to `1` in the running configuration:

```
# sysctl kernel.dmesg_restrict
```

Verify output is:

```
kernel.dmesg_restrict = 1
```

2. Run the following script to verify `kernel.dmesg_restrict = 1` is set in a file being used by systemd sysctl to configure `kernel.dmesg_restrict`:

```
#!/usr/bin/env bash

{
   l_parameter_name="kernel.dmesg_restrict"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      if [ -n "$l_option_value" ]; then
         [ "$l_file" = "$(readlink -e "$l_ufw_file")" ] && \
         a_output+=(" ** \"$l_file\" is UFW's IPT_SYSCTL file **")
         a_output+=(" - \"$l_parameter_name\" is set to: \"$l_option_value\"
in: \"$l_file\"")
      fi
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "kernel.dmesg_restrict" is set to: "1" in: "/etc/sysctl.d/60-
kernel_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `kernel.dmesg_restrict` lines that are not `kernel.dmesg_restrict=1`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="kernel.dmesg_restrict" l_value="1"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*([01]|[3-9]|1[0-9]+)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf` and edit or add the following line:

```
kernel.dmesg_restrict = 1
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "kernel.dmesg_restrict = 1" >> /etc/sysctl.d/60-
kernel_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all system configuration filles:

```
# sysctl --system
```

Default Value:

kernel.dmesg_restrict = 0

References:

1. CCI-001082 | CCI-001090
2. NIST SP 800-53 :: SC-2 | NIST SP 800-53 :: SC-4
3. NIST SP 800-53A :: SC-2.1 | NIST SP 800-53A :: SC-4.1
4. STIG ID: RHEL-08-010375 | RULE ID: SV-230269r1017087 | CAT III
5. STIG ID: OL08-00-010375 | RULE ID: SV-248579r958524 | CAT III
6. STIG ID: RHEL-09-213010 | RULE ID: SV-257797r958514 | CAT II
7. STIG ID: ALMA-09-041050 | RULE ID: SV-269425r1050308 | CAT II
8. STIG ID: OL09-00-002406 | RULE ID: SV-271745r1091947 | CAT II
9. STIG ID: UBTU-22-213010 | RULE ID: SV-260472r958524 | CAT III
10. STIG ID: UBTU-24-600140 | RULE ID: SV-270749r1067179 | CAT III
11. STIG ID: SLES-15-010375 | RULE ID: SV-255921r958524 | CAT III

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.5.6 Ensure kernel.kptr_restrict is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`kernel.kptr_restrict` sets whether restrictions are placed on exposing kernel addresses via /proc and other interfaces.

- `kptr_restrict = 0` - The address is hashed before printing. (equivalent to %p.)
- `kptr_restrict = 1` - kernel pointers printed using the %pK format specifier will be replaced with `0`'s.
- `kptr_restrict = 2` - kernel pointers printed using %pK will be replaced with `0`'s regardless of privileges.

Rationale:

Masking the kernel symbols in `/proc/kallsyms` reduces the ability of an attacker using them to learn more about what to attack on your system.

Audit:

Verify `kernel.kptr_restrict` is set to a value of: `1` or `2`.

1. Run the following command to verify `kernel.kptr_restrict` is set to a value of: `1` or `2` in the running configuration:

```
# sysctl kernel.kptr_restrict
```

Example output:

```
kernel.kptr_restrict = 2
```

2. Run the following script to verify `kernel.kptr_restrict` is set to a value of: `1` or `2` in a sysctl conf file being used by systemd sysctl:

```
#!/usr/bin/env bash

{
   l_parameter_name="kernel.kptr_restrict"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
- "kernel.kptr_restrict" is set to: "1" in: "/etc/sysctl.d/60-
kernel_sysctl.conf"
```

Note:

- If the `UFW set` value is displayed, and is the correct value, this is considered a passing state. If this value is incorrect, it must be updated in the file shown in the audit script output.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `kernel.kptr_restrict` lines that are not `kernel.kptr_restrict=1` or `kernel.kptr_restrict=2`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="kernel.kptr_restrict" l_value="(1|2)"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(0|[3-9]|[1-9][0-9]+)/s/^/# /'
"$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf` and edit or add the following line:

```
kernel.kptr_restrict = {N}
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "kernel.kptr_restrict = 2" >> /etc/sysctl.d/60-
kernel_sysctl.conf
```

Note: The example uses `kernel.kptr_restrict = 2` but value may be set to `1` or `2`

3. Run the following command to load all system configuration filles:

```
# sysctl --system
```

Default Value:

kernel.kptr_restrict = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040283 | RULE ID: SV-230547r1017309 | CAT II
5. STIG ID: OL08-00-040283 | RULE ID: SV-248891r991589 | CAT II
6. STIG ID: RHEL-09-213025 | RULE ID: SV-257800r1044851 | CAT II
7. STIG ID: ALMA-09-040830 | RULE ID: SV-269423r1050306 | CAT II
8. STIG ID: OL09-00-002408 | RULE ID: SV-271747r1091953 | CAT II
9. STIG ID: SLES-15-010540 | RULE ID: SV-234861r958928 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v7	4.8 Log and Alert on Changes to Administrative Group Membership Configure systems to issue a log entry and alert when an account is added to or removed from any group assigned administrative privileges.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

1.5.7 Ensure kernel.randomize_va_space is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Address space layout randomization (ASLR) is an exploit mitigation technique which randomly arranges the address space of key data areas of a process.

Rationale:

Randomly placing virtual memory regions will make it difficult to write memory page exploits as the memory placement will be consistently shifting.

Audit:

Verify `kernel.randomize_va_space` is set to `2`.

1. Run the following command to verify `kernel.randomize_va_space` is set to `2` in the running configuration:

```
# sysctl kernel.randomize_va_space
```

Verify output is:

```
kernel.randomize_va_space = 2
```

2. Run the following script to verify `kernel.randomize_va_space = 2` is set in a file being used by systemd sysctl to configure `kernel.randomize_va_space`:

```
#!/usr/bin/env bash

{
   l_parameter_name="kernel.randomize_va_space"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      if [ -n "$l_option_value" ]; then
         [ "$l_file" = "$(readlink -e "$l_ufw_file")" ] && \
         a_output+=(" ** \"$l_file\" is UFW's IPT_SYSCTL file **")
         a_output+=(" - \"$l_parameter_name\" is set to: \"$l_option_value\"
in: \"$l_file\"")
      fi
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "kernel.randomize_va_space" is set to: "2" in: "/etc/sysctl.d/60-
kernel_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `kernel.randomize_va_space` lines that are not `kernel.randomize_va_space=2`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="kernel.randomize_va_space" l_value="2"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*([01]|[3-9]|1[0-9]+)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf` and edit or add the following line:

```
kernel.randomize_va_space = 2
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "kernel.randomize_va_space = 2" >> /etc/sysctl.d/60-
kernel_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all system configuration filles:

```
# sysctl --system
```

Default Value:

kernel.randomize_va_space = 2

References:

1. CCI-002824
2. NIST SP 800-53 :: SI-16
3. STIG ID: RHEL-08-010430 | RULE ID: SV-230280r1017093 | CAT II
4. STIG ID: OL08-00-010430 | RULE ID: SV-248594r958928 | CAT II
5. STIG ID: RHEL-09-213070 | RULE ID: SV-257809r1044866 | CAT II
6. STIG ID: ALMA-09-044900 | RULE ID: SV-269452r1050335 | CAT II
7. STIG ID: OL09-00-002423 | RULE ID: SV-271761r1091995 | CAT II
8. STIG ID: UBTU-22-213020 | RULE ID: SV-260474r958928 | CAT II
9. STIG ID: UBTU-24-700310 | RULE ID: SV-270772r1066805 | CAT II
10. STIG ID: SLES-15-010550 | RULE ID: SV-234862r958928 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.5 Enable Anti-Exploitation Features Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.		●	●
v7	8.3 Enable Operating System Anti-Exploitation Features/ Deploy Anti-Exploit Technologies Enable anti-exploitation features such as Data Execution Prevention (DEP) or Address Space Layout Randomization (ASLR) that are available in an operating system or deploy appropriate toolkits that can be configured to apply protection to a broader set of applications and executables.		●	●

1.5.8 Ensure systemd-coredump ProcessSizeMax is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

A core dump is the memory of an executable program. It is generally used to determine why a program aborted. It can also be used to glean confidential information from a core file.

Rationale:

A core dump includes a memory image taken at the time the operating system terminates an application. The memory image could contain sensitive data and is generally useful only for developers trying to debug problems, increasing the risk to the system.

Audit:

Run the following script to verify `systemd-coredump ProcessSizeMax` is set to `0`:

```
#!/usr/bin/env bash

{
   l_analyze_cmd="$(readlink -e /bin/systemd-analyze || \
   readlink -e /usr/bin/systemd-analyze)"
   l_conf_file="systemd/coredump.conf" l_block="Coredump"
   l_option="ProcessSizeMax" l_option_value="" a_output=()
   while IFS= read -r l_file; do
      l_file="${l_file//# /}"
      l_opt="$(awk '/\['"$l_block"'\]/{a=1;next}/\[/{a=0}a' "$l_file" \
      2>/dev/null | grep -Poi '^\h*'"$l_option"'\h*=\h*\H+\b' | tail -n 1)"
         l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_option\" is set to: \"$l_option_value\"" \
      "    in: \"$l_file\"")
   done < <("$l_analyze_cmd" cat-config "$l_conf_file" | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   if [ "${#a_output[@]}" -le "0" ]; then
      l_file="/etc/$l_conf_file"
      l_opt="$(awk '/\['"$l_block"'\]/{a=1;next}/\[/{a=0}a' "$l_file" \
      2>/dev/null | grep -Poim 1 '^(\h*#)?\h*'"$l_option"'\h*=\h*\H+\b')"
      l_option_value="$(cut -d= -f2 <<< "${l_opt//# /}" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - The default value: \"${l_opt//#/}\"" \
      "    is being used in the configuration")
   fi
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "ProcessSizeMax" is set to: "0" in: "/etc/systemd/coredump.conf.d/60-
coredump.conf"
```

Note:

- If multiple lines are returned:
  - The first line includes the value being used by `systemd-coredump`. If this is a correct value, this is considered a passing state.
  - Files that include an incorrect value should be modified to correct or comment out the incorrect value to minimize the potential of the incorrect value being used by `systemd-coredump` due to system configuration changes
- If the default value is displayed, and is the correct value, this is considered a passing state. However, it is recommended to follow the Remediation procedure to mitigate the potential of a system update changing the default value to an incorrect value.
- **SYSTEM FILE PRECEDENCE**
  - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
  - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
  - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files ending in `.conf` in the `/etc/systemd/coredump.conf.d/` directory and comment out or remove all `ProcessSizeMax=` lines in the `[Coredump]` block that are not `ProcessSizeMax=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_block="Coredump" l_option="ProcessSizeMax" l_value="0"
   while IFS= read -r -d $'\0' l_file; do
      awk '/\['"$l_block"'\]/{a=1;next}/\[/{a=0}a' "$l_file" 2>/dev/null | \
      grep -Poi '\h*'"$l_option"'\h*=\h*\H+\b' | \
      grep -Pivq '^\h*'"$l_option"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*[Pp]rocess[Ss]ize[Mm]ax\s*=/s/^/# /' "$l_file"
   done < <(find /etc/systemd/coredump.conf.d/ -type f -name '*.conf' -
print0)
}
```

2. Create or edit a file in the `/etc/systemd/coredump.conf.d` directory ending in `.conf` and edit or add the following line to the `[Coredump]` section:

```
ProcessSizeMax=0
```

Example:

```
#!/usr/bin/env bash

{
   [ ! -d /etc/systemd/coredump.conf.d/ ] && mkdir
/etc/systemd/coredump.conf.d/
   l_file="/etc/systemd/coredump.conf.d/60-coredump.conf"
   if grep -Psq -- '^\h*\[Coredump\]' "$l_file"; then
      sed -ri '/^\s*\[Coredump\]/a ProcessSizeMax=0' "$l_file"
   else
      printf '%s\n' "" "[Coredump]" "ProcessSizeMax=0" >> "$l_file"
   fi
}
```

3. Run the following command to load the updated configuration:

```
# systemctl reload-or-restart systemd-coredump.socket
```

Default Value:

ProcessSizeMax=2G

References:

1. COREDUMP.CONF(5)
2. CCI-000366
3. NIST SP 800-53 :: CM-6 b
4. NIST SP 800-53A :: CM-6.1 (iv)
5. STIG ID: RHEL-08-010675 | RULE ID: SV-230315r1017126 | CAT II
6. STIG ID: OL08-00-010675 | RULE ID: SV-248633r991589 | CAT II
7. STIG ID: RHEL-09-213085 | RULE ID: SV-257812r1051005 | CAT II
8. STIG ID: ALMA-09-011570 | RULE ID: SV-269181r1050063 | CAT II
9. STIG ID: OL09-00-002381 | RULE ID: SV-271729r1091899 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

1.5.9 Ensure systemd-coredump Storage is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

A core dump is the memory of an executable program. It is generally used to determine why a program aborted. It can also be used to glean confidential information from a core file.

Rationale:

A core dump includes a memory image taken at the time the operating system terminates an application. The memory image could contain sensitive data and is generally useful only for developers trying to debug problems.

Audit:

Run the following script to verify `systemd-coredump Storage` is set to `none`:

```
#!/usr/bin/env bash

{
   l_analyze_cmd="$(readlink -e /bin/systemd-analyze || \
   readlink -e /usr/bin/systemd-analyze)"
   l_conf_file="systemd/coredump.conf" l_block="Coredump"
   l_option="Storage" l_option_value="" a_output=()
   while IFS= read -r l_file; do
      l_file="${l_file//# /}"
      l_opt="$(awk '/\['"$l_block"'\]/{a=1;next}/\[/{a=0}a' "$l_file" \
      2>/dev/null | grep -Poi '^\h*'"$l_option"'\h*=\h*\H+\b' | tail -n 1)"
         l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_option\" is set to: \"$l_option_value\"" \
      "    in: \"$l_file\"")
   done < <("$l_analyze_cmd" cat-config "$l_conf_file" | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   if [ "${#a_output[@]}" -le "0" ]; then
      l_file="/etc/$l_conf_file"
      l_opt="$(awk '/\['"$l_block"'\]/{a=1;next}/\[/{a=0}a' "$l_file" \
      2>/dev/null | grep -Poim 1 '^(\h*#)?\h*'"$l_option"'\h*=\h*\H+\b')"
      l_option_value="$(cut -d= -f2 <<< "${l_opt//# /}" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - The default value: \"${l_opt//#/}\"" \
      "    is being used in the configuration")
   fi
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "Storage" is set to: "none" in: "/etc/systemd/coredump.conf.d/60-
coredump.conf"
```

Note:

- If multiple lines are returned:
  - The first line includes the value being used by `systemd-coredump`. If this is a correct value, this is considered a passing state.
  - Files that include an incorrect value should be modified to correct or comment out the incorrect value to minimize the potential of the incorrect value being used by `systemd-coredump` due to system configuration changes
- If the default value is displayed, and is the correct value, this is considered a passing state. However, it is recommended to follow the Remediation procedure to mitigate the potential of a system update changing the default value to an incorrect value.
- **SYSTEM FILE PRECEDENCE**
  - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
  - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
  - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files ending in `.conf` in the `/etc/systemd/coredump.conf.d/` directory and comment out or remove all `Storage=` lines in the `[Coredump]` block that are not `Storage=none`.

Example script:

```
#!/usr/bin/env bash

{
   l_block="Coredump" l_option="Storage" l_value="none"
   while IFS= read -r -d $'\0' l_file; do
      awk '/\['"$l_block"'\]/{a=1;next}/\[/{a=0}a' "$l_file" 2>/dev/null | \
      grep -Poi '\h*'"$l_option"'\h*=\h*\H+\b' | \
      grep -Pivq '^\h*'"$l_option"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*[Ss]torage\s*=/s/^/# /' "$l_file"
   done < <(find /etc/systemd/coredump.conf.d/ -type f -name '*.conf' -
print0)
}
```

2. Create or edit a file in the `/etc/systemd/coredump.conf.d` directory ending in `.conf` and edit or add the following line to the `[Coredump]` section:

```
Storage=none
```

Example:

```
#!/usr/bin/env bash

{
   [ ! -d /etc/systemd/coredump.conf.d/ ] && mkdir
/etc/systemd/coredump.conf.d/
   l_file="/etc/systemd/coredump.conf.d/60-coredump.conf"
   if grep -Psq -- '^\h*\[Coredump\]' "$l_file"; then
      sed -ri '/^\s*\[Coredump\]/a Storage=none' "$l_file"
   else
      printf '%s\n' "" "[Coredump]" "Storage=none" >> "$l_file"
   fi
}
```

3. Run the following command to load the updated configuration:

```
# systemctl reload-or-restart systemd-coredump.socket
```

Default Value:

Storage=external

References:

1. COREDUMP.CONF(5)
2. CCI-000366
3. NIST SP 800-53 :: CM-6 b
4. NIST SP 800-53A :: CM-6.1 (iv)
5. STIG ID: RHEL-08-010674 | RULE ID: SV-230314r1017125 | CAT II
6. STIG ID: OL08-00-010674 | RULE ID: SV-248632r991589 | CAT II
7. STIG ID: RHEL-09-213090 | RULE ID: SV-257813r991589 | CAT II
8. STIG ID: ALMA-09-011460 | RULE ID: SV-269180r1050062 | CAT II
9. STIG ID: OL09-00-002382 | RULE ID: SV-271730r1091902 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

1.6 Configure system wide crypto policy

crypto-policy files:

- `/etc/crypto-policies/back-ends` - The individual cryptographical back-end configuration files. Usually linked to the configuration shipped in the crypto-policies package unless a configuration from `local.d` is added.
- `/etc/crypto-policies/config` - A file containing the name of the active crypto-policy set on the system.
- `/etc/crypto-policies/local.d` - Additional configuration shipped by other packages or created by the system administrator. The contents of the -file.config is appended to the configuration from the policy back end as shipped in the crypto-policies package.
- `/usr/share/crypto-policies/policies` - System policy definition files.
- `/usr/share/crypto-policies/policies/modules` - System subpolicy definition files.
- `/etc/crypto-policies/policies` - Custom policy definition files as configured by the system administrator.
- `/etc/crypto-policies/policies/modules` - Custom subpolicy definition files as configured by the system administrator.
- `/usr/share/crypto-policies/<'POLICYNAME'>` - Pre-generated back-end configurations for policy POLICYNAME.

The crypto policy definition files have a simple syntax following an INI file key = value syntax

Full policy definition files have suffix `.pol`, subpolicy files have suffix `.pmod`. Subpolicies do not have to have values set for all the keys.

The effective configuration of a policy with subpolicies applied is the same as a configuration from a single policy obtained by concatenating the policy and the subpolicies in question.

The policy files shipped in packages are placed in `/usr/share/crypto-policies/policies` and the subpolicies in `/usr/share/crypto-policies/policies/modules`.

Locally configured policy files should be placed in `/etc/crypto-policies/policies` and subpolicies in `/etc/crypto-policies/policies/modules`.

The policy and subpolicy files must have names in upper-case except for the `.pol` and `.pmod` suffix as the update-crypto-policies command always converts the policy name to upper-case before searching for the policy on the filesystem.

The following predefined policies are included:

- `DEFAULT` - The default system-wide cryptographic policy level offers secure settings for current threat models. It allows the TLS 1.2 and 1.3 protocols, as well as the IKEv2 and SSH2 protocols. The RSA keys and Diffie-Hellman parameters are accepted if they are at least 2048 bits long.
- `LEGACY` - This policy ensures maximum compatibility with Red Hat Enterprise Linux 5 and earlier; it is less secure due to an increased attack surface. In addition to the DEFAULT level algorithms and protocols, it includes support for the TLS 1.0 and 1.1 protocols. The algorithms DSA, 3DES, and RC4 are allowed, while RSA keys and Diffie-Hellman parameters are accepted if they are at least 1023 bits long.
- `FUTURE` - A stricter forward-looking security level intended for testing a possible future policy. This policy does not allow the use of SHA-1 in signature algorithms. It allows the TLS 1.2 and 1.3 protocols, as well as the IKEv2 and SSH2 protocols. The RSA keys and Diffie-Hellman parameters are accepted if they are at least 3072 bits long. If your system communicates on the public internet, you might face interoperability problems.
- `FIPS` - A policy level that conforms with the FIPS 140 requirements. The fips-mode-setup tool, which switches the RHEL system into FIPS mode, uses this policy internally. Switching to the FIPS policy does not guarantee compliance with the FIPS 140 standard. You also must re-generate all cryptographic keys after you set the system to FIPS mode. This is not possible in many scenarios.

Note: Additional information is available in the `crypto-policies`, `update-crypto-policies`, and `fips-mode-setup` man pages.

1.6.1 Ensure system wide crypto policy is not set to legacy (Automated)

Profile Applicability:

- Level 1 - Server

Description:

When a system-wide policy is set up, the default behavior of applications will be to follow the policy. Applications will be unable to use algorithms and protocols that do not meet the policy, unless you explicitly request the application to do so.

The system-wide crypto-policies followed by the crypto core components allow consistently deprecating and disabling algorithms system-wide.

The `LEGACY` policy ensures maximum compatibility with version 5 of the operating system and earlier; it is less secure due to an increased attack surface. In addition to the `DEFAULT` level algorithms and protocols, it includes support for the `TLS 1.0` and `1.1` protocols. The algorithms `DSA`, `3DES`, and `RC4` are allowed, while `RSA keys` and `Diffie-Hellman` parameters are accepted if they are at least 1023 bits long.

Rationale:

If the `LEGACY` system-wide crypto policy is selected, it includes support for TLS 1.0, TLS 1.1, and SSH2 protocols or later. The algorithms DSA, 3DES, and RC4 are allowed, while RSA and Diffie-Hellman parameters are accepted if larger than 1023-bits.

These legacy protocols and algorithms can make the system vulnerable to attacks, including those listed in RFC 7457

Impact:

Environments that require compatibility with older insecure protocols may require the use of the less secure `LEGACY` policy level.

Audit:

Run the following command to verify that the system-wide crypto policy is not `LEGACY`

```
# grep -Pi '^\h*LEGACY\b' /etc/crypto-policies/config
```

Verify that no lines are returned

Remediation:

Run the following command to change the system-wide crypto policy

```
# update-crypto-policies --set <CRYPTO POLICY>
```

Example:

```
# update-crypto-policies --set DEFAULT
```

Run the following to make the updated system-wide crypto policy active

```
# update-crypto-policies
```

Default Value:

DEFAULT

References:

1. CRYPTO-POLICIES(7)
2. https://access.redhat.com/articles/3642912#what-polices-are-provided-1
3. fips-mode-setup(8)
4. NIST SP 800-53 Rev. 5: SC-8

Additional Information:

- IF - FIPS is required by local site policy:

The system-wide cryptographic policies contain a policy level that enables cryptographic algorithms in accordance with the requirements by the Federal Information Processing Standard (FIPS) Publication 140. The fips-mode-setup tool that enables or disables FIPS mode internally uses the FIPS systemwide cryptographic policy. Switching the system to FIPS mode by using the FIPS system-wide cryptographic policy does not guarantee compliance with the FIPS 140 standard. Re-generating all cryptographic keys after setting the system to FIPS mode may not be possible. For example, in the case of an existing IdM realm with users' cryptographic keys you cannot re-generate all the keys. The fips-mode-setup tool uses the FIPS policy internally. But on top of what the `update-crypto-policies` command with the `--set FIPS` option does, `fips-mode-setup` ensures the installation of the FIPS `dracut` module by using the `fips-finish-install` tool, it also adds the `fips=1` boot option to the kernel command line and regenerates the initial ramdisk.

IMPORTANT: Only enabling FIPS mode during installation ensures that the system generates all keys with FIPS-approved algorithms and continuous monitoring tests in place.

Run the following command to switch the system to FIPS mode:

```
# fips-mode-setup --enable
```

Output:

```
Kernel initramdisks are being regenerated. This might take some time.
Setting system policy to FIPS
Note: System-wide crypto policies are applied on application start-up.
It is recommended to restart the system for the change of policies
to fully take place.
FIPS mode will be enabled.
Please reboot the system for the setting to take effect.
```

Run the following command to restart the system:

```
# reboot
```

After the reboot has completed, run the following command to verify FIPS mode:

```
# fips-mode-setup --check
```

Output:

```
FIPS mode is enabled.
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

1.6.2 Ensure system wide crypto policy disables sha1 hash and signature support (Automated)

Profile Applicability:

- Level 1 - Server

Description:

SHA-1 (Secure Hash Algorithm) is a cryptographic hash function that produces a 160 bit hash value.

Rationale:

The SHA-1 hash function has an inherently weak design, and advancing cryptanalysis has made it vulnerable to attacks. The most significant danger for a hash algorithm is when a "collision" which happens when two different pieces of data produce the same hash value occurs. This hashing algorithm has been considered weak since 2005.

Note: The use of SHA-1 with hashbased message authentication codes (HMAC) do not rely on the collision resistance of the corresponding hash function, and therefore the recent attacks on SHA-1 have a significantly lower impact on the use of SHA-1 for HMAC. Because of this, the recommendation does not disable the hmac-sha1 MAC.

Audit:

Run the following commands to verify `SHA1` hash and signature support has been disabled:

Run the following command to verify that the `hash` and `sign` lines do not include the `SHA1` hash:

```
# gawk -F= '($1~/^\s*(hash|sign)\s*$/ && $2~/SHA1/ && $2!~/^\s*\-
\s*([^#\n\r]+)?SHA1/){print}' /etc/crypto-policies/state/CURRENT.pol
```

Nothing should be returned

Run the following command to verify that `sha1_in_certs` is set to `0` (disabled):

```
# grep -Psi -- '^\h*sha1_in_certs\h*=\h*' /etc/crypto-
policies/state/CURRENT.pol

sha1_in_certs = 0
```

Remediation:

Note:

- The commands below are written for the included `DEFAULT` system-wide crypto policy. If another policy is in use and follows local site policy, replace `DEFAULT` with the name of your system-wide crypto policy.
- Multiple subpolicies may be assigned to a policy as a colon separated list. e.g. `DEFAULT:NO-SHA1:NO-SSHCBC`
- Subpolicies:
  - Not included in the `update-crypto-policies --set` command will **not** be applied to the system wide crypto policy.
  - **must exist** before they can be applied to the system wide crypto policy.
  - `.pmod` file filenames must be in all upper case, upper case, e.g. `NO-SHA1.pmod`, or they will **not** be read by the `update-crypto-policies --set` command.

Create or edit a file in `/etc/crypto-policies/policies/modules/` ending in `.pmod` and add or modify the following lines:

```
hash = -SHA1
sign = -*-SHA1
sha1_in_certs = 0
```

Example:

```
# printf '%s\n' "# This is a subpolicy dropping the SHA1 hash and signature
support" "hash = -SHA1" "sign = -*-SHA1" "sha1_in_certs = 0" >> /etc/crypto-
policies/policies/modules/NO-SHA1.pmod
```

Run the following command to update the system-wide cryptographic policy

```
# update-crypto-policies --set
<CRYPTO_POLICY>:<CRYPTO_SUBPOLICY1>:<CRYPTO_SUBPOLICY2>:<CRYPTO_SUBPOLICY3>
```

Example:

```
update-crypto-policies --set DEFAULT:NO-SHA1
```

Run the following command to reboot the system to make your cryptographic settings effective for already running services and applications:

```
# reboot
```

References:

1. crypto-policies(7)
2. update-crypto-policies(8)
3. Red Hat Enterprise 8 security hardening
4. https://www.redhat.com/en/blog/how-customize-crypto-policies-rhel-82
5. https://access.redhat.com/articles/3642912
6. NIST SP 800-53 Rev. 5: SC-8

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

1.6.3 Ensure system wide crypto policy macs are configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Message Authentication Code (MAC) algorithm is a family of cryptographic functions that is parameterized by a symmetric key. Each of the functions can act on input data (called a “message”) of variable length to produce an output value of a specified length. The output value is called the MAC of the input message.

A MAC algorithm can be used to provide data-origin authentication and data-integrity protection

Rationale:

Weak algorithms continue to have a great deal of attention as a weak spot that can be exploited with expanded computing power. An attacker that breaks the algorithm could take advantage of a MiTM position to decrypt the tunnel and capture credentials and information.

A MAC algorithm must be computationally infeasible to determine the MAC of a message without knowledge of the key, even if one has already seen the results of using that key to compute the MAC's of other messages.

Audit:

Run the following script to verify weak MACs are disabled:

```
# grep -Pi -- '^\h*mac\h*=\h*([^#\n\r]+)?-128\b' /etc/crypto-
policies/state/CURRENT.pol
```

Nothing should be returned

Remediation:

Note:

- The commands below are written for the included `DEFAULT` system-wide crypto policy. If another policy is in use and follows local site policy, replace `DEFAULT` with the name of your system-wide crypto policy.
- Multiple subpolicies may be assigned to a policy as a colon separated list. e.g. `DEFAULT:NO-SHA1:NO-SSHCBC`
- Subpolicies:
  - Not included in the `update-crypto-policies --set` command will **not** be applied to the system wide crypto policy.
  - **must exist** before they can be applied to the system wide crypto policy.
  - `.pmod` file filenames must be in all upper case, upper case, e.g. `NO-WEAKMAC.pmod`, or they will **not** be read by the `update-crypto-policies --set` command.

Create or edit a file in `/etc/crypto-policies/policies/modules/` ending in `.pmod` and add or modify **one** of the following lines:

```
mac = -*-128* # Disables weak macs
```

Example:

```
# printf '%s\n' "# This is a subpolicy to disable weak macs" "mac = -*-128"
>> /etc/crypto-policies/policies/modules/NO-WEAKMAC.pmod
```

Run the following command to update the system-wide cryptographic policy

```
# update-crypto-policies --set
<CRYPTO_POLICY>:<CRYPTO_SUBPOLICY1>:<CRYPTO_SUBPOLICY2>:<CRYPTO_SUBPOLICY3>
```

Example:

```
update-crypto-policies --set DEFAULT:NO-SHA1:NO-WEAKMAC
```

Run the following command to reboot the system to make your cryptographic settings effective for already running services and applications:

```
# reboot
```

References:

1. https://nvd.nist.gov/vuln/detail/CVE-2008-5161
2. crypto-policies(7)
3. update-crypto-policies(8)
4. Red Hat Enterprise 8 security hardening
5. https://www.redhat.com/en/blog/how-customize-crypto-policies-rhel-82
6. https://csrc.nist.gov/glossary/term/message_authentication_code_algorithm
7. NIST SP 800-53 Rev. 5: SC-8

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

1.6.4 Ensure system wide crypto policy disables cbc for ssh (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Cypher Block Chaining (CBC) is an algorithm that uses a block cipher.

Rationale:

A vulnerability exists in SSH messages that employ CBC mode that may allow an attacker to recover plaintext from a block of ciphertext. If exploited, this attack can potentially allow an attacker to recover up to 32 bits of plaintext from an arbitrary block of ciphertext from a connection secured using the SSH protocol.

Impact:

CBC ciphers might be the only common cyphers when connecting to older SSH clients and servers

Audit:

Run the following script to verify CBC is disabled for SSH:

```
#!/usr/bin/env bash

{
   l_output="" l_output2=""
   if grep -Piq -- '^\h*cipher\h*=\h*([^#\n\r]+)?-CBC\b' /etc/crypto-
policies/state/CURRENT.pol; then
      if grep -Piq -- '^\h*cipher@(lib|open)ssh(-server|-client)?\h*=\h*'
/etc/crypto-policies/state/CURRENT.pol; then
         if ! grep -Piq -- '^\h*cipher@(lib|open)ssh(-server|-
client)?\h*=\h*([^#\n\r]+)?-CBC\b' /etc/crypto-policies/state/CURRENT.pol;
then
            l_output="$l_output\n - Cipher Block Chaining (CBC) is disabled
for SSH"
         else
            l_output2="$l_output2\n - Cipher Block Chaining (CBC) is enabled
for SSH"
         fi
      else
         l_output2="$l_output2\n - Cipher Block Chaining (CBC) is enabled for
SSH"
      fi
   else
      l_output=" - Cipher Block Chaining (CBC) is disabled"
   fi
   if [ -z "$l_output2" ]; then # Provide output from checks
      echo -e "\n- Audit Result:\n  ** PASS **\n$l_output\n"
   else
      echo -e "\n- Audit Result:\n  ** FAIL **\n - Reason(s) for audit
failure:\n$l_output2\n"
      [ -n "$l_output" ] && echo -e "\n- Correctly set:\n$l_output\n"
   fi
}
```

Remediation:

Note:

- The commands below are written for the included `DEFAULT` system-wide crypto policy. If another policy is in use and follows local site policy, replace `DEFAULT` with the name of your system-wide crypto policy.
- `CBC` can be turned off globally by using the argument `cipher` opposed to `cipher@SSH`
- Multiple subpolicies may be assigned to a policy as a colon separated list. e.g. `DEFAULT:NO-SHA1:NO-SSHCBC`
- Subpolicies:
  - Not included in the `update-crypto-policies --set` command will **not** be applied to the system wide crypto policy.
  - **must exist** before they can be applied to the system wide crypto policy.
  - `.pmod` file filenames must be in all upper case, upper case, e.g. `NO-SSHCBC.pmod`, or they will **not** be read by the `update-crypto-policies --set` command.
  - Create or edit a file in `/etc/crypto-policies/policies/modules/` ending in `.pmod` and add or modify **one** of the the following lines:

```
cipher@SSH = -*-CBC # Disables the CBC cipher for SSH
```

Example:

```
# printf '%s\n' "# This is a subpolicy to disable all CBC mode ciphers" "#
for the SSH protocol (libssh and OpenSSH)" "cipher@SSH = -*-CBC" >>
/etc/crypto-policies/policies/modules/NO-SSHCBC.pmod
```

Run the following command to update the system-wide cryptographic policy

```
# update-crypto-policies --set
<CRYPTO_POLICY>:<CRYPTO_SUBPOLICY1>:<CRYPTO_SUBPOLICY2>:<CRYPTO_SUBPOLICY3>
```

Example:

```
update-crypto-policies --set DEFAULT:NO-SHA1:NO-WEAKMAC:NO-SSHCBC
```

Run the following command to reboot the system to make your cryptographic settings effective for already running services and applications:

```
# reboot
```

References:

1. https://nvd.nist.gov/vuln/detail/CVE-2008-5161
2. crypto-policies(7)
3. update-crypto-policies(8)
4. Red Hat Enterprise 8 security hardening
5. https://www.redhat.com/en/blog/how-customize-crypto-policies-rhel-82
6. NIST SP 800-53 Rev. 5: SC-8

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

1.6.5 Ensure system wide crypto policy disables chacha20-poly1305 for ssh (Manual)

Profile Applicability:

- Level 1 - Server

Description:

ChaCha20-Poly1305 is an authenticated encryption with additional data (AEAD) algorithm, that combines the ChaCha20 stream cipher with the Poly1305 message authentication code. Its usage in IETF protocols is standardized in RFC 8439.

Note: If CVE-2023-48795 (Terrapin SSH Attack) has been addressed this recommendation is not applicable.

Rationale:

A vulnerability exists in ChaCha20-Poly1305 as referenced in CVE-2023-48795

Audit:

- IF - CVE-2023-48795 has been addressed, and it meets local site policy, this recommendation may be skipped.

Run the following script to verify chacha20-poly1305 is disabled for SSH:

```
#!/usr/bin/env bash

{
   l_output="" l_output2=""
   if grep -Piq -- '^\h*cipher\h*=\h*([^#\n\r]+)?-CBC\b' /etc/crypto-
policies/state/CURRENT.pol; then
      if grep -Piq -- '^\h*cipher@(lib|open)ssh(-server|-client)?\h*=\h*'
/etc/crypto-policies/state/CURRENT.pol; then
         if ! grep -Piq -- '^\h*cipher@(lib|open)ssh(-server|-
client)?\h*=\h*([^#\n\r]+)?\bchacha20-poly1305\b' /etc/crypto-
policies/state/CURRENT.pol; then
            l_output="$l_output\n - chacha20-poly1305 is disabled for SSH"
         else
            l_output2="$l_output2\n - chacha20-poly1305 is enabled for SSH"
         fi
      else
         l_output2="$l_output2\n - chacha20-poly1305 is enabled for SSH"
      fi
   else
      l_output=" - chacha20-poly1305 is disabled"
   fi
   if [ -z "$l_output2" ]; then # Provide output from checks
      echo -e "\n- Audit Result:\n  ** PASS **\n$l_output\n"
   else
      echo -e "\n- Audit Result:\n  ** FAIL **\n - Reason(s) for audit
failure:\n$l_output2\n"
      [ -n "$l_output" ] && echo -e "\n- Correctly set:\n$l_output\n"
   fi
}
```

Remediation:

Note:

- The commands below are written for the included `DEFAULT` system-wide crypto policy. If another policy is in use and follows local site policy, replace `DEFAULT` with the name of your system-wide crypto policy.
- `chacha20-poly1305` can be turned off globally by using the argument `cipher` opposed to `cipher@SSH`
- Multiple subpolicies may be assigned to a policy as a colon separated list. e.g. `DEFAULT:NO-SHA1:NO-SSHCBC`
- Subpolicies:
  - Not included in the `update-crypto-policies --set` command will **not** be applied to the system wide crypto policy.
  - **must exist** before they can be applied to the system wide crypto policy.
  - `.pmod` file filenames must be in all upper case, upper case, e.g. `NO-SSHCHACHA20.pmod`, or they will **not** be read by the `update-crypto-policies --set` command.

- IF - `CVE-2023-48795` has been addressed, and it meets local site policy, this recommendation may be skipped.
Create or edit a file in `/etc/crypto-policies/policies/modules/` ending in `.pmod` and add or modify **one** of the the following lines:

```
cipher@SSH = -CHACHA20-POLY1305 # Disables the chacha20-poly1305 cipher for SSH
```

Example:

```
# printf '%s\n' "# This is a subpolicy to disable the chacha20-poly1305 ciphers" "# for the SSH protocol (libssh and OpenSSH)" "cipher@SSH = -CHACHA20-POLY1305" >> /etc/crypto-policies/policies/modules/NO-SSHCHACHA20.pmod
```

Run the following command to update the system-wide cryptographic policy

```
# update-crypto-policies --set <CRYPTO_POLICY>:<CRYPTO_SUBPOLICY1>:<CRYPTO_SUBPOLICY2>:<CRYPTO_SUBPOLICY3>
```

Example:

```
# update-crypto-policies --set DEFAULT:NO-SHA1:NO-WEAKMAC:NO-SSHCBC:NO-SSHCHACHA20
```

Run the following command to reboot the system to make your cryptographic settings effective for already running services and applications:

```
# reboot
```

References:

1. https://nvd.nist.gov/vuln/detail/CVE-2023-48795
2. crypto-policies(7)
3. update-crypto-policies(8)
4. Red Hat Enterprise 8 security hardening
5. https://www.redhat.com/en/blog/how-customize-crypto-policies-rhel-82
6. NIST SP 800-53 Rev. 5: SC-8

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

1.6.6 Ensure system wide crypto policy disables EtM for ssh (Manual)

Profile Applicability:

- Level 1 - Server

Description:

Encrypt-then-MAC (EtM) - The ciphertext is generated by encrypting the plaintext and then appending a MAC of the encrypted plaintext

`ssh_etm` - Controls if OpenSSH EtM (encrypt-then-mac) extension is allowed.

`Terrapin` is a prefix truncation attack targeting the SSH protocol.

Note: If CVE-2023-48795 (Terrapin SSH Attack) has been addressed this recommendation is not applicable.

Rationale:

There is an effective attack against SSH's use of Cypher-Block-Chaining (CBC) with Encrypt-then-MAC as referenced in `CVE-2023-48795`

Audit:

- IF - `CVE-2023-48795` (Terrapin SSH Attack) has been addressed this recommendation is not applicable.

Run the following command to verify `EtM` is disabled for `SSH`:

```
# grep -Psi -- '^\h*ssh_etm\h*=\h*\d+\b' /etc/crypto-
policies/state/CURRENT.pol
```

Verify output is:

```
ssh_etm = 0
```

Remediation:

Note:

- The commands below are written for the included `DEFAULT` system-wide crypto policy. If another policy is in use and follows local site policy, replace `DEFAULT` with the name of your system-wide crypto policy.
- Multiple subpolicies may be assigned to a policy as a colon separated list. e.g. `DEFAULT:NO-SHA1:NO-SSHCBC`
- Subpolicies:
  - Not included in the `update-crypto-policies --set` command will **not** be applied to the system wide crypto policy.
  - **must exist** before they can be applied to the system wide crypto policy.
  - `.pmod` file filenames must be in all upper case, upper case, e.g. `NO-SSHCHACHA20.pmod`, or they will **not** be read by the `update-crypto-policies --set` command.

- IF - `CVE-2023-48795` has been addressed, and it meets local site policy, this recommendation is not applicable.
Create or edit a file in `/etc/crypto-policies/policies/modules/` ending in `.pmod` and add or modify the following line:

```
ssh_etm = 0 # This disables EtM for openSSH and libssh
```

Example:

```
# printf '%s\n' "# This is a subpolicy to disable Encrypt then MAC" "# for
the SSH protocol (libssh and OpenSSH)" "ssh_etm = 0" >> /etc/crypto-
policies/policies/modules/NO-SSHETM.pmod
```

Run the following command to update the system-wide cryptographic policy

```
# update-crypto-policies --set
<CRYPTO_POLICY>:<CRYPTO_SUBPOLICY1>:<CRYPTO_SUBPOLICY2>:<CRYPTO_SUBPOLICY3>
```

Example:

```
# update-crypto-policies --set DEFAULT:NO-SHA1:NO-WEAKMAC:NO-SSHCBC:NO-
SSHCHACHA20:NO-SSHETM
```

Run the following command to reboot the system to make your cryptographic settings effective for already running services and applications:

```
# reboot
```

References:

1. https://nvd.nist.gov/vuln/detail/CVE-2023-48795
2. crypto-policies(7)
3. update-crypto-policies(8)
4. Red Hat Enterprise 8 security hardening
5. https://www.redhat.com/en/blog/how-customize-crypto-policies-rhel-82
6. NIST SP 800-53 Rev. 5: SC-8
7. https://access.redhat.com/errata/RHSA-2024:0499
8. https://terrapin-attack.com/

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

1.7 Configure Command Line Warning Banners

Presenting a warning message prior to the normal user login may assist in the prosecution of trespassers on the computer system. Changing some of these login banners also has the side effect of hiding OS version information and other detailed system information from attackers attempting to target specific exploits at a system.

Guidelines published by the US Department of Defense require that warning messages include at least the name of the organization that owns the system, the fact that the system is subject to monitoring and that such monitoring is in compliance with local statutes, and that use of the system implies consent to such monitoring. It is important that the organization's legal counsel review the content of all messages before any system modifications are made, as these warning messages are inherently site-specific. More information (including citations of relevant case law) can be found at http://www.justice.gov/criminal/cybercrime/

The `/etc/motd`, `/etc/issue`, and `/etc/issue.net` files govern warning banners for standard command line logins for both local and remote users.

Note: The text provided in the remediation actions for these items is intended as an example only. Please edit to include the specific text for your organization as approved by your legal department.

1.7.1 Ensure /etc/motd is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The contents of the `/etc/motd` file are displayed to users after login and function as a message of the day for authenticated users.

Unix-based systems have typically displayed information about the OS release and patch level upon logging in to the system. This information can be useful to developers who are developing software for a particular OS platform. If `mingetty(8)` supports the following options, they display operating system information: `\m` - machine architecture `\r` - operating system release `\s` - operating system name `\v` - operating system version

Rationale:

Warning messages inform users who are attempting to login to the system of their legal status regarding the system and must include the name of the organization that owns the system and any monitoring policies that are in place. Displaying OS and patch level information in login banners also has the side effect of providing detailed system information to attackers attempting to target specific exploits of a system. Authorized users can easily get this information by running the " `uname -a` " command once they have logged in.

Audit:

Run the following script to verify MOTD files do not contain system information:

```
#!/usr/bin/env bash

{
   l_output="" l_output2=""
   a_files=()
   for l_file in /etc/motd{,.d/*}; do
      if grep -Psqi -- "(\\\v|\\\r|\\\m|\\\s|\b$(grep ^ID= /etc/os-release |
cut -d= -f2 | sed -e 's/"//g')\b)" "$l_file"; then
         l_output2="$l_output2\n - File: \"$l_file\" includes system
information"
      else
         a_files+=("$l_file")
      fi
   done
   if [ "${#a_files[@]}" -gt 0 ]; then
      echo -e "\n-  ** Please review the following files and verify their
contents follow local site policy **\n"
      printf '%s\n' "${a_files[@]}"
   elif [ -z "$l_output2" ]; then
      echo -e "- ** No MOTD files with any size were found. Please verify
this conforms to local site policy ** -"
   fi
   if [ -z "$l_output2" ]; then
      l_output=" - No MOTD files include system information"
      echo -e "\n- Audit Result:\n  ** PASS **\n$l_output\n"
   else
      echo -e "\n- Audit Result:\n  ** FAIL **\n - Reason(s) for audit
failure:\n$l_output2\n"
   fi
}
```

Review any files returned and verify that they follow local site policy

Remediation:

Edit the file found in `/etc/motd.d/*` with the appropriate contents according to your site policy, remove any instances of `\m` , `\r` , `\s` , `\v` or references to the `OS platform`

- OR -

- IF - the `motd` is not used, this file can be removed.

Run the following command to remove the `motd` file:

```
# rm /etc/motd
```

Run the following script and review and/or update all returned files' contents to:

- Remove all system information (`\v`, `\r`; `\m`, `\s`)
- Remove any refence to the operating system
- Ensure contents follow local site policy

```
#!/usr/bin/env bash

{
   a_files=()
   for l_file in /etc/motd{,.d/*}; do
      if grep -Psqi -- "(\\\v|\\\r|\\\m|\\\s|\b$(grep ^ID= /etc/os-release |
cut -d= -f2 | sed -e 's/"//g')\b)" "$l_file"; then
         echo -e "\n - File: \"$l_file\" includes system information. Edit
this file to remove these entries"
      else
      a_files+=("$l_file")
      fi
   done
   if [ "${#a_files[@]}" -gt 0 ]; then
      echo -e "\n-  ** Please review the following files and verify their
contents follow local site policy **\n"
      printf '%s\n' "${a_files[@]}"
   fi
}
```

References:

1. NIST SP 800-53 Rev. 5: CM-6, CM-1, CM-3

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

1.7.2 Ensure /etc/issue is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The contents of the `/etc/issue` file are displayed to users prior to login for local terminals.

Unix-based systems have typically displayed information about the OS release and patch level upon logging in to the system. This information can be useful to developers who are developing software for a particular OS platform. If `mingetty(8)` supports the following options, they display operating system information: `\m` - machine architecture `\r` - operating system release `\s` - operating system name `\v` - operating system version - or the operating system's name

Rationale:

Warning messages inform users who are attempting to login to the system of their legal status regarding the system and must include the name of the organization that owns the system and any monitoring policies that are in place. Displaying OS and patch level information in login banners also has the side effect of providing detailed system information to attackers attempting to target specific exploits of a system. Authorized users can easily get this information by running the " `uname -a` " command once they have logged in.

Audit:

Run the following command and verify that the contents match site policy:

```
# cat /etc/issue
```

Run the following command and verify no results are returned:

```
# grep -E -i "(\\v|\\r|\\m|\\s|$(grep '^ID=' /etc/os-release | cut -d= -
f2 | sed -e 's/"//g'))" /etc/issue
```

Remediation:

Edit the `/etc/issue` file with the appropriate contents according to your site policy, remove any instances of `\m` , `\r` , `\s` , `\v` or references to the `OS platform`

Example:

```
# echo "Authorized users only. All activity may be monitored and reported." >
/etc/issue
```

References:

1. NIST SP 800-53 Rev. 5: CM-6, CM-1, CM-3

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

1.7.3 Ensure /etc/issue.net is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The contents of the `/etc/issue.net` file are displayed to users prior to login for remote connections from configured services.

Unix-based systems have typically displayed information about the OS release and patch level upon logging in to the system. This information can be useful to developers who are developing software for a particular OS platform. If `mingetty(8)` supports the following options, they display operating system information: `\m` - machine architecture `\r` - operating system release `\s` - operating system name `\v` - operating system version

Rationale:

Warning messages inform users who are attempting to login to the system of their legal status regarding the system and must include the name of the organization that owns the system and any monitoring policies that are in place. Displaying OS and patch level information in login banners also has the side effect of providing detailed system information to attackers attempting to target specific exploits of a system. Authorized users can easily get this information by running the " `uname -a` " command once they have logged in.

Audit:

Run the following command and verify that the contents match site policy:

```
# cat /etc/issue.net
```

Run the following command and verify no results are returned:

```
# grep -E -i "(\\v|\\r|\\m|\\s|$(grep '^ID=' /etc/os-release | cut -d= -
f2 | sed -e 's/"//g'))" /etc/issue.net
```

Remediation:

Edit the `/etc/issue.net` file with the appropriate contents according to your site policy, remove any instances of `\m` , `\r` , `\s` , `\v` or references to the `OS platform`

Example:

```
# echo "Authorized users only. All activity may be monitored and reported." >
/etc/issue.net
```

References:

1. NIST SP 800-53 Rev. 5: CM-6, CM-1, CM-3

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

1.7.4 Ensure access to /etc/motd is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The contents of the `/etc/motd` file are displayed to users after login and function as a message of the day for authenticated users.

Rationale:

- IF - the `/etc/motd` file does not have the correct access configured, it could be modified by unauthorized users with incorrect or misleading information.

Audit:

Run the following command and verify that if `/etc/motd` exists, `Access` is `644` or more restrictive, `Uid` and `Gid` are both `0/root`:

```
# [ -e /etc/motd ] && stat -Lc 'Access: (%#a/%A)  Uid: ( %u/ %U) Gid: { %g/
%G)' /etc/motd

Access: (0644/-rw-r--r--)  Uid: ( 0/ root) Gid: ( 0/ root)
  -- OR --
Nothing is returned
```

Remediation:

Run the following commands to set mode, owner, and group on `/etc/motd`:

```
# chown root:root $(readlink -e /etc/motd)
# chmod u-x,go-wx $(readlink -e /etc/motd)
```

- OR -

Run the following command to remove the `/etc/motd` file:

```
# rm /etc/motd
```

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.7.5 Ensure access to /etc/issue is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The contents of the `/etc/issue` file are displayed to users prior to login for local terminals.

Rationale:

- IF - the `/etc/issue` file does not have the correct access configured, it could be modified by unauthorized users with incorrect or misleading information.

Audit:

Run the following command and verify `Access` is `644` or more restrictive and `Uid` and `Gid` are both `0/root`:

```
# stat -Lc 'Access: (%#a/%A)  Uid: ( %u/ %U) Gid: { %g/ %G)' /etc/issue

Access: (0644/-rw-r--r--)  Uid: ( 0/ root) Gid: { 0/ root)
```

Remediation:

Run the following commands to set mode, owner, and group on `/etc/issue`:

```
# chown root:root $(readlink -e /etc/issue)
# chmod u-x,go-wx $(readlink -e /etc/issue)
```

Default Value:

Access: (0644/-rw-r--r--) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.7.6 Ensure access to /etc/issue.net is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The contents of the `/etc/issue.net` file are displayed to users prior to login for remote connections from configured services.

Rationale:

- IF - the `/etc/issue.net` file does not have the correct access configured, it could be modified by unauthorized users with incorrect or misleading information.

Audit:

Run the following command and verify `Access` is `644` or more restrictive and `Uid` and `Gid` are both `0/root`:

```
# stat -Lc 'Access: (%#a/%A)  Uid: ( %u/ %U) Gid: { %g/ %G)' /etc/issue.net

Access: (0644/-rw-r--r--)  Uid: ( 0/ root)   Gid: ( 0/ root)
```

Remediation:

Run the following commands to set mode, owner, and group on `/etc/issue.net`:

```
# chown root:root $(readlink -e /etc/issue.net)
# chmod u-x,go-wx $(readlink -e /etc/issue.net)
```

Default Value:

Access: (0644/-rw-r--r--) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.8 Configure GNOME Display Manager

The GNOME Display Manager (GDM) is a program that manages graphical display servers and handles graphical user logins.

Note: If GDM is not installed on the system, this section can be skipped

1.8.1 Ensure GDM login banner is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

GDM is the GNOME Display Manager which handles graphical login for GNOME based systems.

By using the lockdown mode in dconf, you can prevent users from changing specific settings.

Rationale:

Warning messages inform users who are attempting to login to the system of their legal status regarding the system and must include the name of the organization that owns the system and any monitoring policies that are in place.

Without locking down the system settings, user settings take precedence over the system settings.

Audit:

1. Run the following commands to verify the login banner configuration is locked:

Run the following command to verify the text banner on the login screen can not be disabled by users:

```
# gsettings writable org.gnome.login-screen banner-message-enable

false
```

Run the following command to verify the text banner on the login screen can not be modified by local users:

```
# gsettings writable org.gnome.login-screen banner-message-text

false
```

Note: If the settings are not locked, the values generated by the `gsettings get` commands below may be user level opposed to system-wide settings. These setting will need to be validated and potentially remediated after they are locked in accordance with the Remediation procedure.

2. Run the following commands to verify the login banner is enabled and meets local site policy.

Run the following command to verify that the system-wide text banner on the login screen is enabled:

```
# gsettings get org.gnome.login-screen banner-message-enable

true
```

Run the following command to verify the system-wide text banner on the login screen meets local site policy:

```
# gsettings get org.gnome.login-screen banner-message-text
```

Example output:

```
'Authorized uses only. All activity may be monitored and reported'
```

Remediation:

1. Create or edit the file `/etc/dconf/profile/user` and add the following lines if they do not exist:

```
user-db:user
system-db:local
```

Example:

```
#!/usr/bin/env bash

{
   l_dir="/etc/dconf/profile/"
   [ ! -d "$l_dir" ] && mkdir /etc/dconf/profile/
   ! grep -Psq '^\h*user-db:user\b' "$l_dir/user" && \
   printf '%s\n' "" "user-db:user" >> "$l_dir/user"
   ! grep -Psq '^\h*system-db:local\b' "$l_dir/user" && \
   sed -ri '/^\s*user-db:user/a system-db:local' "$l_dir/user"
}
```

2. Run the following command to create the `/etc/dconf/db/local.d/` and `/etc/dconf/db/local.d/locks/` directories if either does not exist:

```
# [ ! -d "/etc/dconf/db/local.d/locks/" ] && mkdir -p
/etc/dconf/db/local.d/locks/
```

3. Create or edit a file in `/etc/dconf/db/local.d/locks/` and add the following lines to lock the login banner configuration:

```
/org/gnome/login-screen/banner-message-enable
/org/gnome/login-screen/banner-message-text
```

Example:

```
# printf '%s\n' "" "/org/gnome/login-screen/banner-message-enable" \
"/org/gnome/login-screen/banner-message-text" >>
/etc/dconf/db/local.d/locks/60-banner-message
```

4. Run the following script to comment out any incorrect settings in a local system-wide database keyfile:

```
#!/usr/bin/env bash

{
   f_key_file_fix()
   {
      while IFS= read -r -d $'\0' l_file; do
         grep -Psiq -- "^\h*$l_parameter$l_value(\b|\h*$)" "$l_file" && \
         sed -ri '/^\s*'"$l_parameter"'/s/^/# /g' "$l_file"
      done < <(find /etc/dconf/db -mindepth 2 -maxdepth 2 -type f -print0)
   }
   l_parameter="banner-message-enable=" l_value="false"; f_key_file_fix
   l_parameter="banner-message-text=" l_value="(['\"]{2})?"; f_key_file_fix
}
```

5. Create or edit a local keyfile for machine-wide settings in '/etc/dconf/db/local.d/` with the following lines to set the login banner configuration:

```
[org/gnome/login-screen]
banner-message-enable=true
banner-message-text='Type the banner message here.'
```

Example script:

```
#!/usr/bin/env bash

{
   l_file="/etc/dconf/db/local.d/60-banner-message"
   l_banner="'Authorized uses only. All activity may be monitored and
reported'"
   a_keyfile=("[org/gnome/login-screen]" "banner-message-enable=true" \
   "banner-message-text=$l_banner")
   if grep -Psq -- '^\h*\[org\/gnome\/login-screen\]' "$l_file"; then
      ! grep -Psiq -- '^\h*banner-message-enable=true\b' "$l_file" && \
      sed -ri '/^\s*\[org\/gnome\/login-screen\]/a banner-message-
enable=true' "$l_file"
      ! grep -Psiq -- '^\h*banner-message-text=[^#\n\r]+' "$l_file" && \
      sed -ri '/^\s*\[org\/gnome\/login-screen\]/a banner-message-
text='"$l_banner"'' "$l_file"
   else
      printf '%s\n' "" "${a_keyfile[@]}" >> "$l_file"
   fi
}
```

6. Run the following command to update the dconf database:

```
# dconf update
```

Note:

- `banner-message-text` should be set in accordance with local site policy
- Users must log out and back in again before the system-wide settings take effect.
- There is no character limit for the banner message. gnome-shell autodetects longer stretches of text and enters two column mode.
- The banner message cannot be read from an external file

Default Value:

disabled

References:

1. https://help.gnome.org/admin/system-admin-guide/stable/login-banner.html.en
2. CCI-000048 | CCI-001384 | CCI-001385 | CCI-001386 | CCI-001387 | CCI-001388
3. NIST SP 800-53 :: AC-8 a | NIST SP 800-53 :: AC-8 c
4. NIST SP 800-53A :: AC-8.1 (ii) | NIST SP 800-53A :: AC-8.2 (i) | NIST SP 800-53A :: AC-8.2 (ii)
5. STIG ID: RHEL-08-010049 | RULE ID: SV-244519r1017326 | CAT II
6. STIG ID: RHEL-08-010050 | RULE ID: SV-230226r1069298 | CAT II
7. STIG ID: RHEL-09-271010 | RULE ID: SV-258012r1014855 | CAT II
8. STIG ID: RHEL-09-171011 | RULE ID: SV-270174r1044831 | CAT II
9. STIG ID: RHEL-09-271015 | RULE ID: SV-258013r1045082 | CAT II
10. STIG ID: ALMA-09-008490 | RULE ID: SV-269156r1050038 | CAT II
11. STIG ID: ALMA-09-008600 | RULE ID: SV-269157r1050039 | CAT II
12. STIG ID: UBTU-22-271010 | RULE ID: SV-260535r958390 | CAT II
13. STIG ID: UBTU-22-271015 | RULE ID: SV-260536r958390 | CAT II
14. STIG ID: UBTU-24-200650 | RULE ID: SV-270692r1066565 | CAT II
15. STIG ID: UBTU-24-200660 | RULE ID: SV-270693r1066568 | CAT II
16. STIG ID: SLES-15-010080 | RULE ID: SV-234808r958586 | CAT II
17. STIG ID: SLES-15-010090 | RULE ID: SV-234809r958586 | CAT II

Additional Information:

Additional options and sections may appear in the `/etc/dconf/db/gdm.d/01-banner-message` file.

If a different GUI login service is in use, consult your documentation and apply an equivalent banner.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

1.8.2 Ensure GDM disable-user-list is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

GNOME Display Manager (GDM) handles graphical login for GNOME based systems.

The `disable-user-list` option controls if a list of users is displayed on the login screen

By using the lockdown mode in dconf, you can prevent users from changing specific settings.

Rationale:

Displaying the user list eliminates half of the Userid/Password equation that an unauthorized person would need to log on.

Without locking down the system settings, user settings take precedence over the system settings.

Audit:

1. Run the following command to verify the `disable-user-list` option is locked:

```
# gsettings writable org.gnome.login-screen disable-user-list

false
```

Note: If the setting is not locked, the value generated by the `gsettings get` command below may be user level opposed to system-wide settings. This setting will need to be validated and potentially remediated after it is locked in accordance with the Remediation procedure.

2. Run the following command and to verify that the `disable-user-list` option is enabled:

```
# gsettings get org.gnome.login-screen disable-user-list

true
```

Remediation:

1. Create or edit the file `/etc/dconf/profile/user` and add the following lines if they do not exist:

```
user-db:user
system-db:local
```

Example:

```
#!/usr/bin/env bash

{
   l_dir="/etc/dconf/profile/"
   [ ! -d "$l_dir" ] && mkdir /etc/dconf/profile/
   ! grep -Psq '^\h*user-db:user\b' "$l_dir/user" && \
   printf '%s\n' "" "user-db:user" >> "$l_dir/user"
   ! grep -Psq '^\h*system-db:local\b' "$l_dir/user" && \
   sed -ri '/^\s*user-db:user/a system-db:local' "$l_dir/user"
}
```

2. Run the following command to create the `/etc/dconf/db/local.d/` and `/etc/dconf/db/local.d/locks/` directories if either does not exist:

```
# [ ! -d "/etc/dconf/db/local.d/locks/" ] && mkdir -p
/etc/dconf/db/local.d/locks/
```

3. Create or edit a file in `/etc/dconf/db/local.d/locks/` and add the following lines:

```
/org/gnome/login-screen/disable-user-list
```

Example:

```
# printf '%s\n' "" "/org/gnome/login-screen/disable-user-list" >>
/etc/dconf/db/local.d/locks/60-login-screen
```

4. Run the following script to comment out any incorrect settings in a local system-wide database keyfile:

```
#!/usr/bin/env bash

{
   l_parameter="disable-user-list=" l_value="false"
   while IFS= read -r -d $'\0' l_file; do
      grep -Psiq -- "^\h*$l_parameter$l_value(\b|\h*$)" "$l_file" && \
      sed -ri '/^\s*'"$l_parameter"'/s/^/# /g' "$l_file"
   done < <(find /etc/dconf/db -mindepth 2 -maxdepth 2 -type f -print0)
}
```

5. Create or edit a local keyfile for machine-wide settings in '/etc/dconf/db/local.d/` with the following lines:

```
[org/gnome/login-screen]
disable-user-list=true
```

Example script:

```
#!/usr/bin/env bash

{
   l_file="/etc/dconf/db/local.d/60-login-screen"
   a_keyfile=("[org/gnome/login-screen]" "disable-user-list=true")
   if grep -Psq -- '^\h*\[org\/gnome\/login-screen\]' "$l_file"; then
      ! grep -Psiq -- '^\h*disable-user-list=true\b' "$l_file" && \
      sed -ri '/^\s*\[org\/gnome\/login-screen\]/a disable-user-list=true'
"$l_file"
      grep -Psiq -- '^\h*disable-user-list=false\b' "$l_file" && \
      sed -ri 's/^\s*(disable-user-list=)(false).*$/\1true/' "$l_file"
   else
      printf '%s\n' "" "${a_keyfile[@]}" >> "$l_file"
   fi
}
```

6. Run the following command to update the dconf databases:

```
# dconf update
```

Note: Users must log out and back in again before the system-wide settings take effect.

Default Value:

false

References:

1. https://help.gnome.org/admin/system-admin-guide/stable/login-userlist-disable.html.en
2. CCI-000366
3. NIST SP 800-53 :: CM-6 b
4. NIST SP 800-53A :: CM-6.1 (iv)
5. STIG ID: RHEL-08-020032 | RULE ID: SV-244536r1017343 | CAT II
6. STIG ID: RHEL-09-271115 | RULE ID: SV-258033r1045120 | CAT II
7. STIG ID: ALMA-09-014430 | RULE ID: SV-269207r1050089 | CAT II

Additional Information:

If a different GUI login service is in use and required on the system, consult your documentation to disable displaying the user list

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

1.8.3 Ensure GDM screen lock is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

GNOME Desktop Manager can make the screen lock automatically whenever the user is idle for some amount of time.

- `idle-delay=uint32 {n}` - Number of seconds of inactivity before the screen goes blank
- `lock-delay=uint32 {n}` - Number of seconds after the screen is blank before locking the screen

By using the lockdown mode in dconf, you can prevent users from changing specific settings.

Rationale:

Setting a lock-out value reduces the window of opportunity for unauthorized user access to another user's session that has been left unattended.

Without locking down the system settings, user settings take precedence over the system settings.

Satisfies: SRG-OS-000029-GPOS-00010, SRG-OS-000031-GPOS-00012, SRG-OS-000480-GPOS-00227

Audit:

1. Run the following commands to verify the screen lock settings are locked:

Run the following command to verify `idle-delay` is locked:

```
# gsettings writable org.gnome.desktop.session idle-delay

false
```

Run the following command to verify `lock-delay` is locked:

```
# gsettings writable org.gnome.desktop.screensaver lock-delay

false
```

Note: If the setting is not locked, the value generated by the gsettings get command below may be user level opposed to system-wide settings. This setting will need to be validated and potentially remediated after it is locked in accordance with the Remediation procedure.

2. Run the following commands to verify the screen lock settings are configured:

Run the following commands to verify that `lock-delay` is set to `5` or less:

```
# gsettings get org.gnome.desktop.screensaver lock-delay
```

Example output:

```
uint32 5
```

Run the following command to verify `idle-delay` is set to `900` (15 minutes) or less and not `0`:

```
# gsettings get org.gnome.desktop.session idle-delay
```

Example output:

```
uint32 900
```

Remediation:

1. Create or edit the file `/etc/dconf/profile/user` and add the following lines if they do not exist:

```
user-db:user
system-db:local
```

Example:

```
#!/usr/bin/env bash

{
   l_dir="/etc/dconf/profile/"
   [ ! -d "$l_dir" ] && mkdir /etc/dconf/profile/
   ! grep -Psq '^\h*user-db:user\b' "$l_dir/user" && \
   printf '%s\n' "" "user-db:user" >> "$l_dir/user"
   ! grep -Psq '^\h*system-db:local\b' "$l_dir/user" && \
   sed -ri '/^\s*user-db:user/a system-db:local' "$l_dir/user"
}
```

2. Run the following command to create the `/etc/dconf/db/local.d/` and `/etc/dconf/db/local.d/locks/` directories if either does not exist:

```
# [ ! -d "/etc/dconf/db/local.d/locks/" ] && mkdir -p
/etc/dconf/db/local.d/locks/
```

3. Create or edit a file in `/etc/dconf/db/local.d/locks/` and add the following lines to lock the login banner configuration:

```
/org/gnome/desktop/session/idle-delay
/org/gnome/desktop/screensaver/lock-delay
```

Example:

```
# printf '%s\n' "" "/org/gnome/desktop/session/idle-delay" \
"/org/gnome/desktop/screensaver/lock-delay" >>
/etc/dconf/db/local.d/locks/60-screensaver
```

4. Run the following script to comment out any incorrect settings in a local system-wide database keyfile:

```
#!/usr/bin/env bash

{
   f_key_file_fix()
   {
      while IFS= read -r -d $'\0' l_file; do
         grep -Psiq -- "^\h*$l_parameter\h+$l_value(\b|\h*$)" "$l_file" && \
         sed -ri '/^\s*'"$l_parameter"'/s/^/# /g' "$l_file"
      done < <(find /etc/dconf/db -mindepth 2 -maxdepth 2 -type f -print0)
   }
   l_parameter="idle-delay=uint32" l_value="(0|90[1-9]|9[1-9][0-9]|1[0-
9]{3,})"; f_key_file_fix
   l_parameter="lock-delay=uint32" l_value="([6-9]|[1-9][0-9]+)";
f_key_file_fix
}
```

5. Create or edit a local keyfile for machine-wide settings in '/etc/dconf/db/local.d/` with the following lines:

```
[org/gnome/desktop/session]
idle-delay=uint32 900

[org/gnome/desktop/screensaver]
lock-delay=uint32 5
```

- idle-delay=uint32 {n} - Number of seconds of inactivity before the screen goes blank. Should be '900' (15 minutes) or less, and not `0` (disabled)
- lock-delay=uint32 {n} - Number of seconds after the screen is blank before locking the screen. Should be `5` or less

Example script:

```
#!/usr/bin/env bash

{
   l_file="/etc/dconf/db/local.d/60-screensaver"
   a_keyfile1=("[org/gnome/desktop/session]" "idle-delay=uint32 900")
   a_keyfile2=("[org/gnome/desktop/screensaver]" "lock-delay=uint32 5")
   if grep -Psq -- '^\h*\[org\/gnome\/desktop\/session\]' "$l_file"; then
      ! grep -Psiq -- '^\h*idle-delay=' "$l_file" && \
      sed -ri '/^\s*\[org\/gnome\/desktop\/session\]/a idle-delay=uint32 900'
"$l_file"
      grep -Psiq -- '^\h*idle-delay=uint32\h+(0|90[1-9]|9[1-9][0-9]|[1-9][0-
9]{3,})\b' \
      "$l_file" && sed -ri 's/^\s*(idle-delay=uint32)\s+([0-9]|[1-9][0-
9]+).*$/\1 900/' "$l_file"
   else
      printf '%s\n' "" "${a_keyfile1[@]}" >> "$l_file"
   fi
   if grep -Psq -- '^\h*\[org\/gnome\/desktop\/screensaver\]' "$l_file"; then
      ! grep -Psiq -- '^\h*lock-delay=' "$l_file" && \
      sed -ri '/^\s*\[org\/gnome\/desktop\/screensaver\]/a lock-delay=uint32
5' "$l_file"
      grep -Psiq -- '^\h*lock-delay=uint32\h+([6-9]|[1-9][0-9]+)\b' "$l_file"
&& \
      sed -ri 's/^\s*(lock-delay=uint32)\s+([6-9]|[1-9][0-9]+).*$/\1 5/'
"$l_file"
   else
      printf '%s\n' "" "${a_keyfile2[@]}" >> "$l_file"
   fi
}
```

6. Run the following command to update the dconf database:

```
# dconf update
```

Note: Users must log out and back in again before the system-wide settings take effect.

References:

1. https://help.gnome.org/admin/system-admin-guide/stable/desktop-lockscreen.html.en
2. CCI-000057
3. NIST SP 800-53 :: AC-11 a
4. NIST SP 800-53A :: AC-11.1 (ii)
5. STIG ID: RHEL-08-020031 | RULE ID: SV-244535r1017342 | CAT II
6. STIG ID: RHEL-08-020060 | RULE ID: SV-230352r1017165 | CAT II
7. STIG ID: RHEL-08-020080 | RULE ID: SV-230354r1069323 | CAT II
8. STIG ID: RHEL-08-020081 | RULE ID: SV-244538r1069324 | CAT II
9. STIG ID: RHEL-09-271065 | RULE ID: SV-258023r958402 | CAT II
10. STIG ID: RHEL-09-271070 | RULE ID: SV-258024r1045100 CAT II
11. STIG ID: RHEL-09-271075 | RULE ID: SV-258025r958402 | CAT II
12. STIG ID: RHEL-09-271080 | RULE ID: SV-258026r1045103 | CAT II
13. STIG ID: ALMA-09-001120 | RULE ID: SV-269103r1049985 | CAT II
14. STIG ID: ALMA-09-001340 | RULE ID: SV-269105r1049987 | CAT II
15. STIG ID: ALMA-09-001450 | RULE ID: SV-269106r1049988 | CAT II
16. STIG ID: ALMA-09-001560 | RULE ID: SV-269107r1049989 | CAT II
17. STIG ID: UBTU-22-271025 | RULE ID: SV-260538r958402 | CAT II
18. STIG ID: UBTU-24-200020 | RULE ID: SV-270678r1066523 | CAT II
19. STIG ID: SLES-15-010120 | RULE ID: SV-234812r958402 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.3 Configure Automatic Session Locking on Enterprise Assets Configure automatic session locking on enterprise assets after a defined period of inactivity. For general purpose operating systems, the period must not exceed 15 minutes. For mobile end-user devices, the period must not exceed 2 minutes.	●	●	●
v7	16.11 Lock Workstation Sessions After Inactivity Automatically lock workstation sessions after a standard period of inactivity.	●	●	●

1.8.4 Ensure GDM automount is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

By default GNOME automatically mounts removable media when inserted as a convenience to the user.

By using the lockdown mode in dconf, you can prevent users from changing specific settings.

Rationale:

With automounting enabled anyone with physical access could attach a USB drive or disc and have its contents available in system even if they lacked permissions to mount it themselves.

Without locking down the system settings, user settings take precedence over the system settings.

Satisfies: SRG-OS-000114-GPOS-00059, SRG-OS-000378-GPOS-00163, SRG-OS-000480-GPOS-00227

Impact:

The use of portable hard drives is very common for workstation users. If your organization allows the use of portable storage or media on workstations and physical access controls to workstations is considered adequate there is little value add in turning off automounting.

Audit:

1. Run the following commands to verify automount settings are locked:

Run the following command to verify `automount` is locked:

```
# gsettings writable org.gnome.desktop.media-handling automount

false
```

Run the following command to verify `automount-open` is locked:

```
# gsettings writable org.gnome.desktop.media-handling automount-open

false
```

2. Run the following commands to verify the automount settings are disabled:

Run the following command to verify `automount` is disabled:

```
# gsettings get org.gnome.desktop.media-handling automount

false
```

Run the following command to verify `automount-open` is disabled:

```
# gsettings get org.gnome.desktop.media-handling automount-open

false
```

Remediation:

1. Create or edit the file `/etc/dconf/profile/user` and add the following lines if they do not exist:

```
user-db:user
system-db:local
```

Example:

```
#!/usr/bin/env bash

{
   l_dir="/etc/dconf/profile/"
   [ ! -d "$l_dir" ] && mkdir /etc/dconf/profile/
   ! grep -Psq '^\h*user-db:user\b' "$l_dir/user" && \
   printf '%s\n' "" "user-db:user" >> "$l_dir/user"
   ! grep -Psq '^\h*system-db:local\b' "$l_dir/user" && \
   sed -ri '/^\s*user-db:user/a system-db:local' "$l_dir/user"
}
```

2. Run the following command to create the `/etc/dconf/db/local.d/` and `/etc/dconf/db/local.d/locks/` directories if either does not exist:

```
# [ ! -d "/etc/dconf/db/local.d/locks/" ] && mkdir -p
/etc/dconf/db/local.d/locks/
```

3. Create or edit a file in `/etc/dconf/db/local.d/locks/` and add the following lines:

```
/org/gnome/desktop/media-handling/automount
/org/gnome/desktop/media-handling/automount-open
```

Example:

```
# printf '%s\n' "" "/org/gnome/desktop/media-handling/automount" \
"/org/gnome/desktop/media-handling/automount-open" >> \
/etc/dconf/db/local.d/locks/60-media-automount
```

4. Run the following script to comment out any incorrect settings in a local system-wide database keyfile:

```
#!/usr/bin/env bash

{
   f_key_file_fix()
   {
      while IFS= read -r -d $'\0' l_file; do
         grep -Psiq -- "^\h*$l_parameter$l_value(\b|\h*$)" "$l_file" && \
         sed -ri '/^\s*'"$l_parameter"'/s/^/# /g' "$l_file"
      done < <(find /etc/dconf/db -mindepth 2 -maxdepth 2 -type f -print0)
   }
   l_parameter="automount=" l_value="true"; f_key_file_fix
   l_parameter="automount-open=" l_value="true"; f_key_file_fix
}
```

5. Create or edit a local keyfile for machine-wide settings in '/etc/dconf/db/local.d/` with the following lines:

```
[org/gnome/desktop/media-handling]
automount=false
automount-open=false
```

Example script:

```
#!/usr/bin/env bash

{
   l_file="/etc/dconf/db/local.d/60-media-automount"
   a_keyfile=("[org/gnome/desktop/media-handling]" "automount=false"
"automount-open=false")
   if grep -Psq -- '^\h*\[org\/gnome\/desktop\/media-handling\]' "$l_file";
then
      ! grep -Psiq -- '^\h*automount-open=false\b' "$l_file" && \
      sed -ri '/^\s*\[org\/gnome\/desktop\/media-handling\]/a automount-
open=false' "$l_file"
      ! grep -Psiq -- '^\h*automount=false\b' "$l_file" && \
      sed -ri '/^\s*\[org\/gnome\/desktop\/media-handling\]/a
automount=false' "$l_file"
      grep -Psiq -- '^\h*automount=true\b' "$l_file" && \
      sed -ri 's/^\s*(automount=)(true).*$/\1fales/' "$l_file"
      grep -Psiq -- '^\h*automount-open=true\b' "$l_file" && \
      sed -ri 's/^\s*(automount-open=)(true).*$/\1fales/' "$l_file"
   else
      printf '%s\n' "" "${a_keyfile[@]}" >> "$l_file"
   fi
}
```

6. Run the following command to update the dconf databases:

```
# dconf update
```

Note: Users must log out and back in again before the system-wide settings take effect.

References:

1. https://access.redhat.com/solutions/20107
2. CCI-000778 | CCI-001958
3. NIST SP 800-53 :: IA-3
4. NIST SP 800-53A :: IA-3.1 (ii)
5. STIG ID: RHEL-09-271020 | RULE ID: SV-258014r1045084 | CAT II
6. STIG ID: RHEL-09-271025 | RULE ID: SV-258015r1045086 | CAT II
7. STIG ID: ALMA-09-034890 | RULE ID: SV-269377r1050260 | CAT II
8. STIG ID: ALMA-09-035000 | RULE ID: SV-269378r1050261 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.3 Disable Autorun and Autoplay for Removable Media Disable autorun and autoplay auto-execute functionality for removable media.	●	●	●
v7	8.5 Configure Devices Not To Auto-run Content Configure devices to not auto-run content from removable media.	●	●	●

1.8.5 Ensure GDM autorun-never is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `autorun-never` setting allows the GNOME Desktop Display Manager to disable autorun through GDM.

By using the lockdown mode in dconf, you can prevent users from changing specific settings.

Rationale:

Malware on removable media may take advantage of Autorun features when the media is inserted into a system and execute.

Without locking down the system settings, user settings take precedence over the system settings.

Satisfies: SRG-OS-000114-GPOS-00059, SRG-OS-000378-GPOS-00163, SRG-OS-000480-GPOS-00227

Audit:

1. Run the following command to verify the `autorun-never` option is locked:

```
# gsettings writable org.gnome.desktop.media-handling autorun-never

false
```

Note: If the setting is not locked, the value generated by the `gsettings get` command below may be user level opposed to system-wide settings. This setting will need to be validated and potentially remediated after it is locked in accordance with the Remediation procedure.

2. Run the following command and to verify that the `autorun-never` option is enabled:

```
# gsettings get org.gnome.desktop.media-handling autorun-never

true
```

Remediation:

1. Create or edit the file `/etc/dconf/profile/user` and add the following lines if they do not exist:

```
user-db:user
system-db:local
```

Example:

```
#!/usr/bin/env bash

{
   l_dir="/etc/dconf/profile/"
   [ ! -d "$l_dir" ] && mkdir /etc/dconf/profile/
   ! grep -Psq '^\h*user-db:user\b' "$l_dir/user" && \
   printf '%s\n' "" "user-db:user" >> "$l_dir/user"
   ! grep -Psq '^\h*system-db:local\b' "$l_dir/user" && \
   sed -ri '/^\s*user-db:user/a system-db:local' "$l_dir/user"
}
```

2. Run the following command to create the `/etc/dconf/db/local.d/` and `/etc/dconf/db/local.d/locks/` directories if either does not exist:

```
# [ ! -d "/etc/dconf/db/local.d/locks/" ] && mkdir -p
/etc/dconf/db/local.d/locks/
```

3. Create or edit a file in `/etc/dconf/db/local.d/locks/` and add the following lines:

```
/org/gnome/desktop/media-handling/autorun-never
```

Example:

```
# printf '%s\n' "" "/org/gnome/desktop/media-handling/autorun-never" >> \
/etc/dconf/db/local.d/locks/60-media-autorun
```

4. Run the following script to comment out any incorrect settings in a local system-wide database keyfile:

```
#!/usr/bin/env bash

{
   l_parameter="autorun-never=" l_value="false"
   while IFS= read -r -d $'\0' l_file; do
      grep -Psiq -- "^\h*$l_parameter$l_value(\b|\h*$)" "$l_file" && \
      sed -ri '/^\s*'"$l_parameter"'/s/^/# /g' "$l_file"
   done < <(find /etc/dconf/db -mindepth 2 -maxdepth 2 -type f -print0)
}
```

5. Create or edit a local keyfile for machine-wide settings in '/etc/dconf/db/local.d/` with the following lines:

```
[org/gnome/desktop/media-handling]
autorun-never=true
```

Example script:

```
#!/usr/bin/env bash

{
   l_file="/etc/dconf/db/local.d/60-media-autorun"
   a_keyfile=("[org/gnome/desktop/media-handling]" "autorun-never=true")
   if grep -Psq -- '^\h*\[org\/gnome\/desktop\/media-handling\]' "$l_file";
then
      ! grep -Psiq -- '^\h*autorun-never=true\b' "$l_file" && \
      sed -ri '/^\s*\[org\/gnome\/desktop\/media-handling\]/a autorun-
never=true' "$l_file"
      grep -Psiq -- '^\h*autorun-never=false\b' "$l_file" && \
      sed -ri 's/^\s*(autorun-never=)(false).*$/\1true/' "$l_file"
   else
      printf '%s\n' "" "${a_keyfile[@]}" >> "$l_file"
   fi
}
```

6. Run the following command to update the dconf databases:

```
# dconf update
```

Note: Users must log out and back in again before the system-wide settings take effect.

Default Value:

false

References:

1. CCI-001764
2. NIST SP 800-53 :: CM-7 (2)
3. STIG ID: RHEL-09-271030 | RULE ID: SV-258016r958804 | CAT II
4. STIG ID: RHEL-09-271035 | RULE ID: SV-258017r1045088 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.3 Disable Autorun and Autoplay for Removable Media Disable autorun and autoplay auto-execute functionality for removable media.	●	●	●
v7	8.5 Configure Devices Not To Auto-run Content Configure devices to not auto-run content from removable media.	●	●	●

1.8.6 Ensure XDMCP is not enabled (Automated)

Profile Applicability:

- Level 1 - Server

Description:

X Display Manager Control Protocol (XDMCP) is designed to provide authenticated access to display management services for remote displays

Rationale:

XDMCP is inherently insecure.

- XDMCP is not a ciphered protocol. This may allow an attacker to capture keystrokes entered by a user
- XDMCP is vulnerable to man-in-the-middle attacks. This may allow an attacker to steal the credentials of legitimate users by impersonating the XDMCP server.

Audit:

Run the following command and verify the output:

```
# sed -n '/\[xdmcp\]/,/\[/p' /etc/gdm/custom.conf | grep -Psi --
'^\h*Enable\h*=\h*true\b'

Nothing should be returned
```

Remediation:

Edit the file `/etc/gdm/custom.conf` and remove the line from the `[xdmcp]` block:

```
Enable=true
```

Example:

```
# GDM configuration storage

[daemon]
WaylandEnable=false

[security]

[xdmcp]

[chooser]

[debug]
# Uncomment the line below to turn on debugging
#Enable=true
```

Default Value:

false

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

1.8.7 Ensure Xwayland is configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Xwayland is a compatibility layer that allows legacy X11 applications to run within a Wayland environment. It's effectively an X server that runs as a Wayland client, enabling existing X11 software to be displayed on a Wayland compositor.

Rationale:

Wayland's security benefits from not relying on X11's network listener. Without X11, there's no network listener, making it harder for malicious actors to exploit vulnerabilities in X11. However, enabling Xwayland (running X11 applications on Wayland) introduces X11's security concerns.

All X vulnerabilities apply to Xwayland, including keylogging, but they only affect X windows and interactions with them.

Malware can potentially exploit Xwayland vulnerabilities to keylog or intercept other input events

Impact:

Many applications haven't been ported to Wayland yet, and Xwayland makes it possible to run these applications without requiring a full switch back to X11. Disabling Xwayland functionality may cause these applications to fail.

Audit:

Run the following command to verify Xwayland is not enabled:

```
# sed -n '/\[daemon\]/,/\[/p' /etc/gdm/custom.conf | grep -Psi
'^\h*waylandenable\b'
```

Verify output includes:

```
WaylandEnable=false
```

Remediation:

Edit the file `/etc/gdm/custom.conf` and uncomment or add the following line in the `[daemon]` block:

```
WaylandEnable=false
```

Example:

```
# GDM configuration storage

[daemon]
WaylandEnable=false

[security]

[xdmcp]

[chooser]

[debug]
# Uncomment the line below to turn on debugging
#Enable=true
```

Default Value:

Enabled

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2 Services

While applying system updates and patches helps correct known vulnerabilities, one of the best ways to protect the system against as yet unreported vulnerabilities is to disable all services that are not required for normal system operation. This prevents the exploitation of vulnerabilities discovered at a later date. If a service is not enabled, it cannot be exploited. The actions in this section of the document provide guidance on some services which can be safely disabled and under which circumstances, greatly reducing the number of possible threats to the resulting system. Additionally, some services which should remain enabled but with secure configuration are covered as well as insecure service clients.

2.1 Configure Server Services

This section describes services that are installed on systems that specifically need to run these services. If any of these services are not required, it is recommended that the package be removed.

- IF - the package is required for a dependency:

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy
- Stop and mask the service and/or socket to reduce the potential attack surface

The following commands can be used to stop and mask the service and socket:

```
# systemctl stop <service_name>.socket <service_name>.service
# systemctl mask <service_name>.socket <service_name>.service
```

Note: This should not be considered a comprehensive list of services not required for normal system operation. You may wish to consider additions to those listed here for your environment

2.1.1 Ensure autofs services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`autofs` allows automatic mounting of devices, typically including CD/DVDs and USB drives.

Rationale:

With automounting enabled anyone with physical access could attach a USB drive or disc and have its contents available in system even if they lacked permissions to mount it themselves.

Impact:

The use of portable hard drives is very common for workstation users. If your organization allows the use of portable storage or media on workstations and physical access controls to workstations is considered adequate there is little value add in turning off automounting.

There may be packages that are dependent on the `autofs` package. If the `autofs` package is removed, these dependent packages will be removed as well. Before removing the `autofs` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask the `autofs.service` leaving the `autofs` package installed.

Audit:

As a preference `autofs` should not be installed unless other packages depend on it.

Run the following command to verify `autofs` is not installed:

```
# rpm -q autofs

package autofs is not installed
```

- OR -

- IF - the package is required for dependencies:

Run the following command to verify `autofs.service` is not enabled:

```
# systemctl is-enabled autofs.service 2>/dev/null | grep 'enabled'

Nothing should be returned
```

Run the following command to verify the `autofs.service` is not active:

```
# systemctl is-active autofs.service 2>/dev/null | grep '^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `autofs.service` and remove `autofs` package:

```
# systemctl stop autofs.service
# dnf remove autofs
```

- OR -

- IF - the `autofs` package is required as a dependency:

Run the following commands to stop and mask `autofs.service`:

```
# systemctl stop autofs.service
# systemctl mask autofs.service
```

References:

1. NIST SP 800-53 Rev. 5: SI-3, MP-7

Additional Information:

This control should align with the tolerance of the use of portable drives and optical media in the organization. On a server requiring an admin to manually mount media can be part of defense-in-depth to reduce the risk of unapproved software or information being introduced or proprietary software or information being exfiltrated. If admins commonly use flash drives and Server access has sufficient physical controls, requiring manual mounting may not increase security.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.3 Disable Autorun and Autoplay for Removable Media Disable autorun and autoplay auto-execute functionality for removable media.	●	●	●
v7	8.5 Configure Devices Not To Auto-run Content Configure devices to not auto-run content from removable media.	●	●	●

2.1.2 Ensure avahi daemon services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Avahi is a free zeroconf implementation, including a system for multicast DNS/DNS-SD service discovery. Avahi allows programs to publish and discover services and hosts running on a local network with no specific configuration. For example, a user can plug a computer into a network and Avahi automatically finds printers to print to, files to look at and people to talk to, as well as network services running on the machine.

Rationale:

Automatic discovery of network services is not normally required for system functionality. It is recommended to remove this package to reduce the potential attack surface.

Impact:

There may be packages that are dependent on the `avahi` package. If the `avahi` package is removed, these dependent packages will be removed as well. Before removing the `avahi` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask the `avahi-daemon.socket` and `avahi-daemon.service` leaving the `avahi` package installed.

Audit:

Run the following command to verify the `avahi` package is not installed:

```
# rpm -q avahi

package avahi is not installed
```

- OR -

- IF - the `avahi` package is required as a dependency:

Run the following command to verify `avahi-daemon.socket` and `avahi-daemon.service` are not enabled:

```
# systemctl is-enabled avahi-daemon.socket avahi-daemon.service 2>/dev/null |
grep 'enabled'

Nothing should be returned
```

Run the following command to verify `avahi-daemon.socket` and `avahi-daemon.service` are not active:

```
# systemctl is-active avahi-daemon.socket avahi-daemon.service 2>/dev/null |
grep '^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `avahi-daemon.socket` and `avahi-daemon.service`, and remove the `avahi` package:

```
# systemctl stop avahi-daemon.socket avahi-daemon.service
# dnf remove avahi
```

- OR -

- IF - the `avahi` package is required as a dependency:

Run the following commands to stop and mask the `avahi-daemon.socket` and `avahi-daemon.service`:

```
# systemctl stop avahi-daemon.socket avahi-daemon.service
# systemctl mask avahi-daemon.socket avahi-daemon.service
```

References:

1. NIST SP 800-53 Rev. 5: SI-4

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.3 Ensure cockpit web services are not in use (Automated)

Profile Applicability:

- Level 2 - Server

Description:

cockpit Web services provide the ability to remotely administer the system via a web browser.

Rationale:

Unless there is a local site approved requirement for remote web based administration on the system, cockpit web server packages should be removed to reduce the potential attack surface.

Impact:

Removal of cockpit web service packages will remove the ability for remote web administration of that system.

- IF - the cockpit web services package is required for a dependency, any related service or socket should be stopped and masked.

Note: If the remediation steps to mask a service are followed and that package is not installed on the system, the service and/or socket will still be masked. If the package is installed due to an approved requirement to host a web server, the associated service and/or socket would need to be unmasked before it could be enabled and/or started.

Audit:

Run the following command to verify `cockpit-ws` is not installed:

```
# rpm -q cockpit-ws

package cockpit-ws is not installed
```

- OR -

- IF - a package is installed **and** is required for dependencies:

Run the following command to verify `cockpit.socket`, and `cockpit.service` are not enabled:

```
# systemctl is-enabled cockpit.socket cockpit.service 2>/dev/null | grep
'enabled'

Nothing should be returned
```

Run the following command to verify `cockpit.socket`, and `cockpit.service` are not active:

```
# systemctl is-active cockpit.socket cockpit.service 2>/dev/null | grep
'^active'

Nothing should be returned
```

Remediation:

Run the following commands to stop `cockpit.socket`, and `cockpit.service`, and remove the `cockpit-ws` package:

```
# systemctl stop cockpit.socket cockpit.service
# dnf remove cockpit-ws
```

- OR -

- IF - a package is installed **and** is required for dependencies:

Run the following commands to stop and mask `cockpit.socket`, and `cockpit.service`:

```
# systemctl stop cockpit.socket cockpit.service
# systemctl mask cockpit.socket cockpit.service
```

References:

1. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.4 Ensure dhcp server services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The Dynamic Host Configuration Protocol (DHCP) is a service that allows machines to be dynamically assigned IP addresses. There are two versions of the DHCP protocol `DHCPv4` and `DHCPv6`. At startup the server may be started for one or the other via the `-4` or `-6` arguments.

Rationale:

Unless a system is specifically set up to act as a DHCP server, it is recommended that the `dhcp-server` package be removed to reduce the potential attack surface.

Impact:

There may be packages that are dependent on the `dhcp-server` package. If the `dhcp-server` package is removed, these dependent packages will be removed as well. Before removing the `dhcp-server` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask the `dhcpd.service` and `dhcpd6.service` leaving the `dhcp-server` package installed.

Audit:

Run the following command to verify `dhcp-server` is not installed:

```
# rpm -q dhcp-server

package dhcp-server is not installed
```

- OR -

- IF - the package is required for dependencies:

Run the following command to verify `dhcpd.service` and `dhcpd6.service` are not enabled:

```
# systemctl is-enabled dhcpd.service dhcpd6.service 2>/dev/null | grep
'enabled'

Nothing should be returned
```

Run the following command to verify `dhcpd.service` and `dhcpd6.service` are not active:

```
# systemctl is-active dhcpd.service dhcpd6.service 2>/dev/null | grep
'^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `dhcpd.service` and `dhcpd6.service` and remove `dhcp-server` package:

```
# systemctl stop dhcpd.service dhcpd6.service
# dnf remove dhcp-server
```

- OR -

- IF - the `dhcp-server` package is required as a dependency:

Run the following commands to stop and mask `dhcpd.service` and `dhcpd6.service`:

```
# systemctl stop dhcpd.service dhcpd6.service
# systemctl mask dhcpd.service dhcpd6.service
```

References:

1. dhcpd(8)
2. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.5 Ensure dns server services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The Domain Name System (DNS) is a hierarchical naming system that maps names to IP addresses for computers, services and other resources connected to a network.

Rationale:

Unless a system is specifically designated to act as a DNS server, it is recommended that the package be removed to reduce the potential attack surface.

Impact:

There may be packages that are dependent on the `bind` package. If the `bind` package is removed, these dependent packages will be removed as well. Before removing the `bind` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask the `named.service` leaving the `bind` package installed.

Audit:

Run one of the following commands to verify `bind` is not installed:

```
# rpm -q bind

package bind is not installed
```

- OR -

- IF - the package is required for dependencies:

Run the following command to verify `named.service` is not enabled:

```
# systemctl is-enabled named.service 2>/dev/null | grep 'enabled'

Nothing should be returned
```

Run the following command to verify the `named.service` is not active:

```
# systemctl is-active named.service 2>/dev/null | grep '^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `named.service` and remove `bind` package:

```
# systemctl stop named.service
# dnf remove bind
```

- OR -

- IF - the `bind` package is required as a dependency:

Run the following commands to stop and mask `named.service`:

```
# systemctl stop named.service
# systemctl mask named.service
```

References:

1. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.6 Ensure dnsmasq services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`dnsmasq` is a lightweight tool that provides DNS caching, DNS forwarding and DHCP (Dynamic Host Configuration Protocol) services.

Rationale:

Unless a system is specifically designated to act as a DNS caching, DNS forwarding and/or DHCP server, it is recommended that the package be removed to reduce the potential attack surface.

Impact:

There may be packages that are dependent on the `dnsmasq` package. If the `dnsmasq` package is removed, these dependent packages will be removed as well. Before removing the `dnsmasq` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask the `dnsmasq.service` leaving the `dnsmasq` package installed.

Audit:

Run one of the following commands to verify `dnsmasq` is not installed:

```
# rpm -q dnsmasq

package dnsmasq is not installed
```

- OR -

- IF - the package is required for dependencies:

Run the following command to verify `dnsmasq.service` is not enabled:

```
# systemctl is-enabled dnsmasq.service 2>/dev/null | grep 'enabled'

Nothing should be returned
```

Run the following command to verify the `dnsmasq.service` is not active:

```
# systemctl is-active dnsmasq.service 2>/dev/null | grep '^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `dnsmasq.service` and remove `dnsmasq` package:

```
# systemctl stop dnsmasq.service
# dnf remove dnsmasq
```

- OR -

- IF - the `dnsmasq` package is required as a dependency:

Run the following commands to stop and mask the `dnsmasq.service`:

```
# systemctl stop dnsmasq.service
# systemctl mask dnsmasq.service
```

References:

1. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.7 Ensure ftp server services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

FTP (File Transfer Protocol) is a traditional and widely used standard tool for transferring files between a server and clients over a network, especially where no authentication is necessary (permits anonymous users to connect to a server).

Rationale:

Unless there is a need to run the system as a FTP server, it is recommended that the package be removed to reduce the potential attack surface.

Impact:

There may be packages that are dependent on the `vsftpd` package. If the `vsftpd` package is removed, these dependent packages will be removed as well. Before removing the `vsftpd` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask the `vsftpd.service` leaving the `vsftpd` package installed.

Audit:

Run the following command to verify `vsftpd` is not installed:

```
# rpm -q vsftpd

package vsftpd is not installed
```

- OR -

- IF - the package is required for dependencies:

Run the following command to verify `vsftpd` service is not enabled:

```
# systemctl is-enabled vsftpd.service 2>/dev/null | grep 'enabled'

Nothing should be returned
```

Run the following command to verify the `vsftpd` service is not active:

```
# systemctl is-active vsftpd.service 2>/dev/null | grep '^active'

Nothing should be returned
```

Note:

- Other ftp server packages may exist. They should also be audited, if not required and authorized by local site policy
- If the package is required for a dependency:
  - Ensure the dependent package is approved by local site policy
  - Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `vsftpd.service` and remove `vsftpd` package:

```
# systemctl stop vsftpd.service
# dnf remove vsftpd
```

- OR -

- IF - the `vsftpd` package is required as a dependency:

Run the following commands to stop and mask the `vsftpd.service`:

```
# systemctl stop vsftpd.service
# systemctl mask vsftpd.service
```

Note: Other ftp server packages may exist. If not required and authorized by local site policy, they should also be removed. If the package is required for a dependency, the service should be stopped and masked.

References:

1. NIST SP 800-53 Rev. 5: CM-7
2. NIST SP 800-53A :: CM-6.1 (iv)
3. RHEL 8 STIG Vul ID: V-230558
4. RHEL 8 STIG Rule ID: SV-230558r627750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.8 Ensure message access server services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`dovecot` and `cyrus-imapd` are open source IMAP and POP3 server packages for Linux based systems.

Rationale:

Unless POP3 and/or IMAP servers are to be provided by this system, it is recommended that the package be removed to reduce the potential attack surface.

Note: Several IMAP/POP3 servers exist and can use other service names. These should also be audited and the packages removed if not required.

Impact:

There may be packages that are dependent on `dovecot` and `cyrus-imapd` packages. If `dovecot` and `cyrus-imapd` packages are removed, these dependent packages will be removed as well. Before removing `dovecot` and `cyrus-imapd` packages, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask `dovecot.socket`, `dovecot.service` and `cyrus-imapd.service` leaving `dovecot` and `cyrus-imapd` packages installed.

Audit:

Run the following command to verify `dovecot` and `cyrus-imapd` are not installed:

```
# rpm -q dovecot cyrus-imapd

package dovecot is not installed
package cyrus-imapd is not installed
```

- OR -

- IF - a package is installed **and** is required for dependencies:

Run the following commands to verify `dovecot.socket`, `dovecot.service`, and `cyrus-imapd.service` are not enabled:

```
# systemctl is-enabled dovecot.socket dovecot.service cyrus-imapd.service
2>/dev/null | grep 'enabled'

Nothing should be returned
```

Run the following command to verify `dovecot.socket`, `dovecot.service`, and `cyrus-imapd.service` are not active:

```
# systemctl is-active dovecot.socket dovecot.service cyrus-imapd.service
2>/dev/null | grep '^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `dovecot.socket`, `dovecot.service`, and `cyrus-imapd.service`, and remove `dovecot` and `cyrus-imapd` packages:

```
# systemctl stop dovecot.socket dovecot.service cyrus-imapd.service
# dnf remove dovecot cyrus-imapd
```

- OR -

- IF - a package is installed **and** is required for dependencies:

Run the following commands to stop and mask `dovecot.socket`, `dovecot.service`, and `cyrus-imapd.service`:

```
# systemctl stop dovecot.socket dovecot.service cyrus-imapd.service
# systemctl mask dovecot.socket dovecot.service cyrus-imapd.service
```

References:

1. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.9 Ensure network file system services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The Network File System (NFS) is one of the first and most widely distributed file systems in the UNIX environment. It provides the ability for systems to mount file systems of other servers through the network.

Rationale:

If the system does not require access to network shares or the ability to provide network file system services for other host's network shares, it is recommended that the `nfs-utils` package be removed to reduce the attack surface of the system.

Impact:

Many of the `libvirt` packages used by Enterprise Linux virtualization are dependent on the `nfs-utils` package. If the `nfs-utils` package is removed, these dependent packages will be removed as well. Before removing the `nfs-utils` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask the `nfs-server.service` leaving the `nfs-utils` package installed.

Audit:

Run the following command to verify `nfs-utils` is not installed:

```
# rpm -q nfs-utils

package nfs-utils is not installed
```

- OR - If package is required for dependencies:

Run the following command to verify that the `nfs-server.service` is not enabled:

```
# systemctl is-enabled nfs-server.service 2>/dev/null | grep 'enabled'

Nothing should be returned
```

Run the following command to verify the `nfs-server.service` is not active:

```
# systemctl is-active nfs-server.service 2>/dev/null | grep '^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following command to stop `nfs-server.service` and remove `nfs-utils` package:

```
# systemctl stop nfs-server.service
# dnf remove nfs-utils
```

- OR -

- IF - the `nfs-utils` package is required as a dependency:

Run the following commands to stop and mask the `nfs-server.service`:

```
# systemctl stop nfs-server.service
# systemctl mask nfs-server.service
```

References:

1. NIST SP 800-53 Rev. 5: CM-6, CM-7

Additional Information:

Many of the libvirt packages used by Enterprise Linux virtualization are dependent on the nfs-utils package. If the nfs-utils package is required as a dependency, the nfs-server service should be disabled and masked to reduce the attack surface of the system.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.10 Ensure nis server services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The Network Information Service (NIS), formerly known as Yellow Pages, is a client-server directory service protocol used to distribute system configuration files. The NIS client (`ypbind`) was used to bind a machine to an NIS server and receive the distributed configuration files.

Rationale:

The NIS service is inherently an insecure system that has been vulnerable to DOS attacks, buffer overflows and has poor authentication for querying NIS maps. NIS generally has been replaced by such protocols as Lightweight Directory Access Protocol (LDAP). It is recommended that the service be removed.

Impact:

There may be packages that are dependent on the `ypserv` package. If the `ypserv` package is removed, these dependent packages will be removed as well. Before removing the `ypserv` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask the `ypserv.service` leaving the `ypserv` package installed.

Audit:

Run the following command to verify `ypserv` is not installed:

```
# rpm -q ypserv

package ypserv is not installed
```

- OR -

- IF - the package is required for dependencies:

Run the following command to verify `ypserv.service` is not enabled:

```
# systemctl is-enabled ypserv.service 2>/dev/null | grep 'enabled'

Nothing should be returned
```

Run the following command to verify `ypserv.service` is not active:

```
# systemctl is-active ypserv.service 2>/dev/null | grep '^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `ypserv.service` and remove `ypserv` package:

```
# systemctl stop ypserv.service
# dnf remove ypserv
```

- OR -

- IF - the `ypserv` package is required as a dependency:

Run the following commands to stop and mask `ypserv.service`:

```
# systemctl stop ypserv.service
# systemctl mask ypserv.service
```

References:

1. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.11 Ensure print server services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The Common Unix Print System (CUPS) provides the ability to print to both local and network printers. A system running CUPS can also accept print jobs from remote systems and print them to local printers. It also provides a web based remote administration capability.

Rationale:

If the system does not need to print jobs or accept print jobs from other systems, it is recommended that CUPS be removed to reduce the potential attack surface.

Impact:

Removing the cups package, or disabling `cups.socket` and/or `cups.service` will prevent printing from the system, a common task for workstation systems.

There may be packages that are dependent on the `cups` package. If the `cups` package is removed, these dependent packages will be removed as well. Before removing the `cups` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask `cups.socket` and `cups.service` leaving the `cups` package installed.

Audit:

Run the following command to verify `cups` is not installed:

```
# rpm -q cups

package cups is not installed
```

- OR -

- IF - the `cups` package is required as a dependency:

Run the following command to verify the `cups.socket` and `cups.service` are not enabled:

```
# systemctl is-enabled cups.socket cups.service 2>/dev/null | grep 'enabled'

Nothing should be returned
```

Run the following command to verify the `cups.socket` and `cups.service` are not active:

```
# systemctl is-active cups.socket cups.service 2>/dev/null | grep '^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `cups.socket` and `cups.service`, and remove the `cups` package:

```
# systemctl stop cups.socket cups.service
# dnf remove cups
```

- OR -

- IF - the `cups` package is required as a dependency:

Run the following commands to stop and mask the `cups.socket` and `cups.service`:

```
# systemctl stop cups.socket cups.service
# systemctl mask cups.socket cups.service
```

References:

1. http://www.cups.org
2. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.12 Ensure rpcbind services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `rpcbind` utility maps RPC services to the ports on which they listen. RPC processes notify `rpcbind` when they start, registering the ports they are listening on and the RPC program numbers they expect to serve. The client system then contacts `rpcbind` on the server with a particular RPC program number. The `rpcbind.service` redirects the client to the proper port number so it can communicate with the requested service.

Portmapper is an RPC service, which always listens on tcp and udp 111, and is used to map other RPC services (such as nfs, nlockmgr, quotad, mountd, etc.) to their corresponding port number on the server. When a remote host makes an RPC call to that server, it first consults with portmap to determine where the RPC server is listening.

Rationale:

A small request (~82 bytes via UDP) sent to the Portmapper generates a large response (7x to 28x amplification), which makes it a suitable tool for DDoS attacks. If `rpcbind` is not required, it is recommended to remove `rpcbind` package to reduce the potential attack surface.

Impact:

Many of the libvirt packages used by Enterprise Linux virtualization, and the `nfs-utils` package used for The Network File System (NFS), are dependent on the `rpcbind` package. If the `rpcbind` package is removed, these dependent packages will be removed as well. Before removing the `rpcbind` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask the `rpcbind.socket` and `rpcbind.service` leaving the `rpcbind` package installed.

Audit:

Run the following command to verify `rpcbind` package is not installed:

```
# rpm -q rpcbind

package rpcbind is not installed
```

- OR -

- IF - the `rpcbind` package is required as a dependency:

Run the following command to verify `rpcbind.socket` and `rpcbind.service` are not enabled:

```
# systemctl is-enabled rpcbind.socket rpcbind.service 2>/dev/null | grep
'enabled'

Nothing should be returned
```

Run the following command to verify `rpcbind.socket` and `rpcbind.service` are not active:

```
# systemctl is-active rpcbind.socket rpcbind.service 2>/dev/null | grep
'^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `rpcbind.socket` and `rpcbind.service`, and remove the `rpcbind` package:

```
# systemctl stop rpcbind.socket rpcbind.service
# dnf remove rpcbind
```

- OR -

- IF - the `rpcbind` package is required as a dependency:

Run the following commands to stop and mask the `rpcbind.socket` and `rpcbind.service`:

```
# systemctl stop rpcbind.socket rpcbind.service
# systemctl mask rpcbind.socket rpcbind.service
```

References:

1. NIST SP 800-53 Rev. 5: CM-6, CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.13 Ensure rsync services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `rsyncd.service` can be used to synchronize files between systems over network links.

Rationale:

Unless required, the `rsync-daemon` package should be removed to reduce the potential attack surface.

The `rsyncd.service` presents a security risk as it uses unencrypted protocols for communication.

Impact:

There may be packages that are dependent on the `rsync-daemon` package. If the `rsync-daemon` package is removed, these dependent packages will be removed as well. Before removing the `rsync-daemon` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask the `rsyncd.socket` and `rsyncd.service` leaving the `rsync-daemon` package installed.

Audit:

Run the following command to verify the `rsync-daemon` package is not installed:

```
# rpm -q rsync-daemon

package rsync-daemon is not installed
```

- OR -

- IF - the `rsync-daemon` package is required as a dependency:

Run the following command to verify `rsyncd.socket` and `rsyncd.service` are not enabled:

```
# systemctl is-enabled rsyncd.socket rsyncd.service 2>/dev/null | grep
'enabled'

Nothing should be returned
```

Run the following command to verify `rsyncd.socket` and `rsyncd.service` are not active:

```
# systemctl is-active rsyncd.socket rsyncd.service 2>/dev/null | grep
'^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `rsyncd.socket` and `rsyncd.service`, and remove the `rsync-daemon` package:

```
# systemctl stop rsyncd.socket rsyncd.service
# dnf remove rsync-daemon
```

- OR -

- IF - the `rsync-daemon` package is required as a dependency:

Run the following commands to stop and mask the `rsyncd.socket` and `rsyncd.service`:

```
# systemctl stop rsyncd.socket rsyncd.service
# systemctl mask rsyncd.socket rsyncd.service
```

References:

1. NIST SP 800-53 Rev. 5: CM-6, CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.14 Ensure samba file server services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The Samba daemon allows system administrators to configure their Linux systems to share file systems and directories with Windows desktops. Samba will advertise the file systems and directories via the Server Message Block (SMB) protocol. Windows desktop users will be able to mount these directories and file systems as letter drives on their systems.

Rationale:

If there is no need to mount directories and file systems to Windows systems, then this package can be removed to reduce the potential attack surface.

Impact:

There may be packages that are dependent on the `samba` package. If the `samba` package is removed, these dependent packages will be removed as well. Before removing the `samba` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask the `smb.service` leaving the `samba` package installed.

Audit:

Run the following command to verify `samba` package is not installed:

```
# rpm -q samba

package samba is not installed
```

- OR -

- IF - the package is required for dependencies:

Run the following command to verify `smb.service` is not enabled:

```
# systemctl is-enabled smb.service 2>/dev/null | grep 'enabled'

Nothing should be returned
```

Run the following command to verify the `smb.service` is not active:

```
# systemctl is-active smb.service 2>/dev/null | grep '^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following command to stop `smb.service` and remove `samba` package:

```
# systemctl stop smb.service
# dnf remove samba
```

- OR -

- IF - the `samba` package is required as a dependency:

Run the following commands to stop and mask the `smb.service`:

```
# systemctl stop smb.service
# systemctl mask smb.service
```

References:

1. NIST SP 800-53 Rev. 5: CM-6, CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.15 Ensure snmp services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Simple Network Management Protocol (SNMP) is a widely used protocol for monitoring the health and welfare of network equipment, computer equipment and devices like UPSs.

Net-SNMP is a suite of applications used to implement SNMPv1 (RFC 1157), SNMPv2 (RFCs 1901-1908), and SNMPv3 (RFCs 3411-3418) using both IPv4 and IPv6.

Support for SNMPv2 classic (a.k.a. "SNMPv2 historic" - RFCs 1441-1452) was dropped with the 4.0 release of the UCD-snmp package.

The Simple Network Management Protocol (SNMP) server is used to listen for SNMP commands from an SNMP management system, execute the commands or collect the information and then send results back to the requesting system.

Rationale:

The SNMP server can communicate using `SNMPv1`, which transmits data in the clear and does not require authentication to execute commands. `SNMPv3` replaces the simple/clear text password sharing used in `SNMPv2` with more securely encoded parameters. If the the SNMP service is not required, the `net-snmp` package should be removed to reduce the attack surface of the system.

Note: If SNMP is required:

- The server should be configured for `SNMP v3` only. `User Authentication` and `Message Encryption` should be configured.
- If `SNMP v2` is **absolutely** necessary, modify the community strings' values.

Impact:

There may be packages that are dependent on the `net-snmp` package. If the `net-snmp` package is removed, these packages will be removed as well.

Before removing the `net-snmp` package, review any dependent packages to determine if they are required on the system. If a dependent package is required, stop and mask the `snmpd.service` leaving the `net-snmp` package installed.

Audit:

Run the following command to verify `net-snmp` package is not installed:

```
# rpm -q net-snmp

package net-snmp is not installed
```

- OR - If the package is required for dependencies:

Run the following command to verify the `snmpd.service` is not enabled:

```
# systemctl is-enabled snmpd.service 2>/dev/null | grep 'enabled'

Nothing should be returned
```

Run the following command to verify the `snmpd.service` is not active:

```
# systemctl is-active snmpd.service 2>/dev/null | grep '^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `snmpd.service` and remove `net-snmp` package:

```
# systemctl stop snmpd.service
# dnf remove net-snmp
```

- OR - If the package is required for dependencies:

Run the following commands to stop and mask the `snmpd.service`:

```
# systemctl stop snmpd.service
# systemctl mask snmpd.service
```

References:

1. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.16 Ensure telnet server services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `telnet-server` package contains the `telnet` daemon, which accepts connections from users from other systems via the `telnet` protocol.

Rationale:

The `telnet` protocol is insecure and unencrypted. The use of an unencrypted transmission medium could allow a user with access to sniff network traffic the ability to steal credentials. The `ssh` package provides an encrypted session and stronger security.

Impact:

There may be packages that are dependent on the `telnet-server` package. If the `telnet-server` package is removed, these dependent packages will be removed as well. Before removing the `telnet-server` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask the `telnet.socket` leaving the `telnet-server` package installed.

Audit:

Run the following command to verify the `telnet-server` package is not installed:

```
rpm -q telnet-server

package telnet-server is not installed
```

- OR -

- IF - a package is installed **and** is required for dependencies:

Run the following command to verify `telnet.socket` is not enabled:

```
# systemctl is-enabled telnet.socket 2>/dev/null | grep 'enabled'

Nothing should be returned
```

Run the following command to verify `telnet.socket` is not active:

```
# systemctl is-active telnet.socket 2>/dev/null | grep '^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `telnet.socket` and remove the `telnet-server` package:

```
# systemctl stop telnet.socket
# dnf remove telnet-server
```

- OR -

- IF - a package is installed **and** is required for dependencies:

Run the following commands to stop and mask `telnet.socket`:

```
# systemctl stop telnet.socket
# systemctl mask telnet.socket
```

References:

1. NIST SP 800-53 Rev. 5: CM-7, CM-11
2. NIST SP 800-53A :: CM-7.1 (ii)
3. RHEL 8 STIG Vul ID: V-230487
4. RHEL 8 STIG Rule ID: SV-230487r627750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	2.6 Address unapproved software Ensure that unauthorized software is either removed or the inventory is updated in a timely manner	●	●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.17 Ensure tftp server services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Trivial File Transfer Protocol (TFTP) is a simple protocol for exchanging files between two TCP/IP machines. TFTP servers allow connections from a TFTP Client for sending and receiving files.

Rationale:

Unless there is a need to run the system as a TFTP server, it is recommended that the package be removed to reduce the potential attack surface.

TFTP does not have built-in encryption, access control or authentication. This makes it very easy for an attacker to exploit TFTP to gain access to files

Impact:

TFTP is often used to provide files for network booting such as for PXE based installation of servers.

There may be packages that are dependent on the `tftp-server` package. If the `tftp-server` package is removed, these dependent packages will be removed as well. Before removing the `tftp-server` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask the `tftp.socket` and `tftp.service` leaving the `tftp-server` package installed.

Audit:

Run the following command to verify `tftp-server` is not installed:

```
# rpm -q tftp-server

package tftp-server is not installed
```

- OR -

- IF - the package is required for dependencies:

Run the following command to verify `tftp.socket` and `tftp.service` are not enabled:

```
# systemctl is-enabled tftp.socket tftp.service 2>/dev/null | grep 'enabled'

Nothing should be returned
```

Run the following command to verify the `tftp.socket` and `tftp.service` are not active:

```
# systemctl is-active tftp.socket tftp.service 2>/dev/null | grep '^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `tftp.socket` and `tftp.service`, and remove the `tftp-server` package:

```
# systemctl stop tftp.socket tftp.service
# dnf remove tftp-server
```

- OR -

- IF - the `tftp-server` package is required as a dependency:

Run the following commands to stop and mask `tftp.socket` and `tftp.service`:

```
# systemctl stop tftp.socket tftp.service
# systemctl mask tftp.socket tftp.service
```

References:

1. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.18 Ensure web proxy server services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Squid is a standard proxy server used in many distributions and environments.

Rationale:

Unless a system is specifically set up to act as a proxy server, it is recommended that the squid package be removed to reduce the potential attack surface.

Note: Several HTTP proxy servers exist. These should be checked and removed unless required.

Impact:

There may be packages that are dependent on the `squid` package. If the `squid` package is removed, these dependent packages will be removed as well. Before removing the `squid` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask the `squid.service` leaving the `squid` package installed.

Audit:

Run the following command to verify `squid` package is not installed:

```
# rpm -q squid

package squid is not installed
```

- OR -

- IF - the package is required for dependencies:

Run the following command to verify `squid.service` is not enabled:

```
# systemctl is-enabled squid.service 2>/dev/null | grep 'enabled'

Nothing should be returned
```

Run the following command to verify the `squid.service` is not active:

```
# systemctl is-active squid.service 2>/dev/null | grep '^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `squid.service` and remove the `squid` package:

```
# systemctl stop squid.service
# dnf remove squid
```

- OR - If the `squid` package is required as a dependency:

Run the following commands to stop and mask the `squid.service`:

```
# systemctl stop squid.service
# systemctl mask squid.service
```

References:

1. NIST SP 800-53 Rev. 5: CM-6, CM-7

Additional Information:

Several HTTP proxy servers exist. These and other services should be checked.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.19 Ensure web server services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Web servers provide the ability to host web site content.

Rationale:

Unless there is a local site approved requirement to run a web server service on the system, web server packages should be removed to reduce the potential attack surface.

Impact:

Removal of a web server's package, or changing the state of its service and/or socket, will prevent the server from hosting web services.

- IF - a web server package is required for a dependency, any related service or socket should be stopped and masked.

Note: If the remediation steps to mask a service are followed and that package is not installed on the system, the service and/or socket will still be masked. If the package is installed due to an approved requirement to host a web server, the associated service and/or socket would need to be unmasked before it could be enabled and/or started.

Audit:

Run the following command to verify `httpd` and `nginx` are not installed:

```
# rpm -q httpd nginx

package httpd is not installed
package nginx is not installed
```

- OR -

- IF - a package is installed **and** is required for dependencies:

- IF - the httpd package is required for dependencies:

Run the following command to verify `httpd.socket` and `httpd.service` `UnitFileState` is not `enabled` and `ActiveState` is not `active`:

```
# systemctl show httpd.socket httpd.service -p UnitFileState,ActiveState |
grep -Pi '=(enabled|active)'

Nothing should be returned
```

- IF - the nginx package is required for dependencies:

Run the following command to verify `nginx.service` `UnitFileState` is not `enabled` and `ActiveState` is not `active`:

```
# systemctl show nginx.service -p UnitFileState,ActiveState | grep -Pi
'=(enabled|active)'

Nothing should be returned
```

Note:

- Other web server packages may exist. They should also be audited, if not required and authorized by local site policy
- If the package is required for a dependency:
  - Ensure the dependent package is approved by local site policy
  - Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `httpd.socket` and `httpd.service` and remove the `httpd` package:

```
# systemctl stop httpd.socket httpd.service
# dnf remove httpd
```

Run the following commands to stop `nginx.service` and remove the `nginx` package:

```
# systemctl stop nginx.service
# dnf remove httpd nginx
```

- OR -

- IF - a package is installed **and** is required for dependencies:

- IF - the httpd package is required for dependencies:

Run the following commands to stop and mask `httpd.socket` and `httpd.service`:

```
# systemctl stop httpd.socket httpd.service
# systemctl mask httpd.socket httpd.service
```

- IF - the nginx package is required for dependencies:

Run the following commands to stop and mask `nginx.service`:

```
# systemctl stop nginx.service
# systemctl mask nginx.service
```

Note: Other web server packages may exist. If not required and authorized by local site policy, they should also be removed. If the package is required for a dependency, the service and socket should be stopped and masked.

References:

1. NIST SP 800-53 :: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.20 Ensure xinetd services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The eXtended InterNET Daemon (`xinetd`) is an open source super daemon that replaced the original `inetd` daemon. The `xinetd` daemon listens for well known services and dispatches the appropriate daemon to properly respond to service requests.

Rationale:

If there are no `xinetd` services required, it is recommended that the package be removed to reduce the attack surface are of the system.

Note: If an `xinetd` service or services are required, ensure that any `xinetd` service not required is stopped and masked

Impact:

There may be packages that are dependent on the `xinetd` package. If the `xinetd` package is removed, these dependent packages will be removed as well. Before removing the `xinetd` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask `xinetd.service` leaving the `xinetd` package installed.

Audit:

Run the following command to verify the `xinetd` package is not installed:

```
# rpm -q xinetd

package xinetd is not installed
```

- OR -

- IF - the `xinetd` package is required as a dependency:

Run the following command to verify `xinetd.service` is not enabled:

```
# systemctl is-enabled xinetd.service 2>/dev/null | grep 'enabled'

Nothing should be returned
```

Run the following command to verify `xinetd.service` is not active:

```
# systemctl is-active xinetd.service 2>/dev/null | grep '^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `xinetd.service`, and remove the `xinetd` package:

```
# systemctl stop xinetd.service
# dnf remove xinetd
```

- OR -

- IF - the `xinetd` package is required as a dependency:

Run the following commands to stop and mask the `xinetd.service`:

```
# systemctl stop xinetd.service
# systemctl mask xinetd.service
```

References:

1. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.21 Ensure GNOME Display Manager is not installed (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The GNOME Display Manager (GDM) is a program that manages graphical display servers and handles graphical user logins.

Rationale:

If a Graphical User Interface (GUI) is not required, it should be removed to reduce the attack surface of the system.

Impact:

Removing the GNOME Display manager will remove the Graphical User Interface (GUI) from the system.

Audit:

Run the following command to verify the `Installed Environment Group` is not `Server with GUI`:

```
# dnf grouplist --installed
```

Example output:

```
Installed Environment Groups:
   Server
```

Remediation:

Run the following to remove the `Server with GUI` group:

1. Run the following command to install the `Minimal Install` group:

```
# dnf groupinstall -y "Minimal Install"
```

Note: This is important to update dependencies to allow the removal of the `Server with GUI` group with minimal impact to the system functionality.

2. Run the following command to remove the `Server with GUI` group:

```
# dnf groupremove -y "Server with GUI"
```

3. Run the following command to install the `Server` group:

```
# dnf groupinstall -y "Server"
```

4. Run the following command to reboot the system:

```
# reboot
```

References:

1. removing-gui-rhel-8

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.22 Ensure X window server services are not in use (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The X Window System provides a Graphical User Interface (GUI) where users can have multiple windows in which to run programs and various add on. The X Windows system is typically used on workstations where users login, but not on servers where users typically do not login.

Rationale:

Unless your organization specifically requires graphical login access via X Windows, remove it to reduce the potential attack surface.

Impact:

If a Graphical Desktop Manager (GDM) is in use on the system, there may be a dependency on the `xorg-x11-server-common` package. If the GDM is required and approved by local site policy, the package should **not** be removed.

Many Linux systems run applications which require a Java runtime. Some Linux Java packages have a dependency on specific X Windows xorg-x11-fonts. One workaround to avoid this dependency is to use the "headless" Java packages for your specific Java runtime.

Audit:

- IF - a Graphical Desktop Manager or X-Windows server is not required and approved by local site policy:

Run the following command to Verify X Windows Server is not installed.

```
# rpm -q xorg-x11-server-common

package xorg-x11-server-common is not installed
```

Remediation:

- IF - a Graphical Desktop Manager or X-Windows server is not required and approved by local site policy:

Run the following command to remove the X Windows Server packages:

```
# dnf remove xorg-x11-server-common
```

References:

1. NIST SP 800-53 Rev. 5: CM-11
2. NIST SP 800-53A :: CM-6.1 (iv)
3. RHEL 8 STIG Vul ID: V-230553
4. RHEL 8 STIG Rule ID: SV-230553r809324

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.23 Ensure mail transfer agents are configured for local-only mode (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Mail Transfer Agents (MTA), such as sendmail and Postfix, are used to listen for incoming mail and transfer the messages to the appropriate user or mail server. If the system is not intended to be a mail server, it is recommended that the MTA be configured to only process local mail.

Rationale:

The software for all Mail Transfer Agents is complex and most have a long history of security issues. While it is important to ensure that the system can process local mail messages, it is not necessary to have the MTA's daemon listening on a port unless the server is intended to be a mail server that receives and processes mail from other systems.

Audit:

Run the following script to verify that the MTA is not listening on any non-loopback address (127.0.0.1 or ::1):

```
#!/usr/bin/env bash

{
   a_output=(); a_output2=(); a_port_list=("25" "465" "587")
   for l_port_number in "${a_port_list[@]}"; do
      if ss -plntu | grep -P -- ':'"$l_port_number"'\b' | grep -Pvq --
'\h+(127\.0\.0\.1|\[?::1\]?):'"$l_port_number"'\b'; then
         a_output2+=(" - Port \"$l_port_number\" is listening on a non-
loopback network interface")
      else
         a_output+=(" - Port \"$l_port_number\" is not listening on a non-
loopback network interface")
      fi
   done
   if command -v postconf &> /dev/null; then
      l_interfaces="$(postconf -n inet_interfaces)"
   elif command -v exim &> /dev/null; then
      l_interfaces="$(exim -bP local_interfaces)"
   elif command -v sendmail &> /dev/null; then
      l_interfaces="$(grep -i "O DaemonPortOptions=" /etc/mail/sendmail.cf |
grep -oP '(?<=Addr=)[^,+]+' | grep -v '^127\.0\.0\.1$')"
   fi
   if [ -n "$l_interfaces" ]; then
      if grep -Pqi '\ball\b' <<< "$l_interfaces"; then
         a_output2+=(" - MTA is bound to all network interfaces")
      elif ! grep -Pqi '(inet_interfaces\h*=\h*)?(0\.0\.0\.0|::1|loopback-
only|localhost)' <<< "$l_interfaces"; then
         a_output2+=(" - MTA is bound to a network interface" "
\"$l_interfaces\"")
      else
         a_output+=(" - MTA is not bound to a non loopback network interface"
"   \"$l_interfaces\"")
      fi
   else
      a_output+=(" - MTA not detected or in use")
   fi
   if [ "${#a_output2[@]}" -le 0 ]; then
      printf '%s\n' "" "- Audit Result:" "  ** PASS **" "${a_output[@]}"
      exit "${XCCDF_RESULT_PASS:-101}"
   else
      printf '%s\n' "" "- Audit Result:" "  ** FAIL **" "  * Reasons for
audit failure *" "${a_output2[@]}" ""
      [ "${#a_output[@]}" -gt 0 ] && printf '%s\n' "- Correctly set:"
"${a_output[@]}"
      exit "${XCCDF_RESULT_FAIL:-102}"
   fi
}
```

Remediation:

Edit `/etc/postfix/main.cf` and add the following line to the RECEIVING MAIL section. If the line already exists, change it to look like the line below:

```
inet_interfaces = loopback-only
```

Run the following command to restart `postfix`:

```
# systemctl restart postfix
```

Note:

- This recommendation is designed around the postfix mail server.
- Depending on your environment you may have an alternative MTA installed such as exim4 or sendmail. If this is the case consult the documentation for your installed MTA to configure the recommended state.

References:

1. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.1.24 Ensure only approved services are listening on a network interface (Manual)

Profile Applicability:

- Level 1 - Server

Description:

A network port is identified by its number, the associated IP address, and the type of the communication protocol such as TCP or UDP.

A listening port is a network port on which an application or process listens on, acting as a communication endpoint.

Each listening port can be open or closed (filtered) using a firewall. In general terms, an open port is a network port that accepts incoming packets from remote locations.

Rationale:

Services listening on the system pose a potential risk as an attack vector. These services should be reviewed, and if not required, the service should be stopped, and the package containing the service should be removed. If required packages have a dependency, the service should be stopped and masked to reduce the attack surface of the system.

Impact:

There may be packages that are dependent on the service's package. If the service's package is removed, these dependent packages will be removed as well. Before removing the service's package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask the `<service_name>.socket` and `<service_name>.service` leaving the service's package installed.

Audit:

Run the following command:

```
# ss -plntu
```

Review the output to ensure:

- All services listed are required on the system and approved by local site policy.
- Both the port and interface the service is listening on are approved by local site policy.
- If a listed service is not required:
  - Remove the package containing the service
  - **- IF -** the service's package is required for a dependency, stop and mask the service and/or socket

Remediation:

Run the following commands to stop the service and remove the package containing the service:

```
# systemctl stop <service_name>.socket <service_name>.service
# dnf remove <package_name>
```

- OR - If required packages have a dependency:

Run the following commands to stop and mask the service and socket:

```
# systemctl stop <service_name>.socket <service_name>.service
# systemctl mask <service_name>.socket <service_name>.service
```

Note: replace `<service_name>` with the appropriate service name.

References:

1. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.2 Configure Client Services

A number of insecure services exist. While disabling the servers prevents a local attack against these services, it is advised to remove their clients unless they are required.

Note: This should not be considered a comprehensive list of insecure service clients. You may wish to consider additions to those listed here for your environment.

2.2.1 Ensure ftp client is not installed (Automated)

Profile Applicability:

- Level 1 - Server

Description:

FTP (File Transfer Protocol) is a traditional and widely used standard tool for transferring files between a server and clients over a network, especially where no authentication is necessary (permits anonymous users to connect to a server).

Rationale:

FTP does not protect the confidentiality of data or authentication credentials. It is recommended SFTP be used if file transfer is required. Unless there is a need to run the system as a FTP server (for example, to allow anonymous downloads), it is recommended that the package be removed to reduce the potential attack surface.

Audit:

Run the following command to verify `ftp` is not installed:

```
# rpm -q ftp

package ftp is not installed
```

Remediation:

Run the following command to remove `ftp`:

```
# dnf remove ftp
```

References:

1. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.2.2 Ensure ldap client is not installed (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The Lightweight Directory Access Protocol (LDAP) was introduced as a replacement for NIS/YP. It is a service that provides a method for looking up information from a central database.

Rationale:

If the system will not need to act as an LDAP client, it is recommended that the software be removed to reduce the potential attack surface.

Impact:

Removing the LDAP client will prevent or inhibit using LDAP for authentication in your environment.

Audit:

Run the following command to verify that the `openldap-clients` package is not installed:

```
# rpm -q openldap-clients

package openldap-clients is not installed
```

Remediation:

Run the following command to remove the `openldap-clients` package:

```
# dnf remove openldap-clients
```

References:

1. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	2.6 Address unapproved software Ensure that unauthorized software is either removed or the inventory is updated in a timely manner	●	●	●

2.2.3 Ensure nis client is not installed (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The Network Information Service (NIS), formerly known as Yellow Pages, is a client-server directory service protocol used to distribute system configuration files. The NIS client (`ypbind`) was used to bind a machine to an NIS server and receive the distributed configuration files.

Rationale:

The NIS service is inherently an insecure system that has been vulnerable to DOS attacks, buffer overflows and has poor authentication for querying NIS maps. NIS generally has been replaced by such protocols as Lightweight Directory Access Protocol (LDAP). It is recommended that the service be removed.

Impact:

Many insecure service clients are used as troubleshooting tools and in testing environments. Uninstalling them can inhibit capability to test and troubleshoot. If they are required it is advisable to remove the clients after use to prevent accidental or intentional misuse.

Audit:

Run the following command to verify that the `ypbind` package is not installed:

```
# rpm -q ypbind

package ypbind is not installed
```

Remediation:

Run the following command to remove the ypbind package:

```
# dnf remove ypbind
```

References:

1. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.2.4 Ensure telnet client is not installed (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `telnet` package contains the `telnet` client, which allows users to start connections to other systems via the telnet protocol.

Rationale:

The `telnet` protocol is insecure and unencrypted. The use of an unencrypted transmission medium could allow an unauthorized user to steal credentials. The `ssh` package provides an encrypted session and stronger security and is included in most Linux distributions.

Impact:

Many insecure service clients are used as troubleshooting tools and in testing environments. Uninstalling them can inhibit capability to test and troubleshoot. If they are required it is advisable to remove the clients after use to prevent accidental or intentional misuse.

Audit:

Run the following command to verify that the `telnet` package is not installed:

```
# rpm -q telnet

package telnet is not installed
```

Remediation:

Run the following command to remove the `telnet` package:

```
# dnf remove telnet
```

References:

1. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	2.6 Address unapproved software Ensure that unauthorized software is either removed or the inventory is updated in a timely manner	●	●	●

2.2.5 Ensure tftp client is not installed (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Trivial File Transfer Protocol (TFTP) is a simple protocol for exchanging files between two TCP/IP machines. TFTP servers allow connections from a TFTP Client for sending and receiving files.

Rationale:

TFTP does not have built-in encryption, access control or authentication. This makes it very easy for an attacker to exploit TFTP to gain access to files

Audit:

Run the following command to verify `tftp` is not installed:

```
# rpm -q tftp

package tftp is not installed
```

Remediation:

Run the following command to remove `tftp`:

```
# dnf remove tftp
```

References:

1. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

2.3 Configure Time Synchronization

It is recommended that systems be configured to synchronize their time using a service such as `chrony`.

Virtual systems may be configured to receive their time synchronization from their host system.

The host system must be configured to synchronize its time from an authoritative source to be considered compliant with this section.

Any "physical" clock present on a system should be synchronized from an authoritative time source.

Only one time synchronization method should be in use on the system

Notes: Only the section related to the time synchronization method in use on the system should be followed, all other time synchronization recommendations should be skipped

2.3.1 Ensure time synchronization is in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

System time should be synchronized between all systems in an environment. This is typically done by establishing an authoritative time server or set of servers and having all systems synchronize their clocks to them.

Note: If another method for time synchronization is being used, this section may be skipped.

Rationale:

Time synchronization is important to support time sensitive security mechanisms like Kerberos and also ensures log files have consistent time records across the enterprise, which aids in forensic investigations.

Audit:

Run the following commands to verify that `chrony` is installed:

```
# rpm -q chrony

chrony-<version>
```

Remediation:

Run the following command to install `chrony`:

```
# dnf install chrony
```

References:

1. NIST SP 800-53 Rev. 5: AU-3, AU-12

Additional Information:

On systems where host based time synchronization is not available, verify that `chrony` is installed.

On systems where host based time synchronization is available consult your documentation and verify that host based synchronization is in use.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.4 Standardize Time Synchronization Standardize time synchronization. Configure at least two synchronized time sources across enterprise assets, where supported.		●	●
v7	6.1 Utilize Three Synchronized Time Sources Use at least three synchronized time sources from which all servers and network devices retrieve time information on a regular basis so that timestamps in logs are consistent.		●	●

2.3.2 Ensure chrony is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

- server
  - The server directive specifies an NTP server which can be used as a time source. The client-server relationship is strictly hierarchical: a client might synchronize its system time to that of the server, but the server's system time will never be influenced by that of a client.
  - This directive can be used multiple times to specify multiple servers.
  - The directive is immediately followed by either the name of the server, or its IP address.
- pool
  - The syntax of this directive is similar to that for the server directive, except that it is used to specify a pool of NTP servers rather than a single NTP server. The pool name is expected to resolve to multiple addresses which might change over time.
  - This directive can be used multiple times to specify multiple pools.
  - All options valid in the server directive can be used in this directive too.

Rationale:

Time synchronization is important to support time sensitive security mechanisms and to ensure log files have consistent time records across the enterprise to aid in forensic investigations

Audit:

Run the following script to ensure chrony is configured with an authorized timeserver:

```
#!/usr/bin/env bash

{
   a_output=() a_output2=() a_config_files=("/etc/chrony.conf")
   l_include='(confdir|sourcedir)' l_parameter_name='(server|pool)'
l_parameter_value='.+'
   while IFS= read -r l_conf_loc; do
      l_dir="" l_ext=""
      if [ -d "$l_conf_loc" ]; then
         l_dir="$l_conf_loc" l_ext="*"
      elif  grep -Psq '\/\*\.([^#/\n\r]+)?\h*$' <<< "$l_conf_loc" || [ -f
"$(readlink -f "$l_conf_loc")" ]; then
         l_dir="$(dirname "$l_conf_loc")" l_ext="$(basename "$l_conf_loc")"
      fi
      if [[ -n "$l_dir" && -n "$l_ext" ]]; then
         while IFS= read -r -d $'\0' l_file_name; do
            [ -f "$(readlink -f "$l_file_name")" ] &&
a_config_files+=("$(readlink -f "$l_file_name")")
         done < <(find -L "$l_dir" -type f -name "$l_ext" -print0
2>/dev/null)
      fi
   done < <(awk '$1~/^\s*'"$l_include"'$/{print $2}' "${a_config_files[*]}"
2>/dev/null)
   for l_file in "${a_config_files[@]}"; do
      l_parameter_line="$(grep -Psi
'^\h*'"$l_parameter_name"'(\h+|\h*:\h*)'"$l_parameter_value"'\b' "$l_file")"
      [ -n "$l_parameter_line" ] && a_output+=("  - Parameter: \"$(tr -d '()'
<<< ${l_parameter_name//|/ or })\"" \
      "    Exists in the file: \"$l_file\" as:" "$l_parameter_line")
   done
   [ "${#a_output[@]}" -le "0" ] && a_output2+=("  - Parameter: \"$(tr -d
'()' <<< ${l_parameter_name//|/ or })\"" \
   "    Does not exist in the chrony configuration")
   if [ "${#a_output2[@]}" -le 0 ]; then
      printf '%s\n' "" "- Audit Result:" "  ** PASS **" "${a_output[@]}" ""
   else
      printf '%s\n' "" "- Audit Result:" "  ** FAIL **" " - Reason(s) for
audit failure:" "${a_output2[@]}"
   fi
}
```

Remediation:

Edit /etc/chrony.conf or a file ending in .sources in /etc/sources.d/ and add or edit server or pool lines as appropriate according to local site policy:

Edit the Chrony configuration and add or edit the server and/or pool lines returned by the Audit Procedure as appropriate according to local site policy

```
<[server|pool]> <[remote-server|remote-pool]>
```

Example script to add a drop-in configuration for the pool directive:

```
#!/usr/bin/env bash

{
   [ ! -d "/etc/sources.d/" ] && mkdir /etc/sources.d/
   printf '%s\n' "" "#The maxsources option is unique to the pool directive"
\
   "pool time.nist.gov iburst maxsources 4" >> /etc/sources.d/60-
sources.sources
   chronyc reload sources &>/dev/null
}
```

Example script to add a drop-in configuration for the server directive:

```
#!/usr/bin/env bash

{
   [ ! -d "/etc/sources.d/" ] && mkdir /etc/sources.d/
   printf '%s\n' "" "server time-a-g.nist.gov iburst" "server 132.163.97.3
iburst" \
   "server time-d-b.nist.gov iburst" >> /etc/sources.d/60-sources.sources
   chronyc reload sources &>/dev/null
}
```

Run the following command to reload the chronyd config:

```
# systemctl reload-or-restart chronyd
```

References:

1. NIST SP 800-53 Rev. 5: AU-3, AU-12

Additional Information:

On systems where host based time synchronization is not available, verify that chrony is installed.

On systems where host based time synchronization is available consult your documentation and verify that host based synchronization is in use.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.4 Standardize Time Synchronization Standardize time synchronization. Configure at least two synchronized time sources across enterprise assets, where supported.		●	●
v7	6.1 Utilize Three Synchronized Time Sources Use at least three synchronized time sources from which all servers and network devices retrieve time information on a regular basis so that timestamps in logs are consistent.		●	●

2.3.3 Ensure chrony is not run as the root user (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The file `/etc/sysconfig/chronyd` allows configuration of options for `chrony` to include the user `chrony` is run as. By default, this is set to the user `chrony`

Rationale:

Services should not be set to run as the root user

Audit:

Run the following command to verify that `chrony` isn't configured to run as the `root` user:

```
# grep -Psi -- '^\h*OPTIONS=\"?\h*([^#\n\r]+\h+)?-u\h+root\b'
/etc/sysconfig/chronyd

Nothing should be returned
```

Remediation:

Edit the file `/etc/sysconfig/chronyd` and add or modify the following line to remove "`-u root`" from any `OPTIONS=` argument:

Example:

```
OPTIONS="-F 2"
```

Run the following command to reload the `chronyd.service` configuration:

```
# systemctl reload-or-restart chronyd.service
```

Default Value:

OPTIONS="-F 2"

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

2.4 Job Schedulers

A job scheduler is used to execute jobs, commands, or shell scripts, at fixed times, dates, or intervals

2.4.1 Configure cron

`cron` is a time based job scheduler

- IF - `cron` is not installed on the system, this sub section can be skipped

Note: Other methods such as `systemd timers` exist for scheduling jobs. If an alternate method is in use, it should be secured in accordance with local site policy

2.4.1.1 Ensure cron daemon is enabled and active (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `cron` daemon is used to execute batch jobs on the system.

Rationale:

While there may not be user jobs that need to be run on the system, the system does have maintenance jobs that may include security monitoring that have to run, and `cron` is used to execute them.

Audit:

- IF - cron is installed on the system:

Run the following command to verify `cron` is enabled:

```
# systemctl list-unit-files | awk '$1~/^crond?\.service/{print $2}'

enabled
```

Run the following command to verify that `cron` is active:

```
# systemctl list-units | awk '$1~/^crond?\.service/{print $3}'

active
```

Remediation:

- IF - cron is installed on the system:

Run the following commands to unmask, enable, and start `cron`:

```
# systemctl unmask "$(systemctl list-unit-files | awk
'$1~/^crond?\.service/{print $1}')"
# systemctl --now enable "$(systemctl list-unit-files | awk
'$1~/^crond?\.service/{print $1}')"
```

References:

1. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

2.4.1.2 Ensure access to /etc/crontab is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/etc/crontab` file is used by `cron` to control its own jobs. The commands in this item make sure that root is the user and group owner of the file and that only the owner can access the file.

Rationale:

This file contains information on what system jobs are run by cron. Write access to these files could provide unprivileged users with the ability to elevate their privileges. Read access to these files could provide users with the ability to gain insight on system jobs that run on the system and could provide them a way to gain unauthorized privileged access.

Audit:

- IF - cron is installed on the system:

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` does not grant permissions to `group` or `other` :

```
# stat -Lc 'Access: (%a/%A) Uid: ( %u/ %U) Gid: ( %g/ %G)' /etc/crontab

Access: (600/-rw-------) Uid: ( 0/ root) Gid: ( 0/ root)
```

Remediation:

- IF - cron is installed on the system:

Run the following commands to set ownership and permissions on `/etc/crontab`:

```
# chown root:root /etc/crontab
# chmod og-rwx /etc/crontab
```

Default Value:

Access: (644/-rw-r--r--) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

2.4.1.3 Ensure access to /etc/cron.hourly is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

This directory contains system `cron` jobs that need to run on an hourly basis. The files in this directory cannot be manipulated by the `crontab` command, but are instead edited by system administrators using a text editor. The commands below restrict read/write and search access to user and group root, preventing regular users from accessing this directory.

Rationale:

Granting write access to this directory for non-privileged users could provide them the means for gaining unauthorized elevated privileges. Granting read access to this directory could give an unprivileged user insight in how to gain elevated privileges or circumvent auditing controls.

Audit:

- IF - cron is installed on the system:

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` does not grant permissions to `group` or `other`:

```
# stat -Lc 'Access: (%a/%A) Uid: ( %u/ %U) Gid: ( %g/ %G)' /etc/cron.hourly/

Access: (700/drwx------) Uid: ( 0/ root) Gid: ( 0/ root)
```

Remediation:

- IF - cron is installed on the system:

Run the following commands to set ownership and permissions on the `/etc/cron.hourly` directory:

```
# chown root:root /etc/cron.hourly/
# chmod og-rwx /etc/cron.hourly/
```

Default Value:

Access: (755/drwxr-xr-x) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3. MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

2.4.1.4 Ensure access to /etc/cron.daily is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/etc/cron.daily` directory contains system cron jobs that need to run on a daily basis. The files in this directory cannot be manipulated by the `crontab` command, but are instead edited by system administrators using a text editor. The commands below restrict read/write and search access to user and group root, preventing regular users from accessing this directory.

Rationale:

Granting write access to this directory for non-privileged users could provide them the means for gaining unauthorized elevated privileges. Granting read access to this directory could give an unprivileged user insight in how to gain elevated privileges or circumvent auditing controls.

Audit:

- IF - cron is installed on the system:

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` does not grant permissions to `group` or `other`:

```
# stat -Lc 'Access: (%a/%A) Uid: ( %u/ %U) Gid: ( %g/ %G)' /etc/cron.daily/

Access: (700/drwx------) Uid: ( 0/ root) Gid: ( 0/ root)
```

Remediation:

- IF - cron is installed on the system:

Run the following commands to set ownership and permissions on the `/etc/cron.daily` directory:

```
# chown root:root /etc/cron.daily/
# chmod og-rwx /etc/cron.daily/
```

Default Value:

Access: (755/drwxr-xr-x) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3. MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

2.4.1.5 Ensure access to /etc/cron.weekly is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/etc/cron.weekly` directory contains system cron jobs that need to run on a weekly basis. The files in this directory cannot be manipulated by the `crontab` command but are instead edited by system administrators using a text editor. The commands below restrict read/write and search access to user and group root, preventing regular users from accessing this directory.

Rationale:

Granting write access to this directory for non-privileged users could provide them the means for gaining unauthorized elevated privileges. Granting read access to this directory could give an unprivileged user insight in how to gain elevated privileges or circumvent auditing controls.

Audit:

- IF - cron is installed on the system:

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` does not grant permissions to `group` or `other`:

```
# stat -Lc 'Access: (%a/%A) Uid: ( %u/ %U) Gid: ( %g/ %G)' /etc/cron.weekly/

Access: (700/drwx------) Uid: ( 0/ root) Gid: ( 0/ root)
```

Remediation:

- IF - cron is installed on the system:

Run the following commands to set ownership and permissions on the `/etc/cron.weekly` directory:

```
# chown root:root /etc/cron.weekly/
# chmod og-rwx /etc/cron.weekly/
```

Default Value:

Access: (755/drwxr-xr-x) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3. MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

2.4.1.6 Ensure access to /etc/cron.monthly is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/etc/cron.monthly` directory contains system cron jobs that need to run on a monthly basis. The files in this directory cannot be manipulated by the `crontab` command but are instead edited by system administrators using a text editor. The commands below restrict read/write and search access to user and group root, preventing regular users from accessing this directory.

Rationale:

Granting write access to this directory for non-privileged users could provide them the means for gaining unauthorized elevated privileges. Granting read access to this directory could give an unprivileged user insight in how to gain elevated privileges or circumvent auditing controls.

Audit:

- IF - cron is installed on the system:

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` does not grant permissions to `group` or `other`:

```
# stat -Lc 'Access: (%a/%A) Uid: ( %u/ %U) Gid: ( %g/ %G)' /etc/cron.monthly/

Access: (700/drwx------) Uid: ( 0/ root) Gid: ( 0/ root)
```

Remediation:

- IF - cron is installed on the system:

Run the following commands to set ownership and permissions on the `/etc/cron.monthly` directory:

```
# chown root:root /etc/cron.monthly/
# chmod og-rwx /etc/cron.monthly/
```

Default Value:

Access: (755/drwxr-xr-x) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3. MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

2.4.1.7 Ensure access to /etc/cron.yearly is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/etc/cron.yearly` directory contains system cron jobs that need to run on an annual basis. The files in this directory cannot be manipulated by the crontab command but are instead edited by system administrators using a text editor. The commands below restrict read/write and search access to user and group root, preventing regular users from accessing this directory.

Rationale:

Granting write access to this directory for non-privileged users could provide them the means for gaining unauthorized elevated privileges. Granting read access to this directory could give an unprivileged user insight in how to gain elevated privileges or circumvent auditing controls.

Audit:

- IF - cron is installed on the system:

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` does not grant permissions to `group` or `other`:

```
# stat -Lc 'Access: (%a/%A) Uid: ( %u/ %U) Gid: ( %g/ %G)' /etc/cron.yearly/

Access: (700/drwx------) Uid: ( 0/ root) Gid: ( 0/ root)
```

Remediation:

- IF - cron is installed on the system:

Run the following commands to set ownership and permissions on the `/etc/cron.yearly` directory:

```
# chown root:root /etc/cron.yearly/
# chmod og-rwx /etc/cron.yearly/
```

Default Value:

Access: (755/drwxr-xr-x) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3. MP-2

2.4.1.8 Ensure access to /etc/cron.d is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/etc/cron.d` directory contains system `cron` jobs that need to run in a similar manner to the hourly, daily weekly and monthly jobs from `/etc/crontab`, but require more granular control as to when they run. The files in this directory cannot be manipulated by the `crontab` command but are instead edited by system administrators using a text editor. The commands below restrict read/write and search access to user and group root, preventing regular users from accessing this directory.

Rationale:

Granting write access to this directory for non-privileged users could provide them the means for gaining unauthorized elevated privileges. Granting read access to this directory could give an unprivileged user insight in how to gain elevated privileges or circumvent auditing controls.

Audit:

- IF - cron is installed on the system:

Run the following command and verify `Uid` and `Gid` are both `0/root` and `Access` does not grant permissions to `group` or `other`:

```
# stat -Lc 'Access: (%a/%A) Uid: ( %u/ %U) Gid: ( %g/ %G)' /etc/cron.d/

Access: (700/drwx------) Uid: ( 0/ root) Gid: ( 0/ root)
```

Remediation:

- IF - cron is installed on the system:

Run the following commands to set ownership and permissions on the `/etc/cron.d` directory:

```
# chown root:root /etc/cron.d/
# chmod og-rwx /etc/cron.d/
```

Default Value:

Access: (755/drwxr-xr-x) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3. MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

2.4.1.9 Ensure access to crontab is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`crontab` is the program used to install, deinstall, or list the tables used to drive the cron daemon. Each user can have their own crontab, and though files are created, they are not intended to be edited directly.

If the `/etc/cron.allow` file exists, then you must be listed (one user per line) therein in order to be allowed to use this command. If the `/etc/cron.allow` file does not exist but the `/etc/cron.deny` file does exist, then you must not be listed in the `/etc/cron.deny` file in order to use this command.

If neither of these files exists, then depending on site-dependent configuration parameters, only the super user will be allowed to use this command, or all users will be able to use this command.

If both files exist then `/etc/cron.allow` takes precedence. Which means that `/etc/cron.deny` is not considered and your user must be listed in `/etc/cron.allow` in order to be able to use the crontab.

Regardless of the existence of any of these files, the root administrative user is always allowed to setup a crontab.

The files `/etc/cron.allow` and `/etc/cron.deny`, if they exist, must be either world-readable, or readable by group `crontab`. If they are not, then cron will deny access to all users until the permissions are fixed.

There is one file for each user's crontab. Users are not allowed to edit the file directly to ensure that only users allowed by the system to run periodic tasks can add them, and only syntactically correct crontabs will be written. This is enforced by having the directory writable only by the `crontab` group and configuring crontab command with the setgid bid set for that specific group.

Note:

- Even though a given user is not listed in `cron.allow`, cron jobs can still be run as that user
- The files `/etc/cron.allow` and `/etc/cron.deny`, if they exist, only controls administrative access to the crontab command for scheduling and modifying cron jobs

Rationale:

On many systems, only the system administrator is authorized to schedule `cron` jobs. Using the `cron.allow` file to control who can run `cron` jobs enforces this policy. It is easier to manage an allow list than a deny list. In a deny list, you could potentially add a user ID to the system and forget to add it to the deny files.

Audit:

- IF - cron is installed on the system:

Run the following command to verify `/etc/cron.allow`:

- Exists
- Is mode `0640` or more restrictive
- Is owned by the user `root`
- Is group owned by the group `root` **- OR -** the group `crontab`

```
# stat -Lc 'Access: (%a/%A) Owner: (%U) Group: (%G)' /etc/cron.allow
```

Verify the returned value is:

```
Access: (640/-rw-r-----) Owner: (root) Group: (root)
- OR -
Access: (640/-rw-r-----) Owner: (root) Group: (crontab)
```

Run the following command to verify either `cron.deny` doesn't exist or is:

- Mode `0640` or more restrictive
- Owned by the user `root`
- Is group owned by the group `root` **- OR -** the group `crontab`

```
# [ -e "/etc/cron.deny" ] && stat -Lc 'Access: (%a/%A) Owner: (%U) Group:
(%G)' /etc/cron.deny
```

Verify either nothing is returned **- OR -** returned value is one of the following:

```
Access: (640/-rw-r-----) Owner: (root) Group: (root)
- OR -
Access: (640/-rw-r-----) Owner: (root) Group: (crontab)
```

Note: On systems where cron is configured to use the group `crontab`, if the group `crontab` is not set as the owner of `cron.allow`, then cron will deny access to all users and you will see an error similar to:

```
You (<USERNAME>) are not allowed to use this program (crontab)
See crontab(1) for more information
```

Remediation:

- IF - cron is installed on the system:

Run the following script to:

- Create `/etc/cron.allow` if it doesn't exist
- Change owner to user `root`
- Change group owner to group `root` **- OR -** group `crontab` if it exists
- Change mode to `640` or more restrictive

```
#!/usr/bin/env bash

{
   [ ! -e "/etc/cron.allow" ] && touch /etc/cron.allow
   chmod u-x,g-wx,o-rwx /etc/cron.allow
   if grep -Pq -- '^\h*crontab\:' /etc/group; then
      chown root:crontab /etc/cron.allow
   else
      chown root:root /etc/cron.allow
   fi
}
```

- IF - `/etc/cron.deny` exists, run the following script to:

- Change owner to user `root`
- Change group owner to group `root` **- OR -** group `crontab` if it exists
- Change mode to `640` or more restrictive

```
#!/usr/bin/env bash

{
   if [ -e "/etc/cron.deny" ]; then
      chmod u-x,g-wx,o-rwx /etc/cron.deny
      if grep -Pq -- '^\h*crontab\:' /etc/group; then
         chown root:crontab /etc/cron.deny
      else
         chown root:root /etc/cron.deny
      fi
   fi
}
```

Note: On systems where cron is configured to use the group `crontab`, if the group `crontab` is not set as the owner of `cron.allow`, then cron will deny access to all users and you will see an error similar to:

```
You (<USERNAME>) are not allowed to use this program (crontab)
See crontab(1) for more information
```

References:

1. NIST SP 800-53 Rev. 5: AC-3. MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

2.4.2 Configure at

`at` is a command-line utility used to schedule a job for later execution

Note: if `at` is not installed on the system, this section can be skipped

2.4.2.1 Ensure access to at is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`at` allows fairly complex time specifications, extending the POSIX.2 standard. It accepts times of the form HH:MM to run a job at a specific time of day. (If that time is already past, the next day is assumed.) You may also specify midnight, noon, or teatime (4pm) and you can have a time-of-day suffixed with AM or PM for running in the morning or the evening. You can also say what day the job will be run, by giving a date in the form month-name day with an optional year, or giving a date of the form MMDD[CC]YY, MM/DD/[CC]YY, DD.MM.[CC]YY or [CC]YY-MM-DD. The specification of a date must follow the specification of the time of day. You can also give times like now + count time-units, where the time-units can be minutes, hours, days, or weeks and you can tell at to run the job today by suffixing the time with today and to run the job tomorrow by suffixing the time with tomorrow.

The `/etc/at.allow` and `/etc/at.deny` files determine which user can submit commands for later execution via at or batch. The format of the files is a list of usernames, one on each line. Whitespace is not permitted. If the file `/etc/at.allow` exists, only usernames mentioned in it are allowed to use at. If `/etc/at.allow` does not exist, `/etc/at.deny` is checked, every username not mentioned in it is then allowed to use at. An empty `/etc/at.deny` means that every user may use at. If neither file exists, only the superuser is allowed to use at.

Rationale:

On many systems, only the system administrator is authorized to schedule `at` jobs. Using the `at.allow` file to control who can run `at` jobs enforces this policy. It is easier to manage an allow list than a deny list. In a deny list, you could potentially add a user ID to the system and forget to add it to the deny files.

Audit:

- IF - at is installed on the system:

Run the following command to verify `/etc/at.allow`:

- Exists
- Is mode `0640` or more restrictive
- Is owned by the user `root`
- Is group owned by the group `daemon` or group `root`

```
# stat -Lc 'Access: (%a/%A) Owner: (%U) Group: (%G)' /etc/at.allow

Access: (640/-rw-r-----) Owner: (root) Group: (daemon)
-OR-
Access: (640/-rw-r-----) Owner: (root) Group: (root)
```

Verify mode is `640` or more restrictive, owner is `root`, and group is `daemon` or `root`

Run the following command to verify `at.deny` doesn't exist, **-OR-** is:

- Mode `0640` or more restrictive
- Owned by the user `root`
- Group owned by the group `daemon` or group `root`

```
# [ -e "/etc/at.deny" ] && stat -Lc 'Access: (%a/%A) Owner: (%U) Group: (%G)'
/etc/at.deny

Access: (640/-rw-r-----) Owner: (root) Group: (daemon)
-OR-
Access: (640/-rw-r-----) Owner: (root) Group: (root)
-OR-
Nothing is returned
```

If a value is returned, verify mode is 640 or more restrictive, owner is `root`, and group is `daemon` or `root`

Remediation:

- IF - at is installed on the system:

Run the following script to:

- `/etc/at.allow`:
  - Create the file if it doesn't exist
  - Change owner or user `root`
  - If group `daemon` exists, change to group `daemon`, else change group to `root`
  - Change mode to `640` or more restrictive
- **- IF -** `/etc/at.deny` exists:
  - Change owner or user `root`
  - If group `daemon` exists, change to group `daemon`, else change group to `root`
  - Change mode to `640` or more restrictive

```
#!/usr/bin/env bash

{
   grep -Pq -- '^daemon\b' /etc/group && l_group="daemon" || l_group="root"
   [ ! -e "/etc/at.allow" ] && touch /etc/at.allow
   chown root:"$l_group" /etc/at.allow
   chmod u-x,g-wx,o-rwx /etc/at.allow
   [ -e "/etc/at.deny" ] && chown root:"$l_group" /etc/at.deny
   [ -e "/etc/at.deny" ] && chmod u-x,g-wx,o-rwx /etc/at.deny
}
```

References:

1. NIST SP 800-53 Rev. 5: AC-3. MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

3 Network

This section provides guidance on for securing the network configuration of the system

3.1 Configure Network Devices

To reduce the attack surface of a system, unused devices should be disabled.

Note: This should not be considered a comprehensive list, you may wish to consider additions to those listed here for your environment.

3.1.1 Ensure IPv6 status is identified (Manual)

Profile Applicability:

- Level 1 - Server

Description:

Internet Protocol Version 6 (IPv6) is the most recent version of Internet Protocol (IP). It's designed to supply IP addressing and additional security to support the predicted growth of connected devices. IPv6 is based on 128-bit addressing and can support 340 undecillion, which is 340,282,366,920,938,463,463,374,607,431,768,211,456 unique addresses.

Features of IPv6

- Hierarchical addressing and routing infrastructure
- Stateful and Stateless configuration
- Support for quality of service (QoS)
- An ideal protocol for neighboring node interaction

Rationale:

IETF RFC 4038 recommends that applications are built with an assumption of dual stack. It is recommended that IPv6 be enabled and configured in accordance with Benchmark recommendations.

- IF - dual stack and IPv6 are not used in your environment, IPv6 may be disabled to reduce the attack surface of the system, and recommendations pertaining to IPv6 can be skipped.

Note: It is recommended that IPv6 be enabled and configured unless this is against local site policy

Impact:

IETF RFC 4038 recommends that applications are built with an assumption of dual stack.

When enabled, IPv6 will require additional configuration to reduce risk to the system.

Audit:

Run the following script to identify if IPv6 is enabled on the system:

```
#!/usr/bin/env bash

{
   l_output=""
   ! grep -Pqs -- '^\h*0\b' /sys/module/ipv6/parameters/disable &&
l_output="- IPv6 is not enabled"
   if sysctl net.ipv6.conf.all.disable_ipv6 | grep -Pqs --
"^\h*net\.ipv6\.conf\.all\.disable_ipv6\h*=\h*1\b" && \
      sysctl net.ipv6.conf.default.disable_ipv6 | grep -Pqs --
"^\h*net\.ipv6\.conf\.default\.disable_ipv6\h*=\h*1\b"; then
      l_output="- IPv6 is not enabled"
   fi
   [ -z "$l_output" ] && l_output="- IPv6 is enabled"
   echo -e "\n$l_output\n"
}
```

Remediation:

Enable or disable IPv6 in accordance with system requirements and local site policy

Default Value:

IPv6 is enabled

References:

1. NIST SP 800-53 Rev. 5: CM-7

Additional Information:

Having more addresses has grown in importance with the expansion of smart devices and connectivity. IPv6 provides more than enough globally unique IP addresses for every networked device currently on the planet, helping ensure providers can keep pace with the expected proliferation of IP-based devices.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.1.2 Ensure wireless interfaces are not available (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Wireless networking is used when wired networks are unavailable.

Rationale:

- IF - wireless is not to be used, wireless devices can be disabled to reduce the potential attack surface.

Impact:

Many if not all laptop workstations and some desktop workstations will connect via wireless requiring these interfaces be enabled.

Audit:

Run the following script to verify no wireless interfaces are active on the system:

```
#!/usr/bin/env bash

{
   l_output="" l_output2=""
   module_chk()
   {
      # Check how module will be loaded
      l_loadable="$(modprobe -n -v "$l_mname")"
      if grep -Pq -- '^\h*install \/bin\/(true|false)' <<< "$l_loadable";
then
         l_output="$l_output\n - module: \"$l_mname\" is not loadable:
\"$l_loadable\""
      else
         l_output2="$l_output2\n - module: \"$l_mname\" is loadable:
\"$l_loadable\""
      fi
      # Check is the module currently loaded
      if ! lsmod | grep "$l_mname" > /dev/null 2>&1; then
         l_output="$l_output\n - module: \"$l_mname\" is not loaded"
      else
         l_output2="$l_output2\n - module: \"$l_mname\" is loaded"
      fi
      # Check if the module is deny listed
      if modprobe --showconfig | grep -Pq -- "^\h*blacklist\h+$l_mname\b";
then
         l_output="$l_output\n - module: \"$l_mname\" is deny listed in:
\"$(grep -Pl -- "^\h*blacklist\h+$l_mname\b" /etc/modprobe.d/*)\""
      else
         l_output2="$l_output2\n - module: \"$l_mname\" is not deny listed"
      fi
   }
   if [ -n "$(find /sys/class/net/*/ -type d -name wireless)" ]; then
      l_dname=$(for driverdir in $(find /sys/class/net/*/ -type d -name
wireless | xargs -0 dirname); do basename "$(readlink -f
"$driverdir"/device/driver/module)";done | sort -u)
      for l_mname in $l_dname; do
         module_chk
      done
   fi
   # Report results. If no failures output in l_output2, we pass
   if [ -z "$l_output2" ]; then
      echo -e "\n- Audit Result:\n  ** PASS **"
      if [ -z "$l_output" ]; then
         echo -e "\n - System has no wireless NICs installed"
      else
         echo -e "\n$l_output\n"
      fi
   else
      echo -e "\n- Audit Result:\n  ** FAIL **\n - Reason(s) for audit
failure:\n$l_output2\n"
      [ -n "$l_output" ] && echo -e "\n- Correctly set:\n$l_output\n"
   fi
}
```

Remediation:

Run the following script to disable any wireless interfaces:

```
#!/usr/bin/env bash

{
   module_fix()
   {
      if ! modprobe -n -v "$l_mname" | grep -P -- '^\h*install
\/bin\/(true|false)'; then
         echo -e " - setting module: \"$l_mname\" to be un-loadable"
         echo -e "install $l_mname /bin/false" >>
/etc/modprobe.d/"$l_mname".conf
      fi
      if lsmod | grep "$l_mname" > /dev/null 2>&1; then
         echo -e " - unloading module \"$l_mname\""
         modprobe -r "$l_mname"
      fi
      if ! grep -Pq -- "^\h*blacklist\h+$l_mname\b" /etc/modprobe.d/*; then
         echo -e " - deny listing \"$l_mname\""
         echo -e "blacklist $l_mname" >> /etc/modprobe.d/"$l_mname".conf
      fi
   }
   if [ -n "$(find /sys/class/net/*/ -type d -name wireless)" ]; then
      l_dname=$(for driverdir in $(find /sys/class/net/*/ -type d -name
wireless | xargs -0 dirname); do basename "$(readlink -f
"$driverdir"/device/driver/module)";done | sort -u)
      for l_mname in $l_dname; do
         module_fix
      done
   fi
}
```

References:

1. NIST SP 800-53 :: AC-18 (1)
2. NIST SP 800-53 :: AC-18 (1)
3. RHEL 8 STIG Vuln ID: V-230506
4. RHEL 8 STIG Rule ID: SV-230506r627750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	15.4 Disable Wireless Access on Devices if Not Required Disable wireless access on devices that do not have a business purpose for wireless access.			●
v7	15.5 Limit Wireless Access on Client Devices Configure wireless access on client machines that do have an essential wireless business purpose, to allow access only to authorized wireless networks and to restrict access to other wireless networks.			●

3.1.3 Ensure bluetooth services are not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Bluetooth is a short-range wireless technology standard that is used for exchanging data between devices over short distances. It employs UHF radio waves in the ISM bands, from 2.402 GHz to 2.48 GHz. It is mainly used as an alternative to wire connections.

Rationale:

An attacker may be able to find a way to access or corrupt your data. One example of this type of activity is `bluesnarfing`, which refers to attackers using a Bluetooth connection to steal information off of your Bluetooth device. Also, viruses or other malicious code can take advantage of Bluetooth technology to infect other devices. If you are infected, your data may be corrupted, compromised, stolen, or lost.

Impact:

Many personal electronic devices (PEDs) use Bluetooth technology. For example, you may be able to operate your computer with a wireless keyboard. Disabling Bluetooth will prevent these devices from connecting to the system.

There may be packages that are dependent on the `bluez` package. If the `bluez` package is removed, these dependent packages will be removed as well. Before removing the `bluez` package, review any dependent packages to determine if they are required on the system.

- IF - a dependent package is required: stop and mask `bluetooth.service` leaving the `bluez` package installed.

Audit:

Run the following command to verify the `bluez` package is not installed:

```
# rpm -q bluez

package bluez is not installed
```

- OR -

- IF - the `bluez` package is required as a dependency:

Run the following command to verify `bluetooth.service` is not enabled:

```
# systemctl is-enabled bluetooth.service 2>/dev/null | grep 'enabled'

Nothing should be returned
```

Run the following command to verify `bluetooth.service` is not active:

```
# systemctl is-active bluetooth.service 2>/dev/null | grep '^active'

Nothing should be returned
```

Note: If the package is required for a dependency

- Ensure the dependent package is approved by local site policy
- Ensure stopping and masking the service and/or socket meets local site policy

Remediation:

Run the following commands to stop `bluetooth.service`, and remove the `bluez` package:

```
# systemctl stop bluetooth.service
# dnf remove bluez
```

- OR -

- IF - the `bluez` package is required as a dependency:

Run the following commands to stop and mask `bluetooth.service`:

```
# systemctl stop bluetooth.service
# systemctl mask bluetooth.service
```

Note: A reboot may be required

References:

1. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.2 Configure Network Kernel Modules

The Linux kernel modules support several network protocols that are not commonly used. If these protocols are not needed, it is recommended that they be disabled in the kernel.

Note: This should not be considered a comprehensive list of uncommon network protocols, you may wish to consider additions to those listed here for your environment.

3.2.1 Ensure atm kernel module is not available (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The Asynchronous Transfer Mode (ATM) is a protocol operating on network, data link, and physical layers, based on virtual circuits and virtual paths. Disabling ATM protects the system against exploitation of any laws in its implementation.

Rationale:

Removing support for unneeded protocols reduces the local attack surface of the system. If this protocol is not needed, disable it.

Audit:

Verify the atm kernel module is not available on the system or has been disabled.

1. Run the following script to determine if the atm kernel module is available on the system:

```
#!/usr/bin/env bash

{
   l_mod_name="atm" l_mod_type="net"
   while IFS= read -r l_mod_path; do
      if [ -d "$l_mod_path/${l_mod_name//-/\/}" ] &&  \
      [ -n "$(ls -A "$l_mod_path/${l_mod_name//-/\/}")" ]; then
         printf '%s\n' "$l_mod_name exists in $l_mod_path"
      fi
   done < <(readlink -e /usr/lib/modules/**/kernel/$l_mod_type \
   || readlink -e /lib/modules/**/kernel/$l_mod_type)
}
```

If nothing is returned, the atm kernel module is not available on the system and no further audit steps are required.

Note: Some systems may include the atm filesystem as part of the kernel opposed to being available as a kernel module. In this case, the above audit will not return anything. This is also considered a passing state.

If anything is returned by the above script:

2. verify the atm kernel module is not loaded and not loadable by performing the following:

Run the following command to verify the atm kernel module is not loaded:

```
# lsmod | grep 'atm'
```

Nothing should be returned

Run the following command to verify the atm kernel module is not loadable:

```
# modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+atm\b'
```

Verify the output includes:

```
blacklist atm
 -AND-
install atm /bin/false
 -OR-
install atm /bin/true
```

Example output:

```
blacklist atm
install atm /bin/false
```

Remediation:

Unload and disable the `atm` kernel module.

1. Run the following commands to unload the `atm` kernel module:

```
# modprobe -r atm 2>/dev/null
# rmmod can 2>/dev/null
```

2. Perform the following to disable the `atm` kernel module:

Create a file ending in `.conf` with `install can /bin/false` in the `/etc/modprobe.d/` directory
Example:

```
# printf '\n%s\n' "install atm /bin/false" >> /etc/modprobe.d/60-atm.conf
```

Create a file ending in `.conf` with `blacklist atm` in the `/etc/modprobe.d/` directory

Example:

```
# printf '\n%s\n' "blacklist atm" >> /etc/modprobe.d/60-atm.conf
```

References:

1. CCI-000381
2. NIST SP 800-53 :: CM-7
3. NIST SP 800-53A :: CM-7.1 (ii)
4. STIG ID: RHEL-08-040021 | RULE ID: SV-230494r1069310 | CAT III
5. STIG ID: OL08-00-040021 | RULE ID: SV-248829r991589 | CAT II
6. STIG ID: RHEL-09-213045 | RULE ID: SV-257804r1044853 | CAT II
7. STIG ID: ALMA-09-029610 | RULE ID: SV-269341r1050223 | CAT II
8. STIG ID: OL09-00-000040 | RULE ID: SV-271443r1092463 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.2.2 Ensure can kernel module is not available (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The Controller Area Network (CAN) is a serial communications protocol, which was initially developed for automotive and is now also used in marine, industrial, and medical applications. Disabling CAN protects the system against exploitation of any flaws in its implementation.

Rationale:

Removing support for unneeded protocols reduces the local attack surface of the system. If this protocol is not needed, disable it.

Audit:

Verify the can kernel module is not available on the system or has been disabled.

1. Run the following script to determine if the can kernel module is available on the system:

```
#!/usr/bin/env bash

{
   l_mod_name="can" l_mod_type="net"
   while IFS= read -r l_mod_path; do
      if [ -d "$l_mod_path/${l_mod_name//-/\/}" ] &&  \
      [ -n "$(ls -A "$l_mod_path/${l_mod_name//-/\/}")" ]; then
         printf '%s\n' "$l_mod_name exists in $l_mod_path"
      fi
   done < <(readlink -e /usr/lib/modules/**/kernel/$l_mod_type \
   || readlink -e /lib/modules/**/kernel/$l_mod_type)
}
```

If nothing is returned, the can kernel module is not available on the system and no further audit steps are required.

Note: Some systems may include the can filesystem as part of the kernel opposed to being available as a kernel module. In this case, the above audit will not return anything. This is also considered a passing state.

If anything is returned by the above script:

2. verify the can kernel module is not loaded and not loadable by performing the following:

Run the following command to verify the can kernel module is not loaded:

```
# lsmod | grep 'can'
```

Nothing should be returned

Run the following command to verify the can kernel module is not loadable:

```
# modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+can\b'
```

verify the output includes:

```
blacklist can
 -AND-
install can /bin/false
 -OR-
install can /bin/true
```

Example output:

```
blacklist can
install can /bin/false
```

Remediation:

Unload and disable the `can` kernel module.

1. Run the following commands to unload the `can` kernel module:

```
# modprobe -r can 2>/dev/null
# rmmod can 2>/dev/null
```

2. Perform the following to disable the `can` kernel module:

Create a file ending in `.conf` with `install can /bin/false` in the `/etc/modprobe.d/` directory
Example:

```
# printf '\n%s\n' "install can /bin/false" >> /etc/modprobe.d/60-can.conf
```

Create a file ending in `.conf` with `blacklist can` in the `/etc/modprobe.d/` directory

Example:

```
# printf '\n%s\n' "blacklist can" >> /etc/modprobe.d/60-can.conf
```

References:

1. CCI-000381
2. NIST SP 800-53 :: CM-7
3. NIST SP 800-53A :: CM-7.1 (ii)
4. STIG ID: RHEL-08-040022 | RULE ID: SV-230495r1069311 | CAT III
5. STIG ID: OL08-00-040022 | RULE ID: SV-248830r991589 | CAT II
6. STIG ID: RHEL-09-213050 | RULE ID: SV-257805r1044856 | CAT II
7. STIG ID: ALMA-09-029830 | RULE ID: SV-269343r1050225 | CAT II
8. STIG ID: OL09-00-000041 | RULE ID: SV-271444r1091044 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.2.3 Ensure dccp kernel module is not available (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The Datagram Congestion Control Protocol (DCCP) is a transport layer protocol that supports streaming media and telephony. DCCP provides a way to gain access to congestion control, without having to do it at the application layer, but does not provide in-sequence delivery.

Rationale:

Removing support for unneeded protocols reduces the local attack surface of the system. If this protocol is not needed, disable it.

Audit:

Verify the dccp kernel module is not available on the system or has been disabled.

1. Run the following script to determine if the dccp kernel module is available on the system:

```
#!/usr/bin/env bash

{
   l_mod_name="dccp" l_mod_type="net"
   while IFS= read -r l_mod_path; do
      if [ -d "$l_mod_path/${l_mod_name//-/\/}" ] &&  \
      [ -n "$(ls -A "$l_mod_path/${l_mod_name//-/\/}")" ]; then
         printf '%s\n' "$l_mod_name exists in $l_mod_path"
      fi
   done < <(readlink -e /usr/lib/modules/**/kernel/$l_mod_type \
   || readlink -e /lib/modules/**/kernel/$l_mod_type)
}
```

If nothing is returned, the dccp kernel module is not available on the system and no further audit steps are required.

Note: Some systems may include the dccp filesystem as part of the kernel opposed to being available as a kernel module. In this case, the above audit will not return anything. This is also considered a passing state.

If anything is returned by the above script:

2. verify the dccp kernel module is not loaded and not loadable by performing the following:

Run the following command to verify the dccp kernel module is not loaded:

```
# lsmod | grep 'dccp'
```

Nothing should be returned

Run the following command to verify the dccp kernel module is not loadable:

```
# modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+dccp\b'
```

Verify the output includes:

```
blacklist dccp
 -AND-
install dccp /bin/false
 -OR-
install dccp /bin/true
```

Example output:

```
blacklist dccp
install dccp /bin/false
```

Remediation:

Unload and disable the `dccp` kernel module.

1. Run the following commands to unload the `dccp` kernel module:

```
# modprobe -r dccp 2>/dev/null
# rmmod dccp 2>/dev/null
```

2. Perform the following to disable the `dccp` kernel module:

Create a file ending in `.conf` with `install dccp /bin/false` in the `/etc/modprobe.d/` directory
Example:

```
# printf '\n%s\n' "install dccp /bin/false" >> /etc/modprobe.d/60-dccp.conf
```

Create a file ending in `.conf` with `blacklist dccp` in the `/etc/modprobe.d/` directory

Example:

```
# printf '\n%s\n' "blacklist dccp" >> /etc/modprobe.d/60-dccp.conf
```

References:

1. CCI-000381
2. NIST SP 800-53 :: CM-7
3. NIST SP 800-53A :: CM-7.1 (ii)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.2.4 Ensure rds kernel module is not available (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The Reliable Datagram Sockets (RDS) protocol is a transport layer protocol designed to provide low-latency, high-bandwidth communications between cluster nodes. It was developed by the Oracle Corporation.

Rationale:

Removing support for unneeded protocols reduces the local attack surface of the system. If this protocol is not needed, disable it.

Audit:

Verify the rds kernel module is not available on the system or has been disabled.

1. Run the following script to determine if the rds kernel module is available on the system:

```
#!/usr/bin/env bash

{
   l_mod_name="rds" l_mod_type="net"
   while IFS= read -r l_mod_path; do
      if [ -d "$l_mod_path/${l_mod_name//-/\/}" ] &&  \
      [ -n "$(ls -A "$l_mod_path/${l_mod_name//-/\/}")" ]; then
         printf '%s\n' "$l_mod_name exists in $l_mod_path"
      fi
   done < <(readlink -e /usr/lib/modules/**/kernel/$l_mod_type \
   || readlink -e /lib/modules/**/kernel/$l_mod_type)
}
```

If nothing is returned, the rds kernel module is not available on the system and no further audit steps are required.

Note: Some systems may include the rds filesystem as part of the kernel opposed to being available as a kernel module. In this case, the above audit will not return anything. This is also considered a passing state.

If anything is returned by the above script:

2. verify the rds kernel module is not loaded and not loadable by performing the following:

Run the following command to verify the rds kernel module is not loaded:

```
# lsmod | grep 'rds'
```

Nothing should be returned

Run the following command to verify the rds kernel module is not loadable:

```
# modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+rds\b'
```

Verify the output includes:

```
blacklist rds
 -AND-
install rds /bin/false
 -OR-
install rds /bin/true
```

Example output:

```
blacklist rds
install rds /bin/false
```

Remediation:

Unload and disable the `rds` kernel module.

1. Run the following commands to unload the `rds` kernel module:

```
# modprobe -r rds 2>/dev/null
# rmmod rds 2>/dev/null
```

2. Perform the following to disable the `rds` kernel module:

Create a file ending in `.conf` with `install rds /bin/false` in the `/etc/modprobe.d/` directory
Example:

```
# printf '\n%s\n' "install rds /bin/false" >> /etc/modprobe.d/60-rds.conf
```

Create a file ending in `.conf` with `blacklist rds` in the `/etc/modprobe.d/` directory

Example:

```
# printf '\n%s\n' "blacklist rds" >> /etc/modprobe.d/60-rds.conf
```

References:

1. CCI-000381
2. NIST SP 800-53 :: CM-7
3. NIST SP 800-53A :: CM-7.1 (ii)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.2.5 Ensure sctp kernel module is not available (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The Stream Control Transmission Protocol (SCTP) is a transport layer protocol used to support message oriented communication, with several streams of messages in one connection. It serves a similar function as TCP and UDP, incorporating features of both. It is message-oriented like UDP, and ensures reliable in-sequence transport of messages with congestion control like TCP.

Rationale:

Removing support for unneeded protocols reduces the local attack surface of the system. If this protocol is not needed, disable it.

Audit:

Verify the `sctp` kernel module is not available on the system or has been disabled.

1. Run the following script to determine if the `sctp` kernel module is available on the system:

```
#!/usr/bin/env bash

{
   l_mod_name="sctp" l_mod_type="net"
   while IFS= read -r l_mod_path; do
      if [ -d "$l_mod_path/${l_mod_name//-/\/}" ] &&  \
      [ -n "$(ls -A "$l_mod_path/${l_mod_name//-/\/}")" ]; then
         printf '%s\n' "$l_mod_name exists in $l_mod_path"
      fi
   done < <(readlink -e /usr/lib/modules/**/kernel/$l_mod_type \
   || readlink -e /lib/modules/**/kernel/$l_mod_type)
}
```

If nothing is returned, the `sctp` kernel module is not available on the system and no further audit steps are required.

Note: Some systems may include the `sctp` filesystem as part of the kernel opposed to being available as a kernel module. In this case, the above audit will not return anything. This is also considered a passing state.

If anything is returned by the above script:

2. verify the `sctp` kernel module is not loaded and not loadable by performing the following:

Run the following command to verify the `sctp` kernel module is not loaded:

```
# lsmod | grep 'sctp'
```

Nothing should be returned

Run the following command to verify the `sctp` kernel module is not loadable:

```
# modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+sctp\b'
```

Verify the output includes:

```
blacklist sctp
 -AND-
install sctp /bin/false
 -OR-
install sctp /bin/true
```

Example output:

```
blacklist sctp
install sctp /bin/false
```

Remediation:

Unload and disable the `sctp` kernel module.

1. Run the following commands to unload the `sctp` kernel module:

```
# modprobe -r sctp 2>/dev/null
# rmmod sctp 2>/dev/null
```

2. Perform the following to disable the `sctp` kernel module:

Create a file ending in `.conf` with `install sctp /bin/false` in the `/etc/modprobe.d/` directory
Example:

```
# printf '\n%s\n' "install sctp /bin/false" >> /etc/modprobe.d/60-sctp.conf
```

Create a file ending in `.conf` with `blacklist sctp` in the `/etc/modprobe.d/` directory

Example:

```
# printf '\n%s\n' "blacklist sctp" >> /etc/modprobe.d/60-sctp.conf
```

References:

1. CCI-000381
2. NIST SP 800-53 :: CM-7
3. NIST SP 800-53A :: CM-7.1 (ii)
4. STIG ID: RHEL-08-040023 | RULE ID: SV-230496r1069312 | CAT III
5. STIG ID: OL08-00-040023 | RULE ID: SV-248831r991589 | CAT II
6. STIG ID: RHEL-09-213060 | RULE ID: SV-257807r1044862 | CAT II
7. STIG ID: ALMA-09-030050 | RULE ID: SV-269345r1050227 | CAT II
8. STIG ID: OL09-00-000043 | RULE ID: SV-271446r1091050 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.2.6 Ensure tipc kernel module is not available (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The Transparent Inter-Process Communication (TIPC) protocol is designed to provide communication between cluster nodes.

Rationale:

Removing support for unneeded protocols reduces the local attack surface of the system. If this protocol is not needed, disable it.

Audit:

Verify the `tipc` kernel module is not available on the system or has been disabled.

1. Run the following script to determine if the `tipc` kernel module is available on the system:

```
#!/usr/bin/env bash

{
   l_mod_name="tipc" l_mod_type="net"
   while IFS= read -r l_mod_path; do
      if [ -d "$l_mod_path/${l_mod_name//-/\/}" ] &&  \
      [ -n "$(ls -A "$l_mod_path/${l_mod_name//-/\/}")" ]; then
         printf '%s\n' "$l_mod_name exists in $l_mod_path"
      fi
   done < <(readlink -e /usr/lib/modules/**/kernel/$l_mod_type \
   || readlink -e /lib/modules/**/kernel/$l_mod_type)
}
```

If nothing is returned, the `tipc` kernel module is not available on the system and no further audit steps are required.

Note: Some systems may include the `tipc` filesystem as part of the kernel opposed to being available as a kernel module. In this case, the above audit will not return anything. This is also considered a passing state.

If anything is returned by the above script:

2. verify the `tipc` kernel module is not loaded and not loadable by performing the following:

Run the following command to verify the `tipc` kernel module is not loaded:

```
# lsmod | grep 'tipc'
```

Nothing should be returned

Run the following command to verify the `tipc` kernel module is not loadable:

```
# modprobe --showconfig | grep -P -- '\b(install|blacklist)\h+tipc\b'
```

Verify the output includes:

```
blacklist tipc
 -AND-
install tipc /bin/false
 -OR-
install tipc /bin/true
```

Example output:

```
blacklist tipc
install tipc /bin/false
```

Remediation:

Unload and disable the `tipc` kernel module.

1. Run the following commands to unload the `tipc` kernel module:

```
# modprobe -r tipc 2>/dev/null
# rmmod tipc 2>/dev/null
```

2. Perform the following to disable the `tipc` kernel module:

Create a file ending in `.conf` with `install tipc /bin/false` in the `/etc/modprobe.d/` directory
Example:

```
# printf '\n%s\n' "install tipc /bin/false" >> /etc/modprobe.d/60-tipc.conf
```

Create a file ending in `.conf` with `blacklist tipc` in the `/etc/modprobe.d/` directory

Example:

```
# printf '\n%s\n' "blacklist tipc" >> /etc/modprobe.d/60-tipc.conf
```

References:

1. CCI-000381
2. NIST SP 800-53 :: CM-7
3. NIST SP 800-53A :: CM-7.1 (ii)
4. STIG ID: RHEL-08-040024 | RULE ID: SV-230497r1069313 | CAT III
5. STIG ID: OL08-00-040024 | RULE ID: SV-248832r958478 | CAT III
6. STIG ID: RHEL-09-213065 | RULE ID: SV-257808r1044865 | CAT II
7. STIG ID: ALMA-09-030270 | RULE ID: SV-269347r1050229 | CAT II
8. STIG ID: OL09-00-000044 | RULE ID: SV-271447r1092464 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3 Configure Network Kernel Parameters

This section contains Recommendations covering kernel parameters effecting network stack.

Note:

- Some of the Recommendations in this section's subsections are not applicable if the system is a router. These Recommendations include a note in their description.
- sysctl settings are defined through files in `/usr/local/lib`, `/usr/lib/`, `/lib/`, `/run/`, and `/etc/`
- Files are typically placed in the `sysctl.d` directory within the parent directory
- The paths where sysctl preload files usually exist
  - `/run/sysctl.d/*.conf`
  - `/etc/sysctl.d/*.conf`
  - `/usr/local/lib/sysctl.d/*.conf`
  - `/usr/lib/sysctl.d/*.conf`
  - `/lib/sysctl.d/*.conf`
  - `/etc/sysctl.conf`
- Files must have the "`.conf`" extension
- Vendors settings usually live in `/usr/lib/` or `/usr/local/lib/`
- To override a whole file, create a new file with the same name in `/etc/sysctl.d/` and put new settings there.
- To override only specific settings, add a file with a lexically later name in `/etc/sysctl.d/` and put new settings there.
- The command `/usr/lib/systemd/systemd-sysctl --cat-config` produces output containing the system's loaded kernel parameters and the files they're configured in:
  - Entries listed later in the file take precedence over the same settings listed earlier in the file
  - Files containing kernel parameters that are over-ridden by other files with the same name will not be listed
  - On systems running UncomplicatedFirewall, the kernel parameters may be set or overwritten. This will not be visible in the output of the command
- On systems with Uncomplicated Firewall, additional settings may be configured in `/etc/ufw/sysctl.conf`
  - The settings in `/etc/ufw/sysctl.conf` will override settings other settings and **will not** be visible in the output of the `/usr/lib/systemd/systemd-sysctl --cat-config` command
  - This behavior can be changed by updating the `IPT_SYSCTL` parameter in `/etc/default/ufw`

3.3.1 Configure IPv4 parameters

`net.ipv4` kernel parameters control various aspects of the IPv4 network stack. These parameters effect functions to include routing, TCP, and security.

3.3.1.1 Ensure net.ipv4.ip_forward is configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The `net.ipv4.ip_forward` flag tells the system whether it can forward IPv4 packets or not.

Note:

- **If this system is a router this recommendation is not applicable.**
- If `net.ipv4.conf.all.forwarding=0` and `net.ipv4.conf.default.forwarding=0` are configured, this recommendation may be skipped.

Rationale:

Routing protocol daemons are typically used on routers to exchange network topology information with other routers. If this software is used when not required, system network information may be unnecessarily transmitted across the network.

Setting `net.ipv4.ip_forward` to `0` ensures that a system with multiple interfaces (for example, a hard proxy), will not be able to forward IPv4 packets.

Impact:

IP forwarding is required on systems configured to act as a router. If these parameters are disabled, the system will not be able to perform as a router.

Many Cloud Service Provider (CSP) hosted systems require IP forwarding to be enabled. If the system is running on a CSP platform, this requirement should be reviewed before disabling IP forwarding.

Audit:

Verify `net.ipv4.ip_forward` is set to `0`.

1. Run the following command to verify `net.ipv4.ip_forward` is set to `0` in the running configuration:

```
# sysctl net.ipv4.ip_forward
```

Verify output is:

```
net.ipv4.ip_forward = 0
```

2. Run the following script to verify `net.ipv4.ip_forward = 0` is set in a file being used by systemd sysctl to configure `net.ipv4.ip_forward`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.ip_forward"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.ip_forward = 0" is set in: "/etc/sysctl.d/60-ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.ip_forward` lines that are not `net.ipv4.ip_forward=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.ip_forward" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.ip_forward = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.ip_forward = 0" >> /etc/sysctl.d/60-
ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.ip_forward = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: SLES-15-040380 | RULE ID: SV-235024r991589 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.1.2 Ensure net.ipv4.conf.all.forwarding is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

ICMP Redirects are used to send routing information to other hosts. As a host itself does not act as a router (in a host only configuration), there is no need to send redirects.

`net.ipv4.conf.all.forwarding` controls forwarding of IPv4 packet on all interfaces.

Note:

- **If this system is a router this recommendation is not applicable.**
- If `net.ipv4.ip_forward=0` is configured, this recommendation may be skipped.

Rationale:

Routing protocol daemons are typically used on routers to exchange network topology information with other routers. If this capability is used when not required, system network information may be unnecessarily transmitted across the network.

Impact:

IP forwarding is required on systems configured to act as a router. If these parameters are disabled, the system will not be able to perform as a router.

Cloud Service Provider (CSP) hosted systems may require forwarding to be enabled. If the system is running on a CSP platform, this requirement should be reviewed before disabling IPv4 forwarding.

Audit:

Verify `net.ipv4.conf.all.forwarding` is set to `0`.

1. Run the following command to verify `net.ipv4.conf.all.forwarding` is set to `0` in the running configuration:

```
# sysctl net.ipv4.conf.all.forwarding
```

Verify output is:

```
net.ipv4.conf.all.forwarding = 0
```

2. Run the following script to verify `net.ipv4.conf.all.forwarding = 0` is set in a file being used by systemd sysctl to configure `net.ipv4.conf.all.forwarding`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.conf.all.forwarding"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.conf.all.forwarding = 0" is set in: "/etc/sysctl.d/60-
ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.

- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.conf.all.forwarding` lines that are not `net.ipv4.conf.all.forwarding=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.conf.all.forwarding" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.conf.all.forwarding = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.conf.all.forwarding = 0" \
>> /etc/sysctl.d/60-ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.conf.all.forwarding = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040259 | RULE ID: SV-250317r1017358 | CAT II
5. STIG ID: OL08-00-040259 | RULE ID: SV-252662r991589 | CAT II
6. STIG ID: RHEL-09-253075 | RULE ID: SV-257970r1045011 | CAT II
7. STIG ID: ALMA-09-019160 | RULE ID: SV-269249r1050131 | CAT II
8. STIG ID: OL09-00-006028 | RULE ID: SV-271872r1092328 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.1.3 Ensure net.ipv4.conf.default.forwarding is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

ICMP Redirects are used to send routing information to other hosts. As a host itself does not act as a router (in a host only configuration), there is no need to send redirects.

`net.ipv4.conf.default.forwarding` controls forwarding of IPv4 packet on newly added network interfaces.

Note:

- **If this system is a router this recommendation is not applicable.**
- If `net.ipv4.ip_forward=0` is configured, this recommendation may be skipped.

Rationale:

Routing protocol daemons are typically used on routers to exchange network topology information with other routers. If this capability is used when not required, system network information may be unnecessarily transmitted across the network.

Impact:

IP forwarding is required on systems configured to act as a router. If these parameters are disabled, the system will not be able to perform as a router.

Cloud Service Provider (CSP) hosted systems may require forwarding to be enabled. If the system is running on a CSP platform, this requirement should be reviewed before disabling IPv4 forwarding.

Audit:

Verify `net.ipv4.conf.default.forwarding` is set to `0`.

1. Run the following command to verify `net.ipv4.conf.default.forwarding` is set to `0` in the running configuration:

```
# sysctl net.ipv4.conf.default.forwarding
```

Verify output is:

```
net.ipv4.conf.default.forwarding = 0
```

2. Run the following script to verify `net.ipv4.conf.default.forwarding = 0` is set in a file being used by systemd sysctl to configure `net.ipv4.conf.default.forwarding`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.conf.default.forwarding"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.conf.default.forwarding = 0" is set in: "/etc/sysctl.d/60-
ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.

- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.conf.default.forwarding` lines that are not `net.ipv4.conf.default.forwarding=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.conf.default.forwarding" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.conf.default.forwarding = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.conf.default.forwarding = 0" \
>> /etc/sysctl.d/60-ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.conf.default.forwarding = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: ALMA-09-019160 | RULE ID: SV-269249r1050131 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.1.4 Ensure net.ipv4.conf.all.send_redirects is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

ICMP Redirects are used to send routing information to other hosts. As a host itself does not act as a router (in a host only configuration), there is no need to send redirects.

`net.ipv4.conf.all.send_redirects` controls sending of all IPv4 ICMP redirected packets on all interfaces.

Note: If this system is a router this recommendation is not applicable.

Rationale:

An attacker could use a compromised host to send invalid ICMP redirects to other router devices in an attempt to corrupt routing and have users access a system set up by the attacker as opposed to a valid system.

Impact:

IP forwarding is required on systems configured to act as a router. If these parameters are disabled, the system will not be able to perform as a router.

Audit:

Verify `net.ipv4.conf.all.send_redirects` is set to `0`.

1. Run the following command to verify `net.ipv4.conf.all.send_redirects` is set to `0` in the running configuration:

```
# sysctl net.ipv4.conf.all.send_redirects
```

Verify output is:

```
net.ipv4.conf.all.send_redirects = 0
```

2. Run the following script to verify `net.ipv4.ip_forward = 0` is set in a file being used by systemd sysctl to configure `net.ipv4.conf.all.send_redirects`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.conf.all.send_redirects"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.conf.all.send_redirects = 0" is set in: "/etc/sysctl.d/60-
ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.conf.all.send_redirects` lines that are not `net.ipv4.conf.all.send_redirects=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.conf.all.send_redirects" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.conf.all.send_redirects = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.conf.all.send_redirects = 0" \
>> /etc/sysctl.d/60-ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.conf.all.send_redirects = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040220 | RULE ID: SV-230536r1017298 | CAT II
5. STIG ID: OL08-00-040220 | RULE ID: SV-248877r991589 | CAT II
6. STIG ID: RHEL-09-253065 | RULE ID: SV-257968r991589 | CAT II
7. STIG ID: ALMA-09-019930 | RULE ID: SV-269256r1050138 | CAT II
8. STIG ID: OL09-00-006032 | RULE ID: SV-271875r1092337 | CAT II
9. STIG ID: SLES-15-040370 | RULE ID: SV-235023r991589 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.1.5 Ensure net.ipv4.conf.default.send_redirects is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

ICMP Redirects are used to send routing information to other hosts. As a host itself does not act as a router (in a host only configuration), there is no need to send redirects.

`net.ipv4.conf.default.send_redirects` controls sending of all IPv4 ICMP redirected packets on a newly added network interface.

Note: If this system is a router this recommendation is not applicable.

Rationale:

An attacker could use a compromised host to send invalid ICMP redirects to other router devices in an attempt to corrupt routing and have users access a system set up by the attacker as opposed to a valid system.

Impact:

IP forwarding is required on systems configured to act as a router. If these parameters are disabled, the system will not be able to perform as a router.

Audit:

Verify `net.ipv4.conf.default.send_redirects` is set to `0`.

1. Run the following command to verify `net.ipv4.conf.default.send_redirects` is set to `0` in the running configuration:

```
# sysctl net.ipv4.conf.default.send_redirects
```

Verify output is:

```
net.ipv4.conf.default.send_redirects = 0
```

2. Run the following script to verify `net.ipv4.conf.default.send_redirects = 0` is set in a file being used by systemd sysctl to configure `net.ipv4.conf.default.send_redirects`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.conf.default.send_redirects"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.conf.default.send_redirects = 0" is set in: "/etc/sysctl.d/60-
ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.conf.default.send_redirects` lines that are not `net.ipv4.conf.default.send_redirects=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.conf.default.send_redirects" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.conf.default.send_redirects = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.conf.default.send_redirects = 0" \
>> /etc/sysctl.d/60-ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.conf.default.send_redirects = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040270 | RULE ID: SV-230543r1017305 | CAT II
5. STIG ID: OL08-00-040270 | RULE ID: SV-248886r991589 | CAT II
6. STIG ID: RHEL-09-253070 | RULE ID: SV-257969r991589 | CAT II
7. STIG ID: ALMA-09-019930 | RULE ID: SV-269256r1050138 | CAT II
8. STIG ID: OL09-00-006033 | RULE ID: SV-271876r1092641 | CAT II
9. STIG ID: SLES-15-040360 | RULE ID: SV-235022r991589 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.1.6 Ensure net.ipv4.icmp_ignore_bogus_error_responses is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`net.ipv4.icmp_ignore_bogus_error_responses` controls if the kernel logs bogus responses (RFC-1122 non-compliant) from broadcast reframes.

Rationale:

Some routers (and some attackers) will send responses that violate RFC-1122 and attempt to fill up a log file system with many useless error messages.

Audit:

Verify `net.ipv4.icmp_ignore_bogus_error_responses` is set to `1`.

1. Run the following command to verify `net.ipv4.icmp_ignore_bogus_error_responses` is set to `1` in the running configuration:

```
# sysctl net.ipv4.icmp_ignore_bogus_error_responses
```

Verify output is:

```
net.ipv4.icmp_ignore_bogus_error_responses = 1
```

2. Run the following script to verify `net.ipv4.icmp_ignore_bogus_error_responses = 1` is set in a file being used by systemd sysctl to configure `net.ipv4.icmp_ignore_bogus_error_responses`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.icmp_ignore_bogus_error_responses"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.icmp_ignore_bogus_error_responses = 1" is set in:
"/etc/sysctl.d/60-ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.icmp_ignore_bogus_error_responses` lines that are not `net.ipv4.icmp_ignore_bogus_error_responses=1`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.icmp_ignore_bogus_error_responses" l_value="1"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(0|[2-9]|1[0-9]+)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.icmp_ignore_bogus_error_responses = 1
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.icmp_ignore_bogus_error_responses = 1" \
>> /etc/sysctl.d/60-ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.icmp_ignore_bogus_error_responses = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-09-253060 | RULE ID: SV-257967r991589 | CAT II
5. STIG ID: ALMA-09-018940 | RULE ID: SV-269247r1050129 | CAT II
6. STIG ID: OL09-00-006031 | RULE ID: SV-271874r1092612 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.1.7 Ensure net.ipv4.icmp_echo_ignore_broadcasts is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`net.ipv4.icmp_echo_ignore_broadcasts` controls if all ICMP echo and timestamp requests to broadcast and multicast addresses are ignored.

Rationale:

Accepting ICMP echo and timestamp requests with broadcast or multicast destinations for your network could be used to trick your host into starting (or participating) in a Smurf attack. A Smurf attack relies on an attacker sending large amounts of ICMP broadcast messages with a spoofed source address. All hosts receiving this message and responding would send echo-reply messages back to the spoofed address, which is probably not routable. If many hosts respond to the packets, the amount of traffic on the network could be significantly multiplied.

Audit:

Verify `net.ipv4.icmp_echo_ignore_broadcasts` is set to `1`.

1. Run the following command to verify `net.ipv4.icmp_echo_ignore_broadcasts` is set to `1` in the running configuration:

```
# sysctl net.ipv4.icmp_echo_ignore_broadcasts
```

Verify output is:

```
net.ipv4.icmp_echo_ignore_broadcasts = 1
```

2. Run the following script to verify `net.ipv4.icmp_echo_ignore_broadcasts = 1` is set in a file being used by systemd sysctl to configure `net.ipv4.icmp_echo_ignore_broadcasts`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.icmp_echo_ignore_broadcasts"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.icmp_echo_ignore_broadcasts = 1" is set in: "/etc/sysctl.d/60-
ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.icmp_echo_ignore_broadcasts` lines that are not `net.ipv4.icmp_echo_ignore_broadcasts=1`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.icmp_echo_ignore_broadcasts" l_value="1"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(0|[2-9]|1[0-9]+)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.icmp_echo_ignore_broadcasts = 1
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.icmp_echo_ignore_broadcasts = 1" \
>> /etc/sysctl.d/60-ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.icmp_echo_ignore_broadcasts = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040230 | RULE ID: SV-230537r1017299 | CAT II
5. STIG ID: OL08-00-040230 | RULE ID: SV-248878r991589 | CAT II
6. STIG ID: RHEL-09-253055 | RULE ID: SV-257966r991589 | CAT II
7. STIG ID: ALMA-09-019050 | RULE ID: SV-269248r1050130 | CAT II
8. STIG ID: OL09-00-006030 | RULE ID: SV-271873r1092331 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.1.8 Ensure net.ipv4.conf.all.accept_redirects is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

ICMP redirect messages are packets that convey routing information and tell your host (acting as a router) to send packets via an alternate path. It is a way of allowing an outside routing device to update your system routing tables.

`net.ipv4.conf.all.accept_redirects` controls accepting of all IPv4 ICMP redirected packets on all interfaces.

Rationale:

ICMP redirect messages are packets that convey routing information and tell your host (acting as a router) to send packets via an alternate path. It is a way of allowing an outside routing device to update your system routing tables.

By setting `net.ipv4.conf.all.accept_redirects` to `0`, the system will not accept any IPv4 ICMP redirect messages, and therefore, won't allow outsiders to update the system's routing tables.

Audit:

Verify `net.ipv4.conf.all.accept_redirects` is set to `0`.

1. Run the following command to verify `net.ipv4.conf.all.accept_redirects` is set to `0` in the running configuration:

```
# sysctl net.ipv4.conf.all.accept_redirects
```

Verify output is:

```
net.ipv4.conf.all.accept_redirects = 0
```

2. Run the following script to verify `net.ipv4.ip_forward = 0` is set in a file being used by systemd sysctl to configure `net.ipv4.conf.all.send_redirects`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.conf.all.accept_redirects"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.conf.all.accept_redirects = 0" is set in: "/etc/sysctl.d/60-
ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.conf.all.accept_redirects` lines that are not `net.ipv4.conf.all.accept_redirects=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.conf.all.accept_redirects" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.conf.all.accept_redirects = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.conf.all.accept_redirects = 0" \
>> /etc/sysctl.d/60-ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.conf.all.accept_redirects = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040279 | RULE ID: SV-244553r1017353 | CAT II
5. STIG ID: OL08-00-040279 | RULE ID: SV-248887r991589 | CAT II
6. STIG ID: RHEL-09-253015 | RULE ID: SV-257958r991589 | CAT II
7. STIG ID: ALMA-09-018610 | RULE ID: SV-269244r1050126 | CAT II
8. STIG ID: OL09-00-006020 | RULE ID: SV-271864r1092304 | CAT II
9. STIG ID: SLES-15-040330 | RULE ID: SV-235018r991589 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.1.9 Ensure net.ipv4.conf.default.accept_redirects is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

ICMP redirect messages are packets that convey routing information and tell your host (acting as a router) to send packets via an alternate path. It is a way of allowing an outside routing device to update your system routing tables.

`net.ipv4.conf.default.accept_redirects` controls accepting of all IPv4 ICMP redirected packets on a newly added network interface.

Note: If this system is a router this recommendation is not applicable.

Rationale:

ICMP redirect messages are packets that convey routing information and tell your host (acting as a router) to send packets via an alternate path. It is a way of allowing an outside routing device to update your system routing tables.

By setting `net.ipv4.conf.all.accept_redirects` to `0`, the system will not accept IPv4 ICMP redirect messages on a newly added network interface.

Audit:

Verify `net.ipv4.conf.default.accept_redirects` is set to `0`.

1. Run the following command to verify `net.ipv4.conf.default.accept_redirects` is set to `0` in the running configuration:

```
# sysctl net.ipv4.conf.default.accept_redirects
```

Verify output is:

```
net.ipv4.conf.default.accept_redirects = 0
```

2. Run the following script to verify `net.ipv4.conf.default.accept_redirects = 0` is set in a file being used by systemd sysctl to configure `net.ipv4.conf.default.accept_redirects`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.conf.default.accept_redirects"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.conf.default.accept_redirects = 0" is set in: "/etc/sysctl.d/60-
ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.conf.default.accept_redirects` lines that are not `net.ipv4.conf.default.accept_redirects=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.conf.default.accept_redirects" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.conf.default.accept_redirects = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.conf.default.accept_redirects = 0" \
>> /etc/sysctl.d/60-ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.conf.default.accept_redirects = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040209 | RULE ID: SV-244550r1017350 | CAT II
5. STIG ID: OL08-00-040209 | RULE ID: SV-248875r991589 | CAT II
6. STIG ID: RHEL-09-253040 | RULE ID: SV-257963r991589 | CAT II
7. STIG ID: ALMA-09-018610 | RULE ID: SV-269244r1050126 | CAT II
8. STIG ID: OL09-00-006025 | RULE ID: SV-271869r1092319 | CAT II
9. STIG ID: SLES-15-040340 | RULE ID: SV-235019r991589 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.1.10 Ensure net.ipv4.conf.all.secure_redirects is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Secure ICMP redirects are the same as ICMP redirects, except they come from gateways listed on the default gateway list. It is assumed that these gateways are known to your system, and that they are likely to be secure.

Rationale:

It is still possible for even known gateways to be compromised.

Setting `net.ipv4.conf.all.secure_redirects` to `0` the system will not accept any IPv4 routing table updates by possibly compromised known gateways.

Audit:

Verify `net.ipv4.conf.all.secure_redirects` is set to `0`.

1. Run the following command to verify `net.ipv4.conf.all.secure_redirects` is set to `0` in the running configuration:

```
# sysctl net.ipv4.conf.all.secure_redirects
```

Verify output is:

```
net.ipv4.conf.all.secure_redirects = 0
```

2. Run the following script to verify `net.ipv4.conf.all.secure_redirects = 0` is set in a file being used by systemd sysctl to configure `net.ipv4.conf.all.secure_redirects`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.conf.all.secure_redirects"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.conf.all.secure_redirects = 0" is set in: "/etc/sysctl.d/60-
ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.conf.all.secure_redirects` lines that are not `net.ipv4.conf.all.secure_redirects=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.conf.all.secure_redirects" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.conf.all.secure_redirects = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.conf.all.secure_redirects = 0" \
>> /etc/sysctl.d/60-ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.conf.all.secure_redirects = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.1.11 Ensure net.ipv4.conf.default.secure_redirects is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Secure ICMP redirects are the same as ICMP redirects, except they come from gateways listed on the default gateway list. It is assumed that these gateways are known to your system, and that they are likely to be secure.

Rationale:

It is still possible for even known gateways to be compromised.

Setting `net.ipv4.conf.default.secure_redirects` to `0` the system the system will not accept IPv4 routing table updates by possibly compromised known gateways on a newly added network interface.

Audit:

Verify `net.ipv4.conf.default.secure_redirects` is set to `0`.

1. Run the following command to verify `net.ipv4.conf.default.secure_redirects` is set to `0` in the running configuration:

```
# sysctl  net.ipv4.conf.default.secure_redirects
```

Verify output is:

```
net.ipv4.conf.default.secure_redirects = 0
```

2. Run the following script to verify `net.ipv4.conf.default.secure_redirects = 0` is set in a file being used by systemd sysctl to configure `net.ipv4.conf.default.secure_redirects`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.conf.default.secure_redirects"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.conf.default.secure_redirects = 0" is set in: "/etc/sysctl.d/60-
ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.conf.default.secure_redirects` lines that are not `net.ipv4.conf.default.secure_redirects=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.conf.default.secure_redirects" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.conf.default.secure_redirects = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.conf.default.secure_redirects = 0" \
>> /etc/sysctl.d/60-ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.conf.default.secure_redirects = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.1.12 Ensure net.ipv4.conf.all.rp_filter is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`net.ipv4.conf.all.rp_filter` controls reverse path filtering for IPv4 traffic on all network interfaces.

Reverse path filtering is a security mechanism in Linux that helps prevent IP spoofing and other network attacks. When enabled, it checks if the source IP address of an incoming packet is reachable through the same network interface it was received on. If the packet's source address is not reachable through the interface it arrived on, the packet is dropped.

Note: If this system is a router, and uses asymmetrical routing, this recommendation is not applicable.

Rationale:

Setting `net.ipv4.conf.all.rp_filter` to `1` is a good way to deter attackers from sending your system bogus packets that cannot be responded to. One instance where this feature breaks down is if asymmetrical routing is employed. This would occur when using dynamic routing protocols (bgp, ospf, etc) on your system. If you are using asymmetrical routing on your system, you will not be able to enable this feature without breaking the routing.

Impact:

If you are using asymmetrical routing on your system, you will not be able to enable this feature without breaking the routing.

Audit:

Verify `net.ipv4.conf.all.rp_filter` is set to `1`.

1. Run the following command to verify `net.ipv4.conf.all.rp_filter` is set to `1` in the running configuration:

```
# sysctl net.ipv4.conf.all.rp_filter
```

Verify output is:

```
net.ipv4.conf.all.rp_filter = 1
```

2. Run the following script to verify `net.ipv4.conf.all.rp_filter = 1` is set in a file being used by systemd sysctl to configure `net.ipv4.conf.all.rp_filter`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.conf.all.rp_filter"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.conf.all.rp_filter = 1" is set in: "/etc/sysctl.d/60-
ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.conf.all.rp_filter` lines that are not `net.ipv4.conf.all.rp_filter=1`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.conf.all.rp_filter" l_value="1"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(0|[2-9]|1[0-9]+)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.conf.all.rp_filter = 1
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.conf.all.rp_filter = 1" \
>> /etc/sysctl.d/60-ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.conf.all.rp_filter = 2

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040285 | RULE ID: SV-230549r1017311 | CAT II
5. STIG ID: OL08-00-040285 | RULE ID: SV-248893r991589 | CAT II
6. STIG ID: RHEL-09-253035 | RULE ID: SV-257962r991589 | CAT II
7. STIG ID: ALMA-09-019820 | RULE ID: SV-269255r1050137 | CAT II
8. STIG ID: OL09-00-006024 | RULE ID: SV-271868r1092316 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.1.13 Ensure net.ipv4.conf.default.rp_filter is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`net.ipv4.conf.default.rp_filter` controls reverse path filtering for IPv4 traffic on newly added network interfaces.

Reverse path filtering is a security mechanism in Linux that helps prevent IP spoofing and other network attacks. When enabled, it checks if the source IP address of an incoming packet is reachable through the same network interface it was received on. If the packet's source address is not reachable through the interface it arrived on, the packet is dropped.

Note: If this system is a router, and uses asymmetrical routing, this recommendation is not applicable.

Rationale:

Setting `net.ipv4.conf.default.rp_filter` to `1` is a good way to deter attackers from sending your system bogus packets that cannot be responded to. One instance where this feature breaks down is if asymmetrical routing is employed. This would occur when using dynamic routing protocols (bgp, ospf, etc) on your system. If you are using asymmetrical routing on your system, you will not be able to enable this feature without breaking the routing.

Impact:

If you are using asymmetrical routing on your system, you will not be able to enable this feature without breaking the routing.

Audit:

Verify `net.ipv4.conf.default.rp_filter` is set to `1`.

1. Run the following command to verify `net.ipv4.conf.default.rp_filter` is set to `1` in the running configuration:

```
# sysctl net.ipv4.conf.default.rp_filter
```

Verify output is:

```
net.ipv4.conf.default.rp_filter = 1
```

2. Run the following script to verify `net.ipv4.conf.default.rp_filter = 1` is set in a file being used by systemd sysctl to configure `net.ipv4.conf.default.rp_filter`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.conf.default.rp_filter"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.conf.default.rp_filter = 1" is set in: "/etc/sysctl.d/60-
ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.conf.default.rp_filter` lines that are not `net.ipv4.conf.default.rp_filter=1`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.conf.default.rp_filter" l_value="1"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(0|[2-9]|1[0-9]+)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.conf.default.rp_filter = 1
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.conf.default.rp_filter = 1" \
>> /etc/sysctl.d/60-ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.conf.default.rp_filter = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-09-253050 | RULE ID: SV-257965r991589 | CAT II
5. STIG ID: ALMA-09-019820 | RULE ID: SV-269255r1050137 | CAT II
6. STIG ID: OL09-00-006027 | RULE ID: SV-271871r1092325 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.1.14 Ensure net.ipv4.conf.all.accept_source_route is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `accept_source_route` option causes network interfaces to accept packets with the Strict Source Route (SSR) or Loose Source Routing (LSR) option set.

`net.ipv4.conf.all.accept_source_route` controls accepting of all IPv4 packets with the SSR or LSR option set on all interfaces.

In networking, source routing allows a sender to partially or fully specify the route packets take through a network. In contrast, non-source routed packets travel a path determined by routers in the network. In some cases, systems may not be routable or reachable from some locations (e.g. private addresses vs. Internet routable), and so source routed packets would need to be used.

Rationale:

Setting `net.ipv4.conf.all.accept_source_route` to `0` disables the system from accepting source routed packets. Assume this system was capable of routing packets to Internet routable addresses on one interface and private addresses on another interface. Assume that the private addresses were not routable to the Internet routable addresses and vice versa. Under normal routing circumstances, an attacker from the Internet routable addresses could not use the system as a way to reach the private address systems. If, however, source routed packets were allowed, they could be used to gain access to the private address systems as the route could be specified, rather than rely on routing protocols that did not allow this routing.

Audit:

Verify `net.ipv4.conf.all.accept_source_route` is set to `0`.

1. Run the following command to verify `net.ipv4.conf.all.accept_source_route` is set to `0` in the running configuration:

```
# sysctl net.ipv4.conf.all.accept_source_route
```

Verify output is:

```
net.ipv4.conf.all.accept_source_route = 0
```

2. Run the following script to verify `net.ipv4.conf.all.accept_source_route = 0` is set in a file being used by systemd sysctl to configure `net.ipv4.conf.all.accept_source_route`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.conf.all.accept_source_route"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.conf.all.accept_source_route = 0" is set in: "/etc/sysctl.d/60-
ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.conf.all.accept_source_route` lines that are not `net.ipv4.conf.all.accept_source_route=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.conf.all.accept_source_route" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.conf.all.accept_source_route = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.conf.all.accept_source_route = 0" \
>> /etc/sysctl.d/60-ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.conf.all.accept_source_route = 0

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040239 | RULE ID: SV-244551r1017351 | CAT II
5. STIG ID: OL08-00-040239 | RULE ID: SV-248879r991589 | CAT II
6. STIG ID: RHEL-09-253020 | RULE ID: SV-257959r991589 | CAT II
7. STIG ID: ALMA-09-020260 | RULE ID: SV-269259r1050141 | CAT II
8. STIG ID: OL09-00-006021 | RULE ID: SV-271865r1092307 | CAT II
9. STIG ID: SLES-15-040300 | RULE ID: SV-235014r991589 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.1.15 Ensure net.ipv4.conf.default.accept_source_route is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `accept_source_route` option causes network interfaces to accept packets with the Strict Source Route (SSR) or Loose Source Routing (LSR) option set.

`net.ipv4.conf.default.accept_source_route` controls accepting of all IPv4 packets with the SSR or LSR option set on newly added network interfaces.

In networking, source routing allows a sender to partially or fully specify the route packets take through a network. In contrast, non-source routed packets travel a path determined by routers in the network. In some cases, systems may not be routable or reachable from some locations (e.g. private addresses vs. Internet routable), and so source routed packets would need to be used.

Rationale:

Setting `net.ipv4.conf.default.accept_source_route` to `0` disables the system from accepting source routed packets. Assume this system was capable of routing packets to Internet routable addresses on one interface and private addresses on another interface. Assume that the private addresses were not routable to the Internet routable addresses and vice versa. Under normal routing circumstances, an attacker from the Internet routable addresses could not use the system as a way to reach the private address systems. If, however, source routed packets were allowed, they could be used to gain access to the private address systems as the route could be specified, rather than rely on routing protocols that did not allow this routing.

Audit:

Verify `net.ipv4.conf.default.accept_source_route` is set to `0`.

1. Run the following command to verify `net.ipv4.conf.default.accept_source_route` is set to `0` in the running configuration:

```
# sysctl net.ipv4.conf.default.accept_source_route
```

Verify output is:

```
net.ipv4.conf.default.accept_source_route = 0
```

2. Run the following script to verify `net.ipv4.conf.default.accept_source_route = 0` is set in a file being used by systemd sysctl to configure `net.ipv4.conf.default.accept_source_route`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.conf.default.accept_source_route"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.conf.default.accept_source_route = 0" is set in:
"/etc/sysctl.d/60-ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.conf.default.accept_source_route` lines that are not `net.ipv4.conf.default.accept_source_route=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.conf.default.accept_source_route" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.conf.default.accept_source_route = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.conf.default.accept_source_route = 0" \
>> /etc/sysctl.d/60-ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.conf.default.accept_source_route = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040249 | RULE ID: SV-244552r1017352 | CAT II
5. STIG ID: OL08-00-040249 | RULE ID: SV-248881r991589 | CAT II
6. STIG ID: RHEL-09-253045 | RULE ID: SV-257964r991589 | CAT II
7. STIG ID: ALMA-09-020260 | RULE ID: SV-269259r1050141 | CAT II
8. STIG ID: OL09-00-006026 | RULE ID: SV-271870r1092322 | CAT II
9. STIG ID: SLES-15-040320 | RULE ID: SV-235016r991589 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.1.16 Ensure net.ipv4.conf.all.log_martians is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

When enabled, this feature logs packets with un-routable source addresses to the kernel log.

`net.ipv4.conf.all.log_martians` controls if IPv4 packets with un-routable source addresses on any network interface is logged to the kernel log.

Rationale:

Setting `net.ipv4.conf.all.log_martians` to `1` enables this feature. Logging these packets allows an administrator to investigate the possibility that an attacker is sending spoofed packets to their system.

Audit:

Verify `net.ipv4.conf.all.log_martians` is set to `1`.

1. Run the following command to verify `net.ipv4.conf.all.log_martians` is set to `1` in the running configuration:

```
# sysctl net.ipv4.conf.all.log_martians
```

Verify output is:

```
net.ipv4.conf.all.log_martians = 1
```

2. Run the following script to verify `net.ipv4.conf.all.log_martians = 1` is set in a file being used by systemd sysctl to configure `net.ipv4.conf.all.log_martians`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.conf.all.log_martians"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.conf.all.log_martians = 1" is set in: "/etc/sysctl.d/60-
ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.conf.all.log_martians` lines that are not `net.ipv4.conf.all.log_martians=1`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.conf.all.log_martians" l_value="1"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(0|[2-9]|1[0-9]+)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.conf.all.log_martians = 1
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.conf.all.log_martians = 1" \
>> /etc/sysctl.d/60-ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.conf.all.log_martians = 0

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-09-253025 | RULE ID: SV-257960r991589 | CAT II
5. STIG ID: ALMA-09-019380 | RULE ID: SV-269251r1050133 | CAT II
6. STIG ID: OL09-00-006022 | RULE ID: SV-271866r1092310 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

3.3.1.17 Ensure net.ipv4.conf.default.log_martians is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

When enabled, this feature logs packets with un-routable source addresses to the kernel log.

`net.ipv4.conf.default.log_martians` controls if IPv4 packets with un-routable source addresses on a newly added network interface is logged to the kernel log.

Rationale:

Setting `net.ipv4.conf.default.log_martians` to `1` enables this feature. Logging these packets allows an administrator to investigate the possibility that an attacker is sending spoofed packets to their system.

Audit:

Verify `net.ipv4.conf.default.log_martians` is set to `1`.

1. Run the following command to verify `net.ipv4.conf.default.log_martians` is set to `1` in the running configuration:

```
# sysctl net.ipv4.conf.default.log_martians
```

Verify output is:

```
net.ipv4.conf.default.log_martians = 1
```

2. Run the following script to verify `net.ipv4.conf.default.log_martians = 1` is set in a file being used by systemd sysctl to configure `net.ipv4.conf.default.log_martians`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.conf.default.log_martians"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.conf.default.log_martians = 1" is set in: "/etc/sysctl.d/60-
ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.conf.default.log_martians` lines that are not `net.ipv4.conf.default.log_martians=1`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.conf.default.log_martians" l_value="1"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(0|[2-9]|1[0-9]+)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf`and edit or add the following line:

```
net.ipv4.conf.default.log_martians = 1
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.conf.default.log_martians = 1" \
>> /etc/sysctl.d/60-ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.conf.default.log_martians = 0

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-09-253030 | RULE ID: SV-257961r991589 | CAT II
5. STIG ID: ALMA-09-019380 | RULE ID: SV-269251r1050133 | CAT II
6. STIG ID: OL09-00-006023 | RULE ID: SV-271867r1092313 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

3.3.1.18 Ensure net.ipv4.tcp_syncookies is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

When `tcp_syncookies` is set, the kernel will handle TCP SYN packets normally until the half-open connection queue is full, at which time, the SYN cookie functionality kicks in. SYN cookies work by not using the SYN queue at all. Instead, the kernel simply replies to the SYN with a SYN/ACK, but will include a specially crafted TCP sequence number that encodes the source and destination IP address and port number and the time the packet was sent. A legitimate connection would send the ACK packet of the three way handshake with the specially crafted sequence number. This allows the system to verify that it has received a valid response to a SYN cookie and allow the connection, even though there is no corresponding SYN in the queue.

Rationale:

Attackers use SYN flood attacks to perform a denial of service attacked on a system by sending many SYN packets without completing the three way handshake. This will quickly use up slots in the kernel's half-open connection queue and prevent legitimate connections from succeeding. Setting `net.ipv4.tcp_syncookies` to `1` enables SYN cookies, allowing the system to keep accepting valid connections, even if under a denial of service attack.

Audit:

Verify `net.ipv4.tcp_syncookies` is set to `1`.

1. Run the following command to verify `net.ipv4.tcp_syncookies` is set to `1` in the running configuration:

```
# sysctl net.ipv4.tcp_syncookies
```

Verify output is:

```
net.ipv4.tcp_syncookies = 1
```

2. Run the following script to verify `net.ipv4.tcp_syncookies = 1` is set in a file being used by systemd sysctl to configure `net.ipv4.tcp_syncookies`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv4.tcp_syncookies"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv4.tcp_syncookies = 1" is set in: "/etc/sysctl.d/60-
ipv4_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv4.tcp_syncookies` lines that are not `net.ipv4.tcp_syncookies=1`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv4.tcp_syncookies" l_value="1"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(0|[2-9]|1[0-9]+)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf` and edit or add the following line:

```
net.ipv4.tcp_syncookies = 1
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv4.tcp_syncookies = 1" >> /etc/sysctl.d/60-
ipv4_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv4.tcp_syncookies = 1

References:

1. CCI-001095 | CCI-002385
2. NIST SP 800-53 :: SC-5 (2) | NIST SP 800-53 :: SC-5 a
3. NIST SP 800-53A :: SC-5 (2).1
4. STIG ID: RHEL-09-253010 | RULE ID: SV-257957r1045009 | CAT II
5. STIG ID: ALMA-09-042480 | RULE ID: SV-269435r1050318 | CAT II
6. STIG ID: OL09-00-006050 | RULE ID: SV-271884r1092364 | CAT II
7. STIG ID: UBTU-22-253010 | RULE ID: SV-260522r1069097 | CAT II
8. STIG ID: UBTU-24-600190 | RULE ID: SV-270753r1066748 | CAT II
9. STIG ID: SLES-15-010310 | RULE ID: SV-234829r958528 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.2 Configure IPv6 parameters

`net.ipv6` kernel parameters control various aspects of the IPv6 network stack. These parameters effect functions to include routing, TCP, and security.

Note: If IPv6 has been disabled on the system, the Recommendations in this subsection are not applicable and should be skipped.

The following script creates and runs a function called `f_ipv6_chk` that may be used to determine if IPv6 has been disabled on the system:

```
#!/usr/bin/env bash

f_ipv6_chk()
{
   a_output=()
   ! grep -Pqs -- '^\h*0\b' /sys/module/ipv6/parameters/disable && \
   a_output+=(" - IPv6 is disabled")
   if sysctl net.ipv6.conf.all.disable_ipv6 | \
   grep -Pqs -- "^\h*net\.ipv6\.conf\.all\.disable_ipv6\h*=\h*1\b" && \
   sysctl net.ipv6.conf.default.disable_ipv6 | \
   grep -Pqs -- "^\h*net\.ipv6\.conf\.default\.disable_ipv6\h*=\h*1\b"; then
      [ "${#a_output[@]}" -le 0 ] && a_output+=(" - IPv6 is disabled")
   fi
   [ "${#a_output[@]}" -le 0 ] && a_output+=(" - IPv6 is not disabled")
   printf '%s\n' "" "${a_output[@]}" ""
}
f_ipv6_chk
```

3.3.2.1 Ensure net.ipv6.conf.all.forwarding is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `net.ipv6.conf.all.forwarding` flag tells the system whether it can forward IPv6 packets or not.

Note: If IPv6 has been disabled, or this system is a router, this recommendation is not applicable.

Rationale:

Routing protocol daemons are typically used on routers to exchange network topology information with other routers. If this software is used when not required, system network information may be unnecessarily transmitted across the network.

Setting `net.ipv6.conf.all.forwarding` to `0` ensures that a system with multiple interfaces (for example, a hard proxy), will not be able to forward IPv6 packets.

Impact:

IP forwarding is required on systems configured to act as a router. If these parameters are disabled, the system will not be able to perform as a router.

Many Cloud Service Provider (CSP) hosted systems require IP forwarding to be enabled. If the system is running on a CSP platform, this requirement should be reviewed before disabling IP forwarding.

Audit:

- IF IPv6 is enabled on the system -

Verify `net.ipv6.conf.all.forwarding` is set to `0`.

1. Run the following command to verify `net.ipv6.conf.all.forwarding` is set to `0` in the running configuration:

```
# sysctl net.ipv6.conf.all.forwarding
```

Verify output is:

```
net.ipv6.conf.all.forwarding = 0
```

2. Run the following script to verify `net.ipv6.conf.all.forwarding = 0` is set in a file being used by systemd sysctl to configure `net.ipv6.conf.all.forwarding`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv6.conf.all.forwarding"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv6.conf.all.forwarding = 0" is set in: "/etc/sysctl.d/60-
ipv6_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv6.conf.all.forwarding` lines that are not `net.ipv6.conf.all.forwarding=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv6.conf.all.forwarding" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf` and edit or add the following line:

```
net.ipv6.conf.all.forwarding = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv6.conf.all.forwarding = 0" >> /etc/sysctl.d/60-
ipv6_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv6.conf.all.forwarding = 0

References:

1. CI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040260 | RULE ID: SV-230540r1017302 | CAT II
5. STIG ID: OL08-00-040260 | RULE ID: SV-248883r991589 | CAT II
6. STIG ID: RHEL-09-254025 | RULE ID: SV-257974r991589 | CAT II
7. STIG ID: ALMA-09-019160 | RULE ID: SV-269249r1050131 | CAT II
8. STIG ID: OL09-00-006043 | RULE ID: SV-271880r1092352 | CAT II
9. STIG ID: SLES-15-040381 | RULE ID: SV-235025r991589 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.2.2 Ensure net.ipv6.conf.default.forwarding is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `net.ipv6.conf.all.forwarding` flag tells the system whether it can forward IPv6 on the default or newly added network interface.

Note: If IPv6 has been disabled, or this system is a router, this recommendation is not applicable.

Rationale:

Routing protocol daemons are typically used on routers to exchange network topology information with other routers. If this software is used when not required, system network information may be unnecessarily transmitted across the network.

Impact:

IP forwarding is required on systems configured to act as a router. If these parameters are disabled, the system will not be able to perform as a router.

Many Cloud Service Provider (CSP) hosted systems require IP forwarding to be enabled. If the system is running on a CSP platform, this requirement should be reviewed before disabling IP forwarding.

Audit:

- IF IPv6 is enabled on the system -

Verify `net.ipv6.conf.default.forwarding` is set to `0`.

1. Run the following command to verify `net.ipv6.conf.default.forwarding` is set to `0` in the running configuration:

```
# sysctl net.ipv6.conf.default.forwarding
```

Verify output is:

```
net.ipv6.conf.default.forwarding = 0
```

2. Run the following script to verify `net.ipv6.conf.default.forwarding = 0` is set in a file being used by systemd sysctl to configure `net.ipv6.conf.default.forwarding`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv6.conf.default.forwarding"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv6.conf.default.forwarding = 0" is set in: "/etc/sysctl.d/60-
ipv6_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv6.conf.default.forwarding` lines that are not `net.ipv6.conf.default.forwarding=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv6.conf.default.forwarding" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf` and edit or add the following line:

```
net.ipv6.conf.default.forwarding = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv6.conf.default.forwarding = 0" >>
/etc/sysctl.d/60-ipv6_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv6.conf.default.forwarding = 0

References:

1. CI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: ALMA-09-019160 | RULE ID: SV-269249r1050131 | CAT II
5. STIG ID: SLES-15-040382 | RULE ID: SV-235026r991589 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.2.3 Ensure net.ipv6.conf.all.accept_redirects is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

ICMP redirect messages are packets that convey routing information and tell your host (acting as a router) to send packets via an alternate path. It is a way of allowing an outside routing device to update your system routing tables.

`net.ipv6.conf.all.accept_redirects` controls accepting of all IPv6 ICMP redirected packets on all interfaces.

Note: If IPv6 has been disabled, or this system is a router, this recommendation is not applicable.

Rationale:

ICMP redirect messages are packets that convey routing information and tell your host (acting as a router) to send packets via an alternate path. It is a way of allowing an outside routing device to update your system routing tables.

By setting `net.ipv6.conf.all.accept_redirects` to `0`, the system will not accept any IPv6 ICMP redirect messages, and therefore, won't allow outsiders to update the system's routing tables.

Audit:

- IF IPv6 is enabled on the system -

Verify `net.ipv6.conf.all.accept_redirects` is set to `0`.

1. Run the following command to verify `net.ipv6.conf.all.accept_redirects` is set to `0` in the running configuration:

```
# sysctl net.ipv6.conf.all.accept_redirects
```

Verify output is:

```
net.ipv6.conf.all.accept_redirects = 0
```

2. Run the following script to verify `net.ipv6.conf.all.accept_redirects = 0` is set in a file being used by systemd sysctl to configure `net.ipv6.conf.all.accept_redirects`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv6.conf.all.accept_redirects"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv6.conf.all.accept_redirects = 0" is set in: "/etc/sysctl.d/60-
ipv6_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv6.conf.all.accept_redirects` lines that are not `net.ipv6.conf.all.accept_redirects=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv6.conf.all.accept_redirects" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf` and edit or add the following line:

```
net.ipv6.conf.all.accept_redirects = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv6.conf.all.accept_redirects = 0" \
>> /etc/sysctl.d/60-ipv6_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv6.conf.all.accept_redirects = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040280 | RULE ID: SV-230544r1017306 | CAT II
5. STIG ID: OL08-00-040280 | RULE ID: SV-248888r991589 | CAT II
6. STIG ID: RHEL-09-254015 | RULE ID: SV-257972r991589 | CAT II
7. STIG ID: ALMA-09-018610 | RULE ID: SV-269244r1050126 | CAT II
8. STIG ID: OL09-00-006041 | RULE ID: SV-271878r1092346 | CAT II
9. STIG ID: SLES-15-040341 | RULE ID: SV-235020r991589 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.2.4 Ensure net.ipv6.conf.default.accept_redirects is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

ICMP redirect messages are packets that convey routing information and tell your host (acting as a router) to send packets via an alternate path. It is a way of allowing an outside routing device to update your system routing tables.

`net.ipv6.conf.default.accept_redirects` controls accepting of all IPv6 ICMP redirected packets on a newly added network interface.

Note: If IPv6 has been disabled, or this system is a router, this recommendation is not applicable.

Rationale:

ICMP redirect messages are packets that convey routing information and tell your host (acting as a router) to send packets via an alternate path. It is a way of allowing an outside routing device to update your system routing tables.

By setting `net.ipv6.conf.default.accept_redirects` to `0`, the system will not accept IPv6 ICMP redirect messages on a newly added network interface.

Audit:

- IF IPv6 is enabled on the system -

Verify `net.ipv6.conf.default.accept_redirects` is set to `0`.

1. Run the following command to verify `net.ipv6.conf.default.accept_redirects` is set to `0` in the running configuration:

```
# sysctl net.ipv6.conf.default.accept_redirects
```

Verify output is:

```
net.ipv6.conf.default.accept_redirects = 0
```

2. Run the following script to verify `net.ipv6.conf.default.accept_redirects = 0` is set in a file being used by systemd sysctl to configure `net.ipv6.conf.default.accept_redirects`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv6.conf.default.accept_redirects"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv6.conf.default.accept_redirects = 0" is set in: "/etc/sysctl.d/60-
ipv6_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv6.conf.default.accept_redirects` lines that are not `net.ipv6.conf.default.accept_redirects=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv6.conf.default.accept_redirects" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf` and edit or add the following line:

```
net.ipv6.conf.default.accept_redirects = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv6.conf.default.accept_redirects = 0" \
>> /etc/sysctl.d/60-ipv6_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv6.conf.default.accept_redirects = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040210 | RULE ID: SV-230535r1017297 | CAT II
5. STIG ID: OL08-00-040210 | RULE ID: SV-248876r991589 | CAT II
6. STIG ID: RHEL-09-254035 | RULE ID: SV-257976r991589 | CAT II
7. STIG ID: ALMA-09-018610 | RULE ID: SV-269244r1050126 | CAT II
8. STIG ID: OL09-00-006045 | RULE ID: SV-271882r1092358 | CAT II
9. STIG ID: SLES-15-040350 | RULE ID: SV-235021r991589 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.2.5 Ensure net.ipv6.conf.all.accept_source_route is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `accept_source_route` option causes network interfaces to accept packets with the Strict Source Route (SSR) or Loose Source Routing (LSR) option set.

`net.ipv6.conf.all.accept_source_route` controls accepting of all IPv6 packets with the SSR or LSR option set on all interfaces.

In networking, source routing allows a sender to partially or fully specify the route packets take through a network. In contrast, non-source routed packets travel a path determined by routers in the network. In some cases, systems may not be routable or reachable from some locations (e.g. private addresses vs. Internet routable), and so source routed packets would need to be used.

Note: If IPv6 has been disabled this recommendation is not applicable.

Rationale:

Setting `net.ipv6.conf.all.accept_source_route` to `0` disables the system from accepting source routed packets. Assume this system was capable of routing packets to Internet routable addresses on one interface and private addresses on another interface. Assume that the private addresses were not routable to the Internet routable addresses and vice versa. Under normal routing circumstances, an attacker from the Internet routable addresses could not use the system as a way to reach the private address systems. If, however, source routed packets were allowed, they could be used to gain access to the private address systems as the route could be specified, rather than rely on routing protocols that did not allow this routing.

Audit:

- IF IPv6 is enabled on the system -

Verify `net.ipv6.conf.all.accept_source_route` is set to `0`.

1. Run the following command to verify `net.ipv6.conf.all.accept_source_route` is set to `0` in the running configuration:

```
# sysctl net.ipv6.conf.all.accept_source_route
```

Verify output is:

```
net.ipv6.conf.all.accept_source_route = 0
```

2. Run the following script to verify `net.ipv6.conf.all.accept_source_route = 0` is set in a file being used by systemd sysctl to configure `net.ipv6.conf.all.accept_source_route`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv6.conf.all.accept_source_route"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv6.conf.all.accept_source_route = 0" is set in: "/etc/sysctl.d/60-
ipv6_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv6.conf.all.accept_source_route` lines that are not `net.ipv6.conf.all.accept_source_route=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv6.conf.all.accept_source_route" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf` and edit or add the following line:

```
net.ipv6.conf.all.accept_source_route = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv6.conf.all.accept_source_route = 0" \
>> /etc/sysctl.d/60-ipv6_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv6.conf.all.accept_source_route = 0

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040240 | RULE ID: SV-230538r1017300 | CAT II
5. STIG ID: OL08-00-040240 | RULE ID: SV-248880r991589 | CAT II
6. STIG ID: RHEL-09-254020 | RULE ID: SV-257973r991589 | CAT II
7. STIG ID: ALMA-09-020260 | RULE ID: SV-269259r1050141 | CAT II
8. STIG ID: OL09-00-006042 | RULE ID: SV-271879r1092349 | CAT II
9. STIG ID: SLES-15-040310 | RULE ID: SV-235015r991589 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.2.6 Ensure net.ipv6.conf.default.accept_source_route is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `accept_source_route` option causes network interfaces to accept packets with the Strict Source Route (SSR) or Loose Source Routing (LSR) option set.

`net.ipv6.conf.default.accept_source_route` controls accepting of all IPv6 packets with the SSR or LSR option set on newly added network interfaces.

In networking, source routing allows a sender to partially or fully specify the route packets take through a network. In contrast, non-source routed packets travel a path determined by routers in the network. In some cases, systems may not be routable or reachable from some locations (e.g. private addresses vs. Internet routable), and so source routed packets would need to be used.

Note: If IPv6 has been disabled this recommendation is not applicable.

Rationale:

Setting `net.ipv6.conf.default.accept_source_route` to `0` disables the system from accepting source routed packets. Assume this system was capable of routing packets to Internet routable addresses on one interface and private addresses on another interface. Assume that the private addresses were not routable to the Internet routable addresses and vice versa. Under normal routing circumstances, an attacker from the Internet routable addresses could not use the system as a way to reach the private address systems. If, however, source routed packets were allowed, they could be used to gain access to the private address systems as the route could be specified, rather than rely on routing protocols that did not allow this routing.

Audit:

- IF IPv6 is enabled on the system -

Verify `net.ipv6.conf.default.accept_source_route` is set to `0`.

1. Run the following command to verify `net.ipv6.conf.default.accept_source_route` is set to `0` in the running configuration:

```
# sysctl net.ipv6.conf.default.accept_source_route
```

Verify output is:

```
net.ipv6.conf.default.accept_source_route = 0
```

2. Run the following script to verify `net.ipv6.conf.default.accept_source_route = 0` is set in a file being used by systemd sysctl to configure `net.ipv6.conf.default.accept_source_route`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv6.conf.default.accept_source_route"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv6.conf.default.accept_source_route = 0" is set in:
"/etc/sysctl.d/60-ipv6_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv6.conf.default.accept_source_route` lines that are not `net.ipv6.conf.default.accept_source_route=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv6.conf.default.accept_source_route" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf` and edit or add the following line:

```
net.ipv6.conf.default.accept_source_route = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv6.conf.default.accept_source_route = 0" \
>> /etc/sysctl.d/60-ipv6_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv6.conf.default.accept_source_route = 0

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040250 | RULE ID: SV-230539r1017301 | CAT II
5. STIG ID: OL08-00-040250 | RULE ID: SV-248882r991589 | CAT II
6. STIG ID: RHEL-09-254040 | RULE ID: SV-257977r991589 | CAT II
7. STIG ID: ALMA-09-020260 | RULE ID: SV-269259r1050141 | CAT II
8. STIG ID: OL09-00-006046 | RULE ID: SV-271883r1092361 | CAT II
9. STIG ID: SLES-15-040321 | RULE ID: SV-235017r991589 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.2.7 Ensure net.ipv6.conf.all.accept_ra is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Routers periodically multicast Router Advertisement messages to announce their availability and convey information to neighboring nodes that enable them to be automatically configured on the network.

`net.ipv6.conf.all.accept_ra` controls accepting any IPv6 RA messages on any network device.

Note: If IPv6 has been disabled, this recommendation is not applicable.

Rationale:

It is recommended that systems do not accept router advertisements as they could be tricked into routing traffic to compromised machines. Setting hard routes within the system (usually a single default route to a trusted router) protects the system from bad routes.

Audit:

- IF IPv6 is enabled on the system -

Verify `net.ipv6.conf.all.accept_ra` is set to `0`.

1. Run the following command to verify `net.ipv6.conf.all.accept_ra` is set to `0` in the running configuration:

```
# sysctl net.ipv6.conf.all.accept_ra
```

Verify output is:

```
net.ipv6.conf.all.accept_ra = 0
```

2. Run the following script to verify `net.ipv6.conf.all.accept_ra = 0` is set in a file being used by systemd sysctl to configure `net.ipv6.conf.all.accept_ra`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv6.conf.all.accept_ra"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv6.conf.all.accept_ra = 0" is set in: "/etc/sysctl.d/60-
ipv6_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv6.conf.all.accept_ra` lines that are not `net.ipv6.conf.all.accept_ra=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv6.conf.all.accept_ra" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf` and edit or add the following line:

```
net.ipv6.conf.all.accept_ra = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv6.conf.all.accept_ra = 0" >> /etc/sysctl.d/60-
ipv6_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv6.conf.all.accept_ra = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040261 | RULE ID: SV-230541r1017303 | CAT II
5. STIG ID: OL08-00-040261 | RULE ID: SV-248884r991589 | CAT II
6. STIG ID: RHEL-09-254010 | RULE ID: SV-257971r991589 | CAT II
7. STIG ID: ALMA-09-018500 | RULE ID: SV-269243r1050125 | CAT II
8. STIG ID: OL09-00-006040 | RULE ID: SV-271877r1092343 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

3.3.2.8 Ensure net.ipv6.conf.default.accept_ra is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Routers periodically Multicast Router Advertisement (RA) messages to announce their availability and convey information to neighboring nodes that enable them to be automatically configured on the network.

`net.ipv6.conf.default.accept_ra` controls accepting IPv6 RA messages on newly added network devices.

Note: If IPv6 has been disabled, this recommendation is not applicable.

Rationale:

It is recommended that systems do not accept router advertisements as they could be tricked into routing traffic to compromised machines. Setting hard routes within the system (usually a single default route to a trusted router) protects the system from bad routes.

Audit:

- IF IPv6 is enabled on the system -

Verify `net.ipv6.conf.default.accept_ra` is set to `0`.

1. Run the following command to verify `net.ipv6.conf.default.accept_ra` is set to `0` in the running configuration:

```
# sysctl net.ipv6.conf.default.accept_ra
```

Verify output is:

```
net.ipv6.conf.default.accept_ra = 0
```

2. Run the following script to verify `net.ipv6.conf.default.accept_ra = 0` is set in a file being used by systemd sysctl to configure `net.ipv6.conf.default.accept_ra`:

```
#!/usr/bin/env bash

{
   l_parameter_name="net.ipv6.conf.default.accept_ra"
   l_grep="${l_parameter_name//./(\\.|\\/)}" a_output=() a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      l_opt="$(grep -Poi '^\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" | tail -n
1)"
      l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_parameter_name = $l_option_value\" is set in:" \
      "    \"$l_file\"")
   done
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Example output:

```
 - "net.ipv6.conf.default.accept_ra = 0" is set in: "/etc/sysctl.d/60-
ipv6_sysctl.conf"
```

Note:

- This script looks at all files used by systemd sysctl.
- More information about these files and their location is available in the section overview.
- If multiple lines are returned:
    - The first line includes the value being used by `systemd sysctl`. If this is a correct value, this is considered a passing state. If the file listed is not in the `/etc/sysctl.d/` directory, it is highly recommended to follow the remediation procedure to create a `.conf` file in the `/etc/sysctl.d/` directory with the correct setting to prevent a potential change due to an update to the system.
    - Any files in the `/etc/sysctl.d/` directory that include an incorrect value should be modified to comment out or change the incorrect value to minimize the potential of the incorrect value being used by `systemd sysctl` due to system configuration changes.
- **SYSTEM FILE PRECEDENCE**
    - When using the `--system` option, `sysctl` will read files from directories in the following list in given order from top to bottom. Once a file of a given filename is loaded, any file of the same name in subsequent directories is ignored.
    - `/etc/sysctl.d/*.conf /run/sysctl.d/*.conf /usr/local/lib/sysctl.d/*.conf /usr/lib/sysctl.d/*.conf /lib/sysctl.d/*.conf /etc/sysctl.conf`
    - All configuration files are sorted in lexicographic order, regardless of the directory they reside in. Configuration files can either be completely replaced (by having a new configuration file with the same name in a directory of higher priority) or partially replaced (by having a configuration file that is ordered later)--

Remediation:

1. Review all files being used by systemd sysctl and comment out or remove all `net.ipv6.conf.default.accept_ra` lines that are not `net.ipv6.conf.default.accept_ra=0`.

Example script:

```
#!/usr/bin/env bash

{
   l_option="net.ipv6.conf.default.accept_ra" l_value="0"
   l_grep="${l_option//./(\\.|\\/)}" a_files=()
   l_systemdsysctl="$(readlink -e /lib/systemd/systemd-sysctl \
   || readlink -e /usr/lib/systemd/systemd-sysctl)"
   l_ufw_file="$([ -f /etc/default/ufw ] && \
   awk -F= '/^\s*IPT_SYSCTL=/ {print $2}' /etc/default/ufw)"
   [ -f "$(readlink -e "$l_ufw_file")" ] && \
   a_files+=("$l_ufw_file"); a_files+=("/etc/sysctl.conf")
   while IFS= read -r l_fname; do
      l_file="$(readlink -e "${l_fname//# /}")"
      [ -n "$l_file" ] && ! grep -Psiq -- '(^|\h+)'"$l_file"'\b' \
      <<< "${a_files[*]}" && a_files+=("$l_file")
   done < <("$l_systemdsysctl" --cat-config | tac | \
   grep -Pio -- '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   for l_file in "${a_files[@]}"; do
      grep -Poi -- '\h*'"$l_grep"'\h*=\h*\H+\b' "$l_file" \
      | grep -Pivq -- '^\h*'"$l_grep"'\h*=\h*'"$l_value"'\b' && \
      sed -ri '/^\s*'"$l_grep"'\s*=\s*(1[0-9]*)/s/^/# /' "$l_file"
   done
}
```

2. Create or edit a file in the `/etc/sysctl.d/` directory ending in `.conf` and edit or add the following line:

```
net.ipv6.conf.default.accept_ra = 0
```

Example:

```
# [ ! -d "/etc/sysctl.d/" ] && mkdir -p /etc/sysctl.d/
# printf '%s\n' "" "net.ipv6.conf.default.accept_ra = 0" >> /etc/sysctl.d/60-
ipv6_sysctl.conf
```

Note: If the UFW file was the first file listed in the audit, the entry will be commented out as part of the first step, however updating Uncomplicated Firewall (UFW) may update this change. In this case the updated entry will supersede the entry being created as part of this step.

3. Run the following command to load all sysctl configuration filles:

```
# sysctl --system
```

Default Value:

net.ipv6.conf.default.accept_ra = 1

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-040262 | RULE ID: SV-230542r1017304 | CAT II
5. STIG ID: OL08-00-040262 | RULE ID: SV-248885r991589 | CAT II
6. STIG ID: RHEL-09-254030 | RULE ID: SV-257975r991589 | CAT II
7. STIG ID: ALMA-09-018500 | RULE ID: SV-269243r1050125 | CAT II
8. STIG ID: OL09-00-006044 | RULE ID: SV-271881r1092355 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

4 Host Based Firewall

A Host Based Firewall, on a Linux system, is a set of rules. When a data packet moves into or out of a protected network space, its contents (in particular, information about its origin, target, and the protocol it plans to use) are tested against the firewall rules to see if it should be allowed through

To provide a Host Based Firewall, the Linux kernel includes support for NFTables.

NFTables is subsystem of the Linux kernel providing filtering and classification of network packets/datagrams/frames. NFTables replaces parts of Netfilter, while keeping and reusing most of it. NFTables utilizes the building blocks of the Netfilter infrastructure, such as the existing hooks into the networking stack, connection tracking system, userspace queueing component, and logging subsystem.

In order to configure firewall rules for NFTables, a firewall utility needs to be installed. Guidance has been included for firewalld which provides firewall features by acting as a front-end for the Linux kernel's netfilter framework via the NFTables backend. firewalld acts as a front-end for the Linux kernel's netfilter framework via the NFTables userspace utility, acting as an alternative to the `nft` command line program. firewalld supports both IPv4 and IPv6 networks and can administer separate firewall zones with varying degrees of trust as defined in zone profiles.

This Benchmark includes guidance for configuring NFTables though the firewalld front end utility. If your organization is using a different Host Based Firewall, or a different utility to configure the Host Based Firewall, we recommend verifying that your site's configuration meets the Recommendations in this section, otherwise this section may be skipped.

Note:

- Only **one** method should be used to configure a firewall on the system. Use of more than one method could produce unexpected results.
- NFTables is the default packet filtering framework. Though IPTables is still supported, this support is done indirectly through firewalld's ability to translate IPTables commands to NFTables.
- This section is intended only to ensure the resulting firewall rules are in place.
- The `ipset` and `iptables-nft` packages are deprecated. This includes deprecation of nft-variants such as `iptables`, `ip6tables`, `arptables`, and `ebtables` utilities. If you are using any of these tools, for example, because you upgraded from an earlier version, we recommend migrating to using the NFTables package for backend services.

4.1 Configure firewalld

In order to configure firewall rules for Netfilter or nftables, a firewall utility needs to be installed. firewalld is the recommended utility and is the only guidance provided in this recommendation.

`firewalld` uses the concepts of zones and services, that simplify the traffic management. Zones are predefined sets of rules that cover all necessary settings to allow or deny incoming traffic for a specific service and zone. It provides these features by acting as a front-end for the Linux kernel's netfilter framework via the nftables userspace utility, acting as an alternative to the nft command line program. firewalld supports both IPv4 and IPv6 networks and can administer separate firewall zones with varying degrees of trust as defined in zone profiles.

Important: Configuration of a live systems firewall directly over a remote connection will often result in being locked out. It is advised to have a known good firewall configuration set to run on boot and to configure an entire firewall structure in a script that is then run and tested before saving to boot.

The following example will create a `firewalld` zone called `securezone` to implement the firewall rules of this section leveraging the firewalld utility included with the firewalld package. This example will open port 22(ssh) from anywhere. Opening service `SSH` should be updated in accordance with local site policy. If another name for the zone is preferred, replace `securezone` with the name to be used.

Sample securezone zone xml file

```
<?xml version="1.0" encoding="utf-8"?>
<zone target="DROP">
  <description>For use with CIS Linux Benchmark. You do not trust the other
computers on networks to not harm your computer. Only selected incoming
connections are accepted.</description>
  <service name="ssh"/>
  <service name="dhcpv6-client"/>
  <icmp-block name="destination-unreachable"/>
  <icmp-block name="packet-too-big"/>
  <icmp-block name="time-exceeded"/>
  <icmp-block name="parameter-problem"/>
  <icmp-block name="neighbour-advertisement"/>
  <icmp-block name="neighbour-solicitation"/>
  <icmp-block name="router-advertisement"/>
  <icmp-block name="router-solicitation"/>
  <rule family="ipv4">
    <source address="127.0.0.1"/>
    <destination address="127.0.0.1" invert="True"/>
    <drop/>
  </rule>
  <rule family="ipv6">
    <source address="::1"/>
    <destination address="::1" invert="True"/>
    <drop/>
  </rule>
  <icmp-block-inversion/>
</zone>
```

Note: To use this zone, save this as `/etc/firewalld/zones/securezone.xml` and run the following commands:

```
# firewall-cmd --reload
# firewall-cmd --permanent --zone=securezone --change-interface={NAME OF
NETWORK INTERFACE}
```

Warning: Only one method should be used to configure a firewall on the system. Use of more than one method could produce unexpected results.

4.1.1 Ensure firewalld is installed (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`firewalld` is a high-level firewall rules management frontend utility. It does not directly handle packet filtering itself but relies on the `nftables` subsystem within the Linux kernel.

Rationale:

`firewalld` is a dynamic, user friendly, firewall manager that can protect against threats originating from within a corporate network to include malicious mobile code and poorly configured software on a host.

Impact:

Changing firewall settings while connected over the network can result in being locked out of the system.

Audit:

Run the following command to verify that `firewalld` is installed:

```
# rpm -q firewalld

firewalld-<version>
```

Remediation:

Run the following command to install `firewalld`

```
# dnf install firewalld
```

References:

1. NIST SP 800-53 Rev. 5: CA-9

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v7	9.4 Apply Host-based Firewalls or Port Filtering Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●

4.1.2 Ensure firewalld backend is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `FirewallBackend` option selects the firewall backend implementation.

Choices are:

- nftables (default)
- iptables (iptables, ip6tables, ebtables and ipset)

Rationale:

IPTables are deprecated.

Impact:

Verifying the proper backend configuration insures the critical functionality of the firewall.

Audit:

Run the following command to verify `NFTables` is set as the backend for `firewalld`:

```
# grep -Psi -- 'FirewallBackend\h*=\h*nftables\b'
/etc/firewalld/firewalld.conf

FirewallBackend=nftables
```

Remediation:

Edit the file `/etc/firewalld/firewalld.conf` and add or modify the following line:

```
FirewallBackend=nftables
```

Default Value:

FirewallBackend=nftables

References:

1. GRID #
2. NIST SP 800-53 Rev. 5: CA-9

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v7	9.4 Apply Host-based Firewalls or Port Filtering Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●

4.1.3 Ensure firewalld.service is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`firewalld.service` is a firewall service daemon that provides a dynamic, customizable firewall with a D-Bus interface.

Rationale:

`firewalld.service` must be active to enforce rules configured through FirewallD. `firewalld.service` must be enabled to start automatically after a system reboot.

Audit:

Run the following command to verify `firewalld.service` is enabled:

```
# systemctl is-enabled firewalld.service

enabled
```

Run the following command to verify `firewalld.service` is active:

```
# systemctl is-active firewalld.service
```

Remediation:

Run the following commands to unmask, enable, and start `firewalld.service`:

```
# systemctl unmask firewalld.service
# systemctl --now enable firewalld.service
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v7	9.4 Apply Host-based Firewalls or Port Filtering Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●

4.1.4 Ensure firewalld active zone target is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

FirewallD zones are a network or firewall zone that defines the trust level of the interface used for a connection. There are several pre-defined zones provided by firewalld.

A zone target may be set to `ACCEPT`, `%%REJECT%%`, or `DROP`. This can be used to accept, reject, or drop every packet that doesn't match any rule (port, service, etc). The `ACCEPT` target is used in the `trusted` zone to accept every packet not matching any rule, e.g. accept all. The `%%REJECT%%` target is used in the `block` zone to reject, with default firewall reject type, every packet not matching any rule. The `DROP` target is used in the `drop` zone to drop every packet not matching any rule. If the target is not specified, every packet not matching and rule will be rejected.

Note: The target may also be set to `default`. The `default` target provides a convenient way to implement a "deny by default, allow by exception" policy within a firewalld zone, while still allowing essential ICMP traffic.

Rationale:

With a default accept policy the firewall will accept any packet that is not configured to be denied. It is easier to allow list acceptable usage than to deny list unacceptable usage.

Audit:

Run the following command to verify the active zone `target` is not set to `ACCEPT`:

Run the following script to verify:

- active zone `target` for interfaces that are not loopback or virtual is not set to `ACCEPT`.
- an active zone is configured.
- active zone target is written as a permanent firewall rule.

```
{
   a_output=() a_output2=()
   while IFS= read -r l_zone; do
      l_zone="$(awk -F'(' '{print $1}' <<< "${l_zone// /}")"
      l_interfaces="$(firewall-cmd --zone="$l_zone" --list-interfaces)"
      if ! grep -Psq -- '^(lo|virbr[^\h]+)\h*$' <<< "${l_interfaces/ /}";
then
         l_ptarget="$(firewall-cmd --permanent --zone="$l_zone" --get-
target)"
         l_target="$(cut -d: -f2 <<< "$(grep -Pso -- '^\h*target:\h+\H+\b' \
         <<< "$(firewall-cmd --list-all --zone="$l_zone")")" | xargs)"
         if [ -z "$l_target" ] || [ "${l_target,,}" = "accept" ]; then
            a_output2+=(" - Active zone: \"$l_zone\"" \
            "    Target is: \"$l_target\" for interfaces: \"$l_interfaces\"")
         elif [ ! "${l_target,,}" = "${l_ptarget,,}" ]; then
            a_output2+=(" - Active zone: \"$l_zone\"" \
            "   Target is: \"$l_target\" is not a permanent firewall rule")
         else
            a_output+=(" - Active zone: \"$l_zone\"" \
            "    Target is: \"$l_target\""
            "    for interfaces: \"$l_interfaces\"")
         fi
      fi
   done < <(firewall-cmd --get-active-zones | awk '$1!~/interface/{print}')
   printf '%s\n' "" "${a_output2[@]}" "" "${a_output[@]}" ""
}
```

Review the script output. Verify output does not include:

- No output.
- A zone with a target set to `ACCEPT`.
- A zone that has a target that is not a permanent firewall rule.

Remediation:

Run the following command to update an active zone target and write a permanent firewalld rule:

```
# firewall-cmd --zone={ACTIVE_ZONE} --set-target={TARGET} --permanent
```

Example:

```
# firewall-cmd --zone=public --set-target=DROP --permanent
```

Note: `--set-target=default` is also acceptable.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●
v7	9.4 Apply Host-based Firewalls or Port Filtering Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●

4.1.5 Ensure firewalld loopback traffic is configured (Manual)

Profile Applicability:

- Level 1 - Server

Description:

Every device with networking capabilities has a loopback interface.

Loopback traffic refers to network communication where a device sends data to itself, essentially routing the traffic back to its own network interface.

Rationale:

Loopback traffic is generated between processes on machine and is typically critical to operation of the system. The loopback interface is the only place that loopback network traffic should be seen, all other interfaces should ignore traffic on this network as an anti-spoofing measure.

Audit:

Verify the loopback interface accepts all incoming traffic.

1. Run the following command to verify the currently configured zone for the loopback interface:

```
# firewall-cmd --get-zone-of-interface=lo
```

Example output:

```
trusted
```

Verify the output is not `no zone`. If the output is `no zone` the second audit is also automatically considered to be failed.

2. Run the following command to verify the configured zone for the loopback interface `target` is set to `ACCEPT`:

```
# firewall-cmd --list-all --zone="$(firewall-cmd --get-zone-of-interface=lo |
xargs)" | \
grep -Psi -- '^\h*target:\h+\H+'
```

Verify output is:

```
  target: ACCEPT
```

Remediation:

1. Run one of the following commands to add the `lo` interface to the trusted zone.

If the `lo` interface is not currently assigned to a zone:

```
# firewall-cmd --permanent --zone=trusted --add-interface=lo
```

- OR - if the `lo` interface is currently assigned to a zone:

```
# firewall-cmd --zone=public --change-interface=lo
```

2. Run the following command to reload firewalld:

```
# firewall-cmd --reload
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●
v7	9.4 Apply Host-based Firewalls or Port Filtering Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●

4.1.6 Ensure firewalld loopback source address traffic is configured (Manual)

Profile Applicability:

- Level 1 - Server

Description:

Every device with networking capabilities has a loopback interface.

Loopback traffic refers to network communication where a device sends data to itself, essentially routing the traffic back to its own network interface.

Outbound traffic is data sent from a device to another device or network.

Rationale:

The loopback interface is the only place that loopback network traffic should be seen, all other interfaces should ignore traffic on this network as an anti-spoofing measure.

Audit:

Run the following script to verify active zones include dropping traffic with a loopback address as the source address and not also the destination address:

```
#!/usr/bin/env bash

{
   while IFS= read -r l_zone; do
      echo " - Zone: $l_zone"
      firewall-cmd --zone=$l_zone --list-rich-rules | \
      grep -P -- '(::1|127\.0\.0\.1)\b'
   done < <(firewall-cmd --get-zone-of-interface=lo | xargs)
}
```

Verify the output includes:

- A zone.
- The rule: `rule family="ipv4" source address="127.0.0.1" destination NOT address="127.0.0.1" drop`
- The rule: `rule family="ipv6" source address="::1" destination NOT address="::1" drop`

Example output:

```
 - Zone: trusted
rule family="ipv4" source address="127.0.0.1" destination NOT
address="127.0.0.1" drop
rule family="ipv6" source address="::1" destination NOT address="::1" drop
```

Remediation:

Add the appropriate rich rules by running the following commands:

```
# firewall-cmd --permanent --zone={ZONE_NAME} --add-rich-rule='rule
family=ipv4 source address="127.0.0.1" destination not address="127.0.0.1"
drop'

# firewall-cmd --permanent --zone={ZONE_NAME} --add-rich-rule='rule
family=ipv6 source address="::1" destination not address="::1" drop'
```

Example script:

```
#!/usr/bin/env bash

{
   while IFS= read -r l_zone; do
      firewall-cmd --permanent --zone="$l_zone" --add-rich-rule='rule
family=ipv4 source address="127.0.0.1" destination not address="127.0.0.1"
drop'
      firewall-cmd --permanent --zone="$l_zone" --add-rich-rule='rule
family=ipv6 source address="::1" destination not address="::1" drop'
   done < <(firewall-cmd --get-zone-of-interface=lo | xargs)
}
```

Run the following command to load the updated firewalld rules:

```
# firewall-cmd --reload
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●
v7	9.4 Apply Host-based Firewalls or Port Filtering Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●

4.1.7 Ensure firewalld services and ports are configured (Manual)

Profile Applicability:

- Level 1 - Server

Description:

Services and ports can be accepted, explicitly rejected, or dropped by a zone.

For every zone, you can set a default behavior that handles incoming traffic that is not further specified. Such behavior is defined by setting the target of the zone. There are three options - `ACCEPT`, `REJECT`, and `DROP`.

- `ACCEPT` - you accept all incoming packets except those disabled by a specific rule.
- `REJECT` - you disable all incoming packets except those that you have allowed in specific rules and the source machine is informed about the rejection.
- `DROP` - you disable all incoming packets except those that you have allowed in specific rules and no information sent to the source machine.

Note: The target may also be set to a fourth option, `default`. The `default` target provides a convenient way to implement a "deny by default, allow by exception" policy within a firewalld zone, while still allowing essential ICMP traffic.

Rationale:

To reduce the attack surface of a system, all services and ports should be blocked unless required

Audit:

Run the following command and review output to ensure that listed services and ports follow site policy:

```
# firewall-cmd --list-all --zone="$(firewall-cmd --list-all | awk
'/\(active\)/ { print $1 }')" | grep -P -- '^\h*(services:|ports:)'
```

Note: The command `firewall-cmd --get-services | tr ' ' '\n' | column` can be used to produce a list of services firewalld can be configured to address as services.

Remediation:

Run the following command to remove an unnecessary service:

```
# firewall-cmd --remove-service=<service>
```

Example:

```
# firewall-cmd --remove-service=cockpit
```

Run the following command to remove an unnecessary port:

```
# firewall-cmd --remove-port=<port-number>/<port-type>
```

Example:

```
# firewall-cmd --remove-port=25/tcp
```

Run the following command to make new settings persistent:

```
# firewall-cmd --runtime-to-permanent
```

References:

1. https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/9/html-single/configuring_firewalls_and_packet_filters/index

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.4 Implement and Manage a Firewall on Servers Implement and manage a firewall on servers, where supported. Example implementations include a virtual firewall, operating system firewall, or a third-party firewall agent.	●	●	●
v8	4.5 Implement and Manage a Firewall on End-User Devices Implement and manage a host-based firewall or port-filtering tool on end-user devices, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●
v7	9.4 Apply Host-based Firewalls or Port Filtering Apply host-based firewalls or port filtering tools on end systems, with a default-deny rule that drops all traffic except those services and ports that are explicitly allowed.	●	●	●

5 Access Control

5.1 Configure SSH Server

Secure Shell (SSH) is a secure, encrypted replacement for common login services such as `telnet`, `ftp`, `rlogin`, `rsh`, and `rcp`. It is strongly recommended that sites abandon older clear-text login protocols and use SSH to prevent session hijacking and sniffing of sensitive data off the network.

The recommendations in this section only apply if the SSH daemon is installed on the system, **if remote access is not required the SSH daemon can be removed and this section skipped**.

`sshd_config`:

- The openSSH daemon configuration directives, `Include` and `Match`, may cause the audits in this section's recommendations to report incorrectly. It is recommended that these options only be used if they're needed and fully understood. If these options are configured in accordance with local site policy, they should be accounted for when following the recommendations in this section.
- The audits of the running configuration in this section are run in the context of the root user, the local host name, and the local host's IP address. If a `Match` block exists that matches one of these criteria, the output of the audit will be from the match block. The respective matched criteria should be replaced with a non-matching substitution.
- `Include`:
    - Include the specified configuration file(s).
    - Multiple pathnames may be specified and each pathname may contain glob(7) wildcards that will be expanded and processed in lexical order.
    - Files without absolute paths are assumed to be in `/etc/ssh/`.
    - An Include directive may appear inside a Match block to perform conditional inclusion.

- `Match`:
  - Introduces a conditional block. If all of the criteria on the Match line are satisfied, the keywords on the following lines override those set in the global section of the config file, until either another Match line or the end of the file. If a keyword appears in multiple Match blocks that are satisfied, only the first instance of the keyword is applied.
  - The arguments to Match are one or more criteria-pattern pairs or the single token All which matches all criteria. The available criteria are User, Group, Host, LocalAddress, LocalPort, and Address.
  - The match patterns may consist of single entries or comma-separated lists and may use the wildcard and negation operators described in the PATTERNS section of ssh_config(5).
  - The patterns in an Address criteria may additionally contain addresses to match in CIDR address/masklen format, such as `192.0.2.0/24` or `2001:db8::/32`. Note that the mask length provided must be consistent with the address - it is an error to specify a mask length that is too long for the address or one with bits set in this host portion of the address. For example, `192.0.2.0/33` and `192.0.2.0/8`, respectively.
  - Only a subset of keywords may be used on the lines following a Match keyword. Available keywords are available in the ssh_config man page.
- Once all configuration changes have been made to `/etc/ssh/sshd_config` or any included configuration files, the `sshd` configuration must be reloaded

Command to re-load the SSH daemon configuration:

```
# systemctl reload-or-restart sshd
```

`sshd` command:

- `-T` - Extended test mode. Check the validity of the configuration file, output the effective configuration to stdout and then exit. Optionally, Match rules may be applied by specifying the connection parameters using one or more -C options. The configuration does not contain the system-wide crypto-policy configuration. To show the most accurate runtime configuration, use:

```
source /etc/crypto-policies/back-ends/opensshserver.config
source /etc/sysconfig/sshd
sshd -T $OPTIONS $CRYPTO_POLICY
```

- `-C` - connection_spec. Specify the connection parameters to use for the -T extended test mode. If provided, any Match directives in the configuration file that would apply are applied before the configuration is written to standard output. The connection parameters are supplied as keyword=value pairs and may be supplied in any order, either with multiple `-C` options or as a comma-separated list. The keywords are `addr`, `user`, `host`, `laddr`, `lport`, and `rdomain` and correspond to source address, user, resolved source host name, local address, local port number and routing domain respectively.

5.1.1 Ensure sshd crypto_policy is not set (Automated)

Profile Applicability:

- Level 1 - Server

Description:

System-wide Crypto policy can be over-ridden or opted out of for openSSH

Rationale:

Over-riding or opting out of the system-wide crypto policy could allow for the use of less secure Ciphers, MACs, KexAlgorithms and GSSAPIKexAlgorithm

Note: If changes to the system-wide crypto policy are required to meet local site policy for the openSSH server, these changes should be done with a `sub-policy` assigned to the system-wide crypto policy. For additional information see the CRYPTO-POLICIES(7) man page

Audit:

Run the following command:

```
# grep -Psi '^\h*CRYPTO_POLICY\h*=' /etc/sysconfig/sshd
```

No output should be returned

Run the following command to verify that the `CRYPTO_POLICY=` line exists in `/etc/sysconfig/sshd` and that this line is commented out.

```
# grep -Psi '^\h*#\h*CRYPTO_POLICY\h*=' /etc/sysconfig/sshd

# CRYPTO_POLICY=
```

Remediation:

Run the following commands:

```
# sed -ri '/^\s*CRYPTO_POLICY\s*=/Is/^/# /' /etc/sysconfig/sshd

# systemctl reload sshd
```

References:

1. SSHD(8)
2. NIST SP 800-53 :: AC-17 (2)
3. NIST SP 800-53A :: AC-17 (2).1
4. RULE ID: SV-244526r1017332 | STIG ID: RHEL-08-010287 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

5.1.2 Ensure access to /etc/ssh/sshd_config is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The file `/etc/ssh/sshd_config`, and files ending in `.conf` in the `/etc/ssh/sshd_config.d` directory, contain configuration specifications for `sshd`.

Rationale:

Configuration specifications for `sshd` need to be protected from unauthorized changes by non-privileged users.

Audit:

Run the following script and verify `/etc/ssh/sshd_config` and files ending in `.conf` in the `/etc/ssh/sshd_config.d` directory are:

- Mode `0600` or more restrictive
- Owned by the `root` user
- Group owned by the group `root`.

```
#!/usr/bin/env bash

{
   a_output=(); a_output2=()
   perm_mask='0177' && maxperm="$( printf '%o' $(( 0777 & ~$perm_mask)) )"
   f_sshd_files_chk()
   {
      while IFS=: read -r l_mode l_user l_group; do
         a_out2=()
         [ $(( $l_mode & $perm_mask )) -gt 0 ] && a_out2+=("    Is mode:
\"$l_mode\"" \
         "    should be mode: \"$maxperm\" or more restrictive")
         [ "$l_user" != "root" ] && a_out2+=("    Is owned by \"$l_user\"
should be owned by \"root\"")
         [ "$l_group" != "root" ] && a_out2+=("    Is group owned by
\"$l_user\" should be group owned by \"root\"")
         if [ "${#a_out2[@]}" -gt "0" ]; then
            a_output2+=("  - File: \"$l_file\":" "${a_out2[@]}")
         else
            a_output+=("  - File: \"$l_file\":" "    Correct: mode ($l_mode),
owner ($l_user)" \
            "    and group owner ($l_group) configured")
         fi
      done < <(stat -Lc '%#a:%U:%G' "$l_file")
   }
   [ -e "/etc/ssh/sshd_config" ] && l_file="/etc/ssh/sshd_config" &&
f_sshd_files_chk
   while IFS= read -r -d $'\0' l_file; do
      [ -e "$l_file" ] && f_sshd_files_chk
   done < <(find /etc/ssh/sshd_config.d -type f -name '*.conf' \( -perm /077
-o ! -user root -o ! -group root \) -print0 2>/dev/null)
   if [ "${#a_output2[@]}" -le 0 ]; then
      printf '%s\n' "" "- Audit Result:" "  ** PASS **" "${a_output[@]}" ""
   else
      printf '%s\n' "" "- Audit Result:" "  ** FAIL **" " - Reason(s) for
audit failure:" "${a_output2[@]}"
      [ "${#a_output[@]}" -gt 0 ] && printf '%s\n' "" "- Correctly set:"
"${a_output[@]}" ""
   fi
}
```

- IF - other locations are listed in an `Include` statement, `*.conf` files in these locations should also be checked.

Remediation:

Run the following script to set ownership and permissions on `/etc/ssh/sshd_config` and files ending in `.conf` in the `/etc/ssh/sshd_config.d` directory:

```
#!/usr/bin/env bash

{
   chmod u-x,og-rwx /etc/ssh/sshd_config
   chown root:root /etc/ssh/sshd_config
   while IFS= read -r -d $'\0' l_file; do
      if [ -e "$l_file" ]; then
         chmod u-x,og-rwx "$l_file"
         chown root:root "$l_file"
      fi
   done < <(find /etc/ssh/sshd_config.d -type f -print0 2>/dev/null)
}
```

- IF - other locations are listed in an `Include` statement, `*.conf` files in these locations access should also be modified.

Default Value:

Access: (0600/-rw-------) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3. MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.1.3 Ensure access to /etc/sysconfig/sshd is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The file `/etc/sysconfig/sshd` contains configuration specifications for the `sshd` service.

Rationale:

Configuration specifications for the `sshd` service need to be protected from unauthorized changes by non-privileged users.

Audit:

Run the following command to verify `/etc/sysconfig/sshd` is mode `0640` or more restrictive, `Uid` is `0/root` and `Gid` is `0/root`:

```
# stat -Lc 'Access: (%#a/%A)  Uid: ( %u/ %U) Gid: ( %g/ %G)'
/etc/sysconfig/sshd

Access: (0640/-rw-r-----)  Uid: ( 0/ root) Gid: ( 0/ root)
```

Remediation:

Run the following commands to remove excess permissions, set owner, and set group on `/etc/sysconfig/sshd`:

```
# chmod u-x,g-we,o-rwx /etc/sysconfig/sshd
# chown root:root /etc/sysconfig/sshd
```

Default Value:

Access: (0640/-rw-r-----) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3. MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.1.4 Ensure access to SSH private host key files is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

An SSH private key is one of two files used in SSH public key authentication. In this authentication method, the possession of the private key is proof of identity. Only a private key that corresponds to a public key will be able to authenticate successfully. The private keys need to be stored and handled carefully, and no copies of the private key should be distributed.

Rationale:

If an unauthorized user obtains the private SSH host key file, the host could be impersonated.

Audit:

Run the following script to verify SSH private host key files are owned by the root user and either:

- group owned by the group `ssh_keys` and mode `0640` or more restrictive

- OR -

- group owned by the group `root` and mode `0600` or more restrictive

```
#!/usr/bin/env bash

{
   a_output=() a_output2=() l_ssh_group="" l_out="root"
   grep -Psiq -- '^\h*ID_LIKE=\"?([^#\n\r]+)?\bfedora\b' /etc/os-release && \
   l_ssh_group="$(grep -Pso -- '^ssh_keys\b' /etc/group)" && \
   l_out="$l_ssh_group or $l_out"
   f_file_chk()
   {
      while IFS=: read -r l_fmode l_fowner l_fgroup; do
         a_out2=()
         [ "$l_fgroup" = "$l_ssh_group" ] && l_pmask="0137" || l_pmask="0177"
         l_maxperm="$( printf '%o' $(( 0777 & ~$l_pmask )) )"
         if [ $(( $l_fmode & $l_pmask )) -gt 0 ]; then
            a_out2+=("    - mode: \"$l_fmode\"" \
            "      should be mode: \"$l_maxperm\" or more restrictive")
         fi
         if [ "$l_fowner" != "root" ]; then
            a_out2+=("    - owned by: \"$l_fowner\"" \
            "      should be owned by \"root\"")
         fi
         if [ "$l_fgroup" != "$l_ssh_group" ] && [ "$l_fgroup" != "root" ];
then
            a_out2+=("    - group owned by: \"$l_fgroup\"" \
            "      should be group owned by: \"$l_out\"")
         fi
         if [ "${#a_out2[@]}" -gt "0" ]; then
            a_output2+=("  - File: \"$l_file\"" "${a_out2[@]}")
         else
            a_output+=("  - File: \"$l_file\" Correct:" \
            "    - mode: \"$l_fmode\"" \
            "    - owner: \"$l_fowner\"" "    - group owner: \"$l_fgroup\"")
         fi
      done < <(stat -Lc '%#a:%U:%G' "$l_file")
   }
   while IFS= read -r -d $'\0' l_file; do
      if ssh-keygen -lf &>/dev/null "$l_file"; then
         file "$l_file" | \
         grep -Piq -- '\bopenssh\h+([^#\n\r]+\h+)?private\h+key\b' &&
f_file_chk
      fi
   done < <(find -L /etc/ssh -xdev -type f -print0 2>/dev/null)
   if [ "${#a_output2[@]}" -le 0 ]; then
      printf '%s\n' "" "- Audit Result:" "  ** PASS **" "${a_output[@]}" ""
   else
      printf '%s\n' "" "- Audit Result:" "  ** FAIL **" \
      " - Reason(s) for audit failure:" "${a_output2[@]}"
      [ "${#a_output[@]}" -gt 0 ] && \
      printf '%s\n' "" "- Correctly set:" "${a_output[@]}" ""
   fi
}
```

Remediation:

Run the following script to set mode, ownership, and group on the private SSH host key files:

```
#!/usr/bin/env bash

{
   a_output2=() l_ssh_group="" l_out="root" l_new_group="root"
   if grep -Psiq -- '^\h*ID_LIKE=\"?([^#\n\r]+)?\bfedora\b' /etc/os-release
&& \
   grep -Psoq -- '^ssh_keys\b' /etc/group; then
      l_ssh_group="ssh_keys" l_out="$l_ssh_group or root"
      l_new_group="$l_ssh_group"
   fi
   f_file_access_fix()
   {
      while IFS=: read -r l_file_mode l_file_owner l_file_group; do
         a_out2=()
         if [ "$l_file_owner" != "root" ]; then
            a_out2+=("" "    Owned by: \"$l_file_owner\"" \
            "    should be owned by \"root\"" \
            "    Changing ownership to \"root\"")
            chown root "$l_file"
         fi
         if [ "$l_file_group" != "$l_ssh_group" ] && \
         [ "$l_file_group" != "root" ]; then
            a_out2+=("" "    Owned by group \"$l_file_group\"" \
            "    should be group owned by: \"$l_out\"" \
            "    Changing group ownership to \"$l_new_group\"")
            chgrp "$l_new_group" "$l_file"
         fi
         if [ "$(stat -Lc '%G' "$l_file")" = "$l_ssh_group" ]; then
            l_pmask="0137" l_change="u-x,g-wx,o-rwx"
         else
            l_pmask="0177" l_change="u-x,go-rwx"
         fi
         l_maxperm="$( printf '%o' $(( 0777 & ~$l_pmask )) )"
         if [ $(( $l_file_mode & $l_pmask )) -gt 0 ]; then
            a_out2+=("" "    Mode: \"$l_file_mode\"" \
            "    should be mode: \"$l_maxperm\" or more restrictive" \
            "    updating to mode: \"$l_maxperm\"")
            chmod "$l_change" "$l_file"
         fi
         if [ "${#a_out2[@]}" -gt "0" ]; then
            a_output2+=("" "  - File: \"$l_file\"" "${a_out2[@]}")
         fi
      done < <(stat -Lc '%#a:%U:%G' "$l_file")
   }
   while IFS= read -r -d $'\0' l_file; do
      if ssh-keygen -lf &>/dev/null "$l_file"; then
         file "$l_file" | grep -Piq -- \
         '\bopenssh\h+([^#\n\r]+\h+)?private\h+key\b' && f_file_access_fix
      fi
   done < <(find -L /etc/ssh -xdev -type f -print0 2>/dev/null)
   if [ "${#a_output2[@]}" -le "0" ]; then
      printf '%s\n' "" " - No access changes required" ""
   else
      printf '%s\n' "" " - Remediation results:" "${a_output2[@]}" ""
   fi
}
```

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-010490 | RULE ID: SV-230287r1017098 | CAT II
5. STIG ID: RHEL-09-255120 | RULE ID: SV-258000r1045063 | CAT II
6. STIG ID: ALMA-09-020920 | RULE ID: SV-269265r1050147 | CAT II
7. STIG ID: SLES-15-040250 | RULE ID: SV-235009r991589 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.1.5 Ensure access to SSH public host key files is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

An SSH public key is one of two files used in SSH public key authentication. In this authentication method, a public key is a key that can be used for verifying digital signatures generated using a corresponding private key. Only a public key that corresponds to a private key will be able to authenticate successfully.

Rationale:

If a public host key file is modified by an unauthorized user, the SSH service may be compromised.

Audit:

Run the following script to verify SSH public host key files are mode `0644` or more restrictive, owned by the `root` user, and owned by the `root` group:

```
#!/usr/bin/env bash

{
   a_output=(); a_output2=()
   l_pmask="0133"; l_maxperm="$( printf '%o' $(( 0777 & ~$l_pmask )) )"
   f_file_chk()
   {
      while IFS=: read -r l_file_mode l_file_owner l_file_group; do
         a_out2=()
         if [ $(( $l_file_mode & $l_pmask )) -gt 0 ]; then
            a_out2+=("    Mode: \"$l_file_mode\" should be mode:
\"$l_maxperm\" or more restrictive")
         fi
         if [ "$l_file_owner" != "root" ]; then
            a_out2+=("    Owned by: \"$l_file_owner\" should be owned by:
\"root\"")
         fi
         if [ "$l_file_group" != "root" ]; then
            a_out2+=("    Owned by group \"$l_file_group\" should be group
owned by group: \"root\"")
         fi
         if [ "${#a_out2[@]}" -gt "0" ]; then
            a_output2+=("  - File: \"$l_file\"" "${a_out2[@]}")
         else
            a_output+=("  - File: \"$l_file\"" \
            "    Correct: mode: \"$l_file_mode\", owner: \"$l_file_owner\"
and group owner: \"$l_file_group\" configured")
         fi
      done < <(stat -Lc '%#a:%U:%G' "$l_file")
   }
   while IFS= read -r -d $'\0' l_file; do
      if ssh-keygen -lf &>/dev/null "$l_file"; then
         file "$l_file" | grep -Piq --
'\bopenssh\h+([^#\n\r]+\h+)?public\h+key\b' && f_file_chk
      fi
   done < <(find -L /etc/ssh -xdev -type f -print0 2>/dev/null)
   if [ "${#a_output2[@]}" -le 0 ]; then
      [ "${#a_output[@]}" -le 0 ] && a_output+=("  - No openSSH public keys
found")
      printf '%s\n' "" "- Audit Result:" "  ** PASS **" "${a_output[@]}" ""
   else
      printf '%s\n' "" "- Audit Result:" "  ** FAIL **" " - Reason(s) for
audit failure:" "${a_output2[@]}"
      [ "${#a_output[@]}" -gt 0 ] && printf '%s\n' "" "- Correctly set:"
"${a_output[@]}" ""
   fi
}
```

Remediation:

Run the following script to set mode, ownership, and group on the public SSH host key files:

```
#!/usr/bin/env bash

{
   a_output=(); a_output2=()
   l_pmask="0133"; l_maxperm="$( printf '%o' $(( 0777 & ~$l_pmask )) )"
   f_file_access_fix()
   {
      while IFS=: read -r l_file_mode l_file_owner l_file_group; do
         a_out2=()
         [ $(( $l_file_mode & $l_pmask )) -gt 0 ] && \
            a_out2+=("    Mode: \"$l_file_mode\" should be mode:
\"$l_maxperm\" or more restrictive" \
            "    updating to mode: \"$l_maxperm\"") && chmod u-x,go-wx
"$l_file"
         [ "$l_file_owner" != "root" ] && \
            a_out2+=("    Owned by: \"$l_file_owner\" should be owned by
\"root\"" \
            "    Changing ownership to \"root\"") && chown root "$l_file"
         [ "$l_file_group" != "root" ] && \
            a_out2+=("    Owned by group \"$l_file_group\" should be group
owned by: \"root\"" \
            "    Changing group ownership to \"root\"") && chgrp root
"$l_file"
         if [ "${#a_out2[@]}" -gt "0" ]; then
            a_output2+=("  - File: \"$l_file\"" "${a_out2[@]}")
         else
            a_output+=("  - File: \"$l_file\"" \
            "    Correct: mode: \"$l_file_mode\", owner: \"$l_file_owner\",
and group owner: \"$l_file_group\" configured")
         fi
      done < <(stat -Lc '%#a:%U:%G' "$l_file")
   }
   while IFS= read -r -d $'\0' l_file; do
      if ssh-keygen -lf &>/dev/null "$l_file"; then
         file "$l_file" | grep -Piq --
'\bopenssh\h+([^#\n\r]+\h+)?public\h+key\b' && f_file_access_fix
      fi
   done < <(find -L /etc/ssh -xdev -type f -print0 2>/dev/null)
   if [ "${#a_output2[@]}" -le "0" ]; then
      printf '%s\n' "" " - No access changes required" ""
   else
      printf '%s\n' " - Remediation results:" "${a_output2[@]}" ""
   fi
}
```

Default Value:

644 0/root 0/root

References:

1. NIST SP 800-53 Rev. 5: AC-3 CM-6 b MP-2
2. NIST SP 800-53A :: CM-6.1 (iv)
3. RHEL 8 STIG Vul ID: V-230286
4. RHEL 8 STIG Rule ID: SV-230286r627750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.1.6 Ensure sshd access is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

There are several options available to limit which users and group can access the system via SSH. It is recommended that at least one of the following options be leveraged:

- `AllowUsers`:
  - The `AllowUsers` variable gives the system administrator the option of allowing specific users to `ssh` into the system. The list consists of space separated user names. Numeric user IDs are not recognized with this variable. If a system administrator wants to restrict user access further by only allowing the allowed users to log in from a particular host, the entry can be specified in the form of user@host.
- `AllowGroups`:
  - The `AllowGroups` variable gives the system administrator the option of allowing specific groups of users to `ssh` into the system. The list consists of space separated group names. Numeric group IDs are not recognized with this variable.
- `DenyUsers`:
  - The `DenyUsers` variable gives the system administrator the option of denying specific users to `ssh` into the system. The list consists of space separated user names. Numeric user IDs are not recognized with this variable. If a system administrator wants to restrict user access further by specifically denying a user's access from a particular host, the entry can be specified in the form of user@host.
- `DenyGroups`:
  - The `DenyGroups` variable gives the system administrator the option of denying specific groups of users to `ssh` into the system. The list consists of space separated group names. Numeric group IDs are not recognized with this variable.

Rationale:

Restricting which users can remotely access the system via SSH will help ensure that only authorized users access the system.

Audit:

Run the following script and verify the output:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY | grep -Pi --
'^\h*(allow|deny)(users|groups)\h+\H+'
}
```

Verify that the output matches at least one of the following lines:

```
allowusers <userlist>
-OR-
allowgroups <grouplist>
-OR-
denyusers <userlist>
-OR-
denygroups <grouplist>
```

Review the list(s) to ensure included users and/or groups follow local site policy

- IF - `Match` set statements are used in your environment, specify the connection parameters to use for the `-T` extended test mode and run the audit to verify the setting is not incorrectly configured in a match block

Example additional audit needed for a match block for the user `sshuser`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY -C user=sshuser | grep -Pi --
'^\h*(allow|deny)(users|groups)\h+\H+'
}
```

Note: If provided, any Match directives in the configuration file that would apply are applied before the configuration is written to standard output. The connection parameters are supplied as keyword=value pairs and may be supplied in any order, either with multiple `-C` options or as a comma-separated list. The keywords are `addr` (source address), `user` (user), `host` (resolved source host name), `laddr` (local address), `lport` (local port number), and `rdomain` (routing domain).

Remediation:

Edit the `/etc/ssh/sshd_config` file to set one or more of the parameters above any `Include` and `Match` set statements as follows:

```
AllowUsers <userlist>
 - AND/OR -
AllowGroups <grouplist>
```

Note:

- First occurrence of an option takes precedence, `Match` set statements withstanding. If `Include` locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a `.conf` file in an `Include` directory.
- **Be advised** that these options are "AND"ed together. If both `AllowUsers` and `AllowGroups` are set, connections will be limited to the list of users that are also a member of an allowed group. It is recommended that only one be set for clarity and ease of administration.
- It is easier to manage an allow list than a deny list. In a deny list, you could potentially add a user or group and forget to add it to the deny list.

Default Value:

None

References:

1. SSHD_CONFIG(5)
2. NIST SP 800-53 Rev. 5: AC-3. MP-2
3. SSHD(8)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	4.3 Ensure the Use of Dedicated Administrative Accounts Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.	●	●	●

5.1.7 Ensure sshd Banner is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `Banner` parameter specifies a file whose contents must be sent to the remote user before authentication is permitted. By default, no banner is displayed.

Rationale:

Banners are used to warn connecting users of the particular site's policy regarding connection. Presenting a warning message prior to the normal user login may assist the prosecution of trespassers on the computer system.

Audit:

Run the following script to verify `Banner` is set:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config 2>/dev/null
   source /etc/sysconfig/sshd 2>/dev/null
   sshd -T $OPTIONS $CRYPTO_POLICY | grep -Pi -- '^banner\h+\/\H+'
}
```

Example output:

```
Banner /etc/issue.net
```

- IF - `Match` set statements are used in your environment, specify the connection parameters to use for the `-T` extended test mode and run the audit to verify the setting is not incorrectly configured in a match block

Example additional audit needed for a match block for the user `sshuser`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY -C user=sshuser | grep -Pi --
'^banner\h+\/\H+'
}
```

Note: If provided, any Match directives in the configuration file that would apply are applied before the configuration is written to standard output. The connection parameters are supplied as keyword=value pairs and may be supplied in any order, either with multiple `-C` options or as a comma-separated list. The keywords are `addr` (source address), `user` (user), `host` (resolved source host name), `laddr` (local address), `lport` (local port number), and `rdomain` (routing domain).

Run the following script and verify that the contents or the file being called by the `Banner` argument match site policy:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   [ -e "$(sshd -T $OPTIONS $CRYPTO_POLICY | awk '$1 == "banner" {print
$2}')" ] && cat "$(sshd -T $OPTIONS $CRYPTO_POLICY | awk '$1 == "banner"
{print $2}')"
}
```

Run the following command and verify no results are returned:

```
# grep -Psi -- "(\\\v|\\\r|\\\m|\\\s|\b$(grep '^ID=' /etc/os-release | cut -
d= -f2 | sed -e 's/"//g')\b)" "$(sshd -T | awk '$1 == "banner" {print $2}')"
```

Remediation:

Edit the `/etc/ssh/sshd_config` file to set the `Banner` parameter above any `Include` and `Match` entries as follows:

```
Banner /etc/issue.net
```

Note: First occurrence of an option takes precedence, Match set statements withstanding. If Include locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in Include location.

Edit the file being called by the `Banner` argument with the appropriate contents according to your site policy, remove any instances of `\m` , `\r` , `\s` , `\v` or references to the `OS platform`

Example:

```
# printf '%s\n' "Authorized users only. All activity may be monitored and
reported." > "$(sshd -T | awk '$1 == "banner" {print $2}')"
```

References:

1. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.1.8 Ensure sshd Ciphers are configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

This variable limits the ciphers that SSH can use during communication.

Note:

- Some organizations may have stricter requirements for approved ciphers.
- Ensure that ciphers used are in compliance with site policy.
- The only "strong" ciphers currently FIPS 140 compliant are:
  - aes256-gcm@openssh.com
  - aes128-gcm@openssh.com
  - aes256-ctr
  - aes192-ctr
  - aes128-ctr

Rationale:

Weak ciphers that are used for authentication to the cryptographic module cannot be relied upon to provide confidentiality or integrity, and system data may be compromised.

- The Triple DES ciphers, as used in SSH, have a birthday bound of approximately four billion blocks, which makes it easier for remote attackers to obtain clear text data via a birthday attack against a long-duration encrypted session, aka a "Sweet32" attack.
- Error handling in the SSH protocol; Client and Server, when using a block cipher algorithm in Cipher Block Chaining (CBC) mode, makes it easier for remote attackers to recover certain plain text data from an arbitrary block of cipher text in an SSH session via unknown vectors.

Audit:

Run the following script to verify none of the "weak" ciphers are being used:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY | grep -Pi --
'^ciphers\h+\"?([^#\n\r]+,)?((3des|blowfish|cast128|aes(128|192|256))-
cbc|arcfour(128|256)?|rijndael-cbc@lysator\.liu\.se|chacha20-
poly1305@openssh\.com)\b'
}
```

- IF - a line is returned, review the list of ciphers. If the line includes `chacha20-poly1305@openssh.com`, review `CVE-2023-48795` and verify the system has been patched. No ciphers in the list below should be returned as they're considered "weak":

```
3des-cbc
aes128-cbc
aes192-cbc
aes256-cbc
```

Remediation:

Note:

- First occurrence of an option takes precedence.
- Though ciphers may be configured through the `Ciphers` option in the `/etc/ssh/sshd_config` file, it is recommended that the ciphers available to openSSH server are configured through system-wide-crypto-policy
- If the recommendations in the subsection "Configure system wide crypto policy" have been followed, this Audit should be in a passing state. Please review that section before following this Remediation Procedure
- By default, system-wide-crypto-policy is applied to the openSSH server. If the following defaults don't exist due to modifications or upgrade from an earlier release, the system-wide-crypto-policy may not be included by the openSSH server. It is recommended that these defaults be restored, created, or the line `Include /etc/crypto-policies/back-ends/opensshserver.config` be added before any lines containing the `Cipher` argument.
- Defaults:
    - The file `/etc/crypto-policies/back-ends/opensshserver.config` is generated by system-wide-crypto-policy

- IF - `CVE-2023-48795` has been addressed, and it meets local site policy, `chacha20-poly1305` may be removed from the list of excluded ciphers.
Create or edit a file in `/etc/crypto-policies/policies/modules/` ending in `.pmod` and add or modify the following line:

```
cipher@SSH = -3DES-CBC -AES-128-CBC -AES-192-CBC -AES-256-CBC -CHACHA20-
POLY1305
```

Example:

```
# printf '%s\n' "# This is a subpolicy to disable weak ciphers" "# for the
SSH protocol (libssh and OpenSSH)" "cipher@SSH = -3DES-CBC -AES-128-CBC -AES-
192-CBC -AES-256-CBC -CHACHA20-POLY1305" >> /etc/crypto-
policies/policies/modules/NO-SSHWEAKCIPHERS.pmod
```

Run the following command to update the system-wide cryptographic policy

```
# update-crypto-policies --set
<CRYPTO_POLICY>:<CRYPTO_SUBPOLICY1>:<CRYPTO_SUBPOLICY2>:<CRYPTO_SUBPOLICY3>
```

Example:

```
# update-crypto-policies --set DEFAULT:NO-SHA1:NO-WEAKMAC:NO-SSHCBC:NO-
SSHCHACHA20:NO-SSHWEAKCIPHERS
```

Run the following command to reload the openSSH server to make your cryptographic settings effective:

```
# systemctl reload-or-restart sshd
```

- OR - If system-wide-crypto-policy is not being used to configure available ciphers (**This is not recommended**)

Edit the /etc/ssh/sshd_config file and add/modify the `Ciphers` line to contain a comma separated list of the site unapproved (weak) Ciphers preceded with a `-` above any `Include` entries:

Example:

```
Ciphers -3des-cbc,aes128-cbc,aes192-cbc,aes256-cbc,chacha20-
poly1305@openssh.com
```

Default Value:

Ciphers chacha20-poly1305@openssh.com,aes128-ctr,aes192-ctr,aes256-ctr,aes128-gcm@openssh.com,aes256-gcm@openssh.com

References:

1. https://nvd.nist.gov/vuln/detail/CVE-2023-48795
2. https://nvd.nist.gov/vuln/detail/CVE-2019-1543
3. https://nvd.nist.gov/vuln/detail/CVE-2016-2183
4. https://nvd.nist.gov/vuln/detail/CVE-2008-5161
5. https://www.openssh.com/txt/cbc.adv
6. https://www.openssh.com/txt/cbc.adv
7. SSHD_CONFIG(5)
8. NIST SP 800-53 Rev. 5: SC-8

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

5.1.9 Ensure sshd ClientAliveInterval and ClientAliveCountMax are configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Note: To clarify, the two settings described below are only meant for idle connections from a protocol perspective and are not meant to check if the user is active or not. An idle user does not mean an idle connection. SSH does not and never had, intentionally, the capability to drop idle users. In SSH versions before `8.2p1` there was a bug that caused these values to behave in such a manner that they were abused to disconnect idle users. This bug has been resolved in `8.2p1` and thus it can no longer be abused to disconnect idle users.

The two options `ClientAliveInterval` and `ClientAliveCountMax` control the timeout of SSH sessions. Taken directly from `man 5 sshd_config`:

- `ClientAliveInterval` Sets a timeout interval in seconds after which if no data has been received from the client, sshd(8) will send a message through the encrypted channel to request a response from the client. The default is 0, indicating that these messages will not be sent to the client.
- `ClientAliveCountMax` Sets the number of client alive messages which may be sent without sshd(8) receiving any messages back from the client. If this threshold is reached while client alive messages are being sent, sshd will disconnect the client, terminating the session. It is important to note that the use of client alive messages is very different from TCPKeepAlive. The client alive messages are sent through the encrypted channel and therefore will not be spoofable. The TCP keepalive option enabled by TCPKeepAlive is spoofable. The client alive mechanism is valuable when the client or server depend on knowing when a connection has become unresponsive. The default value is 3. If ClientAliveInterval is set to 15, and ClientAliveCountMax is left at the default, unresponsive SSH clients will be disconnected after approximately 45 seconds. Setting a zero ClientAliveCountMax disables connection termination.

Rationale:

In order to prevent resource exhaustion, appropriate values should be set for both `ClientAliveInterval` and `ClientAliveCountMax`. Specifically, looking at the source code, `ClientAliveCountMax` must be greater than zero in order to utilize the ability of SSH to drop idle connections. If connections are allowed to stay open indefinitely, this can potentially be used as a DDOS attack or simple resource exhaustion could occur over unreliable networks.

The example set here is a 45 second timeout. Consult your site policy for network timeouts and apply as appropriate.

Audit:

Run the following script and verify `ClientAliveInterval` and `ClientAliveCountMax` are greater than zero:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY | grep -Pi --
'(clientaliveinterval|clientalivecountmax)'
}
```

Example Output:

```
clientaliveinterval 15
clientalivecountmax 3
```

- IF - `Match` set statements are used in your environment, specify the connection parameters to use for the `-T` extended test mode and run the audit to verify the setting is not incorrectly configured in a match block

Example additional audit needed for a match block for the user `sshuser`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY -C user=sshuser | grep -Pi --
'(clientaliveinterval|clientalivecountmax)'
}
```

Note: If provided, any Match directives in the configuration file that would apply are applied before the configuration is written to standard output. The connection parameters are supplied as keyword=value pairs and may be supplied in any order, either with multiple `-C` options or as a comma-separated list. The keywords are `addr` (source address), `user` (user), `host` (resolved source host name), `laddr` (local address), `lport` (local port number), and `rdomain` (routing domain).

Remediation:

Edit the `/etc/ssh/sshd_config` file to set the `ClientAliveInterval` and `ClientAliveCountMax` parameters above any `Include` and `Match` entries according to site policy.

Example:

```
ClientAliveInterval 15
ClientAliveCountMax 3
```

Note: First occurrence of an option takes precedence, Match set statements withstanding. If Include locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in Include location.

Default Value:

ClientAliveInterval 0

ClientAliveCountMax 3

References:

1. SSHD_CONFIG(5)
2. SSHD(8)
3. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5

Additional Information:

https://bugzilla.redhat.com/show_bug.cgi?id=1873547

https://github.com/openssh/openssh-portable/blob/V_8_9/serverloop.c#L137

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.1.10 Ensure sshd DisableForwarding is enabled (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The `DisableForwarding` parameter disables all forwarding features, including X11, ssh-agent(1), TCP and StreamLocal. This option overrides all other forwarding-related options and may simplify restricted configurations.

- X11Forwarding provides the ability to tunnel X11 traffic through the connection to enable remote graphic connections.
- ssh-agent is a program to hold private keys used for public key authentication. Through use of environment variables the agent can be located and automatically used for authentication when logging in to other machines using ssh.
- SSH port forwarding is a mechanism in SSH for tunneling application ports from the client to the server, or servers to clients. It can be used for adding encryption to legacy applications, going through firewalls, and some system administrators and IT professionals use it for opening backdoors into the internal network from their home machines.

Rationale:

Disable X11 forwarding unless there is an operational requirement to use X11 applications directly. There is a small risk that the remote X11 servers of users who are logged in via SSH with X11 forwarding could be compromised by other users on the X11 server. Note that even if X11 forwarding is disabled, users can always install their own forwarders.

Anyone with root privilege on the intermediate server can make free use of ssh-agent to authenticate them to other servers.

Leaving port forwarding enabled can expose the organization to security risks and backdoors. SSH connections are protected with strong encryption. This makes their contents invisible to most deployed network monitoring and traffic filtering solutions. This invisibility carries considerable risk potential if it is used for malicious purposes such as data exfiltration. Cybercriminals or malware could exploit SSH to hide their unauthorized communications, or to exfiltrate stolen data from the target network.

Impact:

SSH tunnels are widely used in many corporate environments. In some environments the applications themselves may have very limited native support for security. By utilizing tunneling, compliance with SOX, HIPAA, PCI-DSS, and other standards can be achieved without having to modify the applications.

Audit:

Run the following script to verify `DisableForwarding` is set to `yes`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY | grep -i disableforwarding
}
```

Example output:

```
disableforwarding yes
```

Remediation:

Edit the `/etc/ssh/sshd_config` file to set the `DisableForwarding` parameter to `yes` above any `Include` entry as follows:

```
DisableForwarding yes
```

Note: First occurrence of an option takes precedence. If Include locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in Include location.

References:

1. sshd_config(5)
2. SSHD(8)
3. NIST SP 800-53 Rev. 5: CM-7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

5.1.11 Ensure sshd GSSAPIAuthentication is disabled (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The `GSSAPIAuthentication` parameter specifies whether user authentication based on GSSAPI is allowed

Rationale:

Allowing GSSAPI authentication through SSH exposes the system's GSSAPI to remote hosts, and should be disabled to reduce the attack surface of the system

Audit:

Run the following script to verify `GSSAPIAuthentication` is set to `no`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY | grep -i gssapiauthentication
}
```

Example output:

```
gssapiauthentication no
```

- IF - `Match` set statements are used in your environment, specify the connection parameters to use for the `-T` extended test mode and run the audit to verify the setting is not incorrectly configured in a match block

Example additional audit needed for a match block for the user `sshuser`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY -C user=sshuser | grep -i
gssapiauthentication
}
```

Note: If provided, any Match directives in the configuration file that would apply are applied before the configuration is written to standard output. The connection parameters are supplied as keyword=value pairs and may be supplied in any order, either with multiple `-C` options or as a comma-separated list. The keywords are `addr` (source address), `user` (user), `host` (resolved source host name), `laddr` (local address), `lport` (local port number), and `rdomain` (routing domain)

Remediation:

Edit the `/etc/ssh/sshd_config` file to set the `GSSAPIAuthentication` parameter to `no` above any `Include` and `Match` entries as follows:

```
GSSAPIAuthentication no
```

Note: First occurrence of an option takes precedence, `Match` set statements withstanding. If `Include` locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in `Include` location.

Default Value:

GSSAPIAuthentication no

References:

1. SSHD_CONFIG(5)
2. SSHD(8)
3. NIST SP 800-53 :: CM-6 b
4. NIST SP 800-53A :: CM-6.1 (iv)
5. RHEL 8 STIG Vul ID: V-244528
6. RHEL 8 STIG Rule ID: SV-244528r952106

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.1.12 Ensure sshd HostbasedAuthentication is disabled (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `HostbasedAuthentication` parameter specifies if authentication is allowed through trusted hosts via the use of `.rhosts`, or `/etc/hosts.equiv`, along with successful public key client host authentication.

Rationale:

Even though the `.rhosts` files are ineffective if support is disabled in `/etc/pam.conf`, disabling the ability to use `.rhosts` files in SSH provides an additional layer of protection.

Audit:

Run the following script to verify `HostbasedAuthentication` is set to `no`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY | grep -i hostbasedauthentication
}
```

Example output:

```
hostbasedauthentication no
```

- IF - `Match` set statements are used in your environment, specify the connection parameters to use for the `-T` extended test mode and run the audit to verify the setting is not incorrectly configured in a match block

Example additional audit needed for a match block for the user `sshuser`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY -C user=sshuser | grep -i
hostbasedauthentication
}
```

Note: If provided, any Match directives in the configuration file that would apply are applied before the configuration is written to standard output. The connection parameters are supplied as keyword=value pairs and may be supplied in any order, either with multiple `-C` options or as a comma-separated list. The keywords are `addr` (source address), `user` (user), `host` (resolved source host name), `laddr` (local address), `lport` (local port number), and `rdomain` (routing domain)

Remediation:

Edit the `/etc/ssh/sshd_config` file to set the `HostbasedAuthentication` parameter to `no` above any `Include` and `Match` entries as follows:

```
HostbasedAuthentication no
```

Note: First occurrence of an option takes precedence, `Match` set statements withstanding. If `Include` locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in `Include` location.

Default Value:

HostbasedAuthentication no

References:

1. SSHD_CONFIG(5)
2. SSHD(8)
3. NIST SP 800-53 :: CM-6 b
4. NIST SP 800-53A :: CM-6.1 (iv)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.1.13 Ensure sshd IgnoreRhosts is enabled (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `IgnoreRhosts` parameter specifies that `.rhosts` and `.shosts` files will not be used in `RhostsRSAAuthentication` or `HostbasedAuthentication`.

Rationale:

Setting this parameter forces users to enter a password when authenticating with SSH.

Audit:

Run the following script to verify `IgnoreRhosts` is set to `yes`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY | grep -i ignorerhosts
}
```

Example output:

```
ignorerhosts yes
```

Remediation:

Edit the `/etc/ssh/sshd_config` file to set the `IgnoreRhosts` parameter to `yes` above any `Include` entry as follows:

```
IgnoreRhosts yes
```

Note: First occurrence of an option takes precedence. If `Include` locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in `Include` location.

Default Value:

IgnoreRhosts yes

References:

1. SSHD_CONFIG(5)
2. SSHD(8)
3. NIST SP 800-53 Rev. 5: CM-1,CM-2, CM-6, CM-7, IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.1.14 Ensure sshd KexAlgorithms is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Key exchange is a method in cryptography by which cryptographic keys are exchanged between two parties, allowing use of a cryptographic algorithm. If the sender and receiver wish to exchange encrypted messages, each must be equipped to encrypt messages to be sent and decrypt messages received

Note:

- Kex algorithms have a higher preference the earlier they appear in the list
- Some organizations may have stricter requirements for approved Key exchange algorithms
- Ensure that Key exchange algorithms used are in compliance with site policy
- The only Key Exchange Algorithms currently FIPS 140 approved are:
  - ecdh-sha2-nistp256
  - ecdh-sha2-nistp384
  - ecdh-sha2-nistp521
  - diffie-hellman-group-exchange-sha256
  - diffie-hellman-group16-sha512
  - diffie-hellman-group18-sha512
  - diffie-hellman-group14-sha256

Rationale:

Key exchange methods that are considered weak should be removed. A key exchange method may be weak because too few bits are used, or the hashing algorithm is considered too weak. Using weak algorithms could expose connections to man-in-the-middle attacks

Audit:

Run the following script to verify none of the "weak" Key Exchange algorithms are being used:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY | grep -Pi --
'kexalgorithms\h+([^#\n\r]+,)?(diffie-hellman-group1-sha1|diffie-hellman-
group14-sha1|diffie-hellman-group-exchange-sha1)\b'
}
```

Nothing should be returned

The following are considered "weak" Key Exchange Algorithms, and should not be used:

```
diffie-hellman-group1-sha1
diffie-hellman-group14-sha1
diffie-hellman-group-exchange-sha1
```

Remediation:

Note:

- First occurrence of an option takes precedence.
- Though key_exchange may be configured through the `KexAlgorithms` option in the `/etc/ssh/sshd_config` file, it is recommended that the key_exchange available to openSSH server are configured through system-wide-crypto-policy
- If the recommendations in the subsection "Configure system wide crypto policy" have been followed, this Audit should be in a passing state. Please review that section before following this Remediation Procedure
- By default, system-wide-crypto-policy is applied to the openSSH server. If the following defaults don't exist due to modifications or upgrade from an earlier release, the system-wide-crypto-policy may not be included by the openSSH server. It is recommended that these defaults be restored, created, or the line `Include /etc/crypto-policies/back-ends/opensshserver.config` be added before any lines containing the `KexAlgorithms` argument.
- Defaults:
    - The file `/etc/crypto-policies/back-ends/opensshserver.config` is generated by system-wide-crypto-policy

Follow the Remediation Procedure in "Ensure system wide crypto policy disables sha1 hash and signature support"
This is and excerpt of the Remediation Procedure from "Ensure system wide crypto policy disables sha1 hash and signature support":
Create or edit a file in `/etc/crypto-policies/policies/modules/` ending in `.pmod` and add or modify the following lines:

```
hash = -SHA1
sign = -*-SHA1
sha1_in_certs = 0
```

Example:

```
# printf '%s\n' "# This is a subpolicy dropping the SHA1 hash and signature
support" "hash = -SHA1" "sign = -*-SHA1" "sha1_in_certs = 0" >> /etc/crypto-
policies/policies/modules/NO-SHA1.pmod
```

Run the following command to update the system-wide cryptographic policy

```
# update-crypto-policies --set
<CRYPTO_POLICY>:<CRYPTO_SUBPOLICY1>:<CRYPTO_SUBPOLICY2>:<CRYPTO_SUBPOLICY3>
```

Example:

```
# update-crypto-policies --set DEFAULT:NO-SHA1:NO-WEAKMAC:NO-SSHCBC:NO-
SSHCHACHA20:NO-SSHETM:NO-SSHWEAKCIPHERS
```

Run the following command to reload the openSSH server to make your cryptographic settings effective:

```
# systemctl reload-or-restart sshd
```

- OR - If system-wide-crypto-policy is not being used to configure available KexAlgorithms (**This is not recommended**)

Edit the `/etc/ssh/sshd_config` file and add/modify the `KexAlgorithms` line to contain a comma separated list of the site unapproved (weak) KexAlgorithms preceded with a `-` above any `Include` entries:

Example:

```
KexAlgorithms -diffie-hellman-group1-sha1,diffie-hellman-group14-sha1,diffie-
hellman-group-exchange-sha1
```

Default Value:

KexAlgorithms curve25519-sha256,curve25519-sha256@libssh.org,ecdh-sha2-nistp256,ecdh-sha2-nistp384,ecdh-sha2-nistp521,diffie-hellman-group-exchange-sha256,diffie-hellman-group14-sha256,diffie-hellman-group16-sha512,diffie-hellman-group18-sha512,diffie-hellman-group-exchange-sha1,diffie-hellman-group14-sha1

References:

1. https://ubuntu.com/server/docs/openssh-crypto-configuration
2. NIST SP 800-53 Rev. 5: SC-8
3. SSHD(8)
4. SSHD_CONFIG(5)

Additional Information:

The supported algorithms are:

```
curve25519-sha256
curve25519-sha256@libssh.org
diffie-hellman-group1-sha1
diffie-hellman-group14-sha1
diffie-hellman-group14-sha256
diffie-hellman-group16-sha512
diffie-hellman-group18-sha512
diffie-hellman-group-exchange-sha1
diffie-hellman-group-exchange-sha256
ecdh-sha2-nistp256
ecdh-sha2-nistp384
ecdh-sha2-nistp521
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●

5.1.15 Ensure sshd LoginGraceTime is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `LoginGraceTime` parameter specifies the time allowed for successful authentication to the SSH server. The longer the Grace period is the more open unauthenticated connections can exist. Like other session controls in this session the Grace Period should be limited to appropriate organizational limits to ensure the service is available for needed access.

Rationale:

Setting the `LoginGraceTime` parameter to a low number will minimize the risk of successful brute force attacks to the SSH server. It will also limit the number of concurrent unauthenticated connections While the recommended setting is 60 seconds (1 Minute), set the number based on site policy.

Audit:

Run the following script and verify that output `LoginGraceTime` is between `1` and `60` seconds:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY | grep -i logingracetime
}
```

Example output:

```
logingracetime 60
```

Remediation:

Edit the `/etc/ssh/sshd_config` file to set the `LoginGraceTime` parameter to a value between `1` and `60` seconds above any `Include` entry as follows:

Example:

```
LoginGraceTime 60
```

Note: First occurrence of an option takes precedence. If Include locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in Include location.

Default Value:

LoginGraceTime 120

References:

1. SSHD_CONFIG(5)
2. NIST SP 800-53 Rev. 5: CM-6
3. SSHD(8)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.1.16 Ensure sshd LogLevel is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

SSH provides several logging levels with varying amounts of verbosity. The `DEBUG` options are specifically not recommended other than strictly for debugging SSH communications. These levels provide so much data that it is difficult to identify important security information, and may violate the privacy of users.

Rationale:

The `INFO` level is the basic level that only records login activity of SSH users. In many situations, such as Incident Response, it is important to determine when a particular user was active on a system. The logout record can eliminate those users who disconnected, which helps narrow the field.

The `VERBOSE` level specifies that login and logout activity as well as the key fingerprint for any SSH key used for login will be logged. This information is important for SSH key management, especially in legacy environments.

Audit:

Run the following script and verify that output matches `loglevel VERBOSE` or `loglevel INFO`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY | grep -i loglevel
}
```

Example output:

```
loglevel VERBOSE
   - OR -
loglevel INFO
```

- IF - `Match` set statements are used in your environment, specify the connection parameters to use for the `-T` extended test mode and run the audit to verify the setting is not incorrectly configured in a match block

Example additional audit needed for a match block for the user `sshuser`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY -C user=sshuser | grep -i loglevel
}
```

Note: If provided, any Match directives in the configuration file that would apply are applied before the configuration is written to standard output. The connection parameters are supplied as keyword=value pairs and may be supplied in any order, either with multiple `-C` options or as a comma-separated list. The keywords are `addr` (source address), `user` (user), `host` (resolved source host name), `laddr` (local address), `lport` (local port number), and `rdomain` (routing domain)

Remediation:

Edit the `/etc/ssh/sshd_config` file to set the `LogLevel` parameter to `VERBOSE` or `INFO` above any `Include` and `Match` entries as follows:

```
LogLevel VERBOSE
   - OR -
LogLevel INFO
```

Note: First occurrence of an option takes precedence, `Match` set statements withstanding. If `Include` locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in `Include` location.

Default Value:

LogLevel INFO

References:

1. https://www.ssh.com/ssh/sshd_config/
2. NIST SP 800-53 Rev. 5: AU-3, AU-12, SI-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

5.1.17 Ensure sshd MACs are configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

This variable limits the types of MAC algorithms that SSH can use during communication.

Note:

- Some organizations may have stricter requirements for approved MACs.
- Ensure that MACs used are in compliance with site policy.
- The only "strong" MACs currently FIPS 140 approved are:
    - HMAC-SHA1
    - HMAC-SHA2-256
    - HMAC-SHA2-384
    - HMAC-SHA2-512

Rationale:

MD5 and 96-bit MAC algorithms are considered weak and have been shown to increase exploitability in SSH downgrade attacks. Weak algorithms continue to have a great deal of attention as a weak spot that can be exploited with expanded computing power. An attacker that breaks the algorithm could take advantage of a MiTM position to decrypt the SSH tunnel and capture credentials and information.

Audit:

Run the following script to verify none of the "weak" MACs are being used:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T $OPTIONS $CRYPTO_POLICY | grep -Pi -- 'macs\h+([^#\n\r]+,)?(hmac-
md5|hmac-md5-96|hmac-ripemd160|hmac-sha1-96|umac-64@openssh\.com|hmac-md5-
etm@openssh\.com|hmac-md5-96-etm@openssh\.com|hmac-ripemd160-
etm@openssh\.com|hmac-sha1-96-etm@openssh\.com|umac-64-etm@openssh\.com|umac-
128-etm@openssh\.com)\b'
}
```

Nothing should be returned

Note: Review CVE-2023-48795 and verify the system has been patched. If the system has not been patched, review the use of the Encrypt Then Mac (etm) MACs.

The following are considered "weak" MACs, and should not be used:

```
hmac-md5
hmac-md5-96
hmac-ripemd160
hmac-sha1-96
umac-64@openssh.com
hmac-md5-etm@openssh.com
hmac-md5-96-etm@openssh.com
hmac-ripemd160-etm@openssh.com
hmac-sha1-96-etm@openssh.com
umac-64-etm@openssh.com
umac-128-etm@openssh.com
```

Remediation:

Note:

- First occurrence of an option takes precedence.
- Though MACs may be configured through the `MACs` option in the `/etc/ssh/sshd_config` file, it is recommended that the MACs available to openSSH server are configured through system-wide-crypto-policy
- If the recommendations in the subsection "Configure system wide crypto policy" have been followed, this Audit should be in a passing state. Please review that section before following this Remediation Procedure
- By default, system-wide-crypto-policy is applied to the openSSH server. If the following defaults don't exist due to modifications or upgrade from a earlier release, the system-wide-crypto-policy may not be included by the openSSH server. It is recommended that these defaults be restored, created, or the line `Include /etc/crypto-policies/back-ends/opensshserver.config` be added before any lines containing the `MACs` argument.
- Defaults:
    - The file `/etc/crypto-policies/back-ends/opensshserver.config` is generated by system-wide-crypto-policy

- IF - `CVE-2023-48795` has not been reviewed and addressed, Recommendation "Ensure system wide crypto policy disables EtM for ssh" should be followed. Create or edit a file in `/etc/crypto-policies/policies/modules/` ending in `.pmod` and add or modify the the following line:

```
mac@SSH = -HMAC-MD5* -UMAC-64* -UMAC-128*
```

Example:

```
# printf '%s\n' "# This is a subpolicy to disable weak MACs" "# for the SSH
protocol (libssh and OpenSSH)" "mac@SSH = -HMAC-MD5* -UMAC-64* -UMAC-128*" >>
/etc/crypto-policies/policies/modules/NO-SSHWEAKMACS.pmod
```

Run the following command to update the system-wide cryptographic policy

```
# update-crypto-policies --set
<CRYPTO_POLICY>:<CRYPTO_SUBPOLICY1>:<CRYPTO_SUBPOLICY2>:<CRYPTO_SUBPOLICY3>
```

Example:

```
# update-crypto-policies --set DEFAULT:NO-SHA1:NO-WEAKMAC:NO-SSHCBC:NO-
SSHCHACHA20:NO-SSHETM:NO-SSHWEAKCIPHERS:NO-SSHWEAKMACS
```

Run the following command to reload the openSSH server to make your cryptographic settings effective:

```
# systemctl reload-or-restart sshd
```

- OR - If system-wide-crypto-policy is not being used to configure available ciphers (**This is not recommended**)

Edit the `/etc/ssh/sshd_config` file and add/modify the `MACs` line to contain a comma separated list of the site unapproved (weak) MACs preceded with a `-` above any `Include` entries:

Example:

```
MACs -hmac-md5,hmac-md5-96,hmac-ripemd160,hmac-sha1-96,umac-
64@openssh.com,hmac-md5-etm@openssh.com,hmac-md5-96-etm@openssh.com,hmac-
ripemd160-etm@openssh.com,hmac-sha1-96-etm@openssh.com,umac-64-
etm@openssh.com,umac-128-etm@openssh.com
```

- IF - `CVE-2023-48795` has not been reviewed and addressed, the following `etm` MACs should be added to the exclude list: hmac-sha1-etm@openssh.com,hmac-sha2-256-etm@openssh.com,hmac-sha2-512-etm@openssh.com

Default Value:

macs hmac-sha2-256-etm@openssh.com,hmac-sha1-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-512-etm@openssh.com,hmac-sha2-256,hmac-sha1,umac-128@openssh.com,hmac-sha2-512

References:

1. https://nvd.nist.gov/vuln/detail/CVE-2023-48795
2. More information on SSH downgrade attacks can be found here: http://www.mitls.org/pages/attacks/SLOTH
3. SSHD_CONFIG(5)
4. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5

Additional Information:

Supported MACs:

```
hmac-md5
hmac-md5-96
hmac-sha1
hmac-sha1-96
hmac-sha2-256
hmac-sha2-512
umac-64@openssh.com
umac-128@openssh.com
hmac-md5-etm@openssh.com
hmac-md5-96-etm@openssh.com
hmac-sha1-etm@openssh.com
hmac-sha1-96-etm@openssh.com
hmac-sha2-256-etm@openssh.com
hmac-sha2-512-etm@openssh.com
umac-64-etm@openssh.com
umac-128-etm@openssh.com
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.10 Encrypt Sensitive Data in Transit Encrypt sensitive data in transit. Example implementations can include: Transport Layer Security (TLS) and Open Secure Shell (OpenSSH).		●	●
v7	14.4 Encrypt All Sensitive Information in Transit Encrypt all sensitive information in transit.		●	●
v7	16.5 Encrypt Transmittal of Username and Authentication Credentials Ensure that all account usernames and authentication credentials are transmitted across networks using encrypted channels.		●	●

5.1.18 Ensure sshd MaxAuthTries is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `MaxAuthTries` parameter specifies the maximum number of authentication attempts permitted per connection. When the login failure count reaches half the number, error messages will be written to the `syslog` file detailing the login failure.

Rationale:

Setting the `MaxAuthTries` parameter to a low number will minimize the risk of successful brute force attacks to the SSH server. While the recommended setting is 4, set the number based on site policy.

Audit:

Run the following script and verify that `MaxAuthTries` is `4` or less:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T  $OPTIONS $CRYPTO_POLICY | grep -i maxauthtries
}
```

Verify output includes `maxauthtries` is set to a value of `4` or less

Example output:

```
maxauthtries 4
```

- IF - `Match` set statements are used in your environment, specify the connection parameters to use for the `-T` extended test mode and run the audit to verify the setting is not incorrectly configured in a match block

Example additional audit needed for a match block for the user `sshuser`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T  $OPTIONS $CRYPTO_POLICY -C user=sshuser | grep -i maxauthtries
}
```

Note: If provided, any Match directives in the configuration file that would apply are applied before the configuration is written to standard output. The connection parameters are supplied as keyword=value pairs and may be supplied in any order, either with multiple `-C` options or as a comma-separated list. The keywords are `addr` (source address), `user` (user), `host` (resolved source host name), `laddr` (local address), `lport` (local port number), and `rdomain` (routing domain)

Remediation:

Edit the `/etc/ssh/sshd_config` file to set the `MaxAuthTries` parameter to `4` or less above any `Include` and `Match` entries as follows:

Example:

```
MaxAuthTries 4
```

Note: First occurrence of an option takes precedence, `Match` set statements withstanding. If `Include` locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in `Include` location.

Default Value:

MaxAuthTries 6

References:

1. SSHD_CONFIG(5)
2. NIST SP 800-53 Rev. 5: AU-3

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	16.13 Alert on Account Login Behavior Deviation Alert when users deviate from normal login behavior, such as time-of-day, workstation location and duration.			●

5.1.19 Ensure sshd MaxSessions is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `MaxSessions` parameter specifies the maximum number of open sessions permitted from a given connection.

Rationale:

To protect a system from denial of service due to a large number of concurrent sessions, use the rate limiting function of MaxSessions to protect availability of sshd logins and prevent overwhelming the daemon.

Audit:

Run the following script and verify that `MaxSessions` is `10` or less:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T  $OPTIONS $CRYPTO_POLICY | grep -i maxsessions
}
```

Example output:

```
maxsessions 10
```

- IF - `Match` set statements are used in your environment, specify the connection parameters to use for the `-T` extended test mode and run the audit to verify the setting is not incorrectly configured in a match block

Example additional audit needed for a match block for the user `sshuser`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T  $OPTIONS $CRYPTO_POLICY -C user=sshuser | grep -i maxsessions
}
```

Note: If provided, any Match directives in the configuration file that would apply are applied before the configuration is written to standard output. The connection parameters are supplied as keyword=value pairs and may be supplied in any order, either with multiple `-C` options or as a comma-separated list. The keywords are `addr` (source address), `user` (user), `host` (resolved source host name), `laddr` (local address), `lport` (local port number), and `rdomain` (routing domain)

Remediation:

Edit the `/etc/ssh/sshd_config` file to set the `MaxSessions` parameter to `10` or less above any `Include` and `Match` entries:

Example:

```
MaxSessions 10
```

Note: First occurrence of an option takes precedence, `Match` set statements withstanding. If `Include` locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in `Include` location.

Default Value:

MaxSessions 10

References:

1. SSHD_CONFIG(5)
2. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.1.20 Ensure sshd MaxStartups is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `MaxStartups` parameter specifies the maximum number of concurrent unauthenticated connections to the SSH daemon.

Rationale:

To protect a system from denial of service due to a large number of pending authentication connection attempts, use the rate limiting function of MaxStartups to protect availability of sshd logins and prevent overwhelming the daemon.

Audit:

Run the following script to verify `MaxStartups` is `10:30:60` or more restrictive:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T  $OPTIONS $CRYPTO_POLICY | awk '$1 ~ /^\s*maxstartups/{split($2,
a, ":");{if(a[1] > 10 || a[2] > 30 || a[3] > 60) print $0}}'
}
```

Nothing should be returned

Remediation:

Edit the `/etc/ssh/sshd_config` file to set the `MaxStartups` parameter to `10:30:60` or more restrictive above any `Include` entries:

Example:

```
MaxStartups 10:30:60
```

Note: First occurrence of an option takes precedence. If Include locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in Include location.

Default Value:

MaxStartups 10:30:100

References:

1. SSHD_CONFIG(5)
2. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.1.21 Ensure sshd PermitEmptyPasswords is disabled (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `PermitEmptyPasswords` parameter specifies if the SSH server allows login to accounts with empty password strings.

Rationale:

Disallowing remote shell access to accounts that have an empty password reduces the probability of unauthorized access to the system.

Audit:

Run the following script to verify `PermitEmptyPasswords` is set to `no`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T  $OPTIONS $CRYPTO_POLICY | grep -i permitemptypasswords
}
```

Example output

```
permitemptypasswords no
```

- IF - `Match` set statements are used in your environment, specify the connection parameters to use for the `-T` extended test mode and run the audit to verify the setting is not incorrectly configured in a match block

Example additional audit needed for a match block for the user `sshuser`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T  $OPTIONS $CRYPTO_POLICY -C user=sshuser | grep -i
permitemptypasswords
}
```

Note: If provided, any Match directives in the configuration file that would apply are applied before the configuration is written to standard output. The connection parameters are supplied as keyword=value pairs and may be supplied in any order, either with multiple `-C` options or as a comma-separated list. The keywords are `addr` (source address), `user` (user), `host` (resolved source host name), `laddr` (local address), `lport` (local port number), and `rdomain` (routing domain)

Remediation:

Edit `/etc/ssh/sshd_config` and set the `PermitEmptyPasswords` parameter to `no` above any `Include` and `Match` entries:

Example:

```
PermitEmptyPasswords no
```

Note: First occurrence of an option takes precedence, `Match` set statements withstanding. If `Include` locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in `Include` location.

The SSH daemon must be restarted for the changes to take effect. To restart the SSH daemon, run the following command:

```
# systemctl reload-or-restart sshd.service
```

Default Value:

PermitEmptyPasswords no

References:

1. SSHD_CONFIG(5)
2. NIST SP 800-53 Revision 5 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. RHEL 8 STIG Vul ID: V-230380
5. RHEL 8 STIG Rule ID: SV-230380r951612

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.1.22 Ensure sshd PermitRootLogin is disabled (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `PermitRootLogin` parameter specifies if the root user can log in using SSH. The default is `prohibit-password`.

Rationale:

Disallowing `root` logins over SSH requires system admins to authenticate using their own individual account, then escalating to `root`. This limits opportunity for non-repudiation and provides a clear audit trail in the event of a security incident.

Audit:

Run the following script to verify `PermitRootLogin` is set to `no`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T  $OPTIONS $CRYPTO_POLICY | grep -i permitrootlogin
}
```

Example output:

```
permitrootlogin no
```

- IF - `Match` set statements are used in your environment, specify the connection parameters to use for the `-T` extended test mode and run the audit to verify the setting is not incorrectly configured in a match block

Example additional audit needed for a match block for the user `sshuser`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T  $OPTIONS $CRYPTO_POLICY -C user=sshuser | grep -i permitrootlogin
}
```

Note: If provided, any Match directives in the configuration file that would apply are applied before the configuration is written to standard output. The connection parameters are supplied as keyword=value pairs and may be supplied in any order, either with multiple `-C` options or as a comma-separated list. The keywords are `addr` (source address), `user` (user), `host` (resolved source host name), `laddr` (local address), `lport` (local port number), and `rdomain` (routing domain)

Remediation:

Edit the `/etc/ssh/sshd_config` file to set the `PermitRootLogin` parameter to `no` above any `Include` and `Match` entries:

Example:

```
PermitRootLogin no
```

Note: First occurrence of an option takes precedence, `Match` set statements withstanding. If `Include` locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in `Include` location.

Default Value:

PermitRootLogin without-password

References:

1. SSHD_CONFIG(5)
2. NIST SP 800-53 Rev. 5:AC-6
3. NIST SP 800-53A :: IA-2 (5).2 (ii)
4. RHEL 8 STIG Vul ID: V-230296
5. RHEL 8 STIG Rule ID: SV-230296r951608

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.	●	●	●
v7	4.3 Ensure the Use of Dedicated Administrative Accounts Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.	●	●	●

5.1.23 Ensure sshd PermitUserEnvironment is disabled (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `PermitUserEnvironment` option allows users to present environment options to the SSH daemon.

Rationale:

Permitting users the ability to set environment variables through the SSH daemon could potentially allow users to bypass security controls (e.g. setting an execution path that has SSH executing trojan'd programs)

Audit:

Run the following script to verify `PermitUserEnvironment` is set to `no`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T  $OPTIONS $CRYPTO_POLICY | grep -i permituserenvironment
}
```

Example output:

```
permituserenvironment no
```

Remediation:

Edit the `/etc/ssh/sshd_config` file to set the `PermitUserEnvironment` parameter to `no` above any `Include` entries:

Example:

```
PermitUserEnvironment no
```

Note: First occurrence of an option takes precedence. If Include locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in Include location.

Default Value:

PermitUserEnvironment no

References:

1. SSHD_CONFIG(5)
2. SSHD(8)
3. NIST SP 800-53 Rev. 5: CM-1,CM-2, CM-6, CM-7, IA-5
4. NIST SP 800-53A :: CM-6.1 (iv)
5. RHEL 8 STIG Vul ID: V-230330
6. RHEL 8 STIG Rule ID: SV-230330r951610

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.1.24 Ensure sshd UsePAM is enabled (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `UsePAM` directive enables the Pluggable Authentication Module (PAM) interface. If set to `yes` this will enable PAM authentication using `ChallengeResponseAuthentication` and `PasswordAuthentication` directives in addition to PAM account and session module processing for all authentication types.

Rationale:

When `usePAM` is set to `yes`, PAM runs through account and session types properly. This is important if you want to restrict access to services based off of IP, time or other factors of the account. Additionally, you can make sure users inherit certain environment variables on login or disallow access to the server

Audit:

Run the following script to verify `UsePAM` is set to `yes`:

```
{
   #!/usr/bin/env bash

   source /etc/crypto-policies/back-ends/opensshserver.config
   source /etc/sysconfig/sshd
   sshd -T  $OPTIONS $CRYPTO_POLICY | grep -i usepam
}
```

Example output:

```
usepam yes
```

Remediation:

Edit the `/etc/ssh/sshd_config` file to set the `UsePAM` parameter to `yes` above any `Include` entries:

Example:

```
UsePAM yes
```

Note: First occurrence of an option takes precedence. If Include locations are enabled, used, and order of precedence is understood in your environment, the entry may be created in a file in Include location.

Default Value:

UsePAM yes

References:

1. SSHD_CONFIG(5)
2. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5
3. SSHD(8)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.2 Configure privilege escalation

There are various tools which allows a permitted user to execute a command as the superuser or another user, as specified by the security policy.

sudo

https://www.sudo.ws/

The invoking user's real (not effective) user ID is used to determine the user name with which to query the security policy.

`sudo` supports a plug-in architecture for security policies and input/output logging. Third parties can develop and distribute their own policy and I/O logging plug-ins to work seamlessly with the `sudo` front end. The default security policy is `sudoers`, which is configured via the file `/etc/sudoers` and any entries in `/etc/sudoers.d`.

pkexec

https://www.freedesktop.org/software/polkit/docs/0.105/pkexec.1.html

5.2.1 Ensure sudo is installed (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`sudo` allows a permitted user to execute a command as the superuser or another user, as specified by the security policy. The invoking user's real (not effective) user ID is used to determine the user name with which to query the security policy.

Rationale:

`sudo` supports a plug-in architecture for security policies and input/output logging. Third parties can develop and distribute their own policy and I/O logging plug-ins to work seamlessly with the `sudo` front end. The default security policy is `sudoers`, which is configured via the file `/etc/sudoers` and any entries in `/etc/sudoers.d`.

The security policy determines what privileges, if any, a user has to run `sudo`. The policy may require that users authenticate themselves with a password or another authentication mechanism. If authentication is required, `sudo` will exit if the user's password is not entered within a configurable time limit. This limit is policy-specific.

Audit:

Verify that `sudo` is installed.

Run the following command:

```
# dnf list sudo

Installed Packages
sudo.x86_64             <VERSION>         @anaconda
Available Packages
sudo.x86_64             <VERSION>         updates
```

Remediation:

Run the following command to install sudo

```
# dnf install sudo
```

References:

1. SUDO(8)
2. NIST SP 800-53 Rev. 5: AC-6(2), AC-6(5)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.	●	●	●
v7	4.3 Ensure the Use of Dedicated Administrative Accounts Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.	●	●	●

5.2.2 Ensure sudo commands use pty (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`sudo` can be configured to run only from a pseudo terminal (`pseudo-pty`).

Rationale:

Attackers can run a malicious program using `sudo` which would fork a background process that remains even when the main program has finished executing.

Impact:

WARNING: Editing the `sudo` configuration incorrectly can cause `sudo` to stop functioning. Always use `visudo` to modify `sudo` configuration files.

Audit:

Verify that `sudo` can only run other commands from a pseudo terminal.

Run the following command to verify `Defaults use_pty` is set:

```
# grep -rPi -- '^\h*Defaults\h+([^#\n\r]+,\h*)?use_pty\b' /etc/sudoers*
```

Verify the output matches:

```
/etc/sudoers:Defaults use_pty
```

Run the follow command to to verify `Defaults !use_pty` is not set:

```
# grep -rPi -- '^\h*Defaults\h+([^#\n\r]+,\h*)?!use_pty\b' /etc/sudoers*
```

Nothing should be returned

Remediation:

Edit the file `/etc/sudoers` with `visudo` or a file in `/etc/sudoers.d/` with `visudo -f <PATH TO FILE>` and add the following line:

```
Defaults use_pty
```

Edit the file `/etc/sudoers` with `visudo` and any files in `/etc/sudoers.d/` with `visudo -f <PATH TO FILE>` and remove any occurrence of `!use_pty`

Note:

- sudo will read each file in `/etc/sudoers.d`, skipping file names that end in `~` or contain a `.` character to avoid causing problems with package manager or editor temporary/backup files.
- Files are parsed in sorted lexical order. That is, `/etc/sudoers.d/01_first` will be parsed before `/etc/sudoers.d/10_second`.
- Be aware that because the sorting is lexical, not numeric, `/etc/sudoers.d/1_whoops` would be loaded after `/etc/sudoers.d/10_second`.
- Using a consistent number of leading zeroes in the file names can be used to avoid such problems.

References:

1. SUDO(8)
2. VISUDO(8)
3. sudoers(5)
4. NIST SP 800-53 Rev. 5: AC-6

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.	●	●	●
v7	4.3 Ensure the Use of Dedicated Administrative Accounts Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.	●	●	●

5.2.3 Ensure sudo log file exists (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `Defaults logfile` entry sets the path to the sudo log file. Setting a path turns on logging to a file; negating this option turns it off. By default, sudo logs via syslog.

Rationale:

Defining a dedicated log file for sudo simplifies auditing of sudo commands and creation of auditd rules for sudo.

Impact:

WARNING: Editing the `sudo` configuration incorrectly can cause `sudo` to stop functioning. Always use `visudo` to modify `sudo` configuration files.

Creation of additional log files can cause disk space exhaustion if not correctly managed. You should configure `logrotate` to manage the sudo log in accordance with your local policy.

Audit:

Run the following command to verify that sudo has a custom log file configured

```
# grep -rPsi
"^\h*Defaults\h+([^#]+,\h*)?logfile\h*=\h*(\"|\')?\H+(\"|\')?(,\h*\H+\h*)*\h*
(#.*)?$" /etc/sudoers*
```

Example output:

```
Defaults logfile="/var/log/sudo.log"
```

Remediation:

Edit the file `/etc/sudoers` or a file in `/etc/sudoers.d/` with `visudo -f <PATH TO FILE>` and add the following line:

```
Defaults  logfile="<PATH TO CUSTOM LOG FILE>"
```

Example

```
Defaults logfile="/var/log/sudo.log"
```

Notes:

- sudo will read each file in `/etc/sudoers.d`, skipping file names that end in `~` or contain a `.` character to avoid causing problems with package manager or editor temporary/backup files.
- Files are parsed in sorted lexical order. That is, `/etc/sudoers.d/01_first` will be parsed before `/etc/sudoers.d/10_second`.
- Be aware that because the sorting is lexical, not numeric, `/etc/sudoers.d/1_whoops` would be loaded after `/etc/sudoers.d/10_second`.
- Using a consistent number of leading zeroes in the file names can be used to avoid such problems.

References:

1. SUDO(8)
2. VISUDO(8)
3. sudoers(5)
4. NIST SP 800-53 Rev. 5: AU-3, AU-12

Additional Information:

visudo edits the sudoers file in a safe fashion, analogous to vipw(8). visudo locks the sudoers file against multiple simultaneous edits, provides basic sanity checks, and checks for parse errors. If the sudoers file is currently being edited you will receive a message to try again later.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

5.2.4 Ensure users must provide password for escalation (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The operating system must be configured so that users must provide a password for privilege escalation.

Rationale:

Without re-authentication, users may access resources or perform tasks for which they do not have authorization.

When operating systems provide the capability to escalate a functional capability, it is critical the user re-authenticate.

Satisfies: SRG-OS-000373-GPOS-00156, SRG-OS-000373-GPOS-00157, SRG-OS-000373-GPOS-00158

Impact:

This will prevent automated processes from being able to elevate privileges.

Audit:

Note: If passwords are not being used for authentication, this is not applicable.

Verify the operating system requires users to supply a password for privilege escalation.

Check the configuration of the `/etc/sudoers` and `/etc/sudoers.d/*` files with the following command:

```
# grep -r "^[^#].*NOPASSWD" /etc/sudoers*
```

If any line is found refer to the remediation procedure below.

Remediation:

Based on the outcome of the audit procedure, use `visudo -f <PATH TO FILE>` to edit the relevant sudoers file.

Remove any line with occurrences of `NOPASSWD` tags in the file.

References:

1. NIST SP 800-53 Rev. 5: AC-6
2. RHEL 8 STIG Vul ID: V-230271
3. RHEL 8 STIG Rule ID: SV-230271r854026

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.	●	●	●
v7	4.3 Ensure the Use of Dedicated Administrative Accounts Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.	●	●	●

5.2.5 Ensure re-authentication for privilege escalation is not disabled globally (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The operating system must be configured so that users must re-authenticate for privilege escalation.

Rationale:

Without re-authentication, users may access resources or perform tasks for which they do not have authorization.

When operating systems provide the capability to escalate a functional capability, it is critical the user re-authenticate.

Audit:

Verify the operating system requires users to re-authenticate for privilege escalation.

Check the configuration of the `/etc/sudoers` and `/etc/sudoers.d/*` files with the following command:

```
# grep -r '^[^#].*!authenticate" /etc/sudoers*'
```

If any line is found with a `!authenticate` tag, refer to the remediation procedure below.

Remediation:

Configure the operating system to require users to reauthenticate for privilege escalation.

Based on the outcome of the audit procedure, use `visudo -f <PATH TO FILE>` to edit the relevant sudoers file.

Remove any occurrences of `!authenticate` tags in the file(s).

References:

1. NIST SP 800-53 Rev. 5: AC-6
2. RHEL 8 STIG Vul ID: V-230272
3. RHEL 8 STIG Rule ID: SV-230272r854027

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.	●	●	●
v7	4.3 Ensure the Use of Dedicated Administrative Accounts Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.	●	●	●

5.2.6 Ensure sudo timestamp_timeout is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`sudo` caches used credentials for a default of 5 minutes. This is for ease of use when there are multiple administrative tasks to perform. The timeout can be modified to suit local security policies.

Rationale:

Setting a timeout value reduces the window of opportunity for unauthorized privileged access to another user.

Audit:

Ensure that the caching timeout is no more than 15 minutes.

Example:

```
# grep -roP "timestamp_timeout=\K[0-9]*" /etc/sudoers*
```

If there is no `timestamp_timeout` configured in `/etc/sudoers*` then the default is 5 minutes. This default can be checked with:

```
# sudo -V | grep "Authentication timestamp timeout:"
```

Note: A value of `-1` means that the timeout is disabled. Depending on the configuration of the `timestamp_type`, this could mean for all terminals / processes of that user and not just that one single terminal session.

Remediation:

If the currently configured timeout is larger than 15 minutes, edit the file listed in the audit section with `visudo -f <PATH TO FILE>` and modify the entry `timestamp_timeout=` to 15 minutes or less as per your site policy. The value is in minutes. This particular entry may appear on its own, or on the same line as `env_reset`. See the following two examples:

```
Defaults    env_reset, timestamp_timeout=15
Defaults    timestamp_timeout=15
Defaults    env_reset
```

References:

1. https://www.sudo.ws/man/1.9.0/sudoers.man.html
2. NIST SP 800-53 :: IA-11
3. RHEL 8 STIG Vul ID: V-237643
4. RHEL 8 STIG Rule ID: SV-237643r861088

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.	●	●	●
v7	4.3 Ensure the Use of Dedicated Administrative Accounts Ensure that all users with administrative account access use a dedicated or secondary account for elevated activities. This account should only be used for administrative activities and not internet browsing, email, or similar activities.	●	●	●

5.2.7 Ensure access to the su command is restricted (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `su` command allows a user to run a command or shell as another user. The program has been superseded by `sudo`, which allows for more granular control over privileged access. Normally, the `su` command can be executed by any user. By uncommenting the `pam_wheel.so` statement in `/etc/pam.d/su`, the `su` command will only allow users in a specific groups to execute `su`. This group should be empty to reinforce the use of `sudo` for privileged access.

Rationale:

Restricting the use of `su` , and using `sudo` in its place, provides system administrators better control of the escalation of user privileges to execute privileged commands. The sudo utility also provides a better logging and audit mechanism, as it can log each command executed via `sudo` , whereas `su` can only record that a user executed the `su` program.

Audit:

Run the following command and verify the output matches the line:

```
# grep -Pi
'^\h*auth\h+(?:required|requisite)\h+pam_wheel\.so\h+(?:[^#\n\r]+\h+)?((?!\2)
(use_uid\b|group=\H+\b))\h+(?:[^#\n\r]+\h+)?((?!\1)(use_uid\b|group=\H+\b))(\
h+.*)?$' /etc/pam.d/su

auth required pam_wheel.so use_uid group=<group_name>
```

Run the following command and verify that the group specified in `<group_name>` contains no users:

```
# grep <group_name> /etc/group

<group_name>:x:<GID>:
```

There should be no users listed after the Group ID field.

Remediation:

Create an empty group that will be specified for use of the `su` command. The group should be named according to site policy.

Example:

```
# groupadd sugroup
```

Add the following line to the `/etc/pam.d/su` file, specifying the empty group:

```
auth required pam_wheel.so use_uid group=sugroup
```

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.3 Pluggable Authentication Modules

Pluggable Authentication Modules (PAM) is a service that implements modular authentication modules on Linux systems. PAM is implemented as a set of shared objects that are loaded and executed when a program needs to authenticate a user. Files for PAM are typically located in the `/etc/pam.d` directory. PAM must be carefully configured to secure system authentication. While this section covers some of PAM, please consult other PAM resources to fully understand the configuration capabilities.

Note: This section includes guidance that requires the additional modules and the latest version of software packages as covered in the "Configure required security packages" subsection of the "Package Management" section

5.3.1 Configure PAM software packages

Updated versions of PAM and authselect include additional functionality

5.3.1.1 Ensure latest version of pam is installed (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Updated versions of PAM include additional functionality

Rationale:

To ensure the system has full functionality and access to the options covered by this Benchmark, pam-1.3.1-25 or latter is required

Audit:

Run the following command to verify the version of PAM on the system:

```
# rpm -q pam
```

The output should be similar to:

```
pam-1.3.1-25.el8.x86_64
```

Remediation:

- IF - the version of PAM on the system is less that version pam-1.3.1-25:

Run the following command to update to the latest version of PAM:

```
# dnf upgrade pam
```

5.3.1.2 Ensure latest version of authselect is installed (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Authselect is a utility that simplifies the configuration of user authentication. Authselect offers ready-made profiles that can be universally used with all modern identity management systems

You can create and deploy a custom profile by customizing one of the default profiles, the sssd, winbind, or the nis profile. This is particularly useful if Modifying a ready-made authselect profile is not enough for your needs. When you deploy a custom profile, the profile is applied to every user logging into the given host. This would be the recommended method, so that the existing profiles can remain unmodified.

Updated versions of `authselect` include additional functionality

Rationale:

Authselect makes testing and troubleshooting easy because it only modifies files in these directories:

- `/etc/nsswitch.conf`
- `/etc/pam.d/*`
- `/etc/dconf/db/distro.d/*`

To ensure the system has full functionality and access to the options covered by this Benchmark, `authselect-1.2.6-1` or latter is required

Impact:

If local site customizations have been made to an authselect default or custom profile created with the `--symlink-pam` option, these customizations may be over-written by updating authselect.

WARNING:

Do not use authselect if:

- Your host is part of Linux Identity Management. Joining your host to an IdM domain with the ipa-client-install command automatically configures SSSD authentication on your host.
- Your host is part of Active Directory via SSSD. Calling the realm join command to join your host to an Active Directory domain automatically configures SSSD authentication on your host.

It is **not** recommended to change the authselect profiles configured by ipa-client-install or realm join. If you need to modify them, display the current settings before making any modifications, so you can revert back to them if necessary

Audit:

Run the following command to verify the version of `authselect` on the system:

```
# rpm -q authselect
```

The output should be similar to:

```
authselect-1.2.6-1.el8.x86_64
```

Remediation:

Run the following command to install `authselect`:

```
# dnf install authselect
```

- IF - the version of `authselect` on the system is less that version `authselect-1.2.6-1`:

Run the following command to update to the latest version of `authselect`:

```
# dnf upgrade authselect
```

5.3.2 Configure authselect

Authselect is a utility that simplifies the configuration of user authentication. Authselect offers ready-made profiles that can be universally used with all modern identity management systems

Authselect makes testing and troubleshooting easy because it only modifies files in these directories:

- `/etc/nsswitch.conf`
- `/etc/pam.d/* files`
- `/etc/dconf/db/distro.d/* files`

You can create and deploy a custom profile by customizing one of the default profiles, the sssd, winbind, or the nis profile. This is particularly useful if Modifying a ready-made authselect profile is not enough for your needs. When you deploy a custom profile, the profile is applied to every user logging into the given host. This would be the recommended method, so that the existing profiles can remain unmodified.

Profile Directories - Profiles can be found in one of three directories:

- `/usr/share/authselect/default` - Read-only directory containing profiles shipped together with authselect.
- `/usr/share/authselect/vendor` - Read-only directory for vendor-specific profiles that can override the ones in default directory.
- `/etc/authselect/custom` - Place for administrator-defined profiles.

Profile Files - Each profile consists of one or more of these files which provide a mandatory profile description and describe the changes that are done to the system:

- `README` - Description of the profile. The first line must be a name of the profile.
- `system-auth` - PAM stack that is included from nearly all individual service configuration files.
- `password-auth`, `smartcard-auth`, `fingerprint-auth` - These PAM stacks are for applications which handle authentication from different types of devices via simultaneously running individual conversations instead of one aggregate conversation.
- `postlogin` - The purpose of this PAM stack is to provide a common place for all PAM modules which should be called after the stack configured in `system-auth` or the other common PAM configuration files. It is included from all individual service configuration files that provide login service with shell or file access. **Note:** the modules in the postlogin configuration file are executed regardless of the success or failure of the modules in the `system-auth` configuration file.
- `nsswitch.conf` - Name Service Switch configuration file. Only maps relevant to the profile must be set. Maps that are not specified by the profile are included from `/etc/authselect/user-nsswitch.conf`.

- `dconf-db` - Changes to dconf database. The main uses case of this file is to set changes for gnome login screen in order to enable or disable smartcard and fingerprint authentication.
- `dconf-locks` - This file define locks on values set in dconf database.

Conditional lines - Each of these files serves as a template. A template is a plain text file with optional usage of several operators that can be used to provide some optional profile features.

- `{continue if "feature"}` - Immediately stop processing of the file unless "feature" is defined (the rest of the file content will be removed). If "feature" is defined, the whole line with this operator will be removed and the rest of the template will be processed.
- `{stop if "feature"}` - Opposite of "continue if". Immediately stop processing of the file if "feature" is defined (the rest of the file content will be removed). If "feature" is not defined, the whole line with this operator will be removed and the rest of the template will be processed.
- `{include if "feature"}` - Include the line where this operator is placed only if "feature" is defined.
- `{exclude if "feature"}` - Opposite to "include-if". Include the line where this operator is placed only if "feature" is not defined.
- `{imply "implied-feature" if "feature"}` - Enable feature "implied-feature" if feature "feature" is enabled. The whole line with this operator is removed, thus it is not possible to add anything else around this operator at the same line.
- `{if "feature":true|false}` - If "feature" is defined, replace this operator with string "true", otherwise with string "false".
- `{if "feature":true}` - If "feature" is defined, replace this operator with string "true", otherwise with an empty string.

Example of creating a custom authselect profile called custom-profile

```
# authselect create-profile custom-profile -b sssd
```

WARNING:

Do not use authselect if:

- Your host is part of Linux Identity Management. Joining your host to an IdM domain with the ipa-client-install command automatically configures SSSD authentication on your host.
- Your host is part of Active Directory via SSSD. Calling the realm join command to join your host to an Active Directory domain automatically configures SSSD authentication on your host.
- It is not recommended to change the authselect profiles configured by ipa-client-install or realm join. If you need to modify them, display the current settings before making any modifications, so you can revert back to them if necessary

5.3.2.1 Ensure active authselect profile includes pam modules (Automated)

Profile Applicability:

- Level 1 - Server

Description:

A custom profile can be created by copying and customizing one of the default profiles. The default profiles include: local, sssd, and winbind. These profile can be customized to follow site specific requirements.

You can select a profile for the authselect utility for a specific host. The profile will be applied to every user logging into the host.

Rationale:

A custom profile is required to customize many of the pam options.

Modifications made to a default profile may be overwritten during an update.

When you deploy a profile, the profile is applied to every user logging into the given host

Impact:

If local site customizations have been made to the authselect template or files in `/etc/pam.d` these custom entries should be added to the newly created custom profile before it's applied to the system.

Note: The order within the pam stacks is important when adding these entries. Specifically for the password stack, the `use_authtok` option is important, and should appear on all modules except for the first entry.

Example:

```
password   requisite   pam_pwquality.so local_users_only #<-- Top of password
stack, doesn't include use_authtok
password   required    pam_pwhistory.so use_authtok #<-- subsequent entry in
password stack, includes use_authtok
```

Audit:

Run the following command to verify the active authselect profile includes lines for the `pwquality`, `pwhistory`, `faillock`, and `unix` modules:

```
# grep -P --
'\b(pam_pwquality\.so|pam_pwhistory\.so|pam_faillock\.so|pam_unix\.so)\b'
/etc/authselect/"$(head -1
/etc/authselect/authselect.conf)"/{system,password}-auth
```

Example output:

```
/etc/authselect/custom/custom-profile/password-auth:auth   required
pam_faillock.so preauth silent {include if "with-faillock"}
/etc/authselect/custom/custom-profile/password-auth:auth   sufficient
pam_unix.so {if not "without-nullok":nullok}
/etc/authselect/custom/custom-profile/password-auth:auth   required
pam_faillock.so authfail {include if "with-faillock"}

/etc/authselect/custom/custom-profile/password-auth:account   required
pam_faillock.so {include if "with-faillock"}
/etc/authselect/custom/custom-profile/password-auth:account   required
pam_unix.so

/etc/authselect/custom/custom-profile/password-auth:password   requisite
pam_pwquality.so local_users_only
/etc/authselect/custom/custom-profile/password-auth:password  required
pam_pwhistory.so use_authtok
/etc/authselect/custom/custom-profile/password-auth:password  sufficient
pam_unix.so sha512 shadow {if not "without-nullok":nullok} use_authtok

/etc/authselect/custom/custom-profile/password-auth:session   required
pam_unix.so


/etc/authselect/custom/custom-profile/system-auth:auth   required
pam_faillock.so preauth silent {include if "with-faillock"}
/etc/authselect/custom/custom-profile/system-auth:auth   sufficient
pam_unix.so {if not "without-nullok":nullok}
/etc/authselect/custom/custom-profile/system-auth:auth   required
pam_faillock.so authfail {include if "with-faillock"}

/etc/authselect/custom/custom-profile/system-auth:account   required
pam_faillock.so {include if "with-faillock"}
/etc/authselect/custom/custom-profile/system-auth:account     required
pam_unix.so

/etc/authselect/custom/custom-profile/system-auth:password   requisite
pam_pwquality.so local_users_only
/etc/authselect/custom/custom-profile/system-auth:password   required
pam_pwhistory.so use_authtok
/etc/authselect/custom/custom-profile/system-auth:password   sufficient
pam_unix.so sha512 shadow {if not "without-nullok":nullok}

/etc/authselect/custom/custom-profile/system-auth:session   required
pam_unix.so
```

Notes:

- The lines may or may not include feature options defined by text surrounded by curly brackets ({}) e.g. `{include if "with-faillock"}`
- File path may be different due to the active profile in use

Remediation:

Perform the following to create a custom authselect profile, with the modules covered in this Benchmark correctly included in the custom profile template files

Run the following command to create a custom authselect profile:

```
# authselect create-profile <custom-profile name> <options>
```

Example:

```
# authselect create-profile custom-profile -b local
```

Run the following command to select a custom authselect profile:

```
# authselect select custom/<CUSTOM PROFILE NAME> {with-<OPTIONS>} {--force}
```

Example:

```
# authselect select custom/custom-profile --backup=PAM_CONFIG_BACKUP --force
```

Notes:

- The PAM and authselect packages must be versions `pam-1.3.1-25` and `authselect-1.2.6-1` or newer
- The example is based on a custom profile built (copied) from the the `local` default authselect profile found in `/usr/share/authselect/default`.
- The example does not include the `symlink` option for the `PAM` or `Metadata` files. This is due to the fact that by linking the `PAM` files future updates to `authselect` may overwrite local site customizations to the custom profile
- The `--backup=PAM_CONFIG_BACKUP` option will create a backup of the current config. The backup will be stored at `/var/lib/authselect/backups/PAM_CONFIG_BACKUP`
- The `--force` option will force the overwrite of the existing files and automatically backup system files before writing any change unless the `--nobackup` option is set.
    - On a new system where authselect has not been configured. In this case, the `--force` option will force the selected authselect profile to be active and overwrite the existing files with files generated from the selected authselect profile's templates
    - On an existing system with a custom configuration. The `--force` option may be used, but **ensure that you note the backup location included as your custom files will be overwritten.** This will allow you to review the changes and add any necessary customizations to the template files for the authselect profile. After updating the templates, run the command `authselect apply-changes` to add these custom entries to the files in `/etc/pam.d/`

- IF - you receive an error ending with a message similar to:

```
[error] Refusing to activate profile unless those changes are removed or
overwrite is requested.
Some unexpected changes to the configuration were detected. Use 'select'
command instead.
```

This error is caused when the previous configuration was not created by authselect but by another tool or by manual changes and the `--force` option will be required to enable the authselect profile.

References:

1. authselect(8)
2. https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/9/html/configuring_authentication_and_authorization_in_rhel/configuring-user-authentication-using-authselect_configuring-authentication-and-authorization-in-rhel#creating-and-deploying-your-own-authselect-profile_configuring-user-authentication-using-authselect
3. https://docs.oracle.com/en/operating-systems/oracle-linux/9/userauth/OL9-USERAUTH.pdf

Additional Information:

with the option `--base-on=BASE-ID` or `-b=BASE-ID` the new profile will be based on a profile named BASE-ID.

The base profile location is determined with these steps:

1. If BASE-ID starts with prefix custom/ it is a custom profile.
2. Try if BASE-ID is found in vendor profiles.
3. Try if BASE-ID is found in default profiles.
4. Return an error.

The authselect option `--force` or `-f` will cause authselect to write changes even if the previous configuration was not created by authselect but by other tool or by manual changes. This option will automatically backup system files before writing any change unless the `--nobackup` option is set.

Example:

```
authselect select custom/custom-profile with-pwhistory with-faillock without-
nullok --backup=PAM_CONFIG_BACKUP --force
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	16.2 Establish and Maintain a Process to Accept and Address Software Vulnerabilities Establish and maintain a process to accept and address reports of software vulnerabilities, including providing a means for external entities to report. The process is to include such items as: a vulnerability handling policy that identifies reporting process, responsible party for handling vulnerability reports, and a process for intake, assignment, remediation, and remediation testing. As part of the process, use a vulnerability tracking system that includes severity ratings, and metrics for measuring timing for identification, analysis, and remediation of vulnerabilities. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard. Third-party application developers need to consider this an externally-facing policy that helps to set expectations for outside stakeholders.		●	●
v7	16.7 Establish Process for Revoking Access Establish and follow an automated process for revoking system access by disabling accounts immediately upon termination or change of responsibilities of an employee or contractor . Disabling these accounts, instead of deleting accounts, allows preservation of audit trails.		●	●

5.3.2.2 Ensure pam_faillock module is enabled (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `pam_faillock.so` module maintains a list of failed authentication attempts per user during a specified interval and locks the account in case there were more than the configured number of consecutive failed authentications (this is defined by the `deny` parameter in the faillock configuration). It stores the failure records into per-user files in the tally directory.

Rationale:

Locking out user IDs after n unsuccessful consecutive login attempts mitigates brute force password attacks against your systems.

Audit:

Run the following commands to verify that `pam_faillock` is enabled

```
# grep -P -- '\bpam_faillock.so\b' /etc/pam.d/{password,system}-auth
```

Output should be similar to:

```
/etc/pam.d/password-auth:auth        required        pam_faillock.so preauth
silent
/etc/pam.d/password-auth:auth        required        pam_faillock.so authfail

/etc/pam.d/password-auth:account     required        pam_faillock.so

/etc/pam.d/system-auth:auth          required        pam_faillock.so preauth
silent
/etc/pam.d/system-auth:auth          required        pam_faillock.so authfail

/etc/pam.d/system-auth:account       required        pam_faillock.so
```

Remediation:

Run the following script to verify the `pam_faillock.so` lines exist in the profile templates:

```
#!/usr/bin/env bash

{
   l_module_name="faillock"
   l_pam_profile="$(head -1 /etc/authselect/authselect.conf)"
   if grep -Pq -- '^custom\/' <<< "$l_pam_profile"; then
      l_pam_profile_path="/etc/authselect/$l_pam_profile"
   else
      l_pam_profile_path="/usr/share/authselect/default/$l_pam_profile"
   fi
   grep -P -- "\bpam_$l_module_name\.so\b"
"$l_pam_profile_path"/{password,system}-auth
}
```

Example Output with a custom profile named "custom-profile":

```
/etc/authselect/custom/custom-profile/password-auth:auth   required
pam_faillock.so preauth silent {include if "with-faillock"}
/etc/authselect/custom/custom-profile/password-auth:auth   required
pam_faillock.so authfail {include if "with-faillock"}
/etc/authselect/custom/custom-profile/password-auth:account   required
pam_faillock.so {include if "with-faillock"}

/etc/authselect/custom/custom-profile/system-auth:auth   required
pam_faillock.so preauth silent {include if "with-faillock"}
/etc/authselect/custom/custom-profile/system-auth:auth   required
pam_faillock.so authfail {include if "with-faillock"}
/etc/authselect/custom/custom-profile/system-auth:account   required
pam_faillock.so  {include if "with-faillock"}
```

Note: The lines may not include `{include if "with-faillock"}`

- IF - the lines shown above are not returned, refer to the Recommendation "Ensure active authselect profile includes pam modules" to update the authselect profile template files to include the `pam_faillock` entries before continuing this remediation.

- IF - the lines include `{include if "with-faillock"}`, run the following command to enable the authselect `with-faillock` feature and update the files in `/etc/pam.d` to include `pam_faillock.so`:

```
# authselect enable-feature with-faillock
```

- IF - any of the `pam_faillock` lines exist without `{include if "with-faillock"}`, run the following command to update the files in `/etc/pam.d` to include `pam_faillock.so`:

```
# authselect apply-changes
```

References:

1. faillock(8) - Linux man page
2. pam_faillock(8) - Linux man page
3. NIST SP 800-53 :: AC-7 a
4. NIST SP 800-53A :: AC-7.1 (ii)
5. RHEL 8 STIG GROUP ID: V-244533
6. RHEL 8 STIG RULE ID: SV-244533r743848
7. RHEL 8 STIG GROUP ID: V-244534
8. RHEL 8 STIG RULE ID: SV-244534r743851

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.1 Establish and Maintain a Secure Configuration Process Establish and maintain a secure configuration process for enterprise assets (end-user devices, including portable and mobile, non-computing/IoT devices, and servers) and software (operating systems and applications). Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.	●	●	●
v7	16.7 Establish Process for Revoking Access Establish and follow an automated process for revoking system access by disabling accounts immediately upon termination or change of responsibilities of an employee or contractor . Disabling these accounts, instead of deleting accounts, allows preservation of audit trails.		●	●

5.3.2.3 Ensure pam_pwquality module is enabled (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `pam_pwquality.so` module performs password quality checking. This module can be plugged into the password stack of a given service to provide strength-checking for passwords. The code was originally based on pam_cracklib module and the module is backwards compatible with its options.

The action of this module is to prompt the user for a password and check its strength against a system dictionary and a set of rules for identifying poor choices.

The first action is to prompt for a single password, check its strength and then, if it is considered strong, prompt for the password a second time (to verify that it was typed correctly on the first occasion). All being well, the password is passed on to subsequent modules to be installed as the new authentication token.

Rationale:

Use of a unique, complex passwords helps to increase the time and resources required to compromise the password.

Audit:

Run the following commands to verify that `pam_pwquality` is enabled:

```
# grep -P -- '\bpam_pwquality\.so\b' /etc/pam.d/{password,system}-auth
```

Output should be similar to:

```
/etc/pam.d/password-auth:password    requisite    pam_pwquality.so
local_users_only
/etc/pam.d/system-auth:password    requisite    pam_pwquality.so
local_users_only
```

Remediation:

Review the authselect profile templates:

Run the following script to verify the `pam_pwquality.so` lines exist in the active profile templates:

```
#!/usr/bin/env bash

{
   l_module_name="pwquality"
   l_pam_profile="$(head -1 /etc/authselect/authselect.conf)"
   if grep -Pq -- '^custom\/' <<< "$l_pam_profile"; then
      l_pam_profile_path="/etc/authselect/$l_pam_profile"
   else
      l_pam_profile_path="/usr/share/authselect/default/$l_pam_profile"
   fi
   grep -P -- "\bpam_$l_module_name\.so\b"
"$l_pam_profile_path"/{password,system}-auth
}
```

Example Output with a custom profile named "custom-profile":

```
/etc/authselect/custom/custom-profile/password-auth:password   requisite
pam_pwquality.so local_users_only {include if "with-pwquality"}

/etc/authselect/custom/custom-profile/system-auth:password   requisite
pam_pwquality.so local_users_only {include if "with-pwquality"}
```

Note: The lines may not include `{include if "with-pwquality"}`

- IF - the lines shown above are not returned, refer to the Recommendation "Ensure active authselect profile includes pam modules" to update the authselect profile template files to include the `pam_pwquality` entries before continuing this remediation.

- IF - any of the `pam_pwquality` lines include `{include if "with-pwquality"}`, run the following command to enable the authselect `with-pwquality` feature and update the files in `/etc/pam.d` to include `pam_pwquality:

```
# authselect enable-feature with-pwquality
```

- IF - any of the `pam_pwquality` lines exist without `{include if "with-pwquality"}`, run the following command to update the files in `/etc/pam.d` to include `pam_pwquality.so`:

```
# authselect apply-changes
```

References:

1. NIST SP 800-53 :: CM-6 b
2. NIST SP 800-53A :: CM-6.1 (iv)
3. RHEL 8 STIG GROUP ID: V-230356
4. RHEL 8 STIG RULE ID: SV-230356r902728
5. RHEL 8 STIG GROUP ID: V-251713
6. RHEL 8 STIG RULE ID: SV-251713r902740

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.3.2.4 Ensure pam_pwhistory module is enabled (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `pam_history.so` module saves the last passwords for each user in order to force password change history and keep the user from alternating between the same password too frequently.

Rationale:

Requiring users not to reuse their passwords make it less likely that an attacker will be able to guess the password or use a compromised password.

Audit:

Run the following commands to verify that `pam_pwhistory` is enabled:

```
# grep -P -- '\bpam_pwhistory\.so\b' /etc/pam.d/{password,system}-auth
```

Output should be similar to:

```
/etc/pam.d/password-auth:password    required    pam_pwhistory.so use_authtok
/etc/pam.d/system-auth:password    required    pam_pwhistory.so use_authtok
```

Remediation:

Run the following script to verify the pam_pwhistory.so lines exist in the profile templates:

```
#!/usr/bin/env bash

{
   l_module_name="pwhistory"
   l_pam_profile="$(head -1 /etc/authselect/authselect.conf)"
   if grep -Pq -- '^custom\/' <<< "$l_pam_profile"; then
      l_pam_profile_path="/etc/authselect/$l_pam_profile"
   else
      l_pam_profile_path="/usr/share/authselect/default/$l_pam_profile"
   fi
   grep -P -- "\bpam_$l_module_name\.so\b"
"$l_pam_profile_path"/{password,system}-auth
}
```

Example Output with a custom profile named "custom-profile":

```
/etc/authselect/custom/custom-profile/password-auth:password   required
pam_pwhistory.so use_authtok {include if "with-pwhistory"}

/etc/authselect/custom/custom-profile/system-auth:password   required
pam_pwhistory.so use_authtok {include if "with-pwhistory"}
```

Note: The lines may not include {include if "with-pwhistory"}

- IF - the lines shown above are not returned, refer to the Recommendation "Ensure active authselect profile includes pam modules" to update the authselect profile template files to include the pam_pwhistory entries before continuing this remediation.

- IF - the lines include {include if "with-pwhistory"}, run the following command to enable the authselect with-pwhistory feature and update the files in /etc/pam.d to include pam_faillock.so:

```
# authselect enable-feature with-pwhistory
```

- IF - any of the pam_pwhistory lines exist without {include if "with-pwhistory"}, run the following command to update the files in /etc/pam.d to include pam_pwhistory.so:

```
# authselect apply-changes
```

References:

1. NIST SP 800-53 Rev. 5: IA-5(1)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.3.2.5 Ensure pam_unix module is enabled (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `pam_unix.so` module is the standard Unix authentication module. It uses standard calls from the system's libraries to retrieve and set account information as well as authentication. Usually this is obtained from the `/etc/passwd` and the `/etc/shadow` file as well if shadow is enabled.

Rationale:

Requiring users to use authentication make it less likely that an attacker will be able to access the system.

Audit:

Run the following commands to verify that `pam_unix` is enabled:

```
# grep -P -- '\bpam_unix\.so\b' /etc/pam.d/{password,system}-auth
```

Output should be similar to:

```
/etc/pam.d/password-auth:auth   sufficient   pam_unix.so
/etc/pam.d/password-auth:account   required   pam_unix.so
/etc/pam.d/password-auth:password   sufficient   pam_unix.so sha512 shadow
use_authtok
/etc/pam.d/password-auth:session  required   pam_unix.so

/etc/pam.d/system-auth:auth   sufficient   pam_unix.so
/etc/pam.d/system-auth:account   required   pam_unix.so
/etc/pam.d/system-auth:password   sufficient   pam_unix.so sha512 shadow
use_authtok
/etc/pam.d/system-auth:session   required   pam_unix.so
```

Remediation:

Run the following script to verify the `pam_unix.so` lines exist in the profile templates:

```
#!/usr/bin/env bash

{
   l_module_name="unix"
   l_pam_profile="$(head -1 /etc/authselect/authselect.conf)"
   if grep -Pq -- '^custom\/' <<< "$l_pam_profile"; then
      l_pam_profile_path="/etc/authselect/$l_pam_profile"
   else
      l_pam_profile_path="/usr/share/authselect/default/$l_pam_profile"
   fi
   grep -P -- "\bpam_$l_module_name\.so\b"
"$l_pam_profile_path"/{password,system}-auth
}
```

Example Output with a custom profile named "custom-profile":

```
/etc/authselect/custom/custom-profile/password-auth:auth   sufficient
pam_unix.so {if not "without-nullok":nullok}
/etc/authselect/custom/custom-profile/password-auth:account   required
pam_unix.so
/etc/authselect/custom/custom-profile/password-auth:password   sufficient
pam_unix.so sha512 shadow {if not "without-nullok":nullok} use_authtok
remember=5
/etc/authselect/custom/custom-profile/password-auth:session   required
pam_unix.so

/etc/authselect/custom/custom-profile/system-auth:auth   sufficient
pam_unix.so {if not "without-nullok":nullok}
/etc/authselect/custom/custom-profile/system-auth:account   required
pam_unix.so
/etc/authselect/custom/custom-profile/system-auth:password   sufficient
pam_unix.so sha512 shadow {if not "without-nullok":nullok} use_authtok
/etc/authselect/custom/custom-profile/system-auth:session   required
pam_unix.so
```

- IF - the lines shown above are not returned, refer to the Recommendation "Ensure active authselect profile includes pam modules" to update the authselect profile template files to include the `pam_unix` entries before continuing this remediation.

Note: Arguments following `pam_unix.so` may be different than the example output

References:

1. NIST SP 800-53 Rev. 5: IA-5(1)

5.3.3 Configure PAM Arguments

Pluggable Authentication Modules (PAM) uses arguments to pass information to a pluggable module during authentication for a particular module type. These arguments allow the PAM configuration files for particular programs to use a common PAM module but in different ways.

Invalid arguments are ignored and do not otherwise affect the success or failure of the PAM module. When an invalid argument is passed, an error is usually written to `/var/log/messages` file. However, since the reporting method is controlled by the PAM module, the module must be written correctly to log the error to this file.

5.3.3.1 Configure pam_faillock module

faillock.conf provides a way to configure the default settings for locking the user after multiple failed authentication attempts. This file is read by the pam_faillock module and is the preferred method over configuring pam_faillock directly.

The file has a very simple name = value format with possible comments starting with # character. The whitespace at the beginning of line, end of line, and around the `=` sign is ignored.

Options:

- `<dir=/path/to/tally-directory>` - The directory where the user files with the failure records are kept. The default is /var/run/faillock. Note: These files will disappear after reboot on systems configured with directory /var/run/faillock mounted on virtual memory.
- `audit` - Will log the user name into the system log if the user is not found.
- `silent` - Don't print informative messages to the user. Please note that when this option is not used there will be difference in the authentication behavior for users which exist on the system and non-existing users.
- `no_log_info` - Don't log informative messages via syslog(3).
- `local_users_only` - Only track failed user authentications attempts for local users in /etc/passwd and ignore centralized (AD, IdM, LDAP, etc.) users. The faillock(8) command will also no longer track user failed authentication attempts. Enabling this option will prevent a double-lockout scenario where a user is locked out locally and in the centralized mechanism.
- `nodelay` - Don't enforce a delay after authentication failures.
- `deny=<n>` - Deny access if the number of consecutive authentication failures for this user during the recent interval exceeds . The default is 3.
- `fail_interval=n` - The length of the interval during which the consecutive authentication failures must happen for the user account lock out is n seconds. The default is 900 (15 minutes).
- `unlock_time=n` - The access will be re-enabled after n seconds after the lock out. The value 0 has the same meaning as value never - the access will not be re-enabled without resetting the faillock entries by the faillock(8) command. The default is 600 (10 minutes). Note that the default directory that pam_faillock uses is usually cleared on system boot so the access will be also re-enabled after system reboot. If that is undesirable a different tally directory must be set with the dir option. Also note that it is usually undesirable to permanently lock out users as they can become easily a target of denial of service attack unless the usernames are random and kept secret to potential attackers.
- `even_deny_root` - Root account can become locked as well as regular accounts.
- `root_unlock_time=n` - This option implies even_deny_root option. Allow access after n seconds to root account after the account is locked. In case the option is not specified the value is the same as of the unlock_time option.
- `admin_group=name` - If a group name is specified with this option, members of the group will be handled by this module the same as the root account (the

options even_deny_root and root_unlock_time will apply to them. By default the option is not set.

Example /etc/security/faillock.conf file:

```
deny=5
unlock_time=900
even_deny_root
```

5.3.3.1.1 Ensure password failed attempts lockout is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The deny=n option will deny access if the number of consecutive authentication failures for this user during the recent interval exceeds *n*.

Rationale:

Locking out user IDs after *n* unsuccessful consecutive login attempts mitigates brute force password attacks against your systems.

Audit:

Run the following command to verify that Number of failed logon attempts before the account is locked is no greater than 5 and meets local site policy:

```
# grep -Pi -- '^\h*deny\h*=\h*[1-5]\b' /etc/security/faillock.conf

deny = 5
```

Run the following command to verify that the deny argument has not been set, or is set to 5 or less and meets local site policy:

```
# grep -Pi --
'^\h*auth\h+(requisite|required|sufficient)\h+pam_faillock\.so\h+([^#\n\r]+\h
+)?deny\h*=\h*(0|[6-9]|[1-9][0-9]+)\b' /etc/pam.d/system-auth
/etc/pam.d/password-auth
```

Nothing should be returned.

Remediation:

Create or edit the following line in `/etc/security/faillock.conf` setting the `deny` option to `5` or less:

```
deny = 5
```

Run the following script to remove the `deny` argument from the `pam_faillock.so` module in the PAM files:

```
#!/usr/bin/env bash

{
   for l_pam_file in system-auth password-auth; do
     l_authselect_file="/etc/authselect/$(head -1
/etc/authselect/authselect.conf | grep 'custom/')/$l_pam_file"
     sed -ri
's/(^\s*auth\s+(requisite|required|sufficient)\s+pam_faillock\.so.*)(\s+deny\
s*=\s*\S+)(.*$)/\1\4/' "$l_authselect_file"
   done
   authselect apply-changes
}
```

Default Value:

deny = 3

Additional Information:

If a user has been locked out because they have reached the maximum consecutive failure count defined by `deny=` in the `pam_faillock.so` module, the user can be unlocked by issuing the command `faillock --user <USERNAME> --reset`. This command sets the failed count to 0, effectively unlocking the user.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.2 Establish an Access Revoking Process Establish and follow a process, preferably automated, for revoking access to enterprise assets, through disabling accounts immediately upon termination, rights revocation, or role change of a user. Disabling accounts, instead of deleting accounts, may be necessary to preserve audit trails.	●	●	●
v7	16.7 Establish Process for Revoking Access Establish and follow an automated process for revoking system access by disabling accounts immediately upon termination or change of responsibilities of an employee or contractor . Disabling these accounts, instead of deleting accounts, allows preservation of audit trails.		●	●

5.3.3.1.2 Ensure password unlock time is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`unlock_time=n` - The access will be re-enabled after *n* seconds after the lock out. The value `0` has the same meaning as value never - the access will not be re-enabled without resetting the faillock entries by the faillock(8) command.

Notes:

- The default directory that pam_faillock uses is usually cleared on system boot so the access will be also re-enabled after system reboot. If that is undesirable a different tally directory must be set with the dir option.
- It is usually undesirable to permanently lock out users as they can become easily a target of denial of service attack unless the usernames are random and kept secret to potential attackers.
- The maximum configurable value for `unlock_time` is `604800`

Rationale:

Locking out user IDs after *n* unsuccessful consecutive login attempts mitigates brute force password attacks against your systems.

Impact:

Use of `unlock_time=0` may allow an attacker to cause denial of service to legitimate users. This will also require a systems administrator with elevated privileges to unlock the account.

Audit:

Run the following command to verify that the time in seconds before the account is unlocked is either `0` (never) or `900` (15 minutes) or more and meets local site policy:

```
# grep -Pi -- '^\h*unlock_time\h*=\h*(0|9[0-9][0-9]|[1-9][0-9]{3,})\b'
/etc/security/faillock.conf

unlock_time = 900
```

Run the following command to verify that the `unlock_time` argument has not been set, or is either `0` (never) or `900` (15 minutes) or more and meets local site policy:

```
# grep -Pi --
'^\h*auth\h+(requisite|required|sufficient)\h+pam_faillock\.so\h+([^#\n\r]+\h
+)?unlock_time\h*=\h*([1-9]|[1-9][0-9]|[1-8][0-9][0-9])\b' /etc/pam.d/system-
auth /etc/pam.d/password-auth
```

Nothing should be returned.

Remediation:

Set password unlock time to conform to site policy. `unlock_time` should be `0` (never), or `900` seconds or greater.

Edit `/etc/security/faillock.conf` and update or add the following line:

```
unlock_time = 900
```

Run the following script to remove the `unlock_time` argument from the `pam_faillock.so` module in the PAM files:

```
#!/usr/bin/env bash

{
   for l_pam_file in system-auth password-auth; do
     l_authselect_file="/etc/authselect/$(head -1
/etc/authselect/authselect.conf | grep 'custom/')/$l_pam_file"
     sed -ri
's/(^\s*auth\s+(requisite|required|sufficient)\s+pam_faillock\.so.*)(\s+unloc
k_time\s*=\s*\S+)(.*$)/\1\4/' "$l_authselect_file"
   done
   authselect apply-changes
}
```

Default Value:

unlock_time = 600

Additional Information:

If a user has been locked out because they have reached the maximum consecutive failure count defined by `deny=` in the `pam_faillock.so` module, the user can be unlocked by issuing the command `faillock --user <USERNAME> --reset`. This command sets the failed count to 0, effectively unlocking the user.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.2 Establish an Access Revoking Process Establish and follow a process, preferably automated, for revoking access to enterprise assets, through disabling accounts immediately upon termination, rights revocation, or role change of a user. Disabling accounts, instead of deleting accounts, may be necessary to preserve audit trails.	●	●	●
v7	16.7 Establish Process for Revoking Access Establish and follow an automated process for revoking system access by disabling accounts immediately upon termination or change of responsibilities of an employee or contractor . Disabling these accounts, instead of deleting accounts, allows preservation of audit trails.		●	●

5.3.3.1.3 Ensure password failed attempts lockout includes root account (Automated)

Profile Applicability:

- Level 2 - Server

Description:

`even_deny_root` - Root account can become locked as well as regular accounts

`root_unlock_time=n` - This option implies even_deny_root option. Allow access after n seconds to root account after the account is locked. In case the option is not specified the value is the same as of the unlock_time option.

Rationale:

Locking out user IDs after n unsuccessful consecutive login attempts mitigates brute force password attacks against your systems.

Impact:

Use of `unlock_time=0` or `root_unlock_time=0` may allow an attacker to cause denial of service to legitimate users.

Audit:

Run the following command to verify that `even_deny_root` and/or `root_unlock_time` is enabled:

```
# grep -Pi -- '^\h*(even_deny_root|root_unlock_time\h*=\h*\d+)\b'
/etc/security/faillock.conf
```

Example output:

```
even_deny_root

--AND/OR--

root_unlock_time = 60
```

Run the following command to verify that **- IF -** `root_unlock_time` is set, it is set to `60` (One minute) or more:

```
# grep -Pi -- '^\h*root_unlock_time\h*=\h*([1-9]|[1-5][0-9])\b'
/etc/security/faillock.conf

Nothing should be returned
```

Run the following command to check the `pam_faillock.so` module for the `root_unlock_time` argument. Verify **- IF -** `root_unlock_time` is set, it is set to `60` (One minute) or more:

```
# grep -Pi --
'^\h*auth\h+([^#\n\r]+\h+)pam_faillock\.so\h+([^#\n\r]+\h+)?root_unlock_time\
h*=\h*([1-9]|[1-5][0-9])\b' /etc/pam.d/system-auth /etc/pam.d/password-auth

Nothing should be returned
```

Remediation:

Edit `/etc/security/faillock.conf`:

- Remove or update any line containing `root_unlock_time`, **- OR -** set it to a value of `60` or more
- Update or add the following line:

```
even_deny_root
```

Run the following script to remove the `even_deny_root` and `root_unlock_time` arguments from the `pam_faillock.so` module in the PAM files:

```
#!/usr/bin/env bash

{
   for l_pam_file in system-auth password-auth; do
     l_authselect_file="/etc/authselect/$(head -1
/etc/authselect/authselect.conf | grep 'custom/')/$l_pam_file"
     sed -ri
's/(^\s*auth\s+(.*)\s+pam_faillock\.so.*)(\s+even_deny_root)(.*$)/\1\4/'
"$l_authselect_file"
     sed -ri
's/(^\s*auth\s+(.*)\s+pam_faillock\.so.*)(\s+root_unlock_time\s*=\s*\S+)(.*$)
/\1\4/' "$l_authselect_file"
   done
   authselect apply-changes
}
```

Default Value:

disabled

Additional Information:

If a user has been locked out because they have reached the maximum consecutive failure count defined by `deny=` in the `pam_faillock.so` module, the user can be unlocked by issuing the command `faillock --user <USERNAME> --reset`. This command sets the failed count to 0, effectively unlocking the user.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.2 Establish an Access Revoking Process Establish and follow a process, preferably automated, for revoking access to enterprise assets, through disabling accounts immediately upon termination, rights revocation, or role change of a user. Disabling accounts, instead of deleting accounts, may be necessary to preserve audit trails.	●	●	●
v7	16.7 Establish Process for Revoking Access Establish and follow an automated process for revoking system access by disabling accounts immediately upon termination or change of responsibilities of an employee or contractor . Disabling these accounts, instead of deleting accounts, allows preservation of audit trails.		●	●

5.3.3.2 Configure pam_pwquality module

The `pam_pwquality.so` module checks the strength of passwords. It performs checks such as making sure a password is not a dictionary word, it is a certain length, contains a mix of characters (e.g. alphabet, numeric, other) and more.

These checks are configurable by either:

- use of the module arguments
- modifying the `/etc/security/pwquality.conf` configuration file
- creating a `.conf` file in the `/etc/security/pwquality.conf.d/` directory.

Note:

- The module arguments override the settings in the `/etc/security/pwquality.conf` configuration file.
- Settings in the `/etc/security/pwquality.conf` configuration file override settings in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory.

5.3.3.2.1 Ensure password number of changed characters is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `pwquality difok` option sets the number of characters in a password that must not be present in the old password.

Rationale:

Use of a complex password helps to increase the time and resources required to compromise the password. Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks.

Password complexity is one factor of several that determines how long it takes to crack a password. The more complex the password, the greater the number of possible combinations that need to be tested before the password is compromised.

Audit:

Run the following command to verify that the `difok` option is set to `2` or more and follows local site policy:

```
# grep -Psi -- '^\h*difok\h*=\h*([2-9]|[1-9][0-9]+)\b'
/etc/security/pwquality.conf /etc/security/pwquality.conf.d/*.conf
```

Example output:

```
/etc/security/pwquality.conf.d/50-pwdifok.conf:difok = 2
```

Verify returned value(s) are `2` or more and meet local site policy

Run the following command to verify that `difok` is not set, is `2` or more, and conforms to local site policy:

```
# grep -Psi --
'^\h*password\h+(requisite|required|sufficient)\h+pam_pwquality\.so\h+([^#\n\
r]+\h+)?difok\h*=\h*([0-1])\b' /etc/pam.d/system-auth /etc/pam.d/password-
auth
```

Nothing should be returned.

Notes:

- settings should be configured in only **one** location for clarity
- Settings observe an order of precedence:
  - module arguments override the settings in the `/etc/security/pwquality.conf` configuration file
  - settings in the `/etc/security/pwquality.conf` configuration file override settings in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory
  - settings in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory are read in canonical order, with last read file containing the setting taking precedence
- It is recommended that settings be configured in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory for clarity, convenience, and durability.

Remediation:

Create or modify a file ending in `.conf` in the `/etc/security/pwquality.conf.d/` directory or the file `/etc/security/pwquality.conf` and add or modify the following line to set `difok` to `2` or more. Ensure setting conforms to local site policy:

```
difok = 2
```

Example:

```
# sed -ri 's/^\s*difok\s*=/# &/' /etc/security/pwquality.conf
# printf '%s\n' "" "difok = 2" >> /etc/security/pwquality.conf.d/50-
pwdifok.conf
```

Run the following script to remove setting `difok` on the `pam_pwquality.so` module in the PAM files:

```
#!/usr/bin/env bash

{
   for l_pam_file in system-auth password-auth; do
     l_authselect_file="/etc/authselect/$(head -1
/etc/authselect/authselect.conf | grep 'custom/')/$l_pam_file"
     sed -ri
's/(^\s*password\s+(requisite|required|sufficient)\s+pam_pwquality\.so.*)(\s+
difok\s*=\s*\S+)(.*$)/\1\4/' "$l_authselect_file"
   done
   authselect apply-changes
}
```

Default Value:

difok = 1

References:

1. NIST SP 800-53 Rev. 5: IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.3.3.2.2 Ensure password length is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`minlen` - Minimum acceptable size for the new password (plus one if credits are not disabled which is the default). Cannot be set to lower value than 6.

Rationale:

Strong passwords protect systems from being hacked through brute force methods.

Audit:

Run the following command to verify that password length is `14` or more characters, and conforms to local site policy:

```
# grep -Psi -- '^\h*minlen\h*=\h*(1[4-9]|[2-9][0-9]|[1-9][0-9]{2,})\b'
/etc/security/pwquality.conf /etc/security/pwquality.conf.d/*.conf
```

Example output:

```
/etc/security/pwquality.conf.d/50-pwlength.conf:minlen = 14
```

Verify returned value(s) are no less than `14` characters and meet local site policy

Run the following command to verify that `minlen` is not set, or is `14` or more characters, and conforms to local site policy:

```
# grep -Psi --
'^\h*password\h+(requisite|required|sufficient)\h+pam_pwquality\.so\h+([^#\n\
r]+\h+)?minlen\h*=\h*([0-9]|1[0-3])\b' /etc/pam.d/system-auth
/etc/pam.d/password-auth
```

Nothing should be returned.

Notes:

- settings should be configured in only **one** location for clarity
- Settings observe an order of precedence:
  - module arguments override the settings in the `/etc/security/pwquality.conf` configuration file
  - settings in the `/etc/security/pwquality.conf` configuration file override settings in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory
  - settings in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory are read in canonical order, with last read file containing the setting taking precedence
- It is recommended that settings be configured in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory for clarity, convenience, and durability.

Remediation:

Create or modify a file ending in `.conf` in the `/etc/security/pwquality.conf.d/` directory or the file `/etc/security/pwquality.conf` and add or modify the following line to set password length of `14` or more characters. Ensure that password length conforms to local site policy:

Example:

```
# sed -ri 's/^\s*minlen\s*=/# &/' /etc/security/pwquality.conf
# printf '%s\n' "" "minlen = 14" >> /etc/security/pwquality.conf.d/50-
pwlength.conf
```

Run the following script to remove setting `minlen` on the `pam_pwquality.so` module in the PAM files:

```
#!/usr/bin/env bash

{
   for l_pam_file in system-auth password-auth; do
     l_authselect_file="/etc/authselect/$(head -1
/etc/authselect/authselect.conf | grep 'custom/')/$l_pam_file"
     sed -ri
's/(^\s*password\s+(requisite|required|sufficient)\s+pam_pwquality\.so.*)(\s+
minlen\s*=\s*[0-9]+)(.*$)/\1\4/' "$l_authselect_file"
   done
   authselect apply-changes
}
```

Default Value:

minlen = 8

References:

1. pam_pwquality(8)
2. NIST SP 800-53 Rev. 5: IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.3.3.2.3 Ensure password complexity is configured (Manual)

Profile Applicability:

- Level 1 - Server

Description:

Password complexity can be set through:

- `minclass` - The minimum number of classes of characters required in a new password. (digits, uppercase, lowercase, others). e.g. `minclass = 4` requires digits, uppercase, lower case, and special characters.
- `dcredit` - The maximum credit for having digits in the new password. If less than `0` it is the minimum number of digits in the new password. e.g. `dcredit = -1` requires at least one digit
- `ucredit` - The maximum credit for having uppercase characters in the new password. If less than 0 it is the minimum number of uppercase characters in the new password. e.g. `ucredit = -1` requires at least one uppercase character
- `ocredit` - The maximum credit for having other characters in the new password. If less than 0 it is the minimum number of other characters in the new password. e.g. `ocredit = -1` requires at least one special character
- `lcredit` - The maximum credit for having lowercase characters in the new password. If less than 0 it is the minimum number of lowercase characters in the new password. e.g. `lcredit = -1` requires at least one lowercase character

Rationale:

Strong passwords protect systems from being hacked through brute force methods.

Audit:

Run the following command to verify that complexity conforms to local site policy:

```
# grep -Psi -- '^\h*(minclass|[dulo]credit)\b' /etc/security/pwquality.conf
/etc/security/pwquality.conf.d/*.conf
```

Example output:

```
/etc/security/pwquality.conf.d/50-pwcomplexity.conf:minclass = 4
  -- AND/OR --
/etc/security/pwquality.conf.d/50-pwcomplexity.conf:dcredit = -1
/etc/security/pwquality.conf.d/50-pwcomplexity.conf:ucredit = -1
/etc/security/pwquality.conf.d/50-pwcomplexity.conf:ocredit = -1
/etc/security/pwquality.conf.d/50-pwcomplexity.conf:lcredit = -1
```

Run the following command to verify that:

- `minclass` is not set to less than `4`
- `dcredit`, `ucredit`, `lcredit`, and `ocredit` are not set to `0` or greater

```
# grep -Psi --
'^\h*password\h+(requisite|required|sufficient)\h+pam_pwquality\.so\h+([^#\n\
r]+\h+)?(minclass=[0-3]|[dulo]credit=[^-]\d*)\b' /etc/pam.d/system-auth
/etc/pam.d/password-auth
```

Nothing should be returned.

Notes:

- settings should be configured in only **one** location for clarity
- Settings observe an order of precedence:
  - module arguments override the settings in the `/etc/security/pwquality.conf` configuration file
  - settings in the `/etc/security/pwquality.conf` configuration file override settings in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory
  - settings in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory are read in canonical order, with last read file containing the setting taking precedence
- It is recommended that settings be configured in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory for clarity, convenience, and durability.

Remediation:

Create or modify a file ending in `.conf` in the `/etc/security/pwquality.conf.d/` directory or the file `/etc/security/pwquality.conf` and add or modify the following line to set:

- `minclass = 4`

--AND/OR--

- `dcredit = -_N_`
- `ucredit = -_N_`
- `ocredit = -_N_`
- `lcredit = -_N_`

Example:

```
# sed -ri 's/^\s*minclass\s*=/# &/' /etc/security/pwquality.conf
# printf '\n%s' "minclass = 4" >> /etc/security/pwquality.conf.d/50-
pwcomplexity.conf
```

--AND/OR--

```
# sed -ri 's/^\s*[dulo]credit\s*=/# &/' /etc/security/pwquality.conf
# printf '%s\n' "" "dcredit = -1" "ucredit = -1" "ocredit = -1" "lcredit = -
1" > /etc/security/pwquality.conf.d/50-pwcomplexity.conf
```

Run the following script to remove setting `minclass`, `dcredit`, `ucredit`, `lcredit`, and `ocredit` on the `pam_pwquality.so` module in the PAM files

```
#!/usr/bin/env bash

{
   for l_pam_file in system-auth password-auth; do
     l_authselect_file="/etc/authselect/$(head -1
/etc/authselect/authselect.conf | grep 'custom/')/$l_pam_file"
     sed -ri
's/(^\s*password\s+(requisite|required|sufficient)\s+pam_pwquality\.so.*)(\s+
minclass\s*=\s*\S+)(.*$)/\1\4/' "$l_authselect_file"
     sed -ri
's/(^\s*password\s+(requisite|required|sufficient)\s+pam_pwquality\.so.*)(\s+
dcredit\s*=\s*\S+)(.*$)/\1\4/' "$l_authselect_file"
     sed -ri
's/(^\s*password\s+(requisite|required|sufficient)\s+pam_pwquality\.so.*)(\s+
ucredit\s*=\s*\S+)(.*$)/\1\4/' "$l_authselect_file"
     sed -ri
's/(^\s*password\s+(requisite|required|sufficient)\s+pam_pwquality\.so.*)(\s+
lcredit\s*=\s*\S+)(.*$)/\1\4/' "$l_authselect_file"
     sed -ri
's/(^\s*password\s+(requisite|required|sufficient)\s+pam_pwquality\.so.*)(\s+
ocredit\s*=\s*\S+)(.*$)/\1\4/' "$l_authselect_file"
   done
   authselect apply-changes
}
```

Default Value:

minclass = 0

dcredit = 0

ucredit = 0

ocredit = 0

lcredit = 0

References:

1. pam_pwquality(8)
2. PWQUALITY.CONF(5)
3. NIST SP 800-53 Rev. 5: IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.3.3.2.4 Ensure password same consecutive characters is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `pwquality maxrepeat` option sets the maximum number of allowed same consecutive characters in a new password.

Rationale:

Use of a complex password helps to increase the time and resources required to compromise the password. Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks.

Password complexity is one factor of several that determines how long it takes to crack a password. The more complex the password, the greater the number of possible combinations that need to be tested before the password is compromised.

Audit:

Run the following command to verify that the `maxrepeat` option is set to `3` or less, not `0`, and follows local site policy:

```
# grep -Psi -- '^\h*maxrepeat\h*=\h*[1-3]\b' /etc/security/pwquality.conf
/etc/security/pwquality.conf.d/*.conf
```

Example output:

```
/etc/security/pwquality.conf.d/50-pwrepeat.conf:maxrepeat = 3
```

Verify returned value(s) are `3` or less, not `0`, and meet local site policy

Run the following command to verify that `maxrepeat` is not set, is `3` or less, not `0`, and conforms to local site policy:

```
# grep -Psi --
'^\h*password\h+(requisite|required|sufficient)\h+pam_pwquality\.so\h+([^#\n\
r]+\h+)?maxrepeat\h*=\h*(0|[4-9]|[1-9][0-9]+)\b' /etc/pam.d/system-auth
/etc/pam.d/password-auth
```

Nothing should be returned.

Notes:

- settings should be configured in only **one** location for clarity
- Settings observe an order of precedence:
  - module arguments override the settings in the `/etc/security/pwquality.conf` configuration file
  - settings in the `/etc/security/pwquality.conf` configuration file override settings in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory
  - settings in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory are read in canonical order, with last read file containing the setting taking precedence
- It is recommended that settings be configured in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory for clarity, convenience, and durability.

Remediation:

Create or modify a file ending in `.conf` in the `/etc/security/pwquality.conf.d/` directory or the file `/etc/security/pwquality.conf` and add or modify the following line to set `maxrepeat` to `3` or less and not `0`. Ensure setting conforms to local site policy:

Example:

```
# sed -ri 's/^\s*maxrepeat\s*=/# &/' /etc/security/pwquality.conf
# printf '%s\n' "" "maxrepeat = 3" >> /etc/security/pwquality.conf.d/50-
pwrepeat.conf
```

Run the following script to remove setting `maxrepeat` on the `pam_pwquality.so` module in the PAM files:

```
#!/usr/bin/env bash

{
   for l_pam_file in system-auth password-auth; do
     l_authselect_file="/etc/authselect/$(head -1
/etc/authselect/authselect.conf | grep 'custom/')/$l_pam_file"
     sed -ri
's/(^\s*password\s+(requisite|required|sufficient)\s+pam_pwquality\.so.*)(\s+
maxrepeat\s*=\s*\S+)(.*$)/\1\4/' "$l_authselect_file"
   done
   authselect apply-changes
}
```

Default Value:

maxrepeat = 0

References:

1. NIST SP 800-53 :: IA-5 (1) (b)
2. NIST SP 800-53A :: IA-5 (1).1 (v)
3. RHEL 8 STIG GROUP ID: V-230361
4. RHEL 8 STIG RULE ID: SV-230361r858779

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.3.3.2.5 Ensure password maximum sequential characters is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `pwquality maxsequence` option sets the maximum length of monotonic character sequences in the new password. Examples of such sequence are `12345` or `fedcb`. The check is disabled if the value is `0`.

Note: Most such passwords will not pass the simplicity check unless the sequence is only a minor part of the password.

Rationale:

Use of a complex password helps to increase the time and resources required to compromise the password. Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks.

Password complexity is one factor of several that determines how long it takes to crack a password. The more complex the password, the greater the number of possible combinations that need to be tested before the password is compromised.

Audit:

Run the following command to verify that the `maxsequence` option is set to `3` or less, not `0`, and follows local site policy:

```
# grep -Psi -- '^\h*maxsequence\h*=\h*[1-3]\b' /etc/security/pwquality.conf
/etc/security/pwquality.conf.d/*.conf
```

Example output:

```
/etc/security/pwquality.conf.d/50-pwmaxsequence.conf:maxsequence = 3
```

Verify returned value(s) are `3` or less, not `0`, and meet local site policy

Run the following command to verify that `maxsequence` is not set, is `3` or less, not `0`, and conforms to local site policy:

```
# grep -Psi --
'^\h*password\h+(requisite|required|sufficient)\h+pam_pwquality\.so\h+([^#\n\
r]+\h+)?maxsequence\h*=\h*(0|[4-9]|[1-9][0-9]+)\b' /etc/pam.d/system-auth
/etc/pam.d/password-auth
```

Nothing should be returned.

Note:

- settings should be configured in only **one** location for clarity
- Settings observe an order of precedence:
  - module arguments override the settings in the `/etc/security/pwquality.conf` configuration file
  - settings in the `/etc/security/pwquality.conf` configuration file override settings in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory
  - settings in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory are read in canonical order, with last read file containing the setting taking precedence
- It is recommended that settings be configured in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory for clarity, convenience, and durability.

Remediation:

Create or modify a file ending in `.conf` in the `/etc/security/pwquality.conf.d/` directory or the file `/etc/security/pwquality.conf` and add or modify the following line to set `maxsequence` to `3` or less and not `0`. Ensure setting conforms to local site policy:

Example:

```
# sed -ri 's/^\s*maxsequence\s*=/# &/' /etc/security/pwquality.conf
# printf '%s\n' "" "maxsequence = 3" >> /etc/security/pwquality.conf.d/50-
pwmaxsequence.conf
```

Run the following script to remove setting `maxsequence` on the `pam_pwquality.so` module in the PAM files:

```
#!/usr/bin/env bash

{
   for l_pam_file in system-auth password-auth; do
     l_authselect_file="/etc/authselect/$(head -1
/etc/authselect/authselect.conf | grep 'custom/')/$l_pam_file"
     sed -ri
's/(^\s*password\s+(requisite|required|sufficient)\s+pam_pwquality\.so.*)(\s+
maxsequence\s*=\s*\S+)(.*$)/\1\4/' "$l_authselect_file"
   done
   authselect apply-changes
}
```

Default Value:

maxsequence = 0

References:

1. NIST SP 800-53 Rev. 5: IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.3.3.2.6 Ensure password dictionary check is enabled (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `pwquality dictcheck` option sets whether to check for the words from the `cracklib` dictionary.

Rationale:

If the operating system allows the user to select passwords based on dictionary words, this increases the chances of password compromise by increasing the opportunity for successful guesses, and brute-force attacks.

Audit:

Run the following command to verify that the `dictcheck` option is not set to `0` (disabled) in a pwquality configuration file:

```
# grep -Psi -- '^\h*dictcheck\h*=\h*0\b' /etc/security/pwquality.conf
/etc/security/pwquality.conf.d/*.conf
```

Nothing should be returned.

Run the following command to verify that the `dictcheck` option is not set to `0` (disabled) as a module argument in a PAM file:

```
# grep -Psi --
'^\h*password\h+(requisite|required|sufficient)\h+pam_pwquality\.so\h+([^#\n\
r]+\h+)?dictcheck\h*=\h*0\b' /etc/pam.d/system-auth /etc/pam.d/password-auth
```

Nothing should be returned.

Notes:

- Settings observe an order of precedence:
  - module arguments override the settings in the `/etc/security/pwquality.conf` configuration file
  - settings in the `/etc/security/pwquality.conf` configuration file override settings in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory
  - settings in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory are read in canonical order, with last read file containing the setting taking precedence
- It is recommended that settings be configured in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory for clarity, convenience, and durability.

Remediation:

Edit any file ending in `.conf` in the `/etc/security/pwquality.conf.d/` directory and/or the file `/etc/security/pwquality.conf` and comment out or remove any instance of `dictcheck = 0`:

Example:

```
# sed -ri 's/^\s*dictcheck\s*=/# &/' /etc/security/pwquality.conf
/etc/security/pwquality.conf.d/*.conf
```

Run the following script to remove setting `dictcheck` on the `pam_pwquality.so` module in the PAM files:

```
#!/usr/bin/env bash

{
   for l_pam_file in system-auth password-auth; do
     l_authselect_file="/etc/authselect/$(head -1
/etc/authselect/authselect.conf | grep 'custom/')/$l_pam_file"
     sed -ri
's/(^\s*password\s+(requisite|required|sufficient)\s+pam_pwquality\.so.*)(\s+
dictcheck\s*=\s*\S+)(.*$)/\1\4/' "$l_authselect_file"
   done
   authselect apply-changes
}
```

Default Value:

dictcheck = 1

References:

1. NIST SP 800-53 Rev. 5: IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.3.3.2.7 Ensure password quality is enforced for the root user (Automated)

Profile Applicability:

- Level 1 - Server

Description:

If the `pwquality enforce_for_root` option is enabled, the module will return error on failed check even if the user changing the password is root.

This option is off by default which means that just the message about the failed check is printed but root can change the password anyway.

Note: The root is not asked for an old password so the checks that compare the old and new password are not performed.

Rationale:

Use of a complex password helps to increase the time and resources required to compromise the password. Password complexity, or strength, is a measure of the effectiveness of a password in resisting attempts at guessing and brute-force attacks.

Password complexity is one factor of several that determines how long it takes to crack a password. The more complex the password, the greater the number of possible combinations that need to be tested before the password is compromised.

Audit:

Run the following command to verify that the `enforce_for_root` option is enabled in a pwquality configuration file:

```
# grep -Psi -- '^\h*enforce_for_root\b' /etc/security/pwquality.conf
/etc/security/pwquality.conf.d/*.conf
```

Example output:

```
/etc/security/pwquality.conf.d/50-pwroot.conf:enforce_for_root
```

Notes:

- Settings observe an order of precedence:
  - module arguments override the settings in the `/etc/security/pwquality.conf` configuration file
  - settings in the `/etc/security/pwquality.conf` configuration file override settings in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory
  - settings in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory are read in canonical order, with last read file containing the setting taking precedence
- It is recommended that settings be configured in a `.conf` file in the `/etc/security/pwquality.conf.d/` directory for clarity, convenience, and durability.

Remediation:

Edit or add the following line in a `*.conf` file in `/etc/security/pwquality.conf.d` or in `/etc/security/pwquality.conf`:

Example:

```
# printf '%s\n' "" "enforce_for_root" >> /etc/security/pwquality.conf.d/50-
pwroot.conf
```

Default Value:

disabled

References:

1. NIST SP 800-53 Rev. 5: IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.3.3.3 Configure pam_pwhistory module

pam_pwhistory - PAM module to remember last passwords

pam_history.so module - This module saves the last passwords for each user in order to force password change history and keep the user from alternating between the same password too frequently.

This module does not work together with kerberos. In general, it does not make much sense to use this module in conjunction with NIS or LDAP, since the old passwords are stored on the local machine and are not available on another machine for password history checking.

Options:

- debug - Turns on debugging via syslog(3).
- use_authtok - When password changing enforce the module to use the new password provided by a previously stacked password module (this is used in the example of the stacking of the pam_passwdqc module documented below).
- enforce_for_root - If this option is set, the check is enforced for root, too.
- remember=<N> - The last <*N*> passwords for each user are saved. The default is 10. Value of 0 makes the module to keep the existing contents of the opasswd file unchanged.
- retry=<N> - Prompt user at most <*N*> times before returning with error. The default is 1.
- authtok_type=<STRING> - See pam_get_authtok(3) for more details.
- conf=</path/to/config-file> - Use another configuration file instead of the default /etc/security/pwhistory.conf.

Examples:

```
An example password section would be:

    #%PAM-1.0
    password     required       pam_pwhistory.so
    password     required       pam_unix.so        use_authtok

In combination with pam_passwdqc:

    #%PAM-1.0
    password     required       pam_passwdqc.so    config=/etc/passwdqc.conf
    password     required       pam_pwhistory.so   use_authtok
    password     required       pam_unix.so        use_authtok
```

The options for configuring the module behavior are described in the pwhistory.conf(5) manual page. The options specified on the module command line override the values from the configuration file.

pwhistory.conf provides a way to configure the default settings for saving the last passwords for each user. This file is read by the pam_pwhistory module and is the preferred method over configuring pam_pwhistory directly.

The file has a very simple name = value format with possible comments starting with # character. The whitespace at the beginning of line, end of line, and around the `=` sign is ignored.

Options:

- `debug` - Turns on debugging via syslog(3).
- `enforce_for_root` - If this option is set, the check is enforced for root, too.
- `remember=<N>` - The last <*N*> passwords for each user are saved. The default is `10`. Value of `0` makes the module to keep the existing contents of the opasswd file unchanged.
- `retry=<N>` - Prompt user at most <*N*> times before returning with error. The default is `1`.
- `file=</path/filename>` - Store password history in file *`</path/filename>`* rather than the default location. The default location is `/etc/security/opasswd`.

5.3.3.3.1 Ensure password history remember is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/etc/security/opasswd` file stores the users' old passwords and can be checked to ensure that users are not recycling recent passwords. The number of passwords remembered is set via the remember argument value in set for the `pam_pwhistory` module.

- remember=<N> - `<N>` is the number of old passwords to remember

Rationale:

Requiring users not to reuse their passwords make it less likely that an attacker will be able to guess the password or use a compromised password.

Note: These change only apply to accounts configured on the local system.

Audit:

Run the following command and verify that the remember option is set to `24` or more and meets local site policy in `/etc/security/pwhistory.conf`:

```
# grep -Pi -- '^\h*remember\h*=\h*(2[4-9]|[3-9][0-9]|[1-9][0-9]{2,})\b'
/etc/security/pwhistory.conf

remember = 24
```

Run the following command to verify that the remember option is not set to less than `24` on the `pam_pwhistory.so` module in `/etc/pam.d/password-auth` and `/etc/pam.d/system-auth`:

```
# grep -Pi --
'^\h*password\h+(requisite|required|sufficient)\h+pam_pwhistory\.so\h+([^#\n\
r]+\h+)?remember=(2[0-3]|1[0-9]|[0-9])\b' /etc/pam.d/system-auth
/etc/pam.d/password-auth
```

Nothing should be returned.

Remediation:

Edit or add the following line in `/etc/security/pwhistory.conf`:

```
remember = 24
```

Run the following script to remove the `remember` argument from the `pam_pwhistory.so` module in `/etc/pam.d/system-auth` and `/etc/pam.d/password-auth`:

```
#!/usr/bin/env bash

{
   for l_pam_file in system-auth password-auth; do
     l_authselect_file="/etc/authselect/$(head -1
/etc/authselect/authselect.conf | grep 'custom/')/$l_pam_file"
     sed -ri
's/(^\s*password\s+(requisite|required|sufficient)\s+pam_pwhistory\.so.*)(\s+
remember\s*=\s*\S+)(.*$)/\1\4/' "$l_authselect_file"
   done
   authselect apply-changes
}
```

References:

1. NIST SP 800-53 Rev. 5: IA-5(1)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.3.3.3.2 Ensure password history is enforced for the root user (Automated)

Profile Applicability:

- Level 1 - Server

Description:

If the `pwhistory` `enforce_for_root` option is enabled, the module will enforce password history for the root user as well

Rationale:

Requiring users not to reuse their passwords make it less likely that an attacker will be able to guess the password or use a compromised password

Note: These change only apply to accounts configured on the local system.

Audit:

Run the following command to verify that the `enforce_for_root` option is enabled in `/etc/security/pwhistory.conf`:

```
# grep -Pi -- '^\h*enforce_for_root\b' /etc/security/pwhistory.conf

enforce_for_root
```

Notes:

- Settings observe an order of precedence.
- Module arguments override the settings in the `/etc/security/pwhistory.conf` configuration file
- It is recommended that settings be configured in `/etc/security/pwhistory.conf` for clarity, convenience, and durability.

Remediation:

Edit or add the following line in `/etc/security/pwhistory.conf`:

```
enforce_for_root
```

Default Value:

disabled

References:

1. NIST SP 800-53 Rev. 5: IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.3.3.3.3 Ensure pam_pwhistory includes use_authtok (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`use_authtok` - When password changing enforce the module to set the new password to the one provided by a previously stacked password module

Rationale:

`use_authtok` allows multiple pam modules to confirm a new password before it is accepted.

Audit:

Run the following command to verify that `use_authtok` is set on the `pam_pwhistory.so` module lines in the password stack:

```
# grep -P --
'^\h*password\h+([^#\n\r]+)\h+pam_pwhistory\.so\h+([^#\n\r]+\h+)?use_authtok\
b' /etc/pam.d/{password,system}-auth
```

Output should be similar to:

```
/etc/pam.d/password-auth:password    required    pam_pwhistory.so use_authtok

/etc/pam.d/system-auth:password    required    pam_pwhistory.so use_authtok
```

Verify that the lines include `use_authtok`

Remediation:

Run the following script to verify the active authselect profile includes `use_authtok` on the password stack's `pam_pwhistory.so` module lines:

```
#!/usr/bin/env bash

{
   l_pam_profile="$(head -1 /etc/authselect/authselect.conf)"
   if grep -Pq -- '^custom\/' <<< "$l_pam_profile"; then
      l_pam_profile_path="/etc/authselect/$l_pam_profile"
   else
      l_pam_profile_path="/usr/share/authselect/default/$l_pam_profile"
   fi
   grep -P --
'^\h*password\h+(requisite|required|sufficient)\h+pam_pwhistory\.so\h+([^#\n\
r]+\h+)?use_authtok\b' "$l_pam_profile_path"/{password,system}-auth
}
```

Example output:

```
/etc/authselect/custom/custom-profile/password-auth:password   required
pam_pwhistory.so use_authtok

/etc/authselect/custom/custom-profile/system-auth:password   required
pam_pwhistory.so use_authtok
```

- IF - the output does not include `use_authtok`, run the following script:

```
#!/usr/bin/env bash

{
   l_pam_profile="$(head -1 /etc/authselect/authselect.conf)"
   if grep -Pq -- '^custom\/' <<< "$l_pam_profile"; then
      l_pam_profile_path="/etc/authselect/$l_pam_profile"
   else
      l_pam_profile_path="/usr/share/authselect/default/$l_pam_profile"
   fi
   for l_authselect_file in "$l_pam_profile_path"/password-auth
"$l_pam_profile_path"/system-auth; do
      if  grep -Pq
'^\h*password\h+([^#\n\r]+)\h+pam_pwhistory\.so\h+([^#\n\r]+\h+)?use_authtok\
b' "$l_authselect_file"; then
         echo "- \"use_authtok\" is already set"
      else
         echo "- \"use_authtok\" is not set. Updating template"
         sed -ri
's/(^\s*password\s+(requisite|required|sufficient)\s+pam_pwhistory\.so\s+.*)$
/& use_authtok/g' "$l_authselect_file"
      fi
   done
}
```

Run the following command to update the `password-auth` and `system-auth` files in `/etc/pam.d` to include the `use_authtok` argument on the password stack's `pam_pwhistory.so` lines:

```
# authselect apply-changes
```

References:

1. NIST SP 800-53 Rev. 5: IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	16.4 Encrypt or Hash all Authentication Credentials Encrypt or hash with a salt all authentication credentials when stored.		●	●

5.3.3.4 Configure pam_unix module

The `pam_unix.so` module is the standard Unix authentication module. It uses standard calls from the system's libraries to retrieve and set account information as well as authentication. Usually this is obtained from the `/etc/passwd` and the `/etc/shadow` file as well if shadow is enabled.

5.3.3.4.1 Ensure pam_unix does not include nullok (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `nullok` argument overrides the default action of `pam_unix.so` to not permit the user access to a service if their official password is blank.

Rationale:

Using a strong password is essential to helping protect personal and sensitive information from unauthorized access

Audit:

Run the following command to verify that the `nullok` argument is not set on the `pam_unix.so` module:

```
# grep -P --
'^\h*(auth|account|password|session)\h+(requisite|required|sufficient)\h+pam_
unix\.so\b' /etc/pam.d/{password,system}-auth
```

Verify that none of the returned lines includes `nullok`. Output should be similar to:

```
/etc/pam.d/password-auth:auth   sufficient   pam_unix.so
/etc/pam.d/password-auth:account   required   pam_unix.so
/etc/pam.d/password-auth:password   sufficient   pam_unix.so sha512 shadow
use_authtok
/etc/pam.d/password-auth:session   required   pam_unix.so

/etc/pam.d/system-auth:auth   sufficient   pam_unix.so
/etc/pam.d/system-auth:account   required   pam_unix.so
/etc/pam.d/system-auth:password   sufficient   pam_unix.so sha512 shadow
use_authtok
/etc/pam.d/system-auth:session   required   pam_unix.so
```

Remediation:

Run the following script to verify that the active authselect profile's `system-auth` and `password-auth` files include `{if not "without-nullok":nullok}` **- OR -** don't include the `nullok` option on the `pam_unix.so` module:

```
{
   l_module_name="unix"
   l_profile_name="$(head -1 /etc/authselect/authselect.conf)"
   if [[ ! "$l_profile_name" =~ ^custom\/ ]]; then
      printf '%s\n' " - Follow Recommendation \"Ensure pam_unix module is
enabled\"" \
      "    and then return to this Recommendation"
   else
      grep -P -- "\bpam_$l_module_name\.so\b"
/etc/authselect/$l_profile_name/{password,system}-auth
   fi
}
```

Example output with a custom profile named "custom-profile":

```
/etc/authselect/custom/custom-profile/password-auth:auth   sufficient
pam_unix.so {if not "without-nullok":nullok}
/etc/authselect/custom/custom-profile/password-auth:account   required
pam_unix.so
/etc/authselect/custom/custom-profile/password-auth:password   sufficient
pam_unix.so sha512 shadow {if not "without-nullok":nullok} use_authtok
/etc/authselect/custom/custom-profile/password-auth:session   required
pam_unix.so

/etc/authselect/custom/custom-profile/system-auth:auth   sufficient
pam_unix.so {if not "without-nullok":nullok}
/etc/authselect/custom/custom-profile/system-auth:account   required
pam_unix.so
/etc/authselect/custom/custom-profile/system-auth:password   sufficient
pam_unix.so sha512 shadow {if not "without-nullok":nullok} use_authtok
/etc/authselect/custom/custom-profile/system-auth:session   required
pam_unix.so
```

- IF - any line is returned with `nullok` that doesn't also include `{if not "without-nullok":nullok}`, run the following script:

```
#!/usr/bin/env bash

{
   for l_pam_file in system-auth password-auth; do
      l_file="/etc/authselect/$(head -1 /etc/authselect/authselect.conf |
grep 'custom/')/$l_pam_file"
      sed -ri
's/(^\s*(auth|account|password|session)\s+(requisite|required|sufficient)\s+p
am_unix\.so\s+.*)(nullok)(\s*.*)$/\1\2\4/g' $l_file
   done
}
```

- IF - any line is returned with `{if not "without-nullok":nullok}`, run the following command to enable the authselect `without-nullok` feature:

```
# authselect enable-feature without-nullok
```

Run the following command to update the files in `/etc/pam.d` to include `pam_unix.so` without the `nullok` argument:

```
# authselect apply-changes
```

References:

1. NIST SP 800-53 :: CM-6 b
2. NIST SP 800-53A :: CM-6.1 (iv)
3. RHEL 8 STIG GROUP ID: V-244540
4. RHEL 8 STIG RULE ID: SV-244540r743869
5. RHEL 8 STIG GROUP ID: V-244541
6. RHEL 8 STIG RULE ID: SV-244541r743872

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.3.3.4.2 Ensure pam_unix does not include remember (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `remember=n` argument saves the last n passwords for each user in `/etc/security/opasswd` in order to force password change history and keep the user from alternating between the same password too frequently. The MD5 password hash algorithm is used for storing the old passwords. Instead of this option the `pam_pwhistory` module should be used. The `pam_pwhistory` module saves the last n passwords for each user in `/etc/security/opasswd` using the password hash algorithm set on the `pam_unix` module. This allows for the `sha512` hash algorithm to be used.

Rationale:

The `remember=n` argument should be removed to ensure a strong password hashing algorithm is being used. A stronger hash provides additional protection to the system by increasing the level of effort needed for an attacker to successfully determine local user's old passwords stored in `/etc/security/opasswd`.

Audit:

Run the following command to verify that the `remember` argument is not set on the `pam_unix.so` module:

```
# grep -Pi '^\h*password\h+([^#\n\r]+\h+)?pam_unix\.so\b'
/etc/pam.d/{password,system}-auth | grep -Pv '\bremember=\d\b'
```

Output should be similar to:

```
/etc/pam.d/password-auth:password    sufficient    pam_unix.so sha512 shadow
use_authtok

/etc/pam.d/system-auth:password    sufficient    pam_unix.so sha512 shadow
use_authtok
```

Remediation:

Run the following script to verify the active authselect profile doesn't include the `remember` argument on the `pam_unix.so` module lines:

```
#!/usr/bin/env bash

{
   l_pam_profile="$(head -1 /etc/authselect/authselect.conf)"
   if grep -Pq -- '^custom\/' <<< "$l_pam_profile"; then
      l_pam_profile_path="/etc/authselect/$l_pam_profile"
   else
      l_pam_profile_path="/usr/share/authselect/default/$l_pam_profile"
   fi
   grep -P -- '^\h*password\h+([^#\n\r]+\h+)pam_unix\.so\b'
"$l_pam_profile_path"/{password,system}-auth
}
```

Output should be similar to:

```
/etc/authselect/custom/custom-profile/password-auth:password   sufficient
pam_unix.so sha512 shadow {if not "without-nullok":nullok} use_authtok

/etc/authselect/custom/custom-profile/system-auth:password   sufficient
pam_unix.so sha512 shadow {if not "without-nullok":nullok} use_authtok
```

- IF - any line includes `remember=`, run the following script to remove the `remember=` from the `pam_unix.so` lines in the active authselect profile `password-auth` and system-auth` templates:

```
#!/usr/bin/env bash

{
   l_pam_profile="$(head -1 /etc/authselect/authselect.conf)"
   if grep -Pq -- '^custom\/' <<< "$l_pam_profile"; then
      l_pam_profile_path="/etc/authselect/$l_pam_profile"
   else
      l_pam_profile_path="/usr/share/authselect/default/$l_pam_profile"
   fi
   for l_authselect_file in "$l_pam_profile_path"/password-auth
"$l_pam_profile_path"/system-auth; do
      sed -ri
's/(^\s*password\s+(requisite|required|sufficient)\s+pam_unix\.so\s+.*)(remem
ber=[1-9][0-9]*)(\s*.*)$/\1\4/g' "$l_authselect_file"
   done
}
```

Run the following command to update the `password-auth` and system-auth`files in`/etc/pam.d `to include pam_unix.so without the remember` argument:

```
# authselect apply-changes
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.3.3.4.3 Ensure pam_unix includes a strong password hashing algorithm (Automated)

Profile Applicability:

- Level 1 - Server

Description:

A cryptographic hash function converts an arbitrary-length input into a fixed length output. Password hashing performs a one-way transformation of a password, turning the password into another string, called the hashed password.

Rationale:

The `SHA-512` and `yescrypt` algorithms provide a stronger hash than other algorithms used by Linux for password hash generation. A stronger hash provides additional protection to the system by increasing the level of effort needed for an attacker to successfully determine local user passwords.

Note: These changes only apply to the local system.

Audit:

Note: `yescrypt` is not currently supported in Fedora 28 based distributions. It has been included as an acceptable option if it becomes available in a future update to the Operating System.

Run the following command to verify that a strong password hashing algorithm is set on the pam_unix.so module:

```
# grep -P --
'^\h*password\h+([^#\n\r]+)\h+pam_unix\.so\h+([^#\n\r]+\h+)?(sha512|yescrypt)
\b' /etc/pam.d/{password,system}-auth
```

Output should be similar to:

```
/etc/pam.d/password-auth:password   sufficient   pam_unix.so sha512 shadow
use_authtok

/etc/pam.d/system-auth:password   sufficient   pam_unix.so sha512 shadow
use_authtok
```

Verify that the lines include either `sha512` **- OR -** `yescrypt`

Remediation:

Notes:

- If `yescrypt` becomes available in a future release, this would also be acceptable. It is highly recommended that the chosen hashing algorithm is consistent across `/etc/libuser.conf`, `/etc/login.defs`, `/etc/pam.d/password-auth`, and `/etc/pam.d/system-auth`.
- This only effects local users and passwords created after updating the files to use `sha512` or `yescrypt`. If it is determined that the password algorithm being used is not `sha512` or `yescrypt`, once it is changed, it is recommended that all user ID's be immediately expired and forced to change their passwords on next login.

Run the following script to verify the active authselect profile includes a strong password hashing algorithm on the password stack's pam_unix.so module lines:

```
#!/usr/bin/env bash

{
   l_pam_profile="$(head -1 /etc/authselect/authselect.conf)"
   if grep -Pq -- '^custom\/' <<< "$l_pam_profile"; then
      l_pam_profile_path="/etc/authselect/$l_pam_profile"
   else
      l_pam_profile_path="/usr/share/authselect/default/$l_pam_profile"
   fi
   grep -P --
'^\h*password\h+(requisite|required|sufficient)\h+pam_unix\.so\h+([^#\n\r]+\h
+)?(sha512|yescrypt)\b' "$l_pam_profile_path"/{password,system}-auth
}
```

Example output:

```
/etc/authselect/custom/custom-profile/password-auth:password   sufficient
pam_unix.so sha512 shadow {if not "without-nullok":nullok} use_authtok

/etc/authselect/custom/custom-profile/system-auth:password   sufficient
pam_unix.so sha512 shadow {if not "without-nullok":nullok} use_authtok
```

- IF - the output does not include either `sha512` **- OR -** `yescrypt`, or includes a different hashing algorithm, run the following script:

```
#!/usr/bin/env bash

{
   l_pam_profile="$(head -1 /etc/authselect/authselect.conf)"
   if grep -Pq -- '^custom\/' <<< "$l_pam_profile"; then
      l_pam_profile_path="/etc/authselect/$l_pam_profile"
   else
      l_pam_profile_path="/usr/share/authselect/default/$l_pam_profile"
   fi
   for l_authselect_file in "$l_pam_profile_path"/password-auth
"$l_pam_profile_path"/system-auth; do
      if grep -Pq
'^\h*password\h+()\h+pam_unix\.so\h+([^#\n\r]+\h+)?(sha512|yescrypt)\b'
"$l_authselect_file"; then
         echo "- A strong password hashing algorithm is correctly set"
      elif grep -Pq
'^\h*password\h+()\h+pam_unix\.so\h+([^#\n\r]+\h+)?(md5|bigcrypt|sha256|blowf
ish)\b' "$l_authselect_file"; then
         echo "- A weak password hashing algorithm is set, updating to
\"sha512\""
         sed -ri
's/(^\s*password\s+(requisite|required|sufficient)\s+pam_unix\.so\s+.*)(md5|b
igcrypt|sha256|blowfish)(\s*.*)$/\1\4 sha512/g' "$l_authselect_file"
      else
         echo "No password hashing algorithm is set, updating to \"sha512\""
         sed -ri
's/(^\s*password\s+(requisite|required|sufficient)\s+pam_unix\.so\s+.*)$/&
sha512/g' "$l_authselect_file"
      fi
   done
}
```

Run the following command to update the `password-auth` and `system-auth` files in `/etc/pam.d` to include `pam_unix.so` with a strong password hashing algorithm argument:

```
# authselect apply-changes
```

References:

1. NIST SP 800-53 Rev. 5: IA-5

Additional Information:

Additional module options may be set, recommendation only covers those listed here.

The following command may be used to expire all non-system user ID's immediately and force them to change their passwords on next login. Any system accounts that need to be expired should be carefully done separately by the system administrator to prevent any potential problems.

```
# awk -F: '( $3<'"$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)"' && $1 !=
"nfsnobody" ) { print $1 }' /etc/passwd | xargs -n 1 chage -d 0
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	16.4 Encrypt or Hash all Authentication Credentials Encrypt or hash with a salt all authentication credentials when stored.		●	●

5.3.3.4.4 Ensure pam_unix includes use_authtok (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`use_authtok` - When password changing enforce the module to set the new password to the one provided by a previously stacked password module

Rationale:

`use_authtok` allows multiple pam modules to confirm a new password before it is accepted.

Audit:

Run the following command to verify that `use_authtok` is set on the `pam_unix.so` module lines in the password stack:

```
# grep -P --
'^\h*password\h+([^#\n\r]+)\h+pam_unix\.so\h+([^#\n\r]+\h+)?use_authtok\b'
/etc/pam.d/{password,system}-auth
```

Output should be similar to:

```
/etc/pam.d/password-auth:password    sufficient    pam_unix.so sha512 shadow
use_authtok

/etc/pam.d/system-auth:password    sufficient    pam_unix.so sha512 shadow
use_authtok
```

Verify that the lines include `use_authtok`

Remediation:

Run the following script to verify the active authselect profile includes `use_authtok` on the password stack's `pam_unix.so` module lines:

```
#!/usr/bin/env bash

{
   l_pam_profile="$(head -1 /etc/authselect/authselect.conf)"
   if grep -Pq -- '^custom\/' <<< "$l_pam_profile"; then
      l_pam_profile_path="/etc/authselect/$l_pam_profile"
   else
      l_pam_profile_path="/usr/share/authselect/default/$l_pam_profile"
   fi
   grep -P --
'^\h*password\h+(requisite|required|sufficient)\h+pam_unix\.so\h+([^#\n\r]+\h
+)?use_authtok\b' "$l_pam_profile_path"/{password,system}-auth
}
```

Example output:

```
/etc/authselect/custom/custom-profile/password-auth:password   sufficient
pam_unix.so sha512 shadow {if not "without-nullok":nullok} use_authtok

/etc/authselect/custom/custom-profile/system-auth:password   sufficient
pam_unix.so sha512 shadow {if not "without-nullok":nullok} use_authtok
```

- IF - the output does not include `use_authtok`, run the following script:

```
#!/usr/bin/env bash

{
   l_pam_profile="$(head -1 /etc/authselect/authselect.conf)"
   if grep -Pq -- '^custom\/' <<< "$l_pam_profile"; then
      l_pam_profile_path="/etc/authselect/$l_pam_profile"
   else
      l_pam_profile_path="/usr/share/authselect/default/$l_pam_profile"
   fi
   for l_authselect_file in "$l_pam_profile_path"/password-auth
"$l_pam_profile_path"/system-auth; do
      if  grep -Pq
'^\h*password\h+([^#\n\r]+)\h+pam_unix\.so\h+([^#\n\r]+\h+)?use_authtok\b'
"$l_authselect_file"; then
         echo "- \"use_authtok\" is already set"
      else
         echo "- \"use_authtok\" is not set. Updating template"
         sed -ri
's/(^\s*password\s+(requisite|required|sufficient)\s+pam_unix\.so\s+.*)$/&
use_authtok/g' "$l_authselect_file"
      fi
   done
}
```

Run the following command to update the `password-auth` and `system-auth` files in `/etc/pam.d` to include the `use_authtok` argument on the password stack's `pam_unix.so` lines:

```
# authselect apply-changes
```

References:

1. NIST SP 800-53 Rev. 5: IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	16.4 Encrypt or Hash all Authentication Credentials Encrypt or hash with a salt all authentication credentials when stored.		●	●

5.4 User Accounts and Environment

This section provides guidance on setting up secure defaults for system and user accounts and their environment.

5.4.1 Configure shadow password suite parameters

While a majority of the password control parameters have been moved to PAM, some parameters are still available through the shadow password suite. Any changes made to `/etc/login.defs` will only be applied if the `usermod` command is used. If user IDs are added a different way, use the `chage` command to effect changes to individual user IDs.

5.4.1.1 Ensure password expiration is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `PASS_MAX_DAYS` parameter in `/etc/login.defs` allows an administrator to force passwords to expire once they reach a defined age.

`PASS_MAX_DAYS` <*N*> - The maximum number of days a password may be used. If the password is older than this, a password change will be forced. If not specified, -1 will be assumed (which disables the restriction).

Rationale:

The window of opportunity for an attacker to leverage compromised credentials or successfully compromise credentials via an online brute force attack is limited by the age of the password. Therefore, reducing the maximum age of a password also reduces an attacker's window of opportunity.

We recommend a yearly password change. This is primarily because for all their good intentions users will share credentials across accounts. Therefore, even if a breach is publicly identified, the user may not see this notification, or forget they have an account on that site. This could leave a shared credential vulnerable indefinitely. Having an organizational policy of a 1-year (annual) password expiration is a reasonable compromise to mitigate this with minimal user burden.

Impact:

The password expiration must be greater than the minimum days between password changes or users will be unable to change their password.

Excessive password expiration requirements do more harm than good, because these requirements make users select predictable passwords, composed of sequential words and numbers that are closely related to each other. In these cases, the next password can be predicted based on the previous one (incrementing a number used in the password for example). Also, password expiration requirements offer no containment benefits because attackers will often use credentials as soon as they compromise them. Instead, immediate password changes should be based on key events including, but not limited to:

- Indication of compromise
- Change of user roles
- When a user leaves the organization.

Not only does changing passwords every few weeks or months frustrate the user, but it's also been suggested that it does more harm than good, because it could lead to bad practices by the user such as adding a character to the end of their existing password.

Audit:

Run the following command and verify `PASS_MAX_DAYS` is set to 365 days or less and conforms to local site policy:

```
# grep -Pi -- '^\h*PASS_MAX_DAYS\h+\d+\b' /etc/login.defs
```

Example output:

```
PASS_MAX_DAYS 365
```

Run the following command to verify all `/etc/shadow` passwords `PASS_MAX_DAYS`:

- is greater than `0` days
- is less than or equal to `365` days
- conforms to local site policy

```
# awk -F: '($2~/^\$.+\$/) {if($5 > 365 || $5 < 1)print "User: " $1 "
PASS_MAX_DAYS: " $5}' /etc/shadow
```

Nothing should be returned

Remediation:

Set the PASS_MAX_DAYS parameter to conform to site policy in /etc/login.defs :

```
PASS_MAX_DAYS 365
```

Modify user parameters for all users with a password set to match:

```
# chage --maxdays 365 <user>
```

Edit /etc/login.defs and set PASS_MAX_DAYS to a value greater than 0 that follows local site policy:

Example:

```
PASS_MAX_DAYS 365
```

Run the following command to modify user parameters for all users with a password set to a maximum age no greater than 365 or less than 1 that follows local site policy:

```
# chage --maxdays <N> <user>
```

Example:

```
# awk -F: '($2~/^\$.+\$/) {if($5 > 365 || $5 < 1)system ("chage --maxdays 365
" $1)}' /etc/shadow
```

Warning: If a password has been set at system install or kickstart, the last change date field is not set, In this case, setting PASS_MAX_DAYS will immediately expire the password. One possible solution is to populate the last change date field through a command like: chage -d "$(date +%Y-%m-%d)" root

Default Value:

PASS_MAX_DAYS 99999

References:

1. CIS Password Policy Guide
2. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5

Additional Information:

A value of -1 will disable password expiration.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.4.1.2 Ensure minimum password days is configured (Manual)

Profile Applicability:

- Level 2 - Server

Description:

`PASS_MIN_DAYS` <*N*> - The minimum number of days allowed between password changes. Any password changes attempted sooner than this will be rejected. If not specified, 0 will be assumed (which disables the restriction).

Rationale:

Users may have favorite passwords that they like to use because they are easy to remember and they believe that their password choice is secure from compromise. Unfortunately, passwords are compromised and if an attacker is targeting a specific individual user account, with foreknowledge of data about that user, reuse of old, potentially compromised passwords, may cause a security breach.

By restricting the frequency of password changes, an administrator can prevent users from repeatedly changing their password in an attempt to circumvent password reuse controls

Impact:

If a users password is set by other personnel as a procedure in dealing with a lost or expired password, the user should be forced to update this "set" password with their own password. e.g. force "change at next logon".

If it is not possible to have a user set their own password immediately, and this recommendation or local site procedure may cause a user to continue using a third party generated password, `PASS_MIN_DAYS` for the effected user should be temporally changed to `0`via `chage --mindays <user>`, to allow a user to change their password immediately.

For applications where the user is not using the password at console, the ability to "change at next logon" may be limited. This may cause a user to continue to use a password created by other personnel.

Audit:

Run the following command to verify that `PASS_MIN_DAYS` is set to a value greater than `0` and follows local site policy:

```
# grep -Pi -- '^\h*PASS_MIN_DAYS\h+\d+\b' /etc/login.defs
```

Example output:

```
PASS_MIN_DAYS   1
```

Run the following command to verify all passwords have a `PASS_MIN_DAYS` greater than `0`:

```
# awk -F: '($2~/^\$.+\$/) {if($4 < 1)print "User: " $1 " PASS_MIN_DAYS: "
$4}' /etc/shadow
```

Nothing should be returned

Remediation:

Edit `/etc/login.defs` and set `PASS_MIN_DAYS` to a value greater than `0` that follows local site policy:

Example:

```
PASS_MIN_DAYS 1
```

Run the following command to modify user parameters for all users with a password set to a minimum days greater than zero that follows local site policy:

```
# chage --mindays <N> <user>
```

Example:

```
# awk -F: '($2~/^\$.+\$/) {if($4 < 1)system ("chage --mindays 1 " $1)}'
/etc/shadow
```

Default Value:

PASS_MIN_DAYS 0

References:

1. CIS Password Policy Guide
2. NIST SP 800-53 :: IA-5 (1) (d)
3. NIST SP 800-53A :: IA-5 (1).1 (v)
4. STIG ID: RHEL-08-020180 | Rule ID: SV-230364r627750 | CAT II
5. STIG ID: RHEL-08-020190 | Rule ID: SV-230365r858727 | CAT II
6. STIG ID: UBTU-20-010007 | Rule ID: SV-238202r1015140 | CAT III
7. STIG ID: UBTU-22-411025 | Rule ID: SV-260545r1015007 | CAT III

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.4.1.3 Ensure password expiration warning days is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The PASS_WARN_AGE parameter in /etc/login.defs allows an administrator to notify users that their password will expire in a defined number of days.

PASS_WARN_AGE <*N*> - The number of days warning given before a password expires. A zero means warning is given only upon the day of expiration, a negative value means no warning is given. If not specified, no warning will be provided.

Rationale:

Providing an advance warning that a password will be expiring gives users time to think of a secure password. Users caught unaware may choose a simple password or write it down where it may be discovered.

Audit:

Run the following command and verify PASS_WARN_AGE is 7 or more and follows local site policy:

```
# grep -Pi -- '^\h*PASS_WARN_AGE\h+\d+\b' /etc/login.defs
```

Example output:

```
PASS_WARN_AGE 7
```

Run the following command to verify all passwords have a PASS_WARN_AGE of 7 or more:

```
# awk -F: '($2~/^\$.+\$/) {if($6 < 7)print "User: " $1 " PASS_WARN_AGE: "
$6}' /etc/shadow
```

Nothing should be returned

Remediation:

Edit `/etc/login.defs` and set `PASS_WARN_AGE` to a value of `7` or more that follows local site policy:

Example:

```
PASS_WARN_AGE 7
```

Run the following command to modify user parameters for all users with a password set to a minimum warning to `7` or more days that follows local site policy:

```
# chage --warndays <N> <user>
```

Example:

```
# awk -F: '($2~/^\$.+\$/) {if($6 < 7)system ("chage --warndays 7 " $1)}'
/etc/shadow
```

Default Value:

PASS_WARN_AGE 7

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.4.1.4 Ensure strong password hashing algorithm is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

A cryptographic hash function converts an arbitrary-length input into a fixed length output. Password hashing performs a one-way transformation of a password, turning the password into another string, called the hashed password.

`ENCRYPT_METHOD` (string) - This defines the system default encryption algorithm for encrypting passwords (if no algorithm are specified on the command line). It can take one of these values:

- `MD5` - MD5-based algorithm will be used for encrypting password
- `SHA256` - SHA256-based algorithm will be used for encrypting password
- `SHA512` - SHA512-based algorithm will be used for encrypting password
- `BCRYPT` - BCRYPT-based algorithm will be used for encrypting password
- `YESCRYPT` - YESCRYPT-based algorithm will be used for encrypting password
- `DES` - DES-based algorithm will be used for encrypting password (default)

Note:

- This parameter overrides the deprecated `MD5_CRYPT_ENAB` variable.
- This parameter will only affect the generation of group passwords.
- The generation of user passwords is done by PAM and subject to the PAM configuration.
- It is recommended to set this variable consistently with the PAM configuration.

Rationale:

The `SHA-512` and `yescrypt` algorithms provide a stronger hash than other algorithms used by Linux for password hash generation. A stronger hash provides additional protection to the system by increasing the level of effort needed for an attacker to successfully determine local group passwords.

Audit:

Run the following command to verify the hashing algorithm is `sha512` or `yescrypt` in `/etc/login.defs`:

```
# grep -Pi -- '^\h*ENCRYPT_METHOD\h+(SHA512|YESCRYPT)\b' /etc/login.defs
```

Example output:

```
ENCRYPT_METHOD SHA512
 - OR -
ENCRYPT_METHOD YESCRYPT
```

Remediation:

Edit `/etc/login.defs` and set the `ENCRYPT_METHOD` to `SHA512` or `YESCRYPT`:

```
ENCRYPT_METHOD <HASHING_ALGORITHM>
```

Example:

```
ENCRYPT_METHOD YESCRYPT
```

Note:

- This only effects local groups' passwords created after updating the file to use `sha512` or `yescrypt`.
- If it is determined that the password algorithm being used is not `sha512` or `yescrypt`, once it is changed, it is recommended that all group passwords be updated to use the stronger hashing algorithm.
- It is recommended that the chosen hashing algorithm is consistent across `/etc/login.defs` and the PAM configuration

Default Value:

ENCRYPT_METHOD SHA512

References:

1. NIST SP 800-53 Rev. 5: IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	16.4 Encrypt or Hash all Authentication Credentials Encrypt or hash with a salt all authentication credentials when stored.		●	●

5.4.1.5 Ensure inactive password lock is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

User accounts that have been inactive for over a given period of time can be automatically disabled.

`INACTIVE` - Defines the number of days after the password exceeded its maximum age where the user is expected to replace this password.

The value is stored in the shadow password file. An input of `0` will disable an expired password with no delay. An input of `-1` will blank the respective field in the shadow password file.

Rationale:

Inactive accounts pose a threat to system security since the users are not logging in to notice failed login attempts or other anomalies.

Audit:

Run the following command and verify `INACTIVE` conforms to site policy (no more than 45 days):

```
# useradd -D | grep INACTIVE

INACTIVE=45
```

Verify all users with a password have Password inactive no more than 45 days after password expires

Verify all users with a password have Password inactive no more than 45 days after password expires: Run the following command and Review list of users and `INACTIVE` to verify that all users `INACTIVE` conforms to site policy (no more than 45 days):

```
# awk -F: '($2~/^\$.+\$/) {if($7 > 45 || $7 < 0)print "User: " $1 " INACTIVE:
" $7 "Days"}' /etc/shadow
```

Nothing should be returned

Remediation:

Run the following command to set the default password inactivity period to 45 days or less that meets local site policy:

```
# useradd -D -f <N>
```

Example:

```
# useradd -D -f 45
```

Run the following command to modify user parameters for all users with a password set to a inactive age of 45 days or less that follows local site policy:

```
# chage --inactive <N> <user>
```

Example:

```
# awk -F: '($2~/^\$.+\$/) {if($7 > 45 || $7 < 0)system ("chage --inactive 45
" $1)}' /etc/shadow
```

Default Value:

INACTIVE=-1

References:

1. CIS Password Policy Guide

Additional Information:

A value of -1 would disable this setting.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.4.1.6 Ensure all users last password change date is in the past (Automated)

Profile Applicability:

- Level 1 - Server

Description:

All users should have a password change date in the past.

Rationale:

If a user's recorded password change date is in the future, then they could bypass any set password expiration.

Audit:

Run the following script and verify nothing is returned:

```
#!/usr/bin/env bash

{
   while IFS= read -r l_user; do
      l_change=$(date -d "$(chage --list $l_user | grep '^Last password
change' | cut -d: -f2 | grep -v 'never$')" +%s)
      if [[ "$l_change" -gt "$(date +%s)" ]]; then
         echo "User: \"$l_user\" last password change was \"$(chage --list
$l_user | grep '^Last password change' | cut -d: -f2)\""
      fi
   done < <(awk -F: '$2~/^\$.+\$/{print $1}' /etc/shadow)
}
```

Remediation:

Investigate any users with a password change date in the future and correct them. Locking the account, expiring the password, or resetting the password manually may be appropriate.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.4.2 Configure root and system accounts and environment

5.4.2.1 Ensure root is the only UID 0 account (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Any account with UID 0 has superuser privileges on the system.

Rationale:

This access must be limited to only the default `root` account and only from the system console. Administrative access must be through an unprivileged account using an approved mechanism as noted in Item 5.6 Ensure access to the su command is restricted.

Audit:

Run the following command and verify that only "root" is returned:

```
# awk -F: '($3 == 0) { print $1 }' /etc/passwd

root
```

Remediation:

Run the following command to change the `root` account UID to `0`:

```
# usermod -u 0 root
```

Modify any users other than `root` with UID `0` and assign them a new UID.

References:

1. NIST SP 800-53 :: CM-6 b
2. NIST SP 800-53A :: CM-6.1 (iv)
3. RHEL 8 STIG GROUP ID: V-230534
4. RHEL 8 STIG Rule ID: SV-230534r627750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.4.2.2 Ensure root is the only GID 0 account (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `usermod` command can be used to specify which group the `root` account belongs to. This affects permissions of files that are created by the `root` account.

Rationale:

Using GID 0 for the `root` account helps prevent `root` -owned files from accidentally becoming accessible to non-privileged users.

Audit:

Run the following command to verify the `root` user's primary GID is `0`, and no other user's have GID `0` as their primary GID:

```
# awk -F: '($1 !~ /^(sync|shutdown|halt|operator)/ && $4=="0") {print
$1":"$4}' /etc/passwd

root:0
```

Note: User's: sync, shutdown, halt, and operator are excluded from the check for other user's with GID `0`

Remediation:

Run the following command to set the `root` user's GID to `0`:

```
# usermod -g 0 root
```

Run the following command to set the `root` group's GID to `0`:

```
# groupmod -g 0 root
```

Remove any users other than the `root` user with GID 0 or assign them a new GID if appropriate.

References:

1. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.4.2.3 Ensure group root is the only GID 0 group (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `groupmod` command can be used to specify which group the `root` group belongs to. This affects permissions of files that are group owned by the `root` group.

Rationale:

Using GID 0 for the `root` group helps prevent `root` group owned files from accidentally becoming accessible to non-privileged users.

Audit:

Run the following command to verify no group other than `root` is assigned GID `0`:

```
# awk -F: '$3=="0"{print $1":"$3}' /etc/group

root:0
```

Remediation:

Run the following command to set the `root` group's GID to `0`:

```
# groupmod -g 0 root
```

Remove any groups other than the `root` group with GID 0 or assign them a new GID if appropriate.

References:

1. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.4.2.4 Ensure root account access is controlled (Automated)

Profile Applicability:

- Level 1 - Server

Description:

There are a number of methods to access the root account directly. Without a password set any user would be able to gain access and thus control over the entire system.

Rationale:

Access to `root` should be secured at all times.

Impact:

If there are any automated processes that relies on access to the root account without authentication, they will fail after remediation.

Audit:

Run the following command to verify that either the root user's password is set or the root user's account is locked:

```
# passwd -S root | awk '$2 ~ /^(P|L)/ {print "User: \"" $1 "\" Password is
status: " $2}'
```

Verify the output is either:

```
User: "root" Password is status: P
- OR -
User: "root" Password is status: L
```

Note:

- `P` - Password is set
- `L` - Password is locked

Remediation:

Run the following command to set a password for the `root` user:

```
# passwd root
```

- OR -

Run the following command to lock the `root` user account:

```
# usermod -L root
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.4.2.5 Ensure root path integrity (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `root` user can execute any command on the system and could be fooled into executing programs unintentionally if the `PATH` is not set correctly.

Rationale:

Including the current working directory (.) or other writable directory in `root`'s executable path makes it likely that an attacker can gain superuser access by forcing an administrator operating as `root` to execute a Trojan horse program.

Audit:

Run the following script to verify root's path does not include:

- Locations that are not directories
- An empty directory (`::`)
- A trailing (`:`)
- Current working directory (`.`)
- Non `root` owned directories
- Directories that less restrictive than mode `0755`

```
#!/usr/bin/env bash

{
   l_output2=""
   l_pmask="0022"
   l_maxperm="$( printf '%o' $(( 0777 & ~$l_pmask )) )"
   l_root_path="$(sudo -Hiu root env | grep '^PATH' | cut -d= -f2)"
   unset a_path_loc && IFS=":" read -ra a_path_loc <<< "$l_root_path"
   grep -q "::" <<< "$l_root_path" && l_output2="$l_output2\n - root's path
contains a empty directory (::)"
   grep -Pq ":\h*$" <<< "$l_root_path" && l_output2="$l_output2\n - root's
path contains a trailing (:)"
   grep -Pq '(\h+|:)\.(:|\h*$)' <<< "$l_root_path" && l_output2="$l_output2\n
- root's path contains current working directory (.)"
   while read -r l_path; do
      if [ -d "$l_path" ]; then
         while read -r l_fmode l_fown; do
            [ "$l_fown" != "root" ] && l_output2="$l_output2\n - Directory:
\"$l_path\" is owned by: \"$l_fown\" should be owned by \"root\""
            [ $(( $l_fmode & $l_pmask )) -gt 0 ] && l_output2="$l_output2\n -
Directory: \"$l_path\" is mode: \"$l_fmode\" and should be mode:
\"$l_maxperm\" or more restrictive"
         done <<< "$(stat -Lc '%#a %U' "$l_path")"
      else
         l_output2="$l_output2\n - \"$l_path\" is not a directory"
      fi
   done <<< "$(printf "%s\n" "${a_path_loc[@]}")"
   if [ -z "$l_output2" ]; then
      echo -e "\n- Audit Result:\n  *** PASS ***\n - Root's path is correctly
configured\n"
   else
      echo -e "\n- Audit Result:\n  ** FAIL **\n - * Reasons for audit
failure * :\n$l_output2\n"
   fi
}
```

Remediation:

Correct or justify any:

- Locations that are not directories
- Empty directories (`::`)
- Trailing (`:`)
- Current working directory (`.`)
- Non `root` owned directories
- Directories that less restrictive than mode `0755`

References:

1. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.4.2.6 Ensure root user umask is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The user file-creation mode mask (`umask`) is used to determine the file permission for newly created directories and files. In Linux, the default permissions for any newly created directory is 0777 (`rwxrwxrwx`), and for any newly created file it is 0666 (`rw-rw-rw-`). The `umask` modifies the default Linux permissions by restricting (masking) these permissions. The `umask` is not simply subtracted, but is processed bitwise. Bits set in the `umask` are cleared in the resulting file mode.

`umask` can be set with either `Octal` or `Symbolic` values:

- `Octal` (Numeric) Value - Represented by either three or four digits. ie `umask 0027` or `umask 027`. If a four digit umask is used, the first digit is ignored. The remaining three digits effect the resulting permissions for user, group, and world/other respectively.
- `Symbolic` Value - Represented by a comma separated list for User `u`, group `g`, and world/other `o`. The permissions listed are not masked by `umask`. ie a `umask` set by `umask u=rwx,g=rx,o=` is the `Symbolic` equivalent of the `Octal umask 027`. This `umask` would set a newly created directory with file mode `drwxr-x---` and a newly created file with file mode `rw-r-----`.

root user Shell Configuration Files:

- `/root/.bash_profile` - Is executed to configure the root users' shell before the initial command prompt. **Is only read by login shells.**
- `/root/.bashrc` - Is executed for interactive shells. **only read by a shell that's both interactive and non-login**

`umask` is set by order of precedence. If `umask` is set in multiple locations, this order of precedence will determine the system's default `umask`.

Order of precedence:

1. `/root/.bash_profile`
2. `/root/.bashrc`
3. The system default umask

Rationale:

Setting a secure value for `umask` ensures that users make a conscious choice about their file permissions. A permissive `umask` value could result in directories or files with excessive permissions that can be read and/or written to by unauthorized users.

Audit:

Run the following command to verify that the `root` user files, `/root/.bash_profile` and `/root/.bashrc`, do not include a `umask` that is less restrictive than `0027`:

```
# grep -Psi -- '^\h*umask\h+((\d{1,2}(\d[^7]|[^2-
7]\d)\b)|(u=[rwx]{1,3},)?(((g=[rx]?[rx]?w[rx]?[rx]?\b)(,o=[rwx]{1,3})?)|((g=[
wrx]{1,3},)?o=[wrx]{1,3}\b)))' /root/.bash_profile /root/.bashrc
```

Nothing should be returned.

Remediation:

Edit `/root/.bash_profile` and `/root/.bashrc` and either:

- remove, comment out, or update any line with `umask`.

- OR -

- update any line that includes `umask` to a value of `0027` or more restrictive.

Example:

```
umask 027
```

Note: the Recommendation "Ensure default user umask is configured" includes guidance to set the default umask

Default Value:

System default `umask`

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.4.2.7 Ensure system accounts do not have a valid login shell (Automated)

Profile Applicability:

- Level 1 - Server

Description:

There are a number of accounts provided with most distributions that are used to manage applications and are not intended to provide an interactive shell. Furthermore, a user may add special accounts that are not intended to provide an interactive shell.

Rationale:

It is important to make sure that accounts that are not being used by regular users are prevented from being used to provide an interactive shell. By default, most distributions set the password field for these accounts to an invalid string, but it is also recommended that the shell field in the password file be set to the `nologin` shell. This prevents the account from potentially being used to run any commands.

Audit:

Run the following command to verify system accounts, except for `root`, `halt`, `sync`, `shutdown` or `nfsnobody`, do not have a valid login shell:

```
#!/usr/bin/env bash

{
   l_valid_shells="^($(awk -F\/ '$NF != "nologin" {print}' /etc/shells | sed
-rn '/^\//{s,/,\\\\/,g;p}' | paste -s -d '|' - ))$"
   awk -v pat="$l_valid_shells" -F:
'($1!~/^(root|halt|sync|shutdown|nfsnobody)$/ && ($3<'"$(awk
'/^\s*UID_MIN/{print $2}' /etc/login.defs)"' || $3 == 65534) && $(NF) ~ pat)
{print "Service account: \"" $1 "\" has a valid shell: " $7}' /etc/passwd
}
```

Nothing should be returned

Remediation:

Run the following command to set the shell for any service accounts returned by the audit to `nologin`:

```
# usermod -s $(command -v nologin) <user>
```

Example script:

```
#!/usr/bin/env bash

{
   l_valid_shells="^($( awk -F\/ '$NF != "nologin" {print}' /etc/shells | sed
-rn '/^\//{s,/,\\\\/,g;p}' | paste -s -d '|' - ))$"
   awk -v pat="$l_valid_shells" -F:
'($1!~/^(root|halt|sync|shutdown|nfsnobody)$/ && ($3<'"$(awk
'/^\s*UID_MIN/{print $2}' /etc/login.defs)"' || $3 == 65534) && $(NF) ~ pat)
{system ("usermod -s '"$(command -v nologin)"' " $1)}' /etc/passwd
}
```

References:

1. NIST SP 800-53 Rev. 5: AC-2(5), AC-3, AC-11, MP-2

Additional Information:

The `root`, `sync`, `shutdown`, and `halt` users are exempted from requiring a non-login shell.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.4.2.8 Ensure accounts without a valid login shell are locked (Automated)

Profile Applicability:

- Level 1 - Server

Description:

There are a number of accounts provided with most distributions that are used to manage applications. Additionally, a administrator may add special accounts that are not intended for interactive use.

Rationale:

It is important to make sure that accounts that are not intended for interactive use are prevented from being used interactively. By default, most distributions set the password field for these accounts to an invalid string, but it is also recommended that these accounts are locked. This prevents these accounts from potentially being used to run any commands.

Audit:

Run the following script to verify all non-root accounts without a valid login shell are locked.

```
#!/usr/bin/env bash

{
   l_valid_shells="^($(awk -F\/ '$NF != "nologin" {print}' /etc/shells | sed
-rn '/^\//{s,/,\\\\/,g;p}' | paste -s -d '|' - ))$"
   while IFS= read -r l_user; do
      passwd -S "$l_user" | awk '$2 !~ /^L/ {print "Account: \"" $1 "\" does
not have a valid login shell and is not locked"}'
   done < <(awk -v pat="$l_valid_shells" -F: '($1 != "root" && $(NF) !~ pat)
{print $1}' /etc/passwd)
}
```

Nothing should be returned

Remediation:

Run the following command to lock any non-root accounts without a valid login shell returned by the audit:

```
# usermod -L <user>
```

Example script::

```
#!/usr/bin/env bash

{
   l_valid_shells="^($(awk -F\/ '$NF != "nologin" {print}' /etc/shells | sed
-rn '/^\//{s,/,\\\\/,g;p}' | paste -s -d '|' - ))$"
   while IFS= read -r l_user; do
      passwd -S "$l_user" | awk '$2 !~ /^L/ {system ("usermod -L " $1)}'
   done < <(awk -v pat="$l_valid_shells" -F: '($1 != "root" && $(NF) !~ pat)
{print $1}' /etc/passwd)
}
```

References:

1. NIST SP 800-53 Rev. 5: AC-2(5), AC-3, AC-11, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.4.3 Configure user default environment

5.4.3.1 Ensure nologin is not listed in /etc/shells (Automated)

Profile Applicability:

- Level 2 - Server

Description:

`/etc/shells` is a text file which contains the full pathnames of valid login shells. This file is consulted by `chsh` and available to be queried by other programs.

Be aware that there are programs which consult this file to find out if a user is a normal user; for example, FTP daemons traditionally disallow access to users with shells not included in this file.

Rationale:

A user can use `chsh` to change their configured shell.

If a user has a shell configured that isn't in in `/etc/shells`, then the system assumes that they're somehow restricted. In the case of `chsh` it means that the user cannot change that value.

Other programs might query that list and apply similar restrictions.

By putting `nologin` in `/etc/shells`, any user that has `nologin` as its shell is considered a full, unrestricted user. This is not the expected behavior for `nologin`.

Audit:

Run the following command to verify that `nologin` is not listed in the `/etc/shells` file:

```
# grep -Ps '^\h*([^#\n\r]+)?\/nologin\b' /etc/shells
```

Nothing should be returned

Remediation:

Edit `/etc/shells` and remove any lines that include `nologin`

References:

1. shells(5)
2. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.4.3.2 Ensure default user shell timeout is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`TMOUT` is an environmental setting that determines the timeout of a shell in seconds.

- TMOUT=*n* - Sets the shell timeout to *n* seconds. A setting of `TMOUT=0` disables timeout.
- readonly TMOUT- Sets the TMOUT environmental variable as readonly, preventing unwanted modification during run-time.
- export TMOUT - exports the TMOUT variable

System Wide Shell Configuration Files:

- `/etc/profile` - used to set system wide environmental variables on users shells. The variables are sometimes the same ones that are in the `.bash_profile`, however this file is used to set an initial PATH or PS1 for all shell users of the system. **is only executed for interactive *login* shells, or shells executed with the --login parameter.**
- `/etc/profile.d` - `/etc/profile` will execute the scripts within `/etc/profile.d/*.sh`. It is recommended to place your configuration in a shell script within `/etc/profile.d` to set your own system wide environmental variables.
- `/etc/bash.bashrc` - System wide version of `.bashrc`. In Fedora derived distributions, `/etc/bashrc` also invokes /etc/profile.d/*.sh if *non-login* shell, but redirects output to `/dev/null` if *non-interactive.* **Is only executed for *interactive* shells or if `BASH_ENV` is set to `/etc/bash.bashrc`.**

Rationale:

Setting a timeout value reduces the window of opportunity for unauthorized user access to another user's shell session that has been left unattended. It also ends the inactive session and releases the resources associated with that session.

Audit:

Run the following script to verify that `TMOUT` is configured to: include a timeout of no more than `900` seconds, to be `readonly`, to be `exported`, and is not being changed to a longer timeout.

```
#!/usr/bin/env bash

{
   a_output=(); a_output2=(); l_tmout_set="900"
   f_tmout_read_chk()
   {
      a_out=(); a_out2=()
      l_tmout_readonly="$(grep -P -- '^\h*(typeset\h\-
xr\hTMOUT=\d+|([^#\n\r]+)?\breadonly\h+TMOUT\b)' "$l_file")"
      l_tmout_export="$(grep -P -- '^\h*(typeset\h\-
xr\hTMOUT=\d+|([^#\n\r]+)?\bexport\b([^#\n\r]+\b)?TMOUT\b)' "$l_file")"
      if [ -n "$l_tmout_readonly" ]; then
         a_out+=("  - Readonly is set as: \"$l_tmout_readonly\" in:
\"$l_file\"")
      else
         a_out2+=("  - Readonly is not set in: \"$l_file\"")
      fi
      if [ -n "$l_tmout_export" ]; then
         a_out+=("  - Export is set as: \"$l_tmout_export\" in: \"$l_file\"")
      else
         a_out2+=("  - Export is not set in: \"$l_file\"")
      fi
   }
   while IFS= read -r l_file; do
      l_tmout_value="$(grep -Po -- '^([^#\n\r]+)?\bTMOUT=\d+\b' "$l_file" |
awk -F= '{print $2}')"
      f_tmout_read_chk
      if [ -n "$l_tmout_value" ]; then
         if [[ "$l_tmout_value" -le "$l_tmout_set" && "$l_tmout_value" -gt
"0" ]]; then
            a_output+=(" - TMOUT is set to: \"$l_tmout_value\" in:
\"$l_file\"")
            [ "${#a_out[@]}" -gt 0 ] && a_output+=("${a_out[@]}")
            [ "${#a_out2[@]}" -gt 0 ] && a_output2+=("${a_out[@]}")
         fi
         if [[ "$l_tmout_value" -gt "$l_tmout_set" || "$l_tmout_value" -le
"0" ]]; then
            a_output2+=(" - TMOUT is incorrectly set to: \"$l_tmout_value\"
in: \"$l_file\"")
            [ "${#a_out[@]}" -gt 0 ] && a_output2+=("  ** Incorrect TMOUT
value **" "${a_out[@]}")
            [ "${#a_out2[@]}" -gt 0 ] && a_output2+=("${a_out2[@]}")
         fi
      else
         [ "${#a_out[@]}" -gt 0 ] &&  a_output2+=(" - TMOUT is not set"
"${a_out[@]}")
         [ "${#a_out2[@]}" -gt 0 ] &&  a_output2+=(" - TMOUT is not set"
"${a_out2[@]}")
      fi
   done < <(grep -Pls -- '^([^#\n\r]+)?\bTMOUT\b' /etc/*bashrc /etc/profile
/etc/profile.d/*.sh)
   [[ "${#a_output[@]}" -le 0 && "${#a_output2[@]}" -le 0 ]] && a_output2+=("
- TMOUT is not configured")
   if [ "${#a_output2[@]}" -le 0 ]; then
      printf '%s\n' "" "- Audit Result:" "  ** PASS **" "${a_output[@]}"
   else
```

```
      printf '%s\n' "" "- Audit Result:" "  ** FAIL **" "  * Reasons for
audit failure *" "${a_output2[@]}" ""
      [ "${#a_output[@]}" -gt 0 ] && printf '%s\n' "- Correctly set:"
"${a_output[@]}"
   fi
}
```

Note: If `TMOUT` is set as `readonly` through `readonly TMOUT` and/or `typeset -xr` in more than once, you will receive an error message when logging into a terminal session or connecting with openSSH. It is recommended that `TMOUT` be set only once in **only one** file.

Remediation:

Review `/etc/bashrc`, `/etc/profile`, and all files ending in `*.sh` in the `/etc/profile.d/` directory and remove or edit all `TMOUT=_n_` entries to follow local site policy. `TMOUT` should not exceed 900 or be equal to `0`.

Configure `TMOUT` in **one** of the following files:

- A file in the `/etc/profile.d/` directory ending in `.sh`
- `/etc/profile`
- `/etc/bashrc`

Example command to set TMOUT to `900` seconds in a file in `/etc/profile.d/`:

```
# printf '%s\n' "# Set TMOUT to 900 seconds" "typeset -xr TMOUT=900" >
/etc/profile.d/50-tmout.sh
```

`TMOUT` configuration examples:

```
typeset -xr TMOUT=900
```

Deprecated methods:

- As multiple lines:

```
TMOUT=900
readonly TMOUT
export TMOUT
```

- As a single line:

```
readonly TMOUT=900 ; export TMOUT
```

Additional Information:

The audit and remediation in this recommendation apply to bash and shell. If other shells are supported on the system, it is recommended that their configuration files also are checked. Other methods of setting a timeout exist for other shells not covered here.

Ensure that the timeout conforms to your local policy.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.3 Configure Automatic Session Locking on Enterprise Assets Configure automatic session locking on enterprise assets after a defined period of inactivity. For general purpose operating systems, the period must not exceed 15 minutes. For mobile end-user devices, the period must not exceed 2 minutes.	●	●	●
v7	16.11 Lock Workstation Sessions After Inactivity Automatically lock workstation sessions after a standard period of inactivity.	●	●	●

5.4.3.3 Ensure default user umask is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The user file-creation mode mask (`umask`) is used to determine the file permission for newly created directories and files. In Linux, the default permissions for any newly created directory is 0777 (`rwxrwxrwx`), and for any newly created file it is 0666 (`rw-rw-rw-`). The `umask` modifies the default Linux permissions by restricting (masking) these permissions. The `umask` is not simply subtracted, but is processed bitwise. Bits set in the `umask` are cleared in the resulting file mode.

`umask` can be set with either `Octal` or `Symbolic` values:

- `Octal` (Numeric) Value - Represented by either three or four digits. ie `umask 0027` or `umask 027`. If a four digit umask is used, the first digit is ignored. The remaining three digits effect the resulting permissions for user, group, and world/other respectively.
- `Symbolic` Value - Represented by a comma separated list for User `u`, group `g`, and world/other `o`. The permissions listed are not masked by `umask`. ie a `umask` set by `umask u=rwx,g=rx,o=` is the `Symbolic` equivalent of the `Octal umask 027`. This `umask` would set a newly created directory with file mode `drwxr-x---` and a newly created file with file mode `rw-r-----`.

The default `umask` can be set to use the `pam_umask` module or in a `System Wide Shell Configuration File`. The user creating the directories or files has the discretion of changing the permissions via the chmod command, or choosing a different default `umask` by adding the `umask` command into a `User Shell Configuration File`, (`.bash_profile` or `.bashrc`), in their home directory.

Setting the default umask:

- pam_umask module:
  - will set the umask according to the system default in `/etc/login.defs` and user settings, solving the problem of different `umask` settings with different shells, display managers, remote sessions etc.
  - `umask=<mask>` value in the `/etc/login.defs` file is interpreted as Octal
  - Setting `USERGROUPS_ENAB` to yes in `/etc/login.defs` (default):
    - will enable setting of the `umask` group bits to be the same as owner bits. (examples: 022 -> 002, 077 -> 007) for non-root users, if the `uid` is the same as `gid`, and `username` is the same as the `<primary group name>`
    - userdel will remove the user's group if it contains no more members, and useradd will create by default a group with the name of the user
- `System Wide Shell Configuration File`:
  - `/etc/profile` - used to set system wide environmental variables on users shells. The variables are sometimes the same ones that are in the `.bash_profile`, however this file is used to set an initial PATH or PS1 for all shell users of the system. **is only executed for interactive *login* shells, or shells executed with the --login parameter.**
  - `/etc/profile.d` - `/etc/profile` will execute the scripts within `/etc/profile.d/*.sh`. It is recommended to place your configuration in a shell script within `/etc/profile.d` to set your own system wide environmental variables.
  - `/etc/bashrc` - System wide version of `.bashrc`. In Fedora derived distributions, `etc/bashrc` also invokes /etc/profile.d/*.sh if *non-login* shell, but redirects output to `/dev/null` if *non-interactive.* **Is only executed for *interactive* shells or if `BASH_ENV` is set to `/etc/bashrc`.**

User Shell Configuration Files:

- `~/.bash_profile` - Is executed to configure your shell before the initial command prompt. **Is only read by login shells.**
- `~/.bashrc` - Is executed for interactive shells. **only read by a shell that's both interactive and non-login**

`umask` is set by order of precedence. If `umask` is set in multiple locations, this order of precedence will determine the system's default `umask`.

Order of precedence:

1. A file in `/etc/profile.d/` ending in `.sh` - This will override any other system-wide `umask` setting
2. In the file `/etc/profile`
3. On the `pam_umask.so` module in `/etc/pam.d/postlogin`
4. In the file `/etc/login.defs`
5. In the file `/etc/default/login`

Rationale:

Setting a secure default value for `umask` ensures that users make a conscious choice about their file permissions. A permissive `umask` value could result in directories or files with excessive permissions that can be read and/or written to by unauthorized users.

Satisfies: SRG-OS-000480-GPOS-00228, SRG-OS-000480-GPOS-00227

Audit:

Run the following commands to verify the systemwide `umask` is `0027` `(u=rwx,g=rx,o=)` or more restrictive:

1. Run the following command to verify `umask` is set to `027` or more restrictive in a file ending in `.sh` in `/etc/profile.d/`

```
grep -Psi -- '^\h*umask\b' /etc/profile.d/*.sh
```

Example output:

```
umask 027
```

2. Run the following command to verify `UMASK` is `027` or more restrictive in `/etc/login.defs`:

```
grep -Psi -- '^\h*UMASK\b' /etc/login.defs
```

Example output:

```
UMASK           027
```

Remediation:

1. Run the following script to comment out all occurrences of `umask` that are less restrictive than `027` in files ending in `*.sh` in the `/etc/profile.d/` directory:

```
#!/usr/bin/env bash

{
   while IFS= read -r -d $'\0' l_file; do
      sed -ri '/^\s*umask\s+0?(0[01][0-7]|0[0-7][^7]|[^0][0-7][0-
7])(\s*|\s+.*)$/s/^/# /' "$l_file"
   done < <(find /etc/profile.d/ -type f -name '*.sh' -print0)
}
```

2. Create or edit a file in `/etc/profile.d/` ending in `*.sh` and add or modify the following line:

```
umask 0027
```

Example:

```
# printf '%s\n' "" "umask 027" >> /etc/profile.d/60-default_umask.sh
```

3. Edit `/etc/login.defs` and add or update the following line:

```
UMASK 027
```

Notes:

- This method only applies to bash and shell. If other shells are supported on the system, it is recommended that their configuration files also are checked
- If the `pam_umask.so` module is going to be used to set `umask`, ensure that it's not being overridden by another setting. Refer to the PAM_UMASK(8) man page for more information

Default Value:

UMASK 022

References:

1. CCI-000366
2. NIST SP 800-53 :: CM-6 b
3. NIST SP 800-53A :: CM-6.1 (iv)
4. STIG ID: RHEL-08-020351 | RULE ID: SV-230383r1017192 | CAT II
5. STIG ID: RHEL-08-020353 | RULE ID: SV-230385r1017194 | CAT II
6. STIG ID: RHEL-09-412055 | RULE ID: SV-258072r1045155 | CAT II
7. STIG ID: RHEL-09-412065 | RULE ID: SV-258074r991590 | CAT II
8. STIG ID: RHEL-09-412070 | RULE ID: SV-258075r991590 | CAT II
9. STIG ID: ALMA-09-017620 | RULE ID: SV-269235r1050117 | CAT II
10. STIG ID: ALMA-09-017840 | RULE ID: SV-269237r1050119 | CAT II
11. STIG ID: UBTU-22-412035 | RULE ID: SV-260555r991590 | CAT II
12. STIG ID: UBTU-24-300030 | RULE ID: SV-270716r1066637 | CAT II
13. STIG ID: SLES-15-040420 | RULE ID: SV-235030r991590 | CAT II

Additional Information:

- Other methods of setting a default user umask exist
- If other methods are in use in your environment they should be audited
- The default user umask can be overridden with a user specific umask
- The user creating the directories or files has the discretion of changing the permissions:
    - Using the chmod command
    - Setting a different default umask by adding the umask command into a User Shell Configuration File, (.bashrc), in their home directory
    - Manually changing the umask for the duration of a login session by running the umask command

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

6 Logging and Auditing

The items in this section describe how to configure logging, log monitoring, and auditing, using tools included in most distributions.

It is recommended that `rsyslog` be used for logging (with `logwatch` providing summarization) and `auditd` be used for auditing (with `aureport` providing summarization) to automatically monitor logs for intrusion attempts and other suspicious system behavior.

In addition to the local log files created by the steps in this section, it is also recommended that sites collect copies of their system logs on a secure, centralized log server via an encrypted connection. Not only does centralized logging help sites correlate events that may be occurring on multiple systems, but having a second copy of the system log information may be critical after a system compromise where the attacker has modified the local log files on the affected system(s). If a log correlation system is deployed, configure it to process the logs described in this section.

Because it is often necessary to correlate log information from many different systems (particularly after a security incident) it is recommended that the time be synchronized among systems and devices connected to the local network. The standard Internet protocol for time synchronization is the Network Time Protocol (NTP), which is supported by most network-ready devices. Reference <http://chrony.tuxfamily.org/> manual page for more information on configuring chrony.

It is important that all logs described in this section be monitored on a regular basis and correlated to determine trends. A seemingly innocuous entry in one log could be more significant when compared to an entry in another log.

Note on log file permissions: There really isn't a "one size fits all" solution to the permissions on log files. Many sites utilize group permissions so that administrators who are in a defined security group, such as "wheel" do not have to elevate privileges to root in order to read log files. Also, if a third party log aggregation tool is used, it may need to have group permissions to read the log files, which is preferable to having it run setuid to root. Therefore, there are two remediation and audit steps for log file permissions. One is for systems that do not have a secured group method implemented that only permits root to read the log files (`root:root 600`). The other is for sites that do have such a setup and are designated as `root:securegrp 640` where `securegrp` is the defined security group (in some cases `wheel`).

6.1 Configure Integrity Checking

AIDE is a file integrity checking tool. While it cannot prevent intrusions, it can detect unauthorized changes to configuration files by alerting when the files are changed. When setting up AIDE, decide internally what the site policy will be concerning integrity checking. Review the AIDE quick start guide and AIDE documentation before proceeding.

Note: - IF - another local site approved solution is used, and configured to provide the capabilities covered by AIDE in this section, this section may be skipped.

6.1.1 Ensure AIDE is installed (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Advanced Intrusion Detection Environment (AIDE) is a intrusion detection tool that uses predefined rules to check the integrity of files and directories in the Linux operating system. AIDE has its own database to check the integrity of files and directories.

`aide` takes a snapshot of files and directories including modification times, permissions, and file hashes which can then be used to compare against the current state of the filesystem to detect modifications to the system.

Rationale:

By monitoring the filesystem state compromised files can be detected to prevent or limit the exposure of accidental or malicious misconfigurations or modified binaries.

Audit:

Run the following command and verify `aide` is installed:

```
# rpm -q aide

aide-<version>
```

Remediation:

Run the following command to install `aide`:

```
# dnf install aide
```

Configure `aide` as appropriate for your environment. Consult the `aide` documentation for options.

Initialize `aide`:

Run the following commands:

```
# aide --init
# mv /var/lib/aide/aide.db.new.gz /var/lib/aide/aide.db.gz
```

References:

1. AIDE stable manual: http://aide.sourceforge.net/stable/manual.html
2. NIST SP 800-53 Rev. 5: AU-2
3. NIST SP 800-53 Revision 4 :: SI-6 a
4. NIST SP 800-53 Revision 5 :: SI-6 a
5. RHEL 8 STIG Vul ID: V-251710
6. RHEL 8 STIG Rule ID: SV-251710r880730

Additional Information:

The prelinking feature can interfere with `aide` because it alters binaries to speed up their start up times. Run `prelink -ua` to restore the binaries to their prelinked state, thus avoiding false positives from `aide`.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.14 Log Sensitive Data Access Log sensitive data access, including modification and disposal.			●
v7	14.9 Enforce Detail Logging for Access or Changes to Sensitive Data Enforce detailed audit logging for access to sensitive data or changes to sensitive data (utilizing tools such as File Integrity Monitoring or Security Information and Event Monitoring).			●

6.1.2 Ensure filesystem integrity is regularly checked (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Periodic checking of the filesystem integrity is needed to detect changes to the filesystem.

Rationale:

Periodic file checking allows the system administrator to determine on a regular basis if critical files have been changed in an unauthorized fashion.

Satisfies: SRG-OS-000363-GPOS-00150, SRG-OS-000446-GPOS-00200, SRG-OS-000447-GPOS-00201

Audit:

Run the following commands to verify a cron job scheduled to run the aide check.

```
# grep -Ers '^([^#]+\s+)?(\/usr\/s?bin\/|^\s*)aide(\.wrapper)?\s(--?\S+\s)*(--(check|update)|\$AIDEARGS)\b' /etc/cron.* /etc/crontab /var/spool/cron/
```

Ensure a cron job in compliance with site policy is returned.

- OR -

Run the following commands to verify that `aidecheck.service` and `aidecheck.timer` are enabled and `aidcheck.timer` is running

```
# systemctl is-enabled aidecheck.service

# systemctl is-enabled aidecheck.timer
# systemctl status aidecheck.timer
```

Remediation:

- IF - `cron` will be used to schedule and run aide check

Run the following command:

```
# crontab -u root -e
```

Add the following line to the crontab:

```
0 5 * * * /usr/sbin/aide --check
```

- OR -

- IF - `aidecheck.service` and `aidecheck.timer` will be used to schedule and run aide check:

Create or edit the file `/etc/systemd/system/aidecheck.service` and add the following lines:

```
[Unit]
Description=Aide Check

[Service]
Type=simple
ExecStart=/usr/sbin/aide --check

[Install]
WantedBy=multi-user.target
```

Create or edit the file `/etc/systemd/system/aidecheck.timer` and add the following lines:

```
[Unit]
Description=Aide check every day at 5AM

[Timer]
OnCalendar=*-*-* 05:00:00
Unit=aidecheck.service

[Install]
WantedBy=multi-user.target
```

Run the following commands:

```
# chown root:root /etc/systemd/system/aidecheck.*
# chmod 0644 /etc/systemd/system/aidecheck.*

# systemctl daemon-reload

# systemctl enable aidecheck.service
# systemctl --now enable aidecheck.timer
```

References:

1. https://github.com/konstruktoid/hardening/blob/master/config/aidecheck.service
2. https://github.com/konstruktoid/hardening/blob/master/config/aidecheck.timer
3. NIST SP 800-53 Rev. 5: AU-2
4. NIST SP 800-53 Revision 5 :: CM-3 (5)
5. RHEL 8 STIG Vul ID: V-230263
6. RHEL 8 STIG Rule ID: SV-230263r902716

Additional Information:

The checking in this recommendation occurs every day at 5am. Alter the frequency and time of the checks in compliance with site policy.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.14 Log Sensitive Data Access Log sensitive data access, including modification and disposal.			●
v7	14.9 Enforce Detail Logging for Access or Changes to Sensitive Data Enforce detailed audit logging for access to sensitive data or changes to sensitive data (utilizing tools such as File Integrity Monitoring or Security Information and Event Monitoring).			●

6.1.3 Ensure cryptographic mechanisms are used to protect the integrity of audit tools (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Audit tools include, but are not limited to, vendor-provided and open source audit tools needed to successfully view and manipulate audit information system activity and records. Audit tools include custom queries and report generators.

Rationale:

Protecting the integrity of the tools used for auditing purposes is a critical step toward ensuring the integrity of audit information. Audit information includes all information (e.g., audit records, audit settings, and audit reports) needed to successfully audit information system activity.

Attackers may replace the audit tools or inject code into the existing tools with the purpose of providing the capability to hide or erase system activity from the audit logs.

Audit tools should be cryptographically signed in order to provide the capability to identify when the audit tools have been modified, manipulated, or replaced. An example is a checksum hash of the file or files.

Audit:

Verify that Advanced Intrusion Detection Environment (AIDE) is properly configured .

Run the following script to verify:

- AIDE is configured to use cryptographic mechanisms to protect the integrity of audit tools:
- The following audit tool files include the options "p, i, n, u, g, s, b, acl, xattrs and sha512"
    - auditctl
    - auditd
    - ausearch
    - aureport
    - autrace
    - augenrules

```
#!/usr/bin/env bash

{
   a_output=();a_output2=();a_output3=();a_parlist=()
   l_systemd_analyze="$(whereis systemd-analyze | awk '{print $2}')"
   a_audit_files=("auditctl" "auditd" "ausearch" "aureport" "autrace"
"augenrules")
   f_parameter_chk()
   {
      for l_tool_file in "${a_parlist[@]}"; do
         if grep -Pq -- '\b'"$l_tool_file"'\b' <<< "${!A_out[*]}"; then
            for l_string in "${!A_out[@]}"; do
               l_check="$(grep -Po --
'^\h*(\/usr)?\/sbin\/'"$l_tool_file"'\b' <<< "$l_string")"
               if [ -n "$l_check" ]; then
                  l_fname="$(printf '%s' "${A_out[$l_string]}")"
                  [ "$l_check" != "$(readlink -f "$l_check")" ] && \
                  a_output3+=("  - \"$l_check\" should be updated to:
\"$(readlink -f "$l_check")\"" "    in: \"$l_fname\"")
                  a_missing=()
                  for l_var in "${a_items[@]}"; do
                     if ! grep -Pq -- "\b$l_var\b" <<< "$l_string"; then
                        a_missing+=("\"$l_var\"")
                     fi
                  done
                  if [ "${#a_missing[@]}" -gt 0 ]; then
                     a_output2+=(" - Option(s): ( ${a_missing[*]} ) are
missing from: \"$l_tool_file\" in: \"$l_fname\"")
                  else
                     a_output+=(" - Audit tool file \"$l_tool_file\" exists
as:" "   \"$l_string\"" "   in the configuration file: \"$l_fname\"")
                  fi
               fi
            done
         else
            a_output2+=(" - Audit tool file \"$l_tool_file\" doesn't exist in
an AIDE configuration file")
         fi
      done
   }
   f_aide_conf()
   {
      l_config_file="$(whereis aide.conf | awk '{print $2}')"
      if [ -f "$l_config_file" ]; then
         a_items=("p" "i" "n" "u" "g" "s" "b" "acl" "xattrs" "sha512")
         declare -A A_out
         while IFS= read -r l_out; do
            if grep -Pq -- '^\h*\#\h*\/[^#\n\r]+\.conf\b' <<< "$l_out"; then
               l_file="${l_out//# /}"
            else
               for i in "${a_parlist[@]}"; do
                  grep -Pq -- '^\h*(\/usr)?\/sbin\/'"$i"'\b' <<< "$l_out" &&
A_out+=(["$l_out"]="$l_file")
               done
            fi
         done < <("$l_systemd_analyze" cat-config "$l_config_file" | grep -
Pio '^\h*([^#\n\r]+|#\h*\/[^#\n\r\h]+\.conf\b)')
```

```
         if [ "${#A_out[@]}" -gt 0 ]; then
            f_parameter_chk
         else
            a_output2+=(" - No audit tool files are configured in an AIDE
configuration file")
         fi
      else
         a_output2+=(" - AIDE configuration file not found." "   Please
verify AIDE is installed on the system")
      fi
   }
   for l_audit_file in "${a_audit_files[@]}"; do
      if [ -f "$(readlink -f "/sbin/$l_audit_file")" ]; then
         a_parlist+=("$l_audit_file")
      else
         a_output+=(" - Audit tool file \"$(readlink -f
"/sbin/$l_audit_file")\" doesn't exist")
      fi
   done
   [ "${#a_parlist[@]}" -gt 0 ] && f_aide_conf
   if [ "${#a_output2[@]}" -le 0 ]; then
      printf '%s\n' "" "- Audit Result:" "  ** PASS **" "${a_output[@]}"
      [ "${#a_output3[@]}" -gt 0 ] && printf '%s\n' "" "  ** WARNING **"
"${a_output3[@]}"
   else
      printf '%s\n' "" "- Audit Result:" "  ** FAIL **" "  * Reasons for
audit failure *" "${a_output2[@]}" ""
      [ "${#a_output3[@]}" -gt 0 ] && printf '%s\n' "" "  ** WARNING **"
"${a_output3[@]}"
      [ "${#a_output[@]}" -gt 0 ] && printf '%s\n' "- Correctly set:"
"${a_output[@]}"
   fi
}
```

Note: The script is written to read the "winning" configuration setting, to include any configuration settings in files included as part of the `@@x_include` setting.

Remediation:

Run the following command to determine the absolute path to the non-symlinked version on the audit tools:

```
# readlink -f /sbin
```

The output will be either `/usr/sbin` **- OR -** `/sbin`. Ensure the correct path is used.

Edit `/etc/aide.conf` and add or update the following selection lines replacing `<PATH>` with the correct path returned in the command above:

```
# Audit Tools
<PATH>/auditctl p+i+n+u+g+s+b+acl+xattrs+sha512
<PATH>/auditd p+i+n+u+g+s+b+acl+xattrs+sha512
<PATH>/ausearch p+i+n+u+g+s+b+acl+xattrs+sha512
<PATH>/aureport p+i+n+u+g+s+b+acl+xattrs+sha512
<PATH>/autrace p+i+n+u+g+s+b+acl+xattrs+sha512
<PATH>/augenrules p+i+n+u+g+s+b+acl+xattrs+sha512
```

Example

```
# printf '\n%s' "# Audit Tools" "$(readlink -f /sbin/auditctl)
p+i+n+u+g+s+b+acl+xattrs+sha512" "$(readlink -f /sbin/auditd)
p+i+n+u+g+s+b+acl+xattrs+sha512" "$(readlink -f /sbin/ausearch)
p+i+n+u+g+s+b+acl+xattrs+sha512" "$(readlink -f /sbin/aureport)
p+i+n+u+g+s+b+acl+xattrs+sha512" "$(readlink -f /sbin/autrace)
p+i+n+u+g+s+b+acl+xattrs+sha512" "$(readlink -f /sbin/augenrules)
p+i+n+u+g+s+b+acl+xattrs+sha512" >> /etc/aide.conf
```

Note: - IF - `/etc/aide.conf` includes a `@@x_include` statement:

Example:

```
@@x_include /etc/aide.conf.d ^[a-zA-Z0-9_-]+$
```

- `@@x_include` FILE
- `@@x_include` DIRECTORY REGEX
  - `@x_include` is identical to `@@include`, except that if a config file is executable it is run and the output is used as config.
  - If the executable file exits with status greater than zero or writes to stderr aide stops with an error.
  - For security reasons DIRECTORY and each executable config file must be owned by the current user and must not be group or world-writable.

References:

1. AIDE.CONF(5)

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

6.2 System Logging

Logging services should be configured to prevent information leaks and to aggregate logs on a remote server so that they can be reviewed in the event of a system compromise. A centralized log server provides a single point of entry for further analysis, monitoring and filtering.

Security principals for logging

- Ensure transport layer security is implemented between the client and the log server.
- Ensure that logs are rotated as per the environment requirements.
- Ensure all locally generated logs have the appropriate permissions.
- Ensure all security logs are sent to a remote log server.
- Ensure the required events are logged.

What is covered

This section will cover the minimum best practices for the usage of ***either*** `rsyslog` ***or*** `journald`. The recommendations are written such that each is wholly independent of each other and ***only one is implemented***.

- If your organization makes use of an enterprise wide logging system completely outside of `rsyslog` or `journald`, then the following recommendations do not directly apply. However, the principles of the recommendations should be followed regardless of what solution is implemented. If the enterprise solution incorporates either of these tools, careful consideration should be given to the following recommendations to determine exactly what applies.
- Should your organization make use of both `rsyslog` and `journald`, take care how the recommendations may or may not apply to you.

What is not covered

- Enterprise logging systems not utilizing `rsyslog` or `journald`. As logging is very situational and dependent on the local environment, not everything can be covered here.
- Transport layer security should be applied to all remote logging functionality. Both `rsyslog` and `journald` supports secure transport and should be configured as such.
- The log server. There are a multitude of reasons for a centralized log server (and keeping a short period of logging on the local system), but the log server is out of scope for these recommendations.

6.2.1 Configure journald

Included in the systemd suite is a journaling service called `systemd-journald.service` for the collection and storage of logging data. It creates and maintains structured, indexed journals based on logging information that is received from a variety of sources such as:

- Classic RFC3164 BSD syslog via the /dev/log socket
- STDOUT/STDERR of programs via StandardOutput=journal + StandardError=journal in service files (both of which are default settings)
- Kernel log messages via the /dev/kmsg device node
- Audit records via the kernel's audit subsystem
- Structured log messages via journald's native protocol

Any changes made to the `systemd-journald` configuration will require a re-start of `systemd-journald`

6.2.1.1 Configure systemd-journald service

`systemd-journald` is a system service that collects and stores logging data. It creates and maintains structured, indexed journals based on logging information that is received from a variety of sources:

- Kernel log messages, via kmsg
- Simple system log messages, via the libc syslog call
- Structured system log messages via the native Journal API
- Standard output and standard error of service units
- Audit records, originating from the kernel audit subsystem

The daemon will implicitly collect numerous metadata fields for each log messages in a secure and unfakeable way. See systemd.journal-fields man page for more information about the collected metadata.

The journal service stores log data either persistently below `/var/log/journal` or in a volatile way below `/run/log/journal/`. By default, log data is stored persistently if `/var/log/journal/` exists during boot, with an implicit fallback to volatile storage. Use `Storage=` in `journald.conf` to configure where log data is placed, independently of the existence of `/var/log/journal/`.

On systems where `/var/log/journal/` does not exist but where persistent logging is desired, and the default `journald.conf` is used, it is sufficient to create the directory and ensure it has the correct access modes and ownership.

6.2.1.1.1 Ensure journald service is active (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Ensure that the `systemd-journald` service is enabled to allow capturing of logging events.

Rationale:

If the `systemd-journald` service is not enabled to start on boot, the system will not capture logging events.

Audit:

Run the following command to verify `systemd-journald` is active:

```
# systemctl is-active systemd-journald.service

active
```

Remediation:

Run the following commands to unmask, enable, and start `systemd-journald.service`

```
# systemctl unmask systemd-journald.service
# systemctl --now enable systemd-journald.service
```

References:

1. CCI-001665
2. NIST SP 800-53 :: SC-24
3. NIST SP 800-53A :: SC-24.1 (v)
4. STIG ID: RHEL-09-211040 | RULE ID: SV-257783r991562 | CAT II
5. STIG ID: ALMA-09-041490 | RULE ID: SV-269428r1050311 | CAT II
6. STIG ID: OL09-00-002400 | RULE ID: SV-271739r1091929 | CAT II

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.2.1.1.2 Ensure journald log file access is configured (Manual)

Profile Applicability:

- Level 1 - Server

Description:

Journald will create logfiles that do not already exist on the system. This setting controls what permissions will be applied to these newly created files.

Rationale:

It is important to ensure that log files have the correct permissions to ensure that sensitive data is archived and protected.

Audit:

First determine if there is an override file `/etc/tmpfiles.d/systemd.conf`. If so, this file will override all default settings as defined in `/usr/lib/tmpfiles.d/systemd.conf` and should be inspected.

If no override file exists, inspect the default `/usr/lib/tmpfiles.d/systemd.conf` against the site-specific requirements.

Ensure that file permissions are mode `0640` or more restrictive.

Run the following script to verify if an override file exists or not and if the files permissions are mode `640` or more restrictive:

```
#!/usr/bin/env bash

{
    l_output="" file_path=""
    # Check for the existence of an override file
    if [ -f /etc/tmpfiles.d/systemd.conf ]; then
        file_path="/etc/tmpfiles.d/systemd.conf"
    elif [ -f /usr/lib/tmpfiles.d/systemd.conf ]; then
        file_path="/usr/lib/tmpfiles.d/systemd.conf"
    fi
    if [ -n "$file_path" ]; then # Ensure a file path is found
        higher_permissions_found=false  # Initialize a flag to check if
higher permissions are found
        # Read the file line by line and check for permissions higher than
0640
        while IFS= read -r line; do
            if echo "$line" | grep -Piq '^\s*[a-z]+\s+[^\s]+\s+0*([6-7][4-
7][1-7]|7[0-7][0-7])\s+'; then
                higher_permissions_found=true
                break
            fi
        done < "$file_path"
        if $higher_permissions_found; then
            echo -e "\n - permissions other than 0640 found in $file_path"
                      l_output="$l_output\n - Inspect $file_path"
        else
            echo -e "All permissions inside $file_path are 0640 or more
restrictive."
        fi
    fi
   if [ -z "$l_output" ]; then # Provide output from checks
      echo -e "\n- Audit Result:\n  ** PASS **\n$file_path exists and has
correct permissions set\n"
   else
      echo -e "\n- Audit Result:\n  ** REVIEW **\n$l_output\n - Review
permissions to ensure they are set IAW site policy"
   fi
}
```

Remediation:

If the default configuration is not appropriate for the site specific requirements, copy `/usr/lib/tmpfiles.d/systemd.conf` to `/etc/tmpfiles.d/systemd.conf` and modify as required. Requirements is either `0640` or site policy if that is less restrictive.

References:

1. NIST SP 800-53 Rev. 5: AC-3, AU-2, AU-12, MP-2, SI-5

Additional Information:

See `man 5 tmpfiles.d` for detailed information on the permission sets for the relevant log files. Further information with examples can be found at https://www.freedesktop.org/software/systemd/man/tmpfiles.d.html

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

6.2.1.1.3 Ensure journald log file rotation is configured (Manual)

Profile Applicability:

- Level 1 - Server

Description:

Journald includes the capability of rotating log files regularly to avoid filling up the system with logs or making the logs unmanageably large. The file `/etc/systemd/journald.conf` is the configuration file used to specify how logs generated by Journald should be rotated.

Rationale:

By keeping the log files smaller and more manageable, a system administrator can easily archive these files to another system and spend less time looking through inordinately large log files.

Audit:

Review `/etc/systemd/journald.conf` and files in the `/etc/systemd/journald.conf.d/` directory ending in `.conf`. Verify logs are rotated according to site policy. The specific parameters for log rotation are:

```
SystemMaxUse=
SystemKeepFree=
RuntimeMaxUse=
RuntimeKeepFree=
MaxFileSec=
```

Remediation:

Edit `/etc/systemd/journald.conf` or a file ending in `.conf` the `/etc/systemd/journald.conf.d/` directory. Set the following parameters in the `[Journal]` section to ensure logs are rotated according to site policy. The settings should be carefully understood as there are specific edge cases and prioritization of parameters.

The specific parameters for log rotation are:

```
SystemMaxUse=
SystemKeepFree=
RuntimeMaxUse=
RuntimeKeepFree=
MaxFileSec=
```

Note: If these settings appear in a canonically later file, or later in the same file, the setting will be overwritten

References:

1. NIST SP 800-53 Rev. 5: AU-2, AU-7, AU-12

Additional Information:

See `man 5 journald.conf` for detailed information regarding the parameters in use.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.2.1.1.4 Ensure journald ForwardToSyslog is disabled (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Data from `journald` should be kept in the confines of the service and not forwarded to other services.

Rationale:

- IF - `journald` is the method for capturing logs, all logs of the system should be handled by `journald` and not forwarded to other logging mechanisms.

Note: This recommendation **only applies if `journald` is the chosen method for client side logging**. Do not apply this recommendation if `rsyslog` is used.

Audit:

- IF - `journald` is the method for capturing logs

Run the following script to verify `ForwardToSyslog` in not set to `yes`:

```
#!/usr/bin/env bash

{
   l_analyze_cmd="$(readlink -e /bin/systemd-analyze || \
   readlink -e /usr/bin/systemd-analyze)"
   l_conf_file="systemd/journald.conf" l_block="Journal"
   l_option="ForwardToSyslog" l_option_value="no" a_output=()
   while IFS= read -r l_file; do
      l_file="${l_file//# /}"
      l_opt="$(awk '/\['"$l_block"'\]/{a=1;next}/\[/{a=0}a' "$l_file" \
      2>/dev/null | grep -Poi '^\h*'"$l_option"'\h*=\h*\H+\b' | tail -n 1)"
         l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_option\" is set to: \"$l_option_value\"" \
      "    in: \"$l_file\"")
   done < <("$l_analyze_cmd" cat-config "$l_conf_file" | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   if [ "${#a_output[@]}" -le "0" ]; then
      l_file="/etc/$l_conf_file"
      l_opt="$(awk '/\['"$l_block"'\]/{a=1;next}/\[/{a=0}a' "$l_file" \
      2>/dev/null | grep -Poim 1 '^(\h*#)?\h*'"$l_option"'\h*=\h*\H+\b')"
      l_option_value="$(cut -d= -f2 <<< "${l_opt//# /}" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - The default value: \"${l_opt//#/}\"" \
      "    is being used in the configuration")
   fi
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Remediation:

- IF - `rsyslog` is the preferred method for capturing logs, this section and Recommendation should be skipped and the "Configure rsyslog" section followed.

- IF - `journald` is the preferred method for capturing logs:

Set the following parameter in the `[Journal]` section in `/etc/systemd/journald.conf` or a file in `/etc/systemd/journald.conf.d/` ending in `.conf`:

```
ForwardToSyslog=no
```

Example:

```
#!/usr/bin/env bash

{
   [ ! -d /etc/systemd/journald.conf.d/ ] && mkdir
/etc/systemd/journald.conf.d/
   if grep -Psq -- '^\h*\[Journal\]' /etc/systemd/journald.conf.d/60-
journald.conf; then
      printf '%s\n' "ForwardToSyslog=no" >> /etc/systemd/journald.conf.d/60-
journald.conf
   else
      printf '%s\n' "[Journal]" "ForwardToSyslog=no" >>
/etc/systemd/journald.conf.d/60-journald.conf
   fi
}
```

Note: Drop-in configuration files have higher precedence and override the main configuration file. Files in the `*.conf.d/` configuration subdirectories are sorted by their filename in lexicographic order, regardless of in which of the subdirectories they reside. When multiple files specify the same option, for options which accept just a single value, the entry in the file sorted last takes precedence, and for options which accept a list of values,

entries are collected as they occur in the sorted files.

Run to following command to update the parameters in the service:

```
# systemctl reload-or-restart systemd-journald
```

Default Value:

ForwardToSyslog=no

References:

1. NIST SP 800-53 Rev. 5: AU-2, AU-6, AU-7, AU-12
2. journald.conf(5) - Linux manual page: https://man7.org/linux/man-pages/man5/journald.conf.5.html

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.2.1.1.5 Ensure journald Storage is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Data from journald may be stored in volatile memory or persisted locally on the server. Logs in memory will be lost upon a system reboot. By persisting logs to local disk on the server they are protected from loss due to a reboot.

Rationale:

Writing log data to disk will provide the ability to forensically reconstruct events which may have impacted the operations or security of a system even after a system crash or reboot.

Audit:

Run the following script to verify `Storage` is set to `persistent`:

```
#!/usr/bin/env bash

{
   l_analyze_cmd="$(readlink -e /bin/systemd-analyze || \
   readlink -e /usr/bin/systemd-analyze)"
   l_conf_file="systemd/journald.conf" l_block="Journal"
   l_option="Storage" l_option_value="persistent" a_output=()
   while IFS= read -r l_file; do
      l_file="${l_file//# /}"
      l_opt="$(awk '/\['"$l_block"'\]/{a=1;next}/\[/{a=0}a' "$l_file" \
      2>/dev/null | grep -Poi '^\h*'"$l_option"'\h*=\h*\H+\b' | tail -n 1)"
         l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_option\" is set to: \"$l_option_value\"" \
      "    in: \"$l_file\"")
   done < <("$l_analyze_cmd" cat-config "$l_conf_file" | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   if [ "${#a_output[@]}" -le "0" ]; then
      l_file="/etc/$l_conf_file"
      l_opt="$(awk '/\['"$l_block"'\]/{a=1;next}/\[/{a=0}a' "$l_file" \
      2>/dev/null | grep -Poim 1 '^(\h*#)?\h*'"$l_option"'\h*=\h*\H+\b')"
      l_option_value="$(cut -d= -f2 <<< "${l_opt//# /}" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - The default value: \"${l_opt//#/}\"" \
      "    is being used in the configuration")
   fi
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Remediation:

Set the following parameter in the `[Journal]` section in `/etc/systemd/journald.conf` or a file in `/etc/systemd/journald.conf.d/` ending in `.conf`:

```
Storage=persistent
```

Example:

```
#!/usr/bin/env bash

{
   [ ! -d /etc/systemd/journald.conf.d/ ] && mkdir
/etc/systemd/journald.conf.d/
   if grep -Psq -- '^\h*\[Journal\]' /etc/systemd/journald.conf.d/60-
journald.conf; then
      printf '%s\n' "Storage=persistent" >> /etc/systemd/journald.conf.d/60-
journald.conf
   else
      printf '%s\n' "[Journal]" "Storage=persistent" >>
/etc/systemd/journald.conf.d/60-journald.conf
   fi
}
```

Note: Drop-in configuration files have higher precedence and override the main configuration file. Files in the `*.conf.d/` configuration subdirectories are sorted by their filename in lexicographic order, regardless of in which of the subdirectories they reside. When multiple files specify the same option, for options which accept just a single value, the entry in the file sorted last takes precedence, and for options which accept a list of values, entries are collected as they occur in the sorted files.

Run to following command to update the parameters in the service:

```
# systemctl reload-or-restart systemd-journald
```

References:

1. NIST SP 800-53 Rev. 5: AU-3, AU-12
2. journald.conf(5) - Linux manual page: https://man7.org/linux/man-pages/man5/journald.conf.5.html

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.2.1.1.6 Ensure journald Compress is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The journald system includes the capability of compressing overly large files to avoid filling up the system with logs or making the logs unmanageably large.

Rationale:

Uncompressed large files may unexpectedly fill a filesystem leading to resource unavailability. Compressing logs prior to write can prevent sudden, unexpected filesystem impacts.

Audit:

Run the following script to verify `Compress` is set to `yes`:

```
#!/usr/bin/env bash

{
   l_analyze_cmd="$(readlink -e /bin/systemd-analyze || \
   readlink -e /usr/bin/systemd-analyze)"
   l_conf_file="systemd/journald.conf" l_block="Journal"
   l_option="Compress" l_option_value="yes" a_output=()
   while IFS= read -r l_file; do
      l_file="${l_file//# /}"
      l_opt="$(awk '/\['"$l_block"'\]/{a=1;next}/\[/{a=0}a' "$l_file" \
      2>/dev/null | grep -Poi '^\h*'"$l_option"'\h*=\h*\H+\b' | tail -n 1)"
         l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_option\" is set to: \"$l_option_value\"" \
      "    in: \"$l_file\"")
   done < <("$l_analyze_cmd" cat-config "$l_conf_file" | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   if [ "${#a_output[@]}" -le "0" ]; then
      l_file="/etc/$l_conf_file"
      l_opt="$(awk '/\['"$l_block"'\]/{a=1;next}/\[/{a=0}a' "$l_file" \
      2>/dev/null | grep -Poim 1 '^(\h*#)?\h*'"$l_option"'\h*=\h*\H+\b')"
      l_option_value="$(cut -d= -f2 <<< "${l_opt//# /}" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - The default value: \"${l_opt//#/}\"" \
      "    is being used in the configuration")
   fi
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Remediation:

Set the following parameter in the `[Journal]` section in `/etc/systemd/journald.conf` or a file in `/etc/systemd/journald.conf.d/` ending in `.conf`:

```
Compress=yes
```

Example:

```
#!/usr/bin/env bash

{
   [ ! -d /etc/systemd/journald.conf.d/ ] && mkdir
/etc/systemd/journald.conf.d/
   if grep -Psq -- '^\h*\[Journal\]' /etc/systemd/journald.conf.d/60-
journald.conf; then
      printf '%s\n' "Compress=yes" >> /etc/systemd/journald.conf.d/60-
journald.conf
   else
      printf '%s\n' "[Journal]" "Compress=yes" >>
/etc/systemd/journald.conf.d/60-journald.conf
   fi
}
```

Note: Drop-in configuration files have higher precedence and override the main configuration file. Files in the `*.conf.d/` configuration subdirectories are sorted by their filename in lexicographic order, regardless of in which of the subdirectories they reside. When multiple files specify the same option, for options which accept just a single value, the entry in the file sorted last takes precedence, and for options which accept a list of values, entries are collected as they occur in the sorted files.

Run to following command to update the parameters in the service:

```
# systemctl reload-or-restart systemd-journald
```

References:

1. NIST SP 800-53 Rev. 5: AU-4
2. journald.conf(5) - Linux manual page: https://man7.org/linux/man-pages/man5/journald.conf.5.html

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.3 Ensure Adequate Audit Log Storage Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●
v7	6.4 Ensure adequate storage for logs Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●

6.2.1.2 Configure systemd-journal-remote

The `systemd-journal-remote` package includes `systemd-journal-upload`.

`systemd-journal-upload` will upload journal entries to the URL specified with --url=. This program reads journal entries from one or more journal files, similarly to journalctl.

`systemd-journal-upload` transfers the raw content of journal file and uses HTTP as a transport protocol.

`systemd-journal-upload.service` is a system service that uses `systemd-journal-upload` to upload journal entries to a server. It uses the configuration in `journal-upload.conf`.

6.2.1.2.1 Ensure systemd-journal-remote is installed (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Journald `systemd-journal-remote` supports the ability to send log events it gathers to a remote log host or to receive messages from remote hosts, thus enabling centralized log management.

Rationale:

Storing log data on a remote host protects log integrity from local attacks. If an attacker gains root access on the local system, they could tamper with or remove log data that is stored on the local system.

Audit:

- IF - `journald` will be used for logging on the system:

Run the following command to verify `systemd-journal-remote` is installed.

```
# rpm -q systemd-journal-remote
```

Verify the output matches:

```
systemd-journal-remote-<version>
```

Remediation:

Run the following command to install `systemd-journal-remote`:

```
# dnf install systemd-journal-remote
```

References:

1. NIST SP 800-53 Rev. 5: AU-2, AU-7 AU-12

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.2.1.2.2 Ensure systemd-journal-remote authentication is configured (Manual)

Profile Applicability:

- Level 1 - Server

Description:

Journald `systemd-journal-upload` supports the ability to send log events it gathers to a remote log host.

Rationale:

Storing log data on a remote host protects log integrity from local attacks. If an attacker gains root access on the local system, they could tamper with or remove log data that is stored on the local system.

Audit:

Run the following command to verify `systemd-journal-upload` authentication is configured:

```
# grep -P "^ *URL=|^ *ServerKeyFile=|^ *ServerCertificateFile=|^
*TrustedCertificateFile=" /etc/systemd/journal-upload.conf
```

Verify the output matches per your environments certificate locations and the URL of the log server:

Example:

```
[Upload]
URL=192.168.50.42
ServerKeyFile=/etc/ssl/private/journal-upload.pem
ServerCertificateFile=/etc/ssl/certs/journal-upload.pem
TrustedCertificateFile=/etc/ssl/ca/trusted.pem
```

Remediation:

Edit the `/etc/systemd/journal-upload.conf` file or a file in `/etc/systemd/journal-upload.conf.d` ending in `.conf` and ensure the following lines are set in the `[Upload]` section per your environment:

```
[Upload]
URL=192.168.50.42
ServerKeyFile=/etc/ssl/private/journal-upload.pem
ServerCertificateFile=/etc/ssl/certs/journal-upload.pem
TrustedCertificateFile=/etc/ssl/ca/trusted.pem
```

Restart the service:

```
# systemctl restart systemd-journal-upload
```

References:

1. NIST SP 800-53 Rev. 5: AU-2, AU-12

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.2.1.2.3 Ensure systemd-journal-upload is enabled and active (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Journald `systemd-journal-upload` supports the ability to send log events it gathers to a remote log host.

Rationale:

Storing log data on a remote host protects log integrity from local attacks. If an attacker gains root access on the local system, they could tamper with or remove log data that is stored on the local system.

Audit:

Run the following command to verify `systemd-journal-upload` is enabled.

```
# systemctl is-enabled systemd-journal-upload.service

enabled
```

Run the following command to verify `systemd-journal-upload` is active:

```
# systemctl is-active systemd-journal-upload.service

active
```

Remediation:

Run the following commands to unmask, enable and start `systemd-journal-upload`:

```
# systemctl unmask systemd-journal-upload.service
# systemctl --now enable systemd-journal-upload.service
```

References:

1. NIST SP 800-53 Rev. 5: AU-2, AU-12

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.2.1.2.4 Ensure systemd-journal-remote service is not in use (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Journald `systemd-journal-remote` supports the ability to receive messages from remote hosts, thus acting as a log server. Clients should not receive data from other hosts.

Note:

- The same package, `systemd-journal-remote`, is used for both sending logs to remote hosts and receiving incoming logs.
- With regards to receiving logs, there are two services; `systemd-journal-remote.socket` and `systemd-journal-remote.service`.

Rationale:

If a client is configured to also receive data, thus turning it into a server, the client system is acting outside it's operational boundary.

Note: This recommendation **only applies if `journald` is the chosen method for client side logging**. Do not apply this recommendation if `rsyslog` is used.

Audit:

Run the following command to verify `systemd-journal-remote.socket` and `systemd-journal-remote.service` are not enabled:

```
# systemctl is-enabled systemd-journal-remote.socket systemd-journal-
remote.service | grep -P -- '^enabled'
```

Nothing should be returned

Run the following command to verify `systemd-journal-remote.socket` and `systemd-journal-remote.service` are not active:

```
# systemctl is-active systemd-journal-remote.socket systemd-journal-
remote.service | grep -P -- '^active'
```

Nothing should be returned

Remediation:

Run the following commands to stop and mask `systemd-journal-remote.socket` and systemd-journal-remote.service:

```
# systemctl stop systemd-journal-remote.socket systemd-journal-remote.service
# systemctl mask systemd-journal-remote.socket systemd-journal-remote.service
```

References:

1. NIST SP 800-53 Rev. 5: AU-2, AU-7 AU-12

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

6.2.2 Configure rsyslog

The `rsyslog` software package may be used instead of the default `journald` logging mechanism.

Rsyslog has evolved over several decades. For this reason it supports three different configuration formats ("languages"):

- `basic` - previously known as the `sysklogd` format, this is the format best used to express basic things, such as where the statement fits on a single line.
    - It stems back to the original syslog.conf format, in use now for several decades.
    - The most common use case is matching on facility/severity and writing matching messages to a log file.
- `advanced` - previously known as the `RainerScript` format, this format was first available in rsyslog v6 and is the current, best and most precise format for non-trivial use cases where more than one line is needed.
    - Prior to v7, there was a performance impact when using this format that encouraged use of the basic format for best results. Current versions of rsyslog do not suffer from this (historical) performance impact.
    - This new style format is specifically targeted towards more advanced use cases like forwarding to remote hosts that might be partially offline.
- `obsolete legacy` - previously known simply as the `legacy` format, this format is exactly what its name implies: it is obsolete and should not be used when writing new configurations. It was created in the early days (up to rsyslog version 5) where we expected that rsyslog would extend sysklogd just mildly. Consequently, it was primarily aimed at small additions to the original sysklogd format.
    - Practice has shown that it was notoriously hard to use for more advanced use cases, and thus we replaced it with the advanced format.
    - In essence, everything that needs to be written on a single line that starts with a dollar sign is legacy format. Users of this format are encouraged to migrate to the basic or advanced formats.

Note: This section only applies if `rsyslog` is the chosen method for client side logging. Do not apply this section if `journald` is used.

6.2.2.1 Ensure rsyslog is installed (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `rsyslog` software is recommended in environments where `journald` does not meet operation requirements.

Rationale:

The security enhancements of `rsyslog` such as connection-oriented (i.e. TCP) transmission of logs, the option to log to database formats, and the encryption of log data en route to a central logging server) justify installing and configuring the package.

Audit:

- IF - `rsyslog` is being used for logging on the system:

Run the following command to verify `rsyslog` is installed:

```
# rpm -q rsyslog
```

Verify the output matches:

```
rsyslog-<version>
```

Remediation:

Run the following command to install `rsyslog`:

```
# dnf install rsyslog
```

Default Value:

Installed

References:

1. NIST SP 800-53 :: CM-6 b
2. NIST SP 800-53A :: CM-6.1 (iv)
3. RHEL 8 STIG GROUP ID: V-230477
4. RHEL 8 STIG RULE ID: SV-230477r627750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.2.2.2 Ensure rsyslog service is enabled and active (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Once the `rsyslog` package is installed, ensure that the service is enabled.

Rationale:

If the `rsyslog` service is not enabled to start on boot, the system will not capture logging events.

Audit:

- IF - `rsyslog` is being used for logging on the system:

Run the following command to verify `rsyslog.service` is enabled:

```
# systemctl is-enabled rsyslog

enabled
```

Run the following command to verify `rsyslog.service` is active:

```
# systemctl is-active rsyslog.service

active
```

Remediation:

- IF - `rsyslog` is being used for logging on the system:

Run the following commands to unmask, enable, and start `rsyslog.service`:

```
# systemctl unmask rsyslog.service
# systemctl enable rsyslog.service
# systemctl start rsyslog.service
```

References:

1. NIST SP 800-53 Rev. 5: AU-2, AU-3, AU-12

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.2.2.3 Ensure journald is configured to send logs to rsyslog (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Data from `systemd-journald` may be stored in volatile memory or persisted locally on the server. Utilities exist to accept remote export of `systemd-journald` logs, however, use of the `rsyslog` service provides a consistent means of log collection and export.

Rationale:

- IF - `rsyslog` is the preferred method for capturing logs, all logs of the system should be sent to it for further processing.

Impact:

- IF - `Journald` is the preferred method for capturing logs, this section and Recommendation should be skipped and the "Configure Journald" section followed.

Audit:

- IF - `rsyslog` is the preferred method for capturing logs

Run the following command to verify that logs are forwarded to `rsyslog` by setting `ForwardToSyslog` to `yes` in the systemd-journald configuration:

```
#!/usr/bin/env bash

{
   l_analyze_cmd="$(readlink -e /bin/systemd-analyze || \
   readlink -e /usr/bin/systemd-analyze)"
   l_conf_file="systemd/journald.conf" l_block="Journal"
   l_option="ForwardToSyslog" l_option_value="yes" a_output=()
   while IFS= read -r l_file; do
      l_file="${l_file//# /}"
      l_opt="$(awk '/\['"$l_block"'\]/{a=1;next}/\[/{a=0}a' "$l_file" \
      2>/dev/null | grep -Poi '^\h*'"$l_option"'\h*=\h*\H+\b' | tail -n 1)"
         l_option_value="$(cut -d= -f2 <<< "$l_opt" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - \"$l_option\" is set to: \"$l_option_value\"" \
      "    in: \"$l_file\"")
   done < <("$l_analyze_cmd" cat-config "$l_conf_file" | tac | \
   grep -Pio '^\h*#\h*\/[^#\n\r\h]+\.conf\b')
   if [ "${#a_output[@]}" -le "0" ]; then
      l_file="/etc/$l_conf_file"
      l_opt="$(awk '/\['"$l_block"'\]/{a=1;next}/\[/{a=0}a' "$l_file" \
      2>/dev/null | grep -Poim 1 '^(\h*#)?\h*'"$l_option"'\h*=\h*\H+\b')"
      l_option_value="$(cut -d= -f2 <<< "${l_opt//# /}" | xargs)"
      [ -n "$l_option_value" ] && \
      a_output+=(" - The default value: \"${l_opt//#/}\"" \
      "    is being used in the configuration")
   fi
   [ "${#a_output[@]}" -gt "0" ] && printf '%s\n' "" "${a_output[@]}" ""
}
```

Remediation:

- IF - `rsyslog` is the preferred method for capturing logs:

Set the following parameter in the `[Journal]` section in `/etc/systemd/journald.conf` or a file in `/etc/systemd/journald.conf.d/` ending in `.conf`:

```
ForwardToSyslog=yes
```

Example:

```
#!/usr/bin/env bash

{
   [ ! -d /etc/systemd/journald.conf.d/ ] && mkdir
/etc/systemd/journald.conf.d/
   if grep -Psq -- '^\h*\[Journal\]' /etc/systemd/journald.conf.d/60-
journald.conf; then
      printf '%s\n' "ForwardToSyslog=yes" >> /etc/systemd/journald.conf.d/60-
journald.conf
   else
      printf '%s\n' "[Journal]" "ForwardToSyslog=yes" >>
/etc/systemd/journald.conf.d/60-journald.conf
   fi
}
```

Note: Drop-in configuration files have higher precedence and override the main configuration file. Files in the `*.conf.d/` configuration subdirectories are sorted by their filename in lexicographic order, regardless of in which of the subdirectories they reside. When multiple files specify the same option, for options which accept just a single value, the entry in the file sorted last takes precedence, and for options which accept a list of values, entries are collected as they occur in the sorted files.

Run to following command to update the parameters in the service:

Restart `systemd-journald.service`:

```
# systemctl reload-or-restart systemd-journald.service
```

References:

1. NIST SP 800-53 Rev. 5: AC-3, AU-2, AU-4, AU-12, MP-2
2. SYSTEMD-JOURNALD.SERVICE(8)
3. JOURNALD.CONF(5)

Additional Information:

As noted in the `systemd-journald` man pages, `systemd-journald` logs may be exported to `rsyslog` either through the process mentioned here, or through a facility like `systemd-journald.service`. There are trade-offs involved in each implementation, where `ForwardToSyslog` will immediately capture all events (and forward to an external log server, if properly configured), but may not capture all boot-up activities. Mechanisms such as `systemd-journald.service`, on the other hand, will record bootup events, but may delay sending the information to `rsyslog`, leading to the potential for log manipulation prior to export. Be aware of the limitations of all tools employed to secure a system.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.9 Centralize Audit Logs Centralize, to the extent possible, audit log collection and retention across enterprise assets.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●
v7	6.5 Central Log Management Ensure that appropriate logs are being aggregated to a central log management system for analysis and review.		●	●

6.2.2.4 Ensure rsyslog log file creation mode is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`rsyslog` will create logfiles that do not already exist on the system.

The `global()` configuration object `umask`, available in rsyslog 8.26.0+, sets the rsyslogd process' umask. If not specified, the system-provided default is used. The value given must always be a 4-digit octal number, with the initial digit being zero.

The legacy `$umask` parameter sets the `rsyslogd` process' umask. If not specified, the system-provided default is used. The value given must always be a 4-digit octal number, with the initial digit being zero.

The legacy `$FileCreateMode` parameter allows the setting of the mode with which `rsyslogd` creates new files. If not specified, the value `0644` is used. The value given must always be a 4-digit octal number, with the initial digit being zero. Please note that the actual permission depend on `rsyslogd` process `umask`. If in doubt, use `$umask 0000` right at the beginning of the configuration file to remove any restrictions.

The legacy `$FileCreateMode` may be specified multiple times. If so, it specifies the creation mode for all selector lines that follow until the next `$FileCreateMode` parameter. Order of lines is vitally important.

Rationale:

It is important to ensure that log files have the correct permissions to ensure that sensitive data is archived and protected.

Audit:

Run the following command

Run the following command to verify `$FileCreateMode`:

```
# grep -Ps '^\h*\$FileCreateMode\h+0[0,2,4,6][0,2,4]0\b' /etc/rsyslog.conf
/etc/rsyslog.d/*.conf
```

Verify the output is includes 0640 or more restrictive:

```
$FileCreateMode 0640
```

Should a site policy dictate less restrictive permissions, ensure to follow said policy.

NOTE: More restrictive permissions such as `0600` is implicitly sufficient.

Remediation:

Edit either `/etc/rsyslog.conf` or a dedicated `.conf` file in `/etc/rsyslog.d/` and set `$FileCreateMode` to `0640` or more restrictive:

```
$FileCreateMode 0640
```

Restart the service:

```
# systemctl restart rsyslog
```

References:

1. RSYSLOG.CONF(5)
2. NIST SP 800-53 Rev. 5: AC-3, AC-6, MP-2
3. https://www.rsyslog.com/doc/

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	5.1 Establish Secure Configurations Maintain documented, standard security configuration standards for all authorized operating systems and software.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.2.2.5 Ensure rsyslog logging is configured (Manual)

Profile Applicability:

- Level 1 - Server

Description:

The `/etc/rsyslog.conf` and `/etc/rsyslog.d/*.conf` files specifies rules for logging and which files are to be used to log certain classes of messages.

Rationale:

A great deal of important security-related information is sent via `rsyslog` (e.g., successful and failed su attempts, failed login attempts, root login attempts, etc.).

Audit:

Review the contents of `/etc/rsyslog.conf` and `/etc/rsyslog.d/*.conf` files to ensure appropriate logging is set. In addition, run the following command and verify that the log files are logging information as expected:

```
# ls -l /var/log/
```

Remediation:

Edit the following lines in the `/etc/rsyslog.conf` and `/etc/rsyslog.d/*.conf` files as appropriate for your environment.

Note: The below configuration is shown for example purposes only. Due care should be given to how the organization wishes to store log data.

```
*.emerg                                 :omusrmsg:*
auth,authpriv.*                         /var/log/secure
mail.*                                  -/var/log/mail
mail.info                               -/var/log/mail.info
mail.warning                            -/var/log/mail.warn
mail.err                                /var/log/mail.err
cron.*                                  /var/log/cron
*.=warning;*.=err                       -/var/log/warn
*.crit                                  /var/log/warn
*.*;mail.none;news.none                 -/var/log/messages
local0,local1.*                         -/var/log/localmessages
local2,local3.*                         -/var/log/localmessages
local4,local5.*                         -/var/log/localmessages
local6,local7.*                         -/var/log/localmessages
```

Run the following command to reload the `rsyslogd` configuration:

```
# systemctl restart rsyslog
```

References:

1. See the rsyslog.conf(5) man page for more information.
2. NIST SP 800-53 Rev. 5: AU-2, AU-7, AU-12

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.2.2.6 Ensure rsyslog is configured to send logs to a remote log host (Manual)

Profile Applicability:

- Level 1 - Server

Description:

`rsyslog` supports the ability to send log events it gathers to a remote log host or to receive messages from remote hosts, thus enabling centralized log management.

Rationale:

Storing log data on a remote host protects log integrity from local attacks. If an attacker gains root access on the local system, they could tamper with or remove log data that is stored on the local system.

Audit:

Review the `/etc/rsyslog.conf` and `/etc/rsyslog.d/*.conf` files and verify that logs are sent to a central host:

basic format

```
# grep "^*.*[^I][^I]*@@" /etc/rsyslog.conf /etc/rsyslog.d/*.conf
```

Output should include `@@<FQDN or IP of remote loghost>`:

Example:

```
*.* @@loghost.example.com
```

Note: `@@` signifies a tcp connection. If the output only has a single `@`, a UDP connection is being used and this is considered a failing state.

advanced format

```
# grep -Psi -- '^\s*([^#]+\s+)?action\(([^#]+\s+)?\btarget=\"?[^#"]+\"?\b'
/etc/rsyslog.conf /etc/rsyslog.d/*.conf
```

Output should include `target=<FQDN or IP of remote loghost>`:

Example:

```
*.* action(type="omfwd" target="loghost.example.com" port="514"
protocol="tcp"
```

Remediation:

Edit the `/etc/rsyslog.conf` and `/etc/rsyslog.d/*.conf` files and add the following line (where `loghost.example.com` is the name of your central log host). The `target` directive may either be a fully qualified domain name or an IP address.

Example:

```
*.* action(type="omfwd" target="loghost.example.com" port="514"
protocol="tcp"
           action.resumeRetryCount="100"
           queue.type="LinkedList" queue.size="1000")
```

Run the following command to reload `rsyslog.service`:

```
# systemctl reload-or-restart rsyslog.service
```

References:

1. See the rsyslog.conf(5) man page for more information.
2. NIST SP 800-53 Rev. 5: AU-6
3. https://www.rsyslog.com/doc/

Additional Information:

In addition, see the rsyslog documentation for implementation details of TLS.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.2.2.7 Ensure rsyslog is not configured to receive logs from a remote client (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`rsyslog` supports the ability to receive messages from remote hosts, thus acting as a log server. Clients should not receive data from other hosts.

Rationale:

If a client is configured to also receive data, thus turning it into a server, the client system is acting outside its operational boundary.

Audit:

Review the `/etc/rsyslog.conf` and `/etc/rsyslog.d/*.conf` files and verify that the system is not configured to accept incoming logs.

advanced format

```
# grep -Psi -- '^\h*module\(load=\"?imtcp\"?\)' /etc/rsyslog.conf
/etc/rsyslog.d/*.conf
# grep -Psi -- '^\h*input\(type=\"?imtcp\"?\b' /etc/rsyslog.conf
/etc/rsyslog.d/*.conf
```

Nothing should be returned

obsolete legacy format

```
# grep -Psi -- '^\h*\$ModLoad\h+imtcp\b' /etc/rsyslog.conf
/etc/rsyslog.d/*.conf
# grep -Psi -- '^\h*\$InputTCPServerRun\b' /etc/rsyslog.conf
/etc/rsyslog.d/*.conf
```

Nothing should be returned

Remediation:

Should there be any active log server configuration found in the auditing section, modify those files and remove the specific lines highlighted by the audit. Verify none of the following entries are present in any of `/etc/rsyslog.conf` or `/etc/rsyslog.d/*.conf`.

advanced format

```
module(load="imtcp")
input(type="imtcp" port="514")
```

deprecated legacy format

```
$ModLoad imtcp
$InputTCPServerRun
```

Restart the service:

```
# systemctl restart rsyslog
```

References:

1. NIST SP 800-53 Rev. 5: AU-2, AU-7, AU-12, CM-6
2. https://www.rsyslog.com/doc/index.html

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

6.2.2.8 Ensure logrotate is configured (Manual)

Profile Applicability:

- Level 1 - Server

Description:

The system includes the capability of rotating log files regularly to avoid filling up the system with logs or making the logs unmanageably large. The file `/etc/logrotate.d/syslog` is the configuration file used to rotate log files created by `syslog` or `rsyslog`.

Rationale:

By keeping the log files smaller and more manageable, a system administrator can easily archive these files to another system and spend less time looking through inordinately large log files.

Audit:

Review `/etc/logrotate.conf` and `/etc/logrotate.d/*` and verify logs are rotated according to site policy.

Remediation:

Edit `/etc/logrotate.conf` and `/etc/logrotate.d/*` to ensure logs are rotated according to site policy.

References:

1. NIST SP 800-53 Rev. 5: AU-8

Additional Information:

If no `maxage` setting is set for `logrotate` a situation can occur where `logrotate` is interrupted and fails to delete rotated log files. It is recommended to set this to a value greater than the longest any log file should exist on your system to ensure that any such log file is removed but standard rotation settings are not overridden.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 Ensure Adequate Audit Log Storage Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v7	6.4 Ensure adequate storage for logs Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●

6.2.3 Configure Logfiles

6.2.3.1 Ensure access to all logfiles has been configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Log files contain information from many services on the the local system, or in the event of a centralized log server, others systems logs as well.

In general log files are found in `/var/log/`, although application can be configured to store logs elsewhere. Should your application store logs in another, ensure to run the same test on that location.

Rationale:

It is important that log files have the correct permissions to ensure that sensitive data is protected and that only the appropriate users / groups have access to them.

Audit:

Run the following script to verify that files in `/var/log/` have appropriate permissions and ownership:

```
#!/usr/bin/env bash

{
   a_output=(); a_output2=()
   f_file_test_chk()
   {
      a_out2=()
      maxperm="$( printf '%o' $(( 0777 & ~$perm_mask)) )"
      [ $(( $l_mode & $perm_mask )) -gt 0 ] && \
         a_out2+=("   o Mode: \"$l_mode\" should be \"$maxperm\" or more
restrictive")
      [[ ! "$l_user" =~ $l_auser ]] && \
         a_out2+=("   o Owned by: \"$l_user\" and should be owned by
\"${l_auser//|/ or }\"")
      [[ ! "$l_group" =~ $l_agroup ]] && \
         a_out2+=("   o Group owned by: \"$l_group\" and should be group
owned by \"${l_agroup//|/ or }\"")
      [ "${#a_out2[@]}" -gt 0 ] && a_output2+=(" - File: \"$l_fname\" is:"
"${a_out2[@]}")
   }
   while IFS= read -r -d $'\0' l_file; do
      while IFS=: read -r l_fname l_mode l_user l_group; do
         if grep -Pq -- '\/(apt)\h*$' <<< "$(dirname "$l_fname")"; then
            perm_mask='0133' l_auser="root" l_agroup="(root|adm)";
f_file_test_chk
         else
            case "$(basename "$l_fname")" in
               lastlog | lastlog.* | wtmp | wtmp.* | wtmp-* | btmp | btmp.* |
btmp-* | README)
                  perm_mask='0113' l_auser="root" l_agroup="(root|utmp)"
                  f_file_test_chk ;;
               cloud-init.log* | localmessages* | waagent.log*)
                  perm_mask='0133' l_auser="(root|syslog)"
l_agroup="(root|adm)"
                  file_test_chk ;;
               secure{,*.*,.*,-*} | auth.log | syslog | messages)
                  perm_mask='0137' l_auser="(root|syslog)"
l_agroup="(root|adm)"
                  f_file_test_chk ;;
               SSSD | sssd)
                  perm_mask='0117' l_auser="(root|SSSD)"
l_agroup="(root|SSSD)"
                  f_file_test_chk ;;
               gdm | gdm3)
                  perm_mask='0117' l_auser="root" l_agroup="(root|gdm|gdm3)"
                  f_file_test_chk ;;
               *.journal | *.journal~)
                  perm_mask='0137' l_auser="root" l_agroup="(root|systemd-
journal)"
                  f_file_test_chk ;;
               *)
                  perm_mask='0137' l_auser="(root|syslog)"
l_agroup="(root|adm)"
                  if [ "$l_user" = "root" ] || ! grep -Pq -- "^\h*$(awk -F:
'$1=="'"$l_user"'" {print $7}' /etc/passwd)\b" /etc/shells; then
                     ! grep -Pq -- "$l_auser" <<< "$l_user" &&
l_auser="(root|syslog|$l_user)"
```

```
                    ! grep -Pq -- "$l_agroup" <<< "$l_group" &&
l_agroup="(root|adm|$l_group)"
                fi
                f_file_test_chk ;;
            esac
         fi
      done < <(stat -Lc '%n:%#a:%U:%G' "$l_file")
   done < <(find -L /var/log -type f \( -perm /0137 -o ! -user root -o ! -
group root \) -print0)
   if [ "${#a_output2[@]}" -le 0 ]; then
      a_output+=("  - All files in \"/var/log/\" have appropriate permissions
and ownership")
      printf '\n%s' "- Audit Result:" "  ** PASS **" "${a_output[@]}" ""
   else
      printf '\n%s' "- Audit Result:" "  ** FAIL **" " - Reason(s) for audit
failure:" "${a_output2[@]}" ""
   fi
}
```

Remediation:

Run the following script to update permissions and ownership on files in `/var/log`.

Although the script is not destructive, ensure that the output is captured in the event that the remediation causes issues.

```
#!/usr/bin/env bash

{
   a_output2=()
   f_file_test_fix()
   {
      a_out2=()
      maxperm="$( printf '%o' $(( 0777 & ~$perm_mask)) )"
      if [ $(( $l_mode & $perm_mask )) -gt 0 ]; then
         a_out2+=("   o Mode: \"$l_mode\" should be \"$maxperm\" or more
restrictive" "     x Removing excess permissions")
         chmod "$l_rperms" "$l_fname"
      fi
      if [[ ! "$l_user" =~ $l_auser ]]; then
         a_out2+=("   o Owned by: \"$l_user\" and should be owned by
\"${l_auser//|/ or }\"" "     x Changing ownership to: \"$l_fix_account\"")
         chown "$l_fix_account" "$l_fname"
      fi
      if [[ ! "$l_group" =~ $l_agroup ]]; then
         a_out2+=("   o Group owned by: \"$l_group\" and should be group
owned by \"${l_agroup//|/ or }\"" "     x Changing group ownership to:
\"$l_fix_account\"")
         chgrp "$l_fix_account" "$l_fname"
      fi
      [ "${#a_out2[@]}" -gt 0 ] && a_output2+=(" - File: \"$l_fname\" is:"
"${a_out2[@]}")
   }
   l_fix_account='root'
   while IFS= read -r -d $'\0' l_file; do
      while IFS=: read -r l_fname l_mode l_user l_group; do
         if grep -Pq -- '\/(apt)\h*$' <<< "$(dirname "$l_fname")"; then
            perm_mask='0133' l_rperms="u-x,go-wx" l_auser="root"
l_agroup="(root|adm)"; f_file_test_fix
         else
            case "$(basename "$l_fname")" in
               lastlog | lastlog.* | wtmp | wtmp.* | wtmp-* | btmp | btmp.* |
btmp-* | README)
                  perm_mask='0113' l_rperms="ug-x,o-wx" l_auser="root"
l_agroup="(root|utmp)"
                  f_file_test_fix ;;
               cloud-init.log* | localmessages* | waagent.log*)
                  perm_mask='0133' l_rperms="u-x,go-wx"
l_auser="(root|syslog)" l_agroup="(root|adm)"
                  file_test_fix ;;
               secure | auth.log | syslog | messages)
                  perm_mask='0137' l_rperms="u-x,g-wx,o-rwx"
l_auser="(root|syslog)" l_agroup="(root|adm)"
                  f_file_test_fix ;;
               SSSD | sssd)
                  perm_mask='0117' l_rperms="ug-x,o-rwx"
l_auser="(root|SSSD)" l_agroup="(root|SSSD)"
                  f_file_test_fix ;;
               gdm | gdm3)
                  perm_mask='0117' l_rperms="ug-x,o-rwx" l_auser="root"
l_agroup="(root|gdm|gdm3)"
                  f_file_test_fix ;;
               *.journal | *.journal~)
```

```
                  perm_mask='0137' l_rperms="u-x,g-wx,o-rwx" l_auser="root"
l_agroup="(root|systemd-journal)"
                  f_file_test_fix ;;
               *)
                  perm_mask='0137' l_rperms="u-x,g-wx,o-rwx"
l_auser="(root|syslog)" l_agroup="(root|adm)"
                  if [ "$l_user" = "root" ] || ! grep -Pq -- "^\h*$(awk -F:
'$1=="'"$l_user"'" {print $7}' /etc/passwd)\b" /etc/shells; then
                     ! grep -Pq -- "$l_auser" <<< "$l_user" &&
l_auser="(root|syslog|$l_user)"
                     ! grep -Pq -- "$l_agroup" <<< "$l_group" &&
l_agroup="(root|adm|$l_group)"
                  fi
                  f_file_test_fix ;;
            esac
         fi
      done < <(stat -Lc '%n:%#a:%U:%G' "$l_file")
   done < <(find -L /var/log -type f \( -perm /0137 -o ! -user root -o ! -
group root \) -print0)
   if [ "${#a_output2[@]}" -le 0 ]; then # If all files passed, then we
report no changes
      a_output+=("  - All files in \"/var/log/\" have appropriate permissions
and ownership")
      printf '\n%s' "- All files in \"/var/log/\" have appropriate
permissions and ownership" "  o No changes required" ""
   else
      printf '\n%s' "${a_output2[@]}" ""
   fi
}
```

Note: You may also need to change the configuration for your logging software or services for any logs that had incorrect permissions.

If there are services that log to other locations, ensure that those log files have the appropriate access configured.

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

6.3 System Auditing

The Linux Auditing System operates on a set of rules that collects certain types of system activity to facilitate incident investigation, detect unauthorized access or modification of data. By default events will be logged to `/var/log/audit/audit.log`, which can be configured in `/etc/audit/auditd.conf`.

The following types of audit rules can be specified:

- Control rules: Configuration of the auditing system.
- File system rules: Allow the auditing of access to a particular file or a directory. Also known as file watches.
- System call rules: Allow logging of system calls that any specified program makes.

Audit rules can be set:

- On the command line using the `auditctl` utility. These rules are not persistent across reboots.
- In `/etc/audit/audit.rules`. These rules have to be merged and loaded before they are active.

Note:

- For 64 bit systems that have `arch` as a rule parameter, you will need two rules: one for 64 bit and one for 32 bit systems calls. For 32 bit systems, only one rule is needed.
- If the auditing system is configured to be locked (`-e 2`), a system reboot will be required in order to load any changes.
- Key names are optional on the rules and will not be used in compliance auditing. The usage of key names is highly recommended as it facilitates organization and searching; as such, all remediation steps will have key names supplied.
- It is best practice to store the rules, in number prepended files, in `/etc/audit/rules.d/`. Rules must end in a `.rules` suffix. This then requires the use of `augenrules` to merge all the rules into `/etc/audit/audit.rules` based on their alphabetical (lexical) sort order. All benchmark recommendations follow this best practice for remediation, specifically using the prefix of `50` which is center weighed if all rule sets make use of the number prepending naming convention.
- Your system may have been customized to change the default `UID_MIN`. All sample output uses `1000`, but this value will not be used in compliance auditing. To confirm the `UID_MIN` for your system, run the following command: `awk '/^\s*UID_MIN/{print $2}' /etc/login.defs`

Normalization The Audit system normalizes some entries, so when you look at the sample output keep in mind that:

- With regards to users whose login UID is not set, the values `-1` / `unset` / `4294967295` are equivalent and normalized to `-1`.
- When comparing field types and both sides of the comparison is valid fields types, such as `euid!=uid`, then the auditing system may normalize such that the output is `uid!=euid`.
- Some parts of the rule may be rearranged whilst others are dependent on previous syntax. For example, the following two statements are the same:

```
-a always,exit -F arch=b64 -S execve -C uid!=euid -F auid!=-1 -F
key=user_emulation
```

and

```
-a always,exit -F arch=b64 -C euid!=uid -F auid!=unset -S execve -k
user_emulation
```

Capacity planning

The recommendations in this section implement auditing policies that not only produce large quantities of logged data, but may also negatively impact system performance. Capacity planning is critical in order not to adversely impact production environments.

- Disk space. If a significantly large set of events are captured, additional on system or off system storage may need to be allocated. If the logs are not sent to a remote log server, ensure that log rotation is implemented else the disk will fill up and the system will halt. Even when logs are sent to a log server, ensure sufficient disk space to allow caching of logs in the case of temporary network outages.
- Disk IO. It is not just the amount of data collected that should be considered, but the rate at which logs are generated.
- CPU overhead. System call rules might incur considerable CPU overhead. Test the systems open/close syscalls per second with and without the rules to gauge the impact of the rules.

6.3.1 Configure auditd Service

The capturing of system events provides system administrators with information to allow them to determine if unauthorized access to their system is occurring.

6.3.1.1 Ensure auditd packages are installed (Automated)

Profile Applicability:

- Level 2 - Server

Description:

`auditd` is the userspace component to the Linux Auditing System. It's responsible for writing audit records to the disk.

Rationale:

The capturing of system events provides system administrators with information to allow them to determine if unauthorized access to their system is occurring.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000038-GPOS-00016, SRG-OS-000039-GPOS-00017, SRG-OS-000040-GPOS-00018, SRG-OS-000041-GPOS-00019, SRG-OS-000042-GPOS-00021, SRG-OS-000051-GPOS-00024, SRG-OS-000054-GPOS-00025, SRG-OS-000122-GPOS-00063, SRG-OS-000254-GPOS-00095, SRG-OS-000255-GPOS-00096, SRG-OS-000337-GPOS-00129, SRG-OS-000348-GPOS-00136, SRG-OS-000349-GPOS-00137, SRG-OS-000350-GPOS-00138, SRG-OS-000351-GPOS-00139, SRG-OS-000352-GPOS-00140, SRG-OS-000353-GPOS-00141, SRG-OS-000354-GPOS-00142, SRG-OS-000358-GPOS-00145, SRG-OS-000365-GPOS-00152, SRG-OS-000392-GPOS-00172, SRG-OS-000475-GPOS-00220

Audit:

Run the following command and verify `audit` and `audit-libs` packages are installed:

```
# rpm -q audit audit-libs

audit-<version>
audit-libs-<version>
```

Remediation:

Run the following command to install `audit` and `audit-libs`:

```
# dnf install audit audit-libs
```

References:

1. NIST SP 800-53 Rev. 5: AU-2, AU-3, AU-3(1), AU-12, SI-5
2. NIST SP 800-53A :: AU-12.1 (ii)
3. RHEL 8 STIG Vul ID: V-230411
4. RHEL 8 STIG Rule ID: SV-230411r744000

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.3.1.2 Ensure auditing for processes that start prior to auditd is enabled (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Configure `grub2` so that processes that are capable of being audited can be audited even if they start up prior to `auditd` startup.

Rationale:

Audit events need to be captured on processes that start up prior to `auditd` , so that potential malicious activity cannot go undetected.

Audit:

Note: `/etc/default/grub` should be checked because the `grub2-mkconfig -o` command will overwrite `grub.cfg` with parameters listed in `/etc/default/grub`.

Run the following command to verify that the `audit=1` parameter has been set:

```
# grubby --info=ALL | grep -Po '\baudit=1\b'

audit=1
```

Note: `audit=1` may be returned multiple times

Run the following command to verify that the `audit=1` parameter has been set in `/etc/default/grub`:

```
# grep -Psoi -- '^\h*GRUB_CMDLINE_LINUX=\"([^#\n\r]+\h+)?audit=1\b'
/etc/default/grub
```

Example output:

```
GRUB_CMDLINE_LINUX="quiet audit=1"
```

Note: Other parameters may also be listed

Remediation:

Run the following command to update the `grub2` configuration with `audit=1`:

```
# grubby --update-kernel ALL --args 'audit=1'
```

Edit `/etc/default/grub` and add `audit=1` to the `GRUB_CMDLINE_LINUX=` line between the opening and closing double quotes:

Example:

```
GRUB_CMDLINE_LINUX="quiet audit=1"
```

Note: Other parameters may also be listed

References:

1. NIST SP 800-53 :: AU-12 a
2. NIST SP 800-53A :: AU-12.1 (ii)
3. RHEL 8 STIG GROUP ID: V-230468
4. RHEL 8 STIG Rule ID: SV-230468r792904

Additional Information:

This recommendation is designed around the grub 2 bootloader, if another bootloader is in use in your environment enact equivalent settings.

`grubby` is a command line tool used to configure bootloader menu entries across multiple architectures. It is used for updating and displaying information about the configuration files for various architecture specific bootloaders.

It is primarily designed to be used from scripts which install new kernels and need to find information about the current boot environment.

The grubby executable has full support for the grub2 bootloader on x86_64 systems using legacy BIOS or modern UEFI firmware and ppc64 and ppc64le hardware using OPAL or SLOF as firmware.

Legacy s390 and the current s390x architectures and their zipl bootloader are fully supported.

Support for yaboot has been deprecated as all ppc architecture hardware since the Power8 uses grub2 or petitboot which both use the grub2 configuration file format.

Legacy bootloaders LILO, SILO, and ELILO are deprecated and no longer receiving active support in favor of previously mentioned bootloaders.

The default bootloader target is primarily determined by the architecture for which grubby has been built. Each architecture has a preferred bootloader, and each bootloader has its own configuration file. If no bootloader is selected on the command line, grubby will use these default settings to search for an existing configuration. If no bootloader configuration file is found, grubby will use the default value for that architecture.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

6.3.1.3 Ensure audit_backlog_limit is configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The `audit_backlog_limit` parameter determines how auditd records can be held in the auditd backlog. The default setting of 64 may be insufficient to store all audit events during boot.

Rationale:

During boot if `audit=1`, then the backlog will hold 64 records. If more than 64 records are created during boot, auditd records will be lost and potential malicious activity could go undetected.

Audit:

Note: `/etc/default/grub` should be checked because the `grub2-mkconfig -o` command will overwrite `grub.cfg` with parameters listed in `/etc/default/grub`.

Run the following command and verify the `audit_backlog_limit=` parameter is set to an appropriate size for your organization

```
# grubby --info=ALL | grep -Po "\baudit_backlog_limit=\d+\b"

audit_backlog_limit=<BACKLOG SIZE>
```

Validate that the line(s) returned contain a value for `audit_backlog_limit=` that is sufficient for your organization.

Recommended that this value be `8192` or larger.

Run the following command to verify that the `audit_backlog_limit=<BACKLOG SIZE>` parameter has been set in `/etc/default/grub`:

```
# grep -Psoi --
'^\h*GRUB_CMDLINE_LINUX=\"([^#\n\r]+\h+)?\baudit_backlog_limit=\d+\b'
/etc/default/grub
```

Example output:

```
GRUB_CMDLINE_LINUX="quiet audit_backlog_limit=8192"
```

Note: Other parameters may also be listed

Remediation:

Run the following command to add `audit_backlog_limit=<BACKLOG SIZE>` to GRUB_CMDLINE_LINUX:

```
# grubby --update-kernel ALL --args 'audit_backlog_limit=<BACKLOG SIZE>'
```

Example:

```
# grubby --update-kernel ALL --args 'audit_backlog_limit=8192'
```

Edit `/etc/default/grub` and add `audit_backlog_limit=<BACKLOG SIZE>` to the `GRUB_CMDLINE_LINUX=` line between the opening and closing double quotes:

Example:

```
GRUB_CMDLINE_LINUX="quiet audit_backlog_limit=8192"
```

Note: Other parameters may also be listed

References:

1. NIST SP 800-53 Rev. 5: AU-2, AU-12, SI-5

Additional Information:

This recommendation is designed around the grub 2 bootloader, if another bootloader is in use in your environment enact equivalent settings.

`grubby` is a command line tool used to configure bootloader menu entries across multiple architectures. It is used for updating and displaying information about the configuration files for various architecture specific bootloaders.

It is primarily designed to be used from scripts which install new kernels and need to find information about the current boot environment.

The grubby executable has full support for the grub2 bootloader on x86_64 systems using legacy BIOS or modern UEFI firmware and ppc64 and ppc64le hardware using OPAL or SLOF as firmware.

Legacy s390 and the current s390x architectures and their zipl bootloader are fully supported.

Support for yaboot has been deprecated as all ppc architecture hardware since the Power8 uses grub2 or petitboot which both use the grub2 configuration file format.

Legacy bootloaders LILO, SILO, and ELILO are deprecated and no longer receiving active support in favor of previously mentioned bootloaders.

The default bootloader target is primarily determined by the architecture for which grubby has been built. Each architecture has a preferred bootloader, and each bootloader has its own configuration file. If no bootloader is selected on the command line, grubby will use these default settings to search for an existing configuration. If no bootloader configuration file is found, grubby will use the default value for that architecture.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.3.1.4 Ensure auditd service is enabled and active (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Turn on the `auditd` daemon to record system events.

Rationale:

The capturing of system events provides system administrators with information to allow them to determine if unauthorized access to their system is occurring.

Audit:

Run the following command to verify `auditd` is enabled:

```
# systemctl is-enabled auditd | grep '^enabled'

enabled
```

Verify result is "enabled".

Run the following command to verify `auditd` is active:

```
# systemctl is-active auditd | grep '^active'

active
```

Verify result is active

Remediation:

Run the following commands to unmask, enable and start `auditd`:

```
# systemctl unmask auditd
# systemctl enable auditd
# systemctl start auditd
```

References:

1. NIST SP 800-53 :: AU-12 a
2. NIST SP 800-53A :: AU-12.1 (ii)
3. RHEL 8 STIG Vul ID: V-244542
4. RHEL 8 STIG Rule ID: SV-244542r818838

Additional Information:

Additional methods of enabling a service exist. Consult your distribution documentation for appropriate methods.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.3.2 Configure Data Retention

When auditing, it is important to carefully configure the storage requirements for audit logs. By default, auditd will max out the log files at 5MB and retain only 4 copies of them. Older versions will be deleted. It is possible on a system that the 20 MBs of audit logs may fill up the system causing loss of audit data. While the recommendations here provide guidance, check your site policy for audit storage requirements.

6.3.2.1 Ensure audit log storage size is configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Configure the maximum size of the audit log file. Once the log reaches the maximum size, it will be rotated and a new log file will be started.

Rationale:

It is important that an appropriate size is determined for log files so that they do not impact the system and audit data is not lost.

Audit:

Run the following command and ensure output is in compliance with site policy:

```
# grep -Po -- '^\h*max_log_file\h*=\h*\d+\b' /etc/audit/auditd.conf

max_log_file = <MB>
```

Remediation:

Set the following parameter in `/etc/audit/auditd.conf` in accordance with site policy:

```
max_log_file = <MB>
```

Default Value:

`max_log_file = 8`

References:

1. NIST SP 800-53 Rev. 5: AU-8

Additional Information:

The `max_log_file` parameter is measured in megabytes.

Other methods of log rotation may be appropriate based on site policy. One example is time-based rotation strategies which don't have native support in `auditd` configurations. Manual audit of custom configurations should be evaluated for effectiveness and completeness.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 Ensure Adequate Audit Log Storage Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v7	6.4 Ensure adequate storage for logs Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●

6.3.2.2 Ensure audit logs are not automatically deleted (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The `max_log_file_action` setting determines how to handle the audit log file reaching the max file size. A value of `keep_logs` will rotate the logs but never delete old logs.

Rationale:

In high security contexts, the benefits of maintaining a long audit history exceed the cost of storing the audit history.

Audit:

Run the following command and verify output matches:

```
# grep max_log_file_action /etc/audit/auditd.conf

max_log_file_action = keep_logs
```

Remediation:

Set the following parameter in `/etc/audit/auditd.conf:`

```
max_log_file_action = keep_logs
```

Default Value:

max_log_file_action = ROTATE

References:

1. NIST SP 800-53 Rev. 5: AU-8

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.3 Ensure Adequate Audit Log Storage Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●
v7	6.4 Ensure adequate storage for logs Ensure that all systems that store logs have adequate storage space for the logs generated.		●	●

6.3.2.3 Ensure system is disabled when audit logs are full (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The `auditd` daemon can be configured to halt the system or put the system in single user mode, if no free space is available or an error is detected on the partition that holds the audit log files.

The `disk_full_action` parameter tells the system what action to take when no free space is available on the partition that holds the audit log files. Valid values are `ignore`, `syslog`, `rotate`, `exec`, `suspend`, `single`, and `halt`.

- `ignore`, the audit daemon will issue a syslog message but no other action is taken
- `syslog`, the audit daemon will issue a warning to syslog
- `rotate`, the audit daemon will rotate logs, losing the oldest to free up space
- `exec`, /path-to-script will execute the script. You cannot pass parameters to the script. The script is also responsible for telling the auditd daemon to resume logging once its completed its action
- `suspend`, the audit daemon will stop writing records to the disk
- `single`, the audit daemon will put the computer system in single user mode
- `halt`, the audit daemon will shut down the system

The `disk_error_action` parameter tells the system what action to take when an error is detected on the partition that holds the audit log files. Valid values are `ignore`, `syslog`, `exec`, `suspend`, `single`, and `halt`.

- `ignore`, the audit daemon will not take any action
- `syslog`, the audit daemon will issue no more than 5 consecutive warnings to syslog
- `exec`, /path-to-script will execute the script. You cannot pass parameters to the script
- `suspend`, the audit daemon will stop writing records to the disk
- `single`, the audit daemon will put the computer system in single user mode
- `halt`, the audit daemon will shut down the system

Rationale:

In high security contexts, the risk of detecting unauthorized access or nonrepudiation exceeds the benefit of the system's availability.

Impact:

`disk_full_action` parameter:

- Set to `halt` - the `auditd` daemon will shutdown the system when the disk partition containing the audit logs becomes full.
- Set to `single` - the `auditd` daemon will put the computer system in single user mode when the disk partition containing the audit logs becomes full.

`disk_error_action` parameter:

- Set to `halt` - the `auditd` daemon will shutdown the system when an error is detected on the partition that holds the audit log files.
- Set to `single` - the `auditd` daemon will put the computer system in single user mode when an error is detected on the partition that holds the audit log files.
- Set to `syslog` - the `auditd` daemon will issue no more than 5 consecutive warnings to syslog when an error is detected on the partition that holds the audit log files.

Audit:

Run the following command and verify the `disk_full_action` is set to either `halt` or `single`:

```
# grep -P -- '^\h*disk_full_action\h*=\h*(halt|single)\b'
/etc/audit/auditd.conf

disk_full_action = <halt|single>
```

Run the following command and verify the `disk_error_action` is set to `syslog`, `single`, or `halt`:

```
# grep -P -- '^\h*disk_error_action\h*=\h*(syslog|single|halt)\b'
/etc/audit/auditd.conf

disk_error_action = <syslog|single|halt>
```

Remediation:

Set one of the following parameters in `/etc/audit/auditd.conf` depending on your local security policies.

```
disk_full_action = <halt|single>
disk_error_action = <syslog|single|halt>
```

Example:

```
disk_full_action = halt
disk_error_action = halt
```

References:

1. AUDITD.CONF(5)
2. https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/8/html/security_hardening/auditing-the-system_security-hardening#configuring-auditd-for-a-secure-environment_auditing-the-system
3. NIST SP 800-53 :: AU-5 b
4. NIST SP 800-53A :: AU-5.1 (iv)
5. RHEL 8 STIG Vul ID: V-230390
6. RHEL 8 STIG Rule ID: SV-230390r627750_rule
7. RHEL 8 STIG Vul ID: V-230392
8. RHEL 8 STIG Rule ID: SV-230392r627750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.3 Ensure Adequate Audit Log Storage Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●

6.3.2.4 Ensure system warns when audit logs are low on space (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The `auditd` daemon can be configured to halt the system, put the system in single user mode or send a warning message, if the partition that holds the audit log files is low on space.

The `space_left_action` parameter tells the system what action to take when the system has detected that it is starting to get low on disk space. Valid values are `ignore`, `syslog`, `rotate`, `email`, `exec`, `suspend`, `single`, and `halt`.

- `ignore`, the audit daemon does nothing
- `syslog`, the audit daemon will issue a warning to syslog
- `rotate`, the audit daemon will rotate logs, losing the oldest to free up space
- `email`, the audit daemon will send a warning to the email account specified in `action_mail_acct` as well as sending the message to syslog
- `exec`, /path-to-script will execute the script. You cannot pass parameters to the script. The script is also responsible for telling the auditd daemon to resume logging once its completed its action
- `suspend`, the audit daemon will stop writing records to the disk
- `single`, the audit daemon will put the computer system in single user mode
- `halt`, the audit daemon will shut down the system

The `admin_space_left_action` parameter tells the system what action to take when the system has detected that it is low on disk space. Valid values are `ignore`, `syslog`, `rotate`, `email`, `exec`, `suspend`, `single`, and `halt`.

- `ignore`, the audit daemon does nothing
- `syslog`, the audit daemon will issue a warning to syslog
- `rotate`, the audit daemon will rotate logs, losing the oldest to free up space
- `email`, the audit daemon will send a warning to the email account specified in `action_mail_acct` as well as sending the message to syslog
- `exec`, /path-to-script will execute the script. You cannot pass parameters to the script. The script is also responsible for telling the auditd daemon to resume logging once its completed its action
- `suspend`, the audit daemon will stop writing records to the disk
- `single`, the audit daemon will put the computer system in single user mode
- `halt`, the audit daemon will shut down the system

Rationale:

In high security contexts, the risk of detecting unauthorized access or nonrepudiation exceeds the benefit of the system's availability.

Impact:

If the `admin_space_left_action` is set to `single` the audit daemon will put the computer system in single user mode.

Audit:

Run the following command and verify the `space_left_action` is set to `email`, `exec`, `single`, or `halt`:

```
grep -P -- '^\h*space_left_action\h*=\h*(email|exec|single|halt)\b'
/etc/audit/auditd.conf
```

Verify the output is `email`, `exec`, `single`, or `halt`

Example output

```
space_left_action = email
```

Run the following command and verify the `admin_space_left_action` is set to `single` **- OR -** `halt`:

```
grep -P -- '^\h*admin_space_left_action\h*=\h*(single|halt)\b'
/etc/audit/auditd.conf
```

Verify the output is `single` or `halt`

Example output:

```
admin_space_left_action = single
```

Note: A Mail Transfer Agent (MTA) must be installed and configured properly to set `space_left_action = email`

Remediation:

Set the `space_left_action` parameter in `/etc/audit/auditd.conf` to `email`, `exec`, `single`, or `halt`:

Example:

```
space_left_action = email
```

Set the `admin_space_left_action` parameter in `/etc/audit/auditd.conf` to `single` or `halt`:

Example:

```
admin_space_left_action = single
```

Note: A Mail Transfer Agent (MTA) must be installed and configured properly to set `space_left_action = email`

Default Value:

space_left_action = SYSLOG

admin_space_left_action = SUSPEND

References:

1. NIST SP 800-53 Rev. 5: AU-2, AU-8, AU-12, SI-5
2. AUDITD.CONF(5)
3. https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/8/html/security_hardening/auditing-the-system_security-hardening#configuring-auditd-for-a-secure-environment_auditing-the-system

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.3 Ensure Adequate Audit Log Storage Ensure that logging destinations maintain adequate storage to comply with the enterprise's audit log management process.	●	●	●

6.3.3 Configure auditd Rules

The Audit system operates on a set of rules that define what is to be captured in the log files.

The following types of Audit rules can be specified:

- Control rules: Allow the Audit system's behavior and some of its configuration to be modified.
- File system rules: Allow the auditing of access to a particular file or a directory. (Also known as file watches)
- System call rules: Allow logging of system calls that any specified program makes.

Audit rules can be set:

- on the command line using the auditctl utility. Note that these rules are not persistent across reboots.
- in a file ending in `.rules` in the `/etc/audit/rules.d/` directory.

6.3.3.1 Ensure changes to system administration scope (sudoers) is collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Monitor scope changes for system administrators. If the system has been properly configured to force system administrators to log in as themselves first and then use the `sudo` command to execute privileged commands, it is possible to monitor changes in scope. The file `/etc/sudoers`, or files in `/etc/sudoers.d`, will be written to when the file(s) or related attributes have changed. The audit records will be tagged with the identifier "scope".

Rationale:

Changes in the `/etc/sudoers` and `/etc/sudoers.d` files can indicate that an unauthorized change has been made to the scope of system administrator activity.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000004-GPOS-00004, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000304-GPOS-00121, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000470-GPOS-00214, SRG-OS-000471-GPOS-00215, SRG-OS-000239-GPOS-00089, SRG-OS-000240-GPOS-00090, SRG-OS-000241-GPOS-00091, SRG-OS-000303-GPOS-00120, SRG-OS-000304-GPOS-00121, CCI-002884, SRG-OS-000466-GPOS-00210, SRG-OS-000476-GPOS-00221

Audit:

On disk configuration

Run the following command to check the on disk rules:

```
# awk '/^ *-w/ \
&&/\/etc\/sudoers/ \
&&/ +-p *wa/ \
&&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)' /etc/audit/rules.d/*.rules
```

Verify the output matches:

```
-w /etc/sudoers -p wa -k scope
-w /etc/sudoers.d -p wa -k scope
```

Running configuration

Run the following command to check loaded rules:

```
# auditctl -l | awk '/^ *-w/ \
&&/\/etc\/sudoers/ \
&&/ +-p *wa/ \
&&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)'
```

Verify the output matches:

```
-w /etc/sudoers -p wa -k scope
-w /etc/sudoers.d -p wa -k scope
```

Remediation:

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor scope changes for system administrators.

Example:

```
# printf '%s\n' "-w /etc/sudoers -p wa -k scope" "-w /etc/sudoers.d -p wa -k
scope" >> /etc/audit/rules.d/50-scope.rules
```

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 :: AU-12 a
2. NIST SP 800-53A :: AU-12.1 (ii)
3. RHEL 8 STIG Vul ID: V-230409
4. RHEL 8 STIG Rule ID: SV-230409r627750_rule
5. RHEL 8 STIG Vul ID: V-230410
6. RHEL 8 STIG Rule ID: SV-230410r627750

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	4.8 Log and Alert on Changes to Administrative Group Membership Configure systems to issue a log entry and alert when an account is added to or removed from any group assigned administrative privileges.		●	●

6.3.3.2 Ensure actions as another user are always logged (Automated)

Profile Applicability:

- Level 2 - Server

Description:

`sudo` provides users with temporary elevated privileges to perform operations, either as the superuser or another user.

Rationale:

Creating an audit log of users with temporary elevated privileges and the operation(s) they performed is essential to reporting. Administrators will want to correlate the events written to the audit trail with the records written to `sudo`'s logfile to verify if unauthorized commands have been executed.

Satisfies: SRG-OS-000326-GPOS-00126, SRG-OS-000327-GPOS-00127

Audit:

On disk configuration

Run the following command to check the on disk rules:

```
# awk '/^ *-a *always,exit/ \
&&/ -F *arch=b(32|64)/ \
&&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
&&(/ -C *euid!=uid/||/ -C *uid!=euid/) \
&&/ -S *execve/ \
&&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)' /etc/audit/rules.d/*.rules
```

Verify the output matches:

```
-a always,exit -F arch=b64 -C euid!=uid -F auid!=unset -S execve -k
user_emulation
-a always,exit -F arch=b32 -C euid!=uid -F auid!=unset -S execve -k
user_emulation
```

Running configuration

Run the following command to check loaded rules:

```
# auditctl -l | awk '/^ *-a *always,exit/ \
&&/ -F *arch=b(32|64)/ \
&&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
&&(/ -C *euid!=uid/||/ -C *uid!=euid/) \
&&/ -S *execve/ \
&&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)'
```

Verify the output matches:

```
-a always,exit -F arch=b64 -S execve -C uid!=euid -F auid!=-1 -F
key=user_emulation
-a always,exit -F arch=b32 -S execve -C uid!=euid -F auid!=-1 -F
key=user_emulation
```

Remediation:

Create audit rules

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor elevated privileges.

Example:

```
# printf "
-a always,exit -F arch=b64 -C euid!=uid -F auid!=unset -S execve -k
user_emulation
-a always,exit -F arch=b32 -C euid!=uid -F auid!=unset -S execve -k
user_emulation
" >> /etc/audit/rules.d/50-user_emulation.rules
```

Load audit rules

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 Revision 5 :: AC-6 (8)
2. RHEL 8 STIG Vul ID: V-230386
3. RHEL 8 STIG Rule ID: SV-230386r854037

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	4.9 Log and Alert on Unsuccessful Administrative Account Login Configure systems to issue a log entry and alert on unsuccessful logins to an administrative account.		●	●

6.3.3.3 Ensure events that modify the sudo log file are collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Monitor the `sudo` log file. If the system has been properly configured to disable the use of the `su` command and force all administrators to have to log in first and then use `sudo` to execute privileged commands, then all administrator commands will be logged to `/var/log/sudo.log` . Any time a command is executed, an audit event will be triggered as the `/var/log/sudo.log` file will be opened for write and the executed administration command will be written to the log.

Rationale:

Changes in `/var/log/sudo.log` indicate that an administrator has executed a command or the log file itself has been tampered with. Administrators will want to correlate the events written to the audit trail with the records written to `/var/log/sudo.log` to verify if unauthorized commands have been executed.

Audit:

Note: This recommendation requires that the sudo logfile is configured. See guidance provided in the recommendation "Ensure sudo log file exists"

On disk configuration

Run the following command to check the on disk rules:

```
# {
 SUDO_LOG_FILE=$(grep -r logfile /etc/sudoers* | sed -e 's/.*logfile=//;s/,?
.*//' -e 's/"//g' -e 's|/|\\/|g')
 [ -n "${SUDO_LOG_FILE}" ] && awk "/^ *-w/ \
 &&/"${SUDO_LOG_FILE}"/ \
 &&/ +-p *wa/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" /etc/audit/rules.d/*.rules \
 || printf "ERROR: Variable 'SUDO_LOG_FILE' is unset.\n"
}
```

Verify output of matches:

```
-w /var/log/sudo.log -p wa -k sudo_log_file
```

Running configuration

Run the following command to check loaded rules:

```
# {
 SUDO_LOG_FILE=$(grep -r logfile /etc/sudoers* | sed -e 's/.*logfile=//;s/,?
.*//' -e 's/"//g' -e 's|/|\\/|g')
 [ -n "${SUDO_LOG_FILE}" ] && auditctl -l | awk "/^ *-w/ \
 &&/"${SUDO_LOG_FILE}"/ \
 &&/ +-p *wa/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" \
 || printf "ERROR: Variable 'SUDO_LOG_FILE' is unset.\n"
}
```

Verify output matches:

```
-w /var/log/sudo.log -p wa -k sudo_log_file
```

Remediation:

Note: This recommendation requires that the sudo logfile is configured. See guidance provided in the recommendation "Ensure sudo log file exists"

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor events that modify the sudo log file.

Example:

```
# {
SUDO_LOG_FILE=$(grep -r logfile /etc/sudoers* | sed -e 's/.*logfile=//;s/,?
.*//' -e 's/"//g')
[ -n "${SUDO_LOG_FILE}" ] && printf "
-w ${SUDO_LOG_FILE} -p wa -k sudo_log_file
" >> /etc/audit/rules.d/50-sudo.rules || printf "ERROR: Variable
'SUDO_LOG_FILE' is unset.\n"
}
```

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	4.9 Log and Alert on Unsuccessful Administrative Account Login Configure systems to issue a log entry and alert on unsuccessful logins to an administrative account.		●	●

6.3.3.4 Ensure events that modify date and time information are collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Capture events where the system date and/or time has been modified. The parameters in this section are set to determine if the;

- `adjtimex` - tune kernel clock
- `settimeofday` - set time using `timeval` and `timezone` structures
- `stime` - using seconds since 1/1/1970
- `clock_settime` - allows for the setting of several internal clocks and timers

system calls have been executed. Further, ensure to write an audit record to the configured audit log file upon exit, tagging the records with a unique identifier such as "time-change".

Rationale:

Unexpected changes in system date and/or time could be a sign of malicious activity on the system.

Audit:

On disk configuration

Run the following command to check the on disk rules:

```
# {
 awk '/^ *-a *always,exit/ \
 &&/ -F *arch=b(32|64)/ \
 &&/ -S/ \
 &&(/adjtimex/ \
   ||/settimeofday/ \
   ||/clock_settime/ ) \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)' /etc/audit/rules.d/*.rules

 awk '/^ *-w/ \
 &&/\/etc\/localtime/ \
 &&/ +-p *wa/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)' /etc/audit/rules.d/*.rules
}
```

Verify output of matches:

```
-a always,exit -F arch=b64 -S adjtimex,settimeofday -k time-change
-a always,exit -F arch=b32 -S adjtimex,settimeofday -k time-change
-a always,exit -F arch=b64 -S clock_settime -F a0=0x0 -k time-change
-a always,exit -F arch=b32 -S clock_settime -F a0=0x0 -k time-change
-w /etc/localtime -p wa -k time-change
```

Running configuration

Run the following command to check loaded rules:

```
# {
 auditctl -l | awk '/^ *-a *always,exit/ \
 &&/ -F *arch=b(32|64)/ \
 &&/ -S/ \
 &&(/adjtimex/ \
   ||/settimeofday/ \
   ||/clock_settime/ ) \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)'

 auditctl -l | awk '/^ *-w/ \
 &&/\/etc\/localtime/ \
 &&/ +-p *wa/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)'
}
```

Verify the output includes:

```
-a always,exit -F arch=b64 -S adjtimex,settimeofday -F key=time-change
-a always,exit -F arch=b32 -S settimeofday,adjtimex -F key=time-change
-a always,exit -F arch=b64 -S clock_settime -F a0=0x0 -F key=time-change
-a always,exit -F arch=b32 -S clock_settime -F a0=0x0 -F key=time-change
-w /etc/localtime -p wa -k time-change
```

Remediation:

Create audit rules

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor events that modify date and time information.

Example:

```
# printf "
-a always,exit -F arch=b64 -S adjtimex,settimeofday -k time-change
-a always,exit -F arch=b32 -S adjtimex,settimeofday -k time-change
-a always,exit -F arch=b64 -S clock_settime -F a0=0x0 -k time-change
-a always,exit -F arch=b32 -S clock_settime -F a0=0x0 -k time-change
-w /etc/localtime -p wa -k time-change
" >> /etc/audit/rules.d/50-time-change.rules
```

Load audit rules

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 Rev. 5: AU-3, CM-6

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	5.5 Implement Automated Configuration Monitoring Systems Utilize a Security Content Automation Protocol (SCAP) compliant configuration monitoring system to verify all security configuration elements, catalog approved exceptions, and alert when unauthorized changes occur.		●	●

6.3.3.5 Ensure events that modify the system's network environment are collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Record changes to network environment files or system calls. The below parameters monitors the following system calls, and write an audit event on system call exit:

- `sethostname` - set the systems host name
- `setdomainname` - set the systems domain name

The files being monitored are:

- `/etc/issue` and `/etc/issue.net` - messages displayed pre-login
- `/etc/hosts` - file containing host names and associated IP addresses
- `/etc/hostname` - file contains the system's host name
- `/etc/sysconfig/network` - additional information that is valid to all network interfaces
- `/etc/sysconfig/network-scripts/` - directory containing network interface scripts and configurations files
- `/etc/NetworkManager/` - directory contains configuration files and settings used by the `NetworkManager`

Rationale:

Monitoring `sethostname` and `setdomainname` will identify potential unauthorized changes to host and domain name of a system. The changing of these names could potentially break security parameters that are set based on those names. The `/etc/hosts` file is monitored for changes that can indicate an unauthorized intruder is trying to change machine associations with IP addresses and trick users and processes into connecting to unintended machines. Monitoring `/etc/issue` and `/etc/issue.net` is important, as intruders could put disinformation into those files and trick users into providing information to the intruder. Monitoring `/etc/sysconfig/network` is important as it can show if network interfaces or scripts are being modified in a way that can lead to the machine becoming unavailable or compromised. All audit records should have a relevant tag associated with them.

Audit:

On disk configuration

Run the following commands to check the on disk rules:

```
# {
# Check for syscalls related to hostname and domainname change
awk '/^*-a *always, exit/ \
&& /-F *arch=b(32|64)/ \
&& /-S/ && (/sethostname/ \
|| /setdomainname/) \
&& (/skey= *[!-~]* *$/ || /-k *[!-~]* *$/)' /etc/audit/rules.d/*.rules

# Check for file watches on network-related files
awk '/^ *-w/ \
&& (/etc\/issue/ \
|| /etc\/issue.net/ \
|| /etc\/hosts/ \
|| /etc\/sysconfig\/network/ \
|| /etc\/hostname/ \
|| /etc\/NetworkManager/) \
&& / +-p *wa/ \
&& (/ key= *[!-~]* *$/ || /-k *[!-~]* *$/)' /etc/audit/rules.d/*.rules
}
```

Verify the output matches:

```
-a always,exit -F arch=b64 -S sethostname,setdomainname -k system-locale
-a always,exit -F arch=b32 -S sethostname,setdomainname -k system-locale
-w /etc/issue -p wa -k system-locale
-w /etc/issue.net -p wa -k system-locale
-w /etc/hosts -p wa -k system-locale
-w /etc/hostname -p wa -k system-locale
-w /etc/sysconfig/network -p wa -k system-locale
-w /etc/sysconfig/network-scripts/ -p wa -k system-locale
-w /etc/NetworkManager -p wa -k system-locale
```

Running configuration

Run the following command to check loaded rules:

```
# {
 auditctl -l | awk '/^ *-a *always,exit/ \
 &&/ -F *arch=b(32|64)/ \
 &&/ -S/ \
 &&(/sethostname/ \
   ||/setdomainname/) \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)'

 auditctl -l | awk '/^ *-w/ \
 &&(/etc\/issue/ \
   || /etc\/issue.net/ \
   || /etc\/hosts/ \
   || /etc\/sysconfig\/network/ \
   || /etc\/hostname/ \
   || /etc\/NetworkManager/) \
 &&/ +-p *wa/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)'
}
```

Verify the output includes:

```
-a always,exit -F arch=b64 -S sethostname,setdomainname -F key=system-locale
-a always,exit -F arch=b32 -S sethostname,setdomainname -F key=system-locale
-w /etc/issue -p wa -k system-locale
-w /etc/issue.net -p wa -k system-locale
-w /etc/hosts -p wa -k system-locale
-w /etc/hostname -p wa -k system-locale
-w /etc/sysconfig/network -p wa -k system-locale
-w /etc/sysconfig/network-scripts -p wa -k system-locale
-w /etc/NetworkManager -p wa -k system-locale
```

Remediation:

Create audit rules

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor events that modify the system's network environment.

Example:

```
# printf "
-a always,exit -F arch=b64 -S sethostname,setdomainname -k system-locale
-a always,exit -F arch=b32 -S sethostname,setdomainname -k system-locale
-w /etc/issue -p wa -k system-locale
-w /etc/issue.net -p wa -k system-locale
-w /etc/hosts -p wa -k system-locale
-w /etc/hostname -p wa -k system-locale
-w /etc/sysconfig/network -p wa -k system-locale
-w /etc/sysconfig/network-scripts/ -p wa -k system-locale
-w /etc/NetworkManager -p wa -k system-locale
" >> /etc/audit/rules.d/50-system_locale.rules
```

Load audit rules

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 Rev. 5: AU-3, CM-6

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	5.5 Implement Automated Configuration Monitoring Systems Utilize a Security Content Automation Protocol (SCAP) compliant configuration monitoring system to verify all security configuration elements, catalog approved exceptions, and alert when unauthorized changes occur.		●	●

6.3.3.6 Ensure use of privileged commands are collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Monitor privileged programs, those that have the `setuid` and/or `setgid` bit set on execution, to determine if unprivileged users are running these commands.

Rationale:

Execution of privileged commands by non-privileged users could be an indication of someone trying to gain unauthorized access to the system.

Impact:

Both the audit and remediation section of this recommendation will traverse all mounted file systems that is not mounted with either `noexec` or `nosuid` mount options. If there are large file systems without these mount options, **such traversal will be significantly detrimental to the performance of the system.**

Before running either the audit or remediation section, inspect the output of the following command to determine exactly which file systems will be traversed:

```
# findmnt -n -l -k -it $(awk '/nodev/ { print $2 }' /proc/filesystems | paste
-sd,) | grep -Pv "noexec|nosuid"
```

To exclude a particular file system due to adverse performance impacts, update the audit and remediation sections by adding a sufficiently unique string to the `grep` statement. The above command can be used to test the modified exclusions.

Audit:

On disk configuration

Run the following script to check on disk rules:

```
#!/usr/bin/env bash

{
   for PARTITION in $(findmnt -n -l -k -it $(awk '/nodev/ { print $2 }'
/proc/filesystems | paste -sd,) | grep -Pv "noexec|nosuid" | awk '{print
$1}'); do
      for PRIVILEGED in $(find "${PARTITION}" -xdev -perm /6000 -type f); do
         grep -qr "${PRIVILEGED}" /etc/audit/rules.d && printf "OK:
'${PRIVILEGED}' found in auditing rules.\n" || printf "Warning:
'${PRIVILEGED}' not found in on disk configuration.\n"
      done
   done
}
```

Verify that all output is `OK`.

Running configuration

Run the following script to check loaded rules:

```
#!/usr/bin/env bash

{
   RUNNING=$(auditctl -l)
   [ -n "${RUNNING}" ] && for PARTITION in $(findmnt -n -l -k -it $(awk
'/nodev/ { print $2 }' /proc/filesystems | paste -sd,) | grep -Pv
"noexec|nosuid" | awk '{print $1}'); do
      for PRIVILEGED in $(find "${PARTITION}" -xdev -perm /6000 -type f); do
         printf -- "${RUNNING}" | grep -q "${PRIVILEGED}" && printf "OK:
'${PRIVILEGED}' found in auditing rules.\n" || printf "Warning:
'${PRIVILEGED}' not found in running configuration.\n"
      done
   done \
   || printf "ERROR: Variable 'RUNNING' is unset.\n"
}
```

Verify that all output is `OK`.

Special mount points

If there are any special mount points that are not visible by default from `findmnt` as per the above audit, said file systems would have to be manually audited.

Remediation:

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor the use of privileged commands.

Example script:

```
#!/usr/bin/env bash

{
  UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
  AUDIT_RULE_FILE="/etc/audit/rules.d/50-privileged.rules"
  NEW_DATA=()
  for PARTITION in $(findmnt -n -l -k -it $(awk '/nodev/ { print $2 }'
/proc/filesystems | paste -sd,) | grep -Pv "noexec|nosuid" | awk '{print
$1}'); do
    readarray -t DATA < <(find "${PARTITION}" -xdev -perm /6000 -type f | awk
-v UID_MIN=${UID_MIN} '{print "-a always,exit -F path=" $1 " -F perm=x -F
auid>="UID_MIN" -F auid!=unset -k privileged" }')
      for ENTRY in "${DATA[@]}"; do
        NEW_DATA+=("${ENTRY}")
      done
  done
  readarray &> /dev/null -t OLD_DATA < "${AUDIT_RULE_FILE}"
  COMBINED_DATA=( "${OLD_DATA[@]}" "${NEW_DATA[@]}" )
  printf '%s\n' "${COMBINED_DATA[@]}" | sort -u > "${AUDIT_RULE_FILE}"
}
```

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

Special mount points

If there are any special mount points that are not visible by default from just scanning `/`, change the `PARTITION` variable to the appropriate partition and re-run the remediation.

References:

1. NIST SP 800-53 Rev. 5: AU-3, AU-3(1)

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

6.3.3.7 Ensure unsuccessful file access attempts are collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Monitor for unsuccessful attempts to access files. The following parameters are associated with system calls that control files:

- creation - `creat`
- opening - `open` , `openat`
- truncation - `truncate` , `ftruncate`

An audit log record will only be written if all of the following criteria is met for the user when trying to access a file:

- a non-privileged user (auid>=UID_MIN)
- is not a Daemon event (auid=4294967295/unset/-1)
- if the system call returned EACCES (permission denied) or EPERM (some other permanent error associated with the specific system call)

Rationale:

Failed attempts to open, create or truncate files could be an indication that an individual or process is trying to gain unauthorized access to the system.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000064-GPOS-00033

Audit:

On disk configuration

Run the following command to check the on disk rules:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && awk "/^ *-a *always,exit/ \
 &&/ -F *arch=b(32|64)/ \
 &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
 &&/ -F *auid>=${UID_MIN}/ \
 &&(/ -F *exit=-EACCES/||/ -F *exit=-EPERM/) \
 &&/ -S/ \
 &&/creat/ \
 &&/open/ \
 &&/truncate/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" /etc/audit/rules.d/*.rules \
 || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output includes:

```
-a always,exit -F arch=b64 -S creat,open,openat,truncate,ftruncate -F exit=-
EACCES -F auid>=1000 -F auid!=unset -k access
-a always,exit -F arch=b64 -S creat,open,openat,truncate,ftruncate -F exit=-
EPERM -F auid>=1000 -F auid!=unset -k access
-a always,exit -F arch=b32 -S creat,open,openat,truncate,ftruncate -F exit=-
EACCES -F auid>=1000 -F auid!=unset -k access
-a always,exit -F arch=b32 -S creat,open,openat,truncate,ftruncate -F exit=-
EPERM -F auid>=1000 -F auid!=unset -k access
```

Running configuration

Run the following command to check loaded rules:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && auditctl -l | awk "/^ *-a *always,exit/ \
 &&/ -F *arch=b(32|64)/ \
 &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
 &&/ -F *auid>=${UID_MIN}/ \
 &&(/ -F *exit=-EACCES/||/ -F *exit=-EPERM/) \
 &&/ -S/ \
 &&/creat/ \
 &&/open/ \
 &&/truncate/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" \
 || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output includes:

```
-a always,exit -F arch=b64 -S open,truncate,ftruncate,creat,openat -F exit=-
EACCES -F auid>=1000 -F auid!=-1 -F key=access
-a always,exit -F arch=b64 -S open,truncate,ftruncate,creat,openat -F exit=-
EPERM -F auid>=1000 -F auid!=-1 -F key=access
-a always,exit -F arch=b32 -S open,truncate,ftruncate,creat,openat -F exit=-
EACCES -F auid>=1000 -F auid!=-1 -F key=access
-a always,exit -F arch=b32 -S open,truncate,ftruncate,creat,openat -F exit=-
EPERM -F auid>=1000 -F auid!=-1 -F key=access
```

Remediation:

Create audit rules

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor unsuccessful file access attempts.

Example:

```
# {
UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
[ -n "${UID_MIN}" ] && printf "
-a always,exit -F arch=b64 -S creat,open,openat,truncate,ftruncate -F exit=-
EACCES -F auid>=${UID_MIN} -F auid!=unset -k access
-a always,exit -F arch=b64 -S creat,open,openat,truncate,ftruncate -F exit=-
EPERM -F auid>=${UID_MIN} -F auid!=unset -k access
-a always,exit -F arch=b32 -S creat,open,openat,truncate,ftruncate -F exit=-
EACCES -F auid>=${UID_MIN} -F auid!=unset -k access
-a always,exit -F arch=b32 -S creat,open,openat,truncate,ftruncate -F exit=-
EPERM -F auid>=${UID_MIN} -F auid!=unset -k access
" >> /etc/audit/rules.d/50-access.rules || printf "ERROR: Variable 'UID_MIN'
is unset.\n"
}
```

Load audit rules

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 :: AU-12 a
2. NIST SP 800-53A :: AU-12.1 (ii)
3. RHEL 8 STIG Vul ID: V-230449
4. RHEL 8 STIG Rule ID: SV-230449r810455

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	14.9 Enforce Detail Logging for Access or Changes to Sensitive Data Enforce detailed audit logging for access to sensitive data or changes to sensitive data (utilizing tools such as File Integrity Monitoring or Security Information and Event Monitoring).			●

6.3.3.8 Ensure events that modify user/group information are collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Record events affecting the modification of user or group information, including that of passwords and old passwords if in use.

- `/etc/group` - system groups
- `/etc/passwd` - system users
- `/etc/gshadow` - encrypted password for each group
- `/etc/shadow` - system user passwords
- `/etc/security/opasswd` - storage of old passwords if the relevant PAM module is in use
- `/etc/nsswitch.conf` - file configures how the system uses various databases and name resolution mechanisms
- `/etc/pam.conf` - file determines the authentication services to be used, and the order in which the services are used.
- `/etc/pam.d` - directory contains the PAM configuration files for each PAM-aware application.

The parameters in this section will watch the files to see if they have been opened for write or have had attribute changes (e.g. permissions) and tag them with the identifier "identity" in the audit log file.

Rationale:

Unexpected changes to these files could be an indication that the system has been compromised and that an unauthorized user is attempting to hide their activities or compromise additional accounts.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000004-GPOS-00004, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000304-GPOS-00121, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000470-GPOS-00214, SRG-OS-000471-GPOS-00215, SRG-OS-000239-GPOS-00089, SRG-OS-000240-GPOS-00090, SRG-OS-000241-GPOS-00091, SRG-OS-000303-GPOS-00120, SRG-OS-000304-GPOS-00121, SRG-OS-000476-GPOS-00221

Audit:

On disk configuration

Run the following command to check the on disk rules:

```
# awk '/^ *-w/ \
&&(/\/etc\/group/ \
  ||/\/etc\/passwd/ \
  ||/\/etc\/gshadow/ \
  ||/\/etc\/shadow/ \
  ||/\/etc\/security\/opasswd/ \
  ||/\/etc\/nsswitch.conf/ \
  ||/\/etc\/pam.conf/ \
  ||/\/etc\/pam.d/) \
&&/ +-p *wa/ \
&&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)' /etc/audit/rules.d/*.rules
```

Verify the output matches:

```
-w /etc/group -p wa -k identity
-w /etc/passwd -p wa -k identity
-w /etc/gshadow -p wa -k identity
-w /etc/shadow -p wa -k identity
-w /etc/security/opasswd -p wa -k identity
-w /etc/nsswitch.conf -p wa -k identity
-w /etc/pam.conf -p wa -k identity
-w /etc/pam.d -p wa -k identity
```

Running configuration

Run the following command to check loaded rules:

```
# auditctl -l | awk '/^ *-w/ \
&&(/\/etc\/group/ \
  ||/\/etc\/passwd/ \
  ||/\/etc\/gshadow/ \
  ||/\/etc\/shadow/ \
  ||/\/etc\/security\/opasswd/ \
  ||/\/etc\/nsswitch.conf/ \
  ||/\/etc\/pam.conf/ \
  ||/\/etc\/pam.d/) \
&&/ +-p *wa/ \
&&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)'
```

Verify the output matches:

```
-w /etc/group -p wa -k identity
-w /etc/passwd -p wa -k identity
-w /etc/gshadow -p wa -k identity
-w /etc/shadow -p wa -k identity
-w /etc/security/opasswd -p wa -k identity
-w /etc/nsswitch.conf -p wa -k identity
-w /etc/pam.conf -p wa -k identity
-w /etc/pam.d -p wa -k identity
```

Remediation:

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor events that modify user/group information.

Example:

```
# printf "
-w /etc/group -p wa -k identity
-w /etc/passwd -p wa -k identity
-w /etc/gshadow -p wa -k identity
-w /etc/shadow -p wa -k identity
-w /etc/security/opasswd -p wa -k identity
-w /etc/nsswitch.conf -p wa -k identity
-w /etc/pam.conf -p wa -k identity
-w /etc/pam.d -p wa -k identity
" >> /etc/audit/rules.d/50-identity.rules
```

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. https://manpages.debian.org/bookworm/manpages/nsswitch.conf.5.en.html
2. https://access.redhat.com/documentation/en-us/red_hat_enterprise_linux/6/html/managing_smart_cards/pam_configuration_files
3. NIST SP 800-53 :: AU-12 a
4. NIST SP 800-53A :: AU-12.1 (ii)
5. RHEL 8 STIG Vul ID: V-230404
6. RHEL 8 STIG Rule ID: SV-230404r627750
7. RHEL 8 STIG Vul ID: V-230405
8. RHEL 8 STIG Rule ID: SV-230405r627750
9. RHEL 8 STIG Vul ID: V-230406
10. RHEL 8 STIG Rule ID: SV-230406r627750
11. RHEL 8 STIG Vul ID: V-230407
12. RHEL 8 STIG Rule ID: SV-230407r627750
13. RHEL 8 STIG Vul ID: V-230408
14. RHEL 8 STIG Rule ID: SV-230408r627750

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	4.8 Log and Alert on Changes to Administrative Group Membership Configure systems to issue a log entry and alert when an account is added to or removed from any group assigned administrative privileges.		●	●

6.3.3.9 Ensure discretionary access control permission modification events are collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Monitor changes to file permissions, attributes, ownership and group. The parameters in this section track changes for system calls that affect file permissions and attributes. The following commands and system calls effect the permissions, ownership and various attributes of files.

- `chmod`
- `fchmod`
- `fchmodat`
- `chown`
- `fchown`
- `fchownat`
- `lchown`
- `setxattr`
- `lsetxattr`
- `fsetxattr`
- `removexattr`
- `lremovexattr`
- `fremovexattr`

In all cases, an audit record will only be written for non-system user ids and will ignore Daemon events. All audit records will be tagged with the identifier "perm_mod."

Rationale:

Monitoring for changes in file attributes could alert a system administrator to activity that could indicate intruder activity or policy violation.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000064-GPOS-00033, SRG-OS-000466-GPOS-00210

Audit:

Note: Output showing all audited syscalls, e.g. (-a always,exit -F arch=b64 -S chmod,fchmod,fchmodat,chmod,fchmod,fchmodat,setxattr,lsetxattr,fsetxattr,removexattr,lremovexattr,fremovexattr -F auid>=1000 -F auid!=unset -F key=perm_mod) is also acceptable. These have been separated by function on the displayed output for clarity.

On disk configuration

Run the following command to check the on disk rules:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && awk "/^ *-a *always,exit/ \
 &&/ -F *arch=b(32|64)/ \
 &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
 &&/ -S/ \
 &&/ -F *auid>=${UID_MIN}/ \
 &&(/chmod/||/fchmod/||/fchmodat/ \
   ||/chown/||/fchown/||/fchownat/||/lchown/ \
   ||/setxattr/||/lsetxattr/||/fsetxattr/ \
   ||/removexattr/||/lremovexattr/||/fremovexattr/) \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" /etc/audit/rules.d/*.rules \
 || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output matches:

```
-a always,exit -F arch=b64 -S chmod,fchmod,fchmodat -F auid>=1000 -F
auid!=unset -F key=perm_mod
-a always,exit -F arch=b64 -S chown,fchown,lchown,fchownat -F auid>=1000 -F
auid!=unset -F key=perm_mod
-a always,exit -F arch=b32 -S chmod,fchmod,fchmodat -F auid>=1000 -F
auid!=unset -F key=perm_mod
-a always,exit -F arch=b32 -S lchown,fchown,chown,fchownat -F auid>=1000 -F
auid!=unset -F key=perm_mod
-a always,exit -F arch=b64 -S
setxattr,lsetxattr,fsetxattr,removexattr,lremovexattr,fremovexattr -F
auid>=1000 -F auid!=unset -F key=perm_mod
-a always,exit -F arch=b32 -S
setxattr,lsetxattr,fsetxattr,removexattr,lremovexattr,fremovexattr -F
auid>=1000 -F auid!=unset -F key=perm_mod
```

Running configuration

Run the following command to check loaded rules:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && auditctl -l | awk "/^ *-a *always,exit/ \
 &&/ -F *arch=b(32|64)/ \
 &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
 &&/ -S/ \
 &&/ -F *auid>=${UID_MIN}/ \
 &&(/chmod/||/fchmod/||/fchmodat/ \
   ||/chown/||/fchown/||/fchownat/||/lchown/ \
   ||/setxattr/||/lsetxattr/||/fsetxattr/ \
   ||/removexattr/||/lremovexattr/||/fremovexattr/) \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" \
 || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output matches:

```
-a always,exit -F arch=b64 -S chmod,fchmod,fchmodat -F auid>=1000 -F auid!=-1
-F key=perm_mod
-a always,exit -F arch=b64 -S chown,fchown,lchown,fchownat -F auid>=1000 -F
auid!=-1 -F key=perm_mod
-a always,exit -F arch=b32 -S chmod,fchmod,fchmodat -F auid>=1000 -F auid!=-1
-F key=perm_mod
-a always,exit -F arch=b32 -S lchown,fchown,chown,fchownat -F auid>=1000 -F
auid!=-1 -F key=perm_mod
-a always,exit -F arch=b64 -S
setxattr,lsetxattr,fsetxattr,removexattr,lremovexattr,fremovexattr -F
auid>=1000 -F auid!=-1 -F key=perm_mod
-a always,exit -F arch=b32 -S
setxattr,lsetxattr,fsetxattr,removexattr,lremovexattr,fremovexattr -F
auid>=1000 -F auid!=-1 -F key=perm_mod
```

Remediation:

Create audit rules

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor discretionary access control permission modification events.

Example:

```
# {
UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
[ -n "${UID_MIN}" ] && printf "
-a always,exit -F arch=b64 -S chmod,fchmod,fchmodat -F auid>=${UID_MIN} -F
auid!=unset -F key=perm_mod
-a always,exit -F arch=b64 -S chown,fchown,lchown,fchownat -F
auid>=${UID_MIN} -F auid!=unset -F key=perm_mod
-a always,exit -F arch=b32 -S chmod,fchmod,fchmodat -F auid>=${UID_MIN} -F
auid!=unset -F key=perm_mod
-a always,exit -F arch=b32 -S lchown,fchown,chown,fchownat -F
auid>=${UID_MIN} -F auid!=unset -F key=perm_mod
-a always,exit -F arch=b64 -S
setxattr,lsetxattr,fsetxattr,removexattr,lremovexattr,fremovexattr -F
auid>=${UID_MIN} -F auid!=unset -F key=perm_mod
-a always,exit -F arch=b32 -S
setxattr,lsetxattr,fsetxattr,removexattr,lremovexattr,fremovexattr -F
auid>=${UID_MIN} -F auid!=unset -F key=perm_mod
" >> /etc/audit/rules.d/50-perm_mod.rules || printf "ERROR: Variable
'UID_MIN' is unset.\n"
}
```

Load audit rules

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 :: AU-12 a
2. NIST SP 800-53A :: AU-12.1 (ii)
3. RHEL 8 STIG Vul ID: V-230413
4. RHEL 8 STIG Rule ID: SV-230413r810463
5. RHEL 8 STIG Vul ID: V-230455
6. RHEL 8 STIG Rule ID: SV-230455r810459
7. RHEL 8 STIG Vul ID: V-230456
8. RHEL 8 STIG Rule ID: SV-230456r810462

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	5.5 Implement Automated Configuration Monitoring Systems Utilize a Security Content Automation Protocol (SCAP) compliant configuration monitoring system to verify all security configuration elements, catalog approved exceptions, and alert when unauthorized changes occur.		●	●

6.3.3.10 Ensure successful file system mounts are collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Monitor the use of the `mount` system call. The `mount` (and `umount`) system call controls the mounting and unmounting of file systems. The parameters below configure the system to create an audit record when the mount system call is used by a non-privileged user

Rationale:

It is highly unusual for a non privileged user to `mount` file systems to the system. While tracking `mount` commands gives the system administrator evidence that external media may have been mounted (based on a review of the source of the mount and confirming it's an external media type), it does not conclusively indicate that data was exported to the media. System administrators who wish to determine if data were exported, would also have to track successful `open`, `creat` and `truncate` system calls requiring write access to a file under the mount point of the external media file system. This could give a fair indication that a write occurred. The only way to truly prove it, would be to track successful writes to the external media. Tracking write system calls could quickly fill up the audit log and is not recommended. Recommendations on configuration options to track data export to media is beyond the scope of this document.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Audit:

On disk configuration

Run the following command to check the on disk rules:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && awk "/^ *-a *always,exit/ \
 &&/ -F *arch=b(32|64)/ \
 &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
 &&/ -F *auid>=${UID_MIN}/ \
 &&/ -S/ \
 &&/mount/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" /etc/audit/rules.d/*.rules \
 || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output matches:

```
-a always,exit -F arch=b64 -S mount -F auid>=1000 -F auid!=unset -k mounts
-a always,exit -F arch=b32 -S mount -F auid>=1000 -F auid!=unset -k mounts
```

Running configuration

Run the following command to check loaded rules:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && auditctl -l | awk "/^ *-a *always,exit/ \
 &&/ -F *arch=b(32|64)/ \
 &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
 &&/ -F *auid>=${UID_MIN}/ \
 &&/ -S/ \
 &&/mount/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" \
 || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output matches:

```
-a always,exit -F arch=b64 -S mount -F auid>=1000 -F auid!=-1 -F key=mounts
-a always,exit -F arch=b32 -S mount -F auid>=1000 -F auid!=-1 -F key=mounts
```

Remediation:

Create audit rules

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor successful file system mounts.

Example:

```
# {
UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
[ -n "${UID_MIN}" ] && printf "
-a always,exit -F arch=b32 -S mount -F auid>=$UID_MIN -F auid!=unset -k
mounts
-a always,exit -F arch=b64 -S mount -F auid>=$UID_MIN -F auid!=unset -k
mounts
" >> /etc/audit/rules.d/50-mounts.rules || printf "ERROR: Variable 'UID_MIN'
is unset.\n"
}
```

Load audit rules

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 :: AU-12 a
2. NIST SP 800-53A :: AU-12.1 (ii)
3. RHEL 8 STIG GROUP ID: V-230425
4. RHEL 8 STIG RULE ID: SV-230425r627750

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.3.3.11 Ensure session initiation information is collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Monitor session initiation events. The parameters in this section track changes to the files associated with session events.

- `/var/run/utmp` - tracks all currently logged in users.
- `/var/log/wtmp` - file tracks logins, logouts, shutdown, and reboot events.
- `/var/log/btmp` - keeps track of failed login attempts and can be read by entering the command `/usr/bin/last -f /var/log/btmp`.

All audit records will be tagged with the identifier "session."

Rationale:

Monitoring these files for changes could alert a system administrator to logins occurring at unusual hours, which could indicate intruder activity (i.e. a user logging in at a time when they do not normally log in).

Audit:

On disk configuration

Run the following command to check the on disk rules:

```
# awk '/^ *-w/ \
&&(/\/var\/run\/utmp/ \
  ||/\/var\/log\/wtmp/ \
  ||/\/var\/log\/btmp/) \
&&/ +-p *wa/ \
&&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)' /etc/audit/rules.d/*.rules
```

Verify the output matches:

```
-w /var/run/utmp -p wa -k session
-w /var/log/wtmp -p wa -k session
-w /var/log/btmp -p wa -k session
```

Running configuration

Run the following command to check loaded rules:

```
# auditctl -l | awk '/^ *-w/ \
&&(/\/var\/run\/utmp/ \
  ||/\/var\/log\/wtmp/ \
  ||/\/var\/log\/btmp/) \
&&/ +-p *wa/ \
&&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)'
```

Verify the output matches:

```
-w /var/run/utmp -p wa -k session
-w /var/log/wtmp -p wa -k session
-w /var/log/btmp -p wa -k session
```

Remediation:

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor session initiation information.

Example:

```
# printf "
-w /var/run/utmp -p wa -k session
-w /var/log/wtmp -p wa -k session
-w /var/log/btmp -p wa -k session
" >> /etc/audit/rules.d/50-session.rules
```

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 Rev. 5: AU-3, AU-3

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	4.9 Log and Alert on Unsuccessful Administrative Account Login Configure systems to issue a log entry and alert on unsuccessful logins to an administrative account.		●	●
v7	16.13 Alert on Account Login Behavior Deviation Alert when users deviate from normal login behavior, such as time-of-day, workstation location and duration.			●

6.3.3.12 Ensure login and logout events are collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Monitor login and logout events. The parameters below track changes to files associated with login/logout events.

- `/var/log/lastlog` - maintain records of the last time a user successfully logged in.
- `/var/run/faillock` - directory maintains records of login failures via the `pam_faillock` module.

Rationale:

Monitoring login/logout events could provide a system administrator with information associated with brute force attacks against user logins.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000473-GPOS-00218

Audit:

On disk configuration

Run the following command to check the on disk rules:

```
# awk '/^ *-w/ \
&&(/\/var\/log\/lastlog/ \
  ||/\/var\/run\/faillock/) \
&&/ +-p *wa/ \
&&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)' /etc/audit/rules.d/*.rules
```

Verify the output matches:

```
-w /var/log/lastlog -p wa -k logins
-w /var/run/faillock -p wa -k logins
```

Running configuration

Run the following command to check loaded rules:

```
# auditctl -l | awk '/^ *-w/ \
&&(/\/var\/log\/lastlog/ \
  ||/\/var\/run\/faillock/) \
&&/ +-p *wa/ \
&&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)'
```

Verify the output matches:

```
-w /var/log/lastlog -p wa -k logins
-w /var/run/faillock -p wa -k logins
```

Remediation:

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor login and logout events.

Example:

```
# printf "
-w /var/log/lastlog -p wa -k logins
-w /var/run/faillock -p wa -k logins
" >> /etc/audit/rules.d/50-login.rules
```

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 :: AU-12 a
2. NIST SP 800-53A :: AU-12.1 (ii)
3. RHEL 8 STIG Vul ID: V-230467
4. RHEL 8 STIG Rule ID: SV-230467r627750

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	4.9 Log and Alert on Unsuccessful Administrative Account Login Configure systems to issue a log entry and alert on unsuccessful logins to an administrative account.		●	●
v7	16.11 Lock Workstation Sessions After Inactivity Automatically lock workstation sessions after a standard period of inactivity.	●	●	●
v7	16.13 Alert on Account Login Behavior Deviation Alert when users deviate from normal login behavior, such as time-of-day, workstation location and duration.			●

6.3.3.13 Ensure file deletion events by users are collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Monitor the use of system calls associated with the deletion or renaming of files and file attributes. This configuration statement sets up monitoring for:

- `unlink` - remove a file
- `unlinkat` - remove a file attribute
- `rename` - rename a file
- `renameat` rename a file attribute system calls and tags them with the identifier "delete".

Rationale:

Monitoring these calls from non-privileged users could provide a system administrator with evidence that inappropriate removal of files and file attributes associated with protected files is occurring. While this audit option will look at all events, system administrators will want to look for specific privileged files that are being deleted or altered.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215

Audit:

On disk configuration

Run the following command to check the on disk rules:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && awk "/^ *-a *always,exit/ \
 &&/ -F *arch=b(32|64)/ \
 &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
 &&/ -F *auid>=${UID_MIN}/ \
 &&/ -S/ \
 &&(/unlink/||/rename/||/unlinkat/||/renameat/) \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" /etc/audit/rules.d/*.rules \
 || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output matches:

```
-a always,exit -F arch=b64 -S unlink,unlinkat,rename,renameat -F auid>=1000 -
F auid!=unset -k delete
-a always,exit -F arch=b32 -S unlink,unlinkat,rename,renameat -F auid>=1000 -
F auid!=unset -k delete
```

Running configuration

Run the following command to check loaded rules:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && auditctl -l | awk "/^ *-a *always,exit/ \
 &&/ -F *arch=b(32|64)/ \
 &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
 &&/ -F *auid>=${UID_MIN}/ \
 &&/ -S/ \
 &&(/unlink/||/rename/||/unlinkat/||/renameat/) \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" \
 || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output matches:

```
-a always,exit -F arch=b64 -S rename,unlink,unlinkat,renameat -F auid>=1000 -
F auid!=-1 -F key=delete
-a always,exit -F arch=b32 -S unlink,rename,unlinkat,renameat -F auid>=1000 -
F auid!=-1 -F key=delete
```

Remediation:

Create audit rules

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor file deletion events by users.

Example:

```
# {
UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
[ -n "${UID_MIN}" ] && printf "
-a always,exit -F arch=b64 -S rename,unlink,unlinkat,renameat -F
auid>=${UID_MIN} -F auid!=unset -F key=delete
-a always,exit -F arch=b32 -S rename,unlink,unlinkat,renameat -F
auid>=${UID_MIN} -F auid!=unset -F key=delete
" >> /etc/audit/rules.d/50-delete.rules || printf "ERROR: Variable 'UID_MIN'
is unset.\n"
}
```

Load audit rules

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 :: AU-12 a
2. NIST SP 800-53A :: AU-12.1 (ii)
3. RHEL 8 STIG Vul ID: V-230439
4. RHEL 8 STIG Rule ID: SV-230439r810465

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

6.3.3.14 Ensure events that modify the system's Mandatory Access Controls are collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Monitor SELinux, an implementation of mandatory access controls. The parameters below monitor any write access (potential additional, deletion or modification of files in the directory) or attribute changes to the `/etc/selinux/` and `/usr/share/selinux/` directories.

Note: If a different Mandatory Access Control method is used, changes to the corresponding directories should be audited.

Rationale:

Changes to files in the `/etc/selinux/` and `/usr/share/selinux/` directories could indicate that an unauthorized user is attempting to modify access controls and change security contexts, leading to a compromise of the system.

Audit:

On disk configuration

Run the following command to check the on disk rules:

```
# awk '/^ *-w/ \
&&(/\/etc\/selinux/ \
  ||/\/usr\/share\/selinux/) \
&&/ +-p *wa/ \
&&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)' /etc/audit/rules.d/*.rules
```

Verify the output matches:

```
-w /etc/selinux -p wa -k MAC-policy
-w /usr/share/selinux -p wa -k MAC-policy
```

Running configuration

Run the following command to check loaded rules:

```
# auditctl -l | awk '/^ *-w/ \
&&(/\/etc\/selinux/ \
  ||/\/usr\/share\/selinux/) \
&&/ +-p *wa/ \
&&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)'
```

Verify the output matches:

```
-w /etc/selinux -p wa -k MAC-policy
-w /usr/share/selinux -p wa -k MAC-policy
```

Remediation:

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor events that modify the system's Mandatory Access Controls.

Example:

```
# printf "
-w /etc/selinux -p wa -k MAC-policy
-w /usr/share/selinux -p wa -k MAC-policy
" >> /etc/audit/rules.d/50-MAC-policy.rules
```

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 Rev. 5: AU-3, CM-6

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	5.5 Implement Automated Configuration Monitoring Systems Utilize a Security Content Automation Protocol (SCAP) compliant configuration monitoring system to verify all security configuration elements, catalog approved exceptions, and alert when unauthorized changes occur.		●	●

6.3.3.15 Ensure successful and unsuccessful attempts to use the chcon command are collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The operating system must generate audit records for successful/unsuccessful uses of the `chcon` command.

Rationale:

The `chcon` command is used to change file security context. Without generating audit records that are specific to the security and needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one.

Audit records can be generated from various components within the information system (e.g., module or policy filter).

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000468-GPOS-00212, SRG-OS-000471-GPOS-00215

Audit:

On disk configuration

Run the following command to check the on disk rules:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && awk "/^ *-a *always,exit/ \
 &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
 &&/ -F *auid>=${UID_MIN}/ \
 &&/ -F *perm=x/ \
 &&/ -F *path=\/usr\/bin\/chcon/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" /etc/audit/rules.d/*.rules \
 || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output matches:

```
-a always,exit -F path=/usr/bin/chcon -F perm=x -F auid>=1000 -F auid!=unset
-k perm_chng
```

Running configuration

Run the following command to check loaded rules:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && auditctl -l | awk "/^ *-a *always,exit/ \
 &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
 &&/ -F *auid>=${UID_MIN}/ \
 &&/ -F *perm=x/ \
 &&/ -F *path=\/usr\/bin\/chcon/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" \
 || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output matches:

```
-a always,exit -S all -F path=/usr/bin/chcon -F perm=x -F auid>=1000 -F
auid!=-1 -F key=perm_chng
```

Remediation:

Create audit rules

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor successful and unsuccessful attempts to use the `chcon` command.

Example:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && printf "
-a always,exit -F path=/usr/bin/chcon -F perm=x -F auid>=${UID_MIN} -F
auid!=unset -k perm_chng
" >> /etc/audit/rules.d/50-perm_chng.rules || printf "ERROR: Variable
'UID_MIN' is unset.\n"
}
```

Load audit rules

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 :: AU-12 a
2. NIST SP 800-53A :: AU-12.1 (ii)
3. RHEL 8 STIG Vul ID: V-230419
4. RHEL 8 STIG Rule ID: SV-230419r627750

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

6.3.3.16 Ensure successful and unsuccessful attempts to use the setfacl command are collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The operating system must generate audit records for successful/unsuccessful uses of the `setfacl` command

Rationale:

This utility sets Access Control Lists (ACLs) of files and directories. Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one.

Audit records can be generated from various components within the information system (e.g., module or policy filter).

Audit:

On disk configuration

Run the following command to check the on disk rules:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && awk "/^ *-a *always,exit/ \
 &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
 &&/ -F *auid>=${UID_MIN}/ \
 &&/ -F *perm=x/ \
 &&/ -F *path=\/usr\/bin\/setfacl/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" /etc/audit/rules.d/*.rules ||
printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output matches:

```
-a always,exit -F path=/usr/bin/setfacl -F perm=x -F auid>=1000 -F
auid!=unset -k perm_chng
```

Running configuration

Run the following command to check loaded rules:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && auditctl -l | awk "/^ *-a *always,exit/ \
 &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
 &&/ -F *auid>=${UID_MIN}/ \
 &&/ -F *perm=x/ \
 &&/ -F *path=\/usr\/bin\/setfacl/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" \
 || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output matches:

```
-a always,exit -S all -F path=/usr/bin/setfacl -F perm=x -F auid>=1000 -F
auid!=-1 -F key=perm_chng
```

Remediation:

Create audit rules

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor successful and unsuccessful attempts to use the `setfacl` command.

Example:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && printf "
-a always,exit -F path=/usr/bin/setfacl -F perm=x -F auid>=${UID_MIN} -F
auid!=unset -k perm_chng
" >> /etc/audit/rules.d/50-perm_chng.rules || printf "ERROR: Variable
'UID_MIN' is unset.\n"
}
```

Load audit rules

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 Rev. 5: AU-2, AU-12, SI-5

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

6.3.3.17 Ensure successful and unsuccessful attempts to use the chacl command are collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The operating system must generate audit records for successful/unsuccessful uses of the `chacl` command.

`chacl` is an IRIX-compatibility command, and is maintained for those users who are familiar with its use from either XFS or IRIX.

Rationale:

`chacl` changes the ACL(s) for a file or directory. Without generating audit records that are specific to the security and mission needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one.

Audit records can be generated from various components within the information system (e.g., module or policy filter).

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000466-GPOS-00210

Audit:

On disk configuration

Run the following command to check the on disk rules:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && awk "/^ *-a *always,exit/ \
 &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
 &&/ -F *auid>=${UID_MIN}/ \
 &&/ -F *perm=x/ \
 &&/ -F *path=\/usr\/bin\/chacl/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" /etc/audit/rules.d/*.rules \
 || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output matches:

```
-a always,exit -F path=/usr/bin/chacl -F perm=x -F auid>=1000 -F auid!=unset
-k perm_chng
```

Running configuration

Run the following command to check loaded rules:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && auditctl -l | awk "/^ *-a *always,exit/ \
 &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
 &&/ -F *auid>=${UID_MIN}/ \
 &&/ -F *perm=x/ \
 &&/ -F *path=\/usr\/bin\/chacl/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" \
 || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output matches:

```
-a always,exit -S all -F path=/usr/bin/chacl -F perm=x -F auid>=1000 -F
auid!=-1 -F key=perm_chng
```

Remediation:

Create audit rules

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor successful and unsuccessful attempts to use the `chacl` command.

Example:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && printf "
-a always,exit -F path=/usr/bin/chacl -F perm=x -F auid>=${UID_MIN} -F
auid!=unset -k perm_chng
" >> /etc/audit/rules.d/50-perm_chng.rules || printf "ERROR: Variable
'UID_MIN' is unset.\n"
}
```

Load audit rules

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 Rev. 5: AU-2, AU-12, SI-5
2. NIST SP 800-53A :: AU-12.1 (ii)
3. RHEL 8 STIG Vul ID: V-230464
4. RHEL 8 STIG Rule ID: SV-230464r627750

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

6.3.3.18 Ensure successful and unsuccessful attempts to use the usermod command are collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The operating system must generate audit records for successful/unsuccessful uses of the `usermod` command.

Rationale:

The `usermod` command modifies the system account files to reflect the changes that are specified on the command line. Without generating audit records that are specific to the security and needs of the organization, it would be difficult to establish, correlate, and investigate the events relating to an incident or identify those responsible for one.

Audit records can be generated from various components within the information system (e.g., module or policy filter).

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000466-GPOS-00210

Audit:

On disk configuration

Run the following command to check the on disk rules:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && awk "/^ *-a *always,exit/ \
 &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
 &&/ -F *auid>=${UID_MIN}/ \
 &&/ -F *perm=x/ \
 &&/ -F *path=\/usr\/sbin\/usermod/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" /etc/audit/rules.d/*.rules \
 || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output matches:

```
-a always,exit -F path=/usr/sbin/usermod -F perm=x -F auid>=1000 -F
auid!=unset -k usermod
```

Running configuration

Run the following command to check loaded rules:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && auditctl -l | awk "/^ *-a *always,exit/ \
 &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
 &&/ -F *auid>=${UID_MIN}/ \
 &&/ -F *perm=x/ \
 &&/ -F *path=\/usr\/sbin\/usermod/ \
 &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" \
 || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output matches:

```
-a always,exit -S all -F path=/usr/sbin/usermod -F perm=x -F auid>=1000 -F
auid!=-1 -F key=usermod
```

Remediation:

Create audit rules

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor successful and unsuccessful attempts to use the `usermod` command.

Example:

```
# {
 UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
 [ -n "${UID_MIN}" ] && printf "
-a always,exit -F path=/usr/sbin/usermod -F perm=x -F auid>=${UID_MIN} -F
auid!=unset -k usermod
" >> /etc/audit/rules.d/50-usermod.rules || printf "ERROR: Variable 'UID_MIN'
is unset.\n"
}
```

Load audit rules

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 :: AU-12 a
2. NIST SP 800-53A :: AU-12.1 (ii)
3. RHEL 8 STIG Vul ID: V-230463
4. RHEL 8 STIG Rule ID: SV-230463r627750

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

6.3.3.19 Ensure kernel module loading unloading and modification is collected (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Monitor the loading and unloading of kernel modules. All the loading / listing / dependency checking of modules is done by `kmod` via symbolic links.

The following system calls control loading and unloading of modules:

- `init_module` - load a module
- `finit_module` - load a module (used when the overhead of using cryptographically signed modules to determine the authenticity of a module can be avoided)
- `delete_module` - delete a module
- `create_module` - create a loadable module entry
- `query_module` - query the kernel for various bits pertaining to modules

Any execution of the loading and unloading module programs and system calls will trigger an audit record with an identifier of `modules`.

Rationale:

Monitoring the use of all the various ways to manipulate kernel modules could provide system administrators with evidence that an unauthorized change was made to a kernel module, possibly compromising the security of the system.

Satisfies: SRG-OS-000062-GPOS-00031, SRG-OS-000037-GPOS-00015, SRG-OS-000042-GPOS-00020, SRG-OS-000062-GPOS-00031, SRG-OS-000392-GPOS-00172, SRG-OS-000462-GPOS-00206, SRG-OS-000471-GPOS-00215, SRG-OS-000471-GPOS-00216, SRG-OS-000477-GPOS-00222

Audit:

On disk configuration

Run the following script to check the on disk rules:

```
#!/usr/bin/env bash

{
  awk '/^ *-a *always,exit/ \
  &&/ -F *arch=b(32|64)/ \
  &&(/ -F auid!=unset/||/ -F auid!=-1/||/ -F auid!=4294967295/) \
  &&/ -S/ \
  &&(/init_module/ \
    ||/finit_module/ \
    ||/delete_module/ \
    ||/create_module/ \
    ||/query_module/) \
  &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)' /etc/audit/rules.d/*.rules

  UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
  [ -n "${UID_MIN}" ] && awk "/^ *-a *always,exit/ \
  &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
  &&/ -F *auid>=${UID_MIN}/ \
  &&/ -F *perm=x/ \
  &&/ -F *path=\/usr\/bin\/kmod/ \
  &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" /etc/audit/rules.d/*.rules \
  || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output matches:

```
-a always,exit -F arch=b64 -S
init_module,finit_module,delete_module,create_module,query_module -F
auid>=1000 -F auid!=unset -k kernel_modules
-a always,exit -F path=/usr/bin/kmod -F perm=x -F auid>=1000 -F auid!=unset -
k kernel_modules
```

Running configuration

Run the following script to check loaded rules:

```
#!/usr/bin/env bash

{
  auditctl -l | awk '/^ *-a *always,exit/ \
  &&/ -F *arch=b(32|64)/ \
  &&(/ -F auid!=unset/||/ -F auid!=-1/||/ -F auid!=4294967295/) \
  &&/ -S/ \
  &&(/init_module/ \
    ||/finit_module/ \
    ||/delete_module/ \
    ||/create_module/ \
    ||/query_module/) \
  &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)'

  UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
  [ -n "${UID_MIN}" ] && auditctl -l | awk "/^ *-a *always,exit/ \
  &&(/ -F *auid!=unset/||/ -F *auid!=-1/||/ -F *auid!=4294967295/) \
  &&/ -F *auid>=${UID_MIN}/ \
  &&/ -F *perm=x/ \
  &&/ -F *path=\/usr\/bin\/kmod/ \
  &&(/ key= *[!-~]* *$/||/ -k *[!-~]* *$/)" \
  || printf "ERROR: Variable 'UID_MIN' is unset.\n"
}
```

Verify the output includes:

```
-a always,exit -F arch=b64 -S
create_module,init_module,delete_module,query_module,finit_module -F
auid>=1000 -F auid!=-1 -F key=kernel_modules
-a always,exit -S all -F path=/usr/bin/kmod -F perm=x -F auid>=1000 -F
auid!=-1 -F key=kernel_modules
```

Symlink audit

Run the following script to audit if the symlinks `kmod` accepts are indeed pointing at it:

```
#!/usr/bin/env bash

{
   a_files=("/usr/sbin/lsmod" "/usr/sbin/rmmod" "/usr/sbin/insmod"
"/usr/sbin/modinfo" "/usr/sbin/modprobe" "/usr/sbin/depmod")
   for l_file in "${a_files[@]}"; do
      if [ "$(readlink -f "$l_file")" = "$(readlink -f /bin/kmod)" ]; then
         printf "OK: \"$l_file\"\n"
      else
         printf "Issue with symlink for file: \"$l_file\"\n"
      fi
   done
}
```

Verify the output states `OK`. If there is a symlink pointing to a different location it should be investigated

Remediation:

Create audit rules

Edit or create a file in the `/etc/audit/rules.d/` directory, ending in `.rules` extension, with the relevant rules to monitor kernel module modification.

Example:

```
#!/usr/bin/env bash

{
  UID_MIN=$(awk '/^\s*UID_MIN/{print $2}' /etc/login.defs)
  [ -n "${UID_MIN}" ] && printf "
  -a always,exit -F arch=b64 -S
init_module,finit_module,delete_module,create_module,query_module -F
auid>=${UID_MIN} -F auid!=unset -k kernel_modules
  -a always,exit -F path=/usr/bin/kmod -F perm=x -F auid>=${UID_MIN} -F
auid!=unset -k kernel_modules
  " >> /etc/audit/rules.d/50-kernel_modules.rules || printf "ERROR: Variable
'UID_MIN' is unset.\n"
}
```

Load audit rules

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 :: AU-12 a
2. NIST SP 800-53A :: AU-12.1 (ii)
3. RHEL 8 STIG Vul ID: V-230438
4. RHEL 8 STIG Rule ID: SV-230438r810464
5. RHEL 8 STIG Vul ID: V-230446
6. RHEL 8 STIG Rule ID: SV-230446r627750
7. RHEL 8 STIG Vul ID: V-230465
8. RHEL 8 STIG Rule ID: SV-230465r627750

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

System call structure

For performance (`man 7 audit.rules`) reasons it is preferable to have all the system calls on one line. However, your configuration may have them on one line each or some other combination. This is important to understand for both the auditing and remediation sections as the examples given are optimized for performance as per the man page.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

6.3.3.20 Ensure the audit configuration is loaded regardless of errors (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Set `-c` flag so that `auditctl` will continue loading rules in spite of an error. The exit code will not be success if any rule fails to load.

Rationale:

The default behaviour of `auditctl` is to stop loading any further rules if it encounters an error in the rules (for example a file watcher referencing a non-existent file). This can lead to auditd running without valid rules being present. It is best to have all valid rules loaded and active rather than a subset.

Audit:

Run the following command and verify output matches:

```
# grep -Ph -- '^\h*-c\b' /etc/audit/rules.d/*.rules | tail -1

-c
```

Remediation:

Edit or create the file `/etc/audit/rules.d/01-initialize.rules` and add the line `-c` at the end of the file:

Example:

```
# printf '%s\n' "" "-c" >> /etc/audit/rules.d/01-initialize.rules
```

Load audit rules

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.3.3.21 Ensure the audit configuration is immutable (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Set system audit so that audit rules cannot be modified with `auditctl` . Setting the flag "-e 2" forces audit to be put in immutable mode. Audit changes can only be made on system reboot.

Note: This setting will require the system to be rebooted to update the active `auditd` configuration settings.

Rationale:

In immutable mode, unauthorized users cannot execute changes to the audit system to potentially hide malicious activity and then put the audit rules back. Users would most likely notice a system reboot and that could alert administrators of an attempt to make unauthorized audit changes.

Audit:

Run the following command and verify output matches:

```
# grep -Ph -- '^\h*-e\h+2\b' /etc/audit/rules.d/*.rules | tail -1

-e 2
```

Remediation:

Edit or create the file `/etc/audit/rules.d/99-finalize.rules` and add the line `-e 2` at the end of the file:

Example:

```
# printf '%s\n' "" "-e 2" >> /etc/audit/rules.d/99-finalize.rules
```

Load audit rules

Merge and load the rules into active configuration:

```
# augenrules --load
```

Check if reboot is required.

```
# if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then printf "Reboot
required to load rules\n"; fi
```

References:

1. NIST SP 800-53 :: AU-9
2. NIST SP 800-53A :: AU-9.1
3. RHEL 8 STIG Vul ID: V-230402
4. RHEL 8 STIG Rule ID: SV-230402r627750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.3.3.22 Ensure the running and on disk configuration is the same (Manual)

Profile Applicability:

- Level 2 - Server

Description:

The Audit system have both on disk and running configuration. It is possible for these configuration settings to differ.

Note: Due to the limitations of `augenrules` and `auditctl`, it is not absolutely guaranteed that loading the rule sets via `augenrules --load` will result in all rules being loaded or even that the user will be informed if there was a problem loading the rules.

Rationale:

Configuration differences between what is currently running and what is on disk could cause unexpected problems or may give a false impression of compliance requirements.

Audit:

Merged rule sets

Ensure that all rules in `/etc/audit/rules.d` have been merged into `/etc/audit/audit.rules`:

```
# augenrules --check

/usr/sbin/augenrules: No change
```

Should there be any drift, run `augenrules --load` to merge and load all rules.

Remediation:

If the rules are not aligned across all three () areas, run the following command to merge and load all rules:

```
# augenrules --load
```

Check if reboot is required.

```
if [[ $(auditctl -s | grep "enabled") =~ "2" ]]; then echo "Reboot required
to load rules"; fi
```

References:

1. NIST SP 800-53 Rev. 5: AU-3

Additional Information:

Potential reboot required

If the auditing configuration is locked (`-e 2`), then `augenrules` will not warn in any way that rules could not be loaded into the running configuration. A system reboot will be required to load the rules into the running configuration.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.3 Enable Detailed Logging Enable system logging to include detailed information such as an event source, date, user, timestamp, source addresses, destination addresses, and other useful elements.		●	●

6.3.4 Configure auditd File Access

Without the capability to restrict which roles and individuals can select which events are audited, unauthorized personnel may be able to prevent the auditing of critical events.

6.3.4.1 Ensure the audit log file directory mode is configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

The audit log directory contains audit log files.

Rationale:

Audit information includes all information including: audit records, audit settings and audit reports. This information is needed to successfully audit system activity. This information must be protected from unauthorized modification or deletion. If this information were to be compromised, forensic analysis and discovery of the true source of potentially malicious system activity is impossible to achieve.

Audit:

Run the following script to verify the audit log directory is mode 0750 or more restrictive:

```
#!/usr/bin/env bash

{
   l_perm_mask="0027"
   if [ -e "/etc/audit/auditd.conf" ]; then
      l_audit_log_directory="$(dirname "$(awk -F= '/^\s*log_file\s*/{print
$2}' /etc/audit/auditd.conf | xargs)")"
      if [ -d "$l_audit_log_directory" ]; then
         l_maxperm="$(printf '%o' $(( 0777 & ~$l_perm_mask )) )"
         l_directory_mode="$(stat -Lc '%#a' "$l_audit_log_directory")"
         if [ $(( $l_directory_mode & $l_perm_mask )) -gt 0 ]; then
            echo -e "\n- Audit Result:\n  ** FAIL **\n  - Directory:
\"$l_audit_log_directory\" is mode: \"$l_directory_mode\"\n     (should be
mode: \"$l_maxperm\" or more restrictive)\n"
         else
            echo -e "\n- Audit Result:\n  ** PASS **\n  - Directory:
\"$l_audit_log_directory\" is mode: \"$l_directory_mode\"\n     (should be
mode: \"$l_maxperm\" or more restrictive)\n"
         fi
      else
         echo -e "\n- Audit Result:\n  ** FAIL **\n  - Log file directory not
set in \"/etc/audit/auditd.conf\" please set log file directory"
      fi
   else
      echo -e "\n- Audit Result:\n  ** FAIL **\n  - File:
\"/etc/audit/auditd.conf\" not found\n  - ** Verify auditd is installed **"
   fi
}
```

Remediation:

Run the following command to configure the audit log directory to have a mode of "0750" or less permissive:

```
# chmod g-w,o-rwx "$(dirname "$(awk -F= '/^\s*log_file\s*/{print $2}'
/etc/audit/auditd.conf | xargs)")"
```

Default Value:

750

References:

1. NIST SP 800-53 Rev. 5: AU-3

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

6.3.4.2 Ensure audit log files mode is configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Audit log files contain information about the system and system activity.

Rationale:

Access to audit records can reveal system and configuration data to attackers, potentially compromising its confidentiality.

Audit:

Run the following script to verify audit log files are mode `0640` or more restrictive:

```
#!/usr/bin/env bash

{
   l_output="" l_output2=""
   l_perm_mask="0177"
   if [ -e "/etc/audit/auditd.conf" ]; then
      l_audit_log_directory="$(dirname "$(awk -F= '/^\s*log_file\s*/{print
$2}' /etc/audit/auditd.conf | xargs)")"
      if [ -d "$l_audit_log_directory" ]; then
         l_maxperm="$(printf '%o' $(( 0777 & ~$l_perm_mask )) )"
         while IFS= read -r -d $'\0' l_file; do
            while IFS=: read -r l_file_mode l_hr_file_mode; do
               l_output2="$l_output2\n  - File: \"$l_file\" is mode:
\"$l_file_mode\"\n     (should be mode: \"$l_maxperm\" or more
restrictive)\n"
            done <<< "$(stat -Lc '%#a:%A' "$l_file")"
         done < <(find "$l_audit_log_directory" -maxdepth 1 -type f -perm
/"$l_perm_mask" -print0)
      else
         l_output2="$l_output2\n  - Log file directory not set in
\"/etc/audit/auditd.conf\" please set log file directory"
      fi
   else
      l_output2="$l_output2\n  - File: \"/etc/audit/auditd.conf\" not
found.\n  - ** Verify auditd is installed **"
   fi
   if [ -z "$l_output2" ]; then
      l_output="$l_output\n  - All files in \"$l_audit_log_directory\" are
mode: \"$l_maxperm\" or more restrictive"
      echo -e "\n- Audit Result:\n  ** PASS **\n - * Correctly configured *
:$l_output"
   else
      echo -e "\n- Audit Result:\n  ** FAIL **\n - * Reasons for audit
failure * :$l_output2\n"
   fi
}
```

Remediation:

Run the following command to remove more permissive mode than `0640` from audit log files:

```
# [ -f /etc/audit/auditd.conf ] && find "$(dirname $(awk -F "="
'/^\s*log_file/ {print $2}' /etc/audit/auditd.conf | xargs))" -type f -perm
/0137 -exec chmod u-x,g-wx,o-rwx {} +
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

6.3.4.3 Ensure audit log files owner is configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Audit log files contain information about the system and system activity.

Rationale:

Access to audit records can reveal system and configuration data to attackers, potentially compromising its confidentiality.

Audit:

Run the following script to verify audit log files are owned by the `root` user:

```
#!/usr/bin/env bash

{
   l_output="" l_output2=""
   if [ -e "/etc/audit/auditd.conf" ]; then
      l_audit_log_directory="$(dirname "$(awk -F= '/^\s*log_file\s*/{print
$2}' /etc/audit/auditd.conf | xargs)")"
      if [ -d "$l_audit_log_directory" ]; then
         while IFS= read -r -d $'\0' l_file; do
            l_output2="$l_output2\n  - File: \"$l_file\" is owned by user:
\"$(stat -Lc '%U' "$l_file")\"\n     (should be owned by user: \"root\")\n"
         done < <(find "$l_audit_log_directory" -maxdepth 1 -type f ! -user
root -print0)
      else
         l_output2="$l_output2\n  - Log file directory not set in
\"/etc/audit/auditd.conf\" please set log file directory"
      fi
   else
      l_output2="$l_output2\n  - File: \"/etc/audit/auditd.conf\" not
found.\n  - ** Verify auditd is installed **"
   fi
   if [ -z "$l_output2" ]; then
      l_output="$l_output\n  - All files in \"$l_audit_log_directory\" are
owned by user: \"root\"\n"
      echo -e "\n- Audit Result:\n  ** PASS **\n - * Correctly configured *
:$l_output"
   else
      echo -e "\n- Audit Result:\n  ** FAIL **\n - * Reasons for audit
failure * :$l_output2\n"
   fi
}
```

Remediation:

Run the following command to configure the audit log files to be owned by the `root` user:

```
# [ -f /etc/audit/auditd.conf ] && find "$(dirname $(awk -F "="
'/^\s*log_file/ {print $2}' /etc/audit/auditd.conf | xargs))" -type f ! -user
root -exec chown root {} +
```

References:

1. NIST SP 800-53 :: CM-7
2. NIST SP 800-53A :: CM-7.1 (ii)
3. RHEL 8 STIG Vul ID: V-230397
4. RHEL 8 STIG Rule ID: SV-230397r627750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

6.3.4.4 Ensure audit log files group owner is configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Audit log files contain information about the system and system activity.

Rationale:

Access to audit records can reveal system and configuration data to attackers, potentially compromising its confidentiality.

Audit:

Run the following script to verify:

- `log_group` parameter is set to either `adm` or `root` in `/etc/audit/auditd.conf`
- audit log files are group owned by the group "root" or "adm"

```
#!/usr/bin/env bash

{
   l_output="" l_output2=""
   if [ -e "/etc/audit/auditd.conf" ]; then
      l_audit_log_directory="$(dirname "$(awk -F= '/^\s*log_file\s*/{print
$2}' /etc/audit/auditd.conf | xargs)")"
      l_audit_log_group="$(awk -F= '/^\s*log_group\s*/{print $2}'
/etc/audit/auditd.conf | xargs)"
      if grep -Pq -- '^\h*(root|adm)\h*$' <<< "$l_audit_log_group"; then
         l_output="$l_output\n  - Log file group correctly set to:
\"$l_audit_log_group\" in \"/etc/audit/auditd.conf\""
      else
         l_output2="$l_output2\n  - Log file group is set to:
\"$l_audit_log_group\" in \"/etc/audit/auditd.conf\"\n     (should be set to
group: \"root or adm\")\n"
      fi
      if [ -d "$l_audit_log_directory" ]; then
         while IFS= read -r -d $'\0' l_file; do
            l_output2="$l_output2\n  - File: \"$l_file\" is group owned by
group: \"$(stat -Lc '%G' "$l_file")\"\n     (should be group owned by group:
\"root or adm\")\n"
         done < <(find "$l_audit_log_directory" -maxdepth 1 -type f \( ! -
group root -a ! -group adm \) -print0)
      else
         l_output2="$l_output2\n  - Log file directory not set in
\"/etc/audit/auditd.conf\" please set log file directory"
      fi
   else
      l_output2="$l_output2\n  - File: \"/etc/audit/auditd.conf\" not
found.\n  - ** Verify auditd is installed **"
   fi
   if [ -z "$l_output2" ]; then
      l_output="$l_output\n  - All files in \"$l_audit_log_directory\" are
group owned by group: \"root or adm\"\n"
      echo -e "\n- Audit Result:\n  ** PASS **\n - * Correctly configured *
:$l_output"
   else
      echo -e "\n- Audit Result:\n  ** FAIL **\n - * Reasons for audit
failure * :$l_output2\n"
      [ -n "$l_output" ] && echo -e " - * Correctly configured *
:\n$l_output\n"
   fi
}
```

Remediation:

Run the following command to configure the audit log files to be owned by `adm` group:

```
# find $(dirname $(awk -F"=" '/^\s*log_file\s*=\s*/ {print $2}'
/etc/audit/auditd.conf | xargs)) -type f \( ! -group adm -a ! -group root \)
-exec chgrp adm {} +
```

Run the following command to configure the audit log files to be owned by the `adm` group:

```
# chgrp adm /var/log/audit/
```

Run the following command to set the `log_group` parameter in the audit configuration file to `log_group = adm`:

```
# sed -ri 's/^\s*#?\s*log_group\s*=\s*\S+(\s*#.*)?.*$/log_group = adm\1/'
/etc/audit/auditd.conf
```

Run the following command to restart the audit daemon to reload the configuration file:

```
# systemctl restart auditd
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

6.3.4.5 Ensure audit configuration files mode is configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Audit configuration files control auditd and what events are audited.

Rationale:

Access to the audit configuration files could allow unauthorized personnel to prevent the auditing of critical events.

Misconfigured audit configuration files may prevent the auditing of critical events or impact the system's performance by overwhelming the audit log. Misconfiguration of the audit configuration files may also make it more difficult to establish and investigate events relating to an incident.

Audit:

Run the following script to verify that the audit configuration files are mode `0640` or more restrictive:

```
#!/usr/bin/env bash

{
   l_output="" l_output2="" l_perm_mask="0137"
   l_maxperm="$( printf '%o' $(( 0777 & ~$l_perm_mask )) )"
   while IFS= read -r -d $'\0' l_fname; do
      l_mode=$(stat -Lc '%#a' "$l_fname")
      if [ $(( "$l_mode" & "$l_perm_mask" )) -gt 0 ]; then
         l_output2="$l_output2\n - file: \"$l_fname\" is mode: \"$l_mode\"
(should be mode: \"$l_maxperm\" or more restrictive)"
      fi
   done < <(find /etc/audit/ -type f \( -name "*.conf" -o -name '*.rules' \)
-print0)
   if [ -z "$l_output2" ]; then
      echo -e "\n- Audit Result:\n  ** PASS **\n - All audit configuration
files are mode: \"$l_maxperm\" or more restrictive"
   else
      echo -e "\n- Audit Result:\n  ** FAIL **\n$l_output2"
   fi
}
```

Remediation:

Run the following command to remove more permissive mode than 0640 from the audit configuration files:

```
# find /etc/audit/ -type f \( -name '*.conf' -o -name '*.rules' \) -exec
chmod u-x,g-wx,o-rwx {} +
```

References:

1. NIST SP 800-53 :: AU-12 b
2. NIST SP 800-53A :: AU-12.1 (iii)
3. RHEL 8 STIG Vul ID: V-230471
4. RHEL 8 STIG Rule ID: SV-230471r627750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

6.3.4.6 Ensure audit configuration files owner is configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Audit configuration files control auditd and what events are audited.

Rationale:

Access to the audit configuration files could allow unauthorized personnel to prevent the auditing of critical events.

Misconfigured audit configuration files may prevent the auditing of critical events or impact the system's performance by overwhelming the audit log. Misconfiguration of the audit configuration files may also make it more difficult to establish and investigate events relating to an incident.

Audit:

Run the following command to verify that the audit configuration files have mode 640 or more restrictive and are owned by the root user and root group:

```
# find /etc/audit/ -type f \( -name '*.conf' -o -name '*.rules' \) ! -user
root
```

Nothing should be returned

Remediation:

Run the following command to change ownership to `root` user:

```
# find /etc/audit/ -type f \( -name '*.conf' -o -name '*.rules' \) ! -user
root -exec chown root {} +
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

6.3.4.7 Ensure audit configuration files group owner is configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Audit configuration files control auditd and what events are audited.

Rationale:

Access to the audit configuration files could allow unauthorized personnel to prevent the auditing of critical events.

Misconfigured audit configuration files may prevent the auditing of critical events or impact the system's performance by overwhelming the audit log. Misconfiguration of the audit configuration files may also make it more difficult to establish and investigate events relating to an incident.

Audit:

Run the following command to verify that the audit configuration files are owned by the group `root`:

```
# find /etc/audit/ -type f \( -name '*.conf' -o -name '*.rules' \) ! -group
root
```

Nothing should be returned

Remediation:

Run the following command to change group to `root`:

```
# find /etc/audit/ -type f \( -name '*.conf' -o -name '*.rules' \) ! -group
root -exec chgrp root {} +
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

6.3.4.8 Ensure audit tools mode is configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Audit tools include, but are not limited to, vendor-provided and open source audit tools needed to successfully view and manipulate audit information system activity and records. Audit tools include custom queries and report generators.

Rationale:

Protecting audit information includes identifying and protecting the tools used to view and manipulate log data. Protecting audit tools is necessary to prevent unauthorized operation on audit information.

Audit:

Run the following script to verify the audit tools are mode `0755` or more restrictive:

```
#!/usr/bin/env bash

{
   l_output="" l_output2="" l_perm_mask="0022"
   l_maxperm="$( printf '%o' $(( 0777 & ~$l_perm_mask )) )"
   a_audit_tools=("/sbin/auditctl" "/sbin/aureport" "/sbin/ausearch"
"/sbin/autrace" "/sbin/auditd" "/sbin/augenrules")
   for l_audit_tool in "${a_audit_tools[@]}"; do
      l_mode="$(stat -Lc '%#a' "$l_audit_tool")"
      if [ $(( "$l_mode" & "$l_perm_mask" )) -gt 0 ]; then
         l_output2="$l_output2\n - Audit tool \"$l_audit_tool\" is mode:
\"$l_mode\" and should be mode: \"$l_maxperm\" or more restrictive"
      else
         l_output="$l_output\n - Audit tool \"$l_audit_tool\" is correctly
configured to mode: \"$l_mode\""
      fi
   done
   if [ -z "$l_output2" ]; then
      echo -e "\n- Audit Result:\n  ** PASS **\n - * Correctly configured *
:$l_output"
   else
      echo -e "\n- Audit Result:\n  ** FAIL **\n - * Reasons for audit
failure * :$l_output2\n"
      [ -n "$l_output" ] && echo -e "\n - * Correctly configured *
:\n$l_output\n"
   fi
   unset a_audit_tools
}
```

Remediation:

Run the following command to remove more permissive mode from the audit tools:

```
# chmod go-w /sbin/auditctl /sbin/aureport /sbin/ausearch /sbin/autrace
/sbin/auditd /sbin/augenrules
```

References:

1. NIST SP 800-53 Rev. 5: AU-3

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

6.3.4.9 Ensure audit tools owner is configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Audit tools include, but are not limited to, vendor-provided and open source audit tools needed to successfully view and manipulate audit information system activity and records. Audit tools include custom queries and report generators.

Rationale:

Protecting audit information includes identifying and protecting the tools used to view and manipulate log data. Protecting audit tools is necessary to prevent unauthorized operation on audit information.

Audit:

Run the following command to verify the audit tools are owned by the `root` user:

```
# stat -Lc "%n %U" /sbin/auditctl /sbin/aureport /sbin/ausearch /sbin/autrace
/sbin/auditd /sbin/augenrules | awk '$2 != "root" {print}'
```

Nothing should be returned

Remediation:

Run the following command to change the owner of the audit tools to the `root` user:

```
# chown root /sbin/auditctl /sbin/aureport /sbin/ausearch /sbin/autrace
/sbin/auditd /sbin/augenrules
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

6.3.4.10 Ensure audit tools group owner is configured (Automated)

Profile Applicability:

- Level 2 - Server

Description:

Audit tools include, but are not limited to, vendor-provided and open source audit tools needed to successfully view and manipulate audit information system activity and records. Audit tools include custom queries and report generators.

Rationale:

Protecting audit information includes identifying and protecting the tools used to view and manipulate log data. Protecting audit tools is necessary to prevent unauthorized operation on audit information.

Audit:

Run the following command to verify the audit tools are owned by the group `root`

```
# stat -Lc "%n %G" /sbin/auditctl /sbin/aureport /sbin/ausearch /sbin/autrace
/sbin/auditd /sbin/augenrules | awk '$2 != "root" {print}'
```

Nothing should be returned

Remediation:

Run the following command to change group ownership to the group `root`:

```
# chgrp root /sbin/auditctl /sbin/aureport /sbin/ausearch /sbin/autrace
/sbin/auditd /sbin/augenrules
```

References:

1. NIST SP 800-53 Rev. 5: AU-3

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

7 System Maintenance

Recommendations in this section are intended as maintenance and are intended to be checked on a frequent basis to ensure system stability. Many recommendations do not have quick remediations and require investigation into the cause and best fix available and may indicate an attempted breach of system security.

7.1 Configure system file and directory access

This section provides guidance on securing aspects of system files and directories.

7.1.1 Ensure access to /etc/passwd is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/etc/passwd` file contains user account information that is used by many system utilities and therefore must be readable for these utilities to operate.

Rationale:

It is critical to ensure that the `/etc/passwd` file is protected from unauthorized write access. Although it is protected by default, the file permissions could be changed either inadvertently or through malicious actions.

Audit:

Run the following command to verify `/etc/passwd` is mode 644 or more restrictive, `Uid` is `0/root` and `Gid` is `0/root`:

```
# stat -Lc 'Access: (%#a/%A)  Uid: ( %u/ %U) Gid: ( %g/ %G)'  /etc/passwd

Access: (0644/-rw-r--r--)  Uid: ( 0/ root) Gid: ( 0/ root)
```

Remediation:

Run the following commands to remove excess permissions, set owner, and set group on `/etc/passwd`:

```
# chmod u-x,go-wx /etc/passwd
# chown root:root /etc/passwd
```

Default Value:

Access: (0644/-rw-r--r--) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

7.1.2 Ensure access to /etc/passwd- is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/etc/passwd-` file contains backup user account information.

Rationale:

It is critical to ensure that the `/etc/passwd-` file is protected from unauthorized access. Although it is protected by default, the file permissions could be changed either inadvertently or through malicious actions.

Audit:

Run the following command to verify `/etc/passwd-` is mode 644 or more restrictive, `Uid` is `0/root` and `Gid` is `0/root`:

```
# stat -Lc 'Access: (%#a/%A)  Uid: ( %u/ %U) Gid: { %g/ %G)' /etc/passwd-

Access: (0644/-rw-r--r--)  Uid: ( 0/ root) Gid: { 0/ root)
```

Remediation:

Run the following commands to remove excess permissions, set owner, and set group on `/etc/passwd-`:

```
# chmod u-x,go-wx /etc/passwd-
# chown root:root /etc/passwd-
```

Default Value:

Access: (0644/-rw-r--r--) Uid: (0/ root) Gid: { 0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

7.1.3 Ensure access to /etc/group is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/etc/group` file contains a list of all the valid groups defined in the system. The command below allows read/write access for root and read access for everyone else.

Rationale:

The `/etc/group` file needs to be protected from unauthorized changes by non-privileged users, but needs to be readable as this information is used with many non-privileged programs.

Audit:

Run the following command to verify `/etc/group` is mode 644 or more restrictive, `Uid` is `0/root` and `Gid` is `0/root`:

```
# stat -Lc 'Access: (%#a/%A)  Uid: ( %u/ %U) Gid: ( %g/ %G)' /etc/group

Access: (0644/-rw-r--r--)  Uid: ( 0/ root) Gid: ( 0/ root)
```

Remediation:

Run the following commands to remove excess permissions, set owner, and set group on `/etc/group`:

```
# chmod u-x,go-wx /etc/group
# chown root:root /etc/group
```

Default Value:

Access: (0644/-rw-r--r--) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

7.1.4 Ensure access to /etc/group- is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/etc/group-` file contains a backup list of all the valid groups defined in the system.

Rationale:

It is critical to ensure that the `/etc/group-` file is protected from unauthorized access. Although it is protected by default, the file permissions could be changed either inadvertently or through malicious actions.

Audit:

Run the following command to verify `/etc/group-` is mode 644 or more restrictive, `Uid` is `0/root` and `Gid` is `0/root`:

```
# stat -Lc 'Access: (%#a/%A)  Uid: ( %u/ %U) Gid: ( %g/ %G)'  /etc/group-

Access: (0644/-rw-r--r--)  Uid: ( 0/ root) Gid: ( 0/ root)
```

Remediation:

Run the following commands to remove excess permissions, set owner, and set group on `/etc/group-`:

```
# chmod u-x,go-wx /etc/group-
# chown root:root /etc/group-
```

Default Value:

Access: (0644/-rw-r--r--) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

7.1.5 Ensure access to /etc/shadow is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/etc/shadow` file is used to store the information about user accounts that is critical to the security of those accounts, such as the hashed password and other security information.

Rationale:

If attackers can gain read access to the `/etc/shadow` file, they can easily run a password cracking program against the hashed password to break it. Other security information that is stored in the `/etc/shadow` file (such as expiration) could also be useful to subvert the user accounts.

Audit:

Run the following command to verify `/etc/shadow` is mode 000, `Uid` is `0/root` and `Gid` is `0/root`:

```
# stat -Lc 'Access: (%#a/%A)  Uid: ( %u/ %U) Gid: ( %g/ %G)'  /etc/shadow

Access: (0/----------)  Uid: ( 0/ root) Gid: ( 0/ root)
```

Remediation:

Run the following commands to set mode, owner, and group on `/etc/shadow`:

```
# chown root:root /etc/shadow
# chmod 0000 /etc/shadow
```

Default Value:

Access: (0/----------) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

7.1.6 Ensure access to /etc/shadow- is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/etc/shadow-` file is used to store backup information about user accounts that is critical to the security of those accounts, such as the hashed password and other security information.

Rationale:

It is critical to ensure that the `/etc/shadow-` file is protected from unauthorized access. Although it is protected by default, the file permissions could be changed either inadvertently or through malicious actions.

Audit:

Run the following command to verify `/etc/shadow-` is mode 000, `Uid` is `0/root` and `Gid` is `0/root`:

```
# stat -Lc 'Access: (%#a/%A)  Uid: ( %u/ %U) Gid: ( %g/ %G)'  /etc/shadow-

Access: (0/----------)  Uid: ( 0/ root) Gid: ( 0/ root)
```

Remediation:

Run the following commands to set mode, owner, and group on `/etc/shadow-`:

```
# chown root:root /etc/shadow-
# chmod 0000 /etc/shadow-
```

Default Value:

Access: (0/----------) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

7.1.7 Ensure access to /etc/gshadow is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/etc/gshadow` file is used to store the information about groups that is critical to the security of those accounts, such as the hashed password and other security information.

Rationale:

If attackers can gain read access to the `/etc/gshadow` file, they can easily run a password cracking program against the hashed password to break it. Other security information that is stored in the `/etc/gshadow` file (such as group administrators) could also be useful to subvert the group.

Audit:

Run the following command to verify `/etc/gshadow` is mode 000, `Uid` is `0/root` and `Gid` is `0/root`:

```
# stat -Lc 'Access: (%#a/%A)  Uid: ( %u/ %U) Gid: ( %g/ %G)'  /etc/gshadow

Access: (0/----------)  Uid: ( 0/ root) Gid: ( 0/ root)
```

Remediation:

Run the following commands to set mode, owner, and group on `/etc/gshadow`:

```
# chown root:root /etc/gshadow
# chmod 0000 /etc/gshadow
```

Default Value:

Access: (0/----------) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	16.4 Encrypt or Hash all Authentication Credentials Encrypt or hash with a salt all authentication credentials when stored.		●	●

7.1.8 Ensure access to /etc/gshadow- is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The `/etc/gshadow-` file is used to store backup information about groups that is critical to the security of those accounts, such as the hashed password and other security information.

Rationale:

It is critical to ensure that the `/etc/gshadow-` file is protected from unauthorized access. Although it is protected by default, the file permissions could be changed either inadvertently or through malicious actions.

Audit:

Run the following command to verify `/etc/gshadow-` is mode 000, `Uid` is `0/root` and `Gid` is `0/root`:

```
# stat -Lc 'Access: (%#a/%A)  Uid: ( %u/ %U) Gid: ( %g/ %G)'  /etc/gshadow-

Access: (0/----------)  Uid: ( 0/ root) Gid: ( 0/ root)
```

Remediation:

Run the following commands to set mode, owner, and group on `/etc/gshadow-`:

```
# chown root:root /etc/gshadow-
# chmod 0000 /etc/gshadow-
```

Default Value:

Access: (0/----------) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	16.4 Encrypt or Hash all Authentication Credentials Encrypt or hash with a salt all authentication credentials when stored.		●	●

7.1.9 Ensure access to /etc/shells is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`/etc/shells` is a text file which contains the full pathnames of valid login shells. This file is consulted by `chsh` and available to be queried by other programs.

Rationale:

It is critical to ensure that the `/etc/shells` file is protected from unauthorized access. Although it is protected by default, the file permissions could be changed either inadvertently or through malicious actions.

Audit:

Run the following command to verify `/etc/shells` is mode 644 or more restrictive, `Uid` is `0/root` and `Gid` is `0/root`:

```
# stat -Lc 'Access: (%#a/%A)  Uid: ( %u/ %U) Gid: ( %g/ %G)' /etc/shells

Access: (0644/-rw-r--r--)  Uid: ( 0/ root) Gid: ( 0/ root)
```

Remediation:

Run the following commands to remove excess permissions, set owner, and set group on `/etc/shells`:

```
# chmod u-x,go-wx /etc/shells
# chown root:root /etc/shells
```

Default Value:

Access: (0644/-rw-r--r--) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

7.1.10 Ensure access to /etc/security/opasswd is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

`/etc/security/opasswd` and it's backup `/etc/security/opasswd.old` hold user's previous passwords if `pam_unix` or `pam_pwhistory` is in use on the system

Rationale:

It is critical to ensure that `/etc/security/opasswd` is protected from unauthorized access. Although it is protected by default, the file permissions could be changed either inadvertently or through malicious actions.

Audit:

Run the following commands to verify `/etc/security/opasswd` and `/etc/security/opasswd.old` are mode 600 or more restrictive, `Uid` is `0/root` and `Gid` is `0/root` if they exist:

```
#  [ -e "/etc/security/opasswd" ] && stat -Lc '%n Access: (%#a/%A)  Uid: (
%u/ %U) Gid: ( %g/ %G)' /etc/security/opasswd

/etc/security/opasswd Access: (0600/-rw-------)  Uid: ( 0/ root) Gid: ( 0/
root)
 -OR-
Nothing is returned
#  [ -e "/etc/security/opasswd.old" ] && stat -Lc '%n Access: (%#a/%A)  Uid:
( %u/ %U) Gid: ( %g/ %G)' /etc/security/opasswd.old

/etc/security/opasswd.old Access: (0600/-rw-------)  Uid: ( 0/ root) Gid: (
0/ root)
 -OR-
Nothing is returned
```

Remediation:

Run the following commands to remove excess permissions, set owner, and set group on `/etc/security/opasswd` and `/etc/security/opasswd.old` is they exist:

```
# [ -e "/etc/security/opasswd" ] && chmod u-x,go-rwx /etc/security/opasswd
# [ -e "/etc/security/opasswd" ] && chown root:root /etc/security/opasswd
# [ -e "/etc/security/opasswd.old" ] && chmod u-x,go-rwx
/etc/security/opasswd.old
# [ -e "/etc/security/opasswd.old" ] && chown root:root
/etc/security/opasswd.old
```

Default Value:

/etc/security/opasswd Access: (0600/-rw-------) Uid: (0/ root) Gid: (0/ root)

References:

1. NIST SP 800-53 Rev. 5: AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

7.1.11 Ensure world writable files and directories are secured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

World writable files are the least secure. Data in world-writable files can be modified and compromised by any user on the system. World writable files may also indicate an incorrectly written script or program that could potentially be the cause of a larger compromise to the system's integrity. See the `chmod(2)` man page for more information.

Setting the sticky bit on world writable directories prevents users from deleting or renaming files in that directory that are not owned by them.

Rationale:

Data in world-writable files can be modified and compromised by any user on the system. World writable files may also indicate an incorrectly written script or program that could potentially be the cause of a larger compromise to the system's integrity.

This feature prevents the ability to delete or rename files in world writable directories (such as `/tmp`) that are owned by another user.

Audit:

Run the following script to verify:

- No world writable files exist
- No world writable directories without the sticky bit exist

```
#!/usr/bin/env bash

{
   a_output=() a_output2=() a_file=() a_dir=()
   l_smask='01000' l_limit="50"
   a_path=(-path "*/containers/storage/*" -o -path "*/containerd/*" -o -path
"*/kubelet/*" -o -path "/sys/*" -o -path "/snap/*" -o -path "/boot/efi/*")
   while IFS= read -r l_mount; do
      while IFS= read -r -d $'\0' l_file; do
         if [ -e "$l_file" ]; then
            [ -f "$l_file" ] && a_file+=("$l_file")
            if [ -d "$l_file" ]; then
               l_mode="$(stat -Lc '%#a' "$l_file")"
               [ ! $(( $l_mode & $l_smask )) -gt 0 ] && a_dir+=("$l_file")
            fi
         fi
      done < <(find "$l_mount" -mount -xdev \( "${a_path[@]}" \) -prune -o \(
-type f -o -type d \) -perm -0002 -print0 2> /dev/null)
   done < <(findmnt -Dkerno fstype,target | awk '($1 !~
/^\s*(nfs|proc|cifs|smb|vfat|iso9660|efivarfs|selinuxfs|ncpfs)/ && $2 !~
/^(\/run|\/tmp|\/var\/tmp)(\/|$)/){print $2}')
   if [ "${#a_file[@]}" -le 0 ]; then
      a_output+=("  - No world writable files exist on the local
filesystem.")
   else
      a_output2+=("" " - There are \"${#a_file[@]}\" World writable files on
the system." \
      "   - The following is a list of World writable files:" \
      "${a_file[@]:0:$l_limit}" "   - end of list")
   fi
   if [ "${#a_dir[@]}" -le 0 ]; then
      a_output+=("  - Sticky bit is set on world writable directories on the
local filesystem.")
   else
      a_output2+=("" " - There are \"${#a_dir[@]}\" World writable
directories without the sticky bit on the system." \
      "   - The following is a list of World writable directories without the
sticky bit:" \
      "${a_dir[@]:0:$l_limit}" "   - end of list")
   fi
   if [ "${#a_output2[@]}" -le 0 ]; then
      printf '%s\n' "" "- Audit Result:" "  ** PASS **" "${a_output[@]}"
   else
      printf '%s\n' "" "- Audit Result:" "  ** FAIL **" "  * Reasons for
audit failure *" "${a_output2[@]}" ""
      [ "${#a_output[@]}" -gt 0 ] && printf '%s\n' "- Correctly set:"
"${a_output[@]}"
   fi
}
```

Note: On systems with a large number of files and/or directories, this audit may be a long running process

Remediation:

- World Writable Files:
  - It is recommended that write access is removed from `other` with the command (`chmod o-w <filename>`), but always consult relevant vendor documentation to avoid breaking any application dependencies on a given file.
- World Writable Directories:
  - Set the sticky bit on all world writable directories with the command (`chmod a+t <directory_name>`)

Run the following script to:

- Remove other write permission from any world writable files
- Add the sticky bit to all world writable directories

```
#!/usr/bin/env bash

{
   l_smask='01000' a_file=() a_dir=()
   a_path=(-path "*/containers/storage/*" -o -path "*/containerd/*" -o -path
"*/kubelet/*" -o -path "/sys/*" -o -path "/snap/*" -o -path "/boot/efi/*")
   while IFS= read -r l_mount; do
      while IFS= read -r -d $'\0' l_file; do
         if [ -e "$l_file" ]; then
            l_mode="$(stat -Lc '%#a' "$l_file")"
            if [ -f "$l_file" ]; then # Remove excess permissions from WW
files
               echo -e " - File: \"$l_file\" is mode: \"$l_mode\"\n  -
removing write permission on \"$l_file\" from \"other\""
               chmod o-w "$l_file"
            fi
            if [ -d "$l_file" ]; then # Add sticky bit
               if [ ! $(( $l_mode & $l_smask )) -gt 0 ]; then
                  echo -e " - Directory: \"$l_file\" is mode: \"$l_mode\" and
doesn't have the sticky bit set\n  - Adding the sticky bit"
                  chmod a+t "$l_file"
               fi
            fi
         fi
      done < <(find "$l_mount" -mount -xdev \( "${a_path[@]}" \) \( -type f -
o -type d \) -perm -0002 -print0 2> /dev/null)
   done < <(findmnt -Dkerno fstype,target | awk '($1 !~
/^\s*(nfs|proc|cifs|smb|vfat|iso9660|efivarfs|selinuxfs|ncpfs)/ && $2 !~
/^(\/run|\/tmp|\/var\/tmp)(\/|$)/){print $2}')
}
```

References:

1. NIST SP 800-53 :: SC-4
2. NIST SP 800-53A :: SC-4.1
3. RHEL 8 STIG Vul ID: V-230243
4. RHEL 8 STIG Rule ID: SV-230243r792857

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

7.1.12 Ensure no files or directories without an owner and a group exist (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Administrators may delete users or groups from the system and neglect to remove all files and/or directories owned by those users or groups.

Rationale:

A new user or group who is assigned a deleted user's user ID or group ID may then end up "owning" a deleted user or group's files, and thus have more access on the system than was intended.

Audit:

Run the following script to verify no unowned or ungrouped files or directories exist:

```
#!/usr/bin/env bash

{
   a_output=() a_output2=() a_nouser=() a_nogroup=() # Initialize arrays
   a_path=(-path "*/containers/storage/*" -o -path "*/containerd/*" -o -path
"*/kubelet/*" -o -path "/sys/*" -o -path "/snap/*" -o -path "/boot/efi/*")
   while IFS= read -r l_mount; do
      while IFS= read -r -d $'\0' l_file; do
         if [ -e "$l_file" ]; then
            while IFS=: read -r l_user l_group; do
               [ "$l_user" = "UNKNOWN" ] && a_nouser+=("$l_file")
               [ "$l_group" = "UNKNOWN" ] && a_nogroup+=("$l_file")
            done < <(stat -Lc '%U:%G' "$l_file")
         fi
      done < <(find "$l_mount" -mount -xdev \( "${a_path[@]}" \) -prune -o \(
-type f -o -type d \) \( -nouser -o -nogroup \) -print0 2> /dev/null)
   done < <(findmnt -Dkerno fstype,target | awk '($1 !~
/^\s*(nfs|proc|cifs|smb|vfat|iso9660|efivarfs|selinuxfs|ncpfs)/ && $2 !~
/^(\/run|\/tmp|\/var\/tmp)(\/|$)/){print $2}')
   if ! (( ${#a_nouser[@]} > 0 )); then
      a_output+=("  - No files or directories without an owner exist on the
local filesystem.")
   else
      a_output2+=("  - There are \"$(printf '%s' "${#a_nouser[@]}")\" unowned
files or directories on the system." \
      "   - The following is a list of unowned files and/or
directories:\n$(printf '%s\n' "${a_nouser[@]}")" "   - end of list")
   fi
   if ! (( ${#a_nogroup[@]} > 0 )); then
      a_output+=("  - No files or directories without a group owner exist on
the local filesystem.")
   else
      a_output2+=("  - There are \"$(printf '%s' "${#a_nogroup[@]}")\"
ungrouped files or directories on the system." \
      "   - The following is a list of ungrouped files and/or
directories:\n$(printf '%s\n' "${a_nogroup[@]}")" "   - end of list")
   fi
   if [ "${#a_output2[@]}" -le 0 ]; then
      printf '%s\n' "" "- Audit Result:" "  ** PASS **" "${a_output[@]}"
   else
      printf '%s\n' "" "- Audit Result:" "  ** FAIL **" "  * Reasons for
audit failure *" "${a_output2[@]}" ""
      [ "${#a_output[@]}" -gt 0 ] && printf '%s\n' "- Correctly set:"
"${a_output[@]}"
   fi
}
```

Note: On systems with a large number of files and/or directories, this audit may be a long running process

Remediation:

Remove or set ownership and group ownership of these files and/or directories to an active user on the system as appropriate.

References:

1. NIST SP 800-53 :: CM-6 b
2. NIST SP 800-53A :: CM-6.1 (iv)
3. RHEL 8 STIG Vul ID: V-230326
4. RHEL 8 STIG Rule ID: SV-230326r627750
5. RHEL 8 STIG Vul ID: V-230327
6. RHEL 8 STIG Rule ID: SV-230327r627750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

7.1.13 Ensure SUID and SGID files are reviewed (Manual)

Profile Applicability:

- Level 1 - Server

Description:

The owner of a file can set the file's permissions to run with the owner's or group's permissions, even if the user running the program is not the owner or a member of the group. The most common reason for a SUID or SGID program is to enable users to perform functions (such as changing their password) that require root privileges.

Rationale:

There are valid reasons for SUID and SGID programs, but it is important to identify and review such programs to ensure they are legitimate. Review the files returned by the action in the audit section and check to see if system binaries have a different checksum than what from the package. This is an indication that the binary may have been replaced.

Audit:

Run the following script to generate a list of SUID and SGID files:

```
#!/usr/bin/env bash

{
   l_output="" l_output2=""
   a_suid=(); a_sgid=() # initialize arrays
   while IFS= read -r l_mount; do
      while  IFS= read -r -d $'\0' l_file; do
         if [ -e "$l_file" ]; then
            l_mode="$(stat -Lc '%#a' "$l_file")"
            [ $(( $l_mode & 04000 )) -gt 0 ] && a_suid+=("$l_file")
            [ $(( $l_mode & 02000 )) -gt 0 ] && a_sgid+=("$l_file")
         fi
      done < <(find "$l_mount" -xdev -type f \( -perm -2000 -o -perm -4000 \)
-print0 2>/dev/null)
   done < <(findmnt -Dkerno fstype,target,options | awk '($1 !~
/^\s*(nfs|proc|smb|vfat|iso9660|efivarfs|selinuxfs)/ && $2 !~
/^\/run\/user\// && $3 !~/noexec/ && $3 !~/nosuid/) {print $2}')
   if ! (( ${#a_suid[@]} > 0 )); then
      l_output="$l_output\n - No executable SUID files exist on the system"
   else
      l_output2="$l_output2\n - List of \"$(printf '%s' "${#a_suid[@]}")\"
SUID executable files:\n$(printf '%s\n' "${a_suid[@]}")\n - end of list -\n"
   fi
   if ! (( ${#a_sgid[@]} > 0 )); then
      l_output="$l_output\n - No SGID files exist on the system"
   else
      l_output2="$l_output2\n - List of \"$(printf '%s' "${#a_sgid[@]}")\"
SGID executable files:\n$(printf '%s\n' "${a_sgid[@]}")\n - end of list -\n"
   fi
   [ -n "$l_output2" ] && l_output2="$l_output2\n- Review the preceding
list(s) of SUID and/or SGID files to\n- ensure that no rogue programs have
been introduced onto the system.\n"
   unset a_arr; unset a_suid; unset a_sgid # Remove arrays
   # If l_output2 is empty, Nothing to report
   if [ -z "$l_output2" ]; then
      echo -e "\n- Audit Result:\n$l_output\n"
   else
      echo -e "\n- Audit Result:\n$l_output2\n"
      [ -n "$l_output" ] && echo -e "$l_output\n"
   fi
}
```

Note: on systems with a large number of files, this may be a long running process

Remediation:

Ensure that no rogue SUID or SGID programs have been introduced into the system. Review the files returned by the action in the Audit section and confirm the integrity of these binaries.

References:

1. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5, AC-3, MP-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

7.2 Local User and Group Settings

This section provides guidance on securing aspects of the local users and groups.

Note: The recommendations in this section check local users and groups. Any users or groups from other sources such as LDAP will not be audited. In a domain environment similar checks should be performed against domain users and groups.

7.2.1 Ensure accounts in /etc/passwd use shadowed passwords (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Local accounts can use shadowed passwords. With shadowed passwords, the passwords are saved in shadow password file, `/etc/shadow`, encrypted by a salted one-way hash. Accounts with a shadowed password have an `x` in the second field in `/etc/passwd`.

Rationale:

The `/etc/passwd` file also contains information like user ID's and group ID's that are used by many system programs. Therefore, the `/etc/passwd` file must remain world readable. In spite of encoding the password with a randomly-generated one-way hash function, an attacker could still break the system if they got access to the `/etc/passwd` file. This can be mitigated by using shadowed passwords, thus moving the passwords in the `/etc/passwd` file to `/etc/shadow`. The `/etc/shadow` file is set so only root will be able to read and write. This helps mitigate the risk of an attacker gaining access to the encoded passwords with which to perform a dictionary attack.

Notes:

- All accounts must have passwords or be locked to prevent the account from being used by an unauthorized user.
- A user account with an empty second field in `/etc/passwd` allows the account to be logged into by providing only the username.

Audit:

Run the following command and verify that no output is returned:

```
# awk -F: '($2 != "x" ) { print "User: \"" $1 "\" is not set to shadowed
passwords "}' /etc/passwd
```

Remediation:

Run the following command to set accounts to use shadowed passwords and migrate passwords in `/etc/passwd` to `/etc/shadow`:

```
# pwconv
```

Investigate to determine if the account is logged in and what it is being used for, to determine if it needs to be forced off.

References:

1. NIST SP 800-53 Rev. 5: IA-5
2. PWCONV(8)

Additional Information:

The `pwconv` command creates shadow from `passwd` and an optionally existing `shadow`.

- The `pwunconv` command creates `passwd` from `passwd` and `shadow` and then removes `shadow`.
- The `grpconv` command creates `gshadow` from `group` and an optionally existing `gshadow`.
- The `grpunconv` command creates `group` from `group` and `gshadow` and then removes `gshadow`.

These four programs all operate on the normal and shadow password and group files: `/etc/passwd`, `/etc/group`, `/etc/shadow`, and `/etc/gshadow`.

Each program acquires the necessary locks before conversion. `pwconv` and `grpconv` are similar. First, entries in the shadowed file which don't exist in the main file are removed. Then, shadowed entries which don't have `x' as the password in the main file are updated. Any missing shadowed entries are added. Finally, passwords in the main file are replaced with` x'. These programs can be used for initial conversion as well to update the shadowed file if the main file is edited by hand.

`pwconv` will use the values of `PASS_MIN_DAYS`, `PASS_MAX_DAYS`, and `PASS_WARN_AGE` from /etc/login.defs when adding new entries to /etc/shadow.

`pwunconv` and `grpunconv` are similar. Passwords in the main file are updated from the shadowed file. Entries which exist in the main file but not in the shadowed file are left alone. Finally, the shadowed file is removed. Some password aging information is lost by `pwunconv`. It will convert what it can.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.11 Encrypt Sensitive Data at Rest Encrypt sensitive data at rest on servers, applications, and databases containing sensitive data. Storage-layer encryption, also known as server-side encryption, meets the minimum requirement of this Safeguard. Additional encryption methods may include application-layer encryption, also known as client-side encryption, where access to the data storage device(s) does not permit access to the plain-text data.		●	●
v7	16.4 Encrypt or Hash all Authentication Credentials Encrypt or hash with a salt all authentication credentials when stored.		●	●

7.2.2 Ensure /etc/shadow password fields are not empty (Automated)

Profile Applicability:

- Level 1 - Server

Description:

An account with an empty password field means that anybody may log in as that user without providing a password.

Rationale:

All accounts must have passwords or be locked to prevent the account from being used by an unauthorized user.

Audit:

Run the following command and verify that no output is returned:

```
# awk -F: '($2 == "" ) { print $1 " does not have a password "}' /etc/shadow
```

Remediation:

If any accounts in the `/etc/shadow` file do not have a password, run the following command to lock the account until it can be determined why it does not have a password:

```
# passwd -l <username>
```

Also, check to see if the account is logged in and investigate what it is being used for to determine if it needs to be forced off.

References:

1. NIST SP 800-53 :: CM-6 b
2. NIST SP 800-53A :: CM-6.1 (iv)
3. RHEL 8 STIG Vul ID: V-251706
4. RHEL 8 STIG Rule ID: SV-251706r809342

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

7.2.3 Ensure all groups in /etc/passwd exist in /etc/group (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Over time, system administration errors and changes can lead to groups being defined in `/etc/passwd` but not in `/etc/group` .

Rationale:

Groups defined in the `/etc/passwd` file but not in the `/etc/group` file pose a threat to system security since group permissions are not properly managed.

Audit:

Run the following script to verify all GIDs in `/etc/passwd` exist in `/etc/group`:

```
#!/usr/bin/env bash

{
   a_passwd_group_gid=("$(awk -F: '{print $4}' /etc/passwd | sort -u)")
   a_group_gid=("$(awk -F: '{print $3}' /etc/group | sort -u)")
   a_passwd_group_diff=("$(printf '%s\n' "${a_group_gid[@]}"
"${a_passwd_group_gid[@]}" | sort | uniq -u)")
   while IFS= read -r l_gid; do
      awk -F: '($4 == '"$l_gid"') {print "  - User: \"" $1 "\" has GID: \""
$4 "\" which does not exist in /etc/group" }' /etc/passwd
   done < <(printf '%s\n' "${a_passwd_group_gid[@]}"
"${a_passwd_group_diff[@]}" | sort | uniq -D | uniq)
   unset a_passwd_group_gid; unset a_group_gid; unset a_passwd_group_diff
}
```

Nothing should be returned

Remediation:

Analyze the output of the Audit step above and perform the appropriate action to correct any discrepancies found.

References:

1. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

7.2.4 Ensure no duplicate UIDs exist (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Although the `useradd` program will not let you create a duplicate User ID (UID), it is possible for an administrator to manually edit the `/etc/passwd` file and change the UID field.

Rationale:

Users must be assigned unique UIDs for accountability and to ensure appropriate access protections.

Satisfies: SRG-OS-000104-GPOS-00051, SRG-OS-000121-GPOS-00062, SRG-OS-000042-GPOS-00020

Audit:

Run the following script and verify no results are returned:

```
#!/usr/bin/env bash

{
  while read -r l_count l_uid; do
    if [ "$l_count" -gt 1 ]; then
      echo -e "Duplicate UID: \"$l_uid\" Users: \"$(awk -F: '($3 == n) {
print $1 }' n=$l_uid /etc/passwd | xargs)\""
    fi
  done < <(cut -f3 -d":" /etc/passwd | sort -n | uniq -c)
}
```

Remediation:

Based on the results of the audit script, establish unique UIDs and review all files owned by the shared UIDs to determine which UID they are supposed to belong to.

References:

1. NIST SP 800-53 :: IA-2
2. NIST SP 800-53A :: IA-2.1
3. RHEL 8 STIG Vul ID: V-230371
4. RHEL 8 STIG Rule ID: SV-230371r627750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

7.2.5 Ensure no duplicate GIDs exist (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Although the `groupadd` program will not let you create a duplicate Group ID (GID), it is possible for an administrator to manually edit the `/etc/group` file and change the GID field.

Rationale:

User groups must be assigned unique GIDs for accountability and to ensure appropriate access protections.

Audit:

Run the following script and verify no results are returned:

```
#!/usr/bin/env bash

{
   while read -r l_count l_gid; do
      if [ "$l_count" -gt 1 ]; then
      echo -e "Duplicate GID: \"$l_gid\" Groups: \"$(awk -F: '($3 == n) {
print $1 }' n=$l_gid /etc/group | xargs)\""
    fi
  done < <(cut -f3 -d":" /etc/group | sort -n | uniq -c)
}
```

Remediation:

Based on the results of the audit script, establish unique GIDs and review all files owned by the shared GID to determine which group they are supposed to belong to.

References:

1. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5

Additional Information:

You can also use the `grpck` command to check for other inconsistencies in the `/etc/group` file.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

7.2.6 Ensure no duplicate user names exist (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Although the `useradd` program will not let you create a duplicate user name, it is possible for an administrator to manually edit the `/etc/passwd` file and change the username.

Rationale:

If a user is assigned a duplicate user name, it will create and have access to files with the first UID for that username in `/etc/passwd` . For example, if "test4" has a UID of 1000 and a subsequent "test4" entry has a UID of 2000, logging in as "test4" will use UID 1000. Effectively, the UID is shared, which is a security problem.

Audit:

Run the following script and verify no results are returned:

```
#!/usr/bin/env bash

{
   while read -r l_count l_user; do
      if [ "$l_count" -gt 1 ]; then
         echo -e "Duplicate User: \"$l_user\" Users: \"$(awk -F: '($1 == n) {
print $1 }' n=$l_user /etc/passwd | xargs)\""
      fi
   done < <(cut -f1 -d":" /etc/passwd | sort -n | uniq -c)
}
```

Remediation:

Based on the results of the audit script, establish unique user names for the users. File ownerships will automatically reflect the change as long as the users have unique UIDs.

References:

1. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

7.2.7 Ensure no duplicate group names exist (Automated)

Profile Applicability:

- Level 1 - Server

Description:

Although the `groupadd` program will not let you create a duplicate group name, it is possible for an administrator to manually edit the `/etc/group` file and change the group name.

Rationale:

If a group is assigned a duplicate group name, it will create and have access to files with the first GID for that group in `/etc/group` . Effectively, the GID is shared, which is a security problem.

Audit:

Run the following script and verify no results are returned:

```
#!/usr/bin/env bash

{
   while read -r l_count l_group; do
      if [ "$l_count" -gt 1 ]; then
         echo -e "Duplicate Group: \"$l_group\" Groups: \"$(awk -F: '($1 ==
n) { print $1 }' n=$l_group /etc/group | xargs)\""
      fi
   done < <(cut -f1 -d":" /etc/group | sort -n | uniq -c)
}
```

Remediation:

Based on the results of the audit script, establish unique names for the user groups. File group ownerships will automatically reflect the change as long as the groups have unique GIDs.

References:

1. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

7.2.8 Ensure local interactive user home directories are configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

The user home directory is space defined for the particular user to set local environment variables and to store personal files. While the system administrator can establish secure permissions for users' home directories, the users can easily override these. Users can be defined in `/etc/passwd` without a home directory or with a home directory that does not actually exist.

Rationale:

Since the user is accountable for files stored in the user home directory, the user must be the owner of the directory. Group or world-writable user home directories may enable malicious users to steal or modify other users' data or to gain another user's system privileges. If the user's home directory does not exist or is unassigned, the user will be placed in "/" and will not be able to write any files or have local environment variables set.

Audit:

Run the following script to:

- Ensure local interactive user home directories exist
- Ensure local interactive users own their home directories
- Ensure local interactive user home directories are mode 750 or more restrictive

```
#!/usr/bin/env bash

{
   a_output=() a_output2=() a_exists2=() a_mode2=() a_owner2=()
   l_valid_shells="^($( awk -F\/ '$NF != "nologin" {print}' /etc/shells | sed
-rn '/^\//{s,/,\\\\/,g;p}' | paste -s -d '|' - ))$"
   l_mask='0027'; l_max="$( printf '%o' $(( 0777 & ~$l_mask)) )"
   l_users="$(awk -v pat="$l_valid_shells" -F: '$(NF) ~ pat { print $1 " "
$(NF-1) }' /etc/passwd | wc -l)"
   [ "$l_users" -gt 10000 ] && printf '%s\n' "" "  ** INFO **" \
   "  $l_users Local interactive users found on the system" "  This may be a
long running check" "  **********"
   while IFS=" " read -r l_user l_home; do
      if [ -d "$l_home" ]; then
         while IFS=: read -r l_own l_mode; do
            [ "$l_user" != "$l_own" ] && a_owner2+=("  - User: \"$l_user\"
Home \"$l_home\" is owned by: \"$l_own\"")
            [ $(( $l_mode & $l_mask )) -gt 0 ] && a_mode2+=("  - User:
\"$l_user\" Home \"$l_home\" is mode: \"$l_mode\"" \
            "    should be mode: \"$l_max\" or more restrictive")
         done <<< "$(stat -Lc '%U:%#a' "$l_home")"
      else
         a_exists2+=("  - User: \"$l_user\" Home Directory: \"$l_home\"
Doesn't exist")
      fi
   done <<< "$(awk -v pat="$l_valid_shells" -F: '$(NF) ~ pat { print $1 " "
$(NF-1) }' /etc/passwd)"
   [ "${#a_exists2[@]}" -gt 0 ] && a_output2+=("${a_exists2[@]}") || \
   a_output+=("  - All interactive users home directories exist")
   [ "${#a_mode2[@]}" -gt 0 ] && a_output2+=("${a_mode2[@]}") || \
   a_output+=("  - All interactive users home directories are mode \"$l_max\"
or more restrictive")
   [ "${#a_owner2[@]}" -gt 0 ] && a_output2+=("${a_owner2[@]}") || \
   a_output+=("  - All interactive users own their home directory")
   if [ "${#a_output2[@]}" -le 0 ]; then
      printf '%s\n' "" "- Audit Result:" "  ** PASS **" "${a_output[@]}"
   else
      printf '%s\n' "" "- Audit Result:" "  ** FAIL **" " - Reason(s) for
audit failure:" "${a_output2[@]}"
      [ "${#a_output[@]}" -gt 0 ] && printf '%s\n' "- Correctly set:"
"${a_output[@]}"
   fi
}
```

Remediation:

If a local interactive users' home directory is undefined and/or doesn't exist, follow local site policy and perform one of the following:

- Lock the user account
- Remove the user from the system
- Create a directory for the user. If undefined, edit `/etc/passwd` and add the absolute path to the directory to the last field of the user.

Run the following script to:

- Remove excessive permissions from local interactive users home directories
- Update the home directory's owner

```
#!/usr/bin/env bash

{
   a_output=() a_output2=() a_exists2=() a_mode2=() a_owner2=()
   l_valid_shells="^($( awk -F\/ '$NF != "nologin" {print}' /etc/shells | sed
-rn '/^\//{s,/,\\\\/,g;p}' | paste -s -d '|' - ))$"
   l_mask='0027'; l_max="$( printf '%o' $(( 0777 & ~$l_mask)) )"
   l_users="$(awk -v pat="$l_valid_shells" -F: '$(NF) ~ pat { print $1 " "
$(NF-1) }' /etc/passwd | wc -l)"
   [ "$l_users" -gt 10000 ] && printf '%s\n' "" "  ** INFO **" \
   "  $l_users Local interactive users found on the system" "  This may be a
long running process" "  **********"
   while IFS=" " read -r l_user l_home; do
      if [ -d "$l_home" ]; then
         while IFS=: read -r l_own l_mode; do
            if [ "$l_user" != "$l_own" ]; then
               a_owner2+=("  - User: \"$l_user\" Home \"$l_home\" is owned
by: \"$l_own\"" \
               "    changing owner to: \"$l_user\"") && chown "$l_user"
"$l_home"
            fi
            if [ $(( $l_mode & $l_mask )) -gt 0 ]; then
               a_mode2+=("  - User: \"$l_user\" Home \"$l_home\" is mode:
\"$l_mode\"" \
               "    changing to mode: \"$l_max\" or more restrictive")
               chmod g-w,o-rwx "$l_home"
            fi
         done <<< "$(stat -Lc '%U:%#a' "$l_home")"
      else
         a_exists2+=("  - User: \"$l_user\" Home Directory: \"$l_home\"
Doesn't exist")
      fi
   done <<< "$(awk -v pat="$l_valid_shells" -F: '$(NF) ~ pat { print $1 " "
$(NF-1) }' /etc/passwd)"
   [ "${#a_exists2[@]}" -gt 0 ] && a_output2+=("${a_exists2[@]}")
   [ "${#a_mode2[@]}" -gt 0 ] && a_output2+=("${a_mode2[@]}")
   [ "${#a_owner2[@]}" -gt 0 ] && a_output2+=("${a_owner2[@]}")
   if [ "${#a_output2[@]}" -gt 0 ]; then
      printf '%s\n' "" "${a_output2[@]}"
   else
      printf '%s\n' "" "- No changes required"
   fi
}
```

References:

1. NIST SP 800-53 :: CM-6 b
2. NIST SP 800-53A :: CM-6.1 (iv)
3. RHEL 8 STIG Vul ID: 230320
4. RHEL 8 STIG Rule ID: SV-230320r627750
5. RHEL 8 STIG GROUP ID: V-230321
6. RHEL 8 STIG RULE ID: SV-230321r627750
7. RHEL 8 STIG Vul ID: V-230323
8. RHEL 8 STIG Rule ID: SV-230323r627750

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

7.2.9 Ensure local interactive user dot files access is configured (Automated)

Profile Applicability:

- Level 1 - Server

Description:

While the system administrator can establish secure permissions for users' "dot" files, the users can easily override these.

- `.forward` file specifies an email address to forward the user's mail to.
- `.rhost` file provides the "remote authentication" database for the rcp, rlogin, and rsh commands and the rcmd() function. These files bypass the standard password-based user authentication mechanism. They specify remote hosts and users that are considered trusted (i.e. are allowed to access the local system without supplying a password)
- `.netrc` file contains data for logging into a remote host or passing authentication to an API.
- `.bash_history` file keeps track of the user's commands.

Rationale:

User configuration files with excessive or incorrect access may enable malicious users to steal or modify other users' data or to gain another user's system privileges.

Audit:

Run the following script to verify local interactive user dot files:

- Don't include `.forward`, `.rhost`, or `.netrc` files
- Are mode 0644 or more restrictive
- Are owned by the local interactive user
- Are group owned by the user's primary group
- `.bash_history` is mode 0600 or more restrictive

Note: If a `.netrc` file is required, and follows local site policy, it should be mode `0600` or more restrictive.

```
#!/usr/bin/env bash

{
   a_output2=(); a_output3=()
   l_maxsize="1000" # Maximum number of local interactive users before
warning (Default 1,000)
   l_valid_shells="^($( awk -F\/ '$NF != "nologin" {print}' /etc/shells | sed
-rn '/^\//{s,/,\\\\/,g;p}' | paste -s -d '|' - ))$"
   a_user_and_home=() # Create array with local users and their home
directories
   while read -r l_local_user l_local_user_home; do # Populate array with
users and user home location
      [[ -n "$l_local_user" && -n "$l_local_user_home" ]] &&
a_user_and_home+=("$l_local_user:$l_local_user_home")
   done <<< "$(awk -v pat="$l_valid_shells" -F: '$(NF) ~ pat { print $1 " "
$(NF-1) }' /etc/passwd)"
   l_asize="${#a_user_and_home[@]}" # Here if we want to look at number of
users before proceeding
   [ "${#a_user_and_home[@]}" -gt "$l_maxsize" ] && printf '%s\n' "" "  **
INFO **" \
   "  - \"$l_asize\" Local interactive users found on the system" \
   "  - This may be a long running check" ""
   file_access_chk()
   {
      a_access_out=()
      l_max="$( printf '%o' $(( 0777 & ~$l_mask)) )"
      if [ $(( $l_mode & $l_mask )) -gt 0 ]; then
         a_access_out+=("  - File: \"$l_hdfile\" is mode: \"$l_mode\" and
should be mode: \"$l_max\" or more restrictive")
      fi
      if [[ ! "$l_owner" =~ ($l_user) ]]; then
         a_access_out+=("  - File: \"$l_hdfile\" owned by: \"$l_owner\" and
should be owned by \"${l_user//|/ or }\"")
      fi
      if [[ ! "$l_gowner" =~ ($l_group) ]]; then
         a_access_out+=("  - File: \"$l_hdfile\" group owned by:
\"$l_gowner\" and should be group owned by \"${l_group//|/ or }\"")
      fi
   }
   while IFS=: read -r l_user l_home; do
      a_dot_file=(); a_netrc=(); a_netrc_warn=(); a_bhout=(); a_hdirout=()
      if [ -d "$l_home" ]; then
         l_group="$(id -gn "$l_user" | xargs)";l_group="${l_group// /|}"
         while IFS= read -r -d $'\0' l_hdfile; do
            while read -r l_mode l_owner l_gowner; do
               case "$(basename "$l_hdfile")" in
                  .forward | .rhost )
                     a_dot_file+=("  - File: \"$l_hdfile\" exists") ;;
                  .netrc )
                     l_mask='0177'; file_access_chk
                     if [ "${#a_access_out[@]}" -gt 0 ]; then
                        a_netrc+=("${a_access_out[@]}")
                     else
                        a_netrc_warn+=("   - File: \"$l_hdfile\" exists")
                     fi ;;
                  .bash_history )
                     l_mask='0177'; file_access_chk
```

```
                    [ "${#a_access_out[@]}" -gt 0 ] &&
a_bhout+=("${a_access_out[@]}") ;;
                * )
                    l_mask='0133'; file_access_chk
                    [ "${#a_access_out[@]}" -gt 0 ] &&
a_hdirout+=("${a_access_out[@]}") ;;
              esac
           done < <(stat -Lc '%#a %U %G' "$l_hdfile")
        done < <(find "$l_home" -xdev -type f -name '.*' -print0)
     fi
     if [[ "${#a_dot_file[@]}" -gt 0 || "${#a_netrc[@]}" -gt 0 ||
"${#a_bhout[@]}" -gt 0 || "${#a_hdirout[@]}" -gt 0 ]]; then
        a_output2+=(" - User: \"$l_user\" Home Directory: \"$l_home\""
"${a_dot_file[@]}" "${a_netrc[@]}" "${a_bhout[@]}" "${a_hdirout[@]}")
     fi
     [ "${#a_netrc_warn[@]}" -gt 0 ] && a_output3+=(" - User: \"$l_user\"
Home Directory: \"$l_home\"" "${a_netrc_warn[@]}")
   done <<< "$(printf '%s\n' "${a_user_and_home[@]}")"
   if [ "${#a_output2[@]}" -le 0 ]; then # If l_output2 is empty, we pass
      [ "${#a_output3[@]}" -gt 0 ] && printf '%s\n' "  ** WARNING **"
"${a_output3[@]}"
      printf '%s\n' "- Audit Result:" "  ** PASS **"
   else
      printf '%s\n' "- Audit Result:" "  ** FAIL **" " - * Reasons for audit
failure * :" "${a_output2[@]}" ""
      [ "${#a_output3[@]}" -gt 0 ] && printf '%s\n' "  ** WARNING **"
"${a_output3[@]}"
   fi
}
```

Remediation:

Making global modifications to users' files without alerting the user community can result in unexpected outages and unhappy users. Therefore, it is recommended that a monitoring policy be established to report user dot file permissions and determine the action to be taken in accordance with site policy.

The following script will:

- remove excessive permissions on `dot` files within interactive users' home directories
- change ownership of `dot` files within interactive users' home directories to the user
- change group ownership of `dot` files within interactive users' home directories to the user's primary group
- list `.forward` and `.rhost` files to be investigated and manually deleted

```
#!/usr/bin/env bash

{
   a_output2=(); a_output3=()
   l_maxsize="1000" # Maximum number of local interactive users before
warning (Default 1,000)
   l_valid_shells="^($( awk -F\/ '$NF != "nologin" {print}' /etc/shells | sed
-rn '/^\//{s,/,\\\\/,g;p}' | paste -s -d '|' - ))$"
   a_user_and_home=() # Create array with local users and their home
directories
   while read -r l_local_user l_local_user_home; do # Populate array with
users and user home location
      [[ -n "$l_local_user" && -n "$l_local_user_home" ]] &&
a_user_and_home+=("$l_local_user:$l_local_user_home")
   done <<< "$(awk -v pat="$l_valid_shells" -F: '$(NF) ~ pat { print $1 " "
$(NF-1) }' /etc/passwd)"
   l_asize="${#a_user_and_home[@]}" # Here if we want to look at number of
users before proceeding
   [ "${#a_user_and_home[@]}" -gt "$l_maxsize" ] && printf '%s\n' "" "  **
INFO **" \
   "  - \"$l_asize\" Local interactive users found on the system" \
   "  - This may be a long running check" ""
   file_access_fix()
   {
      a_access_out=()
      l_max="$( printf '%o' $(( 0777 & ~$l_mask)) )"
      if [ $(( $l_mode & $l_mask )) -gt 0 ]; then
         printf '%s\n' "" "  - File: \"$l_hdfile\" is mode: \"$l_mode\" and
should be mode: \"$l_max\" or more restrictive" \
         "     Updating file: \"$l_hdfile\" to be mode: \"$l_max\" or more
restrictive"
         chmod "$l_change" "$l_hdfile"
      fi
      if [[ ! "$l_owner" =~ ($l_user) ]]; then
         printf '%s\n' "" "  - File: \"$l_hdfile\" owned by: \"$l_owner\" and
should be owned by \"${l_user//|/ or }\"" \
         "     Updating file: \"$l_hdfile\" to be owned by \"${l_user//|/ or
}\""
         chown "$l_user" "$l_hdfile"
      fi
      if [[ ! "$l_gowner" =~ ($l_group) ]]; then
         printf '%s\n' "" "  - File: \"$l_hdfile\" group owned by:
\"$l_gowner\" and should be group owned by \"${l_group//|/ or }\"" \
         "     Updating file: \"$l_hdfile\" to be group owned by
\"${l_group//|/ or }\""
         chgrp "$l_group" "$l_hdfile"
      fi
   }
   while IFS=: read -r l_user l_home; do
      a_dot_file=(); a_netrc=(); a_netrc_warn=(); a_bhout=(); a_hdirout=()
      if [ -d "$l_home" ]; then
         l_group="$(id -gn "$l_user" | xargs)";l_group="${l_group// /|}"
         while IFS= read -r -d $'\0' l_hdfile; do
            while read -r l_mode l_owner l_gowner; do
               case "$(basename "$l_hdfile")" in
                  .forward | .rhost )
```

```
                    a_dot_file+=("  - File: \"$l_hdfile\" exists" "
Please review and manually delete this file") ;;
                 .netrc )
                    l_mask='0177'; l_change="u-x,go-rwx"; file_access_fix
                    a_netrc_warn+=("   - File: \"$l_hdfile\" exists") ;;
                 .bash_history )
                    l_mask='0177'; l_change="u-x,go-rwx"; file_access_fix ;;
                 * )
                    l_mask='0133'; l_change="u-x,go-wx"; file_access_fix ;;
              esac
           done < <(stat -Lc '%#a %U %G' "$l_hdfile")
        done < <(find "$l_home" -xdev -type f -name '.*' -print0)
     fi
     [ "${#a_dot_file[@]}" -gt 0 ] && a_output2+=(" - User: \"$l_user\" Home
Directory: \"$l_home\"" "${a_dot_file[@]}")
     [ "${#a_netrc_warn[@]}" -gt 0 ] && a_output3+=(" - User: \"$l_user\"
Home Directory: \"$l_home\"" "${a_netrc_warn[@]}")
   done <<< "$(printf '%s\n' "${a_user_and_home[@]}")"
   [ "${#a_output3[@]}" -gt 0 ] && printf '%s\n' "" "  ** WARNING **"
"${a_output3[@]}" ""
   [ "${#a_output2[@]}" -gt 0 ] && printf '%s\n' "" "${a_output2[@]}"
}
```

References:

1. NIST SP 800-53 Rev. 5: CM-1, CM-2, CM-6, CM-7, IA-5

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

Appendix: Summary Table

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1	**Initial Setup**		
1.1	**Filesystem**		
1.1.1	**Configure Filesystem Kernel Modules**		
1.1.1.1	Ensure cramfs kernel module is not available (Automated)	☐	☐
1.1.1.2	Ensure freevxfs kernel module is not available (Automated)	☐	☐
1.1.1.3	Ensure hfs kernel module is not available (Automated)	☐	☐
1.1.1.4	Ensure hfsplus kernel module is not available (Automated)	☐	☐
1.1.1.5	Ensure jffs2 kernel module is not available (Automated)	☐	☐
1.1.1.6	Ensure overlay kernel module is not available (Automated)	☐	☐
1.1.1.7	Ensure squashfs kernel module is not available (Automated)	☐	☐
1.1.1.8	Ensure udf kernel module is not available (Automated)	☐	☐
1.1.1.9	Ensure firewire-core kernel module is not available (Automated)	☐	☐
1.1.1.10	Ensure usb-storage kernel module is not available (Automated)	☐	☐
1.1.1.11	Ensure unused filesystems kernel modules are not available (Manual)	☐	☐
1.1.2	**Configure Filesystem Partitions**		
1.1.2.1	**Configure /tmp**		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.2.1.1	Ensure /tmp is tmpfs or a separate partition (Automated)	☐	☐
1.1.2.1.2	Ensure nodev option set on /tmp partition (Automated)	☐	☐
1.1.2.1.3	Ensure nosuid option set on /tmp partition (Automated)	☐	☐
1.1.2.1.4	Ensure noexec option set on /tmp partition (Automated)	☐	☐
1.1.2.2	**Configure /dev/shm**		
1.1.2.2.1	Ensure /dev/shm is tmpfs (Automated)	☐	☐
1.1.2.2.2	Ensure nodev option set on /dev/shm partition (Automated)	☐	☐
1.1.2.2.3	Ensure nosuid option set on /dev/shm partition (Automated)	☐	☐
1.1.2.2.4	Ensure noexec option set on /dev/shm partition (Automated)	☐	☐
1.1.2.3	**Configure /home**		
1.1.2.3.1	Ensure separate partition exists for /home (Automated)	☐	☐
1.1.2.3.2	Ensure nodev option set on /home partition (Automated)	☐	☐
1.1.2.3.3	Ensure nosuid option set on /home partition (Automated)	☐	☐
1.1.2.4	**Configure /var**		
1.1.2.4.1	Ensure separate partition exists for /var (Automated)	☐	☐
1.1.2.4.2	Ensure nodev option set on /var partition (Automated)	☐	☐
1.1.2.4.3	Ensure nosuid option set on /var partition (Automated)	☐	☐
1.1.2.5	**Configure /var/tmp**		
1.1.2.5.1	Ensure separate partition exists for /var/tmp (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.1.2.5.2	Ensure nodev option set on /var/tmp partition (Automated)	☐	☐
1.1.2.5.3	Ensure nosuid option set on /var/tmp partition (Automated)	☐	☐
1.1.2.5.4	Ensure noexec option set on /var/tmp partition (Automated)	☐	☐
1.1.2.6	**Configure /var/log**		
1.1.2.6.1	Ensure separate partition exists for /var/log (Automated)	☐	☐
1.1.2.6.2	Ensure nodev option set on /var/log partition (Automated)	☐	☐
1.1.2.6.3	Ensure nosuid option set on /var/log partition (Automated)	☐	☐
1.1.2.6.4	Ensure noexec option set on /var/log partition (Automated)	☐	☐
1.1.2.7	**Configure /var/log/audit**		
1.1.2.7.1	Ensure separate partition exists for /var/log/audit (Automated)	☐	☐
1.1.2.7.2	Ensure nodev option set on /var/log/audit partition (Automated)	☐	☐
1.1.2.7.3	Ensure nosuid option set on /var/log/audit partition (Automated)	☐	☐
1.1.2.7.4	Ensure noexec option set on /var/log/audit partition (Automated)	☐	☐
1.2	**Package Management**		
1.2.1	**Configure Package Repositories**		
1.2.1.1	Ensure GPG keys are configured (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.2.1.2	Ensure gpgcheck is configured (Automated)	☐	☐
1.2.1.3	Ensure repo_gpgcheck is globally activated (Manual)	☐	☐
1.2.1.4	Ensure package manager repositories are configured (Manual)	☐	☐
1.2.1.5	Ensure weak dependencies are configured (Automated)	☐	☐
1.2.2	**Configure Package Updates**		
1.2.2.1	Ensure updates, patches, and additional security software are installed (Manual)	☐	☐
1.3	**Mandatory Access Control**		
1.3.1	**Configure SELinux**		
1.3.1.1	Ensure SELinux is installed (Automated)	☐	☐
1.3.1.2	Ensure SELinux policy is configured (Automated)	☐	☐
1.3.1.3	Ensure the SELinux mode is not disabled (Automated)	☐	☐
1.3.1.4	Ensure no unconfined services exist (Manual)	☐	☐
1.3.1.5	Ensure the MCS Translation Service (mcstrans) is not installed (Automated)	☐	☐
1.3.1.6	Ensure SETroubleshoot is not installed (Automated)	☐	☐
1.4	**Configure Bootloader**		
1.4.1	Ensure access to bootloader config is configured (Automated)	☐	☐
1.5	**Configure Additional Process Hardening**		
1.5.1	Ensure core file size is configured (Automated)	☐	☐
1.5.2	Ensure fs.protected_hardlinks is configured (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.5.3	Ensure fs.protected_symlinks is configured (Automated)	☐	☐
1.5.4	Ensure fs.suid_dumpable is configured (Automated)	☐	☐
1.5.5	Ensure kernel.dmesg_restrict is configured (Automated)	☐	☐
1.5.6	Ensure kernel.kptr_restrict is configured (Automated)	☐	☐
1.5.7	Ensure kernel.randomize_va_space is configured (Automated)	☐	☐
1.5.8	Ensure systemd-coredump ProcessSizeMax is configured (Automated)	☐	☐
1.5.9	Ensure systemd-coredump Storage is configured (Automated)	☐	☐
1.6	**Configure system wide crypto policy**		
1.6.1	Ensure system wide crypto policy is not set to legacy (Automated)	☐	☐
1.6.2	Ensure system wide crypto policy disables sha1 hash and signature support (Automated)	☐	☐
1.6.3	Ensure system wide crypto policy macs are configured (Automated)	☐	☐
1.6.4	Ensure system wide crypto policy disables cbc for ssh (Automated)	☐	☐
1.6.5	Ensure system wide crypto policy disables chacha20-poly1305 for ssh (Manual)	☐	☐
1.6.6	Ensure system wide crypto policy disables EtM for ssh (Manual)	☐	☐
1.7	**Configure Command Line Warning Banners**		
1.7.1	Ensure /etc/motd is configured (Automated)	☐	☐
1.7.2	Ensure /etc/issue is configured (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.7.3	Ensure /etc/issue.net is configured (Automated)	☐	☐
1.7.4	Ensure access to /etc/motd is configured (Automated)	☐	☐
1.7.5	Ensure access to /etc/issue is configured (Automated)	☐	☐
1.7.6	Ensure access to /etc/issue.net is configured (Automated)	☐	☐
1.8	**Configure GNOME Display Manager**		
1.8.1	Ensure GDM login banner is configured (Automated)	☐	☐
1.8.2	Ensure GDM disable-user-list is configured (Automated)	☐	☐
1.8.3	Ensure GDM screen lock is configured (Automated)	☐	☐
1.8.4	Ensure GDM automount is configured (Automated)	☐	☐
1.8.5	Ensure GDM autorun-never is configured (Automated)	☐	☐
1.8.6	Ensure XDMCP is not enabled (Automated)	☐	☐
1.8.7	Ensure Xwayland is configured (Automated)	☐	☐
2	**Services**		
2.1	**Configure Server Services**		
2.1.1	Ensure autofs services are not in use (Automated)	☐	☐
2.1.2	Ensure avahi daemon services are not in use (Automated)	☐	☐
2.1.3	Ensure cockpit web services are not in use (Automated)	☐	☐
2.1.4	Ensure dhcp server services are not in use (Automated)	☐	☐
2.1.5	Ensure dns server services are not in use (Automated)	☐	☐
2.1.6	Ensure dnsmasq services are not in use (Automated)	☐	☐
2.1.7	Ensure ftp server services are not in use (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.1.8	Ensure message access server services are not in use (Automated)	☐	☐
2.1.9	Ensure network file system services are not in use (Automated)	☐	☐
2.1.10	Ensure nis server services are not in use (Automated)	☐	☐
2.1.11	Ensure print server services are not in use (Automated)	☐	☐
2.1.12	Ensure rpcbind services are not in use (Automated)	☐	☐
2.1.13	Ensure rsync services are not in use (Automated)	☐	☐
2.1.14	Ensure samba file server services are not in use (Automated)	☐	☐
2.1.15	Ensure snmp services are not in use (Automated)	☐	☐
2.1.16	Ensure telnet server services are not in use (Automated)	☐	☐
2.1.17	Ensure tftp server services are not in use (Automated)	☐	☐
2.1.18	Ensure web proxy server services are not in use (Automated)	☐	☐
2.1.19	Ensure web server services are not in use (Automated)	☐	☐
2.1.20	Ensure xinetd services are not in use (Automated)	☐	☐
2.1.21	Ensure GNOME Display Manager is not installed (Automated)	☐	☐
2.1.22	Ensure X window server services are not in use (Automated)	☐	☐
2.1.23	Ensure mail transfer agents are configured for local-only mode (Automated)	☐	☐
2.1.24	Ensure only approved services are listening on a network interface (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.2	**Configure Client Services**		
2.2.1	Ensure ftp client is not installed (Automated)	☐	☐
2.2.2	Ensure ldap client is not installed (Automated)	☐	☐
2.2.3	Ensure nis client is not installed (Automated)	☐	☐
2.2.4	Ensure telnet client is not installed (Automated)	☐	☐
2.2.5	Ensure tftp client is not installed (Automated)	☐	☐
2.3	**Configure Time Synchronization**		
2.3.1	Ensure time synchronization is in use (Automated)	☐	☐
2.3.2	Ensure chrony is configured (Automated)	☐	☐
2.3.3	Ensure chrony is not run as the root user (Automated)	☐	☐
2.4	**Job Schedulers**		
2.4.1	**Configure cron**		
2.4.1.1	Ensure cron daemon is enabled and active (Automated)	☐	☐
2.4.1.2	Ensure access to /etc/crontab is configured (Automated)	☐	☐
2.4.1.3	Ensure access to /etc/cron.hourly is configured (Automated)	☐	☐
2.4.1.4	Ensure access to /etc/cron.daily is configured (Automated)	☐	☐
2.4.1.5	Ensure access to /etc/cron.weekly is configured (Automated)	☐	☐
2.4.1.6	Ensure access to /etc/cron.monthly is configured (Automated)	☐	☐
2.4.1.7	Ensure access to /etc/cron.yearly is configured (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.4.1.8	Ensure access to /etc/cron.d is configured (Automated)	☐	☐
2.4.1.9	Ensure access to crontab is configured (Automated)	☐	☐
2.4.2	**Configure at**		
2.4.2.1	Ensure access to at is configured (Automated)	☐	☐
3	**Network**		
3.1	**Configure Network Devices**		
3.1.1	Ensure IPv6 status is identified (Manual)	☐	☐
3.1.2	Ensure wireless interfaces are not available (Automated)	☐	☐
3.1.3	Ensure bluetooth services are not in use (Automated)	☐	☐
3.2	**Configure Network Kernel Modules**		
3.2.1	Ensure atm kernel module is not available (Automated)	☐	☐
3.2.2	Ensure can kernel module is not available (Automated)	☐	☐
3.2.3	Ensure dccp kernel module is not available (Automated)	☐	☐
3.2.4	Ensure rds kernel module is not available (Automated)	☐	☐
3.2.5	Ensure sctp kernel module is not available (Automated)	☐	☐
3.2.6	Ensure tipc kernel module is not available (Automated)	☐	☐
3.3	**Configure Network Kernel Parameters**		
3.3.1	**Configure IPv4 parameters**		
3.3.1.1	Ensure net.ipv4.ip_forward is configured (Automated)	☐	☐
3.3.1.2	Ensure net.ipv4.conf.all.forwarding is configured (Automated)	☐	☐
3.3.1.3	Ensure net.ipv4.conf.default.forwarding is configured (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
3.3.1.4	Ensure net.ipv4.conf.all.send_redirects is configured (Automated)	☐	☐
3.3.1.5	Ensure net.ipv4.conf.default.send_redirects is configured (Automated)	☐	☐
3.3.1.6	Ensure net.ipv4.icmp_ignore_bogus_error_responses is configured (Automated)	☐	☐
3.3.1.7	Ensure net.ipv4.icmp_echo_ignore_broadcasts is configured (Automated)	☐	☐
3.3.1.8	Ensure net.ipv4.conf.all.accept_redirects is configured (Automated)	☐	☐
3.3.1.9	Ensure net.ipv4.conf.default.accept_redirects is configured (Automated)	☐	☐
3.3.1.10	Ensure net.ipv4.conf.all.secure_redirects is configured (Automated)	☐	☐
3.3.1.11	Ensure net.ipv4.conf.default.secure_redirects is configured (Automated)	☐	☐
3.3.1.12	Ensure net.ipv4.conf.all.rp_filter is configured (Automated)	☐	☐
3.3.1.13	Ensure net.ipv4.conf.default.rp_filter is configured (Automated)	☐	☐
3.3.1.14	Ensure net.ipv4.conf.all.accept_source_route is configured (Automated)	☐	☐
3.3.1.15	Ensure net.ipv4.conf.default.accept_source_route is configured (Automated)	☐	☐
3.3.1.16	Ensure net.ipv4.conf.all.log_martians is configured (Automated)	☐	☐
3.3.1.17	Ensure net.ipv4.conf.default.log_martians is configured (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
3.3.1.18	Ensure net.ipv4.tcp_syncookies is configured (Automated)	☐	☐
3.3.2	**Configure IPv6 parameters**		
3.3.2.1	Ensure net.ipv6.conf.all.forwarding is configured (Automated)	☐	☐
3.3.2.2	Ensure net.ipv6.conf.default.forwarding is configured (Automated)	☐	☐
3.3.2.3	Ensure net.ipv6.conf.all.accept_redirects is configured (Automated)	☐	☐
3.3.2.4	Ensure net.ipv6.conf.default.accept_redirects is configured (Automated)	☐	☐
3.3.2.5	Ensure net.ipv6.conf.all.accept_source_route is configured (Automated)	☐	☐
3.3.2.6	Ensure net.ipv6.conf.default.accept_source_route is configured (Automated)	☐	☐
3.3.2.7	Ensure net.ipv6.conf.all.accept_ra is configured (Automated)	☐	☐
3.3.2.8	Ensure net.ipv6.conf.default.accept_ra is configured (Automated)	☐	☐
4	**Host Based Firewall**		
4.1	**Configure firewalld**		
4.1.1	Ensure firewalld is installed (Automated)	☐	☐
4.1.2	Ensure firewalld backend is configured (Automated)	☐	☐
4.1.3	Ensure firewalld.service is configured (Automated)	☐	☐
4.1.4	Ensure firewalld active zone target is configured (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
4.1.5	Ensure firewalld loopback traffic is configured (Manual)	☐	☐
4.1.6	Ensure firewalld loopback source address traffic is configured (Manual)	☐	☐
4.1.7	Ensure firewalld services and ports are configured (Manual)	☐	☐
5	**Access Control**		
5.1	**Configure SSH Server**		
5.1.1	Ensure sshd crypto_policy is not set (Automated)	☐	☐
5.1.2	Ensure access to /etc/ssh/sshd_config is configured (Automated)	☐	☐
5.1.3	Ensure access to /etc/sysconfig/sshd is configured (Automated)	☐	☐
5.1.4	Ensure access to SSH private host key files is configured (Automated)	☐	☐
5.1.5	Ensure access to SSH public host key files is configured (Automated)	☐	☐
5.1.6	Ensure sshd access is configured (Automated)	☐	☐
5.1.7	Ensure sshd Banner is configured (Automated)	☐	☐
5.1.8	Ensure sshd Ciphers are configured (Automated)	☐	☐
5.1.9	Ensure sshd ClientAliveInterval and ClientAliveCountMax are configured (Automated)	☐	☐
5.1.10	Ensure sshd DisableForwarding is enabled (Automated)	☐	☐
5.1.11	Ensure sshd GSSAPIAuthentication is disabled (Automated)	☐	☐
5.1.12	Ensure sshd HostbasedAuthentication is disabled (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
5.1.13	Ensure sshd IgnoreRhosts is enabled (Automated)	☐	☐
5.1.14	Ensure sshd KexAlgorithms is configured (Automated)	☐	☐
5.1.15	Ensure sshd LoginGraceTime is configured (Automated)	☐	☐
5.1.16	Ensure sshd LogLevel is configured (Automated)	☐	☐
5.1.17	Ensure sshd MACs are configured (Automated)	☐	☐
5.1.18	Ensure sshd MaxAuthTries is configured (Automated)	☐	☐
5.1.19	Ensure sshd MaxSessions is configured (Automated)	☐	☐
5.1.20	Ensure sshd MaxStartups is configured (Automated)	☐	☐
5.1.21	Ensure sshd PermitEmptyPasswords is disabled (Automated)	☐	☐
5.1.22	Ensure sshd PermitRootLogin is disabled (Automated)	☐	☐
5.1.23	Ensure sshd PermitUserEnvironment is disabled (Automated)	☐	☐
5.1.24	Ensure sshd UsePAM is enabled (Automated)	☐	☐
5.2	**Configure privilege escalation**		
5.2.1	Ensure sudo is installed (Automated)	☐	☐
5.2.2	Ensure sudo commands use pty (Automated)	☐	☐
5.2.3	Ensure sudo log file exists (Automated)	☐	☐
5.2.4	Ensure users must provide password for escalation (Automated)	☐	☐
5.2.5	Ensure re-authentication for privilege escalation is not disabled globally (Automated)	☐	☐
5.2.6	Ensure sudo timestamp_timeout is configured (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
5.2.7	Ensure access to the su command is restricted (Automated)	☐	☐
5.3	**Pluggable Authentication Modules**		
5.3.1	**Configure PAM software packages**		
5.3.1.1	Ensure latest version of pam is installed (Automated)	☐	☐
5.3.1.2	Ensure latest version of authselect is installed (Automated)	☐	☐
5.3.2	**Configure authselect**		
5.3.2.1	Ensure active authselect profile includes pam modules (Automated)	☐	☐
5.3.2.2	Ensure pam_faillock module is enabled (Automated)	☐	☐
5.3.2.3	Ensure pam_pwquality module is enabled (Automated)	☐	☐
5.3.2.4	Ensure pam_pwhistory module is enabled (Automated)	☐	☐
5.3.2.5	Ensure pam_unix module is enabled (Automated)	☐	☐
5.3.3	**Configure PAM Arguments**		
5.3.3.1	**Configure pam_faillock module**		
5.3.3.1.1	Ensure password failed attempts lockout is configured (Automated)	☐	☐
5.3.3.1.2	Ensure password unlock time is configured (Automated)	☐	☐
5.3.3.1.3	Ensure password failed attempts lockout includes root account (Automated)	☐	☐
5.3.3.2	**Configure pam_pwquality module**		
5.3.3.2.1	Ensure password number of changed characters is configured (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
5.3.3.2.2	Ensure password length is configured (Automated)	☐	☐
5.3.3.2.3	Ensure password complexity is configured (Manual)	☐	☐
5.3.3.2.4	Ensure password same consecutive characters is configured (Automated)	☐	☐
5.3.3.2.5	Ensure password maximum sequential characters is configured (Automated)	☐	☐
5.3.3.2.6	Ensure password dictionary check is enabled (Automated)	☐	☐
5.3.3.2.7	Ensure password quality is enforced for the root user (Automated)	☐	☐
5.3.3.3	**Configure pam_pwhistory module**		
5.3.3.3.1	Ensure password history remember is configured (Automated)	☐	☐
5.3.3.3.2	Ensure password history is enforced for the root user (Automated)	☐	☐
5.3.3.3.3	Ensure pam_pwhistory includes use_authtok (Automated)	☐	☐
5.3.3.4	**Configure pam_unix module**		
5.3.3.4.1	Ensure pam_unix does not include nullok (Automated)	☐	☐
5.3.3.4.2	Ensure pam_unix does not include remember (Automated)	☐	☐
5.3.3.4.3	Ensure pam_unix includes a strong password hashing algorithm (Automated)	☐	☐
5.3.3.4.4	Ensure pam_unix includes use_authtok (Automated)	☐	☐
5.4	**User Accounts and Environment**		
5.4.1	**Configure shadow password suite parameters**		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
5.4.1.1	Ensure password expiration is configured (Automated)	☐	☐
5.4.1.2	Ensure minimum password days is configured (Manual)	☐	☐
5.4.1.3	Ensure password expiration warning days is configured (Automated)	☐	☐
5.4.1.4	Ensure strong password hashing algorithm is configured (Automated)	☐	☐
5.4.1.5	Ensure inactive password lock is configured (Automated)	☐	☐
5.4.1.6	Ensure all users last password change date is in the past (Automated)	☐	☐
5.4.2	**Configure root and system accounts and environment**		
5.4.2.1	Ensure root is the only UID 0 account (Automated)	☐	☐
5.4.2.2	Ensure root is the only GID 0 account (Automated)	☐	☐
5.4.2.3	Ensure group root is the only GID 0 group (Automated)	☐	☐
5.4.2.4	Ensure root account access is controlled (Automated)	☐	☐
5.4.2.5	Ensure root path integrity (Automated)	☐	☐
5.4.2.6	Ensure root user umask is configured (Automated)	☐	☐
5.4.2.7	Ensure system accounts do not have a valid login shell (Automated)	☐	☐
5.4.2.8	Ensure accounts without a valid login shell are locked (Automated)	☐	☐
5.4.3	**Configure user default environment**		
5.4.3.1	Ensure nologin is not listed in /etc/shells (Automated)	☐	☐
5.4.3.2	Ensure default user shell timeout is configured (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
5.4.3.3	Ensure default user umask is configured (Automated)	☐	☐
6	**Logging and Auditing**		
6.1	**Configure Integrity Checking**		
6.1.1	Ensure AIDE is installed (Automated)	☐	☐
6.1.2	Ensure filesystem integrity is regularly checked (Automated)	☐	☐
6.1.3	Ensure cryptographic mechanisms are used to protect the integrity of audit tools (Automated)	☐	☐
6.2	**System Logging**		
6.2.1	**Configure journald**		
6.2.1.1	**Configure systemd-journald service**		
6.2.1.1.1	Ensure journald service is active (Automated)	☐	☐
6.2.1.1.2	Ensure journald log file access is configured (Manual)	☐	☐
6.2.1.1.3	Ensure journald log file rotation is configured (Manual)	☐	☐
6.2.1.1.4	Ensure journald ForwardToSyslog is disabled (Automated)	☐	☐
6.2.1.1.5	Ensure journald Storage is configured (Automated)	☐	☐
6.2.1.1.6	Ensure journald Compress is configured (Automated)	☐	☐
6.2.1.2	**Configure systemd-journal-remote**		
6.2.1.2.1	Ensure systemd-journal-remote is installed (Automated)	☐	☐
6.2.1.2.2	Ensure systemd-journal-remote authentication is configured (Manual)	☐	☐
6.2.1.2.3	Ensure systemd-journal-upload is enabled and active (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
6.2.1.2.4	Ensure systemd-journal-remote service is not in use (Automated)	☐	☐
6.2.2	**Configure rsyslog**		
6.2.2.1	Ensure rsyslog is installed (Automated)	☐	☐
6.2.2.2	Ensure rsyslog service is enabled and active (Automated)	☐	☐
6.2.2.3	Ensure journald is configured to send logs to rsyslog (Automated)	☐	☐
6.2.2.4	Ensure rsyslog log file creation mode is configured (Automated)	☐	☐
6.2.2.5	Ensure rsyslog logging is configured (Manual)	☐	☐
6.2.2.6	Ensure rsyslog is configured to send logs to a remote log host (Manual)	☐	☐
6.2.2.7	Ensure rsyslog is not configured to receive logs from a remote client (Automated)	☐	☐
6.2.2.8	Ensure logrotate is configured (Manual)	☐	☐
6.2.3	**Configure Logfiles**		
6.2.3.1	Ensure access to all logfiles has been configured (Automated)	☐	☐
6.3	**System Auditing**		
6.3.1	**Configure auditd Service**		
6.3.1.1	Ensure auditd packages are installed (Automated)	☐	☐
6.3.1.2	Ensure auditing for processes that start prior to auditd is enabled (Automated)	☐	☐
6.3.1.3	Ensure audit_backlog_limit is configured (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
6.3.1.4	Ensure auditd service is enabled and active (Automated)	☐	☐
6.3.2	**Configure Data Retention**		
6.3.2.1	Ensure audit log storage size is configured (Automated)	☐	☐
6.3.2.2	Ensure audit logs are not automatically deleted (Automated)	☐	☐
6.3.2.3	Ensure system is disabled when audit logs are full (Automated)	☐	☐
6.3.2.4	Ensure system warns when audit logs are low on space (Automated)	☐	☐
6.3.3	**Configure auditd Rules**		
6.3.3.1	Ensure changes to system administration scope (sudoers) is collected (Automated)	☐	☐
6.3.3.2	Ensure actions as another user are always logged (Automated)	☐	☐
6.3.3.3	Ensure events that modify the sudo log file are collected (Automated)	☐	☐
6.3.3.4	Ensure events that modify date and time information are collected (Automated)	☐	☐
6.3.3.5	Ensure events that modify the system's network environment are collected (Automated)	☐	☐
6.3.3.6	Ensure use of privileged commands are collected (Automated)	☐	☐
6.3.3.7	Ensure unsuccessful file access attempts are collected (Automated)	☐	☐
6.3.3.8	Ensure events that modify user/group information are collected (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
6.3.3.9	Ensure discretionary access control permission modification events are collected (Automated)	☐	☐
6.3.3.10	Ensure successful file system mounts are collected (Automated)	☐	☐
6.3.3.11	Ensure session initiation information is collected (Automated)	☐	☐
6.3.3.12	Ensure login and logout events are collected (Automated)	☐	☐
6.3.3.13	Ensure file deletion events by users are collected (Automated)	☐	☐
6.3.3.14	Ensure events that modify the system's Mandatory Access Controls are collected (Automated)	☐	☐
6.3.3.15	Ensure successful and unsuccessful attempts to use the chcon command are collected (Automated)	☐	☐
6.3.3.16	Ensure successful and unsuccessful attempts to use the setfacl command are collected (Automated)	☐	☐
6.3.3.17	Ensure successful and unsuccessful attempts to use the chacl command are collected (Automated)	☐	☐
6.3.3.18	Ensure successful and unsuccessful attempts to use the usermod command are collected (Automated)	☐	☐
6.3.3.19	Ensure kernel module loading unloading and modification is collected (Automated)	☐	☐
6.3.3.20	Ensure the audit configuration is loaded regardless of errors (Automated)	☐	☐
6.3.3.21	Ensure the audit configuration is immutable (Automated)	☐	☐
6.3.3.22	Ensure the running and on disk configuration is the same (Manual)	☐	☐
6.3.4	**Configure auditd File Access**		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
6.3.4.1	Ensure the audit log file directory mode is configured (Automated)	☐	☐
6.3.4.2	Ensure audit log files mode is configured (Automated)	☐	☐
6.3.4.3	Ensure audit log files owner is configured (Automated)	☐	☐
6.3.4.4	Ensure audit log files group owner is configured (Automated)	☐	☐
6.3.4.5	Ensure audit configuration files mode is configured (Automated)	☐	☐
6.3.4.6	Ensure audit configuration files owner is configured (Automated)	☐	☐
6.3.4.7	Ensure audit configuration files group owner is configured (Automated)	☐	☐
6.3.4.8	Ensure audit tools mode is configured (Automated)	☐	☐
6.3.4.9	Ensure audit tools owner is configured (Automated)	☐	☐
6.3.4.10	Ensure audit tools group owner is configured (Automated)	☐	☐
7	**System Maintenance**		
7.1	**Configure system file and directory access**		
7.1.1	Ensure access to /etc/passwd is configured (Automated)	☐	☐
7.1.2	Ensure access to /etc/passwd- is configured (Automated)	☐	☐
7.1.3	Ensure access to /etc/group is configured (Automated)	☐	☐
7.1.4	Ensure access to /etc/group- is configured (Automated)	☐	☐
7.1.5	Ensure access to /etc/shadow is configured (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
7.1.6	Ensure access to /etc/shadow- is configured (Automated)	☐	☐
7.1.7	Ensure access to /etc/gshadow is configured (Automated)	☐	☐
7.1.8	Ensure access to /etc/gshadow- is configured (Automated)	☐	☐
7.1.9	Ensure access to /etc/shells is configured (Automated)	☐	☐
7.1.10	Ensure access to /etc/security/opasswd is configured (Automated)	☐	☐
7.1.11	Ensure world writable files and directories are secured (Automated)	☐	☐
7.1.12	Ensure no files or directories without an owner and a group exist (Automated)	☐	☐
7.1.13	Ensure SUID and SGID files are reviewed (Manual)	☐	☐
7.2	**Local User and Group Settings**		
7.2.1	Ensure accounts in /etc/passwd use shadowed passwords (Automated)	☐	☐
7.2.2	Ensure /etc/shadow password fields are not empty (Automated)	☐	☐
7.2.3	Ensure all groups in /etc/passwd exist in /etc/group (Automated)	☐	☐
7.2.4	Ensure no duplicate UIDs exist (Automated)	☐	☐
7.2.5	Ensure no duplicate GIDs exist (Automated)	☐	☐
7.2.6	Ensure no duplicate user names exist (Automated)	☐	☐
7.2.7	Ensure no duplicate group names exist (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
7.2.8	Ensure local interactive user home directories are configured (Automated)	☐	☐
7.2.9	Ensure local interactive user dot files access is configured (Automated)	☐	☐

Appendix: CIS Controls v7 IG 1 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1.2.1.1	Ensure /tmp is tmpfs or a separate partition	☐	☐
1.1.2.1.2	Ensure nodev option set on /tmp partition	☐	☐
1.1.2.1.3	Ensure nosuid option set on /tmp partition	☐	☐
1.1.2.1.4	Ensure noexec option set on /tmp partition	☐	☐
1.1.2.2.1	Ensure /dev/shm is tmpfs	☐	☐
1.1.2.2.2	Ensure nodev option set on /dev/shm partition	☐	☐
1.1.2.2.3	Ensure nosuid option set on /dev/shm partition	☐	☐
1.1.2.2.4	Ensure noexec option set on /dev/shm partition	☐	☐
1.1.2.3.1	Ensure separate partition exists for /home	☐	☐
1.1.2.3.2	Ensure nodev option set on /home partition	☐	☐
1.1.2.3.3	Ensure nosuid option set on /home partition	☐	☐
1.1.2.4.1	Ensure separate partition exists for /var	☐	☐
1.1.2.4.2	Ensure nodev option set on /var partition	☐	☐
1.1.2.4.3	Ensure nosuid option set on /var partition	☐	☐
1.1.2.5.1	Ensure separate partition exists for /var/tmp	☐	☐
1.1.2.5.2	Ensure nodev option set on /var/tmp partition	☐	☐
1.1.2.5.3	Ensure nosuid option set on /var/tmp partition	☐	☐
1.1.2.5.4	Ensure noexec option set on /var/tmp partition	☐	☐
1.1.2.6.2	Ensure nodev option set on /var/log partition	☐	☐
1.1.2.6.3	Ensure nosuid option set on /var/log partition	☐	☐
1.1.2.6.4	Ensure noexec option set on /var/log partition	☐	☐
1.1.2.7.2	Ensure nodev option set on /var/log/audit partition	☐	☐
1.1.2.7.3	Ensure nosuid option set on /var/log/audit partition	☐	☐
1.1.2.7.4	Ensure noexec option set on /var/log/audit partition	☐	☐
1.2.1.1	Ensure GPG keys are configured	☐	☐
1.2.1.2	Ensure gpgcheck is configured	☐	☐
1.2.1.3	Ensure repo_gpgcheck is globally activated	☐	☐

Recommendation		Set Correctly	
		Yes	No
1.2.1.4	Ensure package manager repositories are configured	☐	☐
1.2.2.1	Ensure updates, patches, and additional security software are installed	☐	☐
1.3.1.1	Ensure SELinux is installed	☐	☐
1.3.1.2	Ensure SELinux policy is configured	☐	☐
1.3.1.3	Ensure the SELinux mode is not disabled	☐	☐
1.3.1.4	Ensure no unconfined services exist	☐	☐
1.3.1.6	Ensure SETroubleshoot is not installed	☐	☐
1.4.1	Ensure access to bootloader config is configured	☐	☐
1.5.5	Ensure kernel.dmesg_restrict is configured	☐	☐
1.7.4	Ensure access to /etc/motd is configured	☐	☐
1.7.5	Ensure access to /etc/issue is configured	☐	☐
1.7.6	Ensure access to /etc/issue.net is configured	☐	☐
1.8.3	Ensure GDM screen lock is configured	☐	☐
1.8.4	Ensure GDM automount is configured	☐	☐
1.8.5	Ensure GDM autorun-never is configured	☐	☐
2.1.1	Ensure autofs services are not in use	☐	☐
2.1.16	Ensure telnet server services are not in use	☐	☐
2.2.2	Ensure ldap client is not installed	☐	☐
2.2.4	Ensure telnet client is not installed	☐	☐
2.4.1.2	Ensure access to /etc/crontab is configured	☐	☐
2.4.1.3	Ensure access to /etc/cron.hourly is configured	☐	☐
2.4.1.4	Ensure access to /etc/cron.daily is configured	☐	☐
2.4.1.5	Ensure access to /etc/cron.weekly is configured	☐	☐
2.4.1.6	Ensure access to /etc/cron.monthly is configured	☐	☐
2.4.1.8	Ensure access to /etc/cron.d is configured	☐	☐
2.4.1.9	Ensure access to crontab is configured	☐	☐
2.4.2.1	Ensure access to at is configured	☐	☐
3.3.1.16	Ensure net.ipv4.conf.all.log_martians is configured	☐	☐
3.3.1.17	Ensure net.ipv4.conf.default.log_martians is configured	☐	☐
4.1.1	Ensure firewalld is installed	☐	☐

Recommendation		Set Correctly	
		Yes	No
4.1.2	Ensure firewalld backend is configured	☐	☐
4.1.3	Ensure firewalld.service is configured	☐	☐
4.1.4	Ensure firewalld active zone target is configured	☐	☐
4.1.5	Ensure firewalld loopback traffic is configured	☐	☐
4.1.6	Ensure firewalld loopback source address traffic is configured	☐	☐
4.1.7	Ensure firewalld services and ports are configured	☐	☐
5.1.2	Ensure access to /etc/ssh/sshd_config is configured	☐	☐
5.1.3	Ensure access to /etc/sysconfig/sshd is configured	☐	☐
5.1.4	Ensure access to SSH private host key files is configured	☐	☐
5.1.5	Ensure access to SSH public host key files is configured	☐	☐
5.1.6	Ensure sshd access is configured	☐	☐
5.1.16	Ensure sshd LogLevel is configured	☐	☐
5.1.22	Ensure sshd PermitRootLogin is disabled	☐	☐
5.2.1	Ensure sudo is installed	☐	☐
5.2.2	Ensure sudo commands use pty	☐	☐
5.2.4	Ensure users must provide password for escalation	☐	☐
5.2.5	Ensure re-authentication for privilege escalation is not disabled globally	☐	☐
5.2.6	Ensure sudo timestamp_timeout is configured	☐	☐
5.2.7	Ensure access to the su command is restricted	☐	☐
5.4.2.1	Ensure root is the only UID 0 account	☐	☐
5.4.2.2	Ensure root is the only GID 0 account	☐	☐
5.4.2.3	Ensure group root is the only GID 0 group	☐	☐
5.4.2.4	Ensure root account access is controlled	☐	☐
5.4.2.6	Ensure root user umask is configured	☐	☐
5.4.2.7	Ensure system accounts do not have a valid login shell	☐	☐
5.4.2.8	Ensure accounts without a valid login shell are locked	☐	☐
5.4.3.2	Ensure default user shell timeout is configured	☐	☐
5.4.3.3	Ensure default user umask is configured	☐	☐
6.2.1.1.1	Ensure journald service is active	☐	☐
6.2.1.1.2	Ensure journald log file access is configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
6.2.1.1.3	Ensure journald log file rotation is configured	☐	☐
6.2.1.1.5	Ensure journald Storage is configured	☐	☐
6.2.1.1.6	Ensure journald Compress is configured	☐	☐
6.2.1.2.1	Ensure systemd-journal-remote is installed	☐	☐
6.2.1.2.2	Ensure systemd-journal-remote authentication is configured	☐	☐
6.2.1.2.3	Ensure systemd-journal-upload is enabled and active	☐	☐
6.2.2.1	Ensure rsyslog is installed	☐	☐
6.2.2.2	Ensure rsyslog service is enabled and active	☐	☐
6.2.2.3	Ensure journald is configured to send logs to rsyslog	☐	☐
6.2.2.4	Ensure rsyslog log file creation mode is configured	☐	☐
6.2.2.5	Ensure rsyslog logging is configured	☐	☐
6.2.2.6	Ensure rsyslog is configured to send logs to a remote log host	☐	☐
6.2.3.1	Ensure access to all logfiles has been configured	☐	☐
6.3.1.1	Ensure auditd packages are installed	☐	☐
6.3.1.2	Ensure auditing for processes that start prior to auditd is enabled	☐	☐
6.3.1.3	Ensure audit_backlog_limit is configured	☐	☐
6.3.1.4	Ensure auditd service is enabled and active	☐	☐
6.3.3.6	Ensure use of privileged commands are collected	☐	☐
6.3.3.12	Ensure login and logout events are collected	☐	☐
6.3.3.13	Ensure file deletion events by users are collected	☐	☐
6.3.3.15	Ensure successful and unsuccessful attempts to use the chcon command are collected	☐	☐
6.3.3.16	Ensure successful and unsuccessful attempts to use the setfacl command are collected	☐	☐
6.3.3.17	Ensure successful and unsuccessful attempts to use the chacl command are collected	☐	☐
6.3.3.18	Ensure successful and unsuccessful attempts to use the usermod command are collected	☐	☐
6.3.3.19	Ensure kernel module loading unloading and modification is collected	☐	☐

Recommendation		Set Correctly	
		Yes	No
6.3.3.20	Ensure the audit configuration is loaded regardless of errors	☐	☐
6.3.3.21	Ensure the audit configuration is immutable	☐	☐
6.3.4.1	Ensure the audit log file directory mode is configured	☐	☐
6.3.4.2	Ensure audit log files mode is configured	☐	☐
6.3.4.3	Ensure audit log files owner is configured	☐	☐
6.3.4.4	Ensure audit log files group owner is configured	☐	☐
6.3.4.5	Ensure audit configuration files mode is configured	☐	☐
6.3.4.6	Ensure audit configuration files owner is configured	☐	☐
6.3.4.7	Ensure audit configuration files group owner is configured	☐	☐
6.3.4.8	Ensure audit tools mode is configured	☐	☐
6.3.4.9	Ensure audit tools owner is configured	☐	☐
6.3.4.10	Ensure audit tools group owner is configured	☐	☐
7.1.1	Ensure access to /etc/passwd is configured	☐	☐
7.1.2	Ensure access to /etc/passwd- is configured	☐	☐
7.1.3	Ensure access to /etc/group is configured	☐	☐
7.1.4	Ensure access to /etc/group- is configured	☐	☐
7.1.5	Ensure access to /etc/shadow is configured	☐	☐
7.1.6	Ensure access to /etc/shadow- is configured	☐	☐
7.1.9	Ensure access to /etc/shells is configured	☐	☐
7.1.10	Ensure access to /etc/security/opasswd is configured	☐	☐
7.1.11	Ensure world writable files and directories are secured	☐	☐
7.1.12	Ensure no files or directories without an owner and a group exist	☐	☐
7.1.13	Ensure SUID and SGID files are reviewed	☐	☐
7.2.3	Ensure all groups in /etc/passwd exist in /etc/group	☐	☐
7.2.8	Ensure local interactive user home directories are configured	☐	☐
7.2.9	Ensure local interactive user dot files access is configured	☐	☐

Appendix: CIS Controls v7 IG 2 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1.1.1	Ensure cramfs kernel module is not available	☐	☐
1.1.1.2	Ensure freevxfs kernel module is not available	☐	☐
1.1.1.3	Ensure hfs kernel module is not available	☐	☐
1.1.1.4	Ensure hfsplus kernel module is not available	☐	☐
1.1.1.5	Ensure jffs2 kernel module is not available	☐	☐
1.1.1.6	Ensure overlay kernel module is not available	☐	☐
1.1.1.7	Ensure squashfs kernel module is not available	☐	☐
1.1.1.8	Ensure udf kernel module is not available	☐	☐
1.1.1.9	Ensure firewire-core kernel module is not available	☐	☐
1.1.1.10	Ensure usb-storage kernel module is not available	☐	☐
1.1.1.11	Ensure unused filesystems kernel modules are not available	☐	☐
1.1.2.1.1	Ensure /tmp is tmpfs or a separate partition	☐	☐
1.1.2.1.2	Ensure nodev option set on /tmp partition	☐	☐
1.1.2.1.3	Ensure nosuid option set on /tmp partition	☐	☐
1.1.2.1.4	Ensure noexec option set on /tmp partition	☐	☐
1.1.2.2.1	Ensure /dev/shm is tmpfs	☐	☐
1.1.2.2.2	Ensure nodev option set on /dev/shm partition	☐	☐
1.1.2.2.3	Ensure nosuid option set on /dev/shm partition	☐	☐
1.1.2.2.4	Ensure noexec option set on /dev/shm partition	☐	☐
1.1.2.3.1	Ensure separate partition exists for /home	☐	☐
1.1.2.3.2	Ensure nodev option set on /home partition	☐	☐
1.1.2.3.3	Ensure nosuid option set on /home partition	☐	☐
1.1.2.4.1	Ensure separate partition exists for /var	☐	☐
1.1.2.4.2	Ensure nodev option set on /var partition	☐	☐
1.1.2.4.3	Ensure nosuid option set on /var partition	☐	☐
1.1.2.5.1	Ensure separate partition exists for /var/tmp	☐	☐

Recommendation		Set Correctly	
		Yes	No
1.1.2.5.2	Ensure nodev option set on /var/tmp partition	☐	☐
1.1.2.5.3	Ensure nosuid option set on /var/tmp partition	☐	☐
1.1.2.5.4	Ensure noexec option set on /var/tmp partition	☐	☐
1.1.2.6.1	Ensure separate partition exists for /var/log	☐	☐
1.1.2.6.2	Ensure nodev option set on /var/log partition	☐	☐
1.1.2.6.3	Ensure nosuid option set on /var/log partition	☐	☐
1.1.2.6.4	Ensure noexec option set on /var/log partition	☐	☐
1.1.2.7.1	Ensure separate partition exists for /var/log/audit	☐	☐
1.1.2.7.2	Ensure nodev option set on /var/log/audit partition	☐	☐
1.1.2.7.3	Ensure nosuid option set on /var/log/audit partition	☐	☐
1.1.2.7.4	Ensure noexec option set on /var/log/audit partition	☐	☐
1.2.1.1	Ensure GPG keys are configured	☐	☐
1.2.1.2	Ensure gpgcheck is configured	☐	☐
1.2.1.3	Ensure repo_gpgcheck is globally activated	☐	☐
1.2.1.4	Ensure package manager repositories are configured	☐	☐
1.2.1.5	Ensure weak dependencies are configured	☐	☐
1.2.2.1	Ensure updates, patches, and additional security software are installed	☐	☐
1.3.1.1	Ensure SELinux is installed	☐	☐
1.3.1.2	Ensure SELinux policy is configured	☐	☐
1.3.1.3	Ensure the SELinux mode is not disabled	☐	☐
1.3.1.4	Ensure no unconfined services exist	☐	☐
1.3.1.5	Ensure the MCS Translation Service (mcstrans) is not installed	☐	☐
1.3.1.6	Ensure SETroubleshoot is not installed	☐	☐
1.4.1	Ensure access to bootloader config is configured	☐	☐
1.5.5	Ensure kernel.dmesg_restrict is configured	☐	☐
1.5.6	Ensure kernel.kptr_restrict is configured	☐	☐
1.5.7	Ensure kernel.randomize_va_space is configured	☐	☐
1.6.1	Ensure system wide crypto policy is not set to legacy	☐	☐
1.6.2	Ensure system wide crypto policy disables sha1 hash and signature support	☐	☐

Recommendation		Set Correctly	
		Yes	No
1.6.3	Ensure system wide crypto policy macs are configured	☐	☐
1.6.4	Ensure system wide crypto policy disables cbc for ssh	☐	☐
1.6.5	Ensure system wide crypto policy disables chacha20-poly1305 for ssh	☐	☐
1.6.6	Ensure system wide crypto policy disables EtM for ssh	☐	☐
1.7.4	Ensure access to /etc/motd is configured	☐	☐
1.7.5	Ensure access to /etc/issue is configured	☐	☐
1.7.6	Ensure access to /etc/issue.net is configured	☐	☐
1.8.2	Ensure GDM disable-user-list is configured	☐	☐
1.8.3	Ensure GDM screen lock is configured	☐	☐
1.8.4	Ensure GDM automount is configured	☐	☐
1.8.5	Ensure GDM autorun-never is configured	☐	☐
1.8.6	Ensure XDMCP is not enabled	☐	☐
1.8.7	Ensure Xwayland is configured	☐	☐
2.1.1	Ensure autofs services are not in use	☐	☐
2.1.2	Ensure avahi daemon services are not in use	☐	☐
2.1.3	Ensure cockpit web services are not in use	☐	☐
2.1.4	Ensure dhcp server services are not in use	☐	☐
2.1.5	Ensure dns server services are not in use	☐	☐
2.1.6	Ensure dnsmasq services are not in use	☐	☐
2.1.7	Ensure ftp server services are not in use	☐	☐
2.1.8	Ensure message access server services are not in use	☐	☐
2.1.9	Ensure network file system services are not in use	☐	☐
2.1.10	Ensure nis server services are not in use	☐	☐
2.1.11	Ensure print server services are not in use	☐	☐
2.1.12	Ensure rpcbind services are not in use	☐	☐
2.1.13	Ensure rsync services are not in use	☐	☐
2.1.14	Ensure samba file server services are not in use	☐	☐
2.1.15	Ensure snmp services are not in use	☐	☐
2.1.16	Ensure telnet server services are not in use	☐	☐
2.1.17	Ensure tftp server services are not in use	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.1.18	Ensure web proxy server services are not in use	☐	☐
2.1.19	Ensure web server services are not in use	☐	☐
2.1.20	Ensure xinetd services are not in use	☐	☐
2.1.21	Ensure GNOME Display Manager is not installed	☐	☐
2.1.22	Ensure X window server services are not in use	☐	☐
2.1.23	Ensure mail transfer agents are configured for local-only mode	☐	☐
2.1.24	Ensure only approved services are listening on a network interface	☐	☐
2.2.1	Ensure ftp client is not installed	☐	☐
2.2.2	Ensure ldap client is not installed	☐	☐
2.2.3	Ensure nis client is not installed	☐	☐
2.2.4	Ensure telnet client is not installed	☐	☐
2.2.5	Ensure tftp client is not installed	☐	☐
2.3.1	Ensure time synchronization is in use	☐	☐
2.3.2	Ensure chrony is configured	☐	☐
2.4.1.2	Ensure access to /etc/crontab is configured	☐	☐
2.4.1.3	Ensure access to /etc/cron.hourly is configured	☐	☐
2.4.1.4	Ensure access to /etc/cron.daily is configured	☐	☐
2.4.1.5	Ensure access to /etc/cron.weekly is configured	☐	☐
2.4.1.6	Ensure access to /etc/cron.monthly is configured	☐	☐
2.4.1.8	Ensure access to /etc/cron.d is configured	☐	☐
2.4.1.9	Ensure access to crontab is configured	☐	☐
2.4.2.1	Ensure access to at is configured	☐	☐
3.1.1	Ensure IPv6 status is identified	☐	☐
3.1.3	Ensure bluetooth services are not in use	☐	☐
3.2.1	Ensure atm kernel module is not available	☐	☐
3.2.2	Ensure can kernel module is not available	☐	☐
3.2.3	Ensure dccp kernel module is not available	☐	☐
3.2.4	Ensure rds kernel module is not available	☐	☐
3.2.5	Ensure sctp kernel module is not available	☐	☐
3.2.6	Ensure tipc kernel module is not available	☐	☐

Recommendation		Set Correctly	
		Yes	No
3.3.1.1	Ensure net.ipv4.ip_forward is configured	☐	☐
3.3.1.2	Ensure net.ipv4.conf.all.forwarding is configured	☐	☐
3.3.1.3	Ensure net.ipv4.conf.default.forwarding is configured	☐	☐
3.3.1.4	Ensure net.ipv4.conf.all.send_redirects is configured	☐	☐
3.3.1.5	Ensure net.ipv4.conf.default.send_redirects is configured	☐	☐
3.3.1.6	Ensure net.ipv4.icmp_ignore_bogus_error_responses is configured	☐	☐
3.3.1.7	Ensure net.ipv4.icmp_echo_ignore_broadcasts is configured	☐	☐
3.3.1.8	Ensure net.ipv4.conf.all.accept_redirects is configured	☐	☐
3.3.1.9	Ensure net.ipv4.conf.default.accept_redirects is configured	☐	☐
3.3.1.10	Ensure net.ipv4.conf.all.secure_redirects is configured	☐	☐
3.3.1.11	Ensure net.ipv4.conf.default.secure_redirects is configured	☐	☐
3.3.1.12	Ensure net.ipv4.conf.all.rp_filter is configured	☐	☐
3.3.1.13	Ensure net.ipv4.conf.default.rp_filter is configured	☐	☐
3.3.1.14	Ensure net.ipv4.conf.all.accept_source_route is configured	☐	☐
3.3.1.15	Ensure net.ipv4.conf.default.accept_source_route is configured	☐	☐
3.3.1.16	Ensure net.ipv4.conf.all.log_martians is configured	☐	☐
3.3.1.17	Ensure net.ipv4.conf.default.log_martians is configured	☐	☐
3.3.1.18	Ensure net.ipv4.tcp_syncookies is configured	☐	☐
3.3.2.1	Ensure net.ipv6.conf.all.forwarding is configured	☐	☐
3.3.2.2	Ensure net.ipv6.conf.default.forwarding is configured	☐	☐
3.3.2.3	Ensure net.ipv6.conf.all.accept_redirects is configured	☐	☐
3.3.2.4	Ensure net.ipv6.conf.default.accept_redirects is configured	☐	☐
3.3.2.5	Ensure net.ipv6.conf.all.accept_source_route is configured	☐	☐
3.3.2.6	Ensure net.ipv6.conf.default.accept_source_route is configured	☐	☐
3.3.2.7	Ensure net.ipv6.conf.all.accept_ra is configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
3.3.2.8	Ensure net.ipv6.conf.default.accept_ra is configured	☐	☐
4.1.1	Ensure firewalld is installed	☐	☐
4.1.2	Ensure firewalld backend is configured	☐	☐
4.1.3	Ensure firewalld.service is configured	☐	☐
4.1.4	Ensure firewalld active zone target is configured	☐	☐
4.1.5	Ensure firewalld loopback traffic is configured	☐	☐
4.1.6	Ensure firewalld loopback source address traffic is configured	☐	☐
4.1.7	Ensure firewalld services and ports are configured	☐	☐
5.1.1	Ensure sshd crypto_policy is not set	☐	☐
5.1.2	Ensure access to /etc/ssh/sshd_config is configured	☐	☐
5.1.3	Ensure access to /etc/sysconfig/sshd is configured	☐	☐
5.1.4	Ensure access to SSH private host key files is configured	☐	☐
5.1.5	Ensure access to SSH public host key files is configured	☐	☐
5.1.6	Ensure sshd access is configured	☐	☐
5.1.8	Ensure sshd Ciphers are configured	☐	☐
5.1.10	Ensure sshd DisableForwarding is enabled	☐	☐
5.1.11	Ensure sshd GSSAPIAuthentication is disabled	☐	☐
5.1.12	Ensure sshd HostbasedAuthentication is disabled	☐	☐
5.1.13	Ensure sshd IgnoreRhosts is enabled	☐	☐
5.1.14	Ensure sshd KexAlgorithms is configured	☐	☐
5.1.16	Ensure sshd LogLevel is configured	☐	☐
5.1.17	Ensure sshd MACs are configured	☐	☐
5.1.21	Ensure sshd PermitEmptyPasswords is disabled	☐	☐
5.1.22	Ensure sshd PermitRootLogin is disabled	☐	☐
5.1.24	Ensure sshd UsePAM is enabled	☐	☐
5.2.1	Ensure sudo is installed	☐	☐
5.2.2	Ensure sudo commands use pty	☐	☐
5.2.3	Ensure sudo log file exists	☐	☐
5.2.4	Ensure users must provide password for escalation	☐	☐
5.2.5	Ensure re-authentication for privilege escalation is not disabled globally	☐	☐

Recommendation		Set Correctly	
		Yes	No
5.2.6	Ensure sudo timestamp_timeout is configured	☐	☐
5.2.7	Ensure access to the su command is restricted	☐	☐
5.3.2.1	Ensure active authselect profile includes pam modules	☐	☐
5.3.2.2	Ensure pam_faillock module is enabled	☐	☐
5.3.2.3	Ensure pam_pwquality module is enabled	☐	☐
5.3.2.4	Ensure pam_pwhistory module is enabled	☐	☐
5.3.3.1.1	Ensure password failed attempts lockout is configured	☐	☐
5.3.3.1.2	Ensure password unlock time is configured	☐	☐
5.3.3.1.3	Ensure password failed attempts lockout includes root account	☐	☐
5.3.3.2.1	Ensure password number of changed characters is configured	☐	☐
5.3.3.2.2	Ensure password length is configured	☐	☐
5.3.3.2.3	Ensure password complexity is configured	☐	☐
5.3.3.2.4	Ensure password same consecutive characters is configured	☐	☐
5.3.3.2.5	Ensure password maximum sequential characters is configured	☐	☐
5.3.3.2.6	Ensure password dictionary check is enabled	☐	☐
5.3.3.2.7	Ensure password quality is enforced for the root user	☐	☐
5.3.3.3.1	Ensure password history remember is configured	☐	☐
5.3.3.3.2	Ensure password history is enforced for the root user	☐	☐
5.3.3.3.3	Ensure pam_pwhistory includes use_authtok	☐	☐
5.3.3.4.1	Ensure pam_unix does not include nullok	☐	☐
5.3.3.4.2	Ensure pam_unix does not include remember	☐	☐
5.3.3.4.3	Ensure pam_unix includes a strong password hashing algorithm	☐	☐
5.3.3.4.4	Ensure pam_unix includes use_authtok	☐	☐
5.4.1.1	Ensure password expiration is configured	☐	☐
5.4.1.2	Ensure minimum password days is configured	☐	☐
5.4.1.3	Ensure password expiration warning days is configured	☐	☐
5.4.1.4	Ensure strong password hashing algorithm is configured	☐	☐
5.4.1.5	Ensure inactive password lock is configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
5.4.1.6	Ensure all users last password change date is in the past	☐	☐
5.4.2.1	Ensure root is the only UID 0 account	☐	☐
5.4.2.2	Ensure root is the only GID 0 account	☐	☐
5.4.2.3	Ensure group root is the only GID 0 group	☐	☐
5.4.2.4	Ensure root account access is controlled	☐	☐
5.4.2.6	Ensure root user umask is configured	☐	☐
5.4.2.7	Ensure system accounts do not have a valid login shell	☐	☐
5.4.2.8	Ensure accounts without a valid login shell are locked	☐	☐
5.4.3.2	Ensure default user shell timeout is configured	☐	☐
5.4.3.3	Ensure default user umask is configured	☐	☐
6.2.1.1.1	Ensure journald service is active	☐	☐
6.2.1.1.2	Ensure journald log file access is configured	☐	☐
6.2.1.1.3	Ensure journald log file rotation is configured	☐	☐
6.2.1.1.4	Ensure journald ForwardToSyslog is disabled	☐	☐
6.2.1.1.5	Ensure journald Storage is configured	☐	☐
6.2.1.1.6	Ensure journald Compress is configured	☐	☐
6.2.1.2.1	Ensure systemd-journal-remote is installed	☐	☐
6.2.1.2.2	Ensure systemd-journal-remote authentication is configured	☐	☐
6.2.1.2.3	Ensure systemd-journal-upload is enabled and active	☐	☐
6.2.1.2.4	Ensure systemd-journal-remote service is not in use	☐	☐
6.2.2.1	Ensure rsyslog is installed	☐	☐
6.2.2.2	Ensure rsyslog service is enabled and active	☐	☐
6.2.2.3	Ensure journald is configured to send logs to rsyslog	☐	☐
6.2.2.4	Ensure rsyslog log file creation mode is configured	☐	☐
6.2.2.5	Ensure rsyslog logging is configured	☐	☐
6.2.2.6	Ensure rsyslog is configured to send logs to a remote log host	☐	☐
6.2.2.7	Ensure rsyslog is not configured to receive logs from a remote client	☐	☐
6.2.2.8	Ensure logrotate is configured	☐	☐
6.2.3.1	Ensure access to all logfiles has been configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
6.3.1.1	Ensure auditd packages are installed	☐	☐
6.3.1.2	Ensure auditing for processes that start prior to auditd is enabled	☐	☐
6.3.1.3	Ensure audit_backlog_limit is configured	☐	☐
6.3.1.4	Ensure auditd service is enabled and active	☐	☐
6.3.2.1	Ensure audit log storage size is configured	☐	☐
6.3.2.2	Ensure audit logs are not automatically deleted	☐	☐
6.3.3.1	Ensure changes to system administration scope (sudoers) is collected	☐	☐
6.3.3.2	Ensure actions as another user are always logged	☐	☐
6.3.3.3	Ensure events that modify the sudo log file are collected	☐	☐
6.3.3.4	Ensure events that modify date and time information are collected	☐	☐
6.3.3.5	Ensure events that modify the system's network environment are collected	☐	☐
6.3.3.6	Ensure use of privileged commands are collected	☐	☐
6.3.3.8	Ensure events that modify user/group information are collected	☐	☐
6.3.3.9	Ensure discretionary access control permission modification events are collected	☐	☐
6.3.3.10	Ensure successful file system mounts are collected	☐	☐
6.3.3.11	Ensure session initiation information is collected	☐	☐
6.3.3.12	Ensure login and logout events are collected	☐	☐
6.3.3.13	Ensure file deletion events by users are collected	☐	☐
6.3.3.14	Ensure events that modify the system's Mandatory Access Controls are collected	☐	☐
6.3.3.15	Ensure successful and unsuccessful attempts to use the chcon command are collected	☐	☐
6.3.3.16	Ensure successful and unsuccessful attempts to use the setfacl command are collected	☐	☐
6.3.3.17	Ensure successful and unsuccessful attempts to use the chacl command are collected	☐	☐
6.3.3.18	Ensure successful and unsuccessful attempts to use the usermod command are collected	☐	☐

Recommendation		Set Correctly	
		Yes	No
6.3.3.19	Ensure kernel module loading unloading and modification is collected	☐	☐
6.3.3.20	Ensure the audit configuration is loaded regardless of errors	☐	☐
6.3.3.21	Ensure the audit configuration is immutable	☐	☐
6.3.3.22	Ensure the running and on disk configuration is the same	☐	☐
6.3.4.1	Ensure the audit log file directory mode is configured	☐	☐
6.3.4.2	Ensure audit log files mode is configured	☐	☐
6.3.4.3	Ensure audit log files owner is configured	☐	☐
6.3.4.4	Ensure audit log files group owner is configured	☐	☐
6.3.4.5	Ensure audit configuration files mode is configured	☐	☐
6.3.4.6	Ensure audit configuration files owner is configured	☐	☐
6.3.4.7	Ensure audit configuration files group owner is configured	☐	☐
6.3.4.8	Ensure audit tools mode is configured	☐	☐
6.3.4.9	Ensure audit tools owner is configured	☐	☐
6.3.4.10	Ensure audit tools group owner is configured	☐	☐
7.1.1	Ensure access to /etc/passwd is configured	☐	☐
7.1.2	Ensure access to /etc/passwd- is configured	☐	☐
7.1.3	Ensure access to /etc/group is configured	☐	☐
7.1.4	Ensure access to /etc/group- is configured	☐	☐
7.1.5	Ensure access to /etc/shadow is configured	☐	☐
7.1.6	Ensure access to /etc/shadow- is configured	☐	☐
7.1.7	Ensure access to /etc/gshadow is configured	☐	☐
7.1.8	Ensure access to /etc/gshadow- is configured	☐	☐
7.1.9	Ensure access to /etc/shells is configured	☐	☐
7.1.10	Ensure access to /etc/security/opasswd is configured	☐	☐
7.1.11	Ensure world writable files and directories are secured	☐	☐
7.1.12	Ensure no files or directories without an owner and a group exist	☐	☐
7.1.13	Ensure SUID and SGID files are reviewed	☐	☐
7.2.1	Ensure accounts in /etc/passwd use shadowed passwords	☐	☐

Recommendation		Set Correctly	
		Yes	No
7.2.2	Ensure /etc/shadow password fields are not empty	☐	☐
7.2.3	Ensure all groups in /etc/passwd exist in /etc/group	☐	☐
7.2.8	Ensure local interactive user home directories are configured	☐	☐
7.2.9	Ensure local interactive user dot files access is configured	☐	☐

Appendix: CIS Controls v7 IG 3 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1.1.1	Ensure cramfs kernel module is not available	☐	☐
1.1.1.2	Ensure freevxfs kernel module is not available	☐	☐
1.1.1.3	Ensure hfs kernel module is not available	☐	☐
1.1.1.4	Ensure hfsplus kernel module is not available	☐	☐
1.1.1.5	Ensure jffs2 kernel module is not available	☐	☐
1.1.1.6	Ensure overlay kernel module is not available	☐	☐
1.1.1.7	Ensure squashfs kernel module is not available	☐	☐
1.1.1.8	Ensure udf kernel module is not available	☐	☐
1.1.1.9	Ensure firewire-core kernel module is not available	☐	☐
1.1.1.10	Ensure usb-storage kernel module is not available	☐	☐
1.1.1.11	Ensure unused filesystems kernel modules are not available	☐	☐
1.1.2.1.1	Ensure /tmp is tmpfs or a separate partition	☐	☐
1.1.2.1.2	Ensure nodev option set on /tmp partition	☐	☐
1.1.2.1.3	Ensure nosuid option set on /tmp partition	☐	☐
1.1.2.1.4	Ensure noexec option set on /tmp partition	☐	☐
1.1.2.2.1	Ensure /dev/shm is tmpfs	☐	☐
1.1.2.2.2	Ensure nodev option set on /dev/shm partition	☐	☐
1.1.2.2.3	Ensure nosuid option set on /dev/shm partition	☐	☐
1.1.2.2.4	Ensure noexec option set on /dev/shm partition	☐	☐
1.1.2.3.1	Ensure separate partition exists for /home	☐	☐
1.1.2.3.2	Ensure nodev option set on /home partition	☐	☐
1.1.2.3.3	Ensure nosuid option set on /home partition	☐	☐
1.1.2.4.1	Ensure separate partition exists for /var	☐	☐
1.1.2.4.2	Ensure nodev option set on /var partition	☐	☐
1.1.2.4.3	Ensure nosuid option set on /var partition	☐	☐
1.1.2.5.1	Ensure separate partition exists for /var/tmp	☐	☐

Recommendation		Set Correctly	
		Yes	No
1.1.2.5.2	Ensure nodev option set on /var/tmp partition	☐	☐
1.1.2.5.3	Ensure nosuid option set on /var/tmp partition	☐	☐
1.1.2.5.4	Ensure noexec option set on /var/tmp partition	☐	☐
1.1.2.6.1	Ensure separate partition exists for /var/log	☐	☐
1.1.2.6.2	Ensure nodev option set on /var/log partition	☐	☐
1.1.2.6.3	Ensure nosuid option set on /var/log partition	☐	☐
1.1.2.6.4	Ensure noexec option set on /var/log partition	☐	☐
1.1.2.7.1	Ensure separate partition exists for /var/log/audit	☐	☐
1.1.2.7.2	Ensure nodev option set on /var/log/audit partition	☐	☐
1.1.2.7.3	Ensure nosuid option set on /var/log/audit partition	☐	☐
1.1.2.7.4	Ensure noexec option set on /var/log/audit partition	☐	☐
1.2.1.1	Ensure GPG keys are configured	☐	☐
1.2.1.2	Ensure gpgcheck is configured	☐	☐
1.2.1.3	Ensure repo_gpgcheck is globally activated	☐	☐
1.2.1.4	Ensure package manager repositories are configured	☐	☐
1.2.1.5	Ensure weak dependencies are configured	☐	☐
1.2.2.1	Ensure updates, patches, and additional security software are installed	☐	☐
1.3.1.1	Ensure SELinux is installed	☐	☐
1.3.1.2	Ensure SELinux policy is configured	☐	☐
1.3.1.3	Ensure the SELinux mode is not disabled	☐	☐
1.3.1.4	Ensure no unconfined services exist	☐	☐
1.3.1.5	Ensure the MCS Translation Service (mcstrans) is not installed	☐	☐
1.3.1.6	Ensure SETroubleshoot is not installed	☐	☐
1.4.1	Ensure access to bootloader config is configured	☐	☐
1.5.5	Ensure kernel.dmesg_restrict is configured	☐	☐
1.5.6	Ensure kernel.kptr_restrict is configured	☐	☐
1.5.7	Ensure kernel.randomize_va_space is configured	☐	☐
1.6.1	Ensure system wide crypto policy is not set to legacy	☐	☐
1.6.2	Ensure system wide crypto policy disables sha1 hash and signature support	☐	☐

Recommendation		Set Correctly	
		Yes	No
1.6.3	Ensure system wide crypto policy macs are configured	☐	☐
1.6.4	Ensure system wide crypto policy disables cbc for ssh	☐	☐
1.6.5	Ensure system wide crypto policy disables chacha20-poly1305 for ssh	☐	☐
1.6.6	Ensure system wide crypto policy disables EtM for ssh	☐	☐
1.7.4	Ensure access to /etc/motd is configured	☐	☐
1.7.5	Ensure access to /etc/issue is configured	☐	☐
1.7.6	Ensure access to /etc/issue.net is configured	☐	☐
1.8.2	Ensure GDM disable-user-list is configured	☐	☐
1.8.3	Ensure GDM screen lock is configured	☐	☐
1.8.4	Ensure GDM automount is configured	☐	☐
1.8.5	Ensure GDM autorun-never is configured	☐	☐
1.8.6	Ensure XDMCP is not enabled	☐	☐
1.8.7	Ensure Xwayland is configured	☐	☐
2.1.1	Ensure autofs services are not in use	☐	☐
2.1.2	Ensure avahi daemon services are not in use	☐	☐
2.1.3	Ensure cockpit web services are not in use	☐	☐
2.1.4	Ensure dhcp server services are not in use	☐	☐
2.1.5	Ensure dns server services are not in use	☐	☐
2.1.6	Ensure dnsmasq services are not in use	☐	☐
2.1.7	Ensure ftp server services are not in use	☐	☐
2.1.8	Ensure message access server services are not in use	☐	☐
2.1.9	Ensure network file system services are not in use	☐	☐
2.1.10	Ensure nis server services are not in use	☐	☐
2.1.11	Ensure print server services are not in use	☐	☐
2.1.12	Ensure rpcbind services are not in use	☐	☐
2.1.13	Ensure rsync services are not in use	☐	☐
2.1.14	Ensure samba file server services are not in use	☐	☐
2.1.15	Ensure snmp services are not in use	☐	☐
2.1.16	Ensure telnet server services are not in use	☐	☐
2.1.17	Ensure tftp server services are not in use	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.1.18	Ensure web proxy server services are not in use	☐	☐
2.1.19	Ensure web server services are not in use	☐	☐
2.1.20	Ensure xinetd services are not in use	☐	☐
2.1.21	Ensure GNOME Display Manager is not installed	☐	☐
2.1.22	Ensure X window server services are not in use	☐	☐
2.1.23	Ensure mail transfer agents are configured for local-only mode	☐	☐
2.1.24	Ensure only approved services are listening on a network interface	☐	☐
2.2.1	Ensure ftp client is not installed	☐	☐
2.2.2	Ensure ldap client is not installed	☐	☐
2.2.3	Ensure nis client is not installed	☐	☐
2.2.4	Ensure telnet client is not installed	☐	☐
2.2.5	Ensure tftp client is not installed	☐	☐
2.3.1	Ensure time synchronization is in use	☐	☐
2.3.2	Ensure chrony is configured	☐	☐
2.4.1.2	Ensure access to /etc/crontab is configured	☐	☐
2.4.1.3	Ensure access to /etc/cron.hourly is configured	☐	☐
2.4.1.4	Ensure access to /etc/cron.daily is configured	☐	☐
2.4.1.5	Ensure access to /etc/cron.weekly is configured	☐	☐
2.4.1.6	Ensure access to /etc/cron.monthly is configured	☐	☐
2.4.1.8	Ensure access to /etc/cron.d is configured	☐	☐
2.4.1.9	Ensure access to crontab is configured	☐	☐
2.4.2.1	Ensure access to at is configured	☐	☐
3.1.1	Ensure IPv6 status is identified	☐	☐
3.1.2	Ensure wireless interfaces are not available	☐	☐
3.1.3	Ensure bluetooth services are not in use	☐	☐
3.2.1	Ensure atm kernel module is not available	☐	☐
3.2.2	Ensure can kernel module is not available	☐	☐
3.2.3	Ensure dccp kernel module is not available	☐	☐
3.2.4	Ensure rds kernel module is not available	☐	☐
3.2.5	Ensure sctp kernel module is not available	☐	☐

Recommendation		Set Correctly	
		Yes	No
3.2.6	Ensure tipc kernel module is not available	☐	☐
3.3.1.1	Ensure net.ipv4.ip_forward is configured	☐	☐
3.3.1.2	Ensure net.ipv4.conf.all.forwarding is configured	☐	☐
3.3.1.3	Ensure net.ipv4.conf.default.forwarding is configured	☐	☐
3.3.1.4	Ensure net.ipv4.conf.all.send_redirects is configured	☐	☐
3.3.1.5	Ensure net.ipv4.conf.default.send_redirects is configured	☐	☐
3.3.1.6	Ensure net.ipv4.icmp_ignore_bogus_error_responses is configured	☐	☐
3.3.1.7	Ensure net.ipv4.icmp_echo_ignore_broadcasts is configured	☐	☐
3.3.1.8	Ensure net.ipv4.conf.all.accept_redirects is configured	☐	☐
3.3.1.9	Ensure net.ipv4.conf.default.accept_redirects is configured	☐	☐
3.3.1.10	Ensure net.ipv4.conf.all.secure_redirects is configured	☐	☐
3.3.1.11	Ensure net.ipv4.conf.default.secure_redirects is configured	☐	☐
3.3.1.12	Ensure net.ipv4.conf.all.rp_filter is configured	☐	☐
3.3.1.13	Ensure net.ipv4.conf.default.rp_filter is configured	☐	☐
3.3.1.14	Ensure net.ipv4.conf.all.accept_source_route is configured	☐	☐
3.3.1.15	Ensure net.ipv4.conf.default.accept_source_route is configured	☐	☐
3.3.1.16	Ensure net.ipv4.conf.all.log_martians is configured	☐	☐
3.3.1.17	Ensure net.ipv4.conf.default.log_martians is configured	☐	☐
3.3.1.18	Ensure net.ipv4.tcp_syncookies is configured	☐	☐
3.3.2.1	Ensure net.ipv6.conf.all.forwarding is configured	☐	☐
3.3.2.2	Ensure net.ipv6.conf.default.forwarding is configured	☐	☐
3.3.2.3	Ensure net.ipv6.conf.all.accept_redirects is configured	☐	☐
3.3.2.4	Ensure net.ipv6.conf.default.accept_redirects is configured	☐	☐
3.3.2.5	Ensure net.ipv6.conf.all.accept_source_route is configured	☐	☐
3.3.2.6	Ensure net.ipv6.conf.default.accept_source_route is configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
3.3.2.7	Ensure net.ipv6.conf.all.accept_ra is configured	☐	☐
3.3.2.8	Ensure net.ipv6.conf.default.accept_ra is configured	☐	☐
4.1.1	Ensure firewalld is installed	☐	☐
4.1.2	Ensure firewalld backend is configured	☐	☐
4.1.3	Ensure firewalld.service is configured	☐	☐
4.1.4	Ensure firewalld active zone target is configured	☐	☐
4.1.5	Ensure firewalld loopback traffic is configured	☐	☐
4.1.6	Ensure firewalld loopback source address traffic is configured	☐	☐
4.1.7	Ensure firewalld services and ports are configured	☐	☐
5.1.1	Ensure sshd crypto_policy is not set	☐	☐
5.1.2	Ensure access to /etc/ssh/sshd_config is configured	☐	☐
5.1.3	Ensure access to /etc/sysconfig/sshd is configured	☐	☐
5.1.4	Ensure access to SSH private host key files is configured	☐	☐
5.1.5	Ensure access to SSH public host key files is configured	☐	☐
5.1.6	Ensure sshd access is configured	☐	☐
5.1.8	Ensure sshd Ciphers are configured	☐	☐
5.1.10	Ensure sshd DisableForwarding is enabled	☐	☐
5.1.11	Ensure sshd GSSAPIAuthentication is disabled	☐	☐
5.1.12	Ensure sshd HostbasedAuthentication is disabled	☐	☐
5.1.13	Ensure sshd IgnoreRhosts is enabled	☐	☐
5.1.14	Ensure sshd KexAlgorithms is configured	☐	☐
5.1.16	Ensure sshd LogLevel is configured	☐	☐
5.1.17	Ensure sshd MACs are configured	☐	☐
5.1.18	Ensure sshd MaxAuthTries is configured	☐	☐
5.1.21	Ensure sshd PermitEmptyPasswords is disabled	☐	☐
5.1.22	Ensure sshd PermitRootLogin is disabled	☐	☐
5.1.24	Ensure sshd UsePAM is enabled	☐	☐
5.2.1	Ensure sudo is installed	☐	☐
5.2.2	Ensure sudo commands use pty	☐	☐
5.2.3	Ensure sudo log file exists	☐	☐

Recommendation		Set Correctly	
		Yes	No
5.2.4	Ensure users must provide password for escalation	☐	☐
5.2.5	Ensure re-authentication for privilege escalation is not disabled globally	☐	☐
5.2.6	Ensure sudo timestamp_timeout is configured	☐	☐
5.2.7	Ensure access to the su command is restricted	☐	☐
5.3.2.1	Ensure active authselect profile includes pam modules	☐	☐
5.3.2.2	Ensure pam_faillock module is enabled	☐	☐
5.3.2.3	Ensure pam_pwquality module is enabled	☐	☐
5.3.2.4	Ensure pam_pwhistory module is enabled	☐	☐
5.3.3.1.1	Ensure password failed attempts lockout is configured	☐	☐
5.3.3.1.2	Ensure password unlock time is configured	☐	☐
5.3.3.1.3	Ensure password failed attempts lockout includes root account	☐	☐
5.3.3.2.1	Ensure password number of changed characters is configured	☐	☐
5.3.3.2.2	Ensure password length is configured	☐	☐
5.3.3.2.3	Ensure password complexity is configured	☐	☐
5.3.3.2.4	Ensure password same consecutive characters is configured	☐	☐
5.3.3.2.5	Ensure password maximum sequential characters is configured	☐	☐
5.3.3.2.6	Ensure password dictionary check is enabled	☐	☐
5.3.3.2.7	Ensure password quality is enforced for the root user	☐	☐
5.3.3.3.1	Ensure password history remember is configured	☐	☐
5.3.3.3.2	Ensure password history is enforced for the root user	☐	☐
5.3.3.3.3	Ensure pam_pwhistory includes use_authtok	☐	☐
5.3.3.4.1	Ensure pam_unix does not include nullok	☐	☐
5.3.3.4.2	Ensure pam_unix does not include remember	☐	☐
5.3.3.4.3	Ensure pam_unix includes a strong password hashing algorithm	☐	☐
5.3.3.4.4	Ensure pam_unix includes use_authtok	☐	☐
5.4.1.1	Ensure password expiration is configured	☐	☐
5.4.1.2	Ensure minimum password days is configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
5.4.1.3	Ensure password expiration warning days is configured	☐	☐
5.4.1.4	Ensure strong password hashing algorithm is configured	☐	☐
5.4.1.5	Ensure inactive password lock is configured	☐	☐
5.4.1.6	Ensure all users last password change date is in the past	☐	☐
5.4.2.1	Ensure root is the only UID 0 account	☐	☐
5.4.2.2	Ensure root is the only GID 0 account	☐	☐
5.4.2.3	Ensure group root is the only GID 0 group	☐	☐
5.4.2.4	Ensure root account access is controlled	☐	☐
5.4.2.6	Ensure root user umask is configured	☐	☐
5.4.2.7	Ensure system accounts do not have a valid login shell	☐	☐
5.4.2.8	Ensure accounts without a valid login shell are locked	☐	☐
5.4.3.2	Ensure default user shell timeout is configured	☐	☐
5.4.3.3	Ensure default user umask is configured	☐	☐
6.1.1	Ensure AIDE is installed	☐	☐
6.1.2	Ensure filesystem integrity is regularly checked	☐	☐
6.2.1.1.1	Ensure journald service is active	☐	☐
6.2.1.1.2	Ensure journald log file access is configured	☐	☐
6.2.1.1.3	Ensure journald log file rotation is configured	☐	☐
6.2.1.1.4	Ensure journald ForwardToSyslog is disabled	☐	☐
6.2.1.1.5	Ensure journald Storage is configured	☐	☐
6.2.1.1.6	Ensure journald Compress is configured	☐	☐
6.2.1.2.1	Ensure systemd-journal-remote is installed	☐	☐
6.2.1.2.2	Ensure systemd-journal-remote authentication is configured	☐	☐
6.2.1.2.3	Ensure systemd-journal-upload is enabled and active	☐	☐
6.2.1.2.4	Ensure systemd-journal-remote service is not in use	☐	☐
6.2.2.1	Ensure rsyslog is installed	☐	☐
6.2.2.2	Ensure rsyslog service is enabled and active	☐	☐
6.2.2.3	Ensure journald is configured to send logs to rsyslog	☐	☐
6.2.2.4	Ensure rsyslog log file creation mode is configured	☐	☐
6.2.2.5	Ensure rsyslog logging is configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
6.2.2.6	Ensure rsyslog is configured to send logs to a remote log host	☐	☐
6.2.2.7	Ensure rsyslog is not configured to receive logs from a remote client	☐	☐
6.2.2.8	Ensure logrotate is configured	☐	☐
6.2.3.1	Ensure access to all logfiles has been configured	☐	☐
6.3.1.1	Ensure auditd packages are installed	☐	☐
6.3.1.2	Ensure auditing for processes that start prior to auditd is enabled	☐	☐
6.3.1.3	Ensure audit_backlog_limit is configured	☐	☐
6.3.1.4	Ensure auditd service is enabled and active	☐	☐
6.3.2.1	Ensure audit log storage size is configured	☐	☐
6.3.2.2	Ensure audit logs are not automatically deleted	☐	☐
6.3.3.1	Ensure changes to system administration scope (sudoers) is collected	☐	☐
6.3.3.2	Ensure actions as another user are always logged	☐	☐
6.3.3.3	Ensure events that modify the sudo log file are collected	☐	☐
6.3.3.4	Ensure events that modify date and time information are collected	☐	☐
6.3.3.5	Ensure events that modify the system's network environment are collected	☐	☐
6.3.3.6	Ensure use of privileged commands are collected	☐	☐
6.3.3.7	Ensure unsuccessful file access attempts are collected	☐	☐
6.3.3.8	Ensure events that modify user/group information are collected	☐	☐
6.3.3.9	Ensure discretionary access control permission modification events are collected	☐	☐
6.3.3.10	Ensure successful file system mounts are collected	☐	☐
6.3.3.11	Ensure session initiation information is collected	☐	☐
6.3.3.12	Ensure login and logout events are collected	☐	☐
6.3.3.13	Ensure file deletion events by users are collected	☐	☐
6.3.3.14	Ensure events that modify the system's Mandatory Access Controls are collected	☐	☐

Recommendation		Set Correctly	
		Yes	No
6.3.3.15	Ensure successful and unsuccessful attempts to use the chcon command are collected	☐	☐
6.3.3.16	Ensure successful and unsuccessful attempts to use the setfacl command are collected	☐	☐
6.3.3.17	Ensure successful and unsuccessful attempts to use the chacl command are collected	☐	☐
6.3.3.18	Ensure successful and unsuccessful attempts to use the usermod command are collected	☐	☐
6.3.3.19	Ensure kernel module loading unloading and modification is collected	☐	☐
6.3.3.20	Ensure the audit configuration is loaded regardless of errors	☐	☐
6.3.3.21	Ensure the audit configuration is immutable	☐	☐
6.3.3.22	Ensure the running and on disk configuration is the same	☐	☐
6.3.4.1	Ensure the audit log file directory mode is configured	☐	☐
6.3.4.2	Ensure audit log files mode is configured	☐	☐
6.3.4.3	Ensure audit log files owner is configured	☐	☐
6.3.4.4	Ensure audit log files group owner is configured	☐	☐
6.3.4.5	Ensure audit configuration files mode is configured	☐	☐
6.3.4.6	Ensure audit configuration files owner is configured	☐	☐
6.3.4.7	Ensure audit configuration files group owner is configured	☐	☐
6.3.4.8	Ensure audit tools mode is configured	☐	☐
6.3.4.9	Ensure audit tools owner is configured	☐	☐
6.3.4.10	Ensure audit tools group owner is configured	☐	☐
7.1.1	Ensure access to /etc/passwd is configured	☐	☐
7.1.2	Ensure access to /etc/passwd- is configured	☐	☐
7.1.3	Ensure access to /etc/group is configured	☐	☐
7.1.4	Ensure access to /etc/group- is configured	☐	☐
7.1.5	Ensure access to /etc/shadow is configured	☐	☐
7.1.6	Ensure access to /etc/shadow- is configured	☐	☐
7.1.7	Ensure access to /etc/gshadow is configured	☐	☐
7.1.8	Ensure access to /etc/gshadow- is configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
7.1.9	Ensure access to /etc/shells is configured	☐	☐
7.1.10	Ensure access to /etc/security/opasswd is configured	☐	☐
7.1.11	Ensure world writable files and directories are secured	☐	☐
7.1.12	Ensure no files or directories without an owner and a group exist	☐	☐
7.1.13	Ensure SUID and SGID files are reviewed	☐	☐
7.2.1	Ensure accounts in /etc/passwd use shadowed passwords	☐	☐
7.2.2	Ensure /etc/shadow password fields are not empty	☐	☐
7.2.3	Ensure all groups in /etc/passwd exist in /etc/group	☐	☐
7.2.8	Ensure local interactive user home directories are configured	☐	☐
7.2.9	Ensure local interactive user dot files access is configured	☐	☐

Appendix: CIS Controls v7 Unmapped Recommendations

Recommendation		Set Correctly	
		Yes	No
2.4.1.7	Ensure access to /etc/cron.yearly is configured	☐	☐
5.3.1.1	Ensure latest version of pam is installed	☐	☐
5.3.1.2	Ensure latest version of authselect is installed	☐	☐
5.3.2.5	Ensure pam_unix module is enabled	☐	☐
6.3.2.3	Ensure system is disabled when audit logs are full	☐	☐
6.3.2.4	Ensure system warns when audit logs are low on space	☐	☐

Appendix: CIS Controls v8 IG 1 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1.1.10	Ensure usb-storage kernel module is not available	☐	☐
1.1.2.1.1	Ensure /tmp is tmpfs or a separate partition	☐	☐
1.1.2.1.2	Ensure nodev option set on /tmp partition	☐	☐
1.1.2.1.3	Ensure nosuid option set on /tmp partition	☐	☐
1.1.2.1.4	Ensure noexec option set on /tmp partition	☐	☐
1.1.2.2.1	Ensure /dev/shm is tmpfs	☐	☐
1.1.2.2.2	Ensure nodev option set on /dev/shm partition	☐	☐
1.1.2.2.3	Ensure nosuid option set on /dev/shm partition	☐	☐
1.1.2.2.4	Ensure noexec option set on /dev/shm partition	☐	☐
1.1.2.3.1	Ensure separate partition exists for /home	☐	☐
1.1.2.3.2	Ensure nodev option set on /home partition	☐	☐
1.1.2.3.3	Ensure nosuid option set on /home partition	☐	☐
1.1.2.4.1	Ensure separate partition exists for /var	☐	☐
1.1.2.4.2	Ensure nodev option set on /var partition	☐	☐
1.1.2.4.3	Ensure nosuid option set on /var partition	☐	☐
1.1.2.5.1	Ensure separate partition exists for /var/tmp	☐	☐
1.1.2.5.2	Ensure nodev option set on /var/tmp partition	☐	☐
1.1.2.5.3	Ensure nosuid option set on /var/tmp partition	☐	☐
1.1.2.5.4	Ensure noexec option set on /var/tmp partition	☐	☐
1.1.2.6.1	Ensure separate partition exists for /var/log	☐	☐
1.1.2.6.2	Ensure nodev option set on /var/log partition	☐	☐
1.1.2.6.3	Ensure nosuid option set on /var/log partition	☐	☐
1.1.2.6.4	Ensure noexec option set on /var/log partition	☐	☐
1.1.2.7.1	Ensure separate partition exists for /var/log/audit	☐	☐
1.1.2.7.2	Ensure nodev option set on /var/log/audit partition	☐	☐
1.1.2.7.3	Ensure nosuid option set on /var/log/audit partition	☐	☐
1.1.2.7.4	Ensure noexec option set on /var/log/audit partition	☐	☐

Recommendation		Set Correctly	
		Yes	No
1.2.1.1	Ensure GPG keys are configured	☐	☐
1.2.1.2	Ensure gpgcheck is configured	☐	☐
1.2.1.3	Ensure repo_gpgcheck is globally activated	☐	☐
1.2.1.4	Ensure package manager repositories are configured	☐	☐
1.2.2.1	Ensure updates, patches, and additional security software are installed	☐	☐
1.3.1.1	Ensure SELinux is installed	☐	☐
1.3.1.2	Ensure SELinux policy is configured	☐	☐
1.3.1.3	Ensure the SELinux mode is not disabled	☐	☐
1.3.1.4	Ensure no unconfined services exist	☐	☐
1.4.1	Ensure access to bootloader config is configured	☐	☐
1.5.5	Ensure kernel.dmesg_restrict is configured	☐	☐
1.7.4	Ensure access to /etc/motd is configured	☐	☐
1.7.5	Ensure access to /etc/issue is configured	☐	☐
1.7.6	Ensure access to /etc/issue.net is configured	☐	☐
1.8.2	Ensure GDM disable-user-list is configured	☐	☐
1.8.3	Ensure GDM screen lock is configured	☐	☐
1.8.4	Ensure GDM automount is configured	☐	☐
1.8.5	Ensure GDM autorun-never is configured	☐	☐
2.1.1	Ensure autofs services are not in use	☐	☐
2.4.1.2	Ensure access to /etc/crontab is configured	☐	☐
2.4.1.3	Ensure access to /etc/cron.hourly is configured	☐	☐
2.4.1.4	Ensure access to /etc/cron.daily is configured	☐	☐
2.4.1.5	Ensure access to /etc/cron.weekly is configured	☐	☐
2.4.1.6	Ensure access to /etc/cron.monthly is configured	☐	☐
2.4.1.8	Ensure access to /etc/cron.d is configured	☐	☐
2.4.1.9	Ensure access to crontab is configured	☐	☐
2.4.2.1	Ensure access to at is configured	☐	☐
4.1.1	Ensure firewalld is installed	☐	☐
4.1.2	Ensure firewalld backend is configured	☐	☐
4.1.3	Ensure firewalld.service is configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
4.1.4	Ensure firewalld active zone target is configured	☐	☐
4.1.5	Ensure firewalld loopback traffic is configured	☐	☐
4.1.6	Ensure firewalld loopback source address traffic is configured	☐	☐
4.1.7	Ensure firewalld services and ports are configured	☐	☐
5.1.2	Ensure access to /etc/ssh/sshd_config is configured	☐	☐
5.1.3	Ensure access to /etc/sysconfig/sshd is configured	☐	☐
5.1.4	Ensure access to SSH private host key files is configured	☐	☐
5.1.5	Ensure access to SSH public host key files is configured	☐	☐
5.1.6	Ensure sshd access is configured	☐	☐
5.1.11	Ensure sshd GSSAPIAuthentication is disabled	☐	☐
5.1.12	Ensure sshd HostbasedAuthentication is disabled	☐	☐
5.1.13	Ensure sshd IgnoreRhosts is enabled	☐	☐
5.1.16	Ensure sshd LogLevel is configured	☐	☐
5.1.21	Ensure sshd PermitEmptyPasswords is disabled	☐	☐
5.1.22	Ensure sshd PermitRootLogin is disabled	☐	☐
5.1.24	Ensure sshd UsePAM is enabled	☐	☐
5.2.1	Ensure sudo is installed	☐	☐
5.2.2	Ensure sudo commands use pty	☐	☐
5.2.4	Ensure users must provide password for escalation	☐	☐
5.2.5	Ensure re-authentication for privilege escalation is not disabled globally	☐	☐
5.2.6	Ensure sudo timestamp_timeout is configured	☐	☐
5.2.7	Ensure access to the su command is restricted	☐	☐
5.3.2.2	Ensure pam_faillock module is enabled	☐	☐
5.3.2.3	Ensure pam_pwquality module is enabled	☐	☐
5.3.2.4	Ensure pam_pwhistory module is enabled	☐	☐
5.3.3.1.1	Ensure password failed attempts lockout is configured	☐	☐
5.3.3.1.2	Ensure password unlock time is configured	☐	☐
5.3.3.1.3	Ensure password failed attempts lockout includes root account	☐	☐

Recommendation		Set Correctly	
		Yes	No
5.3.3.2.1	Ensure password number of changed characters is configured	☐	☐
5.3.3.2.2	Ensure password length is configured	☐	☐
5.3.3.2.3	Ensure password complexity is configured	☐	☐
5.3.3.2.4	Ensure password same consecutive characters is configured	☐	☐
5.3.3.2.5	Ensure password maximum sequential characters is configured	☐	☐
5.3.3.2.6	Ensure password dictionary check is enabled	☐	☐
5.3.3.2.7	Ensure password quality is enforced for the root user	☐	☐
5.3.3.3.1	Ensure password history remember is configured	☐	☐
5.3.3.3.2	Ensure password history is enforced for the root user	☐	☐
5.3.3.4.1	Ensure pam_unix does not include nullok	☐	☐
5.3.3.4.2	Ensure pam_unix does not include remember	☐	☐
5.4.1.1	Ensure password expiration is configured	☐	☐
5.4.1.2	Ensure minimum password days is configured	☐	☐
5.4.1.3	Ensure password expiration warning days is configured	☐	☐
5.4.1.5	Ensure inactive password lock is configured	☐	☐
5.4.1.6	Ensure all users last password change date is in the past	☐	☐
5.4.2.1	Ensure root is the only UID 0 account	☐	☐
5.4.2.2	Ensure root is the only GID 0 account	☐	☐
5.4.2.3	Ensure group root is the only GID 0 group	☐	☐
5.4.2.4	Ensure root account access is controlled	☐	☐
5.4.2.6	Ensure root user umask is configured	☐	☐
5.4.2.7	Ensure system accounts do not have a valid login shell	☐	☐
5.4.2.8	Ensure accounts without a valid login shell are locked	☐	☐
5.4.3.2	Ensure default user shell timeout is configured	☐	☐
5.4.3.3	Ensure default user umask is configured	☐	☐
6.2.1.1.1	Ensure journald service is active	☐	☐
6.2.1.1.2	Ensure journald log file access is configured	☐	☐
6.2.1.1.3	Ensure journald log file rotation is configured	☐	☐
6.2.1.1.4	Ensure journald ForwardToSyslog is disabled	☐	☐

Recommendation		Set Correctly	
		Yes	No
6.2.1.1.5	Ensure journald Storage is configured	☐	☐
6.2.1.1.6	Ensure journald Compress is configured	☐	☐
6.2.1.2.1	Ensure systemd-journal-remote is installed	☐	☐
6.2.1.2.2	Ensure systemd-journal-remote authentication is configured	☐	☐
6.2.1.2.3	Ensure systemd-journal-upload is enabled and active	☐	☐
6.2.2.1	Ensure rsyslog is installed	☐	☐
6.2.2.2	Ensure rsyslog service is enabled and active	☐	☐
6.2.2.3	Ensure journald is configured to send logs to rsyslog	☐	☐
6.2.2.4	Ensure rsyslog log file creation mode is configured	☐	☐
6.2.2.5	Ensure rsyslog logging is configured	☐	☐
6.2.2.6	Ensure rsyslog is configured to send logs to a remote log host	☐	☐
6.2.2.8	Ensure logrotate is configured	☐	☐
6.2.3.1	Ensure access to all logfiles has been configured	☐	☐
6.3.1.1	Ensure auditd packages are installed	☐	☐
6.3.1.2	Ensure auditing for processes that start prior to auditd is enabled	☐	☐
6.3.1.3	Ensure audit_backlog_limit is configured	☐	☐
6.3.1.4	Ensure auditd service is enabled and active	☐	☐
6.3.2.1	Ensure audit log storage size is configured	☐	☐
6.3.2.2	Ensure audit logs are not automatically deleted	☐	☐
6.3.2.3	Ensure system is disabled when audit logs are full	☐	☐
6.3.2.4	Ensure system warns when audit logs are low on space	☐	☐
6.3.3.15	Ensure successful and unsuccessful attempts to use the chcon command are collected	☐	☐
6.3.3.16	Ensure successful and unsuccessful attempts to use the setfacl command are collected	☐	☐
6.3.3.17	Ensure successful and unsuccessful attempts to use the chacl command are collected	☐	☐
6.3.3.18	Ensure successful and unsuccessful attempts to use the usermod command are collected	☐	☐
6.3.3.21	Ensure the audit configuration is immutable	☐	☐

Recommendation		Set Correctly	
		Yes	No
6.3.4.1	Ensure the audit log file directory mode is configured	☐	☐
6.3.4.2	Ensure audit log files mode is configured	☐	☐
6.3.4.3	Ensure audit log files owner is configured	☐	☐
6.3.4.4	Ensure audit log files group owner is configured	☐	☐
6.3.4.5	Ensure audit configuration files mode is configured	☐	☐
6.3.4.6	Ensure audit configuration files owner is configured	☐	☐
6.3.4.7	Ensure audit configuration files group owner is configured	☐	☐
6.3.4.8	Ensure audit tools mode is configured	☐	☐
6.3.4.9	Ensure audit tools owner is configured	☐	☐
6.3.4.10	Ensure audit tools group owner is configured	☐	☐
7.1.1	Ensure access to /etc/passwd is configured	☐	☐
7.1.2	Ensure access to /etc/passwd- is configured	☐	☐
7.1.3	Ensure access to /etc/group is configured	☐	☐
7.1.4	Ensure access to /etc/group- is configured	☐	☐
7.1.5	Ensure access to /etc/shadow is configured	☐	☐
7.1.6	Ensure access to /etc/shadow- is configured	☐	☐
7.1.7	Ensure access to /etc/gshadow is configured	☐	☐
7.1.8	Ensure access to /etc/gshadow- is configured	☐	☐
7.1.9	Ensure access to /etc/shells is configured	☐	☐
7.1.10	Ensure access to /etc/security/opasswd is configured	☐	☐
7.1.11	Ensure world writable files and directories are secured	☐	☐
7.1.12	Ensure no files or directories without an owner and a group exist	☐	☐
7.1.13	Ensure SUID and SGID files are reviewed	☐	☐
7.2.2	Ensure /etc/shadow password fields are not empty	☐	☐
7.2.3	Ensure all groups in /etc/passwd exist in /etc/group	☐	☐
7.2.8	Ensure local interactive user home directories are configured	☐	☐
7.2.9	Ensure local interactive user dot files access is configured	☐	☐

Appendix: CIS Controls v8 IG 2 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1.1.1	Ensure cramfs kernel module is not available	☐	☐
1.1.1.2	Ensure freevxfs kernel module is not available	☐	☐
1.1.1.3	Ensure hfs kernel module is not available	☐	☐
1.1.1.4	Ensure hfsplus kernel module is not available	☐	☐
1.1.1.5	Ensure jffs2 kernel module is not available	☐	☐
1.1.1.6	Ensure overlay kernel module is not available	☐	☐
1.1.1.7	Ensure squashfs kernel module is not available	☐	☐
1.1.1.8	Ensure udf kernel module is not available	☐	☐
1.1.1.9	Ensure firewire-core kernel module is not available	☐	☐
1.1.1.10	Ensure usb-storage kernel module is not available	☐	☐
1.1.1.11	Ensure unused filesystems kernel modules are not available	☐	☐
1.1.2.1.1	Ensure /tmp is tmpfs or a separate partition	☐	☐
1.1.2.1.2	Ensure nodev option set on /tmp partition	☐	☐
1.1.2.1.3	Ensure nosuid option set on /tmp partition	☐	☐
1.1.2.1.4	Ensure noexec option set on /tmp partition	☐	☐
1.1.2.2.1	Ensure /dev/shm is tmpfs	☐	☐
1.1.2.2.2	Ensure nodev option set on /dev/shm partition	☐	☐
1.1.2.2.3	Ensure nosuid option set on /dev/shm partition	☐	☐
1.1.2.2.4	Ensure noexec option set on /dev/shm partition	☐	☐
1.1.2.3.1	Ensure separate partition exists for /home	☐	☐
1.1.2.3.2	Ensure nodev option set on /home partition	☐	☐
1.1.2.3.3	Ensure nosuid option set on /home partition	☐	☐
1.1.2.4.1	Ensure separate partition exists for /var	☐	☐
1.1.2.4.2	Ensure nodev option set on /var partition	☐	☐
1.1.2.4.3	Ensure nosuid option set on /var partition	☐	☐
1.1.2.5.1	Ensure separate partition exists for /var/tmp	☐	☐

Recommendation		Set Correctly	
		Yes	No
1.1.2.5.2	Ensure nodev option set on /var/tmp partition	☐	☐
1.1.2.5.3	Ensure nosuid option set on /var/tmp partition	☐	☐
1.1.2.5.4	Ensure noexec option set on /var/tmp partition	☐	☐
1.1.2.6.1	Ensure separate partition exists for /var/log	☐	☐
1.1.2.6.2	Ensure nodev option set on /var/log partition	☐	☐
1.1.2.6.3	Ensure nosuid option set on /var/log partition	☐	☐
1.1.2.6.4	Ensure noexec option set on /var/log partition	☐	☐
1.1.2.7.1	Ensure separate partition exists for /var/log/audit	☐	☐
1.1.2.7.2	Ensure nodev option set on /var/log/audit partition	☐	☐
1.1.2.7.3	Ensure nosuid option set on /var/log/audit partition	☐	☐
1.1.2.7.4	Ensure noexec option set on /var/log/audit partition	☐	☐
1.2.1.1	Ensure GPG keys are configured	☐	☐
1.2.1.2	Ensure gpgcheck is configured	☐	☐
1.2.1.3	Ensure repo_gpgcheck is globally activated	☐	☐
1.2.1.4	Ensure package manager repositories are configured	☐	☐
1.2.1.5	Ensure weak dependencies are configured	☐	☐
1.2.2.1	Ensure updates, patches, and additional security software are installed	☐	☐
1.3.1.1	Ensure SELinux is installed	☐	☐
1.3.1.2	Ensure SELinux policy is configured	☐	☐
1.3.1.3	Ensure the SELinux mode is not disabled	☐	☐
1.3.1.4	Ensure no unconfined services exist	☐	☐
1.3.1.5	Ensure the MCS Translation Service (mcstrans) is not installed	☐	☐
1.3.1.6	Ensure SETroubleshoot is not installed	☐	☐
1.4.1	Ensure access to bootloader config is configured	☐	☐
1.5.5	Ensure kernel.dmesg_restrict is configured	☐	☐
1.5.7	Ensure kernel.randomize_va_space is configured	☐	☐
1.6.1	Ensure system wide crypto policy is not set to legacy	☐	☐
1.6.2	Ensure system wide crypto policy disables sha1 hash and signature support	☐	☐
1.6.3	Ensure system wide crypto policy macs are configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
1.6.4	Ensure system wide crypto policy disables cbc for ssh	☐	☐
1.6.5	Ensure system wide crypto policy disables chacha20-poly1305 for ssh	☐	☐
1.6.6	Ensure system wide crypto policy disables EtM for ssh	☐	☐
1.7.4	Ensure access to /etc/motd is configured	☐	☐
1.7.5	Ensure access to /etc/issue is configured	☐	☐
1.7.6	Ensure access to /etc/issue.net is configured	☐	☐
1.8.2	Ensure GDM disable-user-list is configured	☐	☐
1.8.3	Ensure GDM screen lock is configured	☐	☐
1.8.4	Ensure GDM automount is configured	☐	☐
1.8.5	Ensure GDM autorun-never is configured	☐	☐
1.8.6	Ensure XDMCP is not enabled	☐	☐
1.8.7	Ensure Xwayland is configured	☐	☐
2.1.1	Ensure autofs services are not in use	☐	☐
2.1.2	Ensure avahi daemon services are not in use	☐	☐
2.1.3	Ensure cockpit web services are not in use	☐	☐
2.1.4	Ensure dhcp server services are not in use	☐	☐
2.1.5	Ensure dns server services are not in use	☐	☐
2.1.6	Ensure dnsmasq services are not in use	☐	☐
2.1.7	Ensure ftp server services are not in use	☐	☐
2.1.8	Ensure message access server services are not in use	☐	☐
2.1.9	Ensure network file system services are not in use	☐	☐
2.1.10	Ensure nis server services are not in use	☐	☐
2.1.11	Ensure print server services are not in use	☐	☐
2.1.12	Ensure rpcbind services are not in use	☐	☐
2.1.13	Ensure rsync services are not in use	☐	☐
2.1.14	Ensure samba file server services are not in use	☐	☐
2.1.15	Ensure snmp services are not in use	☐	☐
2.1.16	Ensure telnet server services are not in use	☐	☐
2.1.17	Ensure tftp server services are not in use	☐	☐
2.1.18	Ensure web proxy server services are not in use	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.1.19	Ensure web server services are not in use	☐	☐
2.1.20	Ensure xinetd services are not in use	☐	☐
2.1.21	Ensure GNOME Display Manager is not installed	☐	☐
2.1.22	Ensure X window server services are not in use	☐	☐
2.1.23	Ensure mail transfer agents are configured for local-only mode	☐	☐
2.1.24	Ensure only approved services are listening on a network interface	☐	☐
2.2.1	Ensure ftp client is not installed	☐	☐
2.2.2	Ensure ldap client is not installed	☐	☐
2.2.3	Ensure nis client is not installed	☐	☐
2.2.4	Ensure telnet client is not installed	☐	☐
2.2.5	Ensure tftp client is not installed	☐	☐
2.3.1	Ensure time synchronization is in use	☐	☐
2.3.2	Ensure chrony is configured	☐	☐
2.4.1.2	Ensure access to /etc/crontab is configured	☐	☐
2.4.1.3	Ensure access to /etc/cron.hourly is configured	☐	☐
2.4.1.4	Ensure access to /etc/cron.daily is configured	☐	☐
2.4.1.5	Ensure access to /etc/cron.weekly is configured	☐	☐
2.4.1.6	Ensure access to /etc/cron.monthly is configured	☐	☐
2.4.1.8	Ensure access to /etc/cron.d is configured	☐	☐
2.4.1.9	Ensure access to crontab is configured	☐	☐
2.4.2.1	Ensure access to at is configured	☐	☐
3.1.1	Ensure IPv6 status is identified	☐	☐
3.1.2	Ensure wireless interfaces are not available	☐	☐
3.1.3	Ensure bluetooth services are not in use	☐	☐
3.2.1	Ensure atm kernel module is not available	☐	☐
3.2.2	Ensure can kernel module is not available	☐	☐
3.2.3	Ensure dccp kernel module is not available	☐	☐
3.2.4	Ensure rds kernel module is not available	☐	☐
3.2.5	Ensure sctp kernel module is not available	☐	☐
3.2.6	Ensure tipc kernel module is not available	☐	☐

Recommendation		Set Correctly	
		Yes	No
3.3.1.1	Ensure net.ipv4.ip_forward is configured	☐	☐
3.3.1.2	Ensure net.ipv4.conf.all.forwarding is configured	☐	☐
3.3.1.3	Ensure net.ipv4.conf.default.forwarding is configured	☐	☐
3.3.1.4	Ensure net.ipv4.conf.all.send_redirects is configured	☐	☐
3.3.1.5	Ensure net.ipv4.conf.default.send_redirects is configured	☐	☐
3.3.1.6	Ensure net.ipv4.icmp_ignore_bogus_error_responses is configured	☐	☐
3.3.1.7	Ensure net.ipv4.icmp_echo_ignore_broadcasts is configured	☐	☐
3.3.1.8	Ensure net.ipv4.conf.all.accept_redirects is configured	☐	☐
3.3.1.9	Ensure net.ipv4.conf.default.accept_redirects is configured	☐	☐
3.3.1.10	Ensure net.ipv4.conf.all.secure_redirects is configured	☐	☐
3.3.1.11	Ensure net.ipv4.conf.default.secure_redirects is configured	☐	☐
3.3.1.12	Ensure net.ipv4.conf.all.rp_filter is configured	☐	☐
3.3.1.13	Ensure net.ipv4.conf.default.rp_filter is configured	☐	☐
3.3.1.14	Ensure net.ipv4.conf.all.accept_source_route is configured	☐	☐
3.3.1.15	Ensure net.ipv4.conf.default.accept_source_route is configured	☐	☐
3.3.1.16	Ensure net.ipv4.conf.all.log_martians is configured	☐	☐
3.3.1.17	Ensure net.ipv4.conf.default.log_martians is configured	☐	☐
3.3.1.18	Ensure net.ipv4.tcp_syncookies is configured	☐	☐
3.3.2.1	Ensure net.ipv6.conf.all.forwarding is configured	☐	☐
3.3.2.2	Ensure net.ipv6.conf.default.forwarding is configured	☐	☐
3.3.2.3	Ensure net.ipv6.conf.all.accept_redirects is configured	☐	☐
3.3.2.4	Ensure net.ipv6.conf.default.accept_redirects is configured	☐	☐
3.3.2.5	Ensure net.ipv6.conf.all.accept_source_route is configured	☐	☐
3.3.2.6	Ensure net.ipv6.conf.default.accept_source_route is configured	☐	☐
3.3.2.7	Ensure net.ipv6.conf.all.accept_ra is configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
3.3.2.8	Ensure net.ipv6.conf.default.accept_ra is configured	☐	☐
4.1.1	Ensure firewalld is installed	☐	☐
4.1.2	Ensure firewalld backend is configured	☐	☐
4.1.3	Ensure firewalld.service is configured	☐	☐
4.1.4	Ensure firewalld active zone target is configured	☐	☐
4.1.5	Ensure firewalld loopback traffic is configured	☐	☐
4.1.6	Ensure firewalld loopback source address traffic is configured	☐	☐
4.1.7	Ensure firewalld services and ports are configured	☐	☐
5.1.1	Ensure sshd crypto_policy is not set	☐	☐
5.1.2	Ensure access to /etc/ssh/sshd_config is configured	☐	☐
5.1.3	Ensure access to /etc/sysconfig/sshd is configured	☐	☐
5.1.4	Ensure access to SSH private host key files is configured	☐	☐
5.1.5	Ensure access to SSH public host key files is configured	☐	☐
5.1.6	Ensure sshd access is configured	☐	☐
5.1.8	Ensure sshd Ciphers are configured	☐	☐
5.1.10	Ensure sshd DisableForwarding is enabled	☐	☐
5.1.11	Ensure sshd GSSAPIAuthentication is disabled	☐	☐
5.1.12	Ensure sshd HostbasedAuthentication is disabled	☐	☐
5.1.13	Ensure sshd IgnoreRhosts is enabled	☐	☐
5.1.14	Ensure sshd KexAlgorithms is configured	☐	☐
5.1.16	Ensure sshd LogLevel is configured	☐	☐
5.1.17	Ensure sshd MACs are configured	☐	☐
5.1.18	Ensure sshd MaxAuthTries is configured	☐	☐
5.1.21	Ensure sshd PermitEmptyPasswords is disabled	☐	☐
5.1.22	Ensure sshd PermitRootLogin is disabled	☐	☐
5.1.24	Ensure sshd UsePAM is enabled	☐	☐
5.2.1	Ensure sudo is installed	☐	☐
5.2.2	Ensure sudo commands use pty	☐	☐
5.2.3	Ensure sudo log file exists	☐	☐
5.2.4	Ensure users must provide password for escalation	☐	☐

Recommendation		Set Correctly	
		Yes	No
5.2.5	Ensure re-authentication for privilege escalation is not disabled globally	☐	☐
5.2.6	Ensure sudo timestamp_timeout is configured	☐	☐
5.2.7	Ensure access to the su command is restricted	☐	☐
5.3.2.1	Ensure active authselect profile includes pam modules	☐	☐
5.3.2.2	Ensure pam_faillock module is enabled	☐	☐
5.3.2.3	Ensure pam_pwquality module is enabled	☐	☐
5.3.2.4	Ensure pam_pwhistory module is enabled	☐	☐
5.3.3.1.1	Ensure password failed attempts lockout is configured	☐	☐
5.3.3.1.2	Ensure password unlock time is configured	☐	☐
5.3.3.1.3	Ensure password failed attempts lockout includes root account	☐	☐
5.3.3.2.1	Ensure password number of changed characters is configured	☐	☐
5.3.3.2.2	Ensure password length is configured	☐	☐
5.3.3.2.3	Ensure password complexity is configured	☐	☐
5.3.3.2.4	Ensure password same consecutive characters is configured	☐	☐
5.3.3.2.5	Ensure password maximum sequential characters is configured	☐	☐
5.3.3.2.6	Ensure password dictionary check is enabled	☐	☐
5.3.3.2.7	Ensure password quality is enforced for the root user	☐	☐
5.3.3.3.1	Ensure password history remember is configured	☐	☐
5.3.3.3.2	Ensure password history is enforced for the root user	☐	☐
5.3.3.3.3	Ensure pam_pwhistory includes use_authtok	☐	☐
5.3.3.4.1	Ensure pam_unix does not include nullok	☐	☐
5.3.3.4.2	Ensure pam_unix does not include remember	☐	☐
5.3.3.4.3	Ensure pam_unix includes a strong password hashing algorithm	☐	☐
5.3.3.4.4	Ensure pam_unix includes use_authtok	☐	☐
5.4.1.1	Ensure password expiration is configured	☐	☐
5.4.1.2	Ensure minimum password days is configured	☐	☐
5.4.1.3	Ensure password expiration warning days is configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
5.4.1.4	Ensure strong password hashing algorithm is configured	☐	☐
5.4.1.5	Ensure inactive password lock is configured	☐	☐
5.4.1.6	Ensure all users last password change date is in the past	☐	☐
5.4.2.1	Ensure root is the only UID 0 account	☐	☐
5.4.2.2	Ensure root is the only GID 0 account	☐	☐
5.4.2.3	Ensure group root is the only GID 0 group	☐	☐
5.4.2.4	Ensure root account access is controlled	☐	☐
5.4.2.6	Ensure root user umask is configured	☐	☐
5.4.2.7	Ensure system accounts do not have a valid login shell	☐	☐
5.4.2.8	Ensure accounts without a valid login shell are locked	☐	☐
5.4.3.2	Ensure default user shell timeout is configured	☐	☐
5.4.3.3	Ensure default user umask is configured	☐	☐
6.2.1.1.1	Ensure journald service is active	☐	☐
6.2.1.1.2	Ensure journald log file access is configured	☐	☐
6.2.1.1.3	Ensure journald log file rotation is configured	☐	☐
6.2.1.1.4	Ensure journald ForwardToSyslog is disabled	☐	☐
6.2.1.1.5	Ensure journald Storage is configured	☐	☐
6.2.1.1.6	Ensure journald Compress is configured	☐	☐
6.2.1.2.1	Ensure systemd-journal-remote is installed	☐	☐
6.2.1.2.2	Ensure systemd-journal-remote authentication is configured	☐	☐
6.2.1.2.3	Ensure systemd-journal-upload is enabled and active	☐	☐
6.2.1.2.4	Ensure systemd-journal-remote service is not in use	☐	☐
6.2.2.1	Ensure rsyslog is installed	☐	☐
6.2.2.2	Ensure rsyslog service is enabled and active	☐	☐
6.2.2.3	Ensure journald is configured to send logs to rsyslog	☐	☐
6.2.2.4	Ensure rsyslog log file creation mode is configured	☐	☐
6.2.2.5	Ensure rsyslog logging is configured	☐	☐
6.2.2.6	Ensure rsyslog is configured to send logs to a remote log host	☐	☐
6.2.2.7	Ensure rsyslog is not configured to receive logs from a remote client	☐	☐

Recommendation		Set Correctly	
		Yes	No
6.2.2.8	Ensure logrotate is configured	☐	☐
6.2.3.1	Ensure access to all logfiles has been configured	☐	☐
6.3.1.1	Ensure auditd packages are installed	☐	☐
6.3.1.2	Ensure auditing for processes that start prior to auditd is enabled	☐	☐
6.3.1.3	Ensure audit_backlog_limit is configured	☐	☐
6.3.1.4	Ensure auditd service is enabled and active	☐	☐
6.3.2.1	Ensure audit log storage size is configured	☐	☐
6.3.2.2	Ensure audit logs are not automatically deleted	☐	☐
6.3.2.3	Ensure system is disabled when audit logs are full	☐	☐
6.3.2.4	Ensure system warns when audit logs are low on space	☐	☐
6.3.3.1	Ensure changes to system administration scope (sudoers) is collected	☐	☐
6.3.3.2	Ensure actions as another user are always logged	☐	☐
6.3.3.3	Ensure events that modify the sudo log file are collected	☐	☐
6.3.3.4	Ensure events that modify date and time information are collected	☐	☐
6.3.3.5	Ensure events that modify the system's network environment are collected	☐	☐
6.3.3.6	Ensure use of privileged commands are collected	☐	☐
6.3.3.7	Ensure unsuccessful file access attempts are collected	☐	☐
6.3.3.8	Ensure events that modify user/group information are collected	☐	☐
6.3.3.9	Ensure discretionary access control permission modification events are collected	☐	☐
6.3.3.10	Ensure successful file system mounts are collected	☐	☐
6.3.3.11	Ensure session initiation information is collected	☐	☐
6.3.3.12	Ensure login and logout events are collected	☐	☐
6.3.3.13	Ensure file deletion events by users are collected	☐	☐
6.3.3.14	Ensure events that modify the system's Mandatory Access Controls are collected	☐	☐
6.3.3.15	Ensure successful and unsuccessful attempts to use the chcon command are collected	☐	☐

Recommendation		Set Correctly	
		Yes	No
6.3.3.16	Ensure successful and unsuccessful attempts to use the setfacl command are collected	☐	☐
6.3.3.17	Ensure successful and unsuccessful attempts to use the chacl command are collected	☐	☐
6.3.3.18	Ensure successful and unsuccessful attempts to use the usermod command are collected	☐	☐
6.3.3.19	Ensure kernel module loading unloading and modification is collected	☐	☐
6.3.3.20	Ensure the audit configuration is loaded regardless of errors	☐	☐
6.3.3.21	Ensure the audit configuration is immutable	☐	☐
6.3.3.22	Ensure the running and on disk configuration is the same	☐	☐
6.3.4.1	Ensure the audit log file directory mode is configured	☐	☐
6.3.4.2	Ensure audit log files mode is configured	☐	☐
6.3.4.3	Ensure audit log files owner is configured	☐	☐
6.3.4.4	Ensure audit log files group owner is configured	☐	☐
6.3.4.5	Ensure audit configuration files mode is configured	☐	☐
6.3.4.6	Ensure audit configuration files owner is configured	☐	☐
6.3.4.7	Ensure audit configuration files group owner is configured	☐	☐
6.3.4.8	Ensure audit tools mode is configured	☐	☐
6.3.4.9	Ensure audit tools owner is configured	☐	☐
6.3.4.10	Ensure audit tools group owner is configured	☐	☐
7.1.1	Ensure access to /etc/passwd is configured	☐	☐
7.1.2	Ensure access to /etc/passwd- is configured	☐	☐
7.1.3	Ensure access to /etc/group is configured	☐	☐
7.1.4	Ensure access to /etc/group- is configured	☐	☐
7.1.5	Ensure access to /etc/shadow is configured	☐	☐
7.1.6	Ensure access to /etc/shadow- is configured	☐	☐
7.1.7	Ensure access to /etc/gshadow is configured	☐	☐
7.1.8	Ensure access to /etc/gshadow- is configured	☐	☐
7.1.9	Ensure access to /etc/shells is configured	☐	☐
7.1.10	Ensure access to /etc/security/opasswd is configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
7.1.11	Ensure world writable files and directories are secured	☐	☐
7.1.12	Ensure no files or directories without an owner and a group exist	☐	☐
7.1.13	Ensure SUID and SGID files are reviewed	☐	☐
7.2.1	Ensure accounts in /etc/passwd use shadowed passwords	☐	☐
7.2.2	Ensure /etc/shadow password fields are not empty	☐	☐
7.2.3	Ensure all groups in /etc/passwd exist in /etc/group	☐	☐
7.2.8	Ensure local interactive user home directories are configured	☐	☐
7.2.9	Ensure local interactive user dot files access is configured	☐	☐

Appendix: CIS Controls v8 IG 3 Mapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.1.1.1	Ensure cramfs kernel module is not available	☐	☐
1.1.1.2	Ensure freevxfs kernel module is not available	☐	☐
1.1.1.3	Ensure hfs kernel module is not available	☐	☐
1.1.1.4	Ensure hfsplus kernel module is not available	☐	☐
1.1.1.5	Ensure jffs2 kernel module is not available	☐	☐
1.1.1.6	Ensure overlay kernel module is not available	☐	☐
1.1.1.7	Ensure squashfs kernel module is not available	☐	☐
1.1.1.8	Ensure udf kernel module is not available	☐	☐
1.1.1.9	Ensure firewire-core kernel module is not available	☐	☐
1.1.1.10	Ensure usb-storage kernel module is not available	☐	☐
1.1.1.11	Ensure unused filesystems kernel modules are not available	☐	☐
1.1.2.1.1	Ensure /tmp is tmpfs or a separate partition	☐	☐
1.1.2.1.2	Ensure nodev option set on /tmp partition	☐	☐
1.1.2.1.3	Ensure nosuid option set on /tmp partition	☐	☐
1.1.2.1.4	Ensure noexec option set on /tmp partition	☐	☐
1.1.2.2.1	Ensure /dev/shm is tmpfs	☐	☐
1.1.2.2.2	Ensure nodev option set on /dev/shm partition	☐	☐
1.1.2.2.3	Ensure nosuid option set on /dev/shm partition	☐	☐
1.1.2.2.4	Ensure noexec option set on /dev/shm partition	☐	☐
1.1.2.3.1	Ensure separate partition exists for /home	☐	☐
1.1.2.3.2	Ensure nodev option set on /home partition	☐	☐
1.1.2.3.3	Ensure nosuid option set on /home partition	☐	☐
1.1.2.4.1	Ensure separate partition exists for /var	☐	☐
1.1.2.4.2	Ensure nodev option set on /var partition	☐	☐
1.1.2.4.3	Ensure nosuid option set on /var partition	☐	☐
1.1.2.5.1	Ensure separate partition exists for /var/tmp	☐	☐

Recommendation		Set Correctly	
		Yes	No
1.1.2.5.2	Ensure nodev option set on /var/tmp partition	☐	☐
1.1.2.5.3	Ensure nosuid option set on /var/tmp partition	☐	☐
1.1.2.5.4	Ensure noexec option set on /var/tmp partition	☐	☐
1.1.2.6.1	Ensure separate partition exists for /var/log	☐	☐
1.1.2.6.2	Ensure nodev option set on /var/log partition	☐	☐
1.1.2.6.3	Ensure nosuid option set on /var/log partition	☐	☐
1.1.2.6.4	Ensure noexec option set on /var/log partition	☐	☐
1.1.2.7.1	Ensure separate partition exists for /var/log/audit	☐	☐
1.1.2.7.2	Ensure nodev option set on /var/log/audit partition	☐	☐
1.1.2.7.3	Ensure nosuid option set on /var/log/audit partition	☐	☐
1.1.2.7.4	Ensure noexec option set on /var/log/audit partition	☐	☐
1.2.1.1	Ensure GPG keys are configured	☐	☐
1.2.1.2	Ensure gpgcheck is configured	☐	☐
1.2.1.3	Ensure repo_gpgcheck is globally activated	☐	☐
1.2.1.4	Ensure package manager repositories are configured	☐	☐
1.2.1.5	Ensure weak dependencies are configured	☐	☐
1.2.2.1	Ensure updates, patches, and additional security software are installed	☐	☐
1.3.1.1	Ensure SELinux is installed	☐	☐
1.3.1.2	Ensure SELinux policy is configured	☐	☐
1.3.1.3	Ensure the SELinux mode is not disabled	☐	☐
1.3.1.4	Ensure no unconfined services exist	☐	☐
1.3.1.5	Ensure the MCS Translation Service (mcstrans) is not installed	☐	☐
1.3.1.6	Ensure SETroubleshoot is not installed	☐	☐
1.4.1	Ensure access to bootloader config is configured	☐	☐
1.5.5	Ensure kernel.dmesg_restrict is configured	☐	☐
1.5.7	Ensure kernel.randomize_va_space is configured	☐	☐
1.6.1	Ensure system wide crypto policy is not set to legacy	☐	☐
1.6.2	Ensure system wide crypto policy disables sha1 hash and signature support	☐	☐
1.6.3	Ensure system wide crypto policy macs are configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
1.6.4	Ensure system wide crypto policy disables cbc for ssh	☐	☐
1.6.5	Ensure system wide crypto policy disables chacha20-poly1305 for ssh	☐	☐
1.6.6	Ensure system wide crypto policy disables EtM for ssh	☐	☐
1.7.4	Ensure access to /etc/motd is configured	☐	☐
1.7.5	Ensure access to /etc/issue is configured	☐	☐
1.7.6	Ensure access to /etc/issue.net is configured	☐	☐
1.8.2	Ensure GDM disable-user-list is configured	☐	☐
1.8.3	Ensure GDM screen lock is configured	☐	☐
1.8.4	Ensure GDM automount is configured	☐	☐
1.8.5	Ensure GDM autorun-never is configured	☐	☐
1.8.6	Ensure XDMCP is not enabled	☐	☐
1.8.7	Ensure Xwayland is configured	☐	☐
2.1.1	Ensure autofs services are not in use	☐	☐
2.1.2	Ensure avahi daemon services are not in use	☐	☐
2.1.3	Ensure cockpit web services are not in use	☐	☐
2.1.4	Ensure dhcp server services are not in use	☐	☐
2.1.5	Ensure dns server services are not in use	☐	☐
2.1.6	Ensure dnsmasq services are not in use	☐	☐
2.1.7	Ensure ftp server services are not in use	☐	☐
2.1.8	Ensure message access server services are not in use	☐	☐
2.1.9	Ensure network file system services are not in use	☐	☐
2.1.10	Ensure nis server services are not in use	☐	☐
2.1.11	Ensure print server services are not in use	☐	☐
2.1.12	Ensure rpcbind services are not in use	☐	☐
2.1.13	Ensure rsync services are not in use	☐	☐
2.1.14	Ensure samba file server services are not in use	☐	☐
2.1.15	Ensure snmp services are not in use	☐	☐
2.1.16	Ensure telnet server services are not in use	☐	☐
2.1.17	Ensure tftp server services are not in use	☐	☐
2.1.18	Ensure web proxy server services are not in use	☐	☐

Recommendation		Set Correctly	
		Yes	No
2.1.19	Ensure web server services are not in use	☐	☐
2.1.20	Ensure xinetd services are not in use	☐	☐
2.1.21	Ensure GNOME Display Manager is not installed	☐	☐
2.1.22	Ensure X window server services are not in use	☐	☐
2.1.23	Ensure mail transfer agents are configured for local-only mode	☐	☐
2.1.24	Ensure only approved services are listening on a network interface	☐	☐
2.2.1	Ensure ftp client is not installed	☐	☐
2.2.2	Ensure ldap client is not installed	☐	☐
2.2.3	Ensure nis client is not installed	☐	☐
2.2.4	Ensure telnet client is not installed	☐	☐
2.2.5	Ensure tftp client is not installed	☐	☐
2.3.1	Ensure time synchronization is in use	☐	☐
2.3.2	Ensure chrony is configured	☐	☐
2.4.1.2	Ensure access to /etc/crontab is configured	☐	☐
2.4.1.3	Ensure access to /etc/cron.hourly is configured	☐	☐
2.4.1.4	Ensure access to /etc/cron.daily is configured	☐	☐
2.4.1.5	Ensure access to /etc/cron.weekly is configured	☐	☐
2.4.1.6	Ensure access to /etc/cron.monthly is configured	☐	☐
2.4.1.8	Ensure access to /etc/cron.d is configured	☐	☐
2.4.1.9	Ensure access to crontab is configured	☐	☐
2.4.2.1	Ensure access to at is configured	☐	☐
3.1.1	Ensure IPv6 status is identified	☐	☐
3.1.2	Ensure wireless interfaces are not available	☐	☐
3.1.3	Ensure bluetooth services are not in use	☐	☐
3.2.1	Ensure atm kernel module is not available	☐	☐
3.2.2	Ensure can kernel module is not available	☐	☐
3.2.3	Ensure dccp kernel module is not available	☐	☐
3.2.4	Ensure rds kernel module is not available	☐	☐
3.2.5	Ensure sctp kernel module is not available	☐	☐
3.2.6	Ensure tipc kernel module is not available	☐	☐

Recommendation		Set Correctly	
		Yes	No
3.3.1.1	Ensure net.ipv4.ip_forward is configured	☐	☐
3.3.1.2	Ensure net.ipv4.conf.all.forwarding is configured	☐	☐
3.3.1.3	Ensure net.ipv4.conf.default.forwarding is configured	☐	☐
3.3.1.4	Ensure net.ipv4.conf.all.send_redirects is configured	☐	☐
3.3.1.5	Ensure net.ipv4.conf.default.send_redirects is configured	☐	☐
3.3.1.6	Ensure net.ipv4.icmp_ignore_bogus_error_responses is configured	☐	☐
3.3.1.7	Ensure net.ipv4.icmp_echo_ignore_broadcasts is configured	☐	☐
3.3.1.8	Ensure net.ipv4.conf.all.accept_redirects is configured	☐	☐
3.3.1.9	Ensure net.ipv4.conf.default.accept_redirects is configured	☐	☐
3.3.1.10	Ensure net.ipv4.conf.all.secure_redirects is configured	☐	☐
3.3.1.11	Ensure net.ipv4.conf.default.secure_redirects is configured	☐	☐
3.3.1.12	Ensure net.ipv4.conf.all.rp_filter is configured	☐	☐
3.3.1.13	Ensure net.ipv4.conf.default.rp_filter is configured	☐	☐
3.3.1.14	Ensure net.ipv4.conf.all.accept_source_route is configured	☐	☐
3.3.1.15	Ensure net.ipv4.conf.default.accept_source_route is configured	☐	☐
3.3.1.16	Ensure net.ipv4.conf.all.log_martians is configured	☐	☐
3.3.1.17	Ensure net.ipv4.conf.default.log_martians is configured	☐	☐
3.3.1.18	Ensure net.ipv4.tcp_syncookies is configured	☐	☐
3.3.2.1	Ensure net.ipv6.conf.all.forwarding is configured	☐	☐
3.3.2.2	Ensure net.ipv6.conf.default.forwarding is configured	☐	☐
3.3.2.3	Ensure net.ipv6.conf.all.accept_redirects is configured	☐	☐
3.3.2.4	Ensure net.ipv6.conf.default.accept_redirects is configured	☐	☐
3.3.2.5	Ensure net.ipv6.conf.all.accept_source_route is configured	☐	☐
3.3.2.6	Ensure net.ipv6.conf.default.accept_source_route is configured	☐	☐
3.3.2.7	Ensure net.ipv6.conf.all.accept_ra is configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
3.3.2.8	Ensure net.ipv6.conf.default.accept_ra is configured	☐	☐
4.1.1	Ensure firewalld is installed	☐	☐
4.1.2	Ensure firewalld backend is configured	☐	☐
4.1.3	Ensure firewalld.service is configured	☐	☐
4.1.4	Ensure firewalld active zone target is configured	☐	☐
4.1.5	Ensure firewalld loopback traffic is configured	☐	☐
4.1.6	Ensure firewalld loopback source address traffic is configured	☐	☐
4.1.7	Ensure firewalld services and ports are configured	☐	☐
5.1.1	Ensure sshd crypto_policy is not set	☐	☐
5.1.2	Ensure access to /etc/ssh/sshd_config is configured	☐	☐
5.1.3	Ensure access to /etc/sysconfig/sshd is configured	☐	☐
5.1.4	Ensure access to SSH private host key files is configured	☐	☐
5.1.5	Ensure access to SSH public host key files is configured	☐	☐
5.1.6	Ensure sshd access is configured	☐	☐
5.1.8	Ensure sshd Ciphers are configured	☐	☐
5.1.10	Ensure sshd DisableForwarding is enabled	☐	☐
5.1.11	Ensure sshd GSSAPIAuthentication is disabled	☐	☐
5.1.12	Ensure sshd HostbasedAuthentication is disabled	☐	☐
5.1.13	Ensure sshd IgnoreRhosts is enabled	☐	☐
5.1.14	Ensure sshd KexAlgorithms is configured	☐	☐
5.1.16	Ensure sshd LogLevel is configured	☐	☐
5.1.17	Ensure sshd MACs are configured	☐	☐
5.1.18	Ensure sshd MaxAuthTries is configured	☐	☐
5.1.21	Ensure sshd PermitEmptyPasswords is disabled	☐	☐
5.1.22	Ensure sshd PermitRootLogin is disabled	☐	☐
5.1.24	Ensure sshd UsePAM is enabled	☐	☐
5.2.1	Ensure sudo is installed	☐	☐
5.2.2	Ensure sudo commands use pty	☐	☐
5.2.3	Ensure sudo log file exists	☐	☐
5.2.4	Ensure users must provide password for escalation	☐	☐

Recommendation		Set Correctly	
		Yes	No
5.2.5	Ensure re-authentication for privilege escalation is not disabled globally	☐	☐
5.2.6	Ensure sudo timestamp_timeout is configured	☐	☐
5.2.7	Ensure access to the su command is restricted	☐	☐
5.3.2.1	Ensure active authselect profile includes pam modules	☐	☐
5.3.2.2	Ensure pam_faillock module is enabled	☐	☐
5.3.2.3	Ensure pam_pwquality module is enabled	☐	☐
5.3.2.4	Ensure pam_pwhistory module is enabled	☐	☐
5.3.3.1.1	Ensure password failed attempts lockout is configured	☐	☐
5.3.3.1.2	Ensure password unlock time is configured	☐	☐
5.3.3.1.3	Ensure password failed attempts lockout includes root account	☐	☐
5.3.3.2.1	Ensure password number of changed characters is configured	☐	☐
5.3.3.2.2	Ensure password length is configured	☐	☐
5.3.3.2.3	Ensure password complexity is configured	☐	☐
5.3.3.2.4	Ensure password same consecutive characters is configured	☐	☐
5.3.3.2.5	Ensure password maximum sequential characters is configured	☐	☐
5.3.3.2.6	Ensure password dictionary check is enabled	☐	☐
5.3.3.2.7	Ensure password quality is enforced for the root user	☐	☐
5.3.3.3.1	Ensure password history remember is configured	☐	☐
5.3.3.3.2	Ensure password history is enforced for the root user	☐	☐
5.3.3.3.3	Ensure pam_pwhistory includes use_authtok	☐	☐
5.3.3.4.1	Ensure pam_unix does not include nullok	☐	☐
5.3.3.4.2	Ensure pam_unix does not include remember	☐	☐
5.3.3.4.3	Ensure pam_unix includes a strong password hashing algorithm	☐	☐
5.3.3.4.4	Ensure pam_unix includes use_authtok	☐	☐
5.4.1.1	Ensure password expiration is configured	☐	☐
5.4.1.2	Ensure minimum password days is configured	☐	☐
5.4.1.3	Ensure password expiration warning days is configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
5.4.1.4	Ensure strong password hashing algorithm is configured	☐	☐
5.4.1.5	Ensure inactive password lock is configured	☐	☐
5.4.1.6	Ensure all users last password change date is in the past	☐	☐
5.4.2.1	Ensure root is the only UID 0 account	☐	☐
5.4.2.2	Ensure root is the only GID 0 account	☐	☐
5.4.2.3	Ensure group root is the only GID 0 group	☐	☐
5.4.2.4	Ensure root account access is controlled	☐	☐
5.4.2.6	Ensure root user umask is configured	☐	☐
5.4.2.7	Ensure system accounts do not have a valid login shell	☐	☐
5.4.2.8	Ensure accounts without a valid login shell are locked	☐	☐
5.4.3.2	Ensure default user shell timeout is configured	☐	☐
5.4.3.3	Ensure default user umask is configured	☐	☐
6.1.1	Ensure AIDE is installed	☐	☐
6.1.2	Ensure filesystem integrity is regularly checked	☐	☐
6.2.1.1.1	Ensure journald service is active	☐	☐
6.2.1.1.2	Ensure journald log file access is configured	☐	☐
6.2.1.1.3	Ensure journald log file rotation is configured	☐	☐
6.2.1.1.4	Ensure journald ForwardToSyslog is disabled	☐	☐
6.2.1.1.5	Ensure journald Storage is configured	☐	☐
6.2.1.1.6	Ensure journald Compress is configured	☐	☐
6.2.1.2.1	Ensure systemd-journal-remote is installed	☐	☐
6.2.1.2.2	Ensure systemd-journal-remote authentication is configured	☐	☐
6.2.1.2.3	Ensure systemd-journal-upload is enabled and active	☐	☐
6.2.1.2.4	Ensure systemd-journal-remote service is not in use	☐	☐
6.2.2.1	Ensure rsyslog is installed	☐	☐
6.2.2.2	Ensure rsyslog service is enabled and active	☐	☐
6.2.2.3	Ensure journald is configured to send logs to rsyslog	☐	☐
6.2.2.4	Ensure rsyslog log file creation mode is configured	☐	☐
6.2.2.5	Ensure rsyslog logging is configured	☐	☐
6.2.2.6	Ensure rsyslog is configured to send logs to a remote log host	☐	☐

Recommendation		Set Correctly	
		Yes	No
6.2.2.7	Ensure rsyslog is not configured to receive logs from a remote client	☐	☐
6.2.2.8	Ensure logrotate is configured	☐	☐
6.2.3.1	Ensure access to all logfiles has been configured	☐	☐
6.3.1.1	Ensure auditd packages are installed	☐	☐
6.3.1.2	Ensure auditing for processes that start prior to auditd is enabled	☐	☐
6.3.1.3	Ensure audit_backlog_limit is configured	☐	☐
6.3.1.4	Ensure auditd service is enabled and active	☐	☐
6.3.2.1	Ensure audit log storage size is configured	☐	☐
6.3.2.2	Ensure audit logs are not automatically deleted	☐	☐
6.3.2.3	Ensure system is disabled when audit logs are full	☐	☐
6.3.2.4	Ensure system warns when audit logs are low on space	☐	☐
6.3.3.1	Ensure changes to system administration scope (sudoers) is collected	☐	☐
6.3.3.2	Ensure actions as another user are always logged	☐	☐
6.3.3.3	Ensure events that modify the sudo log file are collected	☐	☐
6.3.3.4	Ensure events that modify date and time information are collected	☐	☐
6.3.3.5	Ensure events that modify the system's network environment are collected	☐	☐
6.3.3.6	Ensure use of privileged commands are collected	☐	☐
6.3.3.7	Ensure unsuccessful file access attempts are collected	☐	☐
6.3.3.8	Ensure events that modify user/group information are collected	☐	☐
6.3.3.9	Ensure discretionary access control permission modification events are collected	☐	☐
6.3.3.10	Ensure successful file system mounts are collected	☐	☐
6.3.3.11	Ensure session initiation information is collected	☐	☐
6.3.3.12	Ensure login and logout events are collected	☐	☐
6.3.3.13	Ensure file deletion events by users are collected	☐	☐
6.3.3.14	Ensure events that modify the system's Mandatory Access Controls are collected	☐	☐

Recommendation		Set Correctly	
		Yes	No
6.3.3.15	Ensure successful and unsuccessful attempts to use the chcon command are collected	☐	☐
6.3.3.16	Ensure successful and unsuccessful attempts to use the setfacl command are collected	☐	☐
6.3.3.17	Ensure successful and unsuccessful attempts to use the chacl command are collected	☐	☐
6.3.3.18	Ensure successful and unsuccessful attempts to use the usermod command are collected	☐	☐
6.3.3.19	Ensure kernel module loading unloading and modification is collected	☐	☐
6.3.3.20	Ensure the audit configuration is loaded regardless of errors	☐	☐
6.3.3.21	Ensure the audit configuration is immutable	☐	☐
6.3.3.22	Ensure the running and on disk configuration is the same	☐	☐
6.3.4.1	Ensure the audit log file directory mode is configured	☐	☐
6.3.4.2	Ensure audit log files mode is configured	☐	☐
6.3.4.3	Ensure audit log files owner is configured	☐	☐
6.3.4.4	Ensure audit log files group owner is configured	☐	☐
6.3.4.5	Ensure audit configuration files mode is configured	☐	☐
6.3.4.6	Ensure audit configuration files owner is configured	☐	☐
6.3.4.7	Ensure audit configuration files group owner is configured	☐	☐
6.3.4.8	Ensure audit tools mode is configured	☐	☐
6.3.4.9	Ensure audit tools owner is configured	☐	☐
6.3.4.10	Ensure audit tools group owner is configured	☐	☐
7.1.1	Ensure access to /etc/passwd is configured	☐	☐
7.1.2	Ensure access to /etc/passwd- is configured	☐	☐
7.1.3	Ensure access to /etc/group is configured	☐	☐
7.1.4	Ensure access to /etc/group- is configured	☐	☐
7.1.5	Ensure access to /etc/shadow is configured	☐	☐
7.1.6	Ensure access to /etc/shadow- is configured	☐	☐
7.1.7	Ensure access to /etc/gshadow is configured	☐	☐
7.1.8	Ensure access to /etc/gshadow- is configured	☐	☐

Recommendation		Set Correctly	
		Yes	No
7.1.9	Ensure access to /etc/shells is configured	☐	☐
7.1.10	Ensure access to /etc/security/opasswd is configured	☐	☐
7.1.11	Ensure world writable files and directories are secured	☐	☐
7.1.12	Ensure no files or directories without an owner and a group exist	☐	☐
7.1.13	Ensure SUID and SGID files are reviewed	☐	☐
7.2.1	Ensure accounts in /etc/passwd use shadowed passwords	☐	☐
7.2.2	Ensure /etc/shadow password fields are not empty	☐	☐
7.2.3	Ensure all groups in /etc/passwd exist in /etc/group	☐	☐
7.2.8	Ensure local interactive user home directories are configured	☐	☐
7.2.9	Ensure local interactive user dot files access is configured	☐	☐

Appendix: CIS Controls v8 Unmapped Recommendations

Recommendation		Set Correctly	
		Yes	No
1.5.6	Ensure kernel.kptr_restrict is configured	☐	☐
2.4.1.7	Ensure access to /etc/cron.yearly is configured	☐	☐
5.3.1.1	Ensure latest version of pam is installed	☐	☐
5.3.1.2	Ensure latest version of authselect is installed	☐	☐
5.3.2.5	Ensure pam_unix module is enabled	☐	☐

Appendix: Change History

Date	Version	Changes for this version
ADDED ITEMS:		
8/27/2025	2.0.0	ADDED SECTION: 1.1 - Filesystem
8/27/2025	2.0.0	ADDED SECTION: 1.1.1 - Configure Filesystem Kernel Modules
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.1.1 - Ensure cramfs kernel module is not available
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.1.2 - Ensure freevxfs kernel module is not available
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.1.3 - Ensure hfs kernel module is not available
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.1.4 - Ensure hfsplus kernel module is not available
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.1.5 - Ensure jffs2 kernel module is not available
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.1.6 - Ensure overlay kernel module is not available
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.1.7 - Ensure squashfs kernel module is not available
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.1.8 - Ensure udf kernel module is not available
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.1.9 - Ensure firewire-core kernel module is not available
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.1.10 - Ensure usb-storage kernel module is not available
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.1.11 - Ensure unused filesystems kernel modules are not available
8/27/2025	2.0.0	ADDED SECTION: 1.1.2 - Configure Filesystem Partitions

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.2.1.1 - Ensure /tmp is tmpfs or a separate partition
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.2.2.1 - Ensure /dev/shm is tmpfs
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.2.4.2 - Ensure nodev option set on /var partition
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.2.6.2 - Ensure nodev option set on /var/log partition
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.2.6.3 - Ensure nosuid option set on /var/log partition
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.2.6.4 - Ensure noexec option set on /var/log partition
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.2.7.2 - Ensure nodev option set on /var/log/audit partition
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.2.7.3 - Ensure nosuid option set on /var/log/audit partition
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.1.2.7.4 - Ensure noexec option set on /var/log/audit partition
8/27/2025	2.0.0	ADDED SECTION: 1.2 - Package Management
8/27/2025	2.0.0	ADDED SECTION: 1.2.1 - Configure Package Repositories
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.2.1.2 - Ensure gpgcheck is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.2.1.3 - Ensure repo_gpgcheck is globally activated
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.2.1.5 - Ensure weak dependencies are configured
8/27/2025	2.0.0	ADDED SECTION: 1.2.2 - Configure Package Updates
8/27/2025	2.0.0	ADDED SECTION: 1.4 - Configure Bootloader

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.4.1 - Ensure access to bootloader config is configured
8/27/2025	2.0.0	ADDED SECTION: 1.5 - Configure Additional Process Hardening
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.5.1 - Ensure core file size is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.5.2 - Ensure fs.protected_hardlinks is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.5.3 - Ensure fs.protected_symlinks is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.5.4 - Ensure fs.suid_dumpable is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.5.5 - Ensure kernel.dmesg_restrict is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.5.6 - Ensure kernel.kptr_restrict is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.5.7 - Ensure kernel.randomize_va_space is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.5.8 - Ensure systemd-coredump ProcessSizeMax is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.5.9 - Ensure systemd-coredump Storage is configured
8/27/2025	2.0.0	ADDED SECTION: 1.6 - Configure system wide crypto policy
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.6.1 - Ensure system wide crypto policy is not set to legacy
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.6.2 - Ensure system wide crypto policy disables sha1 hash and signature support
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.6.3 - Ensure system wide crypto policy macs are configured

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.6.4 - Ensure system wide crypto policy disables cbc for ssh
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.6.5 - Ensure system wide crypto policy disables chacha20-poly1305 for ssh
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.6.6 - Ensure system wide crypto policy disables EtM for ssh
8/27/2025	2.0.0	ADDED SECTION: 1.7 - Configure Command Line Warning Banners
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.7.1 - Ensure /etc/motd is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.7.2 - Ensure /etc/issue is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.7.3 - Ensure /etc/issue.net is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.7.4 - Ensure access to /etc/motd is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.7.5 - Ensure access to /etc/issue is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.7.6 - Ensure access to /etc/issue.net is configured
8/27/2025	2.0.0	ADDED SECTION: 1.8 - Configure GNOME Display Manager
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.8.2 - Ensure GDM disable-user-list is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.8.3 - Ensure GDM screen lock is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.8.4 - Ensure GDM automount is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.8.5 - Ensure GDM autorun-never is configured

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED RECOMMENDATION: 1.8.7 - Ensure Xwayland is configured
8/27/2025	2.0.0	ADDED SECTION: 2.1 - Configure Server Services
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.1 - Ensure autofs services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.2 - Ensure avahi daemon services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.3 - Ensure cockpit web services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.4 - Ensure dhcp server services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.5 - Ensure dns server services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.6 - Ensure dnsmasq services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.7 - Ensure ftp server services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.8 - Ensure message access server services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.9 - Ensure network file system services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.10 - Ensure nis server services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.11 - Ensure print server services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.12 - Ensure rpcbind services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.13 - Ensure rsync services are not in use

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.14 - Ensure samba file server services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.15 - Ensure snmp services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.16 - Ensure telnet server services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.17 - Ensure tftp server services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.18 - Ensure web proxy server services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.19 - Ensure web server services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.20 - Ensure xinetd services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.21 - Ensure GNOME Display Manager is not installed
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.22 - Ensure X window server services are not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.23 - Ensure mail transfer agents are configured for local-only mode
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.1.24 - Ensure only approved services are listening on a network interface
8/27/2025	2.0.0	ADDED SECTION: 2.2 - Configure Client Services
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.2.1 - Ensure ftp client is not installed
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.2.2 - Ensure ldap client is not installed
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.2.3 - Ensure nis client is not installed

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.2.5 - Ensure tftp client is not installed
8/27/2025	2.0.0	ADDED SECTION: 2.3 - Configure Time Synchronization
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.3.3 - Ensure chrony is not run as the root user
8/27/2025	2.0.0	ADDED SECTION: 2.4 - Job Schedulers
8/27/2025	2.0.0	ADDED SECTION: 2.4.1 - Configure cron
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.4.1.1 - Ensure cron daemon is enabled and active
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.4.1.2 - Ensure access to /etc/crontab is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.4.1.3 - Ensure access to /etc/cron.hourly is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.4.1.4 - Ensure access to /etc/cron.daily is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.4.1.5 - Ensure access to /etc/cron.weekly is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.4.1.6 - Ensure access to /etc/cron.monthly is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.4.1.7 - Ensure access to /etc/cron.yearly is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.4.1.8 - Ensure access to /etc/cron.d is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.4.1.9 - Ensure access to crontab is configured
8/27/2025	2.0.0	ADDED SECTION: 2.4.2 - Configure at
8/27/2025	2.0.0	ADDED RECOMMENDATION: 2.4.2.1 - Ensure access to at is configured
8/27/2025	2.0.0	ADDED SECTION: 3 - Network

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED SECTION: 3.1 - Configure Network Devices
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.1.1 - Ensure IPv6 status is identified
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.1.2 - Ensure wireless interfaces are not available
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.1.3 - Ensure bluetooth services are not in use
8/27/2025	2.0.0	ADDED SECTION: 3.2 - Configure Network Kernel Modules
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.2.1 - Ensure atm kernel module is not available
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.2.2 - Ensure can kernel module is not available
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.2.3 - Ensure dccp kernel module is not available
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.2.4 - Ensure rds kernel module is not available
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.2.5 - Ensure sctp kernel module is not available
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.2.6 - Ensure tipc kernel module is not available
8/27/2025	2.0.0	ADDED SECTION: 3.3 - Configure Network Kernel Parameters
8/27/2025	2.0.0	ADDED SECTION: 3.3.1 - Configure IPv4 parameters
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.1 - Ensure net.ipv4.ip_forward is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.2 - Ensure net.ipv4.conf.all.forwarding is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.3 - Ensure net.ipv4.conf.default.forwarding is configured

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.4 - Ensure net.ipv4.conf.all.send_redirects is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.5 - Ensure net.ipv4.conf.default.send_redirects is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.6 - Ensure net.ipv4.icmp_ignore_bogus_error_responses is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.7 - Ensure net.ipv4.icmp_echo_ignore_broadcasts is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.8 - Ensure net.ipv4.conf.all.accept_redirects is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.9 - Ensure net.ipv4.conf.default.accept_redirects is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.10 - Ensure net.ipv4.conf.all.secure_redirects is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.11 - Ensure net.ipv4.conf.default.secure_redirects is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.12 - Ensure net.ipv4.conf.all.rp_filter is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.13 - Ensure net.ipv4.conf.default.rp_filter is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.14 - Ensure net.ipv4.conf.all.accept_source_route is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.15 - Ensure net.ipv4.conf.default.accept_source_route is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.16 - Ensure net.ipv4.conf.all.log_martians is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.17 - Ensure net.ipv4.conf.default.log_martians is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.1.18 - Ensure net.ipv4.tcp_syncookies is configured

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED SECTION: 3.3.2 - Configure IPv6 parameters
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.2.1 - Ensure net.ipv6.conf.all.forwarding is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.2.2 - Ensure net.ipv6.conf.default.forwarding is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.2.3 - Ensure net.ipv6.conf.all.accept_redirects is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.2.4 - Ensure net.ipv6.conf.default.accept_redirects is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.2.5 - Ensure net.ipv6.conf.all.accept_source_route is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.2.6 - Ensure net.ipv6.conf.default.accept_source_route is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.2.7 - Ensure net.ipv6.conf.all.accept_ra is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 3.3.2.8 - Ensure net.ipv6.conf.default.accept_ra is configured
8/27/2025	2.0.0	ADDED SECTION: 4 - Host Based Firewall
8/27/2025	2.0.0	ADDED RECOMMENDATION: 4.1.1 - Ensure firewalld is installed
8/27/2025	2.0.0	ADDED RECOMMENDATION: 4.1.2 - Ensure firewalld backend is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 4.1.3 - Ensure firewalld.service is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 4.1.4 - Ensure firewalld active zone target is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 4.1.5 - Ensure firewalld loopback traffic is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 4.1.6 - Ensure firewalld loopback source address traffic is configured

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED RECOMMENDATION: 4.1.7 - Ensure firewalld services and ports are configured
8/27/2025	2.0.0	ADDED SECTION: 5 - Access Control
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.1 - Ensure sshd crypto_policy is not set
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.2 - Ensure access to /etc/ssh/sshd_config is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.3 - Ensure access to /etc/sysconfig/sshd is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.4 - Ensure access to SSH private host key files is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.5 - Ensure access to SSH public host key files is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.6 - Ensure sshd access is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.7 - Ensure sshd Banner is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.8 - Ensure sshd Ciphers are configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.9 - Ensure sshd ClientAliveInterval and ClientAliveCountMax are configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.10 - Ensure sshd DisableForwarding is enabled
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.11 - Ensure sshd GSSAPIAuthentication is disabled
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.12 - Ensure sshd HostbasedAuthentication is disabled
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.13 - Ensure sshd IgnoreRhosts is enabled

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.14 - Ensure sshd KexAlgorithms is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.15 - Ensure sshd LoginGraceTime is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.16 - Ensure sshd LogLevel is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.17 - Ensure sshd MACs are configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.18 - Ensure sshd MaxAuthTries is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.19 - Ensure sshd MaxSessions is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.20 - Ensure sshd MaxStartups is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.21 - Ensure sshd PermitEmptyPasswords is disabled
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.22 - Ensure sshd PermitRootLogin is disabled
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.23 - Ensure sshd PermitUserEnvironment is disabled
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.1.24 - Ensure sshd UsePAM is enabled
8/27/2025	2.0.0	ADDED SECTION: 5.2 - Configure privilege escalation
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.2.6 - Ensure sudo timestamp_timeout is configured
8/27/2025	2.0.0	ADDED SECTION: 5.3 - Pluggable Authentication Modules
8/27/2025	2.0.0	ADDED SECTION: 5.3.1 - Configure PAM software packages
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.1.1 - Ensure latest version of pam is installed

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.1.2 - Ensure latest version of authselect is installed
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.2.1 - Ensure active authselect profile includes pam modules
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.2.2 - Ensure pam_faillock module is enabled
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.2.3 - Ensure pam_pwquality module is enabled
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.2.4 - Ensure pam_pwhistory module is enabled
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.2.5 - Ensure pam_unix module is enabled
8/27/2025	2.0.0	ADDED SECTION: 5.3.3 - Configure PAM Arguments
8/27/2025	2.0.0	ADDED SECTION: 5.3.3.1 - Configure pam_faillock module
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.1.1 - Ensure password failed attempts lockout is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.1.2 - Ensure password unlock time is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.1.3 - Ensure password failed attempts lockout includes root account
8/27/2025	2.0.0	ADDED SECTION: 5.3.3.2 - Configure pam_pwquality module
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.2.1 - Ensure password number of changed characters is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.2.2 - Ensure password length is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.2.3 - Ensure password complexity is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.2.4 - Ensure password same consecutive characters is configured

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.2.5 - Ensure password maximum sequential characters is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.2.6 - Ensure password dictionary check is enabled
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.2.7 - Ensure password quality is enforced for the root user
8/27/2025	2.0.0	ADDED SECTION: 5.3.3.3 - Configure pam_pwhistory module
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.3.1 - Ensure password history remember is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.3.2 - Ensure password history is enforced for the root user
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.3.3 - Ensure pam_pwhistory includes use_authtok
8/27/2025	2.0.0	ADDED SECTION: 5.3.3.4 - Configure pam_unix module
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.4.1 - Ensure pam_unix does not include nullok
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.4.2 - Ensure pam_unix does not include remember
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.4.3 - Ensure pam_unix includes a strong password hashing algorithm
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.3.3.4.4 - Ensure pam_unix includes use_authtok
8/27/2025	2.0.0	ADDED SECTION: 5.4.1 - Configure shadow password suite parameters
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.4.1.1 - Ensure password expiration is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.4.1.2 - Ensure minimum password days is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.4.1.3 - Ensure password expiration warning days is configured

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.4.1.4 - Ensure strong password hashing algorithm is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.4.1.5 - Ensure inactive password lock is configured
8/27/2025	2.0.0	ADDED SECTION: 5.4.2 - Configure root and system accounts and environment
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.4.2.2 - Ensure root is the only GID 0 account
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.4.2.3 - Ensure group root is the only GID 0 group
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.4.2.4 - Ensure root account access is controlled
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.4.2.5 - Ensure root path integrity
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.4.2.6 - Ensure root user umask is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.4.2.7 - Ensure system accounts do not have a valid login shell
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.4.2.8 - Ensure accounts without a valid login shell are locked
8/27/2025	2.0.0	ADDED SECTION: 5.4.3 - Configure user default environment
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.4.3.1 - Ensure nologin is not listed in /etc/shells
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.4.3.2 - Ensure default user shell timeout is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 5.4.3.3 - Ensure default user umask is configured
8/27/2025	2.0.0	ADDED SECTION: 6.1 - Configure Integrity Checking
8/27/2025	2.0.0	ADDED SECTION: 6.2 - System Logging

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED SECTION: 6.2.1.1 - Configure systemd-journald service
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.2.1.1.1 - Ensure journald service is active
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.2.1.1.2 - Ensure journald log file access is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.2.1.1.3 - Ensure journald log file rotation is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.2.1.1.4 - Ensure journald ForwardToSyslog is disabled
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.2.1.1.5 - Ensure journald Storage is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.2.1.1.6 - Ensure journald Compress is configured
8/27/2025	2.0.0	ADDED SECTION: 6.2.1.2 - Configure systemd-journal-remote
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.2.1.2.2 - Ensure systemd-journal-remote authentication is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.2.1.2.3 - Ensure systemd-journal-upload is enabled and active
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.2.1.2.4 - Ensure systemd-journal-remote service is not in use
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.2.2.2 - Ensure rsyslog service is enabled and active
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.2.2.4 - Ensure rsyslog log file creation mode is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.2.2.5 - Ensure rsyslog logging is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.2.2.7 - Ensure rsyslog is not configured to receive logs from a remote client
8/27/2025	2.0.0	ADDED SECTION: 6.2.3 - Configure Logfiles

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.2.3.1 - Ensure access to all logfiles has been configured
8/27/2025	2.0.0	ADDED SECTION: 6.3 - System Auditing
8/27/2025	2.0.0	ADDED SECTION: 6.3.1 - Configure auditd Service
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.1.1 - Ensure auditd packages are installed
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.1.3 - Ensure audit_backlog_limit is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.1.4 - Ensure auditd service is enabled and active
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.2.4 - Ensure system warns when audit logs are low on space
8/27/2025	2.0.0	ADDED SECTION: 6.3.3 - Configure auditd Rules
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.3.15 - Ensure successful and unsuccessful attempts to use the chcon command are collected
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.3.16 - Ensure successful and unsuccessful attempts to use the setfacl command are collected
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.3.17 - Ensure successful and unsuccessful attempts to use the chacl command are collected
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.3.18 - Ensure successful and unsuccessful attempts to use the usermod command are collected
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.3.20 - Ensure the audit configuration is loaded regardless of errors
8/27/2025	2.0.0	ADDED SECTION: 6.3.4 - Configure auditd File Access
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.4.1 - Ensure the audit log file directory mode is configured

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.4.2 - Ensure audit log files mode is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.4.3 - Ensure audit log files owner is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.4.4 - Ensure audit log files group owner is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.4.5 - Ensure audit configuration files mode is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.4.6 - Ensure audit configuration files owner is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.4.7 - Ensure audit configuration files group owner is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.4.8 - Ensure audit tools mode is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.4.9 - Ensure audit tools owner is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 6.3.4.10 - Ensure audit tools group owner is configured
8/27/2025	2.0.0	ADDED SECTION: 7.1 - Configure system file and directory access
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.1.1 - Ensure access to /etc/passwd is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.1.2 - Ensure access to /etc/passwd- is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.1.3 - Ensure access to /etc/group is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.1.4 - Ensure access to /etc/group- is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.1.5 - Ensure access to /etc/shadow is configured

Date	Version	Changes for this version
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.1.6 - Ensure access to /etc/shadow- is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.1.7 - Ensure access to /etc/gshadow is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.1.8 - Ensure access to /etc/gshadow- is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.1.9 - Ensure access to /etc/shells is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.1.10 - Ensure access to /etc/security/opasswd is configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.1.11 - Ensure world writable files and directories are secured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.1.12 - Ensure no files or directories without an owner and a group exist
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.1.13 - Ensure SUID and SGID files are reviewed
8/27/2025	2.0.0	ADDED SECTION: 7.2 - Local User and Group Settings
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.2.1 - Ensure accounts in /etc/passwd use shadowed passwords
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.2.2 - Ensure /etc/shadow password fields are not empty
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.2.8 - Ensure local interactive user home directories are configured
8/27/2025	2.0.0	ADDED RECOMMENDATION: 7.2.9 - Ensure local interactive user dot files access is configured
DROPPED ITEMS:		
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.10 - Ensure system-wide crypto policy is not legacy
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.11 - Ensure system-wide crypto policy is FUTURE or FIPS

Date	Version	Changes for this version
8/27/2025	2.0.0	DROPPED SECTION: 1.1 - Filesystem Configuration
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.1.9 - Disable Automounting
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.1.10 - Disable USB Storage
8/27/2025	2.0.0	DROPPED SECTION: 1.1.1 - Disable unused filesystems
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.1.1.1 - Ensure mounting of cramfs filesystems is disabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.1.1.2 - Ensure mounting of squashfs filesystems is disabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.1.1.3 - Ensure mounting of udf filesystems is disabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.1.2.1 - Ensure /tmp is a separate partition
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.1.3.2 - Ensure noexec option set on /var partition
8/27/2025	2.0.0	DROPPED SECTION: 1.2 - Command Line Warning Banners
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.2.1 - Ensure message of the day is configured properly
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.2.2 - Ensure local login warning banner is configured properly
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.2.3 - Ensure remote login warning banner is configured properly
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.2.4 - Ensure permissions on /etc/motd are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.2.5 - Ensure permissions on /etc/issue are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.2.6 - Ensure permissions on /etc/issue.net are configured

Date	Version	Changes for this version
8/27/2025	2.0.0	DROPPED SECTION: 1.3 - Configure Software Updates
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.3.2 - Ensure gpgcheck is globally activated
8/27/2025	2.0.0	DROPPED SECTION: 1.4 - Filesystem Integrity Checking
8/27/2025	2.0.0	DROPPED SECTION: 1.5 - Secure Boot Settings
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.5.1 - Ensure bootloader password is set
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.5.2 - Ensure permissions on bootloader config are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.5.3 - Ensure authentication required for single user mode
8/27/2025	2.0.0	DROPPED SECTION: 1.6 - Additional Process Hardening
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.6.1 - Ensure core dumps are restricted
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.6.2 - Ensure address space layout randomization (ASLR) is enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.7.1.2 - Ensure SELinux is not disabled in bootloader configuration
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.7.1.5 - Ensure the SELinux mode is enforcing
8/27/2025	2.0.0	DROPPED SECTION: 1.8 - GNOME Display Manager
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.8.1 - Ensure GNOME Display Manager is removed
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.8.3 - Ensure last logged in user display is disabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 1.8.5 - Ensure automatic mounting of removable media is disabled
8/27/2025	2.0.0	DROPPED SECTION: 2.1 - inetd Services

Date	Version	Changes for this version
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.1.1 - Ensure xinetd is not installed
8/27/2025	2.0.0	DROPPED SECTION: 2.2 - Special Purpose Services
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.2 - Ensure X Window System is not installed
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.3 - Ensure rsync service is not enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.4 - Ensure Avahi Server is not enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.5 - Ensure SNMP Server is not enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.6 - Ensure HTTP Proxy Server is not enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.7 - Ensure Samba is not enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.8 - Ensure IMAP and POP3 server is not enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.9 - Ensure HTTP server is not enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.10 - Ensure FTP Server is not enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.11 - Ensure DNS Server is not enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.12 - Ensure NFS is not enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.13 - Ensure RPC is not enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.14 - Ensure LDAP server is not enabled

Date	Version	Changes for this version
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.15 - Ensure DHCP Server is not enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.16 - Ensure CUPS is not enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.17 - Ensure NIS Server is not enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.2.18 - Ensure mail transfer agent is configured for local-only mode
8/27/2025	2.0.0	DROPPED SECTION: 2.2.1 - Time Synchronization
8/27/2025	2.0.0	DROPPED SECTION: 2.3 - Service Clients
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.3.1 - Ensure NIS Client is not installed
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 2.3.3 - Ensure LDAP client is not installed
8/27/2025	2.0.0	DROPPED SECTION: 3 - Network Configuration
8/27/2025	2.0.0	DROPPED SECTION: 3.1 - Disable unused network protocols and devices
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.1.1 - Verify if IPv6 is enabled on the system
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.1.2 - Ensure SCTP is disabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.1.3 - Ensure DCCP is disabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.1.4 - Ensure wireless interfaces are disabled
8/27/2025	2.0.0	DROPPED SECTION: 3.2 - Network Parameters (Host Only)
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.2.1 - Ensure IP forwarding is disabled

Date	Version	Changes for this version
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.2.2 - Ensure packet redirect sending is disabled
8/27/2025	2.0.0	DROPPED SECTION: 3.3 - Network Parameters (Host and Router)
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.3.1 - Ensure source routed packets are not accepted
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.3.2 - Ensure ICMP redirects are not accepted
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.3.3 - Ensure secure ICMP redirects are not accepted
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.3.4 - Ensure suspicious packets are logged
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.3.5 - Ensure broadcast ICMP requests are ignored
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.3.6 - Ensure bogus ICMP responses are ignored
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.3.7 - Ensure Reverse Path Filtering is enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.3.8 - Ensure TCP SYN Cookies is enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.3.9 - Ensure IPv6 router advertisements are not accepted
8/27/2025	2.0.0	DROPPED SECTION: 3.4 - Firewall Configuration
8/27/2025	2.0.0	DROPPED SECTION: 3.4.1 - Ensure Firewall software is installed
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.1.1 - Ensure a Firewall package is installed
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.2.1 - Ensure firewalld service is enabled and running

Date	Version	Changes for this version
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.2.2 - Ensure iptables is not enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.2.3 - Ensure nftables is not enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.2.4 - Ensure default zone is set
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.2.5 - Ensure network interfaces are assigned to appropriate zone
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.2.6 - Ensure unnecessary services and ports are not accepted
8/27/2025	2.0.0	DROPPED SECTION: 3.4.3 - Configure nftables
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.3.1 - Ensure iptables are flushed
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.3.2 - Ensure a table exists
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.3.3 - Ensure base chains exist
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.3.4 - Ensure loopback traffic is configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.3.5 - Ensure outbound and established connections are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.3.6 - Ensure default deny firewall policy
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.3.7 - Ensure nftables service is enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.3.8 - Ensure nftables rules are permanent
8/27/2025	2.0.0	DROPPED SECTION: 3.4.4 - Configure iptables
8/27/2025	2.0.0	DROPPED SECTION: 3.4.4.1 - Configure software

Date	Version	Changes for this version
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.4.1.1 - Ensure iptables packages are installed
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.4.1.2 - Ensure nftables is not installed
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.4.1.3 - Ensure firewalld is not installed or stopped and masked
8/27/2025	2.0.0	DROPPED SECTION: 3.4.4.2 - Configure IPv4 iptables
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.4.2.1 - Ensure default deny firewall policy
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.4.2.2 - Ensure loopback traffic is configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.4.2.3 - Ensure outbound and established connections are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.4.2.4 - Ensure firewall rules exist for all open ports
8/27/2025	2.0.0	DROPPED SECTION: 3.4.4.3 - Configure IPv6 ip6tables
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.4.3.1 - Ensure IPv6 default deny firewall policy
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.4.3.2 - Ensure IPv6 loopback traffic is configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.4.3.3 - Ensure IPv6 outbound and established connections are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 3.4.4.3.4 - Ensure IPv6 firewall rules exist for all open ports
8/27/2025	2.0.0	DROPPED SECTION: 4.1 - Configure System Accounting (auditd)
8/27/2025	2.0.0	DROPPED SECTION: 4.1.1 - Ensure auditing is enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.1.1 - Ensure auditd is installed

Date	Version	Changes for this version
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.1.2 - Ensure auditd service is enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.1.4 - Ensure audit_backlog_limit is sufficient
8/27/2025	2.0.0	DROPPED SECTION: 4.1.3 - Configure auditd rules
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.3.15 - Ensure successful and unsuccessful attempts to use the chcon command are recorded
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.3.16 - Ensure successful and unsuccessful attempts to use the chsh command are recorded
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.3.17 - Ensure successful and unsuccessful attempts to use the newgrp command are recorded
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.3.18 - Ensure successful and unsuccessful attempts to use the setfacl command are recorded
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.3.19 - Ensure successful and unsuccessful attempts to use the chacl command are recorded
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.3.20 - Ensure successful and unsuccessful attempts to use the kmod command are recorded
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.3.21 - Ensure successful and unsuccessful attempts to use the gpasswd command are recorded
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.3.22 - Ensure successful and unsuccessful attempts to use the chage command are recorded
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.3.23 - Ensure successful and unsuccessful attempts to use the usermod command are recorded

Date	Version	Changes for this version
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.3.24 - Ensure successful and unsuccessful attempts to use the pam_timestamp_check command are recorded
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.3.25 - Ensure successful and unsuccessful uses of the finit_module syscall are recorded
8/27/2025	2.0.0	DROPPED SECTION: 4.1.4 - Configure auditd file access
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.4.1 - Ensure audit log files are not read or write-accessible by unauthorized users
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.4.2 - Ensure only authorized users own audit log files
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.4.3 - Ensure only authorized groups ownership of audit log files
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.4.4 - Ensure the audit log directory is 0750 or more restrictive
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.4.5 - Ensure audit configuration files are 0640 or more restrictive
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.4.6 - Ensure only authorized accounts own the audit configuration files
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.4.7 - Ensure only authorized groups own the audit configuration files
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.4.8 - Ensure audit tools are mode of 0755 or more restrictive
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.4.9 - Ensure audit tools are owned by root
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.1.4.10 - Ensure audit tools are group-owned by root
8/27/2025	2.0.0	DROPPED SECTION: 4.2 - Configure Logging
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.2.3 - Ensure permissions on all logfiles are configured

Date	Version	Changes for this version
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.2.1.2 - Ensure rsyslog Service is enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.2.1.3 - Ensure rsyslog default file permissions configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.2.1.4 - Ensure logging is configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.2.1.6 - Ensure remote rsyslog messages are only accepted on designated log hosts.
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.2.2.2 - Ensure journald is configured to compress large log files
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.2.2.3 - Ensure journald is configured to write logfiles to persistent disk
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.2.2.4 - Ensure journald service is enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.2.2.6 - Ensure journald default file permissions configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.2.2.7 - Ensure journald is not configured to recieve logs from a remote client
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.2.2.8 - Ensure systemd-journal-remote is configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 4.2.2.9 - Ensure systemd-journal-remote is enabled
8/27/2025	2.0.0	DROPPED SECTION: 5 - Access, Authentication and Authorization
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.7 - Ensure root login is restricted to system console
8/27/2025	2.0.0	DROPPED SECTION: 5.1 - Configure time-based job schedulers
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.1.1 - Ensure cron daemon is enabled

Date	Version	Changes for this version
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.1.2 - Ensure permissions on /etc/crontab are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.1.3 - Ensure permissions on /etc/cron.hourly are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.1.4 - Ensure permissions on /etc/cron.daily are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.1.5 - Ensure permissions on /etc/cron.weekly are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.1.6 - Ensure permissions on /etc/cron.monthly are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.1.7 - Ensure permissions on /etc/cron.d are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.1.8 - Ensure at/cron is restricted to authorized users
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.1 - Ensure permissions on /etc/ssh/sshd_config are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.2 - Ensure SSH access is limited
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.3 - Ensure permissions on SSH private host key files are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.4 - Ensure permissions on SSH public host key files are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.5 - Ensure SSH LogLevel is appropriate
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.6 - Ensure SSH X11 forwarding is disabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.7 - Ensure SSH MaxAuthTries is set to 4 or less
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.8 - Ensure SSH IgnoreRhosts is enabled

Date	Version	Changes for this version
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.9 - Ensure SSH HostbasedAuthentication is disabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.10 - Ensure SSH root login is disabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.11 - Ensure SSH PermitEmptyPasswords is disabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.12 - Ensure SSH PermitUserEnvironment is disabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.13 - Ensure SSH Idle Timeout Interval is configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.14 - Ensure SSH LoginGraceTime is set to one minute or less
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.15 - Ensure SSH warning banner is configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.16 - Ensure SSH PAM is enabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.17 - Ensure SSH AllowTcpForwarding is disabled
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.18 - Ensure SSH MaxStartups is configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.19 - Ensure SSH MaxSessions is set to 10 or less
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.2.20 - Ensure system-wide crypto policy is not over-ridden
8/27/2025	2.0.0	DROPPED SECTION: 5.3 - Configure privilage escalation
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.3.6 - Ensure sudo authentication timeout is configured correctly
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.4.1 - Create custom authselect profile

Date	Version	Changes for this version
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.4.2 - Select authselect profile
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.4.3 - Ensure authselect includes with-faillock
8/27/2025	2.0.0	DROPPED SECTION: 5.5 - Configure PAM
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.5.1 - Ensure password creation requirements are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.5.2 - Ensure lockout for failed password attempts is configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.5.3 - Ensure password reuse is limited
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.5.4 - Ensure password hashing algorithm is SHA-512
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.6.2 - Ensure system accounts are secured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.6.3 - Ensure default user shell timeout is 900 seconds or less
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.6.4 - Ensure default group for the root account is GID 0
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.6.5 - Ensure default user umask is 027 or more restrictive
8/27/2025	2.0.0	DROPPED SECTION: 5.6.1 - Set Shadow Password Suite Parameters
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.6.1.1 - Ensure password expiration is 365 days or less
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.6.1.2 - Ensure minimum days between password changes is 7 or more
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.6.1.3 - Ensure password expiration warning days is 7 or more

Date	Version	Changes for this version
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 5.6.1.4 - Ensure inactive password lock is 30 days or less
8/27/2025	2.0.0	DROPPED SECTION: 6.1 - System File Permissions
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.1.1 - Audit system file permissions
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.1.2 - Ensure sticky bit is set on all world-writable directories
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.1.3 - Ensure permissions on /etc/passwd are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.1.4 - Ensure permissions on /etc/shadow are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.1.5 - Ensure permissions on /etc/group are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.1.6 - Ensure permissions on /etc/gshadow are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.1.7 - Ensure permissions on /etc/passwd- are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.1.8 - Ensure permissions on /etc/shadow- are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.1.9 - Ensure permissions on /etc/group- are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.1.10 - Ensure permissions on /etc/gshadow- are configured
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.1.11 - Ensure no world writable files exist
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.1.12 - Ensure no unowned files or directories exist
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.1.13 - Ensure no ungrouped files or directories exist

Date	Version	Changes for this version
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.1.14 - Audit SUID executables
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.1.15 - Audit SGID executables
8/27/2025	2.0.0	DROPPED SECTION: 6.2 - User and Group Settings
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.2.1 - Ensure password fields are not empty
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.2.2 - Ensure root PATH Integrity
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.2.4 - Ensure users home directories permissions are 750 or more restrictive
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.2.5 - Ensure users own their home directories
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.2.6 - Ensure users dot files are not group or world writable
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.2.7 - Ensure no users have .forward files
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.2.8 - Ensure no users have .netrc files
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.2.9 - Ensure users .netrc Files are not group or world accessible
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.2.10 - Ensure no users have .rhosts files
8/27/2025	2.0.0	DROPPED RECOMMENDATION: 6.2.16 - Ensure all users home directories exist
MOVED ITEMS:		
8/27/2025	2.0.0	MOVED SECTION: 1.1.2.1 - Configure /tmp moved from 1.1.2 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.1.2 - Ensure nodev option set on /tmp partition moved from 1.1.2.2 in 1.0.0

Date	Version	Changes for this version
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.1.3 - Ensure nosuid option set on /tmp partition moved from 1.1.2.4 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.1.4 - Ensure noexec option set on /tmp partition moved from 1.1.2.3 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 1.1.2.2 - Configure /dev/shm moved from 1.1.8 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.2.2 - Ensure nodev option set on /dev/shm partition moved from 1.1.8.1 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.2.3 - Ensure nosuid option set on /dev/shm partition moved from 1.1.8.3 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.2.4 - Ensure noexec option set on /dev/shm partition moved from 1.1.8.2 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 1.1.2.3 - Configure /home moved from 1.1.7 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.3.1 - Ensure separate partition exists for /home moved from 1.1.7.1 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.3.2 - Ensure nodev option set on /home partition moved from 1.1.7.2 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.3.3 - Ensure nosuid option set on /home partition moved from 1.1.7.3 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 1.1.2.4 - Configure /var moved from 1.1.3 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.4.1 - Ensure separate partition exists for /var moved from 1.1.3.1 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.4.3 - Ensure nosuid option set on /var partition moved from 1.1.3.3 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 1.1.2.5 - Configure /var/tmp moved from 1.1.4 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.5.1 - Ensure separate partition exists for /var/tmp moved from 1.1.4.1 in 1.0.0

Date	Version	Changes for this version
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.5.2 - Ensure nodev option set on /var/tmp partition moved from 1.1.4.4 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.5.3 - Ensure nosuid option set on /var/tmp partition moved from 1.1.4.3 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.5.4 - Ensure noexec option set on /var/tmp partition moved from 1.1.4.2 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 1.1.2.6 - Configure /var/log moved from 1.1.5 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.6.1 - Ensure separate partition exists for /var/log moved from 1.1.5.1 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 1.1.2.7 - Configure /var/log/audit moved from 1.1.6 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.1.2.7.1 - Ensure separate partition exists for /var/log/audit moved from 1.1.6.1 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.2.1.1 - Ensure GPG keys are configured moved from 1.3.1 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.2.1.4 - Ensure package manager repositories are configured moved from 1.3.3 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.2.2.1 - Ensure updates, patches, and additional security software are installed moved from 1.9 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 1.3 - Mandatory Access Control moved from 1.7 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 1.3.1 - Configure SELinux moved from 1.7.1 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.3.1.1 - Ensure SELinux is installed moved from 1.7.1.1 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.3.1.2 - Ensure SELinux policy is configured moved from 1.7.1.3 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.3.1.3 - Ensure the SELinux mode is not disabled moved from 1.7.1.4 in 1.0.0

Date	Version	Changes for this version
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.3.1.4 - Ensure no unconfined services exist moved from 1.7.1.6 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.3.1.5 - Ensure the MCS Translation Service (mcstrans) is not installed moved from 1.7.1.8 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.3.1.6 - Ensure SETroubleshoot is not installed moved from 1.7.1.7 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.8.1 - Ensure GDM login banner is configured moved from 1.8.2 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 1.8.6 - Ensure XDMCP is not enabled moved from 1.8.4 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 2.2.4 - Ensure telnet client is not installed moved from 2.3.2 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 2.3.1 - Ensure time synchronization is in use moved from 2.2.1.1 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 2.3.2 - Ensure chrony is configured moved from 2.2.1.2 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 4.1 - Configure firewalld moved from 3.4.2 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 5.1 - Configure SSH Server moved from 5.2 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 5.2.1 - Ensure sudo is installed moved from 5.3.1 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 5.2.2 - Ensure sudo commands use pty moved from 5.3.2 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 5.2.3 - Ensure sudo log file exists moved from 5.3.3 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 5.2.4 - Ensure users must provide password for escalation moved from 5.3.4 in 1.0.0

Date	Version	Changes for this version
8/27/2025	2.0.0	MOVED RECOMMENDATION: 5.2.5 - Ensure re-authentication for privilege escalation is not disabled globally moved from 5.3.5 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 5.2.7 - Ensure access to the su command is restricted moved from 5.8 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 5.3.2 - Configure authselect moved from 5.4 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 5.4 - User Accounts and Environment moved from 5.6 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 5.4.1.6 - Ensure all users last password change date is in the past moved from 5.6.1.5 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 5.4.2.1 - Ensure root is the only UID 0 account moved from 6.2.3 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 6 - Logging and Auditing moved from 4 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.1.1 - Ensure AIDE is installed moved from 1.4.1 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.1.2 - Ensure filesystem integrity is regularly checked moved from 1.4.2 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.1.3 - Ensure cryptographic mechanisms are used to protect the integrity of audit tools moved from 4.1.4.11 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 6.2.1 - Configure journald moved from 4.2.2 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.2.1.2.1 - Ensure systemd-journal-remote is installed moved from 4.2.2.5 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 6.2.2 - Configure rsyslog moved from 4.2.1 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.2.2.1 - Ensure rsyslog is installed moved from 4.2.1.1 in 1.0.0

Date	Version	Changes for this version
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.2.2.3 - Ensure journald is configured to send logs to rsyslog moved from 4.2.2.1 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.2.2.6 - Ensure rsyslog is configured to send logs to a remote log host moved from 4.2.1.5 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.2.2.8 - Ensure logrotate is configured moved from 4.3 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.1.2 - Ensure auditing for processes that start prior to auditd is enabled moved from 4.1.1.3 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 6.3.2 - Configure Data Retention moved from 4.1.2 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.2.1 - Ensure audit log storage size is configured moved from 4.1.2.1 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.2.2 - Ensure audit logs are not automatically deleted moved from 4.1.2.2 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.2.3 - Ensure system is disabled when audit logs are full moved from 4.1.2.3 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.1 - Ensure changes to system administration scope (sudoers) is collected moved from 4.1.3.1 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.2 - Ensure actions as another user are always logged moved from 4.1.3.2 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.3 - Ensure events that modify the sudo log file are collected moved from 4.1.3.3 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.4 - Ensure events that modify date and time information are collected moved from 4.1.3.4 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.5 - Ensure events that modify the system's network environment are collected moved from 4.1.3.5 in 1.0.0

Date	Version	Changes for this version
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.6 - Ensure use of privileged commands are collected moved from 4.1.3.6 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.7 - Ensure unsuccessful file access attempts are collected moved from 4.1.3.7 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.8 - Ensure events that modify user/group information are collected moved from 4.1.3.8 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.9 - Ensure discretionary access control permission modification events are collected moved from 4.1.3.9 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.10 - Ensure successful file system mounts are collected moved from 4.1.3.10 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.11 - Ensure session initiation information is collected moved from 4.1.3.11 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.12 - Ensure login and logout events are collected moved from 4.1.3.12 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.13 - Ensure file deletion events by users are collected moved from 4.1.3.13 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.14 - Ensure events that modify the system's Mandatory Access Controls are collected moved from 4.1.3.14 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.19 - Ensure kernel module loading unloading and modification is collected moved from 4.1.3.26 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.21 - Ensure the audit configuration is immutable moved from 4.1.3.28 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 6.3.3.22 - Ensure the running and on disk configuration is the same moved from 4.1.3.27 in 1.0.0
8/27/2025	2.0.0	MOVED SECTION: 7 - System Maintenance moved from 6 in 1.0.0

Date	Version	Changes for this version
8/27/2025	2.0.0	MOVED RECOMMENDATION: 7.2.3 - Ensure all groups in /etc/passwd exist in /etc/group moved from 6.2.11 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 7.2.4 - Ensure no duplicate UIDs exist moved from 6.2.12 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 7.2.5 - Ensure no duplicate GIDs exist moved from 6.2.13 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 7.2.6 - Ensure no duplicate user names exist moved from 6.2.14 in 1.0.0
8/27/2025	2.0.0	MOVED RECOMMENDATION: 7.2.7 - Ensure no duplicate group names exist moved from 6.2.15 in 1.0.0
UPDATED ITEMS:		
8/27/2025	2.0.0	UPDATED SECTION: 1.1.2.1 - Configure /tmp - Sections Modified: Description
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.1.2 - Ensure nodev option set on /tmp partition - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.1.3 - Ensure nosuid option set on /tmp partition - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.1.4 - Ensure noexec option set on /tmp partition - Sections Modified: Profile; Impact Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED SECTION: 1.1.2.2 - Configure /dev/shm - Sections Modified: Description
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.2.2 - Ensure nodev option set on /dev/shm partition - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.2.3 - Ensure nosuid option set on /dev/shm partition - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id

Date	Version	Changes for this version
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.2.4 - Ensure noexec option set on /dev/shm partition - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED SECTION: 1.1.2.3 - Configure /home - Sections Modified: Description
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.3.1 - Ensure separate partition exists for /home - Sections Modified: Profile; Rationale Statement; Impact Statement; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.3.2 - Ensure nodev option set on /home partition - Sections Modified: Profile; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.3.3 - Ensure nosuid option set on /home partition - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.4.1 - Ensure separate partition exists for /var - Sections Modified: Profile; Rationale Statement; Impact Statement; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.4.3 - Ensure nosuid option set on /var partition - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED SECTION: 1.1.2.5 - Configure /var/tmp - Sections Modified: Description
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.5.1 - Ensure separate partition exists for /var/tmp - Sections Modified: Profile; Description; Rationale Statement; Impact Statement; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.5.2 - Ensure nodev option set on /var/tmp partition - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.5.3 - Ensure nosuid option set on /var/tmp partition - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id

Date	Version	Changes for this version
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.5.4 - Ensure noexec option set on /var/tmp partition - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.6.1 - Ensure separate partition exists for /var/log - Sections Modified: Profile; Rationale Statement; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.1.2.7.1 - Ensure separate partition exists for /var/log/audit - Sections Modified: Profile; Rationale Statement; Impact Statement; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.2.1.1 - Ensure GPG keys are configured - Sections Modified: Profile; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.2.1.4 - Ensure package manager repositories are configured - Sections Modified: Profile; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.2.2.1 - Ensure updates, patches, and additional security software are installed - Sections Modified: Profile; Description; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED SECTION: 1.3.1 - Configure SELinux - Sections Modified: Description
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.3.1.1 - Ensure SELinux is installed - Sections Modified: Profile; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.3.1.2 - Ensure SELinux policy is configured - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.3.1.3 - Ensure the SELinux mode is not disabled - Sections Modified: Profile; Description; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.3.1.4 - Ensure no unconfined services exist - Sections Modified: Profile; Assessment Status; Impact Statement; Remediation Procedure; Audit Procedure; Workbench Id

Date	Version	Changes for this version
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.3.1.5 - Ensure the MCS Translation Service (mcstrans) is not installed - Sections Modified: Profile; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.3.1.6 - Ensure SETroubleshoot is not installed - Sections Modified: Profile; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.8.1 - Ensure GDM login banner is configured - Sections Modified: Profile; Description; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 1.8.6 - Ensure XDMCP is not enabled - Sections Modified: Profile; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED SECTION: 2 - Services - Sections Modified: Description
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 2.2.4 - Ensure telnet client is not installed - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 2.3.1 - Ensure time synchronization is in use - Sections Modified: Profile; Assessment Status; Description; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 2.3.2 - Ensure chrony is configured - Sections Modified: Profile; Description; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED SECTION: 4.1 - Configure firewalld - Sections Modified: Description
8/27/2025	2.0.0	UPDATED SECTION: 5.1 - Configure SSH Server - Sections Modified: Description
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 5.2.1 - Ensure sudo is installed - Sections Modified: Profile; Workbench Id

Date	Version	Changes for this version
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 5.2.2 - Ensure sudo commands use pty - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 5.2.3 - Ensure sudo log file exists - Sections Modified: Profile; Description; Rationale Statement; Impact Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 5.2.4 - Ensure users must provide password for escalation - Sections Modified: Profile; Rationale Statement; Impact Statement; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 5.2.5 - Ensure re-authentication for privilege escalation is not disabled globally - Sections Modified: Profile; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 5.2.7 - Ensure access to the su command is restricted - Sections Modified: Profile; Description; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED SECTION: 5.3.2 - Configure authselect - Sections Modified: Description
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 5.4.1.6 - Ensure all users last password change date is in the past - Sections Modified: Profile; Rationale Statement; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 5.4.2.1 - Ensure root is the only UID 0 account - Sections Modified: Profile; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.1.1 - Ensure AIDE is installed - Sections Modified: Profile; Description; Remediation Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.1.2 - Ensure filesystem integrity is regularly checked - Sections Modified: Profile; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id

Date	Version	Changes for this version
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.1.3 - Ensure cryptographic mechanisms are used to protect the integrity of audit tools - Sections Modified: Profile; Description; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.2.1.2.1 - Ensure systemd-journal-remote is installed - Sections Modified: Profile; Description; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED SECTION: 6.2.2 - Configure rsyslog - Sections Modified: Description
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.2.2.1 - Ensure rsyslog is installed - Sections Modified: Profile; Description; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.2.2.3 - Ensure journald is configured to send logs to rsyslog - Sections Modified: Profile; Description; Rationale Statement; Impact Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.2.2.6 - Ensure rsyslog is configured to send logs to a remote log host - Sections Modified: Profile; Assessment Status; Description; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.2.2.8 - Ensure logrotate is configured - Sections Modified: Profile; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.1.2 - Ensure auditing for processes that start prior to auditd is enabled - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.2.1 - Ensure audit log storage size is configured - Sections Modified: Profile; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.2.2 - Ensure audit logs are not automatically deleted - Sections Modified: Profile; Workbench Id

Date	Version	Changes for this version
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.2.3 - Ensure system is disabled when audit logs are full - Sections Modified: Profile; Description; Impact Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.1 - Ensure changes to system administration scope (sudoers) is collected - Sections Modified: Profile; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.2 - Ensure actions as another user are always logged - Sections Modified: Profile; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.3 - Ensure events that modify the sudo log file are collected - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.4 - Ensure events that modify date and time information are collected - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.5 - Ensure events that modify the system's network environment are collected - Sections Modified: Profile; Description; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.6 - Ensure use of privileged commands are collected - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.7 - Ensure unsuccessful file access attempts are collected - Sections Modified: Profile; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.8 - Ensure events that modify user/group information are collected - Sections Modified: Profile; Description; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id

Date	Version	Changes for this version
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.9 - Ensure discretionary access control permission modification events are collected - Sections Modified: Profile; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.10 - Ensure successful file system mounts are collected - Sections Modified: Profile; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.11 - Ensure session initiation information is collected - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.12 - Ensure login and logout events are collected - Sections Modified: Profile; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.13 - Ensure file deletion events by users are collected - Sections Modified: Profile; Description; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.14 - Ensure events that modify the system's Mandatory Access Controls are collected - Sections Modified: Profile; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.19 - Ensure kernel module loading unloading and modification is collected - Sections Modified: Profile; Rationale Statement; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.21 - Ensure the audit configuration is immutable - Sections Modified: Profile; Description; Remediation Procedure; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 6.3.3.22 - Ensure the running and on disk configuration is the same - Sections Modified: Profile; Description; Audit Procedure; Workbench Id

Date	Version	Changes for this version
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 7.2.3 - Ensure all groups in /etc/passwd exist in /etc/group - Sections Modified: Profile; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 7.2.4 - Ensure no duplicate UIDs exist - Sections Modified: Profile; Rationale Statement; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 7.2.5 - Ensure no duplicate GIDs exist - Sections Modified: Profile; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 7.2.6 - Ensure no duplicate user names exist - Sections Modified: Profile; Description; Audit Procedure; Workbench Id
8/27/2025	2.0.0	UPDATED RECOMMENDATION: 7.2.7 - Ensure no duplicate group names exist - Sections Modified: Profile; Audit Procedure; Workbench Id